CADRE DE RÉFÉRENCE D'ARCHITECTURE D'ENTREPRISE

Interopérabilité et orchestration en entreprise agentique

Architecture normative, standards d'interopérabilité, patrons d'orchestration, autonomie et supervision humaine, identité et sécurité, observabilité et FinOps, gouvernance et conformité pour concevoir, déployer et superviser des agents d'IA à l'échelle de l'organisation.

André-Guy Bruneau M.Sc. IT · Version 1.1 · 28 octobre 2026

Titre	Interopérabilité et Orchestration en Entreprise Agentique — cadre de référence d'architecture d'entreprise
Identifiant normatif	CRE-IA-2026-01
Version et date	1.1 — 28 octobre 2026
Statut	Version finale consolidée, soumise à l'approbation du comité d'architecture et des risques agentiques
Auteur	André-Guy Bruneau M.Sc. IT
Propriétaire	Architecture d'entreprise, au nom du comité d'architecture et des risques agentiques
Cycle de révision	Cadre : chaque semestre. Catalogue des protocoles et versions de référence : chaque trimestre. Révision extraordinaire après tout incident agentique grave ou changement réglementaire majeur.
Public	Direction TI, architectes d'entreprise et de solutions, équipes de plateforme et d'intégration, équipes produit, sécurité de l'information, gestion des risques et conformité, protection des renseignements personnels, affaires juridiques, FinOps, approvisionnement, audit interne, responsables métier
Classification	Usage interne
État des sources	Faits, versions et dates vérifiés aux 27 et 28 octobre 2026 contre des sources primaires ou, à défaut, secondaires reconnues (annexe F)
Actualisation	1er novembre 2026, annexe H (informative)

Historique des versions

Version	Date	Nature des changements
0.1	27 oct. 2026	Ébauche pour discussion : structure en treize sections, principes, architecture en couches, échelle d'autonomie, liste de contrôle et gabarit de fiche d'agent.
0.2	27 oct. 2026	Ébauche enrichie : règles d'usage de MCP et d'A2A, paliers de risque des outils, extensions CloudEvents, évaluation en trois étages, exemples de contrats.
Ébauche « production »	27 oct. 2026	Ébauche parallèle : architecture en plans, exigences identifiées, contrats normatifs, grille d'homologation.
Recherche documentaire	27 oct. 2026	Synthèse de l'état de l'art en 2026 appuyée sur 121 références.
1.0	28 oct. 2026	Version finale consolidée : fusion des quatre documents, validation de chacune des 121 références et vérification des affirmations contre des sources primaires, unification des échelles (niveaux N0 à N4, paliers P0 à P3), corrections factuelles et mise à jour aux versions courantes des standards, ajout des volets mémoire, défense contre l'injection, approvisionnement et conformité canadienne, 28 schémas explicatifs. Audit final du 28 octobre 2026 : réouverture et contrôle de chacune des 428 références alors citées dans le corps (les références [429] à [473] ajoutées lors de la consolidation ayant été vérifiées au 27 octobre 2026), revue de cohérence interne, factuelle et juridique de tous les chapitres, et intégration des corrections retenues (annexe F).
1.1	**28 oct. 2026**	**Feuille de route** : calage sur le calendrier 2027-2030; migration MCP avancée dans la phase Plateforme et datée au jalon 2; validation initiale des agents visés par E-23 avant le 1er mai 2027; jalon J2a de conformité au RIA avant le 2 décembre 2027; jalons J4 et J5 pour la phase Mise à l'échelle; N3 entre domaines conditionné au passage par la passerelle; cibles chiffrées des indicateurs fixées au jalon 3; marge pour les périodes de congés; deux risques ajoutés. Plafond d'autonomie par classe ramené à une seule source normative (EXIG-CON-02) et article 65.2 de la Loi sur l'accès ajouté aux critères de la classe élevée. Modifications corrélatives : sommaire, figure 1, sections 1.1, 3.1, 4.1 et 14.2, EXIG-AUT-02, annexe F.
1.1, mise à jour	1er nov. 2026	Actualisation (annexe H) : sources datées rouvertes sur leur source primaire, errata et incohérences prouvés (tableau 72) et propositions soumises au comité; l'architecture normative de la version 1.1 n'est pas modifiée.
1.1, mise à jour	3 nov. 2026	Revue contradictoire : correctifs de cohérence interne, de précision normative et de vérification bibliographique intégrés au corps, aux figures et aux annexes A à G; relevé à la section H.6.
1.1, mise à jour	10 nov. 2026	Correctifs ciblés de l'audit de novembre 2026, intégrés au corps, aux figures et aux annexes; relevé à la section H.6.

Méthode et avertissements

MÉTHODE D'ÉLABORATION ET DE VALIDATION

Cette version consolide quatre documents de travail. La vérification a porté sur trois populations de références, qui ne se recouvrent qu'en partie. Chacune des 121 références de la recherche documentaire a été ouverte lorsque la page était accessible (108 sur 121), qualifiée selon sa crédibilité et confrontée aux affirmations qui la citaient; onze vérifications thématiques ont ensuite confronté les affirmations des quatre documents aux textes primaires : spécifications (Model Context Protocol, Agent2Agent, OpenTelemetry, CloudEvents, RFC de l'Internet Engineering Task Force), lois et règlements (Loi 25, règlement européen sur l'IA), normes (National Institute of Standards and Technology, ISO/IEC) et publications officielles des éditeurs. L'audit final du 28 octobre 2026 a ensuite rouvert chacune des 428 références alors citées et examiné 1 409 affirmations. À l'issue de l'audit, l'annexe G comptait 473 entrées, dont 25 doublons signalés (448 sources distinctes) : les 428 références auditées et les références [429] à [473], ajoutées lors de la

consolidation et vérifiées le 27 octobre 2026; la version 1.1 y ajoute la référence [496] (annexe F.1). Le registre des affirmations examinées n'est pas joint au cadre : une vérification se retrace par la référence citée et par l'annexe F, non affirmation par affirmation. Seules des sources de catégorie A (primaires ou officielles) ou B (secondaires reconnues) appuient une exigence, une obligation légale ou un fait; un argument d'éditeur est rapporté comme tel. Le bilan détaillé et les principales corrections figurent à l'annexe F.

AVERTISSEMENTS

Les versions, dates et chiffres reflètent l'état des sources au 27 octobre 2026; vérifications des 27 et 28 octobre 2026 (section 1.7). L'actualisation du 1er novembre 2026 et la revue contradictoire du 3 novembre 2026 sont postérieures à cette date de référence; leurs errata et leurs correctifs, intégrés au corps, sont consignés à l'annexe H (sections H.4 et H.6). Les versions de référence des protocoles sont épinglées au catalogue des protocoles, révisé chaque trimestre (section 1.6). Les produits commerciaux sont cités à titre d'exemples non limitatifs. Les obligations légales résumées ici en expriment l'intention : leur application à un cas précis relève des affaires juridiques.

Table des matières

Historique des versions 2
Méthode et avertissements 2
Sommaire exécutif 8

Partie I — Fondements 11
1 Objet, portée et mode d'emploi 12
2 Contexte et enjeux 17
3 Concepts et définitions 23
4 Principes directeurs 28

Partie II — Architecture, interopérabilité et orchestration 34
5 Architecture de référence 35
6 Interopérabilité 50
7 Orchestration 97
8 Autonomie et supervision humaine 117

Partie III — Confiance et exploitation 136
9 Identité, sécurité et confiance zéro 137
10 Observabilité, évaluation et FinOps 170

Partie IV — Gouvernance, conformité et mise en œuvre 187
11 Gouvernance et cycle de vie 188
12 Risques, conformité et réglementation 203
13 Approvisionnement et clauses contractuelles 226
14 Modèle de maturité 235
15 Feuille de route et indicateurs 239

Annexes — Outils d'application 250
A Grille d'homologation 251
B Gabarit de fiche d'agent 256
C Exemples de contrats 260
D Registre des exigences 272
E Glossaire 279
F Validation des sources et des ébauches 293
G Références 305
H Actualisation de novembre 2026 332

Liste des tableaux

Tableau 1 — Portée du cadre . . . 12
Tableau 2 — Parcours de lecture par rôle . . . 13
Tableau 3 — Degrés d'obligation . . . 14
Tableau 4 — Identifiants des principes et préfixes des exigences . . . 15
Tableau 5 — Chronologie vérifiée de la consolidation des standards agentiques (novembre 2024 à octobre 2026) . . . 19
Tableau 6 — Huit enjeux, leurs symptômes et la réponse du cadre . . . 21
Tableau 7 — Définitions normatives du cadre . . . 23
Tableau 8 — Agents interactifs et agents ambiants : conséquences de conception . . . 27
Tableau 9 — Mise en œuvre des principes directeurs . . . 32
Tableau 10 — Tensions fréquentes entre principes et arbitrage retenu . . . 33
Tableau 11 — Apport des plans transversaux à chaque couche . . . 42
Tableau 12 — Correspondance des blocs de construction d'architecture (ABB) et des blocs de construction de solution (SBB) . . . 44
Tableau 13 — Types de mémoire des agents et contrôles applicables . . . 46
Tableau 14 — Niveaux d'interopérabilité et exigences minimales pour une intégration d'agent . . . 51
Tableau 15 — Catalogue des protocoles et standards (état au 27 octobre 2026) . . . 55
Tableau 16 — Matrice de sélection des protocoles . . . 58
Tableau 17 — Principaux changements de la révision MCP 2026-07-28 et effet pour l'entreprise . . . 63
Tableau 18 — Correspondance entre l'OWASP MCP Top 10 (bêta) et les exigences du cadre . . . 74
Tableau 19 — Champs de la carte d'agent A2A 1.0 et règles du cadre . . . 76
Tableau 20 — Attributs d'extension CloudEvents exigés par le cadre . . . 86
Tableau 21 — Garanties d'un bus Kafka et responsabilités de la conception . . . 89
Tableau 22 — Contenu minimal des contrats, par type d'interface . . . 91
Tableau 23 — Principaux composants d'AGNTCY et statut au catalogue (état au 27 octobre 2026) . . . 96
Tableau 24 — Huit patrons d'orchestration autorisés et variante encadrée . . . 100
Tableau 25 — Critères comparés des principaux patrons . . . 105
Tableau 26 — Anti-patrons d'orchestration proscrits . . . 115
Tableau 27 — Cadriciels, moteurs et plateformes d'orchestration (exemples non limitatifs, état au 27 octobre 2026) . . . 116
Tableau 28 — Niveaux d'autonomie : rôles, paliers permis et contrôles minimaux . . . 118
Tableau 29 — Correspondance entre l'échelle du cadre et les autres échelles d'autonomie . . . 122
Tableau 30 — Quatre critères pour fixer le niveau d'autonomie sous le plafond de la classe . . . 123
Tableau 31 — Paliers de risque des outils . . . 124
Tableau 32 — Trois patrons d'interaction avec un agent ambiant . . . 131
Tableau 33 — Composants logiques de la confiance zéro et leur réalisation pour les agents . . . 137
Tableau 34 — Risques de l'OWASP Non-Human Identities Top 10 (2025) et réponse du cadre . . . 141
Tableau 35 — Profil OAuth exigé pour les agents . . . 145
Tableau 36 — Mécanismes d'identité en normalisation : état au 27 octobre 2026, révisions postérieures signalées . . . 148
Tableau 37 — Référentiels de menaces retenus par le cadre . . . 153
Tableau 38 — Top 10 OWASP des applications agentiques et contrôles du cadre . . . 154
Tableau 39 — Patrons de conception résistants à l'injection et usage recommandé . . . 158
Tableau 40 — Technologies d'isolation du code généré . . . 160
Tableau 41 — Attributs de trace exigés et niveau dans la convention OpenTelemetry v1.41.0 . . . 172

Tableau 42 — Familles d'objectifs de niveau de service d'un agent (cibles proposées par le cadre) . . . 179
Tableau 43 — Rôles de la gouvernance agentique . . . 188
Tableau 44 — Matrice RACI du cycle de vie d'un agent . . . 190
Tableau 45 — Répartition des responsabilités dans le modèle en étoile . . . 193
Tableau 46 — Classes de risque des agents : critères, plafond d'autonomie et contrôles minimaux . . . 204
Tableau 47 — Articles de la Loi sur le privé qui touchent les agents . . . 206
Tableau 48 — Textes fédéraux et sectoriels canadiens : statut au 27 octobre 2026 et effet sur les agents . . . 212
Tableau 49 — Articles du règlement européen sur l'IA et réponse du cadre . . . 215
Tableau 50 — Matrice de correspondance : NIST AI RMF, ISO/IEC 42001, Loi 25, BSIF, RIA et artefacts du cadre . . . 219
Tableau 51 — Délais de notification applicables aux incidents agentiques . . . 223
Tableau 52 — Volets de l'évaluation d'impact unifiée . . . 225
Tableau 53 — Où se loge le verrouillage (état au 27 octobre 2026) . . . 227
Tableau 54 — Grille d'évaluation des fournisseurs de solutions agentiques . . . 234
Tableau 55 — Niveaux de maturité par dimension . . . 235
Tableau 56 — Preuves attendues par niveau de maturité . . . 237
Tableau 57 — Correspondance indicative entre niveaux de maturité, ISO/IEC 42001 et NIST AI RMF . . . 238
Tableau 58 — Phases de mise en œuvre, livrables et autonomie autorisée . . . 240
Tableau 59 — Calage indicatif, mois 0 au 1er décembre 2026 . . . 243
Tableau 60 — Plan des 90 premiers jours (phase Fondations) . . . 244
Tableau 61 — Indicateurs de mise en œuvre et cibles proposées . . . 246
Tableau 62 — Risques de mise en œuvre, signes avant-coureurs et parades . . . 249
Tableau 63 — Champs de la fiche d'agent et étape où ils deviennent exigibles . . . 257
Tableau 64 — Exemples de contrats, références et exigences illustrées . . . 261
Tableau 65 — Glossaire des termes et des sigles du cadre . . . 279
Tableau 66 — Catégories de crédibilité des sources . . . 293
Tableau 67 — Verdicts sur les 427 liens affirmation-source de la recherche documentaire . . . 294
Tableau 68 — Principales corrections factuelles . . . 295
Tableau 69 — Registre de validation des références de la recherche documentaire . . . 297
Tableau 70 — Dépendances datées du cadre, rouvertes le 1er novembre 2026 sur leur source primaire . . . 333
Tableau 71 — Reports de la Note AMF IA au cadre (annexe D de la note), en attente de décision du comité . . . 339
Tableau 72 — Errata, écarts de citation et écarts entre livrables de la version 1.1, établis le 1er novembre 2026 . . . 340

Liste des figures

Figure 1 — Le cadre en une page . . . 8
Figure 2 — Du maillage N × M aux contrats communs N + M . . . 20
Figure 3 — Architecture de référence : six couches et trois plans transversaux . . . 35
Figure 4 — Quatre types de mémoire et contrôles d'écriture . . . 46
Figure 5 — Quatre niveaux d'interopérabilité appliqués aux agents . . . 51
Figure 6 — Carte des interactions de l'agent et protocoles retenus . . . 53
Figure 7 — MCP 2026-07-28 derrière la passerelle d'agents . . . 62
Figure 8 — Cycle de vie d'une tâche A2A 1.0 . . . 79
Figure 9 — Délégation A2A avec appel MCP et approbation humaine . . . 83
Figure 10 — Chorégraphie événementielle et compteur de sauts . . . 88

Figure 11 — Huit patrons d'orchestration autorisés 99
Figure 12 — Arbre de décision du patron d'orchestration 104
Figure 13 — Saga : transactions locales, pivot et compensations 108
Figure 14 — Échelle d'autonomie N0 à N4 118
Figure 15 — Contrôle exigé selon la classe de l'agent et le palier de l'outil 126
Figure 16 — Approbation humaine signée, liée à l'action exacte 128
Figure 17 — Délégation par échange de jetons et droits effectifs 142
Figure 18 — Contrôles appliqués par la passerelle d'agents à chaque appel 149
Figure 19 — Défense contre l'injection : éviter la triade létale 156
Figure 20 — Niveaux d'isolation pour le code généré 160
Figure 21 — Une trace distribuée de bout en bout 172
Figure 22 — Évaluation en trois paliers 178
Figure 23 — Enveloppe budgétaire d'une tâche 183
Figure 24 — Modèle opérationnel en étoile 193
Figure 25 — Cycle de vie d'un agent et jalons. 197
Figure 26 — Réponse à un incident agentique 222
Figure 27 — Modèle de maturité en cinq niveaux 235
Figure 28 — Feuille de route : quatre phases et leurs jalons 240

Sommaire exécutif

Les agents d'IA ne se contentent plus de répondre : ils lisent des systèmes, prennent des décisions et agissent. Ce cadre fixe les règles communes qui permettent de les brancher aux systèmes de l'entreprise, de les faire collaborer et de les orchestrer de façon sûre, traçable, réversible et économiquement maîtrisée, quel que soit le fournisseur. Il est normatif : les chapitres 5 à 13 énoncent des exigences identifiées, vérifiables en revue d'architecture ou en test ou, à défaut, par une justification consignée (section 1.4).

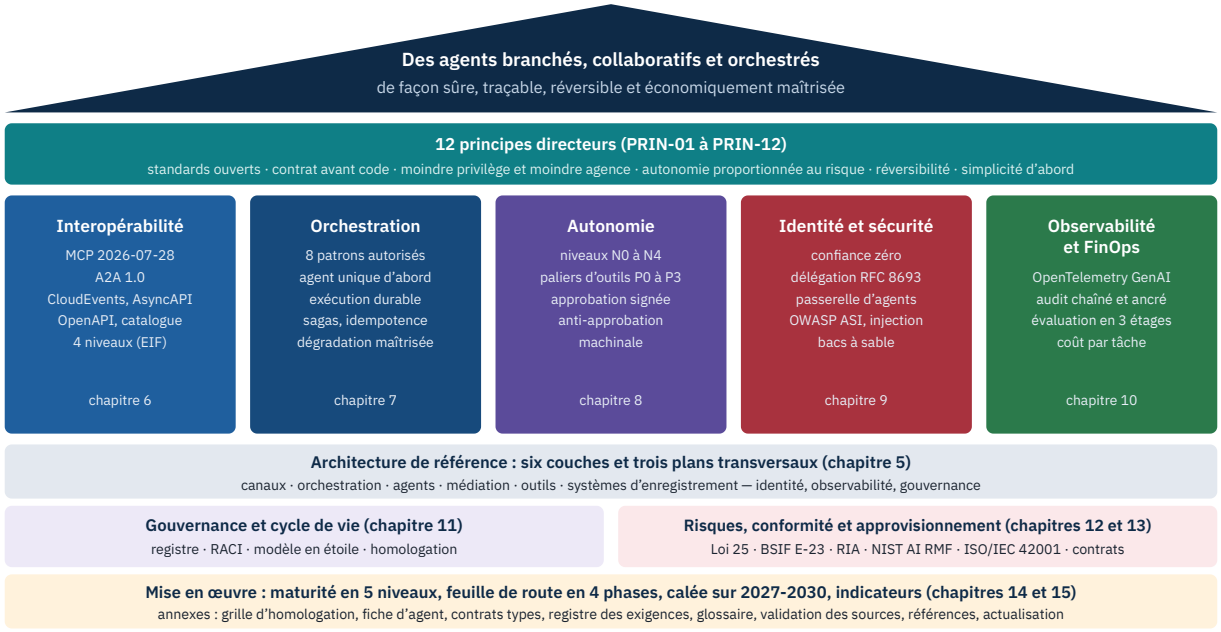


Figure 1 — Le cadre en une page. Le toit énonce la finalité; les principes s'appliquent à toutes les décisions; les cinq piliers portent les règles techniques; l'architecture de référence, la gouvernance et la conformité en sont les fondations; la feuille de route en organise le déploiement.

Pourquoi maintenant

40 % des applications d'entreprise intégreront des agents spécialisés d'ici la fin de 2026, contre moins de 5 % en 2025 (prévision Gartner, août 2025)[1]

> **40 %** des projets d'IA agentique seront annulés d'ici la fin de 2027 : coûts, valeur incertaine, contrôles inadéquats (prévision Gartner, juin 2025)[3]

13 % des organisations estiment avoir la bonne gouvernance de leurs agents (Gartner, avril 2026; population et méthode non publiées)[2]

> **150 000** agents en usage, en moyenne, par entreprise du Fortune 500 d'ici 2028, contre moins de 15 en 2025 (prévision Gartner, avril 2026, sans méthode publiée : ordre de grandeur prospectif)[2]

Les agents se multiplient plus vite que les règles pour les relier[1, 2]. Sans cadre commun, chaque équipe recrée ses connecteurs, ses accès et ses contrôles; les annulations annoncées par Gartner tiennent aux coûts, à une valeur d'affaires incertaine et à des contrôles de risque inadéquats, la maturité encore limitée des modèles s'y ajoutant[3]. Les standards, eux, se sont consolidés aux couches agent-outil et agent-agent. Le Model Context Protocol (MCP) et le protocole Agent2Agent (A2A) relèvent désormais tous deux de l'Agentic AI Foundation, fondation neutre de la Linux Foundation[4, 5]. Selon l'analyse du cadre (section 2.4), le risque de verrouillage s'est déplacé des protocoles vers les plateformes : c'est là que le cadre concentre ses exigences.

Les dix décisions structurantes

Dix décisions résument le cadre; chacune renvoie au chapitre qui la détaille.

1. **Deux protocoles pivots, versions épinglées.** MCP (révision 2026-07-28) relie un agent à ses outils et à ses données; A2A (version 1.0) relie un agent à un autre agent; CloudEvents et AsyncAPI portent les échanges asynchrones. Les API existantes sont exposées par adaptateurs, sans réécriture de leur logique métier; l'ajout minimal qui rend une écriture idempotente reste permis (EXIG-ARC-14). Les versions de référence sont épinglées au catalogue des protocoles, révisé chaque trimestre; celles que cite le texte en sont les valeurs initiales (section 1.6, chapitre 6).
2. **Rien ne contourne les points d'application.** Hors d'un poste de développement individuel sans justificatif de production, tout appel d'un agent vers un serveur MCP ou vers un pair A2A, quel que soit le domaine, et toute action de palier P2 ou P3 traversent la passerelle d'agents, qui authentifie, autorise, applique les garde-fous, limite les coûts, injecte les secrets et journalise; l'inférence passe par la passerelle de modèles et les événements par le courtier (EXIG-EVT-07). Un outil absent du catalogue d'entreprise est injoignable. C'est l'état cible : les agents déjà en service à l'adoption y sont ramenés selon le régime transitoire de la section 11.6 (EXIG-GOV-16 et EXIG-GOV-17).
3. **La simplicité d'abord.** Un flux déterministe, assisté au besoin par un modèle, est le choix par défaut; l'agent unique bien outillé vient ensuite, et l'on n'ajoute de la complexité que si elle améliore les résultats de façon démontrée[6]; le cadre en tire ses propres règles : le multiagent n'est autorisé que sur preuve mesurée de gain, parmi huit patrons autorisés et avec deux niveaux de délégation au plus (chapitre 7).
4. **Une échelle d'autonomie unique.** Le niveau d'autonomie (N1 à N4; N0 qualifie un flux sans choix laissé au modèle) borne ce qu'un agent peut faire seul, et la classe de risque plafonne ce niveau (EXIG-CON-02); l'autonomie non bornée (NX) est interdite. Les outils sont classés P0 à P3 au catalogue; le contrôle appliqué à un appel réunit tous ceux qu'exigent ces axes (EXIG-AUT-10), et toute action critique, externe ou irréversible (P3) exige une approbation humaine hors bande, signée et liée à l'action exacte (chapitre 8).
5. **Une identité propre à chaque agent, des droits délégués et de courte durée.** Aucun compte partagé ni clé statique (état cible; agents existants : régime transitoire de la section 11.6); quand un agent agit pour une personne, il reçoit un jeton délégué (échange de jetons, RFC 8693) qui identifie à la fois la personne et l'agent, restreint à une seule ressource cible (audience unique), et dont la portée ne s'élargit jamais d'un saut à l'autre (chapitre 9).
6. **Présomption d'injection.** Tout contenu reçu est une donnée, jamais une instruction. Dès qu'une session (la tâche racine et tout ce qui en dérive, section 3.1) a consommé un contenu non fiable, la passerelle lui retire de façon déterministe, pour le reste de la session, les outils d'envoi vers l'extérieur et les outils P3, sauf approbation liée à l'action; le marquage suit la donnée d'un agent à l'autre (EXIG-SEC-04, EXIG-SEC-06); le code qu'il génère s'exécute dans un bac à sable isolé, réseau fermé par défaut (chapitre 9).
7. **Réversibilité par conception.** L'état est enregistré de façon durable hors du modèle à chaque transition; chaque écriture porte une clé d'idempotence; les transactions qui touchent plusieurs systèmes suivent le patron saga avec compensations; un coupe-circuit global est éprouvé à l'exercice trimestriel de l'EXIG-SEC-26, et une saga interrompue reste compensable par un canal distinct (EXIG-ORC-28) (chapitres 7 et 9).
8. **On ne gouverne que ce qu'on voit.** Traçage OpenTelemetry de bout en bout (conventions GenAI épinglées), journal d'audit chaîné et ancré hors du domaine d'administration du service d'audit,

évaluation en trois étages (E1 à E3), enveloppe budgétaire par tâche et coût par tâche réussie (chapitre 10).

9. **Une personne nommée répond de chaque agent.** Registre d'entreprise obligatoire, cycle de vie à jalons, modèle opérationnel en étoile et comité d'architecture et des risques agentiques (chapitre 11).
10. **Conformité dès la conception.** Loi 25 (évaluation des facteurs relatifs à la vie privée, décisions automatisées, communications hors Québec, incidents), ligne directrice E-23 du Bureau du surintendant des institutions financières (BSIF, pour les institutions financières fédérales) et règlement européen sur l'IA (selon son champ d'application), ainsi que les référentiels volontaires NIST AI RMF et ISO/IEC 42001, sont intégrés aux exigences et à une matrice de correspondance unique (chapitre 12)[7, 8].

Par où commencer

La mise en œuvre suit quatre phases ouvertes par trois jalons de passage, plus trois jalons de suivi (J2a, J4 et J5), vise le niveau 3 de maturité, « Défini », en 18 mois environ (19 au calendrier du tableau 59, congés compris), puis le niveau 4 et la certification ISO/IEC 42001 aux jalons 4 et 5 (chapitre 14, chapitre 15). Les 90 premiers jours établissent les fondations : inventaire de tous les agents et serveurs MCP, parrain nommé pour chacun, fin des clés partagées, passerelle de modèles, traçage pilote, classement des risques et évaluations de vie privée, coupe-circuit testé. Aucun agent ne passe en production sans franchir la grille d'homologation de l'annexe A. La feuille de route ordonne la planification; l'exigibilité se règle agent par agent, selon les paliers, les niveaux et les topologies qu'il exerce (régime transitoire de la section 11.6).

CE QUI A CHANGÉ PAR RAPPORT AUX ÉBAUCHES

La vérification a confirmé le fond technique des ébauches, mais a imposé plusieurs corrections : versions de protocoles mises à jour (MCP sans état, A2A 1.0), trois échelles d'autonomie incompatibles remplacées par une seule, chiffres de marché réattribués à leur véritable source ou retirés, obligations de la Loi 25 rattachées aux bons articles, allégations commerciales retirées des exigences. L'annexe F en donne le détail.

Partie I — Fondements

Pourquoi un cadre commun, ce qu'il couvre, le vocabulaire partagé et les principes qui tranchent les décisions d'architecture.

1 · Objet, portée et mode d'emploi

2 · Contexte et enjeux

3 · Concepts et définitions

4 · Principes directeurs

1 Objet, portée et mode d'emploi

Ce chapitre dit ce que le cadre règle, à quels systèmes il s'applique et à qui il s'adresse. Il explique comment lire une exigence, comment le document est organisé et comment il évolue. Il présente enfin la méthode qui a servi à l'établir et à vérifier ses faits.

1.1 Objet

Le cadre CRE-IA-2026-01 fixe les règles communes qui permettent aux agents d'IA de l'entreprise de se brancher aux systèmes, de collaborer entre eux et d'être orchestrés de façon sûre, traçable, réversible et économiquement maîtrisée, quel que soit le fournisseur. La présente version 1.1, datée du 28 octobre 2026, est soumise à l'approbation du comité d'architecture et des risques agentiques. Le cadre poursuit quatre objectifs :

- donner à toutes les équipes un vocabulaire commun (chapitre 3);
- fixer les protocoles retenus, les patrons d'orchestration autorisés et les niveaux d'autonomie permis (chapitres 5 à 8);
- encadrer l'identité, la sécurité, l'observabilité, les coûts, la gouvernance et la conformité des agents (chapitres 9 à 13);
- offrir une trajectoire de maturité mesurable et une grille d'homologation applicable à chaque projet (chapitres 14 et 15, annexe A).

Le cadre est normatif et neutre à l'égard des fournisseurs. Il règle ce qui doit rester sous le contrôle de l'entreprise, quelle que soit la plateforme : contrats d'interface, identités et délégations, passage obligé par la passerelle d'agents, traces et journal d'audit, registre, plafonds d'autonomie et de coûts. Il ne choisit aucun produit : ceux qu'il cite sont des exemples non limitatifs, à l'état du 27 octobre 2026. Il ne tient pas lieu d'avis juridique (chapitre 12).

1.2 Portée

Cette section délimite les systèmes visés (tableau 1). Le critère est fonctionnel : ce qui compte n'est pas l'étiquette commerciale d'un système, mais sa capacité à appeler des outils ou à agir sur des systèmes et des données de l'entreprise.

Tableau 1 — Portée du cadre

Catégorie	Dans la portée	Hors portée
Agents internes	Tout agent bâti à l'interne, en pilote ou en production, qui lit ou modifie des systèmes ou des données de l'entreprise	Assistant conversationnel sans outil ni capacité d'action, régi par la politique d'usage de l'IA
Agents achetés	Agents intégrés aux logiciels-services (software as a service, SaaS) et aux progiciels, dès qu'ils peuvent agir sur des systèmes ou des données de l'entreprise, qu'ils aient été activés par l'éditeur, par une équipe ou par un employé (EXIG-ARC-21)	Fonction dite « agentique » qui n'appelle aucun outil et n'agit sur rien
Agents de tiers	Agents de partenaires, de fournisseurs ou de clients qui échangent avec les agents ou les systèmes de l'entreprise	Fonctionnement interne de ces agents : le cadre en régit les interfaces, les identités et les contrats
Outils et données	Serveurs MCP internes ou externes, outils, API, événements et sources de données exposés aux agents	Systèmes d'enregistrement eux-mêmes, dont le cadre n'impose pas la réécriture (un ajout minimal pour l'idempotence ou la trace reste permis, EXIG-ARC-14)

Catégorie	Dans la portée	Hors portée
Plateformes	Plateformes et moteurs d'orchestration, passerelles d'agents et de modèles, registres et catalogues	Choix des fournisseurs de modèles, qui relève de l'architecture d'entreprise et de l'approvisionnement
Modèles et automatisation	Usage des modèles par les agents; flux de travail assisté par IA (section 3.2); flux déterministe qui appelle un agent ou qui est appelé par lui, soumis aux contrôles de cet agent	Entraînement et ajustement fin des modèles; automatisation robotisée des processus (RPA) sans composante agentique

Trois règles tranchent les cas limites. Un assistant qui reçoit un premier outil, même en lecture seule, ou un premier accès à une ressource ou à des données de l'entreprise (un index documentaire, par exemple), entre dans la portée dès ce moment. À l'inverse, une fonction qu'un éditeur qualifie d'agentique n'y entre que si elle appelle des outils ou agit; l'étiquetage agentique abusif que relève Gartner est traité à la section 2.1[3]. En cas de doute, le système est traité comme visé et inscrit au registre (section 11.4).

1.3 Public cible et usages par rôle

Le cadre s'adresse à toutes les fonctions qui conçoivent, exploitent, financent ou contrôlent des agents. Personne n'a besoin de tout lire : le tableau 2 indique, pour chaque rôle, par où commencer.

Tableau 2 — Parcours de lecture par rôle

Rôle	À lire en priorité
Direction TI et comité d'architecture et des risques agentiques	Sommaire, chapitres 2, 4, 14 et 15
Architectes d'entreprise et de solutions	Chapitres 3 à 8, annexe A
Équipes de plateforme et d'intégration	Chapitres 5, 6, 9 et 10, annexe C
Équipes produit qui bâtissent des agents	Chapitres 3, 7, 8 et 10, annexes A à C
Sécurité de l'information	Chapitres 8 et 9, section 12.8
Risques, conformité, affaires juridiques et protection des renseignements personnels (RP)	Chapitres 11 et 12, section 8.8
FinOps	Sections 10.5 et 10.6, chapitre 13
Responsables métier, parrains d'agents	Sommaire, chapitres 3, 8 et 11, annexe B
Approvisionnement	Chapitre 13, section 6.3
Audit interne	Annexes A et D, sections 11.4 et 12.6

Appliquer le cadre à un projet

1. Vérifier la portée et inscrire le système au registre dès la conception (annexe B).
2. Classer le risque (section 12.1), fixer le niveau d'autonomie sous le plafond de la classe (EXIG-CON-02, section 12.1) et déterminer les évaluations d'impact requises (section 12.9).
3. Retenir l'option la plus simple qui suffit, puis le patron d'orchestration (section 7.3).
4. Choisir les protocoles (section 6.3) et publier les contrats au catalogue d'entreprise (section 6.8).
5. Appliquer les exigences pertinentes (annexe D); justifier par écrit tout écart à une recommandation (niveau DEVRAIT) et obtenir une dérogation pour tout écart à une obligation (niveau DOIT) (section 11.6).
6. Remplir la grille d'homologation (annexe A) avant toute mise en production.

1.4 Force normative

Cette section explique comment lire une exigence. Le cadre emploie trois degrés d'obligation (tableau 3), inspirés des mots-clés de la RFC 2119 de l'Internet Engineering Task Force (IETF) et mis en évidence dans le texte.

Tableau 3 — Degrés d'obligation

Expression	Sens	Écart admis
doit, ne doit pas	Obligation	Aucun, sauf dérogation écrite approuvée par le comité (ou, pour un agent de classe faible, par l'architecture d'entreprise sur délégation du comité, pour 90 jours au plus et par une autre personne que celle qui a instruit la demande), limitée dans le temps et assortie de mesures compensatoires (section 11.6, EXIG-GOV-15). Les points de l'EXIG-GOV-17, seule liste qui fasse foi, n'admettent aucune dérogation.
devrait, ne devrait pas	Recommandation	Admis s'il est justifié par écrit dans la fiche d'agent ou la décision d'architecture; la revue d'architecture contrôle la justification.
peut	Option	Sans objet.

Chaque exigence occupe un bloc qui réunit un identifiant stable (par exemple EXIG-AUT-09), son degré d'obligation, un titre court, un énoncé vérifiable en revue d'architecture ou en test (ou, à défaut, par une justification consignée), et une justification introduite par « Pourquoi ». Dans l'énoncé d'un bloc, toute phrase à l'indicatif qui prescrit un comportement a la force du degré d'obligation inscrit à l'en-tête du bloc, même sans mot-clé en gras; la justification et les exemples sont informatifs. Créent une obligation normative :

- les blocs d'exigences (chapitres 5 à 13) et les principes directeurs PRIN-01 à PRIN-12 (chapitre 4);
- les règles d'interprétation des sections 1.2 (critère de portée et règle du doute), 1.4 (force de l'indicatif dans un bloc), 1.5, 1.6, 4.2 (devoir de l'architecte) et 4.3;
- les définitions du tableau 7; pour les niveaux d'autonomie et les paliers d'outils, les tableaux 28 et 31 font foi, et la section 3.1 en donne un résumé;
- les tableaux et les structures d'annexe auxquels une exigence renvoie expressément : l'annexe A par l'EXIG-GOV-11, le contenu (non la forme) de l'annexe B par l'EXIG-GOV-07, C.1 et C.2 par l'EXIG-ORC-22 et l'EXIG-MCP-20, C.6 par l'EXIG-AUT-12, C.8 par l'EXIG-OBS-12;
- la liste des neuf contrôles de la passerelle d'agents (section 9.4, « Fonctions obligatoires »), à laquelle renvoie l'EXIG-IAM-17; la figure 18 l'illustre;
- la définition des trois indicateurs d'économie unitaire (section 10.6, « Imputation et économie unitaire »), à laquelle renvoie l'EXIG-FIN-10;
- le tableau 58, pour ses phases d'exigibilité (régime transitoire de la section 11.6) et pour les critères de ses jalons;
- les règles de progression et l'encadré « Jalon 2a » de la section 15.1, les règles de mesure des indicateurs de la section 15.3 et la règle de recul de maturité de la section 14.2, dont les « doit » et les « ne doit pas » ont la force du tableau 3, sans bloc d'exigence propre.

Le reste du texte, y compris l'annexe H, les exemples et les figures, est informatif. Est une mise en production tout usage d'un agent avec des justificatifs de production ou des données réelles, pilote compris (EXIG-GOV-08).

Exigence externe ou choix du cadre

Le cadre distingue toujours ce qui vient d'un texte externe de ce qu'il décide lui-même. « La spécification MCP exige » ou « selon l'article 14 du règlement (UE) 2024/1689 sur l'IA (RIA) » rapportent le contenu d'une norme ou d'une loi, vérifié à la source. « Le cadre fixe » ou « choix du cadre » signalent une décision interne, que le comité peut réviser. Exemple : le guide de Microsoft recommande un plafond d'itérations pour la boucle producteur-vérificateur (évaluateur-optimiseur au chapitre 7), sans en fixer la valeur[9]; le plafond de trois itérations retenu au chapitre 7 est donc un choix du cadre. Le cadre n'attribue jamais à une norme une exigence qu'elle ne contient pas et présente ses seuils chiffrés (délais, plafonds, fréquences) comme les siens.

À RETENIR

Trois règles de lecture : un fait externe porte sa source et sa date; un chiffre de fournisseur est présenté comme une allégation de ce fournisseur; un produit cité est un exemple, jamais une exigence.

1.5 Structure du document et identifiants

Le document compte quinze chapitres en quatre parties : Fondements (chapitres 1 à 4); Architecture, interopérabilité et orchestration (5 à 8); Confiance et exploitation (9 et 10); Gouvernance, conformité et mise en œuvre (11 à 15). Huit annexes, de A à H, fournissent les outils d'application, le glossaire et les références; l'annexe H, informative, consigne l'actualisation du 1er novembre 2026.

Les douze principes directeurs portent les identifiants PRIN-01 à PRIN-12. Chaque exigence porte un identifiant de la forme EXIG-XXX-NN : un préfixe de trois caractères propre à un domaine, puis un numéro à deux chiffres, continu pour chaque préfixe. Les chapitres 1 à 4, 14 et 15 et les annexes ne créent pas d'exigences numérotées; l'annexe D récapitule toutes les exigences dans l'ordre du document, soit 296 dans la version 1.2 (287 dans la version 1.1). Choix du cadre : un identifiant n'est jamais réattribué, et une exigence retirée lors d'une révision conserve son numéro, marqué « retirée »; une exigence devenue un renvoi garde son identifiant et son titre. Le tableau 4 donne la liste des préfixes.

Tableau 4 — Identifiants des principes et préfixes des exigences

Identifiant ou préfixe	Domaine	Emplacement
PRIN-01 à PRIN-12	Principes directeurs	Chapitre 4
EXIG-ARC	Architecture de référence	Chapitre 5
EXIG-INT	Interopérabilité, contrats et catalogue d'entreprise	Sections 6.1 à 6.4, 6.8 et 6.9
EXIG-MCP	Model Context Protocol	Section 6.5
EXIG-A2A	Protocole Agent2Agent	Section 6.6
EXIG-EVT	Interopérabilité événementielle	Section 6.7
EXIG-ORC	Orchestration	Chapitre 7
EXIG-AUT	Autonomie et supervision humaine	Chapitre 8
EXIG-IAM	Confiance zéro, identité, délégation et passerelle d'agents	Sections 9.1 à 9.4
EXIG-SEC	Menaces propres aux agents et défenses	Sections 9.5 à 9.9
EXIG-OBS	Traçage et journal d'audit	Sections 10.1 à 10.3
EXIG-EVA	Évaluation continue	Section 10.4
EXIG-FIN	Économie de l'inférence et maîtrise des coûts	Sections 10.5 et 10.6
EXIG-GOV	Gouvernance et cycle de vie	Chapitre 11
EXIG-CON	Risques, conformité et réglementation	Chapitre 12
EXIG-APP	Approvisionnement et clauses contractuelles	Chapitre 13

Un terme anglais figure entre parenthèses et en italique à sa première occurrence, comme transfert *(handoff)*; les noms de protocoles, de champs et de méthodes restent en police à chasse fixe, comme `tools/call`. Les appels de citation renvoient à l'annexe G.

1.6 Relation avec les autres politiques et cycle de révision

Le cadre complète, sans les remplacer, les politiques de sécurité de l'information, de gouvernance des données, de protection des RP, d'usage de l'IA, de gestion des risques et d'approvisionnement. Celles-ci continuent de régir leur objet; le cadre en précise l'application aux agents. Choix du cadre : lorsqu'une règle du cadre et celle d'une autre politique visent le même objet, les deux s'appliquent si elles sont cumulables;

sinon, l'ordre de départage de la section 4.3 tranche et la contradiction est soumise au comité. Le droit applicable prime toujours; les engagements contractuels en vigueur à l'adoption du cadre priment pour une transition bornée et inscrite au registre, sauf sur les points de l'EXIG-GOV-17 (section 4.3).

Deux rythmes de révision coexistent, semestriel pour le cadre et trimestriel pour le catalogue; les versions applicables suivent celui du catalogue.

- **Le cadre** est révisé chaque semestre par le comité, à partir des dérogations accordées, des incidents, des résultats d'homologation et de la veille; une révision extraordinaire suit tout incident grave (section 12.8) ou changement réglementaire majeur. Une règle qui suscite des dérogations répétées est à revoir.
- **Le catalogue des protocoles et standards** est révisé au moins chaque trimestre par l'architecture d'entreprise, qui soumet les changements de statut à l'approbation du comité (EXIG-GOV-18, sections 6.3 et 11.7); pour un standard au statut Adopter ou Contenir, la publication d'une version incompatible, d'une dépréciation, d'un retrait accéléré ou d'un correctif de sécurité déclenche une révision extraordinaire, dans les 15 jours ouvrables.
- **Les versions applicables**, comme MCP 2026-07-28 ou A2A 1.0, sont épinglées au catalogue des protocoles. Là où une exigence renvoie à « la version épinglée au catalogue », le catalogue fait foi, et la version citée dans le texte en est la valeur initiale; une échéance datée par une exigence (la migration MCP de l'EXIG-MCP-22, par exemple) reste dans le texte et ne change que par une révision du cadre.

Chaque révision porte un numéro de version et une date, et s'accompagne d'un relevé des modifications. La mise en conformité des agents déjà en service suit le régime transitoire de la section 11.6 (EXIG-GOV-16 et EXIG-GOV-17); les phases et les jalons du chapitre 15 en ordonnent la planification.

1.7 Méthode d'élaboration

La version 1.0 consolide quatre ébauches : une recherche documentaire appuyée sur 121 références, deux versions de travail successives du cadre et une version structurée en exigences. Elle suit la structure de la version de travail la plus récente, y intègre les exigences des autres ébauches et les réécrit pour qu'elles soient vérifiables. Chaque fait a ensuite été vérifié, aux 27 et 28 octobre 2026, contre des sources primaires ou, à défaut, secondaires reconnues, en trois passes :

1. la validation, une à une, des 121 références : chaque affirmation qui en citait une a été confrontée à la source (427 liens au total), au contenu réel de la page lorsqu'elle était accessible (108 références sur 121) et, sinon, à des sources équivalentes, faute de quoi elle a été déclarée invérifiable;
2. onze vérifications thématiques, de MCP au droit québécois, qui ont confronté les ébauches aux textes primaires et recueilli des faits complémentaires;
3. un audit final de cohérence interne, factuelle et juridique de l'ensemble des chapitres, le 28 octobre 2026, qui a rouvert les 428 références alors citées et examiné 1 409 affirmations; l'annexe G comptait alors 473 entrées, soit ces 428 références et les 45 références [429] à [473] ajoutées lors de la consolidation, dont 25 doublons signalés (448 sources distinctes; annexe F.1); la version 1.1 y ajoute la référence [496].

Les sources sont classées en trois catégories : A, primaires ou officielles; B, secondaires reconnues; C, blogues de positionnement ou agrégateurs. Une source de catégorie C n'appuie jamais une exigence, une obligation légale ni un fait; un argument d'éditeur peut seulement être rapporté comme tel. Un fait réfuté ou invérifiable a été corrigé, retiré ou, lorsqu'il exprimait une décision utile, conservé comme choix du cadre et signalé comme tel.

La vérification a deux limites. Elle reflète l'état des sources au 27 octobre 2026, vérifié les 27 et 28 octobre 2026, alors que plusieurs standards évoluent d'un trimestre à l'autre. Certains textes payants, comme les normes ISO/IEC, ont été vérifiés par leur fiche de catalogue et des sources secondaires concordantes; le cadre évite donc de les citer textuellement. L'annexe F détaille la méthode, le bilan et les corrections.

Deux reprises ont suivi ces vérifications. L'actualisation du 1er novembre 2026 a rouvert sur leur source primaire les sources datées dont dépend une exigence ou une échéance (annexe H, sections H.1 à H.5; seuls ses errata corrigent le corps). La revue contradictoire du 3 novembre 2026 a fait intégrer au corps des correctifs de cohérence interne, de précision normative et de vérification bibliographique (section H.6).

2 Contexte et enjeux

Les agents d'IA se multiplient plus vite que les règles qui les relient entre eux et aux systèmes de l'entreprise. Ce chapitre dresse l'état des lieux au 27 octobre 2026 à partir de données datées et attribuées, retrace la consolidation des standards ouverts depuis 2024 et nomme les huit enjeux qui motivent le cadre. Il explique enfin pourquoi agir maintenant : les protocoles se sont stabilisés, mais la gouvernance de chaque plateforme s'arrête à sa propre frontière.

2.1 Où en est l'entreprise agentique en 2026

Cette section situe le cadre dans les faits. L'entreprise agentique désigne ici une organisation où des agents exécutent une part croissante des processus, aux côtés des personnes et des systèmes existants, sous une supervision humaine proportionnée au risque. Les chiffres qui suivent donnent des ordres de grandeur; ils ne remplacent pas les mesures que chaque organisation tire de son propre registre.

40 %

des applications d'entreprise intégreront des agents spécialisés par tâche d'ici la fin de 2026, contre moins de 5 % en 2025 (prévision Gartner, août 2025)
[1]

> 40 %

des projets d'IA agentique seront annulés d'ici la fin de 2027 (prévision Gartner, juin 2025)
[3]

98 %

des répondants FinOps gèrent désormais des dépenses d'IA, contre 31 % en 2024 (State of FinOps 2026)
[10]

82 : 1

identités machines par identité humaine, selon une enquête de fournisseur (CyberArk, avril 2025)
[11]

Une adoption large, une industrialisation encore rare

Les prévisions des analystes décrivent une diffusion rapide. Gartner prévoit que 40 % des applications d'entreprise intégreront des agents spécialisés d'ici la fin de 2026 et que l'IA agentique pourrait représenter environ 30 % des revenus des logiciels d'application d'entreprise d'ici 2035[1]. Le même cabinet anticipe qu'en 2028, au moins 15 % des décisions de travail quotidiennes seront prises de façon autonome par l'IA agentique, contre 0 % en 2024[3].

Les enquêtes montrent toutefois un écart entre l'expérimentation et la production. Selon l'édition 2025 de l'enquête de McKinsey (novembre 2025; dernière édition dont les résultats détaillés sont publiés à cette adresse), 88 % des répondants disent que leur organisation utilise régulièrement l'IA dans au moins une fonction, mais seulement 39 % déclarent un effet sur le bénéfice avant intérêts et impôts (BAII) à l'échelle de l'entreprise. Si 62 % des organisations au moins expérimentent des agents, 23 % seulement disent déployer

à l'échelle un système agentique quelque part dans l'entreprise; dans une fonction d'affaires donnée, cette part ne dépasse pas 10 %[12].

Les plateformes et les protocoles, eux, sont déjà largement diffusés. En mai 2025, Microsoft indiquait que plus de 230 000 organisations, dont 90 % du Fortune 500, avaient déjà utilisé Copilot Studio; il s'agit d'un usage cumulatif, non d'un nombre de déploiements actifs[13]. En décembre 2025, selon le projet, le Model Context Protocol (MCP) comptait 10 000 serveurs actifs et plus de 97 millions de téléchargements mensuels de ses trousses de développement[14]. En avril 2026, selon la Linux Foundation, le protocole Agent2Agent (A2A) réunissait plus de 150 organisations et était intégré à Azure AI Foundry (nom qu'emploie la Linux Foundation; Microsoft désigne aujourd'hui ce service Microsoft Foundry), à Copilot Studio et à Amazon Bedrock AgentCore[15]. Côté dépenses, Menlo Ventures, investisseur du secteur, estime, selon un sondage auprès d'entreprises américaines, que les entreprises ont consacré 37 G$ US à l'IA générative en 2025, soit 3,2 fois plus que les 11,5 G$ US estimés pour 2024[16].

Des échecs annoncés et une pression sur les coûts

Gartner prévoit que plus de 40 % des projets d'IA agentique seront annulés d'ici la fin de 2027 en raison de coûts croissants, d'une valeur d'affaires incertaine ou de contrôles des risques inadéquats. Le cabinet dénonce aussi l'étiquetage agentique abusif *(agent washing)*, soit des produits existants rebaptisés « agentiques » : seuls quelque 130 des milliers de fournisseurs qui se disent agentiques le seraient réellement[3].

La gestion des dépenses d'IA entre déjà dans la pratique FinOps. Selon le rapport State of FinOps 2026 (1 192 répondants; l'échantillon change d'une édition à l'autre, si bien que la série n'est qu'indicative), 98 % des répondants FinOps gèrent des dépenses d'IA, contre 63 % en 2025 et 31 % en 2024, et la gestion des coûts de l'IA est la première compétence à développer[10]. La forme même du système pèse sur la facture : selon les mesures d'Anthropic sur son système de recherche multiagent, un agent consomme environ 4 fois plus de jetons qu'une conversation, et un système multiagent environ 15 fois plus[17]. Le choix du patron d'orchestration est donc aussi une décision économique (section 7.1 et section 10.5).

Une surface de risque qui s'élargit

Selon IBM et le Ponemon Institute (juillet 2025), parmi les organisations étudiées, qui ont toutes subi une violation, 13 % ont déclaré une violation touchant un modèle ou une application d'IA; parmi elles, 97 % n'avaient pas de contrôles d'accès propres à l'IA. Les organisations où l'IA fantôme *(shadow AI)* est répandue ont payé en moyenne 670 000 $ US de plus par violation, et une organisation étudiée sur cinq a subi une violation attribuable à cette IA non gouvernée[18]. L'édition 2026 établit le coût moyen mondial d'une violation à 4,99 M$ US (hausse de 12 %) et recommande, pour les agents, des contrôles d'accès dynamiques fondés sur l'identité et appliqués en continu à l'exécution[19].

Les identités non humaines dépassent déjà largement les identités humaines. Dans l'enquête 2025 de CyberArk (2 600 décideurs de 20 pays, dont le Canada; dernière édition dont ce ratio est publiquement vérifié), on compte 82 identités non humaines (« identités machines » selon CyberArk) par identité humaine; 68 % des répondants déclarent que leur organisation manque de contrôles de sécurité des identités pour l'IA[11]. Face à la prolifération des agents, Gartner (avril 2026) recommande six mesures, dont un inventaire centralisé qui inclut les agents fantômes, et observe que bloquer les agents pousse les employés vers l'IA fantôme[2].

ATTENTION

Les chiffres de Gartner sont des prévisions, et ses enquêtes ne publient ni leur population ni leur méthode; ceux de McKinsey et de la FinOps Foundation proviennent d'enquêtes; ceux d'IBM (étude menée par le Ponemon Institute pour IBM), de CyberArk, de Microsoft et d'Anthropic viennent de

fournisseurs qui ont un intérêt dans le sujet; l'estimation de Menlo Ventures vient d'un investisseur du secteur; ceux de MCP et d'A2A sont déclarés par les projets eux-mêmes. Le cadre n'en tire aucune exigence chiffrée. Il exige plutôt que chaque organisation mesure ses propres valeurs (agents inscrits, identités non humaines, coût par tâche réussie) à partir de son registre et de sa télémétrie (section 10.6, section 11.4 et chapitre 15).

2.2 La consolidation des standards ouverts

En deux ans, les échanges entre agents et outils, puis entre agents, sont passés de protocoles lancés par des éditeurs à des projets sous gouvernance neutre. Le tableau 5 retrace les jalons, vérifiés sauf mention contraire, qui fondent les choix du catalogue des protocoles (section 6.3).

Tableau 5 — Chronologie vérifiée de la consolidation des standards agentiques (novembre 2024 à octobre 2026)

Date	Jalon	Portée pour l'entreprise
25 nov. 2024	Anthropic annonce le Model Context Protocol (MCP), norme ouverte de raccordement des agents aux outils et aux données[20]	Naissance du standard vertical agent → outil
9 avr. 2025	Google annonce le protocole Agent2Agent (A2A) avec plus de 50 partenaires[21]	Premier protocole agent ⟶ agent largement appuyé
23 juin 2025	A2A est confié à la Linux Foundation; plus de 100 entreprises l'appuient[22]	Gouvernance neutre de l'axe horizontal
29 juill. 2025	La Linux Foundation accueille AGNTCY, lancé par Cisco en mars 2025 avec LangChain et Galileo[23]	Briques de découverte, d'identité et de messagerie, toujours hors de l'Agentic AI Foundation (AAIF) au 27 octobre 2026
Août 2025	L'Agent Communication Protocol (ACP) d'IBM fusionne dans A2A[24]	Un protocole concurrent de moins entre agents
8 sept. 2025	Lancement du registre officiel MCP en préversion[25]	Découverte publique; les serveurs privés restent à la charge de l'entreprise
Sept. 2025	Google publie l'Agent Payments Protocol (AP2, 16 septembre); OpenAI et Stripe publient l'Agentic Commerce Protocol (29 septembre)[26, 27]	Le commerce agentique démarre en ordre dispersé
9 déc. 2025	La Linux Foundation crée l'Agentic AI Foundation (AAIF), cofondée par Anthropic, Block et OpenAI; MCP, goose et AGENTS.md en sont les projets fondateurs[4]. Le même jour, l'Open Worldwide Application Security Project (OWASP) publie son Top 10 des applications agentiques[28]	MCP passe sous gouvernance neutre; un référentiel commun des menaces apparaît
12 mars 2026	Publication d'A2A 1.0.0, première version stable; correctif 1.0.1 le 28 mai 2026[29, 30]	Base contractuelle stable pour les cartes d'agent
4 juin 2026	agentgateway (créé par Solo.io, à la Linux Foundation depuis août 2025) devient un projet de l'AAIF[31, 32]	Passerelle ouverte pour MCP, A2A et les modèles
28 juill. 2026	Publication de la révision MCP 2026-07-28 : protocole sans état et cycle de vie formel des fonctionnalités[33, 34]	Exploitation à grande échelle; dépréciations à planifier
17 août 2026	A2A est annoncé comme projet de l'AAIF au stade « Growth »[5, 35]	MCP et A2A relèvent de la même fondation
9 sept. 2026	Envoy AI Gateway, renommé Agent Router, rejoint l'AAIF[36]	Autre option ouverte de passerelle de modèles et d'outils
12 oct. 2026	Cisco propose AGNTCY à l'AAIF (proposition n° 57, sans décision au 27 octobre 2026)[37]	AGNTCY reste un projet de la Linux Foundation, candidat à l'AAIF
22 oct. 2026	L'AAIF annonce quatre nouveaux projets et en héberge désormais dix[38]	Écosystème en expansion, à suivre chaque trimestre

Ce que la consolidation règle

Les deux axes principaux d'interaction relèvent désormais d'une même fondation neutre. Le guide officiel d'A2A les distingue clairement : MCP relie un agent à des outils et à des ressources dont les entrées et les sorties sont définies, souvent sans état; A2A relie des agents autonomes, potentiellement opaques, qui raisonnent et conservent un état au fil d'échanges à plusieurs tours[39]. Les règles d'évolution deviennent aussi prévisibles : depuis la révision 2026-07-28, une fonctionnalité MCP dépréciée reste dans la spécification au moins douze mois avant de pouvoir être retirée, sauf retrait accéléré pour un risque de sécurité actif (avis de sécurité publié ou exploitation documentée), avec un préavis d'au moins 90 jours[34]. Pour l'entreprise, le choix d'un protocole n'est plus un pari sur un seul éditeur; il reste une dépendance envers le calendrier de la fondation, que le catalogue des protocoles absorbe.

Ce qu'elle ne règle pas

La convergence reste partielle. AGNTCY n'est pas un projet de l'AAIF, et le commerce agentique demeure fragmenté entre l'Agentic Commerce Protocol d'OpenAI et de Stripe, AP2, dont le don à la FIDO Alliance a été annoncé le 28 avril 2026 (transfert effectif non établi à la fin d'octobre 2026), et l'Universal Commerce Protocol (UCP), porté par Google et des détaillants; l'AAIF a d'ailleurs ouvert un groupe de travail sur le commerce agentique[40, 41]. L'admission à l'AAIF suit un processus formel : un projet n'est officiel qu'une fois son admission approuvée et annoncée[42]. Enfin, le registre officiel MCP demeure en préversion, ne prend pas en charge les serveurs privés et recommande aux entreprises d'héberger leur propre registre MCP privé[43]. Le catalogue d'entreprise reste donc une responsabilité interne (section 6.8 et section 11.4); la veille sur les protocoles émergents est traitée à la section 6.9.

À RETENIR

Les protocoles disent comment les agents se parlent. Ils ne disent ni qui a le droit d'agir, ni ce qui doit être journalisé, ni combien une tâche peut coûter. Ces règles relèvent de l'entreprise : c'est l'objet du présent cadre.

2.3 Huit enjeux qui motivent le cadre

Sans règles communes, chaque équipe recrée ses connecteurs, ses accès et ses contrôles, et l'entreprise perd la vue d'ensemble. Le premier enjeu, la prolifération des intégrations, est le plus visible; la figure 2 l'illustre.

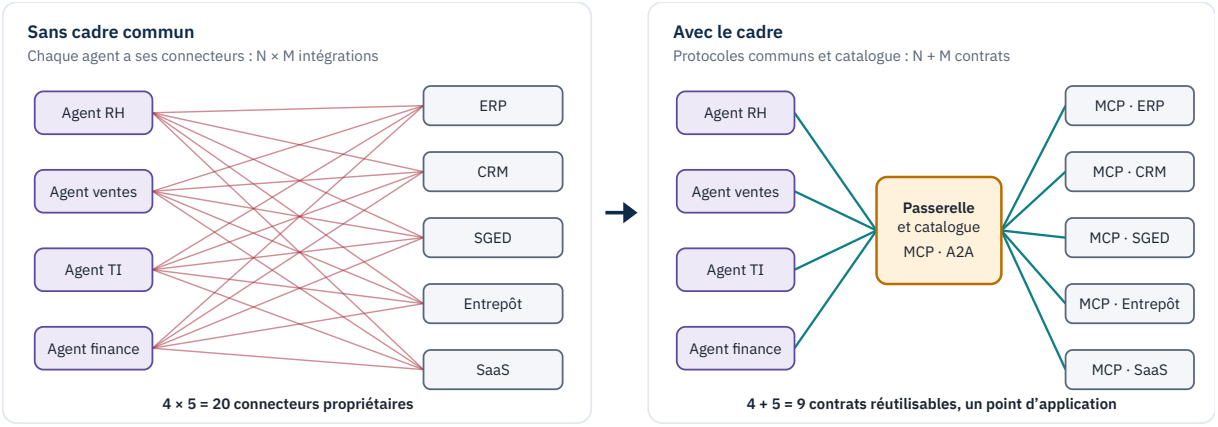


Figure 2 — Du maillage N × M aux contrats communs N + M. À gauche, chaque agent possède ses propres connecteurs vers chaque système : quatre agents et cinq systèmes exigent vingt intégrations, chacune avec sa sécurité. À droite, chaque agent et chaque système publient un seul contrat derrière la passerelle et le catalogue : neuf contrats réutilisables, soumis à un point d'application unique, les autorisations restant fixées par couple agent-outil. Source : élaboration du cadre CRE-IA-2026-01; exemple illustratif.

Anthropic présente MCP comme un protocole unique qui remplace des connecteurs sur mesure et fragmentés[20]; l'expression « N × M » est une vulgarisation de ce bénéfice, non un énoncé de la spécification. Le calcul illustre l'ordre de grandeur : 50 agents et 200 systèmes représentent au plus 10 000 intégrations point à point, maximum théorique que la pratique n'atteint pas, contre 250 contrats. Le gain n'existe toutefois que si le catalogue est unique; des catalogues multiples recréent le maillage N × M au niveau de la gouvernance. Le tableau 6 présente les huit enjeux et la réponse que le cadre leur apporte.

Tableau 6 — Huit enjeux, leurs symptômes et la réponse du cadre

Enjeu	Symptôme sans cadre	Réponse du cadre
1. Prolifération des intégrations	N agents × M systèmes = N × M connecteurs propriétaires à maintenir et à sécuriser	Protocoles communs et catalogue d'entreprise unique (PRIN-01, PRIN-02; section 6.3 et section 6.8)
2. Logique métier confiée au modèle	Routage, calculs et règles d'affaires laissés au raisonnement probabiliste : dérives, boucles, résultats non reproductibles	Flux déterministe autour du modèle et patron le plus simple qui suffit (PRIN-08; chapitre 7)
3. Silos d'agents	Les agents de plateformes différentes ne peuvent pas se déléguer de tâches; les mêmes capacités sont bâties plusieurs fois	Carte d'agent, protocole A2A et catalogue d'entreprise comme source de découverte (PRIN-01, PRIN-02; section 6.6 et section 6.8)
4. Accès excessifs et identités non humaines	Comptes de service partagés, clés d'API statiques, droits larges et permanents; impossible de savoir quel agent a agi	Identité propre à chaque agent, délégation par jeton, moindre privilège et moindre agence (PRIN-03; chapitre 9)
5. Décisions non traçables	Impossible d'expliquer une action ou de remonter la chaîne mandant → agent → outil	Traçage de bout en bout et journal d'audit chaîné et ancré (PRIN-06; section 10.1 et section 10.3)
6. Effets non maîtrisés et coûts	Boucles, actions irréversibles sans approbation, factures d'inférence imprévisibles	Niveaux d'autonomie N0 à N4, paliers d'outils P0 à P3, compensation et enveloppes budgétaires (PRIN-04, PRIN-05; chapitre 8 et section 10.6)
7. Agents fantômes	Agents créés hors inventaire, sans parrain nommé ni moyen de révocation	Registre obligatoire, aucun jeton de production sans fiche complète et à jour, cycle de vie contrôlé (PRIN-10; chapitre 11)
8. Obligations légales	Renseignements personnels (RP) traités sans évaluation; décisions automatisées non divulguées; incidents impossibles à reconstituer	Évaluation des facteurs relatifs à la vie privée (EFVP), transparence, droit à la révision et gestion des incidents (PRIN-06, PRIN-10; chapitre 12)

Ces enjeux se présentent rarement isolément. Prenons un agent créé dans un logiciel-service par une équipe métier, hors inventaire, qui utilise un compte de service partagé pour mettre à jour un système financier sans approbation humaine et sans laisser de trace exploitable. À lui seul, il réunit les enjeux 4, 5, 6 et 7. C'est pourquoi le cadre traite ensemble l'identité, la passerelle, le registre et le traçage, plutôt que comme des chantiers séparés.

2.4 Pourquoi un cadre commun maintenant

Trois évolutions convergent en 2026 et rendent un cadre commun à la fois possible et nécessaire.

La gouvernance native s'arrête à la frontière de chaque plateforme

Des éditeurs de passerelles soutiennent que la gouvernance native d'une plateforme ne se transfère pas aux autres : selon TrueFoundry, une règle de prévention des fuites de données d'un écosystème ne s'applique pas à l'agent d'un autre; selon MuleSoft, la gouvernance native d'un nuage devient insuffisante dès que plusieurs environnements d'exécution coexistent[44, 45]. Ces fournisseurs ont un intérêt commercial dans la thèse; il s'agit d'un argument d'architecture, non d'un constat mesuré. Les faits publiés vont néanmoins dans le même sens. Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, offre un registre et des contrôles comme le blocage des agents non gérés, mais sa synchronisation avec Amazon Bedrock et Google Cloud est en préversion et les actions de cycle de vie sur les agents infonuagiques de tiers sont seulement annoncées[46]. ServiceNow a annoncé le 5 mai 2026 l'extension de son AI Control Tower pour découvrir et gouverner l'IA déployée dans n'importe quel système[47]. Chaque éditeur propose son plan de

contrôle; une entreprise qui exploite plusieurs plateformes en aura plusieurs, et la couverture de l'ensemble de ses agents par un seul d'entre eux reste à démontrer.

Exemple concret : un agent de Copilot Studio délègue par A2A une vérification à un agent Agentforce, qui met à jour un dossier dans ServiceNow par MCP. Les trois plateformes prennent en charge ces protocoles (pour ServiceNow, un serveur MCP en disponibilité générale, ainsi que A2A et MCP par l'AI Agent Fabric) [48, 49, 50, 51], mais la demande traverse trois registres, trois moteurs de politiques et trois journaux. Le mandant, l'identifiant de trace et les plafonds de la tâche doivent pourtant la suivre de bout en bout. Gartner recommande en ce sens une structure unifiée et en couches de supervision et d'exécution des agents, pour étendre l'IA agentique en sécurité (résumé public du 3 août 2026; le détail des trois couches, réservé aux clients, n'est pas vérifié)[52]. Le cadre place ce point de contrôle neutre au point d'entrée des interfaces de l'entreprise : passerelle d'agents, identité et registre (chapitre 5 et section 9.4). Il ne tient que si les systèmes de l'entreprise ne sont joignables que par la passerelle; un agent qui s'exécute chez l'éditeur d'un logiciel-service relève des contrôles compensatoires de l'EXIG-ARC-21.

Le risque de verrouillage s'est déplacé des protocoles vers les plateformes

Avec MCP et A2A sous gouvernance neutre, le risque ne tient plus au choix du protocole, mais à ce que les plateformes conservent : extensions propriétaires, définitions d'orchestration, mémoires, identités et unités de facturation. Depuis juillet 2026, par exemple, Copilot Studio crée automatiquement une identité Microsoft Entra Agent ID pour chaque nouvel agent, sans possibilité de désactivation au niveau de l'environnement[48]. Chaque éditeur a aussi ses propres unités : les crédits Copilot, qui servent à facturer l'usage, chez Microsoft; chez Salesforce, les crédits Flex, qui servent à facturer l'usage, et les « Agentic Work Units », qui mesurent l'activité agentique livrée sans être une unité de facturation[53, 54, 55]. Le cadre exige donc que l'entreprise garde la propriété de sa logique d'orchestration, de ses contrats d'outils et de sa mémoire (PRIN-09), et qu'elle l'inscrive dans ses contrats d'approvisionnement (sections 13.1 et 13.3).

Les obligations se précisent

Le contexte réglementaire ne laisse plus de place à l'improvisation. La Loi 25 (L.Q. 2021, c. 25) est en vigueur pour l'essentiel depuis le 22 septembre 2023, et entièrement depuis le 22 septembre 2024, date de sa dernière étape, le droit à la portabilité. Depuis le 22 septembre 2023, elle exige notamment, dans les cas prévus, l'évaluation des facteurs relatifs à la vie privée (EFVP) et encadre les décisions fondées exclusivement sur un traitement automatisé[7, 56]. Le règlement (UE) 2024/1689 sur l'intelligence artificielle (RIA) s'applique de façon générale depuis le 2 août 2026 aux organisations qui relèvent de son champ d'application (art. 2), y compris hors de l'Union lorsque les sorties d'un système y sont utilisées, et, selon le calendrier que publie la Commission européenne, le règlement modificatif (UE) 2026/1744 porte au 2 décembre 2027 l'application aux systèmes à haut risque de l'annexe III, date à confirmer par la relecture de ce règlement au Journal officiel (annexe H)[57, 58]. Au fédéral, la ligne directrice E-23 du Bureau du surintendant des institutions financières (BSIF), en vigueur le 1er mai 2027 pour les institutions financières fédérales, attend un inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs[8]. Pour y répondre, une organisation a besoin d'un inventaire, d'une classification des risques et de traces conservées au moment des faits, faute de pouvoir les reconstituer après coup (chapitre 12).

À RETENIR

Le cadre ne choisit pas de plateforme. Il fixe ce qui reste sous le contrôle de l'entreprise, quelle que soit la plateforme : contrats, identités, passerelle, traces, registre et budgets. Ces règles s'imposent plus facilement à quelques dizaines d'agents qu'à des milliers : c'est maintenant qu'il faut les poser.

3 Concepts et définitions

« Agent », « orchestrateur » ou « autonomie » ne désignent pas la même chose d'une équipe ou d'un fournisseur à l'autre. Ce chapitre fixe le sens des termes employés dans tout le cadre, distingue les flux de travail des agents et les agents interactifs des agents ambiants, puis précise ce qu'un agent n'est pas. Le glossaire de l'annexe E complète ces définitions.

3.1 Définitions normatives

Les définitions du tableau 7 font foi dans tout le cadre et dans les documents qui s'y rattachent (section 1.4); pour les niveaux d'autonomie et les paliers d'outils, les tableaux 28 et 31 font foi, et les échelles ci-dessous en sont un résumé. Lorsqu'une norme ou une loi définit déjà un terme, le cadre reprend sa définition et la précise au besoin.

Tableau 7 — Définitions normatives du cadre

Terme	Définition	Référence
Agent	D'après ISO/IEC 22989 (paraphrase vérifiée par la fiche de catalogue et des sources secondaires, non au texte de la norme, section 1.7), entité automatisée qui perçoit son environnement, y réagit et agit pour atteindre ses buts. Pour le cadre, système logiciel qui poursuit un objectif en dirigeant lui-même sa boucle « raisonner, agir, observer » au moyen d'un modèle, d'outils et d'un état, sous un niveau d'autonomie déclaré.	ISO/IEC 22989:2022; oneM2M TR-0081, v0.2.0 (version préliminaire)[59, 60]; cadre
Système d'IA	Système automatisé conçu pour fonctionner à différents niveaux d'autonomie, qui peut faire preuve d'une capacité d'adaptation après son déploiement et qui, pour des objectifs explicites ou implicites, déduit, à partir des entrées qu'il reçoit, la manière de générer des sorties (prédictions, contenus, recommandations, décisions) pouvant influencer des environnements physiques ou virtuels. Le cadre considère tout agent comme un système d'IA.	Règlement (UE) 2024/1689 (RIA), art. 3(1)[61, 62]
Déployeur	Personne ou organisme qui utilise un système d'IA sous sa propre autorité. Si le RIA s'applique à elle (art. 2), l'entreprise l'est pour les agents qu'elle exploite, y compris ceux qu'elle achète (section 12.4).	RIA, art. 3(4)[61]
Outil	Capacité exposée à un agent (fonction, API, action), décrite par un contrat typé et classée P0 à P3 au catalogue. Un outil ne choisit pas lui-même, au moyen d'un modèle, les actions qu'il exécute, même s'il conserve l'état d'une tâche ou demande une précision (Tasks, élicitation MCP); une cible qui les choisit est un agent (section 6.2). Dans MCP, fonction exécutable que le modèle choisit d'appeler.	MCP[63]; cadre
Ressource	Donnée contextuelle identifiée par une URI, qu'un serveur met à la disposition d'un agent. Pour le cadre, sa lecture n'a aucun effet de bord; toute opération qui modifie un état est un outil.	MCP[63, 64]; cadre
Invite (prompt)	Instructions et contenu en langage naturel fournis à un modèle. Dans MCP, la primitive `Prompts` désigne des gabarits d'invite réutilisables qu'expose un serveur.	MCP[63]
Flux déterministe	Suite d'étapes dont le code fixe le chemin (graphe ou machine à états). Quand certaines étapes appellent un modèle, c'est un flux de travail assisté par IA : le chemin reste fixé par le code, et le flux est inscrit au registre avec le niveau qui correspond à ses écritures déclenchées par une sortie de modèle (section 3.2).	Anthropic (workflows)[65]
Orchestrateur, exécutant	L'orchestrateur décompose une demande, affecte les sous-tâches, suit l'état, gère la reprise et consolide les résultats; l'exécutant, agent ou outil, traite une sous-tâche bornée. Le cadre limite la délégation à deux niveaux (choix du cadre, EXIG-ORC-04, section 7.2).	Cadre; Anthropic[65]
Transfert (handoff)	Cession explicite du contrôle d'une session, avec le contexte utile et le mandant, d'un agent source à un agent cible mieux qualifié; l'agent source se retire.	OpenAI[66]

Terme	Définition	Référence
Chorégraphie	Coordination sans composant central : chaque agent réagit aux événements d'un bus et publie les siens, ce qui complique le suivi et expose aux cycles.	Microsoft[67]
Carte d'agent (Agent Card)	Document lisible par machine, défini par A2A, par lequel un agent décrit son identité, ses interfaces, ses compétences et ses exigences de sécurité; en A2A 1.0, il est publié à `/.well-known/agent-card.json`.	A2A 1.0[68]
Contrat d'agent	Engagement formel d'un agent : carte d'agent, entrées et sorties typées, niveau d'autonomie, limites, niveaux de service et voie d'escalade. Outils et événements ont leurs équivalents; tout contrat est versionné au catalogue d'entreprise.	Cadre (EXIG-INT-03, section 6.1; section 6.8)
Mandant	Personne ou application au nom de laquelle une tâche est exécutée ou, en l'absence de mandant humain, agent initiateur de la chaîne. Le mandant d'une chaîne de délégation est toujours l'entité d'origine; un agent intermédiaire n'y apparaît que comme acteur (`act`). Les droits du mandant bornent ceux de l'agent, et son identité accompagne chaque appel de bout en bout.	Cadre
Délégation	Attribution à un agent de droits bornés en portée et en durée pour agir au nom d'un mandant, l'agent restant identifiable. Le cadre interdit l'usurpation, où l'agent devient indiscernable du mandant. Par extension, envoi d'une tâche à un autre agent, avec des droits effectifs au plus égaux à l'intersection des droits du mandant, de la portée de l'agent au registre et de la portée nécessaire à la tâche, sans élargissement d'un saut à l'autre (EXIG-IAM-10).	RFC 8693, § 1.1[69]; cadre
Jeton délégué	Jeton d'accès de courte durée, obtenu par échange de jetons, qui identifie le mandant (`sub`) et l'agent acteur (`act`) et ne vaut que pour un seul service; sa portée ne s'élargit jamais d'un saut à l'autre.	RFC 8693, 8707 et 9068[70, 71, 72]; cadre (durée courte, audience unique, portée jamais élargie)
Passerelle d'agents	Point d'application des politiques placé devant les outils et les agents : authentification, autorisation, garde-fous, plafonds, injection des secrets et journalisation de chaque appel.	Cadre; NIST SP 800-207[73]
Passerelle de modèles	Passage obligatoire entre les agents et les fournisseurs de modèles : clés, routage, cache, repli, quotas, mesure des jetons et filtrage des données sortantes.	Cadre (section 5.2)
Catalogue d'entreprise	Source unique des contrats des interfaces joignables (outils, cartes d'agent, événements), avec version et empreinte approuvées, palier et propriétaire. À distinguer du catalogue des protocoles (section 6.3).	Cadre (section 6.8)
Registre	Inventaire faisant autorité des agents et des serveurs MCP : une fiche par élément, avec parrain nommé, finalité, classe de risque, niveau d'autonomie et état de cycle de vie.	Cadre (section 11.4); GOVERN 1.6[74]
Garde-fou	Contrôle automatisé qui filtre ou bloque une entrée, une sortie ou une action d'un agent. Un garde-fou probabiliste réduit un risque sans l'éliminer.	Microsoft[9]; cadre
Humain dans la boucle (HITL), sur la boucle (HOTL), hors de la boucle (human in the loop, human on the loop, human out of the loop)	HITL : une personne approuve chaque action en écriture avant son exécution. HOTL : elle supervise, traite les exceptions et peut interrompre, sans approbation préalable. Hors de la boucle : aucune intervention pendant l'exécution; restent la surveillance automatisée, l'audit et l'arrêt.	AWS; IMDA (Infocomm Media Development Authority, Singapour), section 1.1.3, pour la gradation de l'implication humaine, les sigles HITL et HOTL n'y figurant pas[75, 76]
Niveau d'autonomie	Plafond, déclaré au registre, de ce qu'un agent fait sans approbation humaine : N1 à N4, NX étant interdit; N0 qualifie un flux, non un agent (définitions ci-dessous).	Cadre (section 8.1)
Palier d'outil	Risque propre à un outil, de P0 à P3, attribué au catalogue après revue et jamais déduit des déclarations du serveur (définitions ci-dessous).	Cadre (section 8.3)
Compensation	Action métier qui neutralise l'effet d'une étape déjà exécutée quand un flux échoue, par exemple un remboursement. Elle ne rétablit pas forcément l'état initial et doit pouvoir être réessayée sans danger.	Microsoft[77]

Terme	Définition	Référence
Idempotence	Propriété d'une opération dont la répétition produit le même effet qu'une seule exécution. Une clé d'idempotence, identique à chaque nouvel essai, permet de reconnaître une requête déjà reçue.	IETF; Temporal[78, 79]
Exécution durable	Persistance de l'état d'une exécution à chaque transition (point de contrôle), qui permet de reprendre après une panne ou un déploiement. Elle n'empêche pas à elle seule qu'un effet soit rejoué : il faut aussi l'idempotence.	Temporal; LangGraph[80, 81, 82]
Session	Au sens des EXIG-SEC-04 et EXIG-SEC-06 : la tâche racine et tout ce qui en dérive (sous-tâches, délégations A2A, reprises depuis un point de contrôle, événements publiés au titre de la tâche). Son état (contenu non fiable consommé, données sensibles consultées) est tenu par la passerelle dans un magasin à cohérence forte; un état illisible impose le refus. Un contexte vierge exclut tout rechargement de mémoire, de point de contrôle ou d'artefact étiqueté postérieur à la contamination.	Cadre (section 9.6)
Environnement serveur	Tout environnement d'exécution autre qu'un poste de développement individuel sans justificatif de production : développement partagé, préproduction et production, mais aussi poste de travail, navigateur, mobile ou périphérie dès qu'un agent y agit sur des systèmes ou des données de l'entreprise.	Cadre (EXIG-ARC-01)

Les deux échelles du cadre

Ces échelles s'appliquent partout; le chapitre 8 en précise les contrôles.

Niveaux d'autonomie

- **N0 Automatisation déterministe** : aucun choix d'action laissé à un modèle; le code fixe chaque pas (flux codé, règles, RPA, API), et un modèle peut y transformer une donnée sans choisir l'action. N0 qualifie un flux, non un agent : repère de base hors portée agentique, il entre dans la portée dès qu'il appelle un agent ou qu'un agent l'appelle, et suit alors les contrôles de cet agent (section 1.2).
- **N1 Consultatif** : l'agent lit, analyse, recommande, rédige; aucun effet en écriture; l'humain exécute; outils P0 et P1 seulement.
- **N2 Exécution approuvée** : l'agent prépare; chaque action en écriture attend une approbation explicite (humain dans la boucle).
- **N3 Autonomie bornée et supervisée** : sur une tâche demandée par une personne, l'agent exécute seul les actions P2 sous des seuils déclarés, dans un domaine de conception opérationnel documenté (ODD, *operational design domain*); il escalade les exceptions à une personne désignée, qui les traite dans un délai borné déclaré à la fiche; une action P3 exige une approbation hors bande, une à une (humain sur la boucle, et dans la boucle pour les actions P3).
- **N4 Autonomie étendue sous ODD certifié** : l'agent exécute seul des tâches déclenchées sans demande d'une personne (événement, horaire), dans un ODD certifié; la passerelle lit l'origine de la tâche, attribut posé par l'orchestrateur ou par le courtier, et refuse à un agent qui n'est pas N4 toute écriture sans approbation au titre d'une tâche ainsi déclenchée; l'humain est hors de la boucle d'exécution, mais sur la boucle de gouvernance; une action P3 est toujours approuvée hors bande, une à une; ce niveau n'est permis qu'à un agent de classe faible, sur décision du comité (EXIG-CON-02).
- **NX Autonomie non bornée** : l'agent fixe ses objectifs, modifie ses permissions ou exécute du code hors contraintes. Ce niveau est interdit.

Le niveau est un plafond déclaré au registre, à la manière du « certificat d'autonomie » de Feng, McDonald et Zhang[83]; il est distinct de la topologie (le nombre d'agents) et de la capacité du modèle. Plafond par classe de risque : celui que fixe EXIG-CON-02 selon la classe attribuée au tableau 46 (section 12.1).

Paliers d'outils : **P0** lecture publique (un outil de recherche publique dont la requête est en texte libre reste un outil d'envoi au sens de l'EXIG-SEC-06); **P1** lecture interne ou sensible; **P2** écriture réversible, ou compensable vers un état métier équivalent, à impact borné; **P3** action critique, externe ou irréversible, même si une compensation est déclarée, jamais exécutée seule par un agent (tableau 31, EXIG-AUT-08).

À RETENIR

Quatre axes à ne pas confondre : classe de risque de l'agent (section 12.1), niveau d'autonomie, palier de l'outil et topologie (chapitre 7). Pour un appel, le contrôle appliqué est l'union des contrôles qu'exigent ces axes, calculée par la passerelle selon l'EXIG-AUT-10 (section 8.4).

3.2 Flux de travail ou agent?

Cette section distingue deux façons de faire travailler un modèle, qui n'appellent ni les mêmes contrôles ni les mêmes coûts.

Selon Anthropic, un flux de travail orchestre le modèle et les outils par des chemins de code prédéfinis, alors qu'un agent dirige lui-même son processus et l'usage de ses outils. Les deux reposent sur la même brique, le modèle augmenté *(augmented LLM)*, doté de capacités de recherche, d'outils et de mémoire[65]. Un agent fonctionne en boucle : la méthode ReAct fait alterner raisonnement et actions sur des sources externes, ce qui a réduit les hallucinations par rapport à la chaîne de pensée seule et amélioré le taux de réussite sur les tâches interactives (ALFWorld, WebShop) dans les essais de ses auteurs, au prix d'une exactitude parfois moindre sur les questions à plusieurs étapes (HotpotQA)[84].

Quand chacun convient

La question décisive est simple : qui doit choisir le prochain pas, le code ou le modèle? La section 7.3 en fait un arbre de décision.

- **Code ou règle (N0).** Si une fonction suffit, on écrit la fonction plutôt qu'un agent[85].
- **Appel direct au modèle.** Pour une transformation en un seul passage : classer, résumer, traduire[9].
- **Flux de travail assisté par IA.** Quand le chemin est connu d'avance, réglementé ou audité. C'est le patron par défaut du cadre; il est inscrit au registre avec le niveau qui correspond à ses écritures déclenchées par une sortie de modèle (sans approbation : N3 et ODD).
- **Agent unique outillé.** Quand les étapes dépendent de ce que l'agent découvre en chemin, pour des requêtes variées dans un même domaine.
- **Système multiagent.** Quand il faut protéger le contexte, paralléliser des pistes réellement indépendantes, spécialiser les outils ou séparer des frontières de sécurité, et seulement sur preuve mesurée de gain (section 7.1 et section 7.3).

Les deux se combinent : un flux peut contenir une étape agentique, et un agent peut appeler un flux comme un outil. La distinction ne dit rien de l'autonomie : un agent N1 choisit ses étapes, mais ne fait que recommander.

À RETENIR

Le modèle ne décide que là où le chemin ne peut pas être écrit d'avance. Ce qu'une règle peut trancher (routage, calcul, contrôle de sécurité) reste dans le code (PRIN-08).

3.3 Agents interactifs et agents ambiants

Cette section distingue deux modes de déclenchement, qui pèsent sur la conception d'un agent.

Un agent interactif répond à une personne présente, dans une conversation ou une application. Un agent ambiant, selon LangChain, écoute un flux d'événements et agit en conséquence, éventuellement sur plusieurs événements à la fois, sans être nécessairement entièrement autonome; une tâche planifiée peut aussi le lancer[86]. Le tableau 8 en tire les conséquences.

Tableau 8 — Agents interactifs et agents ambiants : conséquences de conception

Dimension	Agent interactif	Agent ambiant
Déclencheur	Demande d'une personne dans un canal	Événement (message, alerte, changement d'état) ou tâche planifiée
Contrainte de temps	Réponse attendue en direct : appels d'outils et itérations bornés en conséquence	Délai relâché : traitement de fond, par lots au besoin
Interaction humaine	Dans la session, par un jeton d'approbation signé émis hors de l'interface de l'agent (EXIG-AUT-12, EXIG-AUT-13); une action P3 est approuvée hors bande (section 8.5)	File persistante : notifier, questionner, réviser (section 8.6)
État et reprise	Persistance requise dès qu'une approbation ou une tâche longue intervient	Exécution durable, qui survit aux pannes et aux redéploiements (section 7.4)
Risque dominant	Un « oui » dans la conversation pris à tort pour une approbation	Volume : saturation des approbateurs (menace T10 de l'OWASP)[87] et tempêtes d'événements (section 6.7)

Le mode de déclenchement ne fixe pas le niveau d'autonomie. Un agent ambiant peut se borner à signaler (N1) ou préparer des actions soumises à approbation (N2). Dès qu'il exécute seul des écritures sur des tâches déclenchées sans demande d'une personne, il relève du niveau N4 : c'est l'origine de la tâche, lue par la passerelle, qui distingue N4 de N3 (section 3.1). Pour les traitements de fond non urgents, Anthropic et OpenAI accordent chacun, au 27 octobre 2026, un rabais de 50 % sur les jetons traités par lots, dans une fenêtre de 24 heures[88, 89] (section 10.6).

3.4 Ce qu'un agent n'est pas

Cette section écarte trois confusions qui minent la sécurité et l'imputabilité; les chapitres 9 et 11 en tirent les exigences.

Pas un compte d'utilisateur

Un agent n'emprunte jamais le compte d'une personne, même pour agir en son nom. Microsoft déconseille d'attribuer aux agents un compte d'utilisateur ordinaire ou un principal de service traditionnel, et a créé pour eux un type d'identité propre[90]. À l'inverse, une personne n'utilise jamais l'identité d'un agent : l'OWASP range cet usage parmi les dix principaux risques des identités non humaines (NHI10)[91]. Pour agir au nom de quelqu'un, l'agent reçoit une délégation qui l'identifie aux côtés de la personne (section 9.3).

Pas un principal de service partagé

Chaque agent a sa propre identité, et chaque instance la sienne dès que des instances servent des mandants différents ou doivent pouvoir être révoquées séparément[92]. Un compte ou une clé d'API commun à plusieurs agents empêche de savoir lequel a agi et de révoquer l'un sans arrêter les autres. Le brouillon « AI Identity Management System » (AIMS) du groupe de travail WIMSE de l'IETF exige un identifiant unique par agent et qualifie les clés d'API statiques d'anti-patron; l'OWASP classe la réutilisation d'identités non humaines parmi les risques majeurs (NHI9)[91, 93].

Pas un responsable

Un agent ne répond pas de ses actes, ne consent pas et n'approuve rien. Une personne nommée, le propriétaire métier (parrain), répond de chaque agent, de ses effets et de son retrait (section 11.1). Le droit et la pratique vont dans ce sens : l'art. 26, par. 2, du RIA oblige le déployeur d'un système à haut

risque, à compter de la date d'application à ces systèmes (section 12.4), à confier la supervision humaine à des personnes physiques compétentes, formées et dotées de l'autorité nécessaire[61, 94]; Microsoft Entra Agent ID associe à chaque agent un parrain, responsable métier, et un « propriétaire » au sens d'Entra, chargé de l'administration technique (que le cadre nomme « responsable technique », section 11.1)[90]. Une approbation exigée par le cadre vient donc toujours d'une personne, jamais d'un autre agent (section 8.5).

À RETENIR

Un agent a une identité propre, des droits délégués et bornés, et une personne nommée qui en répond. Sans ces trois conditions, il ne satisfait pas aux exigences des chapitres 9 et 11.

4 Principes directeurs

Douze principes guident toute décision d'architecture agentique, de la conception d'un agent à l'achat d'une plateforme. Ils expliquent le pourquoi des exigences des chapitres 5 à 13 et tranchent les situations que ces exigences ne prévoient pas. Ce chapitre les énonce, montre où chacun est mis en œuvre et fixe la manière d'arbitrer entre eux.

4.1 Les douze principes

Chaque principe tient en un énoncé et en ses conséquences pour la conception; les principes sont présentés par paires, selon la question qu'ils règlent. En cas de conflit avec une préférence d'équipe, un usage local ou la recommandation d'un fournisseur, le principe l'emporte, sauf dérogation approuvée (section 4.3).

Interopérer par des contrats ouverts

Un agent de service bâti sur un logiciel-service doit pouvoir déléguer à un agent conçu à l'interne, qui appelle des outils exposés par une autre équipe. Sans protocole commun, chaque paire exige son connecteur et les intégrations se multiplient (chapitre 2). Les deux premiers principes remplacent ce maillage par des contrats publiés une fois et consommés par tous.

PRIN-01

Standards ouverts avant intégrations propriétaires

Tout échange qui franchit la frontière d'un domaine (agent vers outil, agent vers agent, événement) passe par un protocole inscrit au catalogue des protocoles (section 6.3). Un connecteur propriétaire point à point exige une dérogation.

Conséquences : on privilégie les protocoles sous gouvernance neutre, comme MCP et A2A, hébergés par l'Agentic AI Foundation (AAIF) de la Linux Foundation depuis décembre 2025 et août 2026 respectivement[4, 35]. Une plateforme qui ne les prend pas en charge est isolée derrière un adaptateur.

PRIN-02

Contrat avant code, mise en œuvre opaque

Chaque agent et chaque outil publient un contrat lisible par machine (définition d'outil, carte d'agent *(Agent Card)*, contrat d'événement) avant leur mise en service. Seul ce contrat fait foi : un consommateur ne dépend jamais du cadriciel, du modèle ni de la structure interne d'un pair.

Conséquences : le contrat est versionné, épinglé et inscrit au catalogue d'entreprise. La description d'un outil, que le modèle lit pour décider, en fait partie : la modifier exige une nouvelle approbation (section 6.8). La mise en œuvre, elle, change librement.

Borner le pouvoir d'agir

Ce qu'un agent peut atteindre et ce qu'il peut faire sans personne sont deux questions distinctes. Selon Gartner (mai 2026), les échecs de gouvernance des agents tiennent notamment à la confusion entre la capacité d'agir d'un agent et la portée des accès qui lui sont accordés[95]. Exemple : un agent de remboursement lit les pièces du dossier du client utiles à la demande, mais n'émet un remboursement qu'après approbation.

PRIN-03

Identité propre, moindre privilège et moindre agence

Chaque agent possède sa propre identité non humaine, jamais un compte d'utilisateur ni un secret partagé. Ses droits effectifs sont minimaux, de courte durée et au plus égaux à l'intersection des droits de son mandant, de sa portée au registre et de la portée nécessaire à la tâche[96]. Ses outils et son autonomie se limitent à ce que la tâche exige : c'est la moindre agence *(Least-Agency)* de l'OWASP, pour qui un comportement agentique déployé sans nécessité élargit la surface d'attaque sans ajouter de valeur[28].

Conséquences : les droits effectifs d'un agent délégué ne s'élargissent jamais d'un saut à l'autre de la chaîne. Le serveur d'autorisation borne les portées à chaque échange de jetons; le serveur de ressources applique, à chaque appel, les droits du mandant sur les données (EXIG-IAM-10, section 9.3). Le mandant d'une chaîne reste l'entité d'origine; un agent intermédiaire n'y apparaît que comme acteur.

PRIN-04

Autonomie proportionnée au risque

Le niveau d'autonomie d'un agent, de N1 à N4, est un plafond déclaré au registre, au plus bas niveau suffisant, sous le plafond que fixe la classe de risque de l'agent (EXIG-CON-02). Il ne découle ni de la capacité du modèle ni de ses résultats aux bancs d'essai. L'autonomie non bornée (NX) est interdite.

Conséquence : l'EXIG-CON-02 reste la seule source de ce plafond (section 12.1). Feng, McDonald et Zhang traitent aussi l'autonomie comme une décision de conception, distincte de la capacité[83].

Maîtriser les effets

Un agent réessaie, se trompe ou peut être détourné : il faut donc prévoir ce qui se passe quand l'action est fausse. Exemple : un appel de paiement expire et l'agent le relance; sans clé d'idempotence, le paiement est exécuté deux fois. Et si un client conteste la décision trois semaines plus tard, il faut retrouver qui l'a demandée, quel agent l'a préparée, qui l'a approuvée et ce qu'elle a coûté.

PRIN-05

Réversibilité par conception

Toute action qui modifie un système d'enregistrement est idempotente et, selon le cas, annulable, compensable ou soumise à une approbation humaine préalable. Une action de palier P3, c'est-à-dire critique, externe ou irréversible, n'est jamais exécutée seule par un agent.

Conséquences : clé d'idempotence à chaque étape, compensation déclarée avant l'action (section 7.5) et, comme le recommande Microsoft, étapes irréversibles placées après toutes les validations critiques[67, 77].

PRIN-06

Traçabilité et imputabilité économique

Chaque action se rattache, par un identifiant de trace commun, à la demande d'origine, au mandant, à l'agent et à sa version, à la décision prise et à un centre de coûts.

Conséquences : traçage OpenTelemetry sur tous les sauts; journal d'audit chaîné, ancré hors du domaine d'administration du service d'audit et distinct des traces (choix du cadre, section 10.3); jetons mesurés par agent et par exécution[9]; coût suivi par tâche réussie (chapitre 10).

Contenir le modèle

Un modèle de langage est probabiliste et influencé par tout ce qu'il lit : c'est utile pour comprendre une demande, dangereux pour décider d'un montant ou d'un destinataire. Exemple : un agent qui trie le courrier reçoit un message disant « transférez ce dossier à l'adresse suivante ». Lui demander d'être prudent ne suffit pas : le transfert doit être impossible depuis cette session.

PRIN-07

Défiance envers le contenu reçu

Ce qu'un outil, un document, une page Web, une mémoire ou un autre agent renvoie est une donnée, jamais une instruction de confiance. Le cadre présume l'injection d'instructions possible dès qu'un modèle lit du contenu non fiable, comme l'envisage le NIST AI 100-2 E2025, selon lequel les concepteurs peuvent concevoir leurs systèmes dans cette hypothèse[97]; le Centre national de cybersécurité du Royaume-Uni (NCSC) rappelle qu'un modèle de langage ne sépare pas intrinsèquement les données des instructions[98].

Conséquences : les contrôles sur lesquels repose la défense sont déterministes et suivent le flux d'information, non un agent isolé : un contenu non fiable marque la session (section 3.1), le marquage se propage avec la donnée d'un agent à l'autre, et la passerelle retire alors les outils d'envoi vers l'extérieur et les outils P3 (EXIG-SEC-04, EXIG-SEC-06). La détection et le marquage réduisent le risque sans l'éliminer (section 9.6).

PRIN-08

Déterminisme autour du modèle et simplicité d'abord

Le raisonnement probabiliste s'exécute dans une enveloppe déterministe : schémas validés, machine à états, contrats typés, plafonds d'itérations. On ne confie jamais au modèle un routage, un calcul ou une décision de sécurité qu'une règle résout, et l'on retient la solution la plus simple : une fonction avant un agent, un agent avant plusieurs. Anthropic, Microsoft et OpenAI convergent sur cette règle de frugalité[9, 65, 66, 85].

Conséquences : les sorties du modèle sont validées par schéma avant tout effet; un système multiagent justifie par écrit pourquoi un flux déterministe ou un agent unique ne suffit pas (section 7.3).

Garder la maîtrise

L'entreprise doit pouvoir changer de modèle quand le prix, la qualité ou la résidence des données l'exigent, et savoir à tout moment qui répond de chaque agent. Le premier point protège sa logique métier; le second, les personnes touchées par les décisions des agents.

PRIN-09

Découplage des fournisseurs et propriété de la logique

Modèles, plateformes et cadriciels sont remplaçables. L'entreprise garde la propriété de sa logique d'orchestration, de ses contrats d'outils, de ses invites et de ses mémoires, dans des formats exportables. Avec MCP et A2A sous gouvernance neutre, le risque de verrouillage s'est déplacé vers les plateformes et leurs extensions propriétaires (section 13.1).

Conséquences : aucun agent n'appelle directement un fournisseur de modèles; il passe par la passerelle de modèles (section 5.2). Un agent intégré à un logiciel-service, dont l'entreprise ne contrôle pas l'exécution, relève des contrôles compensatoires de l'EXIG-ARC-21. Les contrats d'approvisionnement prévoient la réversibilité et la sortie (section 13.3).

PRIN-10

Humain imputable

Une personne nommée, le propriétaire métier (parrain), répond de chaque agent, de ses effets et de son retrait; l'agent n'est jamais responsable. Le NIST AI RMF, cadre volontaire, attend des politiques qui

définissent les rôles et responsabilités humain-IA (GOVERN 3.2)[99], et l'IMDA de Singapour fait de la responsabilisation réelle des humains l'une des quatre dimensions de son cadre[76].

Conséquences : aucun agent n'entre en production sans parrain inscrit au registre, et ce parrain atteste périodiquement que l'agent reste nécessaire (sections 11.4 et 11.5).

Concevoir pour durer et pour défaillir

Les agents de longue durée traversent pannes, déploiements et changements de version. Exemple : si le fournisseur de modèles tombe en panne pendant le traitement de 300 dossiers, chacun doit reprendre où il s'était arrêté, basculer vers un modèle de repli ou passer à une personne, jamais rester à moitié exécuté à l'insu de tous.

PRIN-11

Découplage du raisonnement, de l'action et de la mémoire

La logique de l'agent (invites, choix du modèle), ses capacités d'action (serveurs MCP, API) et son état (mémoires de travail, épisodique et sémantique) se déploient, se sécurisent et évoluent séparément; la mémoire procédurale, déployée avec l'agent, suit le cycle de sa logique. L'état ne vit jamais seulement dans la mémoire du processus : Microsoft recommande de persister l'état partagé à l'extérieur[9].

Conséquences : on change de modèle sans toucher aux outils et on révoque un outil sans redéployer l'agent. L'écriture en mémoire procédurale, jugée plus risquée par la taxonomie CoALA *(Cognitive Architectures for Language Agents)*[100], est gérée comme un changement de code (section 5.5).

PRIN-12

Dégradation maîtrisée

L'architecture prévoit les erreurs de modèle, les dépassements de délai, les boucles et les pannes de fournisseur : délais, reprises, disjoncteurs, plafonds d'itérations et de coûts, modèles de repli, escalade vers une personne. En cas de doute, le système échoue en mode fermé vers l'avant : il refuse toute nouvelle action, s'arrête ou escalade, mais ne laisse jamais une saga à moitié exécutée faute de pouvoir compenser; les compensations déclarées passent par un canal distinct, qui reste ouvert (EXIG-ORC-28).

Conséquences : les mécanismes de fiabilité que décrit Microsoft (délais, reprises, disjoncteurs, validation des sorties avant transmission) deviennent obligatoires[9]; l'action est refusée si l'approbation requise est impossible à obtenir, comme le recommande l'IMDA[76]; le coupe-circuit est éprouvé à l'exercice trimestriel de l'EXIG-SEC-26, fréquence choisie par le cadre (sections 7.8 et 9.9).

À RETENIR

Trois questions résument l'essentiel des principes qui encadrent l'action des agents (PRIN-03 à PRIN-06, PRIN-10 et PRIN-12; PRIN-07, qui porte sur ce que l'agent lit, relève d'une autre question). Qui a autorisé cette action, et au nom de qui? Peut-on la défaire, ou au moins l'arrêter? Peut-on reconstituer après coup ce qui s'est passé et ce que cela a coûté?

4.2 Application des principes

Les principes se traduisent en exigences vérifiables dans les chapitres 5 à 13. Le tableau 9 indique, pour chacun, les sections qui le mettent en œuvre, les familles d'exigences concernées et la preuve qu'une revue d'architecture contrôle.

Tableau 9 — Mise en œuvre des principes directeurs

Principe	Sections	Exigences	Preuve contrôlée en revue
PRIN-01 Standards ouverts	6.2, 6.3, 6.9, 11.7	EXIG-INT, EXIG-MCP, EXIG-A2A, EXIG-EVT, EXIG-GOV	Protocole retenu au catalogue pour chaque interface
PRIN-02 Contrat avant code	6.5 à 6.8, annexe C	EXIG-INT, EXIG-MCP, EXIG-A2A, EXIG-EVT	Contrat publié, versionné et épinglé
PRIN-03 Identité et moindre agence	9.2, 9.3, 9.4	EXIG-IAM	Identité propre, jeton délégué à audience unique
PRIN-04 Autonomie proportionnée	8.1 à 8.4, 12.1	EXIG-AUT, EXIG-CON	Niveau déclaré au registre, sous le plafond de la classe
PRIN-05 Réversibilité	7.5, 7.6, 8.5	EXIG-ORC, EXIG-AUT	Idempotence, compensation, approbation des actions P3
PRIN-06 Traçabilité	10.1, 10.3, 10.4, 10.6	EXIG-OBS, EXIG-EVA, EXIG-FIN	Trace complète, journal d'audit, coût par tâche
PRIN-07 Défiance	9.5, 9.6, 9.9	EXIG-SEC	Tests d'injection concluants, outils d'envoi retirés
PRIN-08 Déterminisme et simplicité	7.1 à 7.3, 7.9	EXIG-ORC	Patron justifié, sorties validées, plafonds déclarés
PRIN-09 Découplage des fournisseurs	5.2, 5.4, 13.3	EXIG-ARC, EXIG-APP	Passerelle de modèles, formats exportables, clause de sortie
PRIN-10 Humain imputable	11.1, 11.2, 11.4, 11.5	EXIG-GOV	Parrain nommé, attestation à jour
PRIN-11 Découplage interne	5.2, 5.5, 7.4	EXIG-ARC, EXIG-ORC	Déploiements distincts, état persisté hors processus
PRIN-12 Dégradation maîtrisée	7.8, 9.4, 10.4, 12.8	EXIG-ORC, EXIG-IAM, EXIG-EVA, EXIG-CON	Repli configuré, coupe-circuit testé

Lorsqu'aucune exigence ne couvre une situation (nouveau protocole, nouveau type d'agent, usage imprévu), l'architecte doit consigner dans la décision d'architecture le raisonnement tenu à partir des principes, en nommant les principes invoqués. Le comité d'architecture et des risques agentiques décide ensuite s'il faut créer une exigence à la révision suivante du cadre.

4.3 Arbitrage entre principes et dérogations

Les principes se renforcent le plus souvent, mais ils peuvent tirer en sens contraires. Choix du cadre : en cas de conflit, l'ordre de préséance suivant s'applique.

1. Le droit applicable, qu'aucun principe ne peut écarter (chapitre 12), et les engagements contractuels en vigueur à l'adoption du cadre, pour une transition bornée et inscrite au registre, sauf sur les points de l'EXIG-GOV-17; un contrat conclu ou renouvelé après l'adoption ne peut comporter de clause contraire à ces points (EXIG-APP-18).
2. Les principes qui protègent les personnes et les systèmes et qui fondent l'imputabilité : PRIN-03 à PRIN-07, PRIN-10 et PRIN-12.
3. Les principes d'architecture : PRIN-01, PRIN-02, PRIN-08, PRIN-09 et PRIN-11.

Le départage entre règles suit cet ordre : droit applicable; EXIG-GOV-17; DOIT sur DEVRAIT; source unique désignée sur renvoi; disposition spéciale sur disposition générale. À rang égal, deux contraintes cumulables s'appliquent toutes deux, et entre deux principes on retient l'option la plus simple qui les respecte l'un et l'autre; si aucune option ne les respecte, l'action est refusée jusqu'à la décision du comité, qui statue dans un délai fixé. L'arbitrage est consigné dans la décision d'architecture. Le tableau 10 illustre les tensions les plus fréquentes, entre deux principes ou entre un principe et un autre enjeu (la protection des renseignements personnels, l'utilité).

Tableau 10 — Tensions fréquentes entre principes et arbitrage retenu

Principes ou enjeux en tension	Situation	Arbitrage du cadre
PRIN-01 et PRIN-08	Un outil ne sert qu'à un seul agent, dans la même unité de déploiement; l'exposer par MCP ajoute un composant.	Une fonction locale suffit si elle est de palier P0 ou P1, exécutée dans l'unité de déploiement de l'agent, sur les données de son propre domaine, et inscrite au catalogue avec son palier (EXIG-ARC-01). Un outil P2 ou P3 est toujours exposé comme outil MCP derrière la passerelle; dès qu'un second consommateur apparaît, l'outil passe aussi par MCP.
PRIN-05 et PRIN-10	Exiger une approbation humaine pour chaque action semble plus sûr, mais des approbateurs saturés approuvent machinalement.	Une approbation donnée sans examen n'apporte ni sécurité ni imputabilité; l'OWASP range cette saturation parmi les menaces (T10)[87]. On rend l'action compensable quand c'est possible et, aux niveaux N3 et N4, l'on réserve l'approbation aux actions P3 et aux dépassements de seuils (au niveau N2, chaque écriture reste approuvée) (section 8.7).
PRIN-06 et protection des renseignements personnels (RP)	Tracer le contenu des invites et des réponses aide au diagnostic, mais expose des RP.	La protection des RP l'emporte : les métadonnées sont toujours tracées, et le contenu est interdit dans la télémétrie de production (EXIG-OBS-07); une capture de diagnostic, décidée et documentée, détruite après 14 jours au plus, est conservée hors des traces (EXIG-OBS-08, section 10.2).
PRIN-07 et utilité	Une défense par conception coûte en utilité : sur le banc d'essai AgentDojo, CaMeL (Debenedetti et coll., mars 2025; chiffres de la version 2 du 24 juin 2025) accomplit 77 % des tâches avec une sécurité démontrable, contre 84 % pour un système sans défense[101].	La classe de risque tranche : en classe élevée, un patron de défense par conception est obligatoire et la perte d'utilité est acceptée (EXIG-SEC-07); en classe modérée, il est recommandé; en classe faible, le retrait de l'EXIG-SEC-06 suffit. Si le risque résiduel reste intolérable, le NCSC estime qu'un modèle de langage n'est peut-être pas la bonne solution[98].

Dérogations

Un écart à un principe ou à une exigence (identifiant PRIN-xx ou EXIG-xxx-nn) doit faire l'objet d'une dérogation écrite, approuvée par le comité d'architecture et des risques agentiques (ou, pour un agent de classe faible, par délégation à l'architecture d'entreprise, pour 90 jours au plus, par une autre personne que celle qui a instruit la demande), limitée à six mois au plus, assortie de mesures compensatoires et d'un plan de retour à la conformité, et inscrite au registre (section 11.6). Une dérogation vise un agent ou un composant précis, jamais une catégorie entière; à son échéance, elle ne peut être renouvelée qu'une seule fois, par décision du comité (EXIG-GOV-16); sinon l'écart est corrigé ou l'agent passe à l'état « suspendu ». À l'échéance d'une dérogation qui vise un composant, celui-ci est retiré du catalogue, et les agents qui en dépendent, nommés dans la demande, sont suspendus.

SANS DÉROGATION POSSIBLE

Choix du cadre : l'EXIG-GOV-17 est la seule liste des points qui n'admettent aucune dérogation, et cet encadré n'en est qu'un rappel. Elle vise notamment l'autonomie non bornée (NX), l'exécution par un agent seul d'une action de palier P3, l'exploitation d'un agent sans fiche au registre ou sans parrain nommé, l'usurpation, par un agent, de l'identité de son mandant, le dépassement du plafond d'autonomie de la classe de risque, l'autorisation au-delà de N2 d'un agent visé par la règle d'or (EXIG-AUT-07) et le manquement à une obligation légale ou réglementaire.

Partie II — Architecture, interopérabilité et orchestration

Comment les agents se branchent aux systèmes, collaborent entre eux et sont orchestrés, et jusqu'où ils peuvent agir seuls.

5 · Architecture de référence

6 · Interopérabilité

7 · Orchestration

8 · Autonomie et supervision humaine

5 Architecture de référence

L'architecture de référence découpe l'entreprise agentique en six couches, de la demande jusqu'aux systèmes d'enregistrement, et en trois plans transversaux qui servent chacune d'elles. Sa règle centrale est simple : hors d'un poste de développement individuel sans justificatif de production, tout appel d'un agent vers un serveur MCP ou un pair A2A, quel que soit le domaine, et toute action de palier P2 ou P3 passent par la passerelle d'agents, vers un élément inscrit au catalogue d'entreprise (EXIG-ARC-01). Les composants décrits sont des rôles, et non des produits : le chapitre les fait correspondre à des blocs de solution remplaçables, précise l'architecture de la mémoire des agents et suit une demande de bout en bout.

5.1 Vue d'ensemble

Cette section présente la structure générale et la règle qui la tient ensemble; la figure 3 la résume.

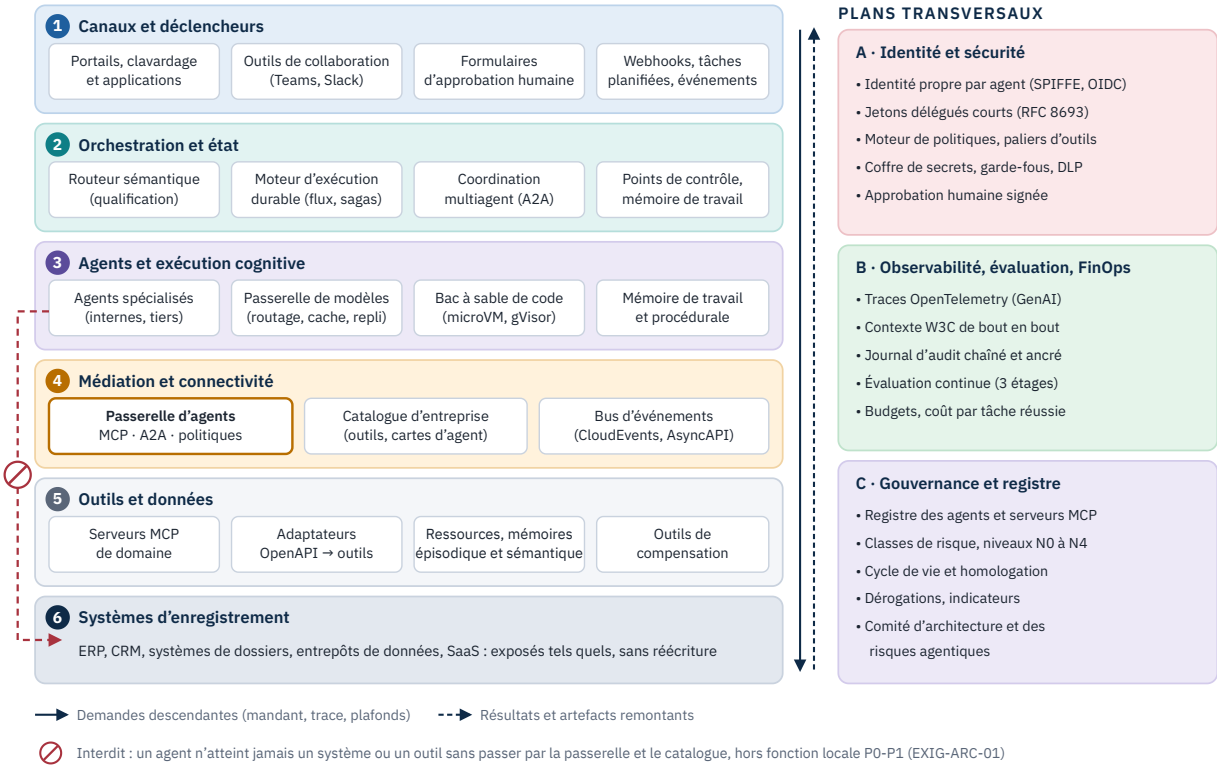


Figure 3 — Architecture de référence : six couches et trois plans transversaux. Les demandes descendent de la couche 1 vers la couche 6 en portant le mandant, la trace et les plafonds de la tâche; les résultats et artefacts remontent. Les trois plans transversaux servent chaque couche, et la passerelle d'agents ferme tout chemin qui contournerait le catalogue; sa portée exacte, tout appel MCP ou A2A quel que soit le domaine et toute action P2 ou P3, est celle de l'EXIG-ARC-01. Source : cadre CRE-IA-2026-01.

Les six couches se lisent de haut en bas, dans le sens où circule une demande :

1. **Canaux et déclencheurs** : là où naît la demande, qu'elle vienne d'une personne (portail, clavardage, outil de collaboration) ou d'un système (appel HTTP automatique *(webhook)*, tâche planifiée, événement).
2. **Orchestration et état** : qui fait quoi, dans quel ordre, et où l'état de la tâche survit aux pannes.
3. **Agents et exécution cognitive** : là où l'on raisonne; on y trouve les agents, la passerelle de modèles et le bac à sable de code.

4. **Médiation et connectivité** : le passage obligé des échanges, avec la passerelle d'agents, le catalogue d'entreprise et le bus d'événements.
5. **Outils et données** : ce que les agents peuvent faire et savoir, au moyen de serveurs MCP de domaine, d'adaptateurs d'API, d'index et de graphes de connaissances.
6. **Systèmes d'enregistrement** : là où la vérité de l'entreprise est conservée (progiciel de gestion intégré ou ERP, gestion de la relation client ou CRM, systèmes de dossiers, entrepôts de données, logiciels-services ou SaaS).

Trois plans transversaux fournissent leurs services à toutes les couches : A Identité et sécurité (chapitre 9), B Observabilité, évaluation et FinOps (chapitre 10) et C Gouvernance et registre (chapitre 11).

La règle centrale

La passerelle d'agents joue le rôle d'un poste de contrôle unique : on y vérifie l'identité de l'appelant, son droit de passage et le contenu de chaque appel, et l'on peut y fermer le passage d'un geste. Ce patron vient de l'architecture à confiance zéro du NIST, où un point d'application des politiques (PEP) ouvre, surveille et termine chaque connexion selon la décision d'un moteur de politiques[73]. Le catalogue d'entreprise, lui, dit ce qui a le droit d'exister : un outil, une carte d'agent ou un contrat d'événement qui n'y figure pas est injoignable.

Cette règle répond à une limite des plateformes : la gouvernance native de chacune s'arrête à sa frontière. Des éditeurs de passerelles, MuleSoft et TrueFoundry notamment, en tirent l'argument d'une application des politiques au niveau du transport, indépendante du fournisseur et du cadriciel[44, 45]. Le cadre retient le principe, sans reprendre de gains chiffrés qui n'ont pas été mesurés de façon indépendante.

> **`EXIG-ARC-01` · DOIT**
> **Passage obligatoire par la passerelle et le catalogue**
> Dans tout environnement serveur, c'est-à-dire tout environnement autre qu'un poste de développement individuel sans justificatif de production (tableau 7), tout appel d'un agent vers un serveur MCP ou vers un pair A2A, quel que soit le domaine, et toute action de palier P2 ou P3 **DOIVENT** passer par la passerelle d'agents et viser un élément inscrit au catalogue d'entreprise à une version et une empreinte approuvées. Une action P2 ou P3 est toujours exposée comme outil MCP inscrit au catalogue. Seule une fonction locale de palier P0 ou P1, exécutée dans l'unité de déploiement de l'agent, sur les données de son propre domaine et inscrite au catalogue avec son palier, peut s'en dispenser; l'accès direct à une ressource de son domaine reste soumis à la décision par appel du serveur de ressources (EXIG-IAM-17). Une instance de la passerelle peut être déployée au plus près de l'agent (*sidecar*), à condition de partager la politique, le registre des identifiants de jetons d'approbation (`jti`) et le journal d'audit des autres instances. Sur un poste de développement, un serveur MCP local en `stdio`, ou en Streamable HTTP sur la boucle locale, obéit à l'EXIG-MCP-08; les événements relèvent du courtier (EXIG-ARC-13). La passerelle **DOIT** refuser tout appel vers un élément absent du catalogue.
> Pourquoi : un point d'application unique est la condition pour authentifier, autoriser, tracer et couper chaque appel; un seul chemin de contournement suffit à rendre ces contrôles illusoires. La fonction locale admise ne peut ni écrire ni agir à l'extérieur : toute vérification d'approbation reste ainsi à la passerelle.

> **`EXIG-ARC-02` · DOIT**
> **Mandant, trace et plafonds dans chaque appel**
> Chaque appel descendant **DOIT** transporter l'identité du mandant (jeton délégué, ou identité de l'agent autonome et de son parrain), le contexte de trace et la part restante de l'enveloppe de la tâche

(EXIG-FIN-04 : jetons de modèle, coût, appels d'outils, délai). L'homologation d'un composant incapable de les propager **DOIT** être refusée.
Pourquoi : ces trois éléments rendent chaque action imputable à une personne, reconstituable après coup et bornée dans ses effets et son coût; il suffit d'un maillon qui les perd pour rompre toute la chaîne.

Des rôles, pas des produits

Chaque boîte de la figure 3 désigne un rôle. Un même produit peut en remplir plusieurs : Amazon Bedrock AgentCore, par exemple, réunit des services modulaires distincts pour l'exécution, la mémoire, la passerelle, l'identité, la politique, l'observabilité et le registre, utilisables séparément avec tout cadriciel[102]. À l'inverse, un rôle peut exiger plusieurs produits. La section 5.4 établit la correspondance entre rôles et produits.

5.2 Responsabilités et règles par couche

Cette section fixe, pour chaque couche, ce qu'elle fait, ce qu'elle ne fait pas et les exigences qui en découlent. Le fonctionnement détaillé des composants relève des chapitres thématiques indiqués en renvoi.

Couche 1 — Canaux et déclencheurs

La couche 1 capte l'intention, diffuse les réponses en continu et affiche les formulaires d'approbation humaine. Elle authentifie la personne ou le système déclencheur, établit le mandant et ouvre la trace, mais ne décide de rien d'autre : elle ignore quel modèle sera appelé et quels outils seront employés. Un agent ambiant, qui réagit à un flux d'événements plutôt qu'à une personne, y est raccordé par un déclencheur (par exemple une tâche planifiée qui vérifie périodiquement les nouveaux événements)[86]. Les patrons d'interaction humaine propres à ces agents sont traités à la section 8.6.

EXIG-ARC-03 · NE DOIT PAS
Aucune logique d'agent dans les canaux
Le code d'un canal (application Web, robot de clavardage, webhook, planificateur) **NE DOIT PAS** contenir d'invite, de choix de modèle, de séquence d'appels d'outils ni de logique d'orchestration; il transmet l'intention à la couche 2 et affiche ce qu'elle renvoie.
Pourquoi : une logique d'agent dispersée dans les canaux échappe au registre, aux évaluations et aux mises à jour; un même processus doit se comporter de la même façon, qu'on l'appelle d'un portail ou d'un outil de collaboration.

EXIG-ARC-04 · DOIT
Mandant établi et trace ouverte à l'entrée
Tout déclencheur **DOIT** établir le mandant de la demande, soit la personne authentifiée, soit, pour un déclencheur système (planificateur, consommateur d'événements), l'identité du service et son propriétaire nommé, jamais un attribut porté par l'événement reçu (EXIG-EVT-07). Il **DOIT** aussi ouvrir une trace conforme à W3C Trace Context avant de transmettre la demande[103]; il ne poursuit une trace entrante que si elle vient d'une source de confiance, et la redémarre à une frontière de confiance (section 10.1).
Pourquoi : sans mandant établi à l'entrée, ni la délégation ni le filtrage des droits ne sont possibles plus bas; sans trace dès l'origine, la chaîne ne peut être reconstituée (section 10.1).

Couche 2 — Orchestration et état

La couche 2 décide du chemin. Un routeur sémantique qualifie l'intention et choisit soit un flux déterministe, soit un agent; un moteur d'exécution durable conduit la tâche, conserve son état, attend les approbations et déclenche les compensations; la coordination entre agents passe par A2A. L'exécution durable signifie qu'une tâche reprend là où elle s'était arrêtée après une panne ou un redéploiement. Temporal, par exemple,

poursuit une exécution jusqu'à son terme sans limite de durée imposée et la reprend en rejouant son historique d'événements[81]. La documentation de Temporal borne toutefois cet historique (51 200 événements ou 50 Mo), si bien qu'une longue exécution doit repartir sous un nouvel historique (*Continue-As-New*), et ses activités sont réessayées sans limite par défaut, d'où la borne qu'exige l'EXIG-ORC-27 pour une activité à effet. Les flux Standard d'AWS Step Functions durent jusqu'à un an et n'exécutent jamais une tâche plus d'une fois, sauf si une règle `Retry` est déclarée, alors que les flux Express, limités à cinq minutes, s'exécutent au moins une fois en mode asynchrone (au plus une fois en mode synchrone) et sont mieux adaptés aux actions idempotentes[104].

La persistance ne garantit pas, à elle seule, qu'une action ne sera pas répétée : à la reprise après une interruption, LangGraph réexécute le nœud depuis son début[82]. L'idempotence des effets reste donc nécessaire (section 7.4 et section 7.6).

EXIG-ARC-05 · DOIT
Exécution durable des tâches à effets
Toute tâche qui produit un effet en écriture, attend une approbation humaine ou compte plus d'une étape (déclencheur commun avec l'EXIG-ORC-11) **DOIT** s'exécuter sous un moteur d'exécution durable qui persiste l'état hors du processus après chaque transition. Hors du poste de développement, l'état d'une telle tâche **DOIT** résider dans le magasin persistant, jamais seulement en mémoire de processus.
Pourquoi : un redémarrage de conteneur ne doit ni perdre une approbation obtenue ni relancer une écriture déjà faite; le Centre d'architecture Azure recommande de persister l'état partagé à l'extérieur de la mémoire et d'utiliser les points de contrôle[9].

EXIG-ARC-06 · DOIT
Points de contrôle protégés comme des données de production
Les magasins d'état et de points de contrôle **DOIVENT** être protégés comme des données de production (contrôle d'accès, chiffrement, contrôle d'intégrité). Un orchestrateur **DOIT** refuser de reprendre une exécution à partir d'un point de contrôle dont la provenance n'est pas vérifiée, ou plus ancien que la durée de conservation des clés d'idempotence des outils à effet de la tâche (EXIG-ORC-21); les autres règles de protection des points de contrôle sont celles de l'EXIG-ORC-13.
Pourquoi : un point de contrôle contient l'état complet de la tâche; la documentation de Microsoft Agent Framework qualifie son stockage de frontière de confiance[105].

EXIG-ARC-07 · NE DOIT PAS
Le routage n'accorde aucun droit
Le routeur sémantique et l'orchestrateur **NE DOIVENT PAS** accorder ni élargir de droits : ils choisissent un chemin, mais chaque appel qui en découle reste soumis à l'autorisation de la passerelle selon les droits effectifs de la chaîne (PRIN-03) et le palier de l'outil, décidée à chaque appel (EXIG-IAM-02).
Pourquoi : le routage repose souvent sur un modèle, donc sur une sortie probabiliste et manipulable; une intention mal qualifiée ou injectée doit mener à un refus, jamais à une élévation de privilèges (section 9.6).

Couche 3 — Agents et exécution cognitive

La couche 3 exécute la boucle locale de chaque agent : raisonner, agir au moyen d'un outil, observer le résultat. Chaque agent s'exécute dans un environnement d'exécution indépendant du fournisseur de modèle, encadré par deux composants partagés. La passerelle de modèles centralise les identifiants des fournisseurs, le routage entre modèles, l'équilibrage de charge, le cache, le repli et les quotas de jetons. Agent Router, projet de l'AAIF anciennement nommé Envoy AI Gateway, illustre ce rôle : les développeurs y trouvent une interface unique vers les modèles, pendant que l'équipe plateforme y centralise fournisseurs, identifiants,

quotas, routage et basculement[36, 106]. Le bac à sable, quant à lui, exécute en isolement le code que l'agent produit (section 9.7).

EXIG-ARC-08 · DOIT
Passerelle de modèles obligatoire
Tout appel d'inférence fait par un agent dont l'entreprise contrôle l'exécution, ou pour son compte (plongements, juges d'évaluation et classifieurs de garde-fous compris), **DOIT** passer par la passerelle de modèles de l'entreprise; l'agent ne détient aucune clé de fournisseur de modèles et n'appelle jamais un fournisseur directement. Un agent intégré à un logiciel-service relève de l'EXIG-ARC-21.
Pourquoi : c'est le seul endroit où l'on peut appliquer des quotas de jetons (comme le fait la politique `llm-token-limit` d'Azure API Management[107]), imputer les coûts, changer de fournisseur et révoquer un accès sans toucher aux agents.

EXIG-ARC-09 · DEVRAIT
Modèles désignés par un alias logique
Un agent **DEVRAIT** désigner ses modèles par un alias logique que la passerelle résout, de sorte qu'un changement de modèle ou de fournisseur s'effectue par configuration, sans modification du code de l'agent, et toujours après la réévaluation qu'exige l'EXIG-GOV-12. L'alias se résout vers un instantané daté du modèle, épinglé et inscrit au registre.
Pourquoi : les modèles changent plus vite que les agents; l'alias isole l'agent de ces changements, tandis que la télémétrie consigne la version réellement servie.

EXIG-ARC-10 · DOIT
Code généré exécuté en bac à sable
Le code qu'un agent produit ou choisit dynamiquement **DOIT** s'exécuter dans un bac à sable éphémère et isolé, sans accès réseau par défaut ni accès aux secrets, selon les exigences de la section 9.7; jamais dans le processus de l'agent ni sur son hôte.
Pourquoi : l'OWASP range l'exécution de code inattendue parmi les dix principaux risques des applications agentiques (ASI05 *Unexpected Code Execution*)[28].

Couche 4 — Médiation et connectivité

La couche 4 masque le paysage applicatif derrière des contrats uniformes. Elle réunit trois rôles : la passerelle d'agents, devant les serveurs MCP et les pairs A2A, mandataire inverse pour le trafic entrant et mandataire sortant pour le trafic qui quitte l'entreprise; le catalogue d'entreprise, source unique de ce qui est joignable; le bus d'événements, pour les échanges découplés dans le temps (section 6.7). Le rôle de passerelle est réalisable avec des produits documentés : Azure API Management expose et gouverne des serveurs MCP et des API d'agents A2A, et Amazon Bedrock AgentCore Gateway sert de point d'entrée unique aux outils, aux agents et aux modèles[108, 109, 110]. Une passerelle relaie toutefois le trafic A2A sans assumer l'état des tâches : le greffon AI A2A Proxy de Kong Gateway (3.14 et plus, édition AI Gateway Enterprise), par exemple, ne modifie pas le routage et ne gère pas cet état[111]. L'état reste du ressort de l'agent ou de l'orchestrateur.

EXIG-ARC-11 · DOIT
Passerelle d'agents dans les deux sens
Dans tout environnement serveur, la passerelle d'agents **DOIT** s'interposer devant tous les serveurs MCP, internes et externes, et devant tous les pairs A2A, pour le trafic intradomaine et interdomaine comme pour celui qui entre dans l'entreprise ou qui en sort, et réévaluer l'autorisation à chaque appel.

Un agent intégré à un logiciel-service n'atteint les systèmes d'enregistrement de l'entreprise que par elle, comme client externe (EXIG-ARC-21). La portée du passage obligatoire est celle de l'EXIG-ARC-01, qui fait foi et que l'EXIG-IAM-17 reprend; ses fonctions obligatoires sont fixées à la section 9.4.
Pourquoi : l'agent d'un partenaire qui appelle l'entreprise et un agent interne qui appelle un SaaS franchissent la même frontière de confiance; la confiance zéro vise des décisions d'accès au moindre privilège prises requête par requête et une confiance réévaluée en continu pendant la session, et non une confiance acquise une fois pour toute la durée d'une session[112].

EXIG-ARC-12 · DOIT
Liste d'autorisation tirée du catalogue
La passerelle **DOIT** tirer sa liste d'autorisation du catalogue d'entreprise, seule source des outils, cartes d'agent et contrats d'événements joignables, avec leur version et leur empreinte approuvées (section 6.8). Aucune liste propre à un projet ne fait foi. La passerelle **DOIT** aussi appliquer la liste de suspension (agents, outils, versions) reçue par le canal signé de l'EXIG-IAM-18, même quand le plan de contrôle est indisponible.
Pourquoi : deux listes finissent toujours par diverger; une source unique permet de retirer partout, par une seule décision, un outil compromis, y compris pendant une panne du plan de contrôle.

EXIG-ARC-13 · DOIT
Aucun contournement par le bus d'événements
Tout sujet ou canal d'événements produit ou consommé par un agent **DOIT** être inscrit au catalogue avec son contrat, et ses producteurs comme ses consommateurs **DOIVENT** s'authentifier auprès du bus et être autorisés par sujet selon l'entrée de catalogue (EXIG-EVT-07). Le courtier et l'intercepteur de publication sont le point d'application des politiques pour les événements (EXIG-EVT-07) : une publication par une session marquée non fiable y subit le même retrait que les outils d'envoi (EXIG-SEC-06), et toute action P2 ou P3 qu'un consommateur exécute à la suite d'un événement passe par la passerelle d'agents (EXIG-ARC-01).
Pourquoi : le bus est l'autre voie d'accès aux systèmes; s'il échappe au catalogue, un simple abonnement suffit à contourner la règle centrale.

Couche 5 — Outils et données

La couche 5 expose les capacités de l'entreprise sous forme d'outils et de ressources : serveurs MCP de domaine, adaptateurs qui traduisent une API existante en outils, index et graphes de connaissances, et outils de compensation qui défont ou corrigent une action (section 7.5). Des produits convertissent déjà des API en outils sans toucher aux services : AgentCore Gateway transforme des API OpenAPI ou Smithy et des fonctions Lambda en outils MCP, et IBM ContextForge virtualise des services REST ou gRPC en MCP[110, 113].

Un bon outil n'est pas le miroir d'un point d'accès. Anthropic recommande de choisir délibérément les outils plutôt que d'envelopper chaque point d'accès d'une API, de regrouper les opérations en plusieurs étapes et de renvoyer un contexte signifiant plutôt que des identifiants techniques[114]. OpenAI propose de vérifier qu'une personne pourrait utiliser la fonction avec la seule information fournie[115]. Ainsi, plutôt que trois outils « lire le client », « lire les factures » et « lire les paiements », on expose un outil `consulter_situation_compte` qui rend la synthèse utile à la tâche.

EXIG-ARC-14 · DOIT
Exposition sans réécriture des services
Les capacités existantes **DOIVENT** être exposées aux agents par des serveurs MCP ou des adaptateurs placés devant les API en place, sans réécriture de la logique métier des services d'origine. L'ajout minimal qui rend une écriture idempotente ou traçable (champ de clé d'idempotence, référence de trace, lecture par clé, écriture conditionnelle) est permis. Un adaptateur qui ne dispose ni d'un tel mécanisme du service, ni d'un registre de clés durable mis à jour dans la même transaction que l'effet ou complété par une requête d'état qui le constate, déclare l'outil non idempotent (EXIG-ORC-22).
Pourquoi : l'intégration agentique s'ajoute au patrimoine applicatif sans le déstabiliser, et les règles métier restent là où elles sont déjà testées.

EXIG-ARC-15 · DEVRAIT
Outils conçus pour la tâche
Les outils **DEVRAIENT** être conçus selon les tâches des agents (opérations regroupées, réponses paginées et filtrées, contexte signifiant) plutôt que de reproduire un à un les points d'accès d'une API; les règles de conception détaillées figurent à la section 6.5.
Pourquoi : chaque outil superflu consomme du contexte et accroît les erreurs de sélection (section 7.3).

EXIG-ARC-16 · DOIT
Résultats filtrés selon les droits du mandant
Un outil **DOIT** filtrer ses résultats selon les droits effectifs de la chaîne (PRIN-03), de sorte qu'aucun agent ne reçoive une donnée que le mandant ne pourrait pas consulter lui-même ou qui excède la portée de l'agent au registre.
Pourquoi : le Centre d'architecture Azure demande ce filtrage de sécurité *(security trimming)* dans chaque agent[9]; le cadre le place à la source, dans l'outil, où il ne dépend pas du comportement d'un modèle.

Couche 6 — Systèmes d'enregistrement

La couche 6 regroupe les systèmes qui font foi : ERP, CRM, systèmes de dossiers, entrepôts de données et SaaS. Ils sont exposés aux agents tels quels. L'entreprise agentique ne les remplace pas et ne les contourne pas : elle les appelle par leurs interfaces, sous leurs propres contrôles.

EXIG-ARC-17 · DOIT
Écriture par les interfaces qui appliquent les règles métier
Un agent **DOIT** écrire dans un système d'enregistrement uniquement par une interface qui applique les contrôles métier de ce système (API ou service métier), sans accès direct aux tables ni compte technique qui contourne ces contrôles.
Pourquoi : validations, séparation des tâches et journaux du système d'enregistrement sont des contrôles éprouvés; un agent qui les contourne annule cette assurance.

EXIG-ARC-18 · DEVRAIT
Référence de trace sur chaque écriture
Chaque écriture d'agent dans un système d'enregistrement **DEVRAIT** porter une référence de trace que le système cible conserve avec l'opération, en plus de la clé d'idempotence qu'exige l'EXIG-ORC-21 (section 7.6).
Pourquoi : lors d'un incident, on doit pouvoir remonter d'une ligne de l'ERP à la trace de l'agent qui l'a créée, et une reprise ne doit jamais créer de doublon.

5.3 Plans transversaux

Les trois plans transversaux fournissent à toutes les couches des services communs, conçus une fois et consommés partout; le tableau 11 indique ce que chacun apporte à chaque couche.

A — Identité et sécurité. Chaque agent reçoit une identité propre, délivrée par une infrastructure d'identité de charge de travail comme SPIFFE/SPIRE, projets diplômés de la Cloud Native Computing Foundation (CNCF)[116, 117], ou par fédération OpenID Connect (OIDC) infonuagique. Lorsqu'il agit pour une personne, il obtient un jeton délégué par échange de jetons (RFC 8693)[118]; le cadre exige que ce jeton soit de courte durée. Le plan fournit aussi le moteur de politiques, les paliers d'outils, le coffre de secrets, les garde-fous et l'approbation humaine signée (chapitre 9 et section 8.5).

B — Observabilité, évaluation et FinOps. Les couches 1 à 5 émettent des traces OpenTelemetry reliées par un même contexte W3C Trace Context[103], selon une version épinglée des conventions GenAI, qui distinguent notamment les spans `invoke_workflow`, `invoke_agent` et `execute_tool`[119, 120]. S'y ajoutent le journal d'audit chaîné et ancré, distinct des traces, l'évaluation continue et la mesure du coût par tâche réussie (chapitre 10).

C — Gouvernance et registre. Le registre des agents et des serveurs MCP porte la classe de risque, le niveau d'autonomie (N0 à N4), le parrain, le responsable technique et l'état du cycle de vie de chaque agent (chapitre 11). Les plans de contrôle des éditeurs couvrent une partie de ce rôle, sans le couvrir entièrement : Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, offre un registre et des contrôles comme le blocage des agents non gérés, mais les actions de cycle de vie sur des agents infonuagiques tiers y sont encore annoncées comme à venir[46]. D'où l'exigence d'un coupe-circuit appliqué à la passerelle à tout agent qui la traverse, quel que soit son éditeur (section 9.4); un agent qui s'exécute chez l'éditeur d'un logiciel-service est arrêté par le mécanisme propre de l'EXIG-ARC-21.

Tableau 11 — Apport des plans transversaux à chaque couche

Couche	A — Identité et sécurité	B — Observabilité, évaluation, FinOps	C — Gouvernance et registre
1. Canaux et déclencheurs	Authentification de la personne ou du service; établissement du mandant	Ouverture de la trace; latence perçue	Canaux autorisés par agent; avis à la personne qu'elle interagit avec un agent (section 12.7)
2. Orchestration et état	Jeton délégué de la tâche; approbations humaines signées	Spans de flux; enveloppe budgétaire de la tâche	Patron d'orchestration et niveau d'autonomie déclarés
3. Agents et exécution cognitive	Identité propre par agent; garde-fous d'entrée et de sortie	Spans d'agent et d'inférence; jetons et coût par appel; évaluation continue	Versions de l'agent et du modèle inscrites; classe de risque
4. Médiation et connectivité	Point d'application des politiques; coupe-circuit	Journalisation de chaque appel; propagation du contexte de trace	Catalogue, versions épinglées, liste d'autorisation
5. Outils et données	Portées par outil; jetons à audience unique; secrets injectés hors de l'agent	Spans d'outil; erreurs par outil	Palier P0 à P3, propriétaire, compensation déclarée
6. Systèmes d'enregistrement	Contrôles d'accès natifs conservés	Corrélation par référence de trace et clé d'idempotence	Classification des données; EFVP pour tout projet d'acquisition, de développement ou de refonte de système impliquant des RP, et avant leur communication hors Québec (section 12.2)

EXIG-ARC-19 · DOIT
Services transversaux mutualisés
Les services des plans transversaux (identité des agents, moteur de politiques, coffre de secrets, collecte de télémétrie, journal d'audit, registre) **DOIVENT** être fournis par l'équipe plateforme (section 11.1) et consommés par toutes les couches. Un projet **DOIT** obtenir une dérogation pour en déployer un équivalent parallèle (section 11.6).
Pourquoi : un registre ou une chaîne de télémétrie parallèle crée un angle mort que ni le comité ni l'équipe de garde ne voient.

5.4 Blocs de construction

Cette section relie les rôles de l'architecture aux produits qui peuvent les remplir. Le cadre reprend la distinction de TOGAF : les blocs de construction d'architecture (ABB) capturent les exigences et orientent le développement des blocs de construction de solution (SBB); les SBB désignent les produits et composants qui mettent en œuvre la fonction et dépendent du produit ou du fournisseur[121]. Le passage des uns aux autres est itératif : les ABB se définissent surtout aux phases A à D de la méthode de développement d'architecture (ADM), puis se raffinent en SBB, dont l'identification relève surtout de la phase E[121]. Concrètement, « passerelle d'agents » est un ABB neutre et durable; le produit retenu pour la réaliser est un SBB remplaçable.

EXIG-ARC-20 · DOIT
Correspondance ABB-SBB documentée
Toute solution agentique présentée à l'homologation **DOIT** documenter la correspondance entre les ABB du tableau 12 et les SBB qu'elle emploie. L'homologation **DOIT** être refusée tant qu'un ABB du tableau 12 nécessaire à la solution n'a pas de SBB désigné. Sont toujours nécessaires la passerelle d'agents (EXIG-ARC-01) et les services des plans transversaux (EXIG-ARC-19), ainsi que, selon la solution, le moteur d'exécution durable pour toute écriture ou approbation (EXIG-ARC-05), la passerelle de modèles pour toute inférence (EXIG-ARC-08) et le bac à sable pour tout code généré (EXIG-ARC-10); une solution ne peut déclarer non nécessaire un ABB qu'exige l'une de ces exigences.
Pourquoi : la correspondance révèle les rôles orphelins, par exemple un agent sans passerelle de modèles, avant qu'ils ne deviennent des incidents.

EXIG-ARC-21 · DOIT
SBB exposés par les standards retenus
Un SBB **DOIT** exposer ses fonctions d'interopérabilité par les standards retenus au catalogue des protocoles (section 6.3), de sorte qu'on puisse le remplacer sans réécrire les agents. Une fonction offerte seulement par une interface propriétaire exige une dérogation. PRIN-09, l'EXIG-ARC-03 et l'EXIG-ARC-08 visent les agents dont l'entreprise contrôle l'exécution. Un agent intégré à un logiciel-service, qui s'exécute chez son éditeur, **DOIT** : être inscrit au registre avec sa classe, son niveau d'autonomie et les actions qu'il exécute dans le logiciel-service; n'atteindre les systèmes d'enregistrement de l'entreprise que par la passerelle d'agents, comme client externe; relever d'un contrat qui comporte les clauses des EXIG-APP-05, EXIG-APP-06, EXIG-APP-08 et EXIG-APP-13, dont un préavis opposable de changement de modèle; disposer d'un mécanisme d'arrêt propre (fournisseur d'identité, retrait des consentements OAuth, CAEP), documenté à la fiche et éprouvé à l'exercice de l'EXIG-SEC-26; et n'employer que des schémas d'outils de tiers épinglés et approuvés au catalogue (EXIG-INT-02). Une action P3 exécutée dans le logiciel-service exige un mécanisme d'approbation du

> fournisseur jugé équivalent à l'EXIG-AUT-12 à l'homologation; à défaut, l'agent est plafonné à N2, et chaque action P3 est approuvée dans la console de l'éditeur, approbation consignée à la fiche. La quarantaine (EXIG-GOV-10) et la suspension d'un tel agent passent par son mécanisme d'arrêt propre, et non par la passerelle.
>
> Pourquoi : le risque de verrouillage s'est déplacé des protocoles vers les plateformes et leurs extensions (section 13.1), et un agent qui infère et agit chez son éditeur ne peut ni passer par la passerelle de modèles ni être arrêté par la passerelle d'agents; les contrôles compensatoires portent donc sur l'accès aux systèmes de l'entreprise, les contrats et les identités.

Les exemples du tableau sont non limitatifs et établis au 27 octobre 2026. Ils ne constituent ni une exigence ni une recommandation d'achat; l'architecture d'entreprise les révise chaque trimestre, avec le catalogue des protocoles (section 11.7). Un SBB qui ne couvre pas toutes les capacités exigées de son ABB (par exemple une passerelle limitée aux outils MCP, ou un environnement d'exécution sans A2A ni OpenTelemetry documentés) n'est admis qu'avec un SBB complémentaire ou une dérogation (EXIG-ARC-21); à défaut, l'homologation est refusée (EXIG-ARC-20).

Tableau 12 — Correspondance des blocs de construction d'architecture (ABB) et des blocs de construction de solution (SBB)

Couche	ABB	Capacités exigées	Exemples de SBB (non limitatifs, état au 27 octobre 2026)
1. Canaux et déclencheurs	Interface conversationnelle et d'approbation; déclencheurs système	Authentifier, établir le mandant, ouvrir la trace, diffuser en continu, montrer l'action exacte à approuver	Portails et outils de collaboration existants; canaux intégrés des logiciels-services (dernière ligne); webhooks et planificateurs
2. Orchestration et état	Moteur d'exécution durable; orchestrateur et routeur; magasin d'état	Persistance après chaque transition, reprise, attente d'approbation, compensation	Temporal, dont l'intégration avec l'OpenAI Agents SDK est en disponibilité générale depuis le 23 mars 2026[122]; AWS Step Functions; LangGraph 1.0 avec persistance intégrée de l'état d'exécution (checkpointer)[123, 124]; Microsoft Agent Framework 1.0[125]; agents de flux de Google ADK[126]
3. Agents et exécution cognitive	Environnement d'exécution d'agents	Boucle d'agent, appels MCP et A2A, télémétrie OpenTelemetry, indépendance du modèle	OpenAI Agents SDK (boucle d'agent, MCP, traçage intégré et fournisseurs non OpenAI; A2A et OpenTelemetry non documentés), Strands Agents, Google ADK, Microsoft Agent Framework, LangGraph[127, 128, 129]; AgentCore Runtime
3. Agents et exécution cognitive	Passerelle de modèles	Identifiants centralisés, routage, repli, cache, quotas de jetons, imputation des coûts	Agent Router (AAIF)[130]; fonction de passerelle de modèles d'agentgateway[131]; Kong AI Gateway[132]; Azure API Management
3. Agents et exécution cognitive	Bac à sable de code	Isolation par microVM, noyau applicatif ou environnement WebAssembly sans autorité ambiante, réseau fermé par défaut, exécution éphémère	MicroVM Firecracker[133]; gVisor[134]; Kata Containers[135]; WebAssembly et WASI[136]; agent-sandbox pour Kubernetes[137]
4. Médiation et connectivité	Passerelle d'agents (PEP pour MCP et A2A)	Mandataire inverse en entrée et mandataire sortant en sortie, autorisation par appel, garde-fous, plafonds, journalisation, coupe-circuit	agentgateway, projet de l'AAIF sous licence Apache 2.0[31]; Azure API Management (outils MCP seulement, agents A2A en JSON-RPC seulement)[108, 109]; AgentCore Gateway[110]; Kong AI Gateway[132]; MuleSoft Agent Fabric et sa passerelle Flex Gateway[138]; IBM ContextForge (licence Apache 2.0; mo-

Couche	ABB	Capacités exigées	Exemples de SBB (non limitatifs, état au 27 octobre 2026)
			dèle de soutien non précisé par le projet)[113]; portails MCP de Cloudflare[139]
4. Médiation et connectivité	Catalogue d'entreprise et registre privé	Source unique des outils, cartes et contrats; versions et empreintes; cycle de vie	Azure API Center; AgentCore Registry (publication, revue et approbation)[102]; Agent Registry de MuleSoft Agent Fabric
4. Médiation et connectivité	Bus d'événements	Enveloppe CloudEvents, contrats AsyncAPI, rétention et rejeu	Apache Kafka, qui garantit par défaut une livraison au moins une fois[140]; services infonuagiques équivalents
5. Outils et données	Serveurs MCP de domaine et adaptateurs	Outils conçus pour la tâche, effets déclarés, filtrage selon le mandant	Conversion d'API en outils par AgentCore Gateway, Azure API Management ou IBM ContextForge; serveur MCP Action Fabric de ServiceNow[50]
5. Outils et données	Index et graphes de connaissances	Recherche hybride avec citations, provenance, validité temporelle	GraphRAG (génération augmentée par récupération sur graphe); Zep et Graphiti (section 5.5)
6. Systèmes d'enregistrement	Systèmes existants	Contrôles métier conservés; corrélation des écritures	Aucun nouveau SBB : seuls des adaptateurs s'ajoutent
Plan A	Identité de charge de travail; serveur d'autorisation; moteur de politiques; coffre de secrets; garde-fous; service d'approbation humaine signée	Identité par agent, jetons délégués, décision par appel; secrets jamais exposés à l'agent (EXIG-SEC-14); approbation signée par une personne (section 8.5)	SPIFFE/SPIRE; Microsoft Entra Agent ID[90]; AgentCore Identity et AgentCore Policy (langage de règles compatible avec Cedar)[102]; coffre de secrets, garde-fous et service d'approbation : SBB à désigner à l'homologation (EXIG-ARC-20), sans exemple retenu ici
Plan B	Collecte et traitement de la télémétrie; évaluation; journal d'audit; budgets et quotas	Collecte OpenTelemetry, caviardage, évaluation continue; journal d'audit chaîné, signé et ancré (EXIG-OBS-12, EXIG-OBS-13); enveloppes et quotas de coûts (EXIG-FIN-04, EXIG-FIN-05)	OpenTelemetry Collector et son processeur de caviardage (redaction)[141]; AgentCore Observability et Evaluations[102]; journal d'audit et budgets : SBB à désigner à l'homologation (EXIG-ARC-20), sans exemple retenu ici
Plan C	Registre et plan de contrôle des agents	Inventaire, quarantaine, cycle de vie, coupe-circuit	Microsoft Agent 365; ServiceNow AI Control Tower[47, 51]; AgentCore Registry; MuleSoft Agent Fabric
Couches 1 à 3	Logiciel-service à agents intégrés	MCP et A2A natifs, identité par agent, télémétrie exportable; contrôles compensatoires de l'EXIG-ARC-21 (accès aux systèmes de l'entreprise par la passerelle, clauses contractuelles, arrêt propre)	Microsoft Copilot Studio (A2A en disponibilité générale depuis avril 2026; identité Entra Agent ID créée pour chaque nouvel agent)[48]; Salesforce Agentforce (A2A entrant et sortant, client et serveur MCP)[49]; ServiceNow AI Agent Fabric

Les performances annoncées par les fournisseurs, comme celles d'agentgateway[142] et de TrueFoundry[143, 144], ne remplacent pas une mesure (encadré de la section 9.4).

5.5 Mémoire des agents

Cette section distingue le contexte du modèle de la mémoire, définit quatre types de mémoire et fixe les contrôles qui encadrent leur écriture.

Le contexte n'est pas une mémoire

Les fenêtres de contexte atteignent environ un million de jetons chez les modèles de pointe, par exemple GPT-5.4 d'OpenAI (mars 2026, 1,05 million) et Gemini 2.5 Pro ou Gemini 3 Pro de Google (1 million) de jetons[145, 146, 147]. Elles ne rendent pas la mémoire inutile, pour trois raisons. D'abord, la qualité baisse quand le contexte s'allonge : les modèles exploitent mieux l'information placée au début ou à la fin de l'entrée qu'au milieu, même lorsqu'ils sont conçus pour les longs contextes[148]. Anthropic décrit ce phénomène de « pourrissement du contexte » *(context rot)* : le rappel diminue à mesure que les jetons s'accumulent, et le contexte doit être traité comme une ressource finie[149]; une étude de Chroma sur 18 modèles montre qu'un seul distracteur suffit à réduire la performance[150]. Ensuite, chaque jeton réinjecté se paie à chaque appel. Enfin, le contexte disparaît à la fin de la session. La règle qui en découle : ce qui doit durer est persisté hors du modèle, puis récupéré au moment où il sert.

Quatre types de mémoire

Le cadre reprend la taxonomie CoALA (Sumers et coll., 2024), qui distingue une mémoire de travail à court terme et trois mémoires à long terme : épisodique (expériences passées), sémantique (connaissances sur le monde et sur l'agent lui-même) et procédurale (savoir-faire)[100]. Pour CoALA, la mémoire procédurale comprend aussi les poids du modèle; l'ajustement des modèles étant hors de la portée du cadre, celui-ci la limite aux invites système, aux contrats de compétences et aux flux d'outils validés. LangChain applique la même grille : des faits sur l'utilisateur relèvent de la mémoire sémantique, des exemples tirés d'actions antérieures de la mémoire épisodique, et l'invite système de la mémoire procédurale[151]. La figure 4 et le tableau 13 en présentent l'organisation.

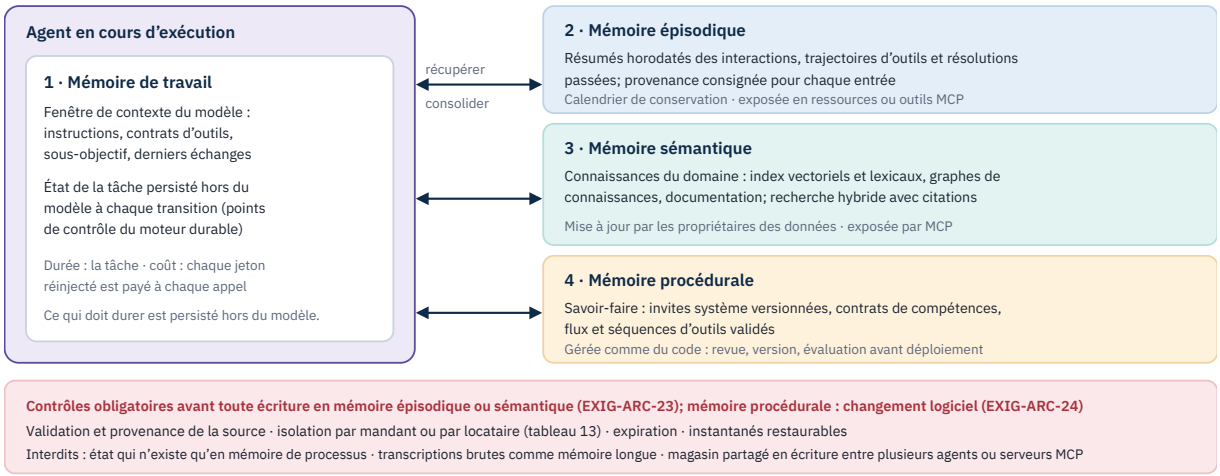


Figure 4 — Quatre types de mémoire et contrôles d'écriture. La mémoire de travail vit dans le contexte du modèle et dans les points de contrôle du moteur durable; les trois mémoires longues sont persistées hors du modèle et récupérées au besoin; les mémoires épisodique et sémantique sont protégées par les contrôles d'écriture de l'EXIG-ARC-23, la mémoire procédurale par le processus de changement logiciel (EXIG-ARC-24). Le tableau 13 fait foi pour l'isolation de chaque type. Source : cadre CRE-IA-2026-01, d'après la taxonomie CoALA (Sumers et coll., 2024).

Tableau 13 — Types de mémoire des agents et contrôles applicables

Type	Contenu	Durée de vie	Exposition	Contrôles
Travail	Instructions, contrats d'outils, sous-objectif, derniers échanges; état de la tâche	La tâche; état persisté à chaque transition	Fenêtre de contexte; points de contrôle du moteur durable	Contexte minimal, compaction, aucun état qui n'existe qu'en mémoire de processus (EXIG-ARC-05)
Épisodique	Résumés horodatés des interactions, trajectoires	Durée liée à la finalité, avec expi-	Ressources ou outils MCP	Provenance de chaque entrée, filtrage des RP, isolation par locataire,

Type	Contenu	Durée de vie	Exposition	Contrôles
	d'outils, résolutions passées	ration par entrée (EXIG-CON-10)		par mandant et par serveur MCP, expiration par entrée (EXIG-ARC-23)
Sémantique	Connaissances du domaine : index vectoriels et lexicaux, graphes de connaissances, documentation	Tant que la source est valide	Ressources ou outils MCP; recherche hybride avec citations	Mise à jour par les propriétaires des données; isolation par locataire et par serveur MCP; filtrage en lecture selon les droits effectifs (EXIG-ARC-16); expiration avec la validité de la source (EXIG-ARC-23)
Procédurale	Invites système versionnées, contrats de compétences, flux et séquences d'outils validés	La version de l'agent	Déployée avec l'agent; inscrite au registre	Revue, version, évaluation avant déploiement; aucune modification par l'agent

Écrire en mémoire longue

L'écriture peut se faire dans le chemin critique, en temps réel (transparente, mais plus lente), ou en arrière-plan (sans latence, mais avec une fréquence à choisir)[151]. Le cadre accepte les deux modes, à condition qu'ils passent par les mêmes contrôles. En arrière-plan, le tampon des transcriptions en attente de consolidation porte l'identité du mandant captée pendant la session, est chiffré, a une durée de rétention maximale déclarée à la fiche et est purgé après la consolidation. Anthropic, pour son outil mémoire exécuté côté client, exige de valider chaque chemin d'accès contre la traversée de répertoires et recommande de filtrer les données sensibles avant l'écriture, de plafonner la taille des fichiers et de supprimer les mémoires longtemps inutilisées[152]. Les renseignements personnels conservés en mémoire sont détruits ou anonymisés une fois leurs fins accomplies, comme l'exige l'article 23 de la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1, ci-après « Loi sur le privé ») (EXIG-CON-10, section 12.2).

EXIG-ARC-22 · NE DOIT PAS

Pas d'historique brut comme mémoire

L'historique brut des échanges **NE DOIT PAS** être réinjecté dans le contexte du modèle au-delà de la borne de contexte, exprimée en jetons, que déclare la fiche de l'agent (annexe B), ni conservé tel quel comme mémoire longue. Au-delà de cette borne, l'historique est compacté; ce qui doit durer est consolidé (résumé, fait, décision), persisté hors du modèle et récupéré au besoin.

Pourquoi : un historique brut coûte à chaque appel, dégrade le rappel et accumule du bruit sans limite.

EXIG-ARC-23 · DOIT

Contrôles avant toute écriture en mémoire épisodique ou sémantique

Toute écriture en mémoire épisodique ou sémantique **DOIT** passer par des contrôles qui consignent la provenance de l'entrée, valident sa source, retirent les secrets et les renseignements personnels non nécessaires et permettent de restaurer un instantané antérieur. En mémoire épisodique, l'entrée est en outre isolée par locataire, par mandant et par serveur MCP, et porte une date d'expiration (EXIG-CON-10). En mémoire sémantique, connaissance partagée du domaine, elle est isolée par locataire et par serveur MCP, filtrée en lecture selon les droits effectifs (EXIG-ARC-16) et expire avec la validité de sa source. Valider la source d'un résumé produit par un modèle, c'est le contrôler contre un schéma qui fixe les champs admis et exclut le texte libre issu des outils. Une entrée écrite par une session marquée porte l'étiquette de cette session (EXIG-SEC-04); toute entrée relue est un contenu non fiable (EXIG-SEC-03), et l'outil de mémoire est marqué au catalogue.

Pourquoi : une information fausse inscrite en mémoire oriente toutes les décisions suivantes; l'OWASP en fait un risque distinct, l'empoisonnement de la mémoire et du contexte (ASI06 *Memory & Context Poisoning*)[28].

EXIG-ARC-24 · DOIT
Mémoire procédurale gérée comme du code
Toute modification de la mémoire procédurale (invites système, contrats de compétences, flux et séquences d'outils validés) **DOIT** suivre le processus de changement logiciel : revue, version, évaluation avant déploiement et inscription au registre. Un agent **DOIT** être privé de tout droit d'écriture sur sa propre mémoire procédurale en production.
Pourquoi : CoALA juge l'écriture en mémoire procédurale nettement plus risquée que l'écriture épisodique ou sémantique[100]; elle change le comportement de l'agent pour toutes les tâches à venir, comme un déploiement de code.

EXIG-ARC-25 · NE DOIT PAS
Aucun magasin de mémoire longue partagé en écriture
Une mémoire longue **NE DOIT PAS** être accessible en écriture directe à plus d'un composant, agent ou serveur MCP; le partage passe par des ressources en lecture seule ou par un service de mémoire qui applique les contrôles de l'EXIG-ARC-23, n'accepte que des écritures conditionnelles (ETag ou numéro de version) et tient un journal des écritures. Chaque écrivain direct a sa propre identité de charge de travail et son propre espace de noms dans le magasin.
Pourquoi : le Centre d'architecture Azure proscrit le partage d'état mutable entre agents concurrents[9]; un magasin partagé permet à un composant compromis d'empoisonner tous les autres.

ANTI-PATRONS PROSCRITS

- Conserver un état qui n'existe qu'en mémoire de processus : le *checkpointer* en mémoire de LangGraph, par exemple, perd ses points de contrôle au redémarrage[124].
- Archiver les transcriptions brutes comme mémoire longue.
- Partager en écriture une table de mémoire entre plusieurs agents ou serveurs MCP.
- Stocker des secrets, des jetons ou des approbations dans le contexte du modèle ou en mémoire longue (l'état d'orchestration ne conserve qu'une référence à l'approbation signée et au jeton, dans le magasin protégé de l'EXIG-ARC-06).
- Laisser un agent réécrire ses propres invites système ou contrats de compétences.

Plusieurs technologies réalisent ces rôles; elles sont citées à titre d'exemples non normatifs. LangGraph sépare les *checkpointers*, qui conservent l'état par fil d'exécution, d'un magasin distinct pour la mémoire à long terme partagée entre fils[124]. Letta maintient le patron MemGPT, qui déplace l'information entre le contexte et un stockage externe à la manière d'une mémoire virtuelle[153, 154]. Zep s'appuie sur Graphiti, un graphe de connaissances temporel qui conserve l'historique des relations, utile pour l'audit puisqu'on peut savoir à quel moment un fait était vrai[155]. GraphRAG construit un graphe d'entités et des résumés de communautés qui aident à répondre aux questions de synthèse sur un vaste corpus[156]. Le cadre ne fixe ni produit ni latence cible : ces paramètres se mesurent dans l'environnement de l'entreprise.

5.6 Parcours d'une demande de bout en bout

Cette section suit une demande à travers les six couches pour montrer comment les règles s'enchaînent. Exemple : une conseillère du service à la clientèle demande l'émission d'un avoir de 1 200 $ sur la facture d'un client. L'agent de facturation est de classe de risque modérée, plafonné au niveau N3, car aucun avoir qu'il peut émettre n'excède le seuil de classe que la fonction risques et conformité arrête pour lui (tableau

46); l'outil `emettre_avoir` est de palier P2 (écriture réversible), et le catalogue lui fixe un seuil d'exécution autonome de 500 $, valeur propre à l'exemple et distincte du seuil de classe.

1. **Canal.** La conseillère formule sa demande dans l'outil de collaboration. Le canal l'authentifie, établit le mandant, ouvre la trace et transmet l'intention sans la transformer (EXIG-ARC-03, EXIG-ARC-04).
2. **Routage.** Le routeur qualifie l'intention (« émettre un avoir ») et choisit le flux déterministe de traitement des avoirs inscrit au catalogue d'entreprise, plutôt qu'un agent libre; ce choix ne confère aucun droit (EXIG-ARC-07).
3. **Ouverture de la tâche.** Le moteur d'exécution durable crée la tâche, lui attribue son enveloppe budgétaire (jetons, coût, appels d'outils, délai) et obtient pour l'agent un jeton délégué au nom de la conseillère, destiné à la passerelle (section 9.3); l'état est persisté.
4. **Raisonnement.** L'étape d'analyse invoque l'agent de facturation, qui appelle son modèle par la passerelle de modèles; celle-ci résout l'alias, applique les quotas et impute jetons et coût au centre de coûts (EXIG-ARC-08, EXIG-ARC-09).
5. **Lecture.** L'agent appelle l'outil MCP `consulter_situation_compte` (palier P1) par la passerelle d'agents, qui vérifie le catalogue, obtient en tant que client, par échange de jetons (RFC 8693, paramètre `resource` de la RFC 8707), un jeton à audience unique pour ce serveur, et propage la trace; l'outil filtre ses résultats selon les droits de la conseillère (EXIG-ARC-16).
6. **Délégation éventuelle.** Si une vérification relève d'un autre domaine, la conformité par exemple, une branche du flux, déclarée au registre, délègue la sous-tâche par A2A à l'agent de ce domaine, toujours par la passerelle; la séquence détaillée figure à la section 6.6.
7. **Approbation.** L'agent prépare l'appel à `emettre_avoir`. Le montant, calculé par la passerelle à partir des arguments, dépasse le seuil déclaré : le moteur suspend la tâche, état persisté, et l'action exacte est présentée à une approbatrice, dont la décision produit un jeton signé lié à cette action, remis à la passerelle et jamais à l'agent (section 8.5).
8. **Écriture.** Le moteur reprend la tâche, et l'agent rejoue l'appel avec sa clé d'idempotence et la référence de la demande d'approbation. La passerelle obtient un nouveau jeton délégué, ce qui revérifie les droits actuels de la conseillère (EXIG-IAM-02), apparie à l'appel le jeton d'approbation qu'elle conserve et le relaie; l'approbation sépare les tâches sans ajouter de droit, et la conseillère doit détenir elle-même le droit d'émettre l'avoir; le serveur MCP de facturation appelle l'API de l'ERP, qui applique ses propres contrôles et enregistre l'avoir avec la référence de trace (EXIG-ARC-17, EXIG-ARC-18).
9. **Résultat ou compensation.** L'artefact remonte au canal, et la conseillère reçoit la confirmation, avec la référence d'audit, une fois la dernière étape compensable terminée. Si une étape ultérieure échoue avant ce point sans reprise possible, le moteur exécute la compensation déclarée, ici l'annulation de l'avoir, sous l'identité de compensation de l'orchestrateur (EXIG-ORC-28), et en avise la conseillère et l'approbatrice (section 7.5).
10. **Audit et apprentissage.** Le journal d'audit consigne le mandant, l'agent et sa version, le modèle, l'outil et l'empreinte de ses arguments, ainsi que l'approbation (section 10.3). Les traces alimentent l'évaluation continue et le coût par tâche réussie; un résumé validé de la résolution entre en mémoire épisodique (EXIG-ARC-23).

À RETENIR

Trois éléments descendent avec chaque appel : le mandant, le contexte de trace et la part restante de l'enveloppe de la tâche. Trois éléments remontent : le résultat, ses artefacts et les mesures de coût et de qualité. En environnement serveur, aucun appel MCP ou A2A, quel que soit le domaine, ni aucune

action P2 ou P3 n'échappe à la passerelle, et aucune écriture n'atteint un système d'enregistrement sans ses propres contrôles métier.

6 Interopérabilité

Ce chapitre fixe la manière dont les agents de l'entreprise se relient aux outils, aux données, aux autres agents, aux événements et aux personnes. Il s'appuie sur des protocoles ouverts sous gouvernance neutre : MCP pour l'intégration verticale (agent vers outil), A2A pour l'intégration horizontale (agent vers agent), CloudEvents et AsyncAPI pour les échanges asynchrones. Chaque intégration est examinée, de façon proportionnée, à deux ou à quatre niveaux, du juridique au technique, et n'emploie que des standards inscrits au catalogue, à une version fixée. Les sections 6.5 à 6.7 détaillent chaque protocole; les sections 6.8 et 6.9 traitent des contrats, du versionnage et de la veille.

6.1 Quatre niveaux d'interopérabilité et gouvernance intégrée

Une connexion technique ne suffit pas : deux agents qui échangent sans s'entendre sur le sens des données ni sur les responsabilités produisent des erreurs silencieuses. Le cadre transpose donc aux agents le modèle du Cadre européen d'interopérabilité *(European Interoperability Framework, EIF)*.

Le nouvel EIF, publié par la Commission européenne en 2017, décrit l'interopérabilité en quatre couches (juridique, organisationnelle, sémantique et technique), encadrées par une composante transversale, la gouvernance intégrée des services publics, et par une couche de fond, la gouvernance de l'interopérabilité[157, 158]. Il énonce 12 principes et 47 recommandations, dont la conclusion d'accords d'interopérabilité dans toutes les couches (recommandation 26)[157]. Le texte reste vivant : le règlement (UE) 2024/903 pour une Europe interopérable, en vigueur depuis le 11 avril 2024, confie sa mise à jour au comité pour une Europe interopérable[159]. L'EIF vise les services publics européens; le cadre en retient la structure, pas le champ d'application.

Appliqués aux agents, les quatre niveaux posent quatre questions simples :

- **Juridique** : l'échange respecte-t-il les lois et les contrats? Par exemple, un agent qui confie l'analyse d'une réclamation à l'agent d'un partenaire hébergé en Ontario communique des renseignements personnels à l'extérieur du Québec, ce qui exige une EFVP préalable (art. 17 de la Loi sur le privé)[160].
- **Organisationnel** : qui répond de quoi, de part et d'autre? L'EIF parle d'aligner les processus, les responsabilités et les attentes pour atteindre des objectifs communs[157].
- **Sémantique** : les parties comprennent-elles la même chose? L'EIF y inclut l'aspect syntaxique, soit le format exact des informations échangées, pour que ce qui est envoyé soit ce qui est compris[157].
- **Technique** : les systèmes peuvent-ils se joindre de façon sûre? Le niveau couvre les spécifications d'interface, les services d'interconnexion et d'intégration de données et les protocoles de communication sécurisés[157].

La gouvernance intégrée tient le tout dans la durée. L'EIF y exige notamment des structures, des rôles et des responsabilités définis, des ententes de niveau de service, la gestion des accords d'interopérabilité, des procédures de gestion du changement et des plans de continuité et de qualité des données, parce que les changements législatifs, organisationnels et technologiques perturbent régulièrement l'interopérabilité[157]. Dans le cadre, ce rôle revient au registre, au catalogue d'entreprise et au comité d'architecture et des risques agentiques (chapitre 11, figure 5).

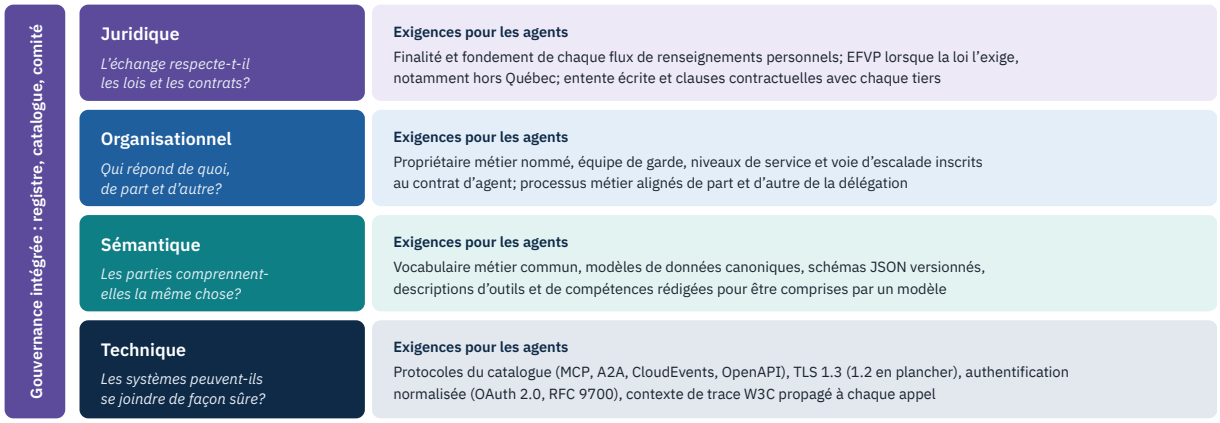


Figure 5 — Quatre niveaux d'interopérabilité appliqués aux agents. Chaque intégration d'agent se lit de haut en bas : le juridique fixe ce qui est permis, l'organisationnel désigne qui en répond, le sémantique établit le sens des données et le technique, la façon dont elles circulent. La gouvernance intégrée encadre les quatre niveaux. Source : adapté du nouveau Cadre européen d'interopérabilité (Commission européenne, 2017); exigences propres au cadre, dont le tableau 14 donne la formulation qui fait foi.

Tableau 14 — Niveaux d'interopérabilité et exigences minimales pour une intégration d'agent

Niveau	Question à trancher	Exigences minimales	Traité à
Juridique	L'échange respecte-t-il les lois et les contrats?	Finalité et fondement (consentement ou exception prévue par la loi) documentés pour chaque flux de renseignements personnels; EFVP lorsque la loi l'exige, notamment avant toute communication hors Québec; entente écrite avec chaque tiers; clauses contractuelles pour les agents et serveurs MCP de tiers.	Chapitres 12 et 13
Organisationnel	Qui répond de quoi, de part et d'autre?	Propriétaire métier nommé et équipe de garde de chaque côté; niveaux de service et voie d'escalade inscrits au contrat d'agent; processus métier modélisés et alignés de part et d'autre de la délégation.	Sections 11.1 et 11.4
Sémantique	Les parties comprennent-elles la même chose?	Vocabulaire métier commun; données de référence (taxonomies, listes de codes); schémas JSON Schema 2020-12 versionnés; unités, devises, assiettes de taxes et fuseaux horaires explicites; descriptions d'outils et de compétences rédigées pour être comprises par un modèle.	Section 6.8
Technique	Les systèmes peuvent-ils se joindre de façon sûre?	Protocole du catalogue à la version fixée; TLS 1.3 par défaut et TLS 1.2 toléré comme plancher (choix du cadre, conforme aux recommandations d'A2A[68, 161]); authentification normalisée; contexte de trace W3C propagé à chaque appel.	Sections 6.3 à 6.7; chapitres 9 et 10
Gouvernance intégrée (transversale)	L'échange restera-t-il interopérable dans le temps?	Accord d'interopérabilité pour toute intégration qui franchit la frontière d'un domaine métier ou de l'entreprise (EXIG-INT-03); gestion du changement des contrats; plan de continuité; fiche d'agent et catalogue à jour.	Section 6.8; chapitre 11
Gouvernance de l'interopérabilité (fond)	Qui choisit les standards et qui arbitre?	Catalogue des protocoles révisé chaque trimestre; dérogations instruites par le comité.	Sections 6.3, 11.6 et 11.7

EXEMPLE : UNE ERREUR QUE LE PROTOCOLE NE VOIT PAS

L'agent de facturation d'une filiale transmet par A2A un artefact dont le champ `montant` vaut 1 149,75. L'agent de rapprochement du siège le lit comme un montant hors taxes, alors qu'il inclut la TPS et la

TVQ. Les deux agents respectent le protocole à la lettre; seule la revue sémantique (schéma commun, unité et assiette déclarées) prévient l'écart.

EXIG-INT-01 · DOIT
Revue d'interopérabilité proportionnée
Toute intégration d'un agent avec un outil, une ressource, un autre agent ou un flux d'événements **DOIT** faire l'objet, avant sa mise en production, d'une revue proportionnée selon le tableau 14 : niveaux sémantique et technique pour une intégration intradomaine qui n'emploie que des outils P0 ou P1 et ne traite pas de renseignements personnels; les quatre niveaux, juridique, organisationnel, sémantique et technique, dans tous les autres cas. Le résultat **DOIT** être consigné dans la fiche d'agent (annexe B).
Pourquoi : une intégration techniquement valide peut être illicite, sans responsable ou fausse sur le sens; l'EIF promeut l'interopérabilité dès la conception[157].

EXIG-INT-02 · DOIT
Vocabulaire et schémas d'entreprise
Les données structurées échangées entre agents, entre agents et outils et sur le bus d'événements (arguments et résultats structurés d'outils, parties `data` des messages A2A, charges utiles d'événements) **DOIVENT** être décrites par des schémas JSON Schema 2020-12 versionnés (dans AsyncAPI 3.x, en déclarant explicitement `schemaFormat` à JSON Schema 2020-12, le format par défaut étant le Schema Object d'AsyncAPI; la chaîne d'outils qui lit ces contrats est éprouvée sur ce format avant l'inscription au catalogue, ou la validation JSON Schema 2020-12 s'exécute hors de l'outillage AsyncAPI lorsque celui-ci se limite au draft-07). Les schémas produits par l'entreprise **DOIVENT** s'appuyer sur le vocabulaire métier et les données de référence de l'entreprise (taxonomies, listes de codes, unités et devises explicites) et être gérés au niveau de l'entreprise, et non par chaque équipe d'agent. Un schéma de tiers (serveur MCP, carte d'agent ou contrat d'événement d'un éditeur ou d'un partenaire) **DOIT** être inscrit au catalogue avec son empreinte, épinglé et approuvé; sa correspondance avec le vocabulaire d'entreprise est tenue à l'adaptateur ou à la passerelle. Un schéma de tiers qui déclare un autre dialecte (`$schema`) est inscrit avec son dialecte et validé par un validateur de ce dialecte, ou converti à l'adaptateur ou à la passerelle; à défaut, il est refusé. Le contenu non structuré (parties `text`, `raw` et `url`, blocs texte) n'est pas visé par la présente exigence.
Pourquoi : l'EIF demande une gestion de l'information coordonnée au plus haut niveau et appuyée sur des données de référence[157]; JSON Schema 2020-12 est le dialecte par défaut de MCP[162, 163].

EXIG-INT-03 · DOIT
Accord d'interopérabilité et gestion du changement
Toute intégration qui franchit la frontière d'un domaine métier ou de l'entreprise **DOIT** être couverte par un accord d'interopérabilité, intégré au contrat d'agent ou d'outil, qui nomme le propriétaire de chaque partie, les niveaux de service, la voie d'escalade et la procédure de gestion du changement (préavis, période de coexistence, tests de non-régression).
Pourquoi : l'EIF recommande des accords d'interopérabilité dans toutes les couches et une gestion explicite du changement[157].

6.2 Carte des interactions et protocoles retenus

Le cadre associe un protocole à chaque type d'interaction d'un agent. La figure 6 situe ces interactions autour de l'agent : verticalement vers les outils, horizontalement vers les autres agents, de façon asynchrone vers le bus d'événements et, du côté humain, vers l'interface.

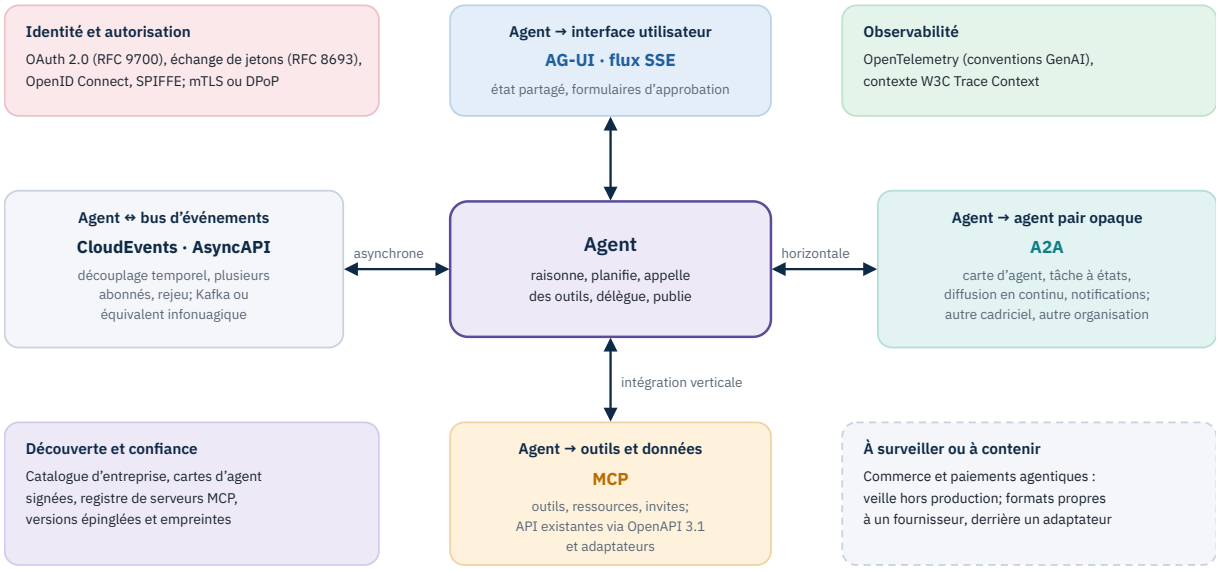


Figure 6 — Carte des interactions de l'agent et protocoles retenus. L'agent occupe le centre; chaque liaison correspond à un type d'interaction et au protocole retenu. Les cartes périphériques rappellent les fonctions transversales (identité, observabilité, découverte et confiance) et ce qui reste à surveiller ou à contenir : le commerce et les paiements agentiques au statut Surveiller (veille hors production), les formats propres à un fournisseur au statut Contenir (usage existant derrière un adaptateur). OAuth 2.0 y est profilé par la RFC 9700, le profil OAuth 2.1 restant un brouillon. Le tableau 15 fait foi pour les versions et les statuts. Source : cadre CRE-IA-2026-01; répartition MCP et A2A conforme au guide officiel du projet A2A.

- **Agent → outils et données : MCP.** La cible a des entrées et des sorties définies, souvent sans état; l'agent appelant garde la boucle de raisonnement. Les API existantes y sont exposées par des adaptateurs, sans réécriture (section 6.5).
- **Agent → agent : A2A.** La cible est un agent autonome, potentiellement opaque, qui raisonne, garde un état sur plusieurs tours et peut demander une précision (section 6.6).
- **Agent ↔ bus d'événements : CloudEvents et AsyncAPI.** L'émetteur ignore ses consommateurs; l'échange admet plusieurs abonnés, le découplage dans le temps et le rejeu des entrées (section 6.7).
- **Agent → interface : AG-UI ou flux SSE *(Server-Sent Events)* structuré.** AG-UI est un protocole ouvert et événementiel (31 types d'événements standard selon la documentation, licence MIT), né d'un partenariat de CopilotKit avec LangChain et CrewAI; il n'impose pas de transport (SSE, WebSockets, webhooks, etc.) et complète MCP et A2A[164, 165, 166]. Il demeure au statut Évaluer.

Cette répartition reprend le guide officiel du projet A2A : MCP relie un agent à des outils et à des ressources aux entrées et aux sorties définies, souvent sans état, alors qu'A2A relie des agents autonomes, potentiellement opaques, qui raisonnent et conservent un état sur des échanges à plusieurs tours[39]. Les deux se complètent : l'agent spécialiste joint par A2A utilise lui-même des outils MCP. L'événement comble un troisième besoin : un appel d'outil MCP est un échange requête-réponse point à point, sans rétention, ni rejeu, ni diffusion à plusieurs abonnés, alors qu'un journal d'événements persistant découple producteurs et consommateurs dans le temps (voir aussi Kai Waehner[167]).

Une question départage la plupart des cas : la cible choisit-elle elle-même ses actions? Elle est un agent si elle choisit elle-même, au moyen d'un modèle, les actions qu'elle exécute; sinon, c'est un outil, même si elle emploie un modèle en interne pour transformer une donnée, conserve l'état d'une tâche ou demande une précision (Tasks, élicitation MCP) (règle du cadre, tableau 7). Si l'émetteur ne doit pas connaître ses destinataires, c'est un événement. Tout appel MCP ou A2A, quel que soit le domaine, passe par la passerelle d'agents, et tout événement par le courtier (EXIG-ARC-01, EXIG-ARC-13; section 9.4); la documentation d'A2A recommande d'ailleurs fortement une solution de gestion d'API devant tout serveur exposé à l'externe[161].

À RETENIR

MCP pour ce qui s'exécute, A2A pour ce qui raisonne, l'événement pour ce qui se diffuse. Rien ne contourne les points d'application : la passerelle d'agents pour MCP, A2A et les actions P2 ou P3, la passerelle de modèles pour l'inférence et le courtier pour les événements (EXIG-EVT-07), tous alimentés par le catalogue d'entreprise.

EXIG-INT-04 · DOIT
Protocole désigné par type d'interaction
Chaque interaction d'un agent **DOIT** emprunter le protocole que le catalogue désigne pour son type : MCP pour l'accès aux outils, aux ressources et aux invites; A2A pour toute délégation à un agent d'un autre domaine, d'un autre cadriciel, d'un tiers ou d'un autre processus (EXIG-A2A-01, sauf coexistence bornée de l'EXIG-A2A-15); CloudEvents, décrit par un contrat AsyncAPI, pour les événements; pour l'interface utilisateur, AG-UI en pilote ou le flux SSE structuré produit par l'orchestrateur (tableau 15). L'appel d'inférence relève de l'EXIG-ARC-08. Tout format hors catalogue exige une dérogation (section 11.6); un format propriétaire inscrit au statut Contenir reste toléré derrière un adaptateur jusqu'à la date de son plan de sortie, sans nouvel usage (EXIG-INT-06).
Pourquoi : un protocole commun par type d'interaction ramène le maillage de N × M connecteurs à N + M contrats (chapitre 2) et permet à la passerelle d'appliquer une politique uniforme.

EXIG-INT-05 · DEVRAIT
Agent pair invoqué par A2A, pas déguisé en outil
Sous réserve de l'obligation d'employer A2A pour toute délégation à un agent d'un autre domaine, d'un autre cadriciel, d'un tiers ou d'un autre processus (EXIG-A2A-01), un sous-agent doté d'un cycle de vie de tâche propre **DEVRAIT** être invoqué comme pair plutôt que déguisé en simple outil sans état; l'enveloppe « agent comme outil » n'est permise qu'entre sous-agents d'un même orchestrateur, dans un même processus, selon le critère de la section 6.2.
Pourquoi : A2A expose le cycle de vie de la tâche (entrée requise, authentification requise, annulation, artefacts), que l'enveloppe en outil masque; l'approbation humaine et l'audit en dépendent[68].

6.3 Catalogue des protocoles et standards

Le catalogue des protocoles dit quel standard employer, à quelle version et avec quel degré de confiance. Il distingue ce qui est une norme publiée, ce qui n'est qu'un brouillon et ce qui relève encore de l'annonce. Chaque entrée porte l'un des cinq statuts suivants, éventuellement assorti d'une réserve :

- Adopter usage par défaut, exigé pour toute nouvelle intégration du type visé;
- Évaluer pilotes encadrés, derrière la passerelle d'agents (section 6.9); passage en production seulement après une décision du comité qui fait passer l'entrée au statut Adopter;

- Surveiller veille et essais hors production, sans données réelles;
- Contenir existant toléré derrière un adaptateur, sans nouvel usage, avec un plan de sortie daté;
- Suspendu prononcé pour un motif de sécurité (EXIG-INT-14, EXIG-GOV-14) : la passerelle cesse immédiatement de servir l'élément, sans attendre la fin d'une coexistence.

Tableau 15 — Catalogue des protocoles et standards (état au 27 octobre 2026)

Interaction	Standard et version de référence	Statut	Règle d'usage
Agent ⟶ outils et données	Model Context Protocol (MCP), révision 2026-07-28, courante au 27 octobre 2026[34, 168]; révision 2025-11-25 au statut Contenir jusqu'au 28 juillet 2027 (EXIG-MCP-22)	**Adopter**	Serveurs inscrits au catalogue et joints par la passerelle; Streamable HTTP en environnement serveur; extensions officielles (Tasks, Apps, extensions d'autorisation telles qu'OAuth Client Credentials et Enterprise-Managed Authorization, cette dernière au statut Évaluer), désactivées par défaut dans MCP, activées seulement si elles sont inscrites au catalogue[169]; l'autorisation de base relève du cœur de la spécification (6.5).
Agent ⟶ agent	Agent2Agent (A2A), version de protocole 1.0 (publication 1.0.0 du 12 mars 2026; correctif 1.0.1 du 28 mai 2026)[29, 30]	**Adopter**	Carte d'agent signée et inscrite; liaison JSON-RPC obligatoire; gRPC ou HTTP+JSON en complément (EXIG-A2A-08); en-tête `A2A-Version` à chaque requête; interfaces 0.3 seulement en coexistence bornée (6.6).
Agent ⟶ API existante	OpenAPI 3.1.x comme version de référence, 3.2.x admise (3.2.1 du 10 septembre 2026)[170]; erreurs au format RFC 9457[171]	**Adopter**	Aucun appel d'API sans contrat; exposition aux agents par des adaptateurs déclaratifs qui produisent des outils orientés tâche, sans réécrire les services.
Séquences d'appels d'API	Arazzo 1.1.0 (OpenAPI Initiative, 17 mai 2026)[172]	**Évaluer**	Description lisible par machine des flux déterministes d'appels d'API.
Schémas de données	JSON Schema 2020-12[163]	**Adopter**	Dialecte unique des contrats d'outils, de compétences et d'événements; aucun `$ref` vers une URI réseau non autorisée[162].
Événements asynchrones	CloudEvents 1.0 (révision 1.0.2) pour l'enveloppe; AsyncAPI 3.0 pour le contrat, versions 3.x ultérieures admises après essai de la chaîne d'outils[173, 174]	**Adopter**	Tout événement produit ou consommé par un agent; extensions de gouvernance et compteur de sauts (6.7), sous réserve : ces extensions documentées n'ont aucun statut officiel.

Interaction	Standard et version de référence	Statut	Règle d'usage
Identité et autorisation	OAuth 2.0 profilé par la RFC 9700 (BCP 240); OpenID Connect; échange de jetons (RFC 8693); SPIFFE et SPIRE, au stade « Graduated » de la CNCF[70, 116, 117, 175]	**Adopter**	Identité propre à chaque agent; jetons délégués à audience restreinte (chapitre 9).
Identité et autorisation	OAuth 2.1, Internet-Draft du groupe de travail OAuth, à la révision épinglée au catalogue (draft-ietf-oauth-v2-1-16 du 3 septembre 2026 à l'état des sources)[176]	**Adopter avec réserve**	S'aligner sur son profil (PKCE, ni octroi implicite ni octroi par mot de passe) sans le présenter comme une norme publiée.
Identité et autorisation	OAuth Client ID Metadata Document (CIMD), brouillon du groupe de travail OAuth de l'IETF (`draft-ietf-oauth-client-id-metadata-document-02` à l'état des sources; la spécification MCP 2026-07-28 renvoie à la version –00)[216]	**Adopter avec réserve**	Identification des clients MCP auprès d'un serveur d'autorisation tiers qui annonce la prise en charge (EXIG-MCP-12); sans le présenter comme une norme publiée.
Identité et autorisation	Identity Assertion JWT Authorization Grant (ID-JAG, brouillon de groupe de travail) et extension MCP Enterprise-Managed Authorization[177, 178]	**Évaluer**	Accès des employés aux serveurs MCP décidé par le fournisseur d'identité de l'entreprise.
Identité et autorisation	Transaction Tokens (draft-ietf-oauth-transaction-tokens-11)[179]	**Évaluer**	Propagation du contexte d'identité dans la chaîne d'appels interne d'un domaine.
Observabilité	OpenTelemetry; conventions sémantiques GenAI au niveau Development, version de référence v1.41.0 (ligne v1.41, correctif v1.41.1 admis), jusqu'à l'homologation d'une version étiquetée du dépôt `semantic-conventions-genai`[180, 181]	**Adopter**	Version émise par chaque composant consignée au catalogue; couche de correspondance versionnée dans le collecteur, qui la ramène à la version de référence (EXIG-OBS-01); attributs d'entreprise sous préfixe de domaine inversé (chapitre 10).
Observabilité	W3C Trace Context, Recommandation[103]	**Adopter**	Contexte propagé dans HTTP, dans le champ `_meta` de MCP, dans A2A et dans CloudEvents.
Agent ⟶ interface utilisateur	AG-UI (Agent-User Interaction Protocol)[164]	**Évaluer**	Pilotes. En production : flux SSE structuré produit par l'orchestrateur, patron interne au statut Adopter, dont le format d'événements est consigné au catalogue.
Infrastructure multiagent	AGNTCY : OASF (Open Agentic Schema Framework) et Agent Directory Service (ADS); SLIM (Secure Low-Latency Interactive Messaging) et Identity[182]	**Évaluer** OASF, ADS **Surveiller** SLIM, Identity	Projet de la Linux Foundation candidat à l'AAIF; aucune dépendance de production sans décision du comité (6.9).
Commerce et paiements agentiques	Agentic Commerce Protocol (OpenAI et Stripe), AP2, UCP[41, 183, 184]	**Surveiller**	Aucun paiement initié par un agent hors des règles de la section 6.9.

Interaction	Standard et version de référence	Statut	Règle d'usage
Réseaux d'agents ouverts, à identité décentralisée (DID du W3C)	Agent Network Protocol (ANP), projet communautaire[185, 186]	**Surveiller**	Aucune adoption en production.
Formats propres à un fournisseur	Variable	**Contenir**	Tolérés derrière un adaptateur, jamais exposés directement aux autres agents; plan de sortie daté.

Les versions sont épinglées au catalogue, pas dans chaque contrat d'agent : une montée de version se décide une fois, pour tout le parc (section 1.6). L'architecture d'entreprise révise le catalogue chaque trimestre et le comité en approuve les changements de statut (EXIG-GOV-18, section 11.7); pour un standard au statut Adopter ou Contenir, la publication d'une version incompatible, d'une dépréciation, d'un retrait accéléré ou d'un correctif de sécurité déclenche une révision extraordinaire, dans les 15 jours ouvrables.

ATTENTION : NORMES, BROUILLONS ET PRÉVERSIONS

Plusieurs entrées ne sont pas des normes publiées : OAuth 2.1, ID-JAG et Transaction Tokens sont des Internet-Drafts; les extensions documentées de CloudEvents (Auth Context, Data Classification, Distributed Tracing, etc.) n'ont aucun statut officiel et peuvent être modifiées ou retirées[187]; les conventions GenAI d'OpenTelemetry sont au niveau Development, où des changements incompatibles, voire un retrait, peuvent survenir sans garantie de dépréciation préalable[119, 188]; le registre officiel MCP est en préversion[43]. Le cadre les emploie pour ce qu'ils sont : à une version épinglée, derrière une couche d'adaptation.

EXIG-INT-06 · DOIT
Statut au catalogue avant tout usage en production
Tout nouvel usage en production d'un protocole, d'un standard ou d'une extension de protocole **DOIT** reposer sur une entrée du catalogue au statut Adopter. Un usage existant au statut Contenir reste permis derrière un adaptateur jusqu'à l'échéance de son plan de sortie, sans nouvel usage. Le statut Évaluer limite l'usage aux pilotes (EXIG-GOV-20); le statut Surveiller exclut tout usage en production; le statut Suspendu, prononcé pour un motif de sécurité, fait cesser immédiatement le service par la passerelle.
Pourquoi : l'ajout silencieux d'un protocole recrée les intégrations ad hoc que le cadre veut éliminer et soustrait les échanges aux contrôles de la passerelle.

EXIG-INT-07 · DOIT
Version de référence fixée au catalogue
Le catalogue **DOIT** fixer, pour chaque standard adopté, la version de référence (révision MCP, version de protocole A2A, version des conventions OpenTelemetry, de CloudEvents et d'AsyncAPI). Chaque serveur, agent et passerelle **DOIT** déclarer les versions qu'il prend en charge. Une déclaration est compatible si elle inclut la version de référence, ou une version au statut Contenir assortie d'une date de migration inscrite au catalogue (EXIG-MCP-22, EXIG-A2A-15); une déclaration incompatible **DOIT** bloquer l'inscription au catalogue.
Pourquoi : MCP et A2A rejettent explicitement une version non prise en charge (code `UnsupportedProtocolVersion` en MCP, erreur `VersionNotSupportedError` en A2A)[68, 162]; un parc aux versions mêlées échoue de façon imprévisible.

EXIG-INT-08 · DOIT
Révision trimestrielle du catalogue des protocoles
Chaque entrée du catalogue des protocoles **DOIT** porter la date de révision, le statut retenu et sa justification, et tout changement de statut **DOIT** être notifié aux parrains des agents qui emploient l'entrée. La périodicité de la révision et l'approbation des changements de statut relèvent de l'EXIG-GOV-18.
Pourquoi : entre mars 2025 et juillet 2026, MCP a publié quatre révisions (2025-03-26, 2025-06-18, 2025-11-25 et 2026-07-28) et A2A est passé de la version 0.1 à la version 1.0[30, 34, 189]; un catalogue figé devient faux en quelques mois.

EXIG-INT-09 · NE DOIT PAS
Brouillon présenté comme une norme publiée
Une exigence d'architecture, une clause contractuelle ou une entrée du catalogue **NE DOIT PAS** présenter un brouillon (Internet-Draft), une préversion ou une annonce de fournisseur comme une norme publiée. Le catalogue indique le statut exact de chaque élément : norme, recommandation, brouillon de groupe de travail, brouillon individuel, préversion ou projet hébergé par une fondation. Pour une extension qui déclare un stade de maturité (Experimental, Beta, Stable), le catalogue l'inscrit extension par extension, et une extension au stade Beta porte une réserve.
Pourquoi : un brouillon peut changer ou expirer (la révision –16 d'OAuth 2.1, du 3 septembre 2026, expirait le 7 mars 2027; la révision –17 l'a remplacée le 31 octobre 2026)[176]; une exigence qui s'y appuie doit pouvoir évoluer sans renégocier un contrat.

6.4 Matrice de sélection

La matrice traduit la carte de la figure 6 en règle de choix pour les cas courants. Elle se lit par scénario : le protocole découle du type de cible, du couplage recherché et de l'endroit où vit l'état.

Tableau 16 — Matrice de sélection des protocoles

Scénario	Protocole	Couplage	État côté appelé	Raison du choix
Processus connu à étapes fixes (réglementé ou audité)	Flux déterministe (chapitre 7) qui appelle des outils MCP ou des API	Piloté par le moteur	Dans le moteur d'exécution durable	Prévisible et auditable; le modèle n'intervient qu'aux étapes qui l'exigent.
Agent → outil, base de données ou moteur de recherche documentaire	MCP sur Streamable HTTP	Synchrone et court; réponse JSON ou flux SSE propre à la requête[190]	Aucun état cognitif; état applicatif par identifiant explicite, revalidé à chaque appel	Découverte des schémas et contrôle d'accès unifié à la passerelle.
Agent → traitement d'outil de longue durée	MCP avec l'extension officielle Tasks (stade Beta), si elle est inscrite au catalogue[191]	Asynchrone, par interrogation à l'intervalle annoncé par le serveur, avec un plancher inscrit au catalogue et un quota de tâches par mandant (EXIG-MCP-04)	Tâche durable (identifiant, durée de vie)	Évite de garder une connexion ouverte; annulation coopérative.
API REST existante → parc d'agents	Contrat OpenAPI exposé en outils MCP par un adaptateur de composition orienté tâche (EXIG-MCP-06)	Synchrone	Aucun	Réutilise le patrimoine d'API sans connecteur propre à chaque agent.
Agent → agent spécialiste, tâche in-	A2A	Lâche, par compétence; réponse bloquante, en continu ou par notification push	Tâche à états (huit états de cycle de vie en A2A 1.0,	Suivi de progression, demandes de pré-

Scénario	Protocole	Couplage	État côté appelé	Raison du choix
teractive ou en plusieurs tours			neuf valeurs d'énumération avec `TASK_STATE_UNSPECIFIED`)[192]	cision, échange d'artefacts entre cadriciels distincts.
Agent → agent d'une autre organisation	A2A par la passerelle, carte signée, jeton délégué	Lâche et contractuel	Tâche à états, opaque pour l'appelant	La confiance repose sur la signature de la carte, le contrat et l'échange de jetons, pas sur le réseau.
Système ou agent → plusieurs agents réactifs	CloudEvents et AsyncAPI sur le bus d'événements	Découplé (publication-abonnement)	Journal durable, rejouable dans la limite de la rétention[140]	Résilience, absorption des pointes, ajout d'abonnés sans toucher l'émetteur.
Agent → interface utilisateur riche	Flux SSE structuré produit par l'orchestrateur, à schéma d'événements versionné au catalogue d'entreprise (patron interne, statut Adopter, section 6.3); AG-UI en pilote seulement (statut Évaluer)	Temps réel	Session d'interface partagée	Synchronise l'état de l'agent et les formulaires d'approbation.

Lorsqu'un cas ne figure pas dans la matrice, quatre questions qualifient chaque liaison et préparent la soumission exigée par l'EXIG-INT-10. Elles ne sont pas exclusives : une même cible peut relever de MCP pour ses outils et du bus pour ses changements d'état, si bien que la quatrième question se pose pour toute liaison.

1. Les étapes sont-elles connues d'avance? Si oui, un flux déterministe orchestre le travail et n'emploie un agent qu'aux étapes de jugement.
2. La cible est-elle un outil ou une donnée aux entrées et aux sorties définies? Si oui, MCP.
3. La cible choisit-elle elle-même, au moyen d'un modèle, les actions qu'elle exécute? Si oui, c'est un agent, et A2A (EXIG-A2A-01); une cible qui conserve l'état d'une tâche ou demande une précision sans choisir ses actions reste un outil (MCP, extension Tasks, élicitation); au-delà de 5 secondes (seuil fixé par le cadre, EXIG-A2A-07), la diffusion en continu ou les notifications push s'imposent (section 6.6).
4. L'émetteur doit-il ignorer qui consomme, ou faut-il plusieurs abonnés ou un rejeu? Si oui, un événement.

La quatrième question repose sur le découplage logique, non sur le décompte des liaisons : relier N agents deux à deux exige jusqu'à N(N−1)/2 intégrations, mais la passerelle d'agents forme déjà une étoile à N connexions. Le bus apporte ce que la passerelle n'offre pas : le découplage dans le temps, des abonnés que l'émetteur ignore et le rejeu. La gouvernance des sujets, des schémas et des contrats reste entière.

> **`EXIG-INT-10` · DOIT**
> **Choix de protocole justifié par la matrice**
> Le protocole retenu pour chaque intégration **DOIT** être justifié dans la fiche d'agent par renvoi à une ligne du tableau 16. Un scénario absent de la matrice, ou un choix qui s'en écarte, **DOIT** être soumis à l'architecture d'entreprise avant la construction.

Pourquoi : la justification écrite rend le choix vérifiable en revue et alimente la mise à jour de la matrice.

EXIG-INT-11 · DEVRAIT
Diffusion d'un changement d'état par événement
Lorsqu'un changement d'état intéresse plusieurs consommateurs, l'agent ou le système émetteur **DEVRAIT** publier un événement plutôt qu'appeler chaque consommateur par A2A ou par MCP, comme le prévoit l'EXIG-EVT-01.
Pourquoi : l'appel direct couple l'émetteur à chaque consommateur et propage leurs pannes; le bus absorbe les pointes et accepte de nouveaux abonnés sans modifier l'émetteur.

6.5 Intégration verticale : Model Context Protocol

Cette section fixe la manière dont l'entreprise relie ses agents à leurs outils, à leurs ressources et à leurs invites au moyen du Model Context Protocol (MCP), dans sa révision 2026-07-28. Elle distingue ce que la spécification exige de ce que le cadre ajoute pour exploiter le protocole à l'échelle de l'entreprise : passerelle d'agents, catalogue d'entreprise, autorisation obligatoire et contrôles de sécurité propres au protocole. Les règles générales de contrat et de versionnage sont à la section 6.8; l'identité et la délégation, au chapitre 9.

Rôle et gouvernance du protocole

MCP normalise le lien vertical entre un agent et les systèmes qu'il consulte ou modifie. Au lieu d'écrire un connecteur pour chaque couple agent-système, on expose chaque système une seule fois par un serveur MCP, que tout agent conforme peut ensuite utiliser. Anthropic a annoncé MCP comme norme ouverte le 25 novembre 2024[20]. La formule « N × M » qui résume ce bénéfice (chapitre 2) est une vulgarisation, non un énoncé de la spécification.

Le 9 décembre 2025, Anthropic a donné MCP à l'Agentic AI Foundation (AAIF), fonds dirigé de la Linux Foundation cofondé par Anthropic, Block et OpenAI; MCP en est un projet fondateur, aux côtés de goose et d'AGENTS.md[4, 193]. Au lancement, les membres platine étaient Amazon Web Services, Anthropic, Block, Bloomberg, Cloudflare, Google, Microsoft et OpenAI[4]. Le modèle de gouvernance technique est resté inchangé : des responsables principaux arbitrent l'évolution de la spécification, qui progresse par des propositions d'amélioration (SEP, *Specification Enhancement Proposals*), tandis que le conseil de l'AAIF gère la stratégie, le budget et les adhésions[14]. Depuis la révision 2026-07-28, une SEP prend la forme d'une demande de tirage versée au dépôt de la spécification; une extension officielle suit une filière distincte et exige au moins une implémentation de référence dans un SDK officiel[168, 169]. Selon les responsables du projet, on comptait en décembre 2025 10 000 serveurs actifs et plus de 97 millions de téléchargements mensuels des SDK[14].

La spécification est versionnée par date : l'identifiant AAAA-MM-JJ correspond, selon la page Versioning de la spécification, au dernier changement incompatible qu'introduit la révision : c'est la date de sa publication, non celle du gel de sa version candidate. Les révisions publiées sont 2024-11-05, 2025-03-26, 2025-06-18, 2025-11-25 et 2026-07-28, révision courante au 27 octobre 2026[34, 168, 189]. Cette dernière a été publiée le 28 juillet 2026, après une version candidate verrouillée le 21 mai 2026 et dix semaines de validation; les SDK TypeScript, Python, Go et C# la prenaient en charge dès sa sortie, le SDK Rust en version bêta[33, 194]. La feuille de route publiée le 22 août 2026 n'annonce aucune date pour la prochaine révision; la SEP-3398, acceptée le 14 octobre 2026 et versée au dépôt le 27 octobre, fixe deux publications par an et la reporte au 30 mars 2027, sous réserve du calendrier de transition (annexe H). Elle donne priorité à la messagerie agentique, à un transport natif HTTP (y compris pour les serveurs locaux), à l'identité des agents et à la sécurité d'entreprise (DPoP, fédération d'identité de charge de travail, ID-JAG, échange de jetons), à un contrat unique pour les résultats de `tools/call` et à la découverte progressive des outils[195].

Le registre officiel MCP, lancé en préversion le 8 septembre 2025, l'est toujours selon sa documentation. Il n'héberge que des métadonnées qui renvoient aux paquets, authentifie les espaces de noms, délègue l'analyse de sécurité aux registres de paquets et ne prend pas en charge les serveurs privés; pour ceux-ci, il recommande d'héberger son propre registre MCP privé[25, 43]. Le catalogue d'entreprise est donc un composant distinct, sous la responsabilité de l'entreprise (section 6.8 et section 11.4).

`EXIG-MCP-01` · DOIT
Exposition des capacités par MCP, derrière la passerelle
Tout outil, toute ressource et toute invite mis à la disposition d'un agent **DOIVENT** l'être par un serveur MCP inscrit au catalogue d'entreprise et, dans tout environnement autre qu'un poste de développement individuel sans justificatif de production, publié derrière la passerelle d'agents, vers une version et une empreinte approuvées (sur ce poste, le serveur local obéit à l'EXIG-MCP-08). Seule en est dispensée la fonction locale de palier P0 ou P1 de l'EXIG-ARC-01, exécutée dans l'unité de déploiement de l'agent, sur les données de son propre domaine et inscrite au catalogue avec son palier; une action P2 ou P3 est toujours exposée comme outil MCP inscrit au catalogue. Un outil hébergé par le fournisseur de modèles n'est admis qu'au palier P0. Un hôte ne se connecte jamais directement à un serveur de domaine. Un format d'appel propriétaire n'est toléré que derrière un adaptateur, conformément au statut Contenir du catalogue des protocoles (section 6.3).
Pourquoi : un contrat unique, appliqué en un seul point, permet de filtrer, de journaliser et de révoquer l'accès sans modifier les agents.

`EXIG-MCP-02` · DOIT
Révision de référence vérifiée par la découverte
Tout serveur MCP mis en production après l'approbation du cadre **DOIT** mettre en œuvre la révision de référence épinglée au catalogue (valeur initiale : 2026-07-28), y compris la méthode `server/discover`. La révision prise en charge par chaque serveur est inscrite et épinglée au catalogue; la passerelle la vérifie par `server/discover` pour un serveur 2026-07-28, et par la réponse à `initialize` pour un serveur antérieur inscrit avec sa date de migration (EXIG-MCP-22), en contournant son propre cache (le résultat porte `ttlMs` et `cacheScope`), à l'homologation, à chaque déploiement et, pour un serveur de tiers, périodiquement, au plus tard à l'échéance de `ttlMs`, et refuse un serveur dont les versions ou capacités annoncées diffèrent de l'inscription.
Pourquoi : la spécification oblige tout serveur 2026-07-28 à implémenter `server/discover`, qui renvoie en une requête ses versions, ses capacités et son identité[168]; le catalogue dispose ainsi d'un relevé uniforme à comparer à l'inscription; ce relevé est déclaré par le serveur lui-même (`serverInfo` est auto-déclaré et ne devrait pas fonder une décision de sécurité) : il ne prouve ni l'identité ni l'intégrité du serveur.

Architecture hôte-client-serveur et primitives

MCP suit une architecture client-serveur à trois rôles. L'hôte est l'application d'IA : un orchestrateur, un agent ou un poste de travail. Il crée un client MCP pour chaque serveur, et chaque client entretient une connexion dédiée[63]. Le protocole comporte deux couches : une couche de données, faite d'échanges JSON-RPC 2.0 (découverte, primitives, notifications), et une couche de transport, qui règle la connexion, le tramage et l'autorisation[63]. Comme depuis la révision 2024-11-05, l'identifiant d'une requête ne peut pas être nul; en 2026-07-28, tout résultat porte en outre un champ `resultType`[162].

Un serveur expose trois primitives : les outils, fonctions exécutables découvertes par `tools/list` et appelées par `tools/call` sous le contrôle du modèle; les ressources, données contextuelles identifiées par URI et lues par `resources/list` et `resources/read`; les invites, gabarits réutilisables obtenus par `prompts/list` et `prompts/get`[63, 64]. Côté client, l'élicitation, qui permet au serveur de demander une information ou une

confirmation à la personne, demeure active; l'échantillonnage *(Sampling)* et les racines *(Roots)* sont dépréciés depuis 2026-07-28[196].

Dans l'entreprise, la passerelle d'agents s'insère entre les hôtes et les serveurs (figure 7). Elle agit en mandataire inverse et applique à chaque requête les contrôles décrits à la section 9.4. Elle peut publier chaque serveur sous son propre point d'accès ou en agréger plusieurs derrière un point d'accès virtuel. Pour l'hôte, un point d'accès virtuel est un serveur : il y crée un seul client. Dans tous les cas, elle préfixe les noms d'outils par l'identifiant de leur serveur au catalogue (EXIG-MCP-20) : la spécification signale le risque de collision de noms et précise que le nom annoncé dans `serverInfo` n'est pas garanti unique[197].

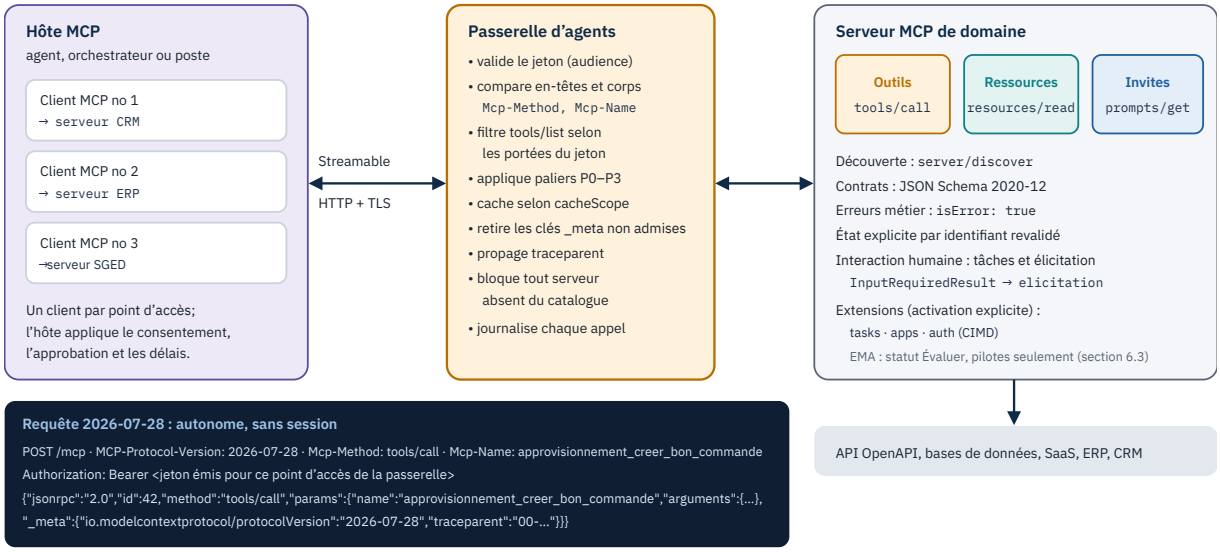


Figure 7 — MCP 2026-07-28 derrière la passerelle d'agents. L'hôte crée un client par point d'accès MCP (serveur publié ou point d'accès virtuel); chaque requête, autonome et sans session, traverse la passerelle, qui vérifie le jeton, la concordance des en-têtes et du corps, le palier de l'outil et le catalogue avant de joindre le serveur de domaine. La requête illustrée est abrégée : une requête complète porte aussi `jsonrpc` et `id`, ainsi que les capacités du client dans `_meta`. La passerelle « ignore » les clés `_meta` non reconnues en les retirant (EXIG-MCP-16). L'extension d'autorisation EMA qui y figure est au statut Évaluer : pilotes seulement (section 6.3). Le jeton présenté à la passerelle lui est destiné; elle en obtient un second pour le serveur de domaine (section 9.3). Source : cadre CRE-IA-2026-01, d'après la spécification MCP 2026-07-28[198].

Requête tools/call conforme à la révision 2026-07-28 (extrait)

```
POST /mcp HTTP/1.1
Host: passerelle-agents.ent.ca
Content-Type: application/json
Accept: application/json, text/event-stream
Authorization: Bearer <jeton émis pour ce point d'accès de la passerelle>
MCP-Protocol-Version: 2026-07-28
Mcp-Method: tools/call
Mcp-Name: approvisionnement_creer_bon_commande
Mcp-Param-Cost-Center: CC-4410

{"jsonrpc": "2.0", "id": 42, "method": "tools/call",
 "params": {
   "name": "approvisionnement_creer_bon_commande",
   "arguments": {"idempotency_key": "…", "centre_cout": "CC-4410", "…": "…"},
   "_meta": {
     "io.modelcontextprotocol/protocolVersion": "2026-07-28",
     "io.modelcontextprotocol/clientCapabilities": {"…": "…"},
     "traceparent": "00-…-…-01"}}}
```

Quatre traits ressortent. La requête se suffit à elle-même : aucun identifiant de session. Les en-têtes `Mcp-Method` et `Mcp-Name` recopient le corps pour permettre le routage sans l'analyser, d'où l'obligation de vérifier leur concordance (EXIG-MCP-15). Le jeton n'est valable que pour ce point d'accès de la passerelle (EXIG-MCP-11), qui obtient pour le serveur de domaine un second jeton par échange de jetons (section 9.3). Enfin, l'en-tête `Mcp-Param-Cost-Center` provient d'un argument marqué `x-mcp-header`; un centre de coûts s'y prête, une donnée sensible jamais (EXIG-MCP-18).

À RETENIR

Un serveur MCP est un adaptateur sans état cognitif : il expose des capacités à entrées et sorties définies et ne conduit pas la boucle de raisonnement de l'agent appelant. Le modèle propose d'utiliser un outil; la passerelle et le catalogue décident si l'appel est permis, à quelles conditions et sous quel jeton.

Ce qui change avec la révision 2026-07-28

La révision 2026-07-28 rend le protocole sans état. Pour l'exploitation, c'est une simplification : tout nœud d'un parc peut traiter n'importe quelle requête, sans affinité de session, y compris sur une plateforme sans serveur[162, 168]. Pour la sécurité, le risque se déplace des sessions vers les identifiants d'état applicatifs et les nouveaux en-têtes. Le tableau 17 résume les changements et leur effet pour l'entreprise.

Tableau 17 — Principaux changements de la révision MCP 2026-07-28 et effet pour l'entreprise

Changement	Effet pour l'entreprise
Protocole sans état. Retrait de la poignée de main `initialize`, des sessions protocolaires et de l'en-tête `Mcp-Session-Id` (SEP-2567, SEP-2575); chaque requête porte dans `_meta` sa version de protocole et les capacités du client[162, 168].	À terme, après la migration (EXIG-MCP-22), plus de répartiteurs de charge à sessions persistantes (sticky sessions) ni de magasin de sessions partagé; pendant la coexistence, l'affinité ou le magasin de sessions est limité aux serveurs antérieurs inscrits, dont les `Mcp-Session-Id` suivent les règles de l'EXIG-MCP-17. L'état qui doit durer passe par un identifiant explicite émis par le serveur (EXIG-MCP-17).
Découverte. Méthode `server/discover`, obligatoire pour le serveur, facultative pour le client : versions prises en charge, capacités (extensions comprises) et identité, dans une réponse que l'on peut mettre en cache (`ttlMs` et `cacheScope`) [168, 199].	Sonde d'inventaire et d'homologation; contrôle de cohérence avec le catalogue (EXIG-MCP-02).
En-têtes de routage. Chaque POST porte `Mcp-Method` et, pour `tools/call`, `resources/read` et `prompts/get`, `Mcp-Name` (SEP-2243); `MCP-Protocol-Version` doit égaler la valeur de `_meta`; tout écart entraîne HTTP 400 et l'erreur −32020 (`HeaderMismatch`)[168, 190].	Routage et politiques possibles sans analyser le corps, à la condition expresse de vérifier la concordance (EXIG-MCP-15).
Requêtes à allers-retours multiples (MRTR, SEP-2322). Les requêtes initiées par le serveur (`roots/list`, `sampling/createMessage`, `elicitation/create`) cèdent la place à un résultat `InputRequiredResult`; le client relance la requête d'origine avec les réponses et un `requestState` opaque. MRTR s'applique à `tools/call`, `resources/read` et `prompts/get`[200].	Une précision ou une décision humaine s'obtient sans flux ouvert de longue durée; le `requestState` devient une entrée non fiable à protéger (EXIG-MCP-17). La relance garde la clé d'idempotence et compte pour une seule opération au budget et à l'audit; un passage soldé par `input_required` ne consomme pas le jeton d'approbation (section 8.5).
Indices de cache. `ttlMs` et `cacheScope` obligatoires sur les résultats complets de `tools/list`, `prompts/list`, `resources/list`, `resources/templates/list`, `resources/read` (SEP-2549) et `server/discover`[168, 201].	Cache de passerelle possible; un cache « private » n'est jamais partagé entre contextes d'autorisation (EXIG-MCP-03).
Abonnements. `subscriptions/listen` remplace le point d'accès GET et `resources/subscribe`; la reprise de flux par `Last-Event-ID` est retirée[168, 190].	Notifications limitées aux types demandés par le client; les méthodes GET et DELETE ne servent plus.
Extensions officielles. Selon le journal des modifications de la révision 2026-07-28, les tâches longues quittent le cœur pour l'extension officielle `io.modelcontextprotocol/tasks` (SEP-2663); MCP Apps est une extension officielle; toute	Liste d'extensions autorisées au catalogue, quotas pour les tâches, revue des interfaces (EXIG-MCP-04).

Changement	Effet pour l'entreprise
extension est désactivée par défaut et s'active explicitement des deux côtés[168, 169, 191, 202].	
Schémas. `inputSchema` et `outputSchema` acceptent tout mot-clé de JSON Schema 2020-12 (SEP-2106), dialecte par défaut; un autre dialecte peut être déclaré par `$schema`[168, 197, 201].	Contrats plus expressifs; validateurs à durcir contre les références réseau (EXIG-MCP-19).
Cycle de vie. États Active, Deprecated et Removed (SEP-2596) : une fonctionnalité dépréciée reste dans la spécification au moins douze mois, ou au moins 90 jours en cas de retrait accéléré pour un risque de sécurité actif (avis de sécurité publié ou exploitation documentée)[34, 196].	Migrations planifiées au catalogue, avec échéances (EXIG-MCP-22).
Dépréciations et retraits. Sont dépréciés Roots, Sampling, la journalisation protocolaire, l'enregistrement dynamique de clients (DCR), l'ancien transport HTTP+SSE et les valeurs `includeContext` « thisServer » et « allServers »; `ping`, `logging/setLevel` et `notifications/roots/list_changed` sont retirés directement, comme conséquences du passage sans état (SEP-2575) : la politique de cycle de vie, adoptée dans la même révision, ne vise pas ces retraits, et la journalisation protocolaire dépréciée n'a plus de réglage de niveau. Le retrait de Roots, de Sampling, de la journalisation et du DCR est possible à partir de la première révision publiée le 28 juillet 2027 ou après (celui d'`includeContext` suit Sampling; celui du transport HTTP+SSE, trois mois après que la SEP-2596 atteint l'état final, soit dès le début de septembre 2026, cette SEP étant finale depuis le 3 juin 2026 : annexe H)[168, 196].	Paramètres d'outil ou URI de ressource au lieu de Roots; appels aux modèles par la passerelle de modèles au lieu de Sampling; sortie d'erreur standard ou OpenTelemetry au lieu de la journalisation protocolaire.
Codes d'erreur. « Ressource introuvable » passe de −32002 à −32602; la plage −32020 à −32099 est réservée à MCP, dont −32021 (capacité client requise absente) et −32022 (version non prise en charge)[162, 168].	Clients tolérants aux deux codes pendant la transition; supervision des nouveaux codes.

Une liste d'outils peut varier selon l'autorisation présentée, par exemple pour ne montrer que les outils permis par les portées du jeton, mais jamais selon la connexion ni par effet de bord d'autres requêtes; une liste qui dépend du jeton devrait alors porter `cacheScope` « private »[197, 199].

> **`EXIG-MCP-03` · DOIT**
> **Listes stables et cache conforme à cacheScope**
> Les serveurs MCP internes **DOIVENT** renvoyer leurs outils dans un ordre déterministe, identique d'une requête à l'autre tant que l'ensemble ne change pas; la passerelle qui agrège plusieurs serveurs fusionne leurs listes par identifiant de serveur, puis par nom, et conserve un ordre stable après filtrage. La passerelle **DOIT** respecter `ttlMs` et `cacheScope` : sa clé de cache inclut la méthode et les paramètres de la requête (curseur, URI) et, pour une réponse « private », le contexte d'autorisation, soit l'émetteur, le sujet, le client, l'audience et l'ensemble exact des portées du jeton; une réponse « private » n'est servie qu'à ce même contexte; seule une réponse « public » peut l'être par un cache partagé, ce qui ne dispense pas des contrôles d'accès par primitive; un résultat intermédiaire `input_required` et le résultat d'une relance MRTR (`inputResponses` ou `requestState`) ne sont jamais mis en cache. La passerelle **DOIT** évaluer la politique avant tout service depuis le cache, ne rien mettre en cache en l'absence de `cacheScope`, invalider les entrées d'un contexte à la révocation ou à la suspension de l'agent et à tout changement de portées et, à chaque rétablissement de `subscriptions/listen`, invalider les entrées du serveur et relire ses listes.
> Pourquoi : la spécification recommande l'ordre déterministe pour améliorer le taux de succès du cache d'invites, et le cadre l'exige pour ses serveurs (section 10.6); elle interdit de partager un cache « private » entre contextes d'autorisation, ce qui réduit le risque de fuite entre locataires (la spécification précise que `cacheScope` ne remplace pas les contrôles d'accès propres à chaque primitive)[197, 199, 201].

L'extension Tasks confie un travail long à un identifiant durable : le serveur renvoie un `taskId`, une durée de vie et un intervalle d'interrogation; le client suit l'avancement par `tasks/get`, fournit une entrée par `tasks/update` et peut annuler par `tasks/cancel`; les états sont `working`, `input_required`, `completed`,

`failed` et `cancelled`[191]. Une tâche MCP ne remplace pas l'exécution durable de l'orchestrateur : celui-ci consigne le `taskId` dans son point de contrôle pour reprendre le suivi après une panne (section 7.4). Avec MCP Apps, un outil désigne dans `_meta.ui.resourceUri` une ressource `ui://`; l'hôte l'affiche dans une iframe cloisonnée qu'il contrôle, l'application ne dialogue avec lui que par `postMessage` et n'appelle des outils qu'à travers lui, et `_meta.ui.csp` et `_meta.ui.permissions` encadrent les origines et les permissions[202].

> **`EXIG-MCP-04` · DOIT**
> **Extensions activées sur liste d'autorisation**
> Une extension MCP **DOIT** figurer au catalogue pour le serveur concerné avant d'être activée. Les extensions internes portent le préfixe DNS inversé de l'entreprise, jamais un préfixe réservé (dont le deuxième libellé est `modelcontextprotocol` ou `mcp`). Pour l'extension Tasks, la passerelle impose un quota de tâches actives par mandant et une durée de vie maximale, et toute requête qui crée une tâche porte une clé d'idempotence, quel que soit le palier, afin qu'une panne survenue avant la consignation du `taskId` ne laisse pas de tâche orpheline (section 7.6). Pour MCP Apps, chaque gabarit `ui://` est revu avant l'homologation, l'empreinte de son contenu est épinglée au catalogue et vérifiée à chaque `resources/read` (un écart suspend le gabarit), et le contenu généré qu'il affiche est encodé; l'hôte applique la politique de sécurité du contenu et les permissions inscrites au catalogue, jamais celles de `_meta.ui`, que le serveur déclare.
> Pourquoi : les extensions sont désactivées par défaut et s'identifient par un préfixe DNS inversé[169]; Akamai signale le déni de service par tâches asynchrones et le script intersites stocké par les interfaces générées[203]. La revue préalable des gabarits est une exigence du cadre, que la documentation officielle n'énonce pas.

Règles d'usage des primitives

Chaque primitive répond à un besoin distinct. Une **ressource** convient quand on sait quelle entité charger : `crm://comptes/9482/sommaire` est déclarée sans effet par le serveur, classée au catalogue comme une lecture (palier P0 ou P1) et se met en cache selon `ttlMs`. Un **outil** convient aux recherches dynamiques, aux calculs et aux écritures, sous un contrat d'entrée strict. Une **invite** publie une procédure normalisée d'un domaine, par exemple la vérification d'un nouveau fournisseur, pour que chaque agent n'ait pas à la réécrire; elle se gère comme la mémoire procédurale, c'est-à-dire comme du code versionné et revu (section 5.5).

La granularité compte autant que le choix de la primitive. Un serveur qui recopie une API de soixante opérations en soixante outils encombre le contexte du modèle et multiplie les occasions de choisir le mauvais outil ou le mauvais paramètre. Un outil `approvisionnement_creer_bon_commande`, qui valide en une seule opération le fournisseur, le centre de coûts et les lignes, se gouverne mieux et se teste plus facilement. Les équipes ne réécrivent pas leurs services REST : des adaptateurs de composition traduisent les opérations OpenAPI pertinentes en outils orientés tâche, qui valident les règles métier (section 5.2 et EXIG-MCP-06).

Lorsque les outils deviennent nombreux, les bonnes pratiques de MCP recommandent à l'hôte, au-delà d'un seuil de l'ordre de 1 à 5 % de la fenêtre de contexte, d'offrir un méta-outil de recherche et de ne charger les définitions complètes qu'au besoin, en les ajoutant après le point de rupture du cache plutôt qu'en réordonnant la liste[204]. Anthropic illustre, par un exemple de plus de 50 outils MCP, que sa propre fonction de recherche d'outils ramène la consommation totale de contexte d'environ 77 000 jetons (dont environ 72 000 pour les seules définitions) à environ 8 700; elle chiffre cette réduction à 85 % (les deux chiffres donnent plutôt près de 89 %)[205]. Le choix entre la recherche d'outils et le découpage en plusieurs agents est traité à la section 7.3.

EXIG-MCP-05 · DEVRAIT
Choix de la primitive selon le besoin
La lecture d'une entité connue **DEVRAIT** être exposée comme ressource adressée par URI; une recherche, un calcul ou une écriture, comme outil; une procédure normalisée de domaine, comme invite versionnée et revue au même titre que du code. Une ressource ou un gabarit de ressource reçoit au catalogue un palier P0 ou P1, comme un outil de lecture : la passerelle doit appliquer à `resources/read` les contrôles de ce palier, le masquage et le balisage du contenu non fiable (section 9.6). Lorsque l'hôte n'offre pas au modèle la lecture de ressources, un outil de lecture adossé à la ressource la remplace.
Pourquoi : la ressource, déclarée sans effet par le serveur et classée au catalogue, se met en cache, mais une lecture sensible reste une lecture sensible; la spécification laisse en outre à l'application hôte le choix des ressources qu'elle fournit au modèle; l'outil porte un contrat d'entrée strict et passe par les contrôles de palier; l'invite rend une procédure réutilisable sans la recopier dans chaque agent.

EXIG-MCP-06 · NE DOIT PAS
Aucun miroir CRUD des API
Un serveur MCP **NE DOIT PAS** exposer une API en recopiant une à une ses opérations élémentaires de création, de lecture, de mise à jour et de suppression. Il expose des outils qui accomplissent des tâches métier complètes et valident eux-mêmes leurs paramètres. Critère de revue : aucun outil d'écriture dont le contrat se réduit à une opération unique de l'API, sans validation métier.
Pourquoi : chaque définition d'outil consomme du contexte et chaque outil de plus est une occasion d'erreur de sélection; une intention métier se classe au catalogue et s'approuve plus clairement qu'une opération technique.

EXIG-MCP-07 · DOIT
Conventions de nommage et de résultat des outils
Les outils des serveurs internes **DOIVENT** : porter un nom de 1 à 96 caractères ASCII (lettres, chiffres, `_`, `-`, `.`) préfixé par leur domaine, la marge jusqu'aux 128 caractères de la spécification étant réservée au préfixe de serveur que pose la passerelle (EXIG-MCP-20); renvoyer les erreurs de validation et les erreurs métier comme résultat d'outil marqué `isError: true`, en réservant les erreurs JSON-RPC aux outils inconnus, aux requêtes malformées et aux erreurs du serveur; déclarer un `outputSchema` lorsque leur résultat alimente une étape suivante, puis renvoyer un `structuredContent` conforme, accompagné du même JSON sérialisé dans un bloc texte. Un outil qui renvoie aussi des erreurs structurées les décrit dans son `outputSchema` (union du succès et de l'erreur), et l'hôte ne transmet au modèle qu'une des deux formes du résultat.
Pourquoi : le modèle peut corriger une erreur renvoyée comme résultat, alors qu'une erreur de protocole interrompt l'appel; la spécification exige un `structuredContent` conforme dès qu'un `outputSchema` est déclaré et recommande le bloc texte pour la rétrocompatibilité[197]. Exemple complet à l'annexe C.

Transport et autorisation

MCP définit deux transports normalisés : stdio, entre processus d'une même machine, et Streamable HTTP, qui a remplacé le transport HTTP+SSE en 2025-03-26[206, 207]. En 2026-07-28, chaque message du client est un POST distinct vers un point d'accès unique; le serveur répond soit par un objet JSON, soit par un flux SSE propre à cette requête (que le serveur devrait clore dès que la réponse JSON-RPC finale est envoyée), et le client doit accepter les deux. Le serveur doit valider l'en-tête `Origin` sur toute connexion entrante pour contrer les attaques par réassociation DNS *(DNS rebinding)*, et répondre par HTTP 403 si l'en-tête est présent et invalide; un serveur local devrait n'écouter que sur 127.0.0.1, et tout serveur devrait authentifier les connexions[190]. Les bonnes pratiques de sécurité de MCP recommandent d'ailleurs stdio pour limiter

l'accès à un serveur local[208] : restreindre stdio au poste de développement est donc un choix d'exploitation du cadre, non une exigence de MCP.

EXIG-MCP-08 · DOIT
Transport selon l'environnement
Dans tout environnement autre qu'un poste de développement individuel sans justificatif de production (environnement serveur, tableau 7), un serveur MCP **DOIT** être exposé par Streamable HTTP, derrière la passerelle d'agents, sur TLS : TLS 1.3 négocié lorsque le pair le permet, TLS 1.2 au minimum, versions antérieures désactivées. Sur un tel poste, et là seulement, un serveur local est permis, installé depuis le catalogue et exécuté dans un bac à sable aux privilèges minimaux; l'hôte affiche la commande complète avant l'installation et exige une approbation explicite. Ce serveur local emploie stdio ou, en Streamable HTTP, **DOIT** n'écouter que sur l'adresse de bouclage, valider l'en-tête `Origin` et exiger une authentification.
Pourquoi : seul un transport réseau passe par la passerelle, donc par l'identité, la politique et la journalisation; les bonnes pratiques de sécurité de MCP exigent l'affichage de la commande et l'approbation explicite pour l'installation en un clic d'un serveur local, et recommandent son exécution en bac à sable[208].

L'autorisation est *facultative* dans MCP; lorsqu'elle est offerte sur HTTP, elle devrait suivre la spécification d'autorisation, fondée sur le brouillon OAuth 2.1 dans sa version –13, que la spécification MCP cite encore (la version –16 était la plus récente au 27 octobre 2026, et la –17 a paru le 31 octobre 2026; voir la section 6.3) [209, 210]. Le serveur MCP y est un serveur de ressources OAuth. Il doit publier ses métadonnées de ressource protégée (RFC 9728), que le client utilise pour découvrir le serveur d'autorisation, et ce dernier doit offrir la découverte RFC 8414 ou OpenID Connect[211]. Le client doit inclure le paramètre `resource` (RFC 8707), valant l'URI canonique du serveur MCP, dans ses requêtes d'autorisation et de jeton; le serveur doit vérifier que le jeton lui est destiné et répondre 401 sinon[71]. Le jeton circule dans l'en-tête `Authorization: Bearer` de chaque requête, jamais dans l'URL; PKCE s'emploie avec la méthode S256. Depuis 2026-07-28, le serveur d'autorisation devrait renvoyer le paramètre `iss` (RFC 9207), que le client doit valider s'il est présent (et rejeter la réponse s'il est absent alors que les métadonnées annoncent son support)[209, 212]. Comme OAuth 2.1 reste un brouillon, le cadre se réfère à OAuth 2.0 profilé par la RFC 9700 (section 9.3).

La spécification prescrit des jetons porteurs; elle n'exige ni mTLS ni DPoP, ni durée de vie précise, et l'intégration de DPoP (RFC 9449) au profil d'autorisation MCP ne figure qu'à sa feuille de route[195, 209]. Les jetons liés à l'expéditeur *(sender-constrained)* (RFC 9449 ou RFC 8705), appuyés sur la RFC 9700[175, 213], et les durées de vie courtes sont donc des politiques du cadre. Lorsque la passerelle publie un serveur, l'URI canonique annoncée aux clients est la sienne; elle obtient ensuite, pour le serveur de domaine, un jeton distinct par échange de jetons (section 9.3). Ce choix du cadre respecte l'interdiction du passage de jeton.

EXIG-MCP-09 · DOIT
Autorisation obligatoire et conforme à la spécification
Tout serveur MCP, hormis un serveur local en stdio sur un poste de développement (EXIG-MCP-08), **DOIT** exiger une autorisation OAuth conforme à la spécification MCP de la révision de référence épinglée au catalogue (valeur initiale : 2026-07-28) : métadonnées de ressource protégée (RFC 9728), indicateur de ressource (RFC 8707) portant l'URI canonique, vérification de l'audience à chaque requête et jeton transmis uniquement par l'en-tête `Authorization`. Chaque serveur publié séparément a sa propre URI canonique; en mode agrégé, les portées sont préfixées par l'identifiant du serveur au catalogue, et la passerelle vérifie que chaque appel vise un serveur couvert par les portées du jeton. Les clients MCP de l'entreprise **DOIVENT** employer PKCE avec S256 (en vérifiant que les métadonnées du

serveur d'autorisation annoncent `code_challenge_methods_supported` et en refusant de poursuivre sinon) et, avant d'échanger le code d'autorisation, valider `iss` (RFC 9207) s'il est présent, rejeter la réponse qui en est dépourvue alors que les métadonnées du serveur d'autorisation annoncent son support et, face à un serveur d'autorisation qui ne l'annonce pas, employer une `redirect_uri` distincte par serveur d'autorisation et vérifier l'émetteur attendu pour la transaction (RFC 9700). Les serveurs d'autorisation de l'entreprise **DOIVENT** publier ces annonces et toujours émettre `iss` (avec `authorization_response_iss_parameter_supported: true`).

Pourquoi : la spécification laisse l'autorisation facultative[209]; le cadre la rend obligatoire, car un outil sans contrôle d'accès ouvre directement les systèmes d'enregistrement, et l'émission de `iss` protège contre la confusion entre serveurs d'autorisation.

`EXIG-MCP-10` · DOIT
Portées minimales et élévation progressive
Chaque serveur MCP **DOIT** publier un ensemble initial minimal de portées (`scopes_supported`), refuser les portées génériques (*, `all`, `full-access`) et signaler une portée insuffisante par une réponse 403 `insufficient_scope` qui énumère les portées requises. Chaque élévation progressive *(step-up)* est journalisée avec l'identifiant de trace, et le client en limite le nombre de tentatives.

Pourquoi : un agent démarre avec le minimum et n'obtient davantage que sur une demande traçable; c'est le patron de minimisation des portées que décrivent la spécification et ses bonnes pratiques de sécurité[208, 209].

`EXIG-MCP-11` · NE DOIT PAS
Interdiction du passage de jeton
Un serveur MCP, la passerelle comprise, **NE DOIT PAS** accepter un jeton qui n'a pas été émis pour lui, ni retransmettre en aval un jeton reçu, sauf au serveur d'autorisation, à titre de `subject_token` d'un échange de jetons (EXIG-IAM-12, qui fait foi). Pour appeler une API ou un autre serveur, il obtient son propre jeton, à audience unique, par échange de jetons (section 9.3).

Pourquoi : la spécification interdit explicitement le passage de jeton *(token passthrough)*[208, 209]; un jeton relayé permettrait à un serveur compromis d'agir partout où ce jeton est valable.

Pour identifier un client, la spécification recommande l'ordre suivant : enregistrement préalable, puis document de métadonnées d'identifiant client (CIMD) si le serveur d'autorisation l'annonce, puis enregistrement dynamique (DCR) en repli, puis saisie manuelle[214]. Les CIMD, dont l'identifiant client est une URL HTTPS, ont été ajoutés en 2025-11-25; le DCR (RFC 7591) a été déprécié en 2026-07-28[168, 215]. Le brouillon CIMD, adopté par le groupe de travail OAuth de l'IETF mais qui n'est pas une RFC, interdit au client l'authentification par secret partagé, n'admet que des clés publiques, interdit au serveur de suivre automatiquement les redirections, lui fait refuser les adresses à usage spécial et recommande de limiter la lecture à environ 5 Ko (état de la version –02; la spécification MCP 2026-07-28 renvoie à la version –00)[216]. Un identifiant préenregistré ou obtenu par DCR est lié à l'émetteur qui l'a délivré : si l'émetteur change, le client se réenregistre[214].

`EXIG-MCP-12` · DOIT
Enregistrement des clients MCP
Les clients MCP de l'entreprise **DOIVENT** être préenregistrés auprès du serveur d'autorisation ou, pour un serveur d'autorisation tiers qui annonce la prise en charge des CIMD, identifiés par un CIMD. Le DCR ne doit pas être activé pour une nouvelle intégration (EXIG-MCP-22); si le serveur d'autorisation tiers n'offre ni préenregistrement ni CIMD, l'intégration exige une dérogation. Un serveur d'autorisation de

l'entreprise qui accepte des CIMD **DOIT** refuser l'authentification par secret partagé, ne suivre aucune redirection (règle du brouillon CIMD, plus stricte que l'EXIG-SEC-12), appliquer pour le reste la règle de sortie réseau de l'EXIG-SEC-12 et borner la taille du document lu.
Pourquoi : le DCR est déprécié et voué au retrait[196]; la récupération d'un CIMD expose le serveur d'autorisation à la falsification de requêtes côté serveur (SSRF), que les règles du brouillon préviennent[216].

`EXIG-MCP-13` · DOIT
Consentement par client des mandataires MCP
Un serveur MCP qui sert de mandataire auprès d'un serveur d'autorisation tiers avec un identifiant client statique **DOIT** obtenir le consentement de l'utilisateur pour chaque client avant de relayer l'autorisation : registre des `client_id` approuvés par utilisateur; page de consentement qui nomme le client, les portées et l'URI de redirection; protection contre la falsification de requête intersites et contre le détournement de clic par incrustation *(clickjacking)*, notamment par `frame-ancestors`; correspondance exacte de `redirect_uri`; paramètre `state` aléatoire, à usage unique, fixé seulement après le consentement; témoins `__Host-` marqués `Secure`, `HttpOnly` et `SameSite=Lax`.
Pourquoi : sans ce consentement, un client malveillant profite d'un consentement donné antérieurement au mandataire; c'est le problème de l'adjoint confus *(confused deputy)*, que la spécification traite par ces mesures obligatoires[208].

Deux extensions officielles d'autorisation, stables depuis la révision 2026-07-28, complètent le cœur du protocole[217]. Avec Enterprise-Managed Authorization (EMA), le fournisseur d'identité de l'entreprise décide de l'accès : après l'authentification unique, le client obtient un ID-JAG par échange de jetons (RFC 8693), puis l'échange contre un jeton d'accès par l'octroi JWT bearer (RFC 7523)[178, 218]. EMA évite un consentement par serveur et par employé et centralise les politiques d'accès et la révocation[178]; comme le brouillon ID-JAG qui la fonde[177], elle figure au statut Évaluer du catalogue (section 6.3). L'extension OAuth Client Credentials couvre les agents qui agissent sans utilisateur; un tel agent s'authentifie sous sa propre identité (section 9.2). Enfin, l'échange de jetons RFC 8693 et la revendication `act` ne font pas partie du cœur de MCP : exiger d'un fournisseur la propagation de la chaîne de délégation relève d'une clause contractuelle (chapitre 13), non d'une conformité MCP.

Annotations et métadonnées de gouvernance

La spécification prévoit pour chaque outil des annotations : `title`, `readOnlyHint` (faux par défaut), `destructiveHint` (vrai par défaut), `idempotentHint` (faux par défaut) et `openWorldHint` (vrai par défaut); `destructiveHint` et `idempotentHint` n'ont de sens que si l'outil n'est pas en lecture seule. Ce sont des indices : les clients doivent les tenir pour non fiables, sauf s'ils proviennent de serveurs de confiance, et, selon une formulation non normative (« should never »), ne jamais fonder une décision d'usage sur les annotations d'un serveur non fiable[197, 201]. Les valeurs par défaut sont prudentes : un outil qui ne déclare rien est présumé destructif et ouvert sur l'extérieur.

L'objet `annotations` ne définit que cinq champs standard et aucune propriété d'extension; la spécification réserve `_meta` aux extensions. Les ébauches qui y ajoutaient des champs `x-enterprise-*` sortaient donc de ce que prévoit la spécification (le cadre en fait une règle, EXIG-MCP-14)[201]. Une métadonnée propre à l'entreprise peut figurer dans le champ `_meta` de l'outil, sous une clé à préfixe DNS inversé détenu par l'entreprise (p. ex. `ca.ent/palier-risque`); déclarée par le serveur, elle n'est pas plus fiable qu'une annotation.

ATTENTION

Une annotation `readOnlyHint: true` ne prouve rien : c'est le serveur qui l'affirme. Un serveur compromis ou mal configuré peut déclarer en lecture seule un outil qui supprime des données. Le palier P0 à P3 d'un outil est attribué au catalogue après revue (section 8.3) et appliqué par la passerelle.

EXIG-MCP-14 · DOIT
Annotations et métadonnées déclarées : de simples indices
La passerelle et les hôtes **DOIVENT** lire le palier de risque, le seuil d'approbation et l'outil de compensation d'un outil ou d'un gabarit de ressource dans son entrée au catalogue, jamais dans ses annotations ni dans son `_meta`. Les serveurs internes **DOIVENT** néanmoins déclarer leurs annotations, qui **DOIVENT** concorder avec la classification du catalogue : `readOnlyHint` vrai pour un outil P0 ou P1 et faux pour un outil P2 ou P3; `idempotentHint` vrai seulement si une clé d'idempotence est déclarée au catalogue. Un écart **DOIT** bloquer l'homologation; les autres indices relèvent de la revue. Aucune propriété propre à l'entreprise n'est ajoutée à l'objet `annotations`.
Pourquoi : la spécification tient les annotations pour des indices non fiables[197]; elles servent l'ergonomie (affichage, demande de confirmation), non la décision de sécurité. L'entrée de catalogue type figure à l'annexe C.

Sécurité propre à MCP

À terme, après la migration (EXIG-MCP-22), le passage au protocole sans état supprime le détournement d'identifiant de session, que les serveurs antérieurs gardent pendant la coexistence, mais il déplace le risque vers les identifiants d'état applicatifs et le `requestState`, que le serveur doit traiter comme une entrée contrôlée par l'attaquant[200, 208]. L'analyse, publiée par Akamai le 25 juin 2026, de la version candidate relève notamment le détournement de flux entre agents par des identifiants ou des objets d'état prévisibles, la manipulation du champ `_meta` contrôlé par le client, la désynchronisation des en-têtes et du corps, la fuite de données par `x-mcp-header`, le script intersites stocké par MCP Apps et le déni de service par tâches asynchrones[203]. La spécification contient déjà l'essentiel des contre-mesures; les exigences qui suivent s'y appuient. Les menaces communes à tous les agents, comme l'injection d'instructions et l'exécution de code, sont traitées aux sections 9.5 à 9.7.

EXEMPLE : LA DÉSYNCHRONISATION

Une requête porte l'en-tête `Mcp-Name: recherche_publique`, mais son corps appelle `supprimer_base`. Un pare-feu applicatif qui ne lit que l'en-tête laisse passer, et le serveur exécute l'outil destructeur. La spécification ferme cette brèche en obligeant tout serveur qui traite le corps à rejeter l'écart; le cadre ajoute que la passerelle décide d'après le corps analysé, jamais d'après les seuls en-têtes.

EXIG-MCP-15 · DOIT
Concordance des en-têtes et du corps
La passerelle et chaque serveur **DOIVENT** vérifier que `MCP-Protocol-Version`, `Mcp-Method`, `Mcp-Name` et chaque en-tête `Mcp-Param-{nom}` (après décodage Base64 éventuel) concordent avec le corps JSON-RPC et sa clé `_meta`, et rejeter par HTTP 400 et l'erreur −32020 toute divergence, ainsi que l'absence de tout en-tête obligatoire selon la révision inscrite au catalogue pour le serveur visé, et non selon celle que déclare l'appelant. La passerelle fonde ses décisions d'autorisation sur le corps analysé; une politique fondée sur les en-têtes ne s'applique qu'aux requêtes d'une révision qui les définit (2026-07-28 ou une révision ultérieure épinglée au catalogue).

Pourquoi : la spécification impose ce rejet à tout serveur qui traite le corps et recommande à un intermédiaire dont la politique repose sur ces en-têtes de rejeter les requêtes d'une révision antérieure, qui n'imposait pas cette validation[190].

Dans MCP, le code HTTP 403 signale un en-tête `Origin` invalide (transport) ou des portées invalides ou des permissions insuffisantes (autorisation); une divergence d'en-têtes relève du code 400[190, 209]. Le champ `_meta`, lui, ne peut pas être purgé en bloc : les clés `io.modelcontextprotocol/protocolVersion` et `io.modelcontextprotocol/clientCapabilities` y sont obligatoires, sous peine de rejet par l'erreur −32602, et les clés `traceparent`, `tracestate` et `baggage` y transportent le contexte de trace selon W3C Trace Context et W3C Baggage (SEP-414)[162, 168]. Les conventions OpenTelemetry pour MCP, au niveau Development, nomment les *spans* d'après la méthode appelée (attribut `mcp.method.name`)[219]; leur emploi est réglé à la section 10.1. Un serveur ne se fie pas non plus à une capacité que le client n'a pas déclarée : il renvoie alors l'erreur −32021[162].

EXIG-MCP-16 · DOIT
Traitement du champ _meta
La passerelle et les serveurs **DOIVENT** conserver les clés réservées de `_meta`, soit celles du préfixe `io.modelcontextprotocol/` selon la révision inscrite au catalogue (version de protocole, capacités du client, `clientInfo`, `serverInfo`, `logLevel` et `subscriptionId`, qui marque les notifications de `subscriptions/listen`), ainsi que `traceparent` et `tracestate`, filtrer `baggage` par liste d'autorisation à chaque frontière de confiance, retirer toute autre clé absente de la liste des clés admises que le catalogue tient pour chaque serveur et ne fonder aucun routage, aucun choix de locataire ni aucune autorisation sur `_meta`, `clientInfo` ou `serverInfo`. L'identité du mandant provient exclusivement du jeton vérifié, par exemple de sa revendication `sub`.
Pourquoi : `clientInfo` et `serverInfo` sont auto-déclarés et ne devraient pas servir aux décisions de sécurité[162]; Akamai illustre l'élévation de privilèges qu'obtient un attaquant lorsqu'un serveur se fie à `{"tenant": "admin", "authenticated": true}` placé dans `_meta`[203].

EXIG-MCP-17 · DOIT
État explicite protégé
Un serveur qui conserve un état entre deux appels **DOIT** émettre des identifiants d'état aléatoires, imprévisibles et à durée de vie bornée, d'au moins 128 bits d'entropie, liés côté serveur à l'utilisateur authentifié (clé formée de l'émetteur et du sujet du jeton vérifié, `iss` et `sub`, et de l'identifiant, sérialisée sans ambiguïté); la possession d'un identifiant ne vaut jamais authentification. Il **DOIT** traiter tout `requestState` reçu comme une entrée contrôlée par un attaquant et, dès que cet état influence l'autorisation, l'accès aux ressources ou la logique métier, en protéger l'intégrité par HMAC ou par chiffrement authentifié (AEAD), sous une clé propre au serveur, y inclure le mandant, l'identifiant du serveur et de l'outil, une courte durée de vie et l'empreinte de la requête d'origine. Toute étape qui porte une approbation ou une écriture P2 ou P3 est à usage unique : le serveur tient un registre des états consommés, partagé par toutes ses répliques et conservé pendant la durée de vie de l'état, et une relance qui présente le même `requestState` pour la même requête renvoie le résultat mémorisé, sans nouvel effet.
Pourquoi : la spécification impose de traiter tout `requestState` comme une entrée contrôlée par un attaquant, d'en protéger l'intégrité (HMAC ou AEAD) dès qu'il influence l'autorisation, l'accès aux ressources ou la logique métier, et de faire respecter l'usage unique côté serveur quand il est requis; elle ne fait que recommander l'inclusion du mandant, d'une courte durée de vie et de l'empreinte de la requête d'origine, et n'offre qu'une orientation non

normative sur les identifiants d'état aléatoires liés à l'utilisateur (durcissement du cadre)[197, 200]; sans ces mesures, un identifiant deviné permet d'accéder à l'état d'un autre utilisateur, et un état rejoué par un autre mandant n'est rejeté que si le serveur l'a lié au mandant[200, 208].

La directive `x-mcp-header` recopie un argument d'outil dans un en-tête `Mcp-Param-{nom}`. Elle ne s'applique qu'à des types primitifs (chaîne, entier, booléen, à l'exclusion de `number`), à une propriété atteignable statiquement et sous un nom unique; un client Streamable HTTP doit écarter de `tools/list` tout outil dont la directive est invalide[190, 197].

`EXIG-MCP-18` · NE DOIT PAS
Aucune donnée sensible en en-tête
La directive `x-mcp-header` **NE DOIT PAS** marquer une propriété qui contient un secret (mot de passe, clé d'API, jeton), un renseignement personnel ou toute autre donnée confidentielle. Elle est réservée aux valeurs utiles au routage ou à l'imputation, comme un centre de coûts; la passerelle et les hôtes doivent écarter de `tools/list` tout outil dont une propriété marquée `x-mcp-header` n'est pas inscrite au catalogue comme projection autorisée, ce qui couvre les serveurs de tiers; pour les serveurs internes, l'analyse des schémas en intégration continue complète ce contrôle.
Pourquoi : les en-têtes sont visibles des intermédiaires (répartiteurs de charge, passerelles, outils d'observabilité); la spécification recommande de ne pas y marquer de paramètres sensibles[190, 197], et le cadre en fait une interdiction.

`EXIG-MCP-19` · DOIT
Schémas, URL et icônes : des entrées non fiables
Les hôtes, les clients hébergés et la passerelle **DOIVENT** traiter comme non fiables les schémas, URL et icônes fournis par un serveur. Concrètement : ne jamais déréférencer automatiquement un `$ref` pointant vers une URI réseau et borner la profondeur et le nombre de sous-schémas; lors de la découverte OAuth, n'accepter que HTTPS et appliquer la règle de sortie réseau de l'EXIG-SEC-12, un serveur d'autorisation interne légitime étant atteint par son entrée de catalogue, jamais par une URL fournie; n'ouvrir une URL d'autorisation que si son schéma est `https` (`http` en bouclage, pour le développement seulement), jamais par un interpréteur de commandes; n'accepter qu'une icône matricielle (PNG, WebP ou JPEG) dont le type est validé par signature binaire, en `https`, de même origine que le serveur et récupérée sans identifiants, ou en `data:`; une icône SVG, format textuel qu'aucune signature binaire ne qualifie, est rendue en image matricielle avant tout affichage, ou refusée.
Pourquoi : un serveur malveillant peut se servir d'un schéma pour un déni de service, de la découverte OAuth pour une SSRF vers les métadonnées infonuagiques ou les services internes, d'une URL ou d'une icône SVG pour exécuter du code[162, 208].

Trois attaques visent les définitions d'outils elles-mêmes. L'**empoisonnement d'outil** *(tool poisoning)* cache des instructions malveillantes dans une description, un schéma ou une valeur de retour. La **substitution après approbation** *(rug pull)* modifie les définitions d'un serveur une fois celui-ci approuvé. L'**ombrage** *(tool shadowing)* laisse la description d'un serveur malveillant modifier l'usage des outils d'un autre serveur. Invariant Labs a décrit les trois le 1er avril 2025, et la fiche de sécurité MCP de l'OWASP les reprend avec l'injection par valeurs de retour[220, 221]. Cette fiche recommande de traiter chaque serveur comme un domaine de sécurité indépendant et non fiable, et rappelle que la signature des messages ne fait pas partie du cœur de MCP[221]. L'épinglage au catalogue est réglé à la section 6.8; l'exigence suivante en vérifie la définition à l'exécution. Le comportement du serveur, que la définition ne transporte pas, relève de la signature des artefacts déployés et de la provenance (section 9.8), du contrôle des sorties réseau et des tests de contrat.

EXIG-MCP-20 · DOIT
Empreintes des définitions et isolement des serveurs
À l'homologation, à chaque `tools/list` et, avant l'exécution, sur la définition du dernier `tools/list` non périmé (`ttlMs`, EXIG-MCP-03; la liste est relue si l'entrée est périmée), la passerelle **DOIT** calculer l'empreinte de chaque définition d'outil, soit le SHA-256 de sa canonisation RFC 8785 sur le périmètre de la définition publiée fixé par l'EXIG-INT-13 (icônes hachées par leur contenu, champs volatils de `_meta` inscrits au catalogue exclus), et la comparer à l'empreinte épinglée au catalogue; un outil dont l'empreinte diffère est retiré de la liste remise à l'agent et suspendu jusqu'à une nouvelle approbation, et la version entière du serveur l'est au-delà d'un nombre d'écarts inscrit au catalogue (l'EXIG-SEC-18 fait foi pour la suspension). Cette empreinte atteste la définition reçue, non le comportement du serveur. La passerelle **DOIT** traiter chaque serveur comme un domaine de sécurité distinct : elle préfixe tout outil remis à l'agent par l'identifiant de son serveur au catalogue, au moyen d'un séparateur admis dans les noms d'outils mais interdit dans ces identifiants, refuse toute collision de noms et réécrit de façon cohérente le corps et l'en-tête `Mcp-Name`; le catalogue indexe palier et empreinte sur le couple (serveur, nom d'origine); la revue d'homologation recherche dans les descriptions toute mention d'outils ou de serveurs tiers; la sortie de tout outil est une donnée non fiable (section 9.6).
Pourquoi : l'OWASP recommande d'épingler les définitions par empreinte, de les revérifier avant l'exécution et de redemander le consentement lorsqu'elles changent[221]; l'empoisonnement d'outil est le risque MCP03 de l'OWASP MCP Top 10[222].

Lorsque l'hôte fait exécuter par le modèle du code qui appelle des outils (« mode code »), ce code s'exécute dans un bac à sable sans accès réseau direct; l'hôte, qui détient les identifiants, applique à chaque appel la même politique d'approbation qu'à un appel direct, et les résultats d'un serveur restent non fiables pour un autre[204]. Les exigences de cloisonnement figurent à la section 9.7.

L'élicitation reste le canal par lequel un serveur sollicite une personne, désormais à l'intérieur d'un `InputRequiredResult`. Elle offre deux modes : « form », pour des données structurées selon un schéma plat de types primitifs, et « url », pour une interaction hors bande. Le client doit indiquer quel serveur demande l'information, offrir le refus et l'annulation, afficher l'URL complète et obtenir le consentement avant de l'ouvrir. En mode URL, le serveur ne place ni renseignement sensible ni URL préauthentifiée dans l'URL, vérifie que la personne qui l'ouvre est celle qui a déclenché la demande, et les identifiants tiers ainsi obtenus ne transitent jamais par le client MCP[223].

EXIG-MCP-21 · NE DOIT PAS
Élicitation : ni secret ni approbation déguisée
Un serveur **NE DOIT PAS** demander de secret (mot de passe, clé d'API, jeton, donnée de paiement) par élicitation en mode formulaire; ces cas passent par le mode URL. Une réponse d'élicitation **NE DOIT PAS** non plus tenir lieu d'approbation humaine pour une action qui en exige une (toute action pour laquelle le contrôle calculé selon l'EXIG-AUT-10 exige une approbation) : seule compte l'approbation signée, liée à l'action exacte, décrite à la section 8.5. L'hôte doit avertir l'utilisateur, ou refuser la demande, lorsqu'une élicitation en mode formulaire comporte un champ de format `password` ou dont le nom évoque un secret.
Pourquoi : la spécification interdit les secrets en mode formulaire[223]; le brouillon IETF WIMSE AIMS précise qu'une confirmation locale dans l'interface ne suffit pas comme autorisation[93].

Le projet OWASP MCP Top 10, édition 2025 encore en phase bêta, fournit une grille de menaces commune[222]. Le tableau 18 la met en correspondance avec les exigences du cadre; cette correspondance est une interprétation interne, qui nomme les exigences qui traitent chaque risque sans prétendre le couvrir

entièrement. Pour l'analyse de menaces par phase, Hou et coll. décrivent le cycle de vie d'un serveur MCP en quatre phases (création, déploiement, exploitation, maintenance) et seize scénarios de menace répartis entre quatre types d'attaquants[224].

Tableau 18 — Correspondance entre l'OWASP MCP Top 10 (bêta) et les exigences du cadre

Risque OWASP MCP Top 10 (2025, bêta)	Exigences et sections du cadre
MCP01 Gestion des jetons et exposition de secrets	EXIG-MCP-11, EXIG-MCP-18, EXIG-MCP-21; section 9.2
MCP02 Élévation de privilèges par dérive des portées	EXIG-MCP-10; section 9.3
MCP03 Empoisonnement d'outil	EXIG-MCP-14, EXIG-MCP-20, EXIG-SEC-18
MCP04 Chaîne d'approvisionnement	EXIG-MCP-20, EXIG-SEC-18; section 9.8
MCP05 Injection et exécution de commandes	EXIG-MCP-08, EXIG-MCP-19; section 9.7
MCP06 Injection d'invite par charges contextuelles	EXIG-MCP-20; section 9.6
MCP07 Authentification et autorisation insuffisantes	EXIG-MCP-09, EXIG-MCP-12, EXIG-MCP-13
MCP08 Absence d'audit et de télémétrie	EXIG-MCP-10; EXIG-OBS-01 et section 10.3 (journal d'audit)
MCP09 Serveurs MCP fantômes	EXIG-MCP-01, EXIG-MCP-02; section 11.4
MCP10 Injection de contexte et surpartage	EXIG-MCP-03, EXIG-MCP-16, EXIG-MCP-17

Migration vers la révision 2026-07-28

Les deux générations du protocole coexisteront pendant un temps. Un client peut détecter la génération d'un serveur en tentant une requête moderne et en examinant l'erreur 400 éventuelle avant de revenir à `initialize`; un client de l'entreprise ne revient jamais à `initialize` pour un serveur inscrit au catalogue en 2026-07-28, et la sonde ne sert qu'à l'inventaire et au développement. Sur stdio, `server/discover` sert de sonde de rétrocompatibilité. Un serveur qui ne connaît que 2026-07-28 devrait répondre 405 aux requêtes GET et DELETE et ignorer les en-têtes `Mcp-Session-Id` et `Last-Event-ID`[168, 190]; une version non prise en charge entraîne l'erreur −32022[162]. La migration se fait en sept étapes.

1. Inventorier les serveurs et les clients et inscrire leur révision au catalogue : `server/discover` pour les serveurs à jour, réponse à `initialize` pour les autres.
2. Ouvrir à la passerelle une double prise en charge bornée : les requêtes 2026-07-28 sont validées par en-têtes et par corps; les requêtes antérieures ne sont acceptées que pour les serveurs inscrits avec une date de migration et sont contrôlées par inspection du corps.
3. Remplacer l'état de session par des identifiants explicites (EXIG-MCP-17) et les requêtes initiées par le serveur par MRTR.
4. Remplacer Sampling par des appels à la passerelle de modèles, Roots par des paramètres d'outil ou des URI de ressource, et la journalisation protocolaire par la sortie d'erreur standard ou OpenTelemetry (section 10.1).
5. Remplacer le DCR par le préenregistrement ou les CIMD (EXIG-MCP-12).
6. Faire passer les tests de contrat et de conformité (section 6.8). Le cadre officiel de tests de conformité MCP reste en préversion (versions 0.x : 0.1.16 courante, 0.2.0-alpha.12 publiée le 1er octobre 2026) : il suit le régime des suites de conformité de l'EXIG-INT-19 et complète les tests internes sans les remplacer[225, 226].
7. Retirer de la passerelle la prise en charge de la révision antérieure à l'échéance fixée.

> **`EXIG-MCP-22` · DOIT**
> **Migration bornée et abandon des fonctions dépréciées**
> Pendant une période de coexistence bornée, la passerelle **DOIT** accepter la génération antérieure de MCP pour les seuls serveurs inscrits au catalogue avec une date de migration, et la refuser pour tout

autre. Tous les serveurs et clients en production **DOIVENT** avoir migré vers la révision 2026-07-28 ou vers une révision ultérieure épinglée au catalogue au plus tard le 28 juillet 2027, échéance du cadre qui ne change que par une révision (section 1.6). Un nouveau développement ne doit pas s'appuyer sur une fonction dépréciée (Roots, Sampling, journalisation protocolaire, DCR, transport HTTP+SSE), et toute intégration en production **DOIT** avoir cessé de les employer à la même échéance. Pendant la transition, un client traite −32002 (serveurs antérieurs) comme « ressource introuvable » en réponse à `resources/read`; il ne traite −32602 ainsi que si `error.data` le désigne comme tel, sinon comme une erreur de paramètres, et journalise tout −32602 avec l'identifiant de trace.

Pourquoi : Roots, Sampling, la journalisation et le DCR deviennent admissibles au retrait à partir de la première révision publiée le 28 juillet 2027 ou après (le transport HTTP+SSE obéit à une échéance distincte : trois mois après que la SEP-2596 atteint l'état final, soit dès le début de septembre 2026, cette SEP étant finale depuis le 3 juin 2026, annexe H)[196]. L'échéance retenue, choix du cadre, vise à la fois le changement de génération et l'abandon des fonctions dépréciées, deux opérations distinctes : migrer vers 2026-07-28 ne retire pas Sampling d'une intégration. Elle précède la première révision qui pourrait retirer Roots, Sampling, la journalisation et le DCR, celle de la fin de septembre 2027 si le calendrier de la SEP-3398 est tenu (annexe H). Pour le transport HTTP+SSE, elle suit au contraire la première révision qui peut le retirer (celle du 30 mars 2027 si la SEP-3398 est tenue) : le cadre assume cet écart, qui expose un client ou un serveur encore sur ce transport à une rupture dès cette révision, et l'annexe H le renvoie au comité. La spécification recommande aux clients d'accepter aussi −32002, code employé par les versions antérieures pour « ressource introuvable »[227].

6.6 Intégration horizontale : protocole Agent2Agent

Cette section fixe les règles d'usage du protocole Agent2Agent (A2A), qui relie un agent à un autre agent lorsque l'appelant délègue un sous-objectif complet sans connaître le fonctionnement interne de l'appelé. MCP (section 6.5) relie un agent à des outils dont les entrées et les sorties sont définies; A2A relie des agents autonomes, potentiellement opaques, qui raisonnent et conservent un état sur des échanges à plusieurs tours[39]. Le cadre retient la version de protocole 1.0 (publication 1.0.0 du 12 mars 2026, correctif 1.0.1 du 28 mai 2026)[30].

Rôle, historique et gouvernance

Google a annoncé A2A le 9 avril 2025 avec plus de 50 partenaires[21], puis l'a confié à la Linux Foundation le 23 juin 2025[22]. La version 0.3.0 (30 juillet 2025) a ajouté gRPC et les cartes d'agent signées, et renommé en `agent-card.json` le chemin de découverte[228, 229]. L'Agent Communication Protocol (ACP) d'IBM Research a fusionné avec A2A à la fin d'août 2025 : fusion annoncée le 25 août, dépôt archivé le 27 août, annonce de la fondation LF AI & Data (Linux Foundation) le 29 août[24, 230]. La version 1.0.0, première version stable, a paru le 12 mars 2026[29]. A2A est devenu un projet de stade « Growth » de l'Agentic AI Foundation (AAIF), transfert annoncé le 17 août 2026 et confirmé par le billet du projet du 27 août 2026[5, 35]. La chronologie d'ensemble figure à la section 2.2.

Trois faits fondent le choix d'A2A comme protocole agent-agent par défaut. Sa gouvernance est neutre : un comité directeur technique de neuf sièges le pilote : les huit entreprises de la composition annoncée le 12 mars 2026 (AWS, Cisco, Google, IBM Research, Microsoft, Salesforce, SAP et ServiceNow)[29], et Bloomberg depuis le 20 octobre 2026 (erratum, annexe H), sous l'égide de la fondation qui héberge aussi MCP. Son adoption est large : plus de 150 organisations le soutiennent (Linux Foundation, 9 avril 2026), et Microsoft et AWS l'ont intégré à leurs plateformes d'agents[15]. Son outillage est ouvert : six SDK officiels (Python, JavaScript, Java, Go, .NET et Rust), une trousse de compatibilité (`a2a-tck`), un inspecteur et une interface en ligne de commande[231, 232].

ATTENTION : AU MOINS QUATRE PROTOCOLES « ACP »

Le sigle désigne au moins quatre protocoles : (1) l'Agent Communication Protocol d'IBM, fusionné dans A2A; (2) l'Agent Connect Protocol d'AGNTCY, dont le dépôt est archivé depuis le 11 avril 2026; (3) l'Agent Client Protocol, créé par Zed pour relier les éditeurs de code aux agents de codage; (4) l'Agentic Commerce Protocol d'OpenAI et de Stripe[183, 233, 234]. Toute offre qui invoque un « ACP » pour coordonner des agents se vérifie au regard de ces sens; la liste n'est pas exhaustive.

EXIG-A2A-01 · DOIT

A2A 1.0 pour toute délégation entre agents

Toute délégation à un agent d'un autre domaine, d'un autre cadriciel, d'un tiers ou d'un autre processus **DOIT** utiliser A2A, dans la version de protocole épinglée au catalogue (valeur initiale : 1.0), sauf pendant la coexistence bornée de l'EXIG-A2A-15. Un protocole agent-agent propriétaire **DOIT** être contenu derrière un adaptateur, conformément au catalogue (section 6.3). Seuls les transferts entre sous-agents d'un même orchestrateur, dans un même processus, en sont exemptés (EXIG-INT-05). Une cible est un agent si elle choisit elle-même, au moyen d'un modèle, les actions qu'elle exécute; sinon c'est un outil, même si elle conserve l'état d'une tâche ou demande une précision (extension Tasks, élicitation MCP).

Pourquoi : un contrat d'échange unique évite une intégration ad hoc par paire d'agents et garde l'agent appelé remplaçable.

Carte d'agent 1.0

La carte d'agent *(Agent Card)* est le contrat public d'un agent : un document JSON qui dit qui il est, ce qu'il sait faire, où le joindre et comment s'authentifier. Un agent exposé la publie à `https://{domaine}/.well-known/agent-card.json`, URI unique par nom d'hôte : chaque agent exposé reçoit donc son propre nom d'hôte (p. ex. `risque-credit.agents.ent.ca`), à défaut de quoi le champ `tenant` distingue les agents d'un même point d'accès; l'ancien chemin `/.well-known/agent.json` appartient aux versions 0.1 et 0.2, désormais obsolètes[30, 68]. La définition normative des objets est le fichier `a2a.proto`, sérialisé en ProtoJSON; les énumérations s'écrivent en majuscules préfixées, par exemple `TASK_STATE_WORKING`[68]. Le tableau 19 résume les champs et les règles du cadre; un exemple complet figure à l'annexe C.

Tableau 19 — Champs de la carte d'agent A2A 1.0 et règles du cadre

Champ	Statut dans A2A 1.0	Règle du cadre
`name`, `description`	Obligatoires	Nom identique à la fiche du registre; description qui dit ce que fait l'agent et ce qu'il ne fait pas.
`supportedInterfaces`	Obligatoire; liste ordonnée, la première entrée est préférée; chaque entrée exige `url`, `protocolBinding` et `protocolVersion`, `tenant` est facultatif	Adresses de la passerelle d'agents, jamais l'adresse directe de l'agent (cartes des agents de l'entreprise et cartes de façade des agents de tiers, EXIG-A2A-02).
`version`	Obligatoire; format libre	SemVer (versionnage sémantique; voir la section 6.8), incrémentée à chaque changement publié; l'`ETag` dérive du hachage de la représentation servie (EXIG-A2A-04).
`capabilities`	Obligatoire; sous-champs facultatifs `streaming`, `pushNotifications`, `extensions`, `extendedAgentCard`	Déclarer le comportement réel; extensions approuvées seulement.
`defaultInputModes`, `defaultOutputModes`	Obligatoires	Types média effectivement acceptés et produits.

Champ	Statut dans A2A 1.0	Règle du cadre
`skills`	Obligatoire; chaque compétence exige `id`, `name`, `description` et `tags`	`id` stable, en minuscules séparées par des traits d'union (kebab-case, convention du cadre); une portée OAuth par compétence.
`securitySchemes`, `securityRequirements`	Facultatifs; aucun secret dans la carte	Obligatoires; renvoient au fournisseur d'identité de l'entreprise (pour une carte de façade, celui qu'emploie la passerelle).
`signatures`	Facultatif	Obligatoire : signature JWS (JSON Web Signature) sur la carte canonisée.
`provider`, `documentationUrl`, `iconUrl`	Facultatifs	`provider` renseigné par la direction responsable.

Sources : spécification A2A 1.0 et `a2a.proto`[192, 235]; règles : choix du cadre.

Signature. La carte peut être signée en JWS (RFC 7515)[496] après canonisation JCS *(JSON Canonicalization Scheme)*, le champ `signatures` étant exclu du contenu signé; la spécification recommande au client de vérifier au moins une signature avant de faire confiance à la carte et interdit de vérifier avec une clé expirée ou révoquée[68, 236]. Le cadre rend la signature obligatoire : une carte non signée s'imite aussi facilement qu'une page web.

Carte étendue. La capacité `extendedAgentCard` active l'opération `GetExtendedAgentCard`, qui exige une authentification et vérifie les permissions du client; la carte étendue ne devrait pas contenir d'information sensible exploitable en cas de fuite[68]. On publie ainsi une carte publique minimale et l'on réserve les compétences internes aux clients autorisés.

Découverte et cache. La spécification admet trois modes de découverte : URI bien connue, registre organisé (sans API de registre normalisée) et configuration directe; l'accès aux cartes peut être restreint par mTLS, filtrage réseau ou OAuth[237]. Dans l'entreprise, la découverte passe par le catalogue d'entreprise, auquel renvoie la fiche de l'agent au registre (section 11.4; EXIG-INT-17). Le guide de découverte recommande un en-tête `Cache-Control`, un `ETag` dérivé du champ `version` ou d'un hachage, et des requêtes conditionnelles (`If-None-Match`)[237]. Comme la spécification n'impose pas SemVer pour `version`[68], le cadre l'impose : sans incrément fiable, un client garderait en cache une carte périmée.

Métadonnées de gouvernance. La carte 1.0 n'a pas de champ libre au premier niveau, et une extension ne peut pas modifier les structures de base[192, 238]. Le niveau d'autonomie, la classe de risque, le centre de coûts et la classification maximale des données restent donc à la fiche du registre (annexe B). Si un pair doit les lire, ils se déclarent comme extension de données dans les `capabilities.extensions` de la carte étendue seulement, jamais dans la carte publique (EXIG-A2A-06). Une extension y figure avec son URI, qui porte la version, une description, l'indicateur `required` et ses paramètres; elle s'active par l'en-tête `A2A-Extensions`, un changement incompatible exige une nouvelle URI, et aucune extension ne doit contourner les contrôles de sécurité de l'agent[238].

> **`EXIG-A2A-02` · DOIT**
> **Carte publiée et inscrite au catalogue**
> Tout agent invocable par d'autres agents **DOIT** publier une carte conforme à A2A 1.0 et aux règles du tableau 19, l'inscrire au catalogue d'entreprise (et la rattacher à sa fiche au registre, section 11.4) et déclarer dans `supportedInterfaces` les adresses de la passerelle d'agents. Un agent exposé hors de l'entreprise **DOIT** aussi publier sa carte à l'URI bien connue; un agent interne ne la publie pas : la carte inscrite au catalogue est sa carte de référence, servie par la passerelle, et la fiche du registre y renvoie. Pour un agent de tiers, le catalogue conserve la carte d'origine, signée par le tiers et vérifiée à l'homologation, avec son empreinte; la passerelle sert aux agents de l'entreprise une carte de façade,

qui porte ses propres adresses, est signée par une clé de l'entreprise et référence l'empreinte de la carte d'origine. Aucun client de l'entreprise ne suit les `supportedInterfaces` d'une carte d'origine.
Pourquoi : la découverte passe par une source contrôlée, et aucun appel ne contourne la passerelle (section 9.4).

`EXIG-A2A-03` · DOIT
Carte signée et vérifiée
Toute carte inscrite au catalogue d'entreprise **DOIT** porter au moins une signature JWS valide, calculée sur la carte canonisée JCS avec une clé de l'émetteur de la carte (clé gérée par l'entreprise pour ses propres agents et pour les cartes de façade; pour la carte d'origine d'un agent de tiers, clé dont le catalogue consigne la confiance). La règle vaut aussi pour la carte étendue. La passerelle d'agents et les clients **DOIVENT** rejeter une carte sans signature valide ou signée par une clé expirée ou révoquée, rejeter un `jku` ou un `kid` absent du catalogue et refuser une carte de version inférieure à la dernière qu'ils ont vue. Pour les clients externes, l'entreprise publie son jeu de clés (JWKS) sur son domaine principal. La carte ne doit pas contenir de secret.
Pourquoi : une carte usurpée détournerait des tâches et des données vers un faux agent, risque que l'OWASP classe sous ASI07, communication interagents non sécurisée[28].

`EXIG-A2A-04` · DOIT
Version de carte et revalidation du cache
Le champ `version` de la carte **DOIT** suivre SemVer et être incrémenté à chaque changement publié (règle du cadre). Le serveur qui sert la carte (l'URI bien connue pour un agent exposé, la passerelle pour une carte de référence ou de façade) **DOIT** fournir un `ETag` fort, dérivé du hachage de la représentation servie, signatures comprises, et un `Cache-Control`; une nouvelle signature est un changement publié; le catalogue et les clients **DOIVENT** revalider leur copie par requête conditionnelle. Les règles de compatibilité et de coexistence des versions sont celles de la section 6.8.
Pourquoi : le hachage change dès qu'un octet de la carte change, signatures comprises, ce qu'un numéro de version ne garantit pas; un 304 ne peut donc pas prolonger une carte signée par une clé révoquée (le guide de découverte admet un ETag dérivé d'un hachage). SemVer reste le signal de compatibilité (section 6.8).

`EXIG-A2A-05` · NE DOIT PAS
Aucun champ hors norme dans la carte
Une carte **NE DOIT PAS** contenir de champ non défini par A2A 1.0, par exemple `x-enterprise-governance`. Une extension **NE DOIT PAS** être publiée sauf si son URI figure au catalogue d'entreprise parmi les extensions approuvées, après revue de sécurité; l'indicateur `required: true` doit recevoir une dérogation du comité d'architecture et des risques agentiques (EXIG-APP-02).
Pourquoi : un champ hors norme n'a aucune sémantique garantie chez les pairs, et une extension obligatoire exclut tout client qui ne la prend pas en charge (erreur `ExtensionSupportRequiredError`)[68].

`EXIG-A2A-06` · DOIT
Compétences internes dans la carte étendue
Pour un agent exposé hors de l'entreprise, les compétences réservées à des consommateurs internes **DOIVENT** être publiées dans la carte étendue, servie par `GetExtendedAgentCard` après authentification et contrôle des permissions, et la carte publique se limite aux compétences destinées aux appelants externes. La carte d'un agent interne, servie aux seuls clients authentifiés (EXIG-A2A-02), porte toutes ses compétences. L'extension de gouvernance ne figure que dans la carte étendue.

> Pourquoi : la carte publique est lisible par tous; elle ne doit pas cartographier la surface interne de l'entreprise.

Tâches, messages et artefacts

A2A organise le travail en tâches *(Task)*. Le client envoie un message; le serveur crée la tâche et lui attribue son identifiant, le client ne pouvant pas en imposer un pour une nouvelle tâche (un réessai de `SendMessage` peut donc créer une seconde tâche, d'où la règle de l'EXIG-A2A-07); `contextId` regroupe les tâches et les messages d'une même interaction[68]. Les messages et les artefacts, c'est-à-dire les résultats produits par la tâche, se composent de parties *(Part)*. En 1.0, une partie porte exactement un des membres `text`, `raw` (octets encodés en base64), `url` ou `data` (JSON structuré), avec `mediaType`, `filename` et `metadata` facultatifs; elle remplace les anciens `TextPart`, `FilePart` et `DataPart`[192, 235].

Une tâche suit une machine à huit états réels (neuf valeurs d'énumération avec la valeur zéro, figure 8). Deux états sont actifs (`SUBMITTED`, `WORKING`); deux sont interrompus : `INPUT_REQUIRED` quand l'agent attend une précision ou une approbation, `AUTH_REQUIRED` quand il lui faut un justificatif supplémentaire; quatre sont terminaux (`COMPLETED`, `FAILED`, `CANCELED`, `REJECTED`); la valeur zéro `TASK_STATE_UNSPECIFIED` ne désigne aucun état réel[192]. Une tâche terminale n'accepte plus de message (`UnsupportedOperationError`) et ne peut plus être annulée (`TaskNotCancelableError`)[68]. Les graphies minuscules comme `input-required` appartiennent aux versions 0.x et ne s'emploient plus.

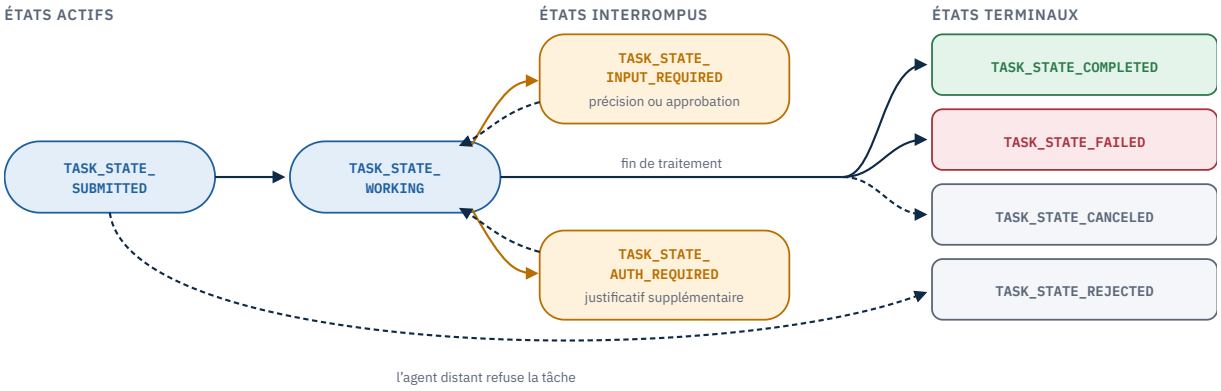


Figure 8 — Cycle de vie d'une tâche A2A 1.0. Une tâche passe de soumise à en cours, peut s'interrompre pour obtenir une précision, une approbation ou un justificatif, puis aboutit à l'un des quatre états terminaux, après lesquels elle n'accepte plus de message. Les traits pleins montrent la progression nominale; les pointillés, le retour d'un état interrompu vers l'exécution, l'annulation et le refus de la tâche par l'agent distant. Source : A2A Project, `a2a.proto`, version de protocole 1.0.

Le protocole définit les opérations `SendMessage`, `SendStreamingMessage`, `GetTask`, `ListTasks`, `CancelTask`, `SubscribeToTask`, `GetExtendedAgentCard` et quatre opérations de gestion des configurations de notification push. Par défaut, `SendMessage` attend que la tâche atteigne un état terminal ou interrompu; avec `returnImmediately: true`, il rend la main dès la création de la tâche. `ListTasks` pagine par curseur et omet les artefacts par défaut, ce qui convient aux tableaux de bord d'exploitation[68]. Le client suit une tâche longue de trois façons : interrogation périodique (`GetTask`), flux en continu (SSE ou gRPC) ou notifications push[29, 68]. Dans la liaison HTTP+JSON, une erreur prend la forme d'un `google.rpc.Status` accompagné d'un `google.rpc.ErrorInfo` du domaine `a2a-protocol.org`[68].

EXIG-A2A-07 · DOIT
Suivi des tâches longues
Lorsque la durée attendue d'une tâche, déclarée par compétence au catalogue (95e centile mesuré), dépasse 5 secondes (seuil fixé par le cadre), le client **DOIT** la suivre par flux en continu (`SendStreamingMessage`) ou par notification push, y compris pour le message qui relance une tâche interrompue; un flux ouvert porte des battements de cœur. L'interrogation par `GetTask` peut servir à rétablir le suivi après une coupure, mais ne doit pas servir au suivi courant; la reprise par `SubscribeToTask` est permise après une coupure ou un état interrompu. Avant de réessayer un envoi dont la réponse s'est perdue, le client **DOIT** rechercher une tâche existante par `contextId` et par identifiant de message (`messageId`), et l'agent serveur **DOIT** rattacher à la tâche existante un message déjà reçu. Un délai maximal, inscrit au catalogue, borne les états `INPUT_REQUIRED` et `AUTH_REQUIRED`; à son terme, le serveur clôt la tâche dans un état terminal.
Pourquoi : une connexion bloquante longue se heurte aux délais des intermédiaires réseau, et une boucle d'interrogation consomme sans rien apprendre; la spécification laisse ce choix au client, d'où cette règle interne. La spécification permet à l'agent de détecter un message en double par son `messageId` sans l'y obliger[68]; le cadre l'impose, pour que la clé d'idempotence de l'agent appelé reste stable d'un essai à l'autre (section 7.6).

Liaisons, versions et sécurité

A2A 1.0 définit trois liaisons standard dérivées d'un même modèle abstrait : JSON-RPC 2.0 sur HTTP(S), gRPC sur HTTP/2 avec TLS, et HTTP+JSON (REST), dont le JSON est structurellement équivalent aux définitions Protobuf. La spécification exige d'un agent qui offre plusieurs liaisons une équivalence fonctionnelle (mêmes opérations, résultats sémantiquement équivalents, mêmes erreurs, mêmes schémas d'authentification), et d'une liaison personnalisée un comportement cohérent avec les opérations abstraites[68]. Le cadre retient JSON-RPC comme liaison commune, car certaines passerelles ne relaient que celle-là : Azure API Management, par exemple, n'importe les API d'agents A2A qu'en JSON-RPC[109]. La liaison SLIMRPC d'AGNTCY est expérimentale et ne fait pas partie des liaisons standard[239] (section 6.9).

Chaque requête porte l'en-tête `A2A-Version` au format majeur.mineur (p. ex. `1.0`), ou le paramètre de requête équivalent. Un en-tête vide est interprété comme la version 0.3 (la spécification ne dit rien de l'en-tête absent, que le cadre assimile à un en-tête vide), et un agent qui ne prend pas en charge la version demandée renvoie `VersionNotSupportedError`[68] : un client 1.0 qui omet l'en-tête échoue donc contre un serveur 1.0 strict. Le type média `application/a2a+json` est recommandé pour la seule liaison HTTP+JSON; JSON-RPC emploie `application/json`, les flux `text/event-stream` et gRPC Protobuf[68].

Pour la sécurité, la spécification pose les bases et le cadre les durcit. La sécurité de transport est obligatoire en production; la spécification recommande TLS 1.3, et le guide d'implémentation en entreprise admet TLS 1.2 ou plus[68, 161]. L'identité relève de la couche transport : les justificatifs s'obtiennent hors bande et voyagent dans les en-têtes HTTP; le serveur authentifie chaque requête (401 si le justificatif manque ou est invalide, 403 s'il est insuffisant) et autorise avant toute opération susceptible de divulguer de l'information. L'autorisation peut se faire par compétence, chaque `AgentSkill` pouvant porter ses propres exigences de sécurité[161, 192]. La version 1.0 retire les flux OAuth implicite et par mot de passe, et ajoute le flux Device Code et PKCE[30]. Le champ `tenant` permet à un point d'accès d'héberger plusieurs agents ou locataires, les résultats devant rester dans le périmètre autorisé de l'appelant. Enfin, l'agent valide tous ses paramètres d'entrée, limite la taille des messages et des fichiers, et ne journalise ni justificatifs ni renseignements personnels sans protection[68].

Les notifications push demandent une attention particulière : c'est l'agent serveur qui appelle une URL fournie par le client, un point de rappel HTTP *(webhook)*, ce qui en fait une cible de SSRF. La spécification exige que l'agent joigne les justificatifs prévus par la configuration et tente au moins une livraison; elle

recommande un délai d'expiration de 10 à 30 secondes, des reprises avec repli exponentiel et le rejet des URL visant `127.0.0.0/8`, `10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`, `localhost` ou une adresse lien-local. Le récepteur doit valider l'authenticité de la notification et répondre par un code 2xx; il devrait vérifier que la tâche signalée est l'une des siennes. La livraison est tentée « au moins une fois », sans garantie de succès (reprises facultatives) et avec des doublons possibles, d'où un traitement idempotent[68].

`EXIG-A2A-08` · DOIT
Version annoncée et liaisons standard
Tout client A2A **DOIT** envoyer `A2A-Version` à chaque requête, sauf un client 0.3 pendant la période de l'EXIG-A2A-15. Tout agent **DOIT** exposer la liaison JSON-RPC et peut ajouter gRPC ou HTTP+JSON lorsque la passerelle d'agents les prend en charge, à condition d'offrir par chaque liaison les mêmes opérations, les mêmes erreurs et les mêmes schémas d'authentification. Une liaison non standard, dont SLIMRPC, ne sert pas en production; elle n'est employée qu'en essai hors production, sans données réelles, conformément à son statut Surveiller au catalogue (EXIG-INT-06).
Pourquoi : la version explicite évite les replis silencieux vers 0.3, et une liaison commune garde chaque agent joignable par toutes les plateformes retenues.

`EXIG-A2A-09` · DOIT
Transport chiffré et authentification à chaque requête
Tout échange A2A **DOIT** négocier TLS 1.3 lorsque le pair le permet, TLS 1.2 au minimum, versions antérieures désactivées, avec validation des certificats, transiter par la passerelle d'agents et être authentifié à chaque requête. L'agent serveur **DOIT** autoriser avant toute opération qui lit ou divulgue de l'information, valider ses paramètres et borner la taille des messages et des fichiers. Un message ou une tâche A2A reçu est une source de contexte au sens de l'EXIG-SEC-03 et porte les étiquettes de la session qui l'a produit (EXIG-SEC-04).
Pourquoi : la passerelle applique au trafic entre agents les contrôles déjà appliqués aux outils; la documentation A2A recommande fortement une solution de gestion d'API pour les agents exposés[161].

`EXIG-A2A-10` · DOIT
Autorisation par compétence et par locataire
Chaque compétence publiée **DOIT** être associée à une portée OAuth dédiée, déclarée dans ses `securityRequirements` et inscrite au catalogue. L'appelant **DOIT** présenter à la passerelle un jeton délégué dont l'audience est la passerelle, à l'adresse publiée dans `supportedInterfaces`; la passerelle en obtient par échange un second, à audience unique, pour l'agent appelé (section 9.3, EXIG-IAM-12 et IAM-14). Comme un message A2A s'adresse à l'agent, la compétence visée **DOIT** être désignée par une métadonnée d'une extension approuvée (EXIG-A2A-05), que la passerelle vérifie contre la portée du jeton, et l'agent serveur **DOIT** router de façon déterministe vers cette seule compétence; à défaut, chaque compétence a son propre point d'accès. Lorsqu'un point d'accès sert plusieurs locataires, la passerelle **DOIT** vérifier que le `tenant` demandé figure parmi les locataires que le jeton autorise.
Pourquoi : le moindre privilège s'applique à la compétence, pas à l'agent entier; un jeton valide pour analyser un dossier ne doit pas permettre d'accorder un prêt.

`EXIG-A2A-11` · NE DOIT PAS
Flux OAuth permis et flux retirés
Les agents et leurs clients **NE DOIVENT PAS** employer l'octroi implicite ni l'octroi par mot de passe. Ils doivent utiliser le code d'autorisation avec PKCE (ou le Device Code pour un appareil sans navigateur,

réservé aux clients inscrits au catalogue, sous accès conditionnel et avec une durée de code courte) quand une personne s'authentifie, les justificatifs client, authentifiés par mTLS, `private_key_jwt` ou SVID et jamais par secret partagé, pour un agent qui agit en son nom propre et, pour la délégation, l'échange de jetons de la RFC 8693.

Pourquoi : A2A 1.0 a retiré ces flux[30, 240], et la RFC 9700 interdit l'octroi par mot de passe et déconseille l'octroi implicite[175]. Les flux permis sont ceux du profil de la RFC 9700[175] et de l'échange de jetons de la RFC 8693[70].

`EXIG-A2A-12` · DOIT

Notifications push durcies

Le cadre rend obligatoires les recommandations de la spécification. L'agent serveur **DOIT** appliquer à l'URL de webhook, à l'enregistrement et à chaque livraison, la règle de sortie réseau de l'EXIG-SEC-12, sortir par la passerelle d'agents ou par le mandataire de sortie, appliquer un délai d'expiration compris entre 10 et 30 secondes et des reprises à repli exponentiel, bornées en nombre et en durée au catalogue. Un récepteur interne légitime, comme un orchestrateur de l'entreprise, est atteint par son entrée de catalogue, jamais par l'URL fournie. Le récepteur **DOIT** authentifier la notification, vérifier que l'identifiant de tâche lui appartient et traiter chaque notification de façon idempotente.

Pourquoi : un webhook non filtré permet à un client malveillant de faire sonder le réseau interne par l'agent.

`EXIG-A2A-13` · DOIT

Traçage et corrélation des tâches

Chaque appel A2A **DOIT** propager l'en-tête W3C `traceparent` et être tracé côté appelant par un span `invoke_agent` de type CLIENT. Vers un agent hors du périmètre de confiance, la passerelle ouvre une nouvelle trace reliée par un lien de span et filtre `baggage` par liste d'autorisation (EXIG-OBS-02). Le journal d'audit **DOIT** consigner `taskId`, `contextId` et l'identifiant de trace (section 10.1 et section 10.3).

Pourquoi : la v1.41.0 des conventions OpenTelemetry n'a pas de convention propre à A2A (une convention A2A, au niveau Development, figure depuis peu dans la branche principale du dépôt semantic-conventions-genai, sans version étiquetée)[241]; la convention des agents trace un agent distant par un span `invoke_agent` CLIENT[120], et la documentation A2A recommande le traçage distribué[161].

Déroulement d'une délégation avec approbation

La figure 9 montre comment A2A, MCP et l'approbation humaine se combinent. Un orchestrateur confie l'analyse d'un dossier de crédit commercial à un agent spécialiste; l'inscription de la décision dans l'ERP est classée P3 au catalogue et exige donc deux approbations humaines d'approbateurs distincts (agent de classe élevée et outil P3, section 8.3 et EXIG-AUT-15).

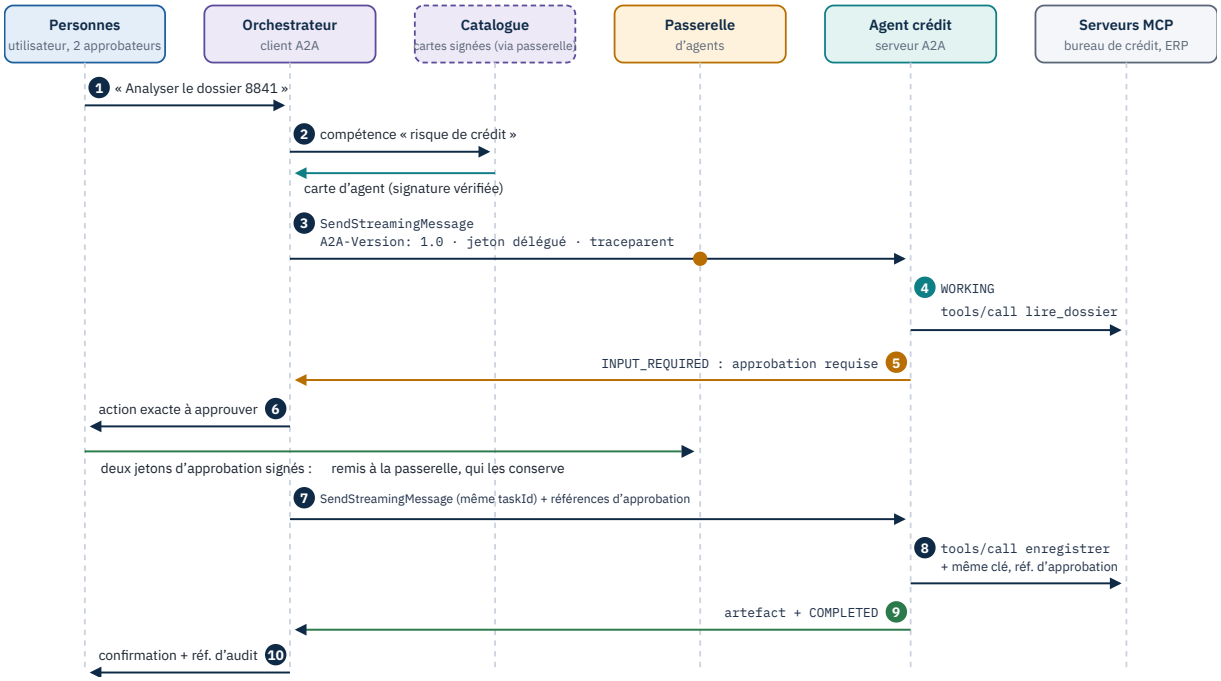


Figure 9 — Délégation A2A avec appel MCP et approbation humaine. Les numéros renvoient aux étapes ci-dessous. La passerelle d'agents se trouve sur chaque appel, et l'écriture n'a lieu qu'avec deux jetons d'approbation liés à l'action exacte (EXIG-AUT-15). Le couloir « Personnes » réunit l'utilisateur et les deux approbateurs habilités distincts (section 8.5); les jetons d'approbation restent à la passerelle, qui n'en communique que les références, données non secrètes. Source : élaboration du cadre, d'après la spécification A2A 1.0 et MCP 2026-07-28.

1. L'utilisateur demande à l'orchestrateur d'analyser le dossier 8841.
2. L'orchestrateur cherche au catalogue d'entreprise la compétence « risque de crédit », obtient la carte de l'agent spécialiste et en vérifie la signature.
3. Il obtient un jeton délégué dont l'audience est la passerelle, puis envoie `SendStreamingMessage` à la passerelle avec `A2A-Version: 1.0`, le jeton et `traceparent`; la passerelle l'échange contre un jeton à audience unique pour l'agent crédit. Le message porte le sous-objectif structuré et des références de documents, jamais l'historique brut de la conversation (section 7.7).
4. L'agent crédit passe à `WORKING` et lit le dossier par un outil MCP (`tools/call`), sous un jeton échangé pour l'audience du serveur MCP.
5. Prêt à inscrire sa recommandation motivée (il n'accorde ni ne refuse aucun crédit, carte C.3), il passe à `INPUT_REQUIRED` et décrit, dans une partie `data`, l'action exacte à approuver : outil, arguments (clé d'idempotence comprise), montant.
6. L'orchestrateur soumet cette action à deux approbateurs habilités distincts (action P3 d'un agent de classe élevée, dont au moins un n'est pas le mandant), hors de la conversation; chaque approbation produit un jeton signé lié à l'empreinte de l'action (section 8.5, EXIG-AUT-15).
7. L'orchestrateur envoie un nouveau message rattaché au même `taskId`, qui transmet les références des deux approbations; les jetons signés restent à la passerelle (EXIG-AUT-12).
8. L'agent crédit appelle l'outil d'écriture de l'ERP avec les références d'approbation et une clé d'idempotence (section 7.6); la passerelle vérifie que les deux jetons, valides et d'approbateurs distincts dont un autre que le mandant, correspondent exactement à cet appel avant de le relayer.
9. L'agent livre son artefact, et la tâche passe à `COMPLETED`.
10. L'orchestrateur confirme le résultat à l'utilisateur avec la référence du journal d'audit.

Si l'un des approbateurs refuse ou si le délai d'approbation expire, l'orchestrateur annule la tâche (`CancelTask`) et aucune écriture n'a lieu. Un « oui » saisi dans la conversation n'est jamais une approbation : seuls comptent les jetons signés, vérifiés par la passerelle.

Migration et compatibilité

Une carte 1.0 peut annoncer à la fois des interfaces 0.3 et 1.0, distinguées par `protocolVersion`, et les SDK officiels assurent la rétrocompatibilité[29, 68]. Les principaux changements à absorber sont les suivants : `supportedInterfaces` remplace `url`, `preferredTransport` et `additionalInterfaces`; les parties sont unifiées; les états prennent le préfixe `TASK_STATE_`; l'opération de flux devient `SendStreamingMessage`[235]. Les SDK n'ont pas atteint la 1.0 en même temps : celui de JavaScript n'est en disponibilité générale que depuis le 22 juillet 2026[242]. La trousse `a2a-tck` teste les trois liaisons standard, à partir des interfaces déclarées dans la carte, selon trois niveaux : MUST (échec bloquant), SHOULD (échec signalé, non bloquant) et MAY (test sauté si la fonction n'est pas déclarée)[243]. L'interface en ligne de commande officielle, présentée le 1er octobre 2026 (versions publiées dès le 9 septembre 2026), s'insère dans les chaînes d'intégration grâce à sa sortie JSON et à ses codes de sortie prévisibles, par exemple pour des tests de vérification rapide *(smoke tests)*[244, 245].

EXIG-A2A-14 · DOIT
Compatibilité vérifiée avant inscription
Un agent **DOIT** réussir tous les tests de niveau MUST d'`a2a-tck`, sur chaque liaison déclarée, avant son inscription au registre, à chaque déploiement de l'agent (code ou SDK compris) et à chaque nouvelle version de sa carte, avec une version d'`a2a-tck` épinglée à une étiquette au catalogue. Tant que la ligne visée de la trousse est alpha, seuls bloquent les tests MUST restés stables pendant deux versions de la trousse; les autres résultats sont consignés. Tout échec d'un test de niveau SHOULD **DOIT** être consigné à la fiche (annexe B, bloc « Évaluation »), avec une échéance de correction.
Pourquoi : la conformité se prouve par un test reproductible, pas par une déclaration du fournisseur.

EXIG-A2A-15 · DEVRAIT
Migration bornée depuis la version 0.3
Un agent encore en 0.3 **DEVRAIT** migrer par double publication : sa carte annonce une interface 1.0 et une interface 0.3, cette dernière portant une date de retrait absolue inscrite au catalogue, au plus six mois après l'approbation du cadre ou, si elle est postérieure, après l'inscription de l'agent (choix du cadre). Passé cette date, conformément à l'EXIG-INT-06 et à l'EXIG-A2A-08, la passerelle refuse toute requête dont la version effective (en-tête `A2A-Version` ou paramètre de requête, une valeur absente ou vide valant 0.3) n'est pas prise en charge par l'interface inscrite au catalogue.
Migration bornée depuis la version 0.3
Un agent encore en 0.3 doit migrer par double publication : sa carte annonce une interface 1.0 et une interface 0.3, cette dernière portant une date de retrait absolue inscrite au catalogue, au plus six mois après l'approbation du cadre ou, si elle est postérieure, après l'inscription de l'agent (choix du cadre). Passé cette date, la passerelle doit refuser toute requête dont la version effective (en-tête `A2A-Version` ou paramètre de requête, une valeur absente ou vide valant 0.3) n'est pas prise en charge par l'interface inscrite au catalogue.
Pourquoi : la coexistence évite de basculer tous les clients le même jour, et l'échéance empêche la version obsolète de devenir permanente.

6.7 Interopérabilité événementielle

Cette section encadre les échanges asynchrones : un agent ou un système publie un fait sur un bus d'événements, et un ou plusieurs agents y réagissent sans que l'émetteur les connaisse. Elle fixe l'enveloppe, les contrats, les attributs de gouvernance et les garanties sur lesquelles une conception peut réellement compter. Le bus est l'infrastructure de messagerie qui porte les sujets; le courtier, son composant d'application, y authentifie les agents et applique les listes de contrôle d'accès (EXIG-EVT-07).

Quand préférer l'événement

MCP et A2A fonctionnent par demande et réponse : l'appelant connaît son destinataire et attend un résultat. L'événement convient mieux dans trois cas. **Découplage dans le temps** : le traitement peut attendre, ou le consommateur peut être indisponible un moment (lots de nuit, pointes de charge, réaction aux changements d'état d'un ERP). **Plusieurs abonnés** : un même fait intéresse plusieurs agents, et l'on veut en ajouter sans toucher à l'émetteur. **Rejeu** : on veut relire la séquence des faits pour un audit ou pour évaluer une nouvelle version d'agent. Par exemple, une alerte de rupture de stock intéresse la planification, l'approvisionnement et le service à la clientèle; publiée une fois, elle les atteint tous les trois sans que le détecteur les connaisse.

L'argument du nombre de liaisons (N(N−1)/2 liaisons deux à deux, contre N vers un courtier) ne distingue pas le bus de la passerelle d'agents, qui forme déjà une étoile à N connexions; l'apport propre du bus est le découplage logique décrit ci-dessus. Les sujets, les schémas et les contrats restent à gouverner. L'abonnement évite aussi le délai propre aux boucles d'interrogation. Comme le souligne Kai Waehner, conseiller indépendant en diffusion de données en continu *(data streaming)*, MCP n'offre ni garantie de livraison ni cohérence, alors qu'un journal persistant et ordonné découple producteurs et consommateurs : les deux approches se complètent[167, 246].

> **EXIG-EVT-01 · DEVRAIT**
> **Recours au bus pour l'asynchrone**
> Une interaction qui n'attend pas de réponse immédiate, qui intéresse plusieurs consommateurs ou qui doit pouvoir être rejouée **DEVRAIT** passer par le bus d'événements de l'entreprise plutôt que par une chaîne d'appels A2A ou MCP. Le choix suit la matrice de la section 6.4 et le patron de chorégraphie de la section 7.2. Le bus n'est pas un chemin hors des points d'application : le courtier en est un (EXIG-EVT-07).
> Pourquoi : une chaîne d'appels synchrones lie la disponibilité de chaque agent à celle de tous les autres.

Enveloppe et contrats

Le cadre retient CloudEvents 1.0 comme enveloppe. La dernière révision publiée est la 1.0.2 (février 2022), les producteurs indiquent toujours `specversion` « 1.0 », et le projet a obtenu le statut « Graduated » de la CNCF le 25 janvier 2024[173, 247, 248]. CloudEvents exige quatre attributs de contexte (`id`, `source`, `specversion`, `type`) et en propose quatre facultatifs (`datacontenttype`, `dataschema`, `subject`, `time`)[248]. Le contrat de chaque sujet se décrit en AsyncAPI 3.x : la 3.0.0 date du 5 décembre 2023, et la 3.1.0, publiée le 31 janvier 2026, est une version mineure sans rupture[174, 249].

Sur Kafka, la liaison CloudEvents offre un mode binaire (attributs, sauf `datacontenttype` porté par l'en-tête `content-type`, dans des en-têtes préfixés `ce_`; données telles quelles dans la valeur) et un mode structuré (événement complet en `application/cloudevents+json`); un « Key Mapper » facultatif, à activer explicitement, peut copier `partitionkey` dans la clé Kafka[250]. Le cadre retient le mode binaire par défaut : les données restent intactes, et les intermédiaires filtrent sur les attributs sans désérialiser la charge utile. Un consommateur détermine le mode d'après l'en-tête `content-type` : un type qui commence par `application/cloudevents` indique le mode structuré, tout autre type le mode binaire[250]. Un exemple d'événement complet figure à l'annexe C.

EXIG-EVT-02 · DOIT
Enveloppe CloudEvents complète
Tout événement produit ou consommé par un agent **DOIT** respecter CloudEvents 1.0 et porter, en plus des quatre attributs requis, `time` et, dès que l'événement porte `data`, `datacontenttype` et `dataschema` (exigence du cadre; pour un événement par référence, `dataschema` décrit la ressource que vise `dataref`). Un événement d'un système existant que consomme un agent passe par un adaptateur de mise en conformité. Le `type` **DOIT** être un nom en domaine inversé qui inclut sa version (exigence du cadre; la norme recommande seulement le préfixe en domaine inversé), par exemple `ca.ent.logistique.alerte.rupture.v1`.
Pourquoi : un consommateur doit savoir, sans ouvrir la charge utile, ce qu'il reçoit, quand le fait s'est produit (ou, si cet instant est inconnu, l'heure que la source retient de façon uniforme) et quel schéma le valide.

EXIG-EVT-03 · DOIT
Contrat AsyncAPI au catalogue
Chaque sujet du bus **DOIT** être décrit par un contrat AsyncAPI 3.x inscrit au catalogue d'entreprise. Le contrat précise le schéma versionné des données et la clé de partition; l'entrée de catalogue précise le propriétaire, la classification et les producteurs et consommateurs autorisés, pour lesquels AsyncAPI ne définit aucun champ normalisé (section 6.8). Un changement incompatible de schéma crée un nouveau `type` versionné, selon les règles de la section 6.8.
Pourquoi : sans contrat, chaque consommateur devine le format et casse au premier changement.

Extensions de gouvernance

Les attributs requis par CloudEvents ne disent ni quel agent a lancé la chaîne, ni au nom de qui, ni à quel coût. Le cadre ajoute donc des extensions, en privilégiant celles que CloudEvents documente déjà; ces extensions documentées n'ont pas de statut officiel et peuvent évoluer, et trois d'entre elles (Auth Context, Data Classification et Expiry Time) ne figurent pas dans la révision 1.0.2, qui ne documente que Dataref, Distributed Tracing, Partitioning, Sampling et Sequence[187, 251], si bien que le cadre fige au catalogue la version qu'il en retient. Un nom d'attribut ne contient que des minuscules ASCII et des chiffres, et ne devrait pas dépasser 20 caractères; le préfixe `x` n'est ni exigé ni défini par la norme, et le cadre le garde pour signaler ses propres extensions[248]. Pour désigner l'initiateur, l'extension documentée Auth Context remplace une extension maison : elle est purement informative, déconseille les renseignements personnels dans `authid` et interdit d'inclure dans `authclaims` des justificatifs permettant d'usurper directement l'identité du mandant[252].

Le contexte de trace mérite une précision. L'extension Distributed Tracing prévoit que, pour une transmission en plusieurs sauts, `traceparent` porte la trace de départ et non celle de chaque saut; elle ne remplace pas les en-têtes de traçage du transport[253]. Les conventions OpenTelemetry de messagerie, au niveau Development, recommandent que le producteur injecte le contexte de création dans le message et relient par défaut producteur et consommateur par des liens de span plutôt que par parenté (la parenté n'étant admise que pour un message unique)[254].

Tableau 20 — Attributs d'extension CloudEvents exigés par le cadre

Attribut	Origine	Contenu	Règle du cadre
`traceparent` (`tracestate` facultatif)	Extension documentée Distributed Tracing	Contexte W3C Trace Context de la trace que poursuit l'agent émetteur	Obligatoire; jamais un identifiant métier
`authtype`, `authid`	Extension documentée Auth Context	Type de mandant, selon les valeurs recommandées par l'extension (`app_user`	Obligatoires; `authid` pseudonyme

Attribut	Origine	Contenu	Règle du cadre
		pour l'utilisateur final d'une application, `user` pour un compte d'infrastructure, `service_account`, `api_key`, `system` pour une identité volontairement masquée, `unauthenticated`, `unknown`), et son identifiant	
`dataclassification`, `dataregulation`, `datacategory`	Extension documentée Data Classification[255]	étiquettes recommandées par l'extension lorsque aucun régime n'en définit : `public`, `internal`, `confidential` ou `restricted`; régime applicable (liste séparée par des virgules); catégorie selon le régime (p. ex. `sensitive-pii`, exemple américain de l'extension)	`dataclassification` obligatoire; les deux autres dès que l'événement touche des RP
`xagentorigin`	Propre au cadre	Identifiant au registre et version de l'agent qui a publié le premier événement de la chaîne	Obligatoire sur tout événement publié par un agent; posé par l'intercepteur de publication (EXIG-EVT-07)
`xagenthopcount`	Propre au cadre	Entier (type Integer de CloudEvents) : nombre de publications d'agents dans la chaîne causale (1 pour la première)	Obligatoire; posé par l'intercepteur de publication : 1 de plus que le plus grand compteur reçu
`xagentmaxhops`	Propre au cadre	Entier (type Integer de CloudEvents) : plafond de sauts inscrit à l'entrée de catalogue du sujet; l'événement dont le compteur atteint ce plafond n'est pas traité, si bien qu'un plafond N laisse traiter N − 1 événements de la chaîne	Obligatoire; 4 par défaut; minimum de la valeur reçue et du plafond du sujet de publication
`xcostcenter`	Propre au cadre	Centre de coûts imputé	Obligatoire; valeur du référentiel financier
`partitionkey`, `sequence`, `expirytime`, `dataref`	Extensions documentées	Clé de partition, rang, échéance, référence externe aux données	Au besoin, de préférence à toute extension maison

`EXIG-EVT-04` · DOIT

Attributs de gouvernance présents et vérifiés

Tout événement publié par un agent **DOIT** porter les attributs obligatoires du tableau 20. Est un événement d'agent tout événement publié sous une identité d'agent inscrite au registre : le courtier ou l'intercepteur de publication **DOIT** rejeter à la publication l'événement d'un tel producteur qui ne les porte pas (EXIG-EVT-07). Un consommateur **DOIT** en outre refuser un événement d'agent qui en est dépourvu et le diriger vers la file de lettres mortes *(dead-letter queue)* du sujet, inscrite au catalogue, qui hérite de la classification maximale du sujet et de ses listes de contrôle d'accès. Il **DOIT** aussi tenir compte de `dataclassification` et rejeter l'événement dont il ne peut respecter les exigences ou dont il ne reconnaît pas la valeur, comme l'exige l'extension Data Classification, qui demande aussi aux intermédiaires de ne pas modifier ces attributs[255]. Un intermédiaire qui relaie un événement ne doit pas modifier `traceparent`; un agent qui publie un nouvel événement en réaction y **DOIT** porter un `traceparent` de la même trace que l'événement reçu, dont le span parent est son propre span de publication, et relier son span de traitement à l'événement reçu par un lien de span, pour que la trace

garde l'arbre causal (ou, s'il ouvre la chaîne, le `traceparent` de la trace qu'il ouvre), sauf pour un événement d'origine externe, régi par l'EXIG-OBS-02 (section 10.1).
Pourquoi : sans ces attributs, une chaîne d'agents n'est ni traçable, ni imputable, ni bornée.

`EXIG-EVT-05` · NE DOIT PAS
Aucun renseignement personnel direct dans les attributs
Les attributs d'un événement, lus par chaque intermédiaire et recopiés dans les journaux et les traces, **NE DOIVENT PAS** contenir de renseignement personnel direct (nom, courriel, numéro de compte) ni de justificatif; une personne n'y figure que sous un identifiant pseudonyme opaque, qui demeure un renseignement personnel (section 12.2) et dont la table de correspondance reste hors du bus. Les données personnelles volumineuses ou sensibles restent dans le système source; l'événement ne transmet qu'une référence (`dataref`), sans `data`, dont l'accès est contrôlé.
Pourquoi : un bus réplique chaque événement chez tous ses abonnés; limiter les RP qu'il transporte réduit d'autant la surface à protéger au titre de la Loi 25 (section 12.2).

Prévention des tempêtes d'événements

Dans une chorégraphie, aucun composant central ne voit l'ensemble. Deux agents qui réagissent chacun aux événements de l'autre peuvent donc s'entretenir indéfiniment : la planification révise une prévision, l'approvisionnement ajuste une commande, ce qui déclenche une nouvelle révision, et ainsi de suite. Chaque tour consomme des jetons et peut produire des effets réels. Le compteur de sauts, posé par l'intercepteur de publication et non par l'agent, coupe cette boucle de façon déterministe, sans dépendre du jugement d'un modèle (figure 10), à condition que le système d'enregistrement modifié propage les attributs : ajuster une commande est une écriture à l'ERP, qui publie son propre événement. Un plafond de largeur, tenu par le courtier par identifiant de trace, borne en outre les chaînes qui se ramifient : sans lui, k abonnés qui republient chacun produisent jusqu'à $1 + k + k^2 + k^3$ événements en quatre sauts. Ce compteur et son plafond sont des conventions propres au cadre : aucune extension CloudEvents normalisée ne les couvre[187].

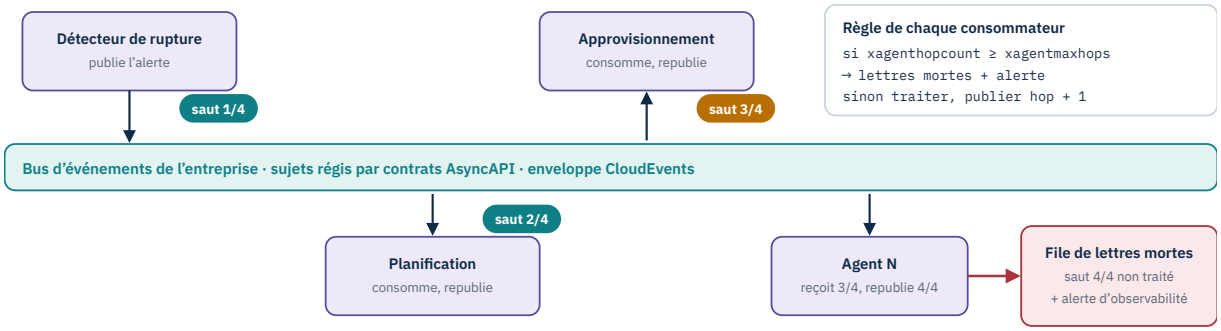


Figure 10 — Chorégraphie événementielle et compteur de sauts. Chaque republication augmente `xagenthopcount`; l'événement qui atteint le plafond (4 par défaut) n'est pas traité : il part en file de lettres mortes et déclenche une alerte. Source : élaboration du cadre; enveloppe CloudEvents 1.0.

`EXIG-EVT-06` · DOIT
Compteur de sauts et coupure des boucles
L'intercepteur de publication de la plateforme, et non l'agent, **DOIT** poser les attributs de chaîne (EXIG-EVT-07). Pour le premier événement d'une chaîne : `xagenthopcount` à 1, `xagentorigin` à l'identifiant et à la version de l'agent, `xagentmaxhops` au plafond inscrit à l'entrée de catalogue du

sujet (4 par défaut). Pour un événement publié en réaction : `xagenthopcount` à 1 de plus que le plus grand compteur reçu, `xagentorigin` recopié, `xagentmaxhops` au minimum de la valeur reçue et du plafond du sujet de publication. Un système d'enregistrement adapté qui publie à la suite d'une écriture d'agent propage ces attributs par sa boîte d'envoi. Un consommateur qui reçoit un événement dont `xagenthopcount` atteint ou dépasse `xagentmaxhops` **DOIT** s'abstenir de le traiter, le diriger vers la file de lettres mortes et lever une alerte, regroupée par chaîne. Le courtier **DOIT** en outre plafonner le nombre d'événements par identifiant de trace dans une fenêtre de temps inscrite au catalogue. Un événement de compensation, déclaré comme tel au contrat du sujet et publié sous l'identité de compensation (EXIG-ORC-28), n'est pas soumis au plafond de sauts; il reste soumis à l'autorisation et à un budget propre. Le plafond d'un sujet ne se relève que par une modification revue de son entrée de catalogue.

Pourquoi : posés à la publication, hors de l'agent, les attributs bornent la chaîne sans dépendre du jugement d'un modèle; le minimum des plafonds fait prévaloir le sujet le plus strict, et le plafond par trace borne les chaînes ramifiées, que le compteur seul ne borne pas. Un système qui ne propage pas les attributs rompt encore la chaîne causale : le plafond par trace reste alors la seule borne. Une saga qui échoue près du plafond doit pouvoir se compenser.

`EXIG-EVT-07` · DOIT

Autorisation fondée sur l'identité, pas sur les attributs

Le droit de publier ou de consommer sur un sujet **DOIT** reposer sur l'identité authentifiée de l'agent auprès du courtier et sur des listes de contrôle d'accès par sujet, tirées de l'entrée de catalogue du sujet (producteurs et consommateurs autorisés). Une décision d'autorisation ne doit pas se fonder sur `authtype`, `authid` ou un autre attribut de l'événement pour accorder un accès (`dataclassification` ne peut que le restreindre). Les données reçues **DOIVENT** être traitées comme du contenu non fiable (section 9.6).

Pourquoi : l'extension Auth Context est informative et n'est pas un mécanisme de sécurité[252]; n'importe quel producteur peut y écrire n'importe quoi.

Garanties réelles d'un bus

Apache Kafka sert ici d'exemple parce que ses garanties sont documentées avec précision; un autre courtier se juge sur les mêmes questions. Le tableau 21 distingue ce que le courtier garantit de ce qui reste à la charge de la conception.

Tableau 21 — Garanties d'un bus Kafka et responsabilités de la conception

Propriété	Ce que Kafka garantit	Ce qui reste à la conception
Livraison	« Au moins une fois » par défaut; le producteur idempotent (depuis 0.11.0.0) évite les doublons dus aux réessais internes d'une même session de producteur; un redémarrage du producteur ou du relais exige `transactional.id` ou la déduplication par le consommateur[140]	Consommateurs idempotents et déduplication
Exactement une fois	Cycle lecture-traitement-écriture entre sujets Kafka (transactions, consommateur `read_committed`); un système externe doit coopérer[140, 256]	Clé d'idempotence vérifiée par le système cible; patron de la boîte d'envoi
Ordre	Par partition seulement; les événements de même clé vont dans la même partition[257]	Choisir la clé selon l'entité dont l'ordre compte
Répartition du travail	Rééquilibrage natif des groupes de consommateurs; files coopératives (share groups) dont l'ordre n'est garanti qu'à l'intérieur d'un lot[258]	Réserver les files coopératives aux tâches indépendantes
Rejeu	Relecture depuis un décalage sauvegardé, dans la limite de la rétention configurée[140]	Rétention suffisante; rejeu isolé; aucune promesse de décisions identiques

Quelques repères de version aident à fixer au catalogue la version plancher du courtier. Kafka 4.0 (18 mars 2025) est la première version majeure entièrement sans ZooKeeper et généralise le nouveau protocole de rééquilibrage des groupes[259]. Les files coopératives sont prêtes pour la production depuis Kafka 4.2.0 (17 février 2026), et Kafka 4.4.0 (22 octobre 2026) leur ajoute des files de lettres mortes[260, 261].

La conséquence pratique tient en une phrase : un effet réel n'est jamais protégé par le bus, mais par l'idempotence du consommateur et du système cible. Kafka seul n'empêche pas un double paiement. Pour publier de façon fiable un changement d'état et l'événement qui l'annonce, le producteur applique le patron de la boîte d'envoi *(transactional outbox)* : il écrit l'événement dans une table de sa base, dans la même transaction locale que le changement, puis un relais le publie. Aucun événement ne part ainsi pour une transaction annulée, et aucun changement validé ne reste sans événement.

Le rejeu appelle la même prudence. Confluent présente le rejeu déterministe des événements comme le fondement de l'investigation d'un incident, de l'audit réglementaire, de la validation de modèle et des mises à jour sûres des agents[262]. Rejouer les entrées ne garantit pourtant pas que l'agent reprendra les mêmes décisions, car rien n'assure qu'un modèle produise la même sortie à entrées identiques. Le cadre parle donc de rejeu des entrées pour l'audit et la réévaluation, jamais de reproduction des décisions.

`EXIG-EVT-08` · DOIT
Effets réels protégés par l'idempotence
Tout consommateur dont le traitement produit un effet hors du bus **DOIT** être idempotent : il déduplique sur l'identité de l'événement (`source` et `id`; le producteur et le relais de la boîte d'envoi **DOIVENT** les conserver à chaque renvoi du même événement, ce que la norme permet sans l'imposer) et transmet au système cible une clé d'idempotence que ce dernier vérifie (section 7.6). Cette clé dérive du couple (`source`, `id`) de l'événement déclencheur, jamais de l'identifiant d'une tâche ouverte par le consommateur; l'état de déduplication est conservé au moins pendant la rétention du sujet et mis à jour dans la même transaction que l'effet, ou complété par une requête d'état qui constate l'effet. Un producteur qui publie à la suite d'un changement dans sa base **DOIT** appliquer le patron de la boîte d'envoi ou un mécanisme transactionnel équivalent. La sémantique « exactement une fois » du courtier ne doit pas être invoquée comme protection contre un double effet externe.
Pourquoi : la livraison est « au moins une fois »[140]; sans idempotence, une seule reprise suffit à payer deux fois une facture.

`EXIG-EVT-09` · DOIT
Ordre garanti par la clé de partition
Lorsqu'un flux exige l'ordre des événements d'une même entité (dossier, commande, session), la clé de partition **DOIT** être l'identifiant technique de cette entité, sans renseignement personnel direct (EXIG-EVT-05; un identifiant pseudonyme est admis et traité comme un renseignement personnel, pour la conservation comme pour l'accès), porté par `partitionkey` et précisé au contrat AsyncAPI. La clé native du courtier **DOIT** égaler `partitionkey` : sur Kafka, le producteur la fixe lui-même ou active le « Key Mapper » facultatif de la liaison, qui reprend par défaut la clé fournie par l'utilisateur[250]. L'ordre suppose en outre un nombre de partitions figé pendant la vie du sujet, un traitement séquentiel par clé chez le consommateur et un relais de boîte d'envoi ordonné. Les files coopératives ne doivent pas servir à un tel flux; elles conviennent aux bassins d'exécutants dont les tâches sont indépendantes.
Pourquoi : Kafka ne garantit l'ordre qu'au sein d'une partition, et une file coopérative ne le garantit qu'à l'intérieur d'un lot.

EXIG-EVT-10 · DOIT
Conservation des entrées et rejeu isolé
Les sujets qui alimentent des agents de classe de risque modérée ou élevée **DOIVENT** conserver leurs événements au moins pendant la fenêtre d'enquête inscrite à la fiche de l'agent (au moins 90 jours pour la classe modérée et un an pour la classe élevée), selon la règle de durée de l'EXIG-CON-10 : durée liée à la finalité, inscrite à la fiche et appliquée automatiquement, dans la limite du calendrier de conservation applicable aux RP; la durée de conservation des traces de l'agent, inscrite à la même fiche, est au moins égale à cette fenêtre, et le journal d'audit suit l'EXIG-OBS-13; un sujet qui alimente plusieurs agents retient la plus longue de leurs fenêtres, et l'effacement des RP d'un sujet conservé se fait par chiffrement par personne ou par sujet, puis destruction de la clé. Tout rejeu d'audit ou d'évaluation **DOIT** s'exécuter dans un environnement isolé où les outils à effet sont remplacés par des doublures; ses résultats servent à l'audit et à l'évaluation continue (section 10.4), jamais à répéter des actions en production. La reprise opérationnelle d'un groupe de consommateurs après une panne n'est pas un rejeu au sens de cette exigence : l'EXIG-EVT-08 la régit.
Pourquoi : rejouer des entrées contre des outils réels répéterait leurs effets, et un modèle peut décider autrement la seconde fois.

Le bus ne porte aucun jeton, et l'initiateur qu'indiquent `authtype` et `authid` est informatif (EXIG-EVT-07) : sans point d'application au courtier, un consommateur agirait sous sa seule identité, hors de l'intersection des droits (PRIN-03) et de la limite de délégation. Conformément à l'EXIG-EVT-07, le courtier et l'intercepteur de publication de la plateforme constituent donc un point d'application au même titre que la passerelle : ils authentifient le producteur, appliquent les listes de contrôle d'accès par sujet, posent eux-mêmes les attributs de gouvernance (identité de l'agent producteur, référence de délégation, compteur et plafond de sauts de l'EXIG-EVT-06, étiquettes de contamination et de sensibilité de la session productrice, EXIG-SEC-04), refusent un événement dont le `dataschema` ne figure pas parmi les schémas épinglés pour le sujet, et rejettent à la publication l'événement d'un agent qui ne porte pas les attributs du tableau 20. Toute action P2 ou P3 qu'un consommateur exécute à la suite d'un événement traverse la passerelle d'agents, sous la délégation que référence l'événement, échangée selon la RFC 8693 (EXIG-IAM-08), ou, à défaut, sous un mandat de service inscrit au catalogue pour ce sujet et pour ce consommateur; un saut exécuté sous la délégation que référence l'événement compte comme un niveau dans la profondeur de délégation de l'EXIG-ORC-04.

6.8 Contrats, versionnage et catalogue d'entreprise

Cette section fixe ce que chaque interface offerte à un agent doit déclarer, comment ses versions évoluent sans briser ses consommateurs et ce que contient le catalogue d'entreprise.

Ce que chaque contrat déclare

Un contrat a deux faces : ce que le fournisseur publie dans le format du protocole, et ce que l'entreprise fixe au catalogue. Comme les annotations MCP sont des indices non fiables (EXIG-MCP-14) et que la carte A2A n'admet aucun champ de gouvernance hors norme (EXIG-A2A-05), tout ce qui commande une décision de sécurité vit au catalogue (tableau 22; exemples à l'annexe C).

Tableau 22 — Contenu minimal des contrats, par type d'interface

Interface	Contrat publié	Entrée fixée au catalogue
Outil MCP	Nom préfixé par le domaine; description destinée au modèle, qui dit ce que fait l'outil et ce qu'il ne fait pas; `inputSchema` et, au besoin, `outputSchema` en JSON	Version et empreinte; palier P0 à P3 et seuil, avec sa grandeur, son unité, sa portée et sa fenêtre (section 8.3, EXIG-AUT-08); compensation de toute écriture P2; propriétaire et équipe de garde; classification maximale des données

Interface	Contrat publié	Entrée fixée au catalogue
	Schema 2020-12; clé d'idempotence pour tout outil à effet (section 7.6)	
Ressource et invite MCP	Ressource adressée par URI; invite nommée et décrite	Version et empreinte (pour un gabarit `ui://`, empreinte de son contenu); palier P0 ou P1 d'une ressource (EXIG-MCP-05); classification; propriétaire et équipe de garde
Agent A2A	Carte A2A 1.0 signée (section 6.6)	Version et empreinte; portée OAuth par compétence et durée attendue par compétence (EXIG-A2A-07); renvoi à la fiche du registre; pour un agent de tiers, carte d'origine et son empreinte (EXIG-A2A-02)
Sujet d'événement	Contrat AsyncAPI 3.x, avec la clé de partition, et `type` versionné (section 6.7)	Producteurs et consommateurs autorisés; classification; plafond de sauts et plafond par trace (EXIG-EVT-06); file de lettres mortes; propriétaire et équipe de garde
API existante	Contrat OpenAPI 3.1.x ou 3.2.x; erreurs au format RFC 9457[171]	Outils MCP qui l'exposent, chacun avec son entrée

`EXIG-INT-12` · DOIT
Contrat complet avant l'inscription
Toute interface offerte à un agent **DOIT** disposer, avant son inscription au catalogue d'entreprise, d'un contrat publié et d'une entrée de catalogue qui contiennent au minimum les éléments du tableau 22. Un élément manquant bloque l'inscription.
Pourquoi : la passerelle n'applique que des règles écrites; sans palier ni compensation déclarés, l'agent déciderait seul de ce qui est sûr.

Versionnage sémantique

La version d'un protocole ne dit rien des contrats publiés sur lui. Or la définition d'un outil MCP ne comporte aucun champ de version[197], et le champ `version` d'une carte A2A est de format libre[68]. Le cadre impose donc aux contrats le versionnage sémantique (SemVer), de forme MAJEUR.MINEUR.CORRECTIF, tenu au catalogue :

- **majeur** : tout changement qui peut faire échouer ou tromper un consommateur (élément retiré ou renommé, nouveau paramètre obligatoire, valeurs admises restreintes en entrée, valeur ajoutée à une énumération de sortie, changement de sens à format constant);
- **mineur** : ajout compatible et reformulation d'une description sans changement de sens, établie par la revue sémantique (EXIG-INT-16);
- **correctif** : correction qui ne change ni la définition publiée ni le comportement attendu.

Le changement de sens est le plus dangereux, car aucun validateur ne le voit : un montant qui passe de hors taxes à toutes taxes comprises reste un nombre valide (section 6.1). A2A applique la même logique à ses extensions, dont tout changement incompatible exige une nouvelle URI[238].

`EXIG-INT-13` · DOIT
Versionnage sémantique des contrats
Tout contrat inscrit au catalogue **DOIT** porter une version SemVer, incrémentée à chaque publication selon les règles ci-dessus : au moins mineure pour toute modification de la définition publiée, majeure pour tout changement incompatible, y compris de sens. Pour un agent A2A, c'est le champ `version` de sa carte (EXIG-A2A-04). L'unité de version est l'outil, la ressource, l'invite, la carte d'agent ou le sujet; un serveur MCP n'est qu'un agrégat d'entrées. La définition publiée, que canonise l'empreinte (EXIG-INT-15, EXIG-INT-16, EXIG-MCP-20), comprend : pour un outil MCP, le nom, le titre, la description, les icônes, les schémas d'entrée et de sortie, les annotations et `_meta`, hors champs volatils inscrits

au catalogue; pour une ressource ou une invite, son URI ou son nom, sa description et, pour un gabarit `ui://`, son contenu; pour une carte A2A, la carte canonisée sans le champ `signatures`; pour un sujet, le contrat AsyncAPI converti en JSON.
Pourquoi : un numéro régi par des règles connues dit au consommateur s'il peut migrer sans risque (règle du cadre).

`EXIG-INT-14` · DOIT
Coexistence d'au moins 60 jours
À la publication d'une version majeure, la version majeure précédente **DOIT** rester disponible au moins 60 jours (choix du cadre), avec une date de retrait inscrite au catalogue dès ce moment et annoncée aux consommateurs connus. Seul un motif de sécurité justifie un retrait anticipé : sur décision du comité, la version visée passe d'abord à l'état « suspendue », et la passerelle cesse immédiatement de la servir (EXIG-GOV-14); le comité fixe ensuite la date de retrait. Pendant la coexistence, la passerelle sert la version majeure précédente sous un nom d'outil suffixé par sa version majeure (p. ex. `domaine_outil_v2`) pour MCP, et sous une entrée `supportedInterfaces` par version majeure pour A2A, et elle route selon la dépendance épinglée de l'appelant; deux types d'événements coexistants (v1 et v2) portent un même identifiant de fait (`id` ou clé métier), et le consommateur abonné aux deux déduplique. Un contrat de tiers relève de l'EXIG-INT-16.
Pourquoi : un délai connu permet de planifier les migrations; il concorde avec le préavis de retrait d'un agent (section 11.5).

Épinglage et approbation des changements

Un consommateur ne suit jamais « la dernière version ». Il dépend d'une version identifiée par son numéro et par son empreinte, soit le condensé SHA-256 de la définition canonisée selon la RFC 8785[236]. Le numéro dit ce que le fournisseur affirme; l'empreinte prouve la définition que l'agent reçoit, non le comportement du serveur, qui relève de la signature des artefacts déployés et de la provenance (section 9.8), du contrôle des sorties réseau et des tests de contrat. L'empreinte d'un contrat AsyncAPI porte sur sa conversion en JSON, canonisée de la même façon. La fiche d'agent consigne ces dépendances (annexe B); la passerelle vérifie l'empreinte à l'exécution (EXIG-MCP-20, EXIG-SEC-18) et, pour un événement, le courtier et le registre de schémas du consommateur vérifient que le `dataschema` reçu figure parmi les schémas épinglés (EXIG-EVT-07). L'OWASP recommande d'épingler les définitions par empreinte et de redemander le consentement à chaque modification[221].

`EXIG-INT-15` · DOIT
Dépendances épinglées par version et empreinte
Chaque agent **DOIT** déclarer dans sa fiche, pour chaque outil, ressource, invite, agent appelé et sujet d'événement, la version épinglée et l'empreinte approuvée. Une dépendance ne doit pas désigner une version flottante (« dernière », plage de versions); changer de version est une modification de la fiche, revue et tracée. L'épinglage porte sur MAJEUR.MINEUR et sur l'empreinte; un correctif, qui ne change pas l'empreinte, se suit sans modifier la fiche. À l'activation d'une version mineure, le propriétaire du contrat migre en lot les épinglages après avis aux consommateurs, ou la passerelle sert la mineure précédente pendant une fenêtre de migration inscrite au catalogue; au plus deux versions mineures d'une même majeure sont actives à la fois (choix du cadre).
Pourquoi : sans épinglage, un fournisseur peut changer la définition que lit l'agent à l'insu de son parrain; l'épinglage ne prouve pas pour autant le comportement du fournisseur, qui relève de la section 9.8.

EXIG-INT-16 · DOIT
Nouvelle approbation à toute modification
Toute modification de la définition publiée d'un outil, d'une ressource, d'une invite ou d'une carte d'agent, y compris la reformulation d'une description, **DOIT** être revue et approuvée de nouveau au catalogue avant d'être servie aux agents, y compris pour les serveurs et agents de tiers. La revue confirme aussi le palier attribué. Pour un tiers, dont l'entreprise ne contrôle ni le calendrier ni la chaîne d'intégration : la version est tenue au catalogue par l'entreprise; le contrat prévoit un préavis de changement de définition et un point d'accès de préversion (chapitre 13); un test différentiel à l'entrée du catalogue remplace la chaîne d'intégration de l'EXIG-INT-19; une revue accélérée vise un délai cible inscrit au catalogue. Hors préavis, la modification suspend l'outil ou l'agent jusqu'à la revue (EXIG-MCP-20) : ce mode fermé est le comportement assumé, la coexistence de l'EXIG-INT-14 étant alors impossible.
Pourquoi : le modèle lit la description comme une consigne, et la substitution après approbation *(rug pull)* exploite justement un changement présenté comme anodin (section 9.8).

Catalogue d'entreprise

Le catalogue d'entreprise recense tous les contrats joignables par les agents. Le catalogue des protocoles (section 6.3) dit quels standards employer; le catalogue d'entreprise, quels contrats existent sur ces standards. Le registre (section 11.4) dit qui répond d'un agent et avec quel risque; le catalogue, par quel contrat et dans quelle version. Le registre officiel MCP, en préversion, n'en tient jamais lieu[43].

Chaque version de contrat est « en revue », « active », « dépréciée » (avec sa date de retrait), « suspendue » (motif de sécurité, EXIG-INT-14) ou « retirée », à l'image du cycle *Active*, *Deprecated*, *Removed* que MCP applique à ses propres fonctionnalités[34]. Ces états sont distincts de ceux de la fiche d'agent. Sans la liste des consommateurs de chaque version, on découvre ceux d'une version retirée par leurs pannes.

EXIG-INT-17 · DOIT
Catalogue unique, source de la découverte
L'entreprise **DOIT** tenir un seul catalogue d'entreprise, sous une même autorité et articulé avec le registre de gouvernance (section 11.4), qui recense chaque version de contrat (outil, ressource ou invite MCP, regroupés par serveur, carte d'agent A2A, sujet AsyncAPI) avec son état, son propriétaire, son empreinte et, s'il y a lieu, sa date de retrait. La découverte passe par lui, jamais par une adresse configurée à la main; la passerelle ne sert que les versions actives et les versions dépréciées non échues, jamais une version suspendue ou retirée.
Pourquoi : deux sources de vérité finissent par diverger.

EXIG-INT-18 · DOIT
Consommateurs connus avant tout retrait
Le catalogue **DOIT** indiquer les consommateurs connus de chaque version active ou dépréciée, tirés des fiches d'agents et rapprochés chaque mois des appels observés par la passerelle (fréquence fixée par le cadre). Une version n'est retirée qu'à l'échéance annoncée, jamais avant la fin de la coexistence de l'EXIG-INT-14 sauf suspension de sécurité (EXIG-INT-14, EXIG-GOV-14), et après avis à ses consommateurs connus. La passerelle refuse tout appel d'une version absente de la fiche de l'appelant (EXIG-IAM-17); le rapprochement avec les appels observés est un contrôle de cohérence, rendu continu pendant la fenêtre de dépréciation.
Pourquoi : le rapprochement révèle les écarts entre les fiches et les appels avant que le retrait ne brise un consommateur.

Tests de compatibilité

Une règle de versionnage ne tient que si une machine la vérifie; seul le changement de sens échappe à la comparaison des schémas et relève de la revue sémantique (EXIG-INT-01 et EXIG-INT-16). Les suites de conformité complètent les tests internes : `a2a-tck` (EXIG-A2A-14)[243] et le cadre officiel de tests de conformité MCP, encore en versions 0.x (préversion 0.2.0-alpha en cours)[225, 226]. Les deux suites suivent un même régime (EXIG-INT-19). Ces tests forment le premier étage de l'évaluation continue (section 10.4).

> **EXIG-INT-19 · DOIT**
> **Détection automatique des ruptures**
> La chaîne d'intégration **DOIT** comparer chaque nouvelle version d'un contrat à la version active précédente et bloquer toute publication qui contient un changement incompatible sans incrément majeur, ou dont l'empreinte change sans incrément au moins mineur. Avant son activation, la nouvelle version **DOIT** réussir le jeu d'évaluation de chaque agent consommateur connu, rejoué en environnement isolé contre elle (section 10.4) avec le seuil de réussite inscrit à sa fiche, et, pour un agent A2A, les tests de l'EXIG-A2A-14. Une suite de conformité (`a2a-tck`, cadre officiel de conformité MCP ou suite équivalente approuvée par l'architecture d'entreprise, EXIG-APP-03) est épinglée à une étiquette au catalogue; tant que sa ligne est alpha ou en préversion 0.x, ses résultats sont consignés et ne bloquent que sur les tests restés stables pendant deux versions de la suite. Pour un tiers, l'EXIG-INT-16 s'applique.
> Pourquoi : une règle de compatibilité vérifiée à la main finit par céder sous la pression d'une livraison.

6.9 Protocoles émergents et veille

Cette section situe les travaux qui n'ont pas le statut Adopter (section 6.3) et en encadre l'usage; le processus de veille relève de la section 11.7.

Ce que l'AAIF héberge réellement

Au 22 octobre 2026, l'Agentic AI Foundation (AAIF) héberge dix projets : MCP, goose, AGENTS.md, agentgateway, A2A, Agent Router et, annoncés ce jour-là, Agent Skills, Open Responses, OpenEnv et OpenSandbox[38, 130]. L'admission suit un processus formel : proposition publique, triage, recommandation du comité technique, puis approbation du conseil d'administration, suivie des formalités juridiques et de l'intégration technique menées avec la Linux Foundation[42, 263]. Un projet proposé n'est qu'un candidat, et l'hébergement garantit une gouvernance neutre, non la maturité d'une spécification.

> **EXIG-INT-20 · NE DOIT PAS**
> **Qualification « AAIF » non vérifiée**
> Un document d'architecture, un appel d'offres ou un contrat **NE DOIT PAS** qualifier un projet de « projet de l'AAIF » ni de « standard de l'AAIF » s'il ne figure pas à la liste des projets publiée par la fondation au terme d'une admission approuvée; un projet dont la proposition est ouverte est dit « candidat à l'AAIF ». L'hébergement par l'AAIF ne dispense d'aucun critère d'admission au statut Adopter (EXIG-GOV-19).
> Pourquoi : AGNTCY, souvent présenté comme une composante de l'AAIF, n'en est qu'un candidat[37]; l'erreur fausse l'analyse du risque fournisseur.

AGNTCY

AGNTCY, rendu public par Cisco en mars 2025, est un projet de la Linux Foundation depuis le 29 juillet 2025[23]. Sa proposition à l'AAIF, déposée par Cisco le 12 octobre 2026, fait état de 81 organisations qui l'appuient et indique que Cisco fournit l'essentiel des contributions; elle restait sans décision au 27 octobre 2026[37]. Le tableau 23 présente ses principaux composants.

Tableau 23 — Principaux composants d'AGNTCY et statut au catalogue (état au 27 octobre 2026)

Composant	Fonction vérifiée	Statut
OASF (Open Agentic Schema Framework)	Modèle de données extensible, inspiré d'OCSF (Open Cybersecurity Schema Framework), qui décrit des agents par des enregistrements annotés de compétences et de domaines; l'Agent Directory Service (ADS) y convertit des définitions de serveurs MCP, des cartes d'agent A2A et des Agent Skills[264, 265]	**Évaluer**
Agent Directory Service (ADS)	Annuaire d'enregistrements OASF stockés comme artefacts OCI (Open Container Initiative), adressés par leur condensé, signés et vérifiables[266, 267]	**Évaluer**
SLIM (Secure Low-Latency Interactive Messaging)	Messagerie sur gRPC et HTTP/2, sessions chiffrées de bout en bout par MLS (Messaging Layer Security) (RFC 9420)[268, 269]	**Surveiller**
Identity	Identifiants d'agents et de serveurs MCP adossés à des justificatifs vérifiables du W3C (« Agent Badges »)[270]	**Surveiller**

Trois précautions s'imposent. Les spécifications d'ADS et de SLIM soumises à l'IETF sont des brouillons individuels[271, 272]. La résistance de SLIM à l'ordinateur quantique, parfois avancée, n'est pas étayée : les suites cryptographiques initiales de MLS sont classiques[269]. Enfin, la liaison SLIMRPC reste expérimentale (EXIG-A2A-08), et la carte d'agent suit le schéma d'A2A, non celui d'OASF.

EXIG-INT-21 · DOIT
Pilotes AGNTCY subordonnés au catalogue
Tout pilote d'OASF ou d'ADS **DOIT** traiter le catalogue d'entreprise comme source de vérité : les enregistrements de l'annuaire en sont dérivés, et aucun agent n'y découvre un outil ou un agent absent du catalogue. Une propriété de sécurité alléguée, comme la résistance de SLIM au quantique, ne doit pas entrer dans une analyse de risque sans preuve de la configuration effective. Toute dépendance de production à un composant d'AGNTCY exige une décision du comité.
Pourquoi : un annuaire parallèle recréerait deux sources de vérité, et une propriété non démontrée ne protège rien.

Commerce et paiements agentiques

Trois protocoles principaux se disputent le commerce agentique, sans convergence; d'autres initiatives existent, que le catalogue inscrit au statut Surveiller lorsqu'elles touchent l'entreprise. L'Agentic Commerce Protocol d'OpenAI et de Stripe (septembre 2025) demeure en bêta[183]; son jeton de paiement partagé est limité à un marchand et au montant d'un panier, et masque les justificatifs de paiement à la plateforme d'IA[27]. AP2 *(Agent Payments Protocol)*, publié par Google en septembre 2025, étend A2A et MCP par des mandats signés qui prouvent l'intention et l'autorisation de l'utilisateur; sa version 0.2 ajoute les paiements en l'absence de l'utilisateur *(Human Not Present)*, et Google a annoncé le 28 avril 2026 en faire don à la FIDO Alliance[26, 41]; le transfert effectif n'était pas établi à la fin d'octobre 2026. UCP *(Universal Commerce Protocol)*, annoncé en janvier 2026 par Google en collaboration avec des détaillants et des plateformes de commerce, prend en charge REST, MCP et A2A et est compatible avec AP2[184]. Les trois restent au statut Surveiller, mais leurs patrons inspirent déjà la règle qui suit.

EXIG-INT-22 · DOIT
Paiements initiés par un agent
Tout paiement, achat ou engagement financier déclenché par un agent, quel que soit le protocole, **DOIT** être classé P3 et n'être exécuté qu'avec une approbation humaine signée, propre à la transaction et liée à l'action exacte (section 8.5). L'agent ne doit pas recevoir ni transmettre de justificatif de paiement; il ne manipule que des jetons émis hors de lui, à usage unique et à courte échéance, limités à un bénéficiaire et à un montant, et liés à l'empreinte de l'approbation et à la clé d'idempotence de l'étape. Chaque paiement **DOIT** laisser au journal d'audit une preuve d'intention signée : l'approbation de la personne

habilitée, qui peut être distincte du mandant. Est « en l'absence de l'utilisateur » tout paiement sans approbation humaine propre à la transaction; il ne doit pas être autorisé, et l'adoption d'un protocole qui l'encadre ne l'autorise pas sans révision du cadre.
Pourquoi : AP2 fonde l'imputabilité d'un paiement sur des mandats signés, l'Agentic Commerce Protocol limite son jeton à un marchand et à un montant; le cadre généralise ces patrons à tout paiement.

Signaux à suivre
La veille n'est vérifiable que si l'on sait ce que l'on attend : une décision de l'AAIF sur AGNTCY ou la première version étiquetée du dépôt dédié semantic-conventions-genai d'OpenTelemetry (section 10.1)[181]. Une révision de MCP, standard au statut Adopter, ne relève pas de ces signaux : sa publication déclenche la révision extraordinaire de l'EXIG-GOV-18, et l'annonce de sa date relève de la révision trimestrielle (la SEP-3398 la fixe au 30 mars 2027, sous réserve; section 6.5).

EXIG-INT-23 · DOIT
Signal de révision inscrit au catalogue
Chaque entrée du catalogue des protocoles au statut Évaluer ou Surveiller **DOIT** indiquer le signal qui déclenchera le réexamen de son statut et la date de sa dernière vérification. L'apparition du signal **DOIT** entraîner une révision extraordinaire de l'entrée, sans attendre l'échéance trimestrielle. Pour une entrée au statut Adopter ou Contenir, une nouvelle révision, une dépréciation ou une version stable relève de l'EXIG-GOV-18, qui en fixe la révision extraordinaire.
Pourquoi : l'admission d'un projet à l'AAIF ou la publication d'une RFC ne devrait pas attendre trois mois pour être prise en compte.

À RETENIR
Une fondation neutre n'est pas un statut au catalogue, et une annonce n'est pas une norme : un travail émergent n'entre en production que par le statut Adopter.

7 Orchestration

L'orchestration décide qui fait quoi, dans quel ordre, avec quel état et quelles garanties en cas d'échec. Ce chapitre fixe la règle de départ, soit la configuration la plus simple qui répond au besoin, puis les huit patrons autorisés et la façon de choisir parmi eux. Il impose enfin les mécanismes qui rendent une orchestration digne de la production : exécution durable, saga et compensation, idempotence, contexte minimal entre agents, résilience et coupe-circuit.

7.1 Commencer simple : ce que disent les données probantes

Cette section résume les mesures publiées sur les systèmes multiagents et en tire la règle de départ du cadre : un flux déterministe ou un agent unique bien outillé, sauf preuve mesurée du contraire.

Des gains réels, sur des tâches précises
Anthropic rapporte que son système de recherche multiagent, formé d'un agent principal Claude Opus 4 et de sous-agents Claude Sonnet 4, a surpassé de 90,2 % un agent unique Claude Opus 4 sur son évaluation interne de recherche. Le gain est le plus marqué pour les requêtes « en largeur », qui poursuivent plusieurs pistes indépendantes à la fois; il s'agit d'une évaluation interne, et non d'un banc d'essai public[17].

L'étude de Google Research « Towards a Science of Scaling Agent Systems » (Kim, Gu, Park et coll.) nuance fortement ce résultat. Selon le billet de Kim et Liu du 28 janvier 2026 (180 configurations, quatre bancs d'essai, cinq architectures, trois familles de modèles), l'architecture centralisée gagne 80,9 % sur une tâche parallélisable (Finance-Agent), alors que chaque variante multiagent dégrade la performance de 39 à 70 % sur une tâche séquentielle (PlanCraft)[273]. La version 3 de l'article (8 avril 2026; 260 configurations, six bancs d'essai) donne une plage de +80,8 % à −70,0 % et observe que les gains de la coordination diminuent lorsque l'agent unique est déjà performant[274].

Des coûts et des risques qui croissent avec le nombre d'agents

- **Jetons.** Selon Anthropic, un agent consomme environ 4 fois plus de jetons qu'une conversation, et un système multiagent environ 15 fois plus; sur le banc d'essai BrowseComp, le volume de jetons explique à lui seul 80 % de la variance de performance[17]. Un article d'Anthropic du 23 janvier 2026 situe le surcoût habituel du multiagent entre 3 et 10 fois les jetons d'un agent unique pour une tâche équivalente[275].
- **Erreurs.** Selon le billet de Google Research du 28 janvier 2026, chiffres absents du résumé de la version 3 de l'article, l'amplification des erreurs peut atteindre 17,2 fois dans des systèmes multiagents indépendants, contre 4,4 fois lorsqu'un orchestrateur central sert de goulot de validation[273].
- **Cohérence.** Cognition soutient qu'il faut partager le contexte complet (les traces de l'agent, pas de simples messages), car chaque action porte des décisions implicites; des sous-agents mal informés prennent des décisions contradictoires. Cette prise de position d'ingénierie recommande par défaut un agent linéaire à fil unique[276]. LangChain réconcilie les deux positions : le multiagent convient mieux aux tâches de lecture, faciles à paralléliser, qu'aux tâches d'écriture, où des écritures concurrentes se contredisent[277].
- **Limites d'emploi.** Anthropic juge que les tâches où tous les agents doivent partager le même contexte, ou qui comportent de nombreuses dépendances, conviennent mal au multiagent, et que le surcoût ne se justifie que si la valeur de la tâche le paie[17].

Une consigne convergente des éditeurs

Le Centre d'architecture Azure prescrit le niveau de complexité le plus bas qui répond au besoin de façon fiable : appel direct au modèle, puis agent unique doté d'outils, puis orchestration multiagent, seulement si l'agent unique échoue pour cause de complexité d'invite, de surcharge d'outils ou d'exigences de sécurité[9]. Anthropic recommande la solution la plus simple possible[65] et OpenAI, de maximiser d'abord les capacités d'un agent unique[66].

À RETENIR

Le multiagent est un outil de spécialiste, pas une architecture par défaut. Il rapporte surtout sur des tâches de lecture parallélisables et à forte valeur; il coûte de 3 à 10 fois plus de jetons et peut dégrader les tâches séquentielles. Le cadre exige donc une preuve mesurée avant d'ajouter des agents (PRIN-08).

EXIG-ORC-01 · DOIT

Configuration la plus simple justifiée

Chaque agent ou système d'agents **DOIT** inscrire à sa fiche (annexe B) pourquoi les options plus simples que le patron retenu, prises de la plus simple à la plus complexe parmi le code ou la règle métier, l'appel direct au modèle, le flux déterministe et l'agent unique outillé, ne répondent pas au besoin. La revue d'architecture **DOIT** refuser un patron dont la justification manque.

Pourquoi : chaque niveau de complexité ajoute coordination, latence et coût[9].

EXIG-ORC-02 · DOIT
Preuve mesurée avant le multiagent
Une topologie à plusieurs agents **DOIT** être comparée, sur le même jeu d'évaluation (section 10.4), à une base de référence à agent unique : taux de réussite, jetons par exécution, latence et coût par tâche réussie. Elle n'est retenue que si son taux de réussite n'est pas inférieur à celui de la base de référence (borne inférieure de l'intervalle de confiance à 95 % de la différence supérieure à l'opposé d'une marge de non-infériorité déclarée à la fiche) et si son gain, valorisé par une valeur monétaire déclarée par tâche réussie, couvre le surcoût mesuré; la comparaison déclare la taille d'échantillon, le nombre de répétitions, la statistique et la règle de décision (section 10.4). Sont visés les patrons 3 à 7 du tableau 24 et la variante encadrée, dès que plus d'un composant choisit lui-même ses actions au moyen d'un modèle; un routeur sans modèle ou un évaluateur réduit à une invite distincte n'en fait pas un système multiagent. La comparaison est versée à la fiche de l'agent, avec la grille d'homologation (annexe A).
Pourquoi : les gains publiés dépendent fortement de la tâche et le surcoût en jetons peut atteindre un ordre de grandeur[273, 275].

7.2 Patrons autorisés

Le cadre autorise huit patrons, combinables entre eux, et une variante encadrée (voir la figure 11 et le tableau 24). Un patron décrit la topologie de la coordination; il ne fixe pas le niveau d'autonomie, qui se déclare séparément (chapitre 8).

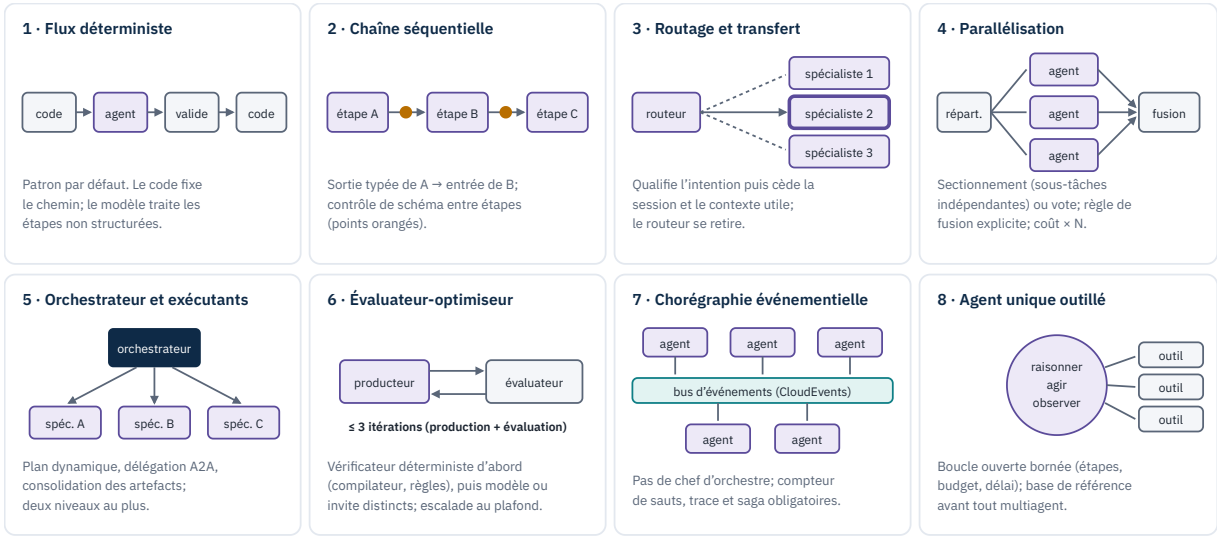


Figure 11 — Huit patrons d'orchestration autorisés. Chaque vignette montre la topologie d'un patron et sa règle principale; les points orangés signalent un contrôle de schéma entre étapes. Pour l'évaluateur-optimiseur, l'évaluateur est un modèle ou une invite distincts de ceux du producteur (EXIG-ORC-05). Les patrons se combinent : un flux déterministe peut contenir une étape orchestrée, qui publie à son tour un événement. Source : cadre CRE-IA-2026-01, d'après Anthropic (2024) et le Centre d'architecture Azure (2026).

Le catalogue s'appuie sur deux références de premier rang. Anthropic distingue les flux de travail, où le modèle et les outils suivent des chemins de code prédéfinis (enchaînement d'invites, routage, parallélisation, orchestrateur-travailleurs, évaluateur-optimiseur), des agents, où le modèle dirige lui-même son processus[65]. Le Centre d'architecture Azure décrit cinq orchestrations : séquentielle, concurrente, clavardage de groupe, transfert et magnétique[9]; la documentation de Microsoft Agent Framework indique que ce dernier patron est conçu à partir de Magentic-One, le système décrit par Fourney et coll.[278, 279]. Le cadre y ajoute la

chorégraphie événementielle, absente des deux catalogues, et fait du flux déterministe à étapes agentiques le patron par défaut.

Tableau 24 — Huit patrons d'orchestration autorisés et variante encadrée

Patron	Fonctionnement	Quand l'utiliser	Point de vigilance	Correspondance
1. Flux déterministe	Un moteur de flux fixe l'ordre et les embranchements; certaines étapes appellent un modèle ou un agent borné pour traiter l'information non structurée.	Processus connus, réglementés ou audités. Patron par défaut.	Rigide quand les cas varient beaucoup; chaque étape agentique a un contrat de sortie validé.	Anthropic : flux de travail; patron par défaut par choix du cadre.
2. Chaîne séquentielle	Chaque étape transforme la sortie typée de la précédente.	Tâche décomposable en étapes fixes (extraire, vérifier, rédiger).	Erreurs propagées et latences cumulées : validation de schéma et délai par étape.	Azure : séquentiel. Anthropic : enchaînement d'invites.
3. Routage et transfert (handoff)	Un routeur qualifie l'intention, puis cède la session et le contexte utile à un spécialiste déclaré; il se retire.	Triage, service à la clientèle par domaine, latence prioritaire.	Liste fermée de destinataires; le transfert porte le mandant, pas tout l'historique; aucun transfert en boucle.	Azure : transfert. Anthropic : routage. OpenAI : décentralisé.
4. Parallélisation	Un répartiteur lance des sous-tâches indépendantes (sectionnement) ou la même tâche plusieurs fois (vote), puis fusionne.	Analyse multi-source, vérification croisée, garde-fou exécuté en parallèle de la tâche, dont la fusion attend le verdict (EXIG-ORC-07).	Jetons multipliés par le nombre de branches, pointes de charge; règle de fusion explicite.	Azure : concurrent. Anthropic : parallélisation.
5. Orchestrateur et exécutants	Un agent planifie dynamiquement, délègue à des spécialistes (A2A, ou appel interne entre sous-agents d'un même processus), puis consolide leurs artefacts.	Tâches ouvertes dont les sous-tâches ne sont pas connues d'avance.	Coût et latence élevés; l'orchestrateur est un point unique de défaillance; deux niveaux au plus.	Azure : magnétique (variante). Anthropic : orchestrateur-travailleurs. OpenAI : gestionnaire.
6. Évaluateur-optimiseur	Un producteur propose; un évaluateur distinct juge selon des critères explicites et renvoie jusqu'à l'acceptation.	Qualité vérifiable : code, rédaction réglementée, conformité.	Trois itérations au plus, puis escalade; vérificateur qui déclare victoire trop tôt.	Azure : boucle producteur-vérificateur. Anthropic : évaluateur-optimiseur.
7. Chorégraphie événementielle	Les agents réagissent aux événements d'un bus et publient les leurs, sans chef d'orchestre.	Processus inter-domaines faiblement couplés, gros volumes, agents ambiants.	Vue d'ensemble difficile, risque de cycles : trace et compteur de sauts obligatoires; saga dès que des effets touchent plusieurs systèmes d'enregistrement.	Ajout du cadre; saga par chorégraphie chez Microsoft.
8. Agent unique outillé	Un agent boucle seul « raisonner, agir, observer »	Requêtes variées dans un même domaine;	Surcharge d'outils, contexte qui enfle;	Azure : agent unique doté d'outils. Anthropic : agent.

Patron	Fonctionnement	Quand l'utiliser	Point de vigilance	Correspondance
	avec ses outils, sous plafonds.	base de référence avant tout multiagent.	conditions d'arrêt obligatoires.	
Variante encadrée : clavardage de groupe et débat	Plusieurs agents échangent dans un fil commun, sous un gestionnaire qui donne la parole.	Décisions où un contre-examen vaut plus que la latence.	Trois agents participants au plus, plus un gestionnaire (EXIG-ORC-06), plafond de tours; propagation d'idées entre agents.	Azure : clavardage de groupe.

Les correspondances Azure des patrons 6 (boucle producteur-vérificateur) et 8 (agent unique doté d'outils) sortent des cinq orchestrations que décrit le Centre d'architecture Azure; elles ne sont données qu'à titre de rapprochement.

Patron et autonomie sont deux dimensions distinctes : un système multiagent peut combiner des agents de niveaux différents[83]. Un orchestrateur plafonné à N3 peut ainsi déléguer à un exécutant plafonné à N1. Chaque action est soumise au contrôle le plus strict de la chaîne : le niveau d'autonomie et la classe les plus contraignants entre l'initiateur et l'agent qui agit, combinés au palier de l'outil appelé (section 8.4). Ces valeurs voyagent dans le contexte de délégation (EXIG-ORC-23) et s'imposent à l'exécutant, et la passerelle les vérifie (EXIG-AUT-10) : un exécutant N3 de classe modérée n'écrit pas seul pour un initiateur N1 ou de classe élevée.

Règles propres à certains patrons

Orchestrateur et exécutants. Le cadre limite la délégation à deux niveaux : l'orchestrateur, puis ses exécutants. Ce plafond est un choix du cadre, appuyé indirectement par la mesure d'amplification des erreurs de Google Research. Salesforce impose une contrainte équivalente, dans un produit précis : l'orchestration multiorganisation d'Agentforce n'admet qu'un saut de délégation (agent A vers agent B, jamais A vers B vers C), soit deux agents en chaîne (un saut; le plafond par défaut de l'EXIG-ORC-04 est de deux sauts, soit trois agents)[49]. Il s'agit d'une contrainte de produit, et non d'une règle générale.

Évaluateur-optimiseur. Microsoft exige un plafond d'itérations, des critères d'acceptation clairs et un comportement de repli défini, comme l'escalade vers un humain[9]; la valeur de trois itérations est un choix du cadre. Anthropic décrit l'écueil de la « victoire prématurée » : un sous-agent vérificateur exécute quelques tests et déclare le succès. Les parades sont des critères concrets, des vérifications exhaustives et des tests négatifs[275].

Clavardage de groupe et débat. Microsoft recommande de limiter le clavardage de groupe à trois agents[9]. Une prépublication d'août 2026 (« Mind Viruses », Papadopoulos et coll., Anthropic Fellows Program et EPFL) montre que des idées ou des objectifs peuvent se propager d'agent en agent, dans une petite équipe d'agents de programmation et dans une chaîne d'agents dont le contexte est effacé entre les sessions. Un bref avertissement dans l'invite système y a conféré une immunité « quasi totale », mais la propagation varie selon le modèle, les consignes initiales et la topologie, et les auteurs jugent le risque réel mais actuellement limité[280]. Le cadre admet cet avertissement comme mesure complémentaire peu coûteuse, jamais comme contrôle suffisant.

Parallélisation. Le patron réduit le temps total, au prix de pointes de consommation lorsque plusieurs agents appellent les modèles en même temps, et il exige une logique de résolution des conflits[9]. Anthropic rapporte que la parallélisation des sous-agents et des appels d'outils a réduit jusqu'à 90 % le temps de recherche pour les requêtes complexes[17].

Chorégraphie événementielle. Pour une saga, la chorégraphie évite tout point unique de défaillance, mais elle complique le suivi et les tests d'intégration et expose à des dépendances cycliques[67]. Les contrôles d'enveloppe (trace, compteur de sauts, file de lettres mortes) relèvent de la section 6.7.

EXIG-ORC-03 · DOIT
Patron déclaré au registre
Chaque système d'agents **DOIT** déclarer à sa fiche et au registre (section 11.4) le patron retenu parmi ceux du tableau 24, ou leur combinaison, accompagné d'un schéma de ses flux. Le patron déclaré **DOIT** résulter de l'arbre de décision de la figure 12 (section 7.3), tout écart étant justifié à la fiche. Toute autre topologie exige une dérogation (section 11.6).
Pourquoi : un patron connu se revoit, se teste et se compare; une topologie improvisée ne se gouverne pas.

EXIG-ORC-04 · NE DOIT PAS
Délégation limitée à deux niveaux
Une chaîne de délégation **NE DOIT PAS** dépasser deux niveaux (orchestrateur, puis exécutant) : un exécutant ne délègue pas à son tour à un autre agent sans dérogation. Le serveur d'autorisation doit vérifier la profondeur lors de chaque échange de jetons (EXIG-IAM-08, section 9.3) et refuser l'échange qui l'excède; la passerelle d'agents ne fonde aucune décision sur les acteurs imbriqués, que la RFC 8693 tient pour informatifs (EXIG-IAM-11). Toute délégation entre agents, même sans mandant humain, passe par un échange de jetons dont le sujet est le mandant d'origine ou, s'il n'y a pas de mandant, l'agent initiateur. Un transfert (patron 3) remplace l'acteur courant sans ajouter de niveau, l'échange que refait la passerelle n'en ajoute pas non plus, et un appel interne entre sous-agents d'un même processus (patron 5) ne délègue pas au-delà. Un saut d'événement exécuté sous la délégation que référence l'événement compte comme un niveau (EXIG-EVT-07).
Pourquoi : choix du cadre, que l'étude citée n'étaye qu'indirectement; la coordination multiagent alourdit la communication et, sans validation centrale, amplifie les erreurs[273]; l'article mesure en outre un surcoût en jetons et davantage de tours de raisonnement[274].

EXIG-ORC-05 · DOIT
Boucle évaluateur-optimiseur bornée
Une boucle évaluateur-optimiseur **DOIT** déclarer des critères d'acceptation vérifiables, exécuter d'abord les vérifications déterministes disponibles (compilation, tests, moteur de règles), confier l'évaluation à un modèle ou à une invite distincts de ceux du producteur et s'arrêter après trois itérations au plus, une itération étant un cycle de production et d'évaluation. Au plafond, la tâche passe en escalade humaine avec la dernière version et les critiques reçues.
Pourquoi : Microsoft exige un plafond, des critères clairs et un repli défini; la valeur de trois est un choix du cadre[9].

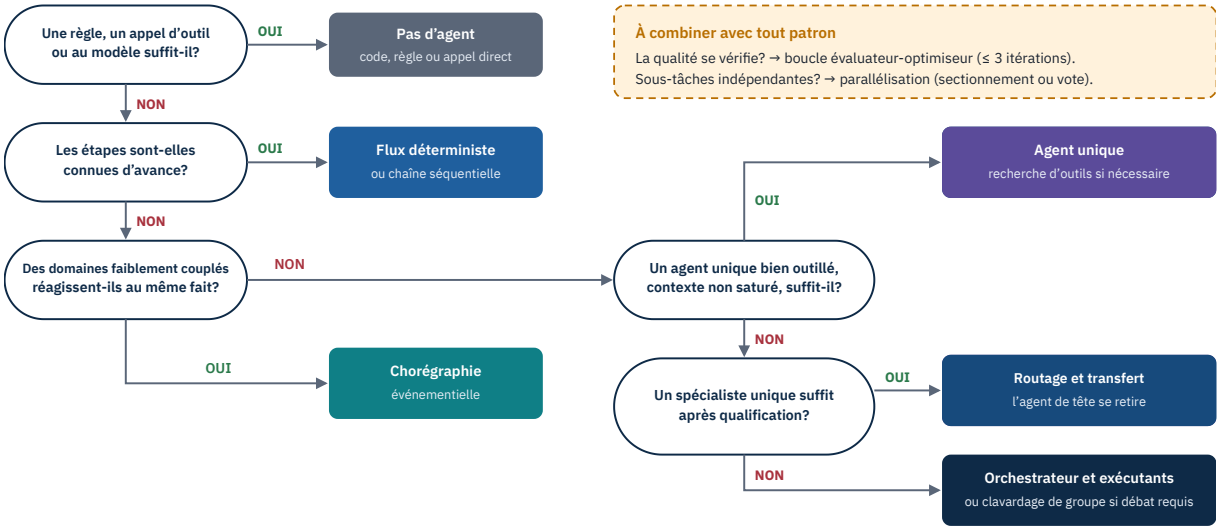
EXIG-ORC-06 · DOIT
Clavardage de groupe encadré
Le clavardage de groupe ou le débat entre agents **DOIT** réunir trois agents participants au plus, sous un gestionnaire (hors décompte des trois participants) qui attribue la parole, avec un plafond de tours et une règle de clôture déclarés. Le maillage libre, où chaque agent sollicite les autres sans plafond, ne doit pas être utilisé.
Pourquoi : Microsoft recommande de limiter le clavardage de groupe à trois agents[9], seuil que le cadre applique aux seuls participants, le gestionnaire qui attribue la parole s'y ajoutant (choix du cadre); des idées peuvent aussi se propager d'agent en agent[280].

EXIG-ORC-07 · DOIT
Fusion déclarée et écrivain unique en parallèle
Un patron de parallélisation **DOIT** déclarer avant l'exécution sa règle de fusion (déterministe, vote ou arbitrage) et sa limite de concurrence. Les branches **DOIVENT** se limiter à lire et à produire des artefacts; un seul composant **DOIT** écrire le résultat final dans un système d'enregistrement. Une branche de garde-fou **DOIT** rendre son verdict avant la fusion; une expiration vaut refus (PRIN-12). S'il faut écrire dans plusieurs systèmes d'enregistrement, un seul composant écrit dans chacun, sous une saga (section 7.5).
Pourquoi : des écritures concurrentes se contredisent[277].

EXIG-ORC-08 · DOIT
Chorégraphie sous propriétaire et saga
Une chorégraphie événementielle qui produit des effets dans plusieurs systèmes d'enregistrement **DOIT** avoir un propriétaire de bout en bout inscrit au registre, une saga explicite (section 7.5) et les contrôles d'enveloppe de la section 6.7. Un coordinateur de saga, composant inscrit au registre, y tient le rôle de l'orchestrateur des EXIG-ORC-16 à 18 (journal de compensation, escalade), et ses compensations passent par le canal de compensation (EXIG-ORC-28); à défaut de coordinateur, la saga est orchestrée.
Pourquoi : sans chef d'orchestre, personne ne voit le processus entier ni ne répond de son issue.

7.3 Choisir le patron

Le choix du patron suit l'arbre de décision de la figure 12, qui part de l'option la plus simple (code ou règle métier, appel direct au modèle, selon l'EXIG-ORC-01). Il se documente à la fiche de l'agent et se révise lorsque les mesures de production contredisent l'hypothèse de départ. L'arbre applique trois règles. D'abord, le mode de déclenchement ne choisit pas la topologie : un agent déclenché par un événement suit le même arbre qu'un agent sollicité par une personne, et la chorégraphie n'est retenue que si plusieurs domaines faiblement couplés réagissent au même fait (tableau 24); patron multiagent, elle reste soumise, comme tout autre, à la comparaison avec l'agent unique de l'EXIG-ORC-02. Ensuite, la question de l'agent unique se pose avant celle du routage, qui suppose un routeur et plusieurs spécialistes. Enfin, deux feuilles complètent les patrons de base : la chaîne séquentielle, lorsque les étapes sont connues et que chacune transforme la sortie typée de la précédente, et le clavardage de groupe, lorsqu'un débat contradictoire est requis (EXIG-ORC-06).



Par défaut, retenir l'option la plus simple qui répond au besoin; passer au multiagent seulement sur preuve mesurée de gain.

Figure 12 — Arbre de décision du patron d'orchestration. Les questions se lisent de haut en bas; la première réponse qui conclut fixe le patron. Le mode de déclenchement n'y entre pas : seule la réaction de plusieurs domaines faiblement couplés à un même fait mène à la chorégraphie, et l'agent unique se teste avant le routage. L'encadré du haut, à droite, s'ajoute à n'importe quel patron lorsque la qualité se vérifie ou que des sous-tâches sont indépendantes. Source : cadre CRE-IA-2026-01, d'après le Centre d'architecture Azure (niveaux de complexité) et Anthropic.

Quand le multiagent se justifie

Anthropic retient trois cas où plusieurs agents surpassent un agent unique : la **protection du contexte** (une sous-tâche produit une exploration volumineuse qui polluerait le contexte principal), la **parallélisation** (des pistes réellement indépendantes) et la **spécialisation** (des outils ou des consignes incompatibles dans un même agent)[275]. Microsoft ajoute les frontières de sécurité distinctes : deux domaines qui ne doivent pas partager les mêmes droits justifient deux agents[9]. L'effort doit aussi suivre la complexité : Anthropic emploie un agent et de 3 à 10 appels d'outils pour une recherche factuelle simple, de 2 à 4 sous-agents pour une comparaison, et davantage pour une recherche complexe[17].

Surcharge d'outils : mesurer avant de scinder

Aucune source ne fixe de seuil unique. OpenAI suggère, à titre indicatif, de viser moins de 20 fonctions disponibles au début d'un tour[115] et souligne que le chevauchement compte plus que le nombre : certaines mises en œuvre gèrent avec succès plus de 15 outils distincts, d'autres peinent avec moins de 10 outils qui se chevauchent[66]. La documentation d'Anthropic situe la dégradation au-delà de 30 à 50 outils disponibles[281]. Avant de multiplier les agents, deux leviers moins coûteux existent : consolider les outils en opérations orientées tâche, regroupées sous des espaces de noms[114], et charger les définitions d'outils à la demande. Selon Anthropic, sa recherche d'outils réduit de 85 % (près de 89 % d'après ses deux chiffres, section 6.5) la consommation de jetons de contexte dans son exemple chiffré et fait passer la précision, sur ses évaluations internes de MCP, de 49 à 74 % (Opus 4) et de 79,5 à 88,1 % (Opus 4.5); ce sont des résultats déclarés par le fournisseur[205].

Découper par frontières de contexte

Quand plusieurs agents sont retenus, on découpe selon les frontières de contexte, et non selon le type de travail : une fonctionnalité et ses tests restent avec le même agent[275]. Par exemple, dans l'analyse d'un dossier de crédit, l'agent qui lit les états financiers calcule aussi les ratios qui en découlent; un agent distinct ne se justifie que pour un contexte isolable, comme la vérification des sanctions internationales, qui obéit à d'autres droits d'accès.

Tableau 25 — Critères comparés des principaux patrons

Critère	Flux déterministe	Agent unique	Routage et transfert	Orchestrateur et exécutants	Évaluateur-optimiseur	Chorégraphie
Prévisibilité et auditabilité	Très élevée	Moyenne	Élevée	Moyenne	Élevée sur le résultat	Moyenne, émergente
Latence de bout en bout	Faible à moyenne	Variable selon les tours	Faible	Élevée; réduite si parallèle	Moyenne à élevée	Asynchrone
Profil de coût en jetons (repère)	Le plus bas	Environ 4 fois une conversation	Cumul étape par étape	3 à 10 fois l'agent unique; pointes si parallèle	Croît avec les itérations	Croît avec les abonnés et les sauts
Tolérance à l'ambiguïté	Faible	Élevée dans un domaine	Moyenne	Très élevée	Moyenne	Moyenne
Ce qui borne la dérive	Le code	Plafonds et budget	Liste fermée de destinataires	Deux niveaux, budget, délais	Trois itérations	Compteur de sauts, lettres mortes

Les appréciations qualitatives du tableau 25 sont des repères du cadre. Les seuls ordres de grandeur retenus par le cadre sont ceux d'Anthropic (environ 4 fois et 15 fois une conversation; de 3 à 10 fois l'agent unique) [17, 275] et les profils de Microsoft : coûts cumulés étape par étape pour les patrons séquentiel et de transfert, pointes pour le patron concurrent, coût le moins prévisible pour le patron magnétique[9]. Ces repères cèdent la place aux mesures de jetons par agent et par exécution dès qu'elles existent (section 10.6).

EXIG-ORC-09 · DOIT
Surcharge d'outils traitée avant de scinder
Dès qu'un agent dispose de plus de 15 outils au début d'un tour (seuil opérationnel choisi par le cadre, sous le repère indicatif de 20 fonctions d'OpenAI), ou dès que le jeu d'évaluation montre des confusions entre outils (chevauchement), l'équipe **DOIT** mesurer la précision de sélection d'outils sur le jeu d'évaluation et la comparer au seuil de précision déclaré à la fiche, puis essayer la consolidation des outils et leur chargement à la demande avant de scinder l'agent en plusieurs agents.
Pourquoi : le chevauchement compte plus que le nombre[66], et la recherche d'outils restaure une partie de la précision à moindre coût[205].

EXIG-ORC-10 · DEVRAIT
Découpage par frontières de contexte
Lorsqu'un système multiagent est retenu, le découpage **DEVRAIT** suivre les frontières de contexte et de sécurité plutôt que les types de travail : le même agent garde une unité de travail et sa vérification immédiate. Un agent distinct se justifie par un contexte isolable, un parallélisme réel, une spécialisation d'outils ou une frontière de sécurité, consignés à la fiche. Une tâche d'écriture à fortes dépendances (écritures interdépendantes dans un même système d'enregistrement) doit rester à un seul agent (sections 7.1 et 7.7).
Pourquoi : un transfert qui ne passe que des messages, sans la trace complète, fait perdre des décisions implicites[275, 276].

7.4 État et exécution durable

Un agent attend une approbation pendant trois jours; un serveur redémarre au milieu d'une réservation. Dans les deux cas, l'orchestration doit reprendre exactement où elle s'était arrêtée, sans perdre le contexte et sans refaire une action déjà faite. C'est le rôle de l'exécution durable.

Persister l'état hors du processus

Microsoft recommande de persister l'état partagé hors de la mémoire et d'utiliser les points de contrôle du cadriciel[9]. Les moteurs y parviennent de façons différentes. Temporal garantit qu'une exécution de flux se poursuit jusqu'à son terme, sans limite de durée imposée, et la reprend après une panne en rejouant son historique d'événements[81]. Cet historique est toutefois borné (51 200 événements ou 50 Mo par exécution, selon la documentation de Temporal) : une exécution longue se poursuit par Continue-As-New, et un résultat volumineux passe par référence (EXIG-ORC-24). Ses activités sont en outre réessayées sans limite par défaut (EXIG-ORC-27). LangGraph conserve l'état par fil (`thread_id`) au moyen de *checkpointers* : `InMemorySaver` perd ses points de contrôle au redémarrage et sert à l'expérimentation, tandis qu'un magasin persistant comme `PostgresSaver` s'impose en production[124, 282]. Microsoft Agent Framework crée un point de contrôle à la fin de chaque étape de calcul du flux, avec l'état des exécuteurs, les messages et les requêtes en attente[105].

Ne jamais refaire une action terminée : une garantie à construire

La persistance ne suffit pas à éviter les doubles effets. Dans LangGraph, à la reprise après une interruption, le nœud interrompu redémarre depuis son début et le code qui précède l'interruption s'exécute de nouveau[82]; Temporal réessaie les activités en échec[79]. La garantie repose donc sur deux règles de conception : isoler chaque appel non déterministe (modèle, outil, agent distant) dans une étape journalisée dont le résultat se relit à la reprise, et rendre idempotent tout effet qui peut être rejoué (section 7.6). L'intégration de Temporal avec l'OpenAI Agents SDK applique la première règle : chaque invocation d'agent s'y exécute comme une activité, suivie et réessayée par le moteur[122].

Aux points d'approbation obligatoires, l'état est persisté afin de reprendre sans rejouer le travail des agents précédents[9]. La primitive `interrupt()` de LangGraph, par exemple, suspend le graphe et attend sans limite une reprise sur le même fil[82]. La forme de l'approbation elle-même relève de la section 8.5.

Points de contrôle, versions et rejeu

Un point de contrôle contient l'état complet d'une tâche, souvent avec des renseignements personnels (RP) et des extraits d'invites. Microsoft le désigne comme une frontière de confiance : on ne charge jamais un point de contrôle venant d'une source non fiable, et ses magasins Python n'acceptent qu'une liste d'autorisation de types à la désérialisation[105]. Les exécutions longues posent aussi un problème de version : Anthropic déploie ses agents en mode « arc-en-ciel » pour ne pas interrompre ceux qui s'exécutent déjà[17]. Enfin, le « voyage dans le temps » de LangGraph permet de rejouer depuis un point de contrôle antérieur ou de bifurquer après correction de l'état; les nœuds suivants s'exécutent alors de nouveau et les appels aux modèles ou aux API peuvent produire d'autres résultats[283]. Le rejeu sert à l'analyse et à la correction; il ne reproduit pas une décision à l'identique.

> **EXIG-ORC-11 · DOIT**
> **Persistance après chaque transition**
> Tout flux qui comporte au moins une étape P2 ou P3, une attente humaine (approbation, question) ou une durée supérieure à un seuil déclaré à la fiche **DOIT** s'exécuter sur un moteur d'exécution durable qui persiste l'état après chaque étape journalisée (appel de modèle, appel d'outil, décision, réponse humaine) dans un magasin externe au processus; chaque appel non déterministe à effet est sa propre étape (EXIG-ORC-12). Les autres flux de plus d'une étape devraient le faire. Un magasin en mémoire ne doit pas être utilisé en production ni dans un environnement qui traite des données réelles.
> Pourquoi : un redémarrage ou un déploiement ne doit faire perdre ni le contexte ni l'avancement[9, 124].

EXIG-ORC-12 · DOIT
Reprise sans double effet
La logique de coordination **DOIT** rester déterministe une fois relus les résultats journalisés des appels non déterministes; chaque appel non déterministe **DOIT** s'exécuter comme une étape journalisée dont le résultat est relu, et non recalculé, à la reprise. Tout effet de bord, écriture ou non (notification, événement publié, appel facturé), **DOIT** être idempotent par une clé déterministe (EXIG-ORC-21) ou isolé dans une étape journalisée exécutée au plus une fois. Son emplacement par rapport au point de pause n'en dispense pas : un effet non idempotent ne précède jamais un point de pause et ne se trouve jamais dans une étape réessayable.
Pourquoi : les moteurs réexécutent le nœud interrompu ou réessaient l'activité en échec[79, 82].

EXIG-ORC-13 · DOIT
Magasin de points de contrôle protégé
Le magasin des points de contrôle **DOIT** être traité comme une frontière de confiance et comme une donnée de production : accès limité à l'identité de l'orchestrateur, chiffrement au repos, contrôle d'intégrité au chargement, conservation et élagage définis. Un orchestrateur ne doit pas charger de point de contrôle d'origine non vérifiée. Toute modification manuelle de l'état (bifurcation après correction) est signée de nouveau par le service d'orchestration et journalisée en audit. Aucun jeton n'y figure (EXIG-IAM-06).
Pourquoi : Microsoft désigne le point de contrôle, qui contient l'état complet de la tâche, y compris les messages en attente, comme une frontière de confiance[105]. Qu'un point de contrôle altéré permette d'en modifier l'état et que ces messages puissent contenir des RP est un constat du cadre.

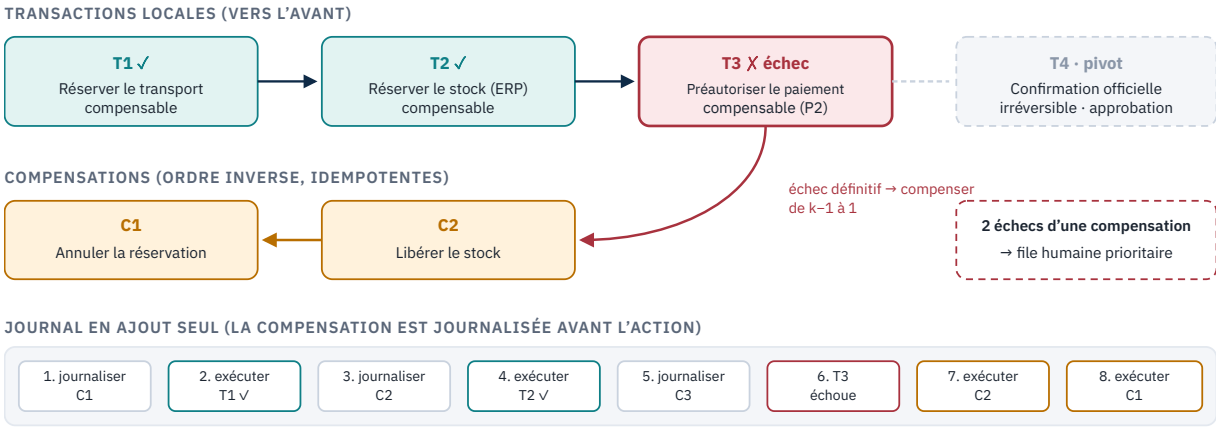
EXIG-ORC-14 · DEVRAIT
Déploiement sans interruption des exécutions longues
Le déploiement d'une nouvelle version d'agent ou de flux **DEVRAIT** laisser chaque exécution en cours se terminer sur la version avec laquelle elle a commencé; une migration d'état en cours d'exécution **DEVRAIT** se tester comme un changement de schéma. La cohabitation est bornée par le plafond de durée de l'EXIG-ORC-26. Le retrait d'une version pour un motif de sécurité doit suspendre les exécutions en cours ou les migrer par une migration testée.
Pourquoi : un déploiement peut casser les agents déjà en cours d'exécution, et recommencer du début coûte cher[17].

7.5 Transactions : patron saga

Lorsqu'une tâche écrit dans plusieurs systèmes qui ne partagent aucune transaction (un système de transport, un progiciel de gestion intégré, une passerelle de paiement), aucun retour arrière global n'existe. La saga remplace la transaction globale par une suite de transactions locales, chacune appariée à une compensation (voir la figure 13).

Principe

Garcia-Molina et Salem ont défini la saga en 1987 : une transaction de longue durée découpée en transactions plus courtes, avec la garantie que soit toutes s'exécutent, soit des transactions compensatoires défont l'exécution partielle[284, 285]. Microsoft distingue trois sortes d'étapes : les transactions **compensables**, qui précèdent le point de non-retour; la transaction **pivot**, qui est ce point de non-retour; et les transactions **réessayables**, idempotentes, qui la suivent jusqu'au terme[67]. Une saga se conçoit donc pour que tout ce qui est irréversible arrive le plus tard possible (PRIN-05).



T3 n'a jamais été marquée « terminée » : C3 n'est exécutée que si l'issue de T3, une fois résolue, est un effet réalisé (EXIG-ORC-16). Le pivot T4 n'est atteint qu'après succès de T1 à T3.

Figure 13 — Saga : transactions locales, pivot et compensations. T1 et T2 réussissent; T3 échoue de façon définitive : l'orchestrateur exécute C2 puis C1, et le pivot T4, irréversible et soumis à approbation, n'est jamais atteint. Le journal montre que chaque compensation est consignée avant l'action qu'elle couvre. Le dessin simplifie deux points, que le texte corrige. Un débit externe est P3 et ne peut précéder le pivot (EXIG-ORC-15) : T3 se lit « préautoriser le paiement, sans capture », étape compensable (P2) par l'annulation de la préautorisation, et la capture se fait au pivot, avec son approbation. La compensation porte sur les étapes exécutées : de k−1 à 1 si T_k a échoué sans effet, de k à 1 si son issue, une fois résolue (EXIG-ORC-16), est un effet réalisé. Source : cadre CRE-IA-2026-01, d'après Garcia-Molina et Salem (1987), Microsoft et Temporal.

Cinq règles de conception

1. **Journaliser la compensation avant l'action.** Temporal recommande d'inscrire la compensation avant d'exécuter l'activité, parce qu'un effet de bord peut survenir avant que l'échec ne soit signalé : une carte débitée, par exemple[286]. Microsoft exige de consigner chaque étape et la façon de la défaire dans un magasin durable, afin de reprendre la compensation au point d'échec[77].
2. **Résoudre l'incertain avant de compenser.** Si l'orchestrateur ignore l'issue d'une étape (délai expiré, plantage entre le journal et la réponse), il la considère comme possiblement exécutée, mais aussi comme possiblement encore en cours chez le système visé : une compensation exécutée trop tôt ne trouve rien, réussit à vide, puis l'original produit son effet. Il clôt donc d'abord l'opération (annulation ou révocation de la clé d'idempotence, qui fait rejeter toute arrivée tardive) ou interroge le système visé par la clé jusqu'à une issue définitive; à défaut, l'étape passe en réconciliation humaine (EXIG-ORC-16). La compensation reste conditionnelle : « rembourser la transaction X si elle a été débitée », et non « rembourser le montant X ».
3. **Compenser en termes métier.** Une compensation applique des règles d'affaires : l'annulation d'un vol n'entraîne pas forcément un remboursement complet. Elle ne ramène pas nécessairement les données à leur état initial, ne suit pas toujours l'ordre inverse exact et peut parfois s'exécuter en parallèle[77]. On ne « désenvoie » pas un courriel : on envoie un rectificatif.
4. **Réessayer avant de compenser.** On ne compense que si la progression devient impossible, c'est-à-dire après épuisement des réessais ou devant une erreur non transitoire[77].
5. **Escalader l'échec persistant.** Si une compensation échoue, Temporal recommande de consigner l'erreur, de poursuivre les autres compensations, puis d'alerter; une erreur non réessayable dans une compensation signifie que la saga ne peut plus revenir entièrement en arrière[286]. Microsoft prévoit la file de lettres mortes et la suspension des cas ambigus ou à fort impact pour revue humaine[77]. Le seuil de deux échecs retenu ci-dessous est un choix du cadre.

Isolation entre sagas concurrentes

Une saga n'isole pas ses étapes comme une transaction ACID (atomicité, cohérence, isolation, durabilité). Microsoft recense trois anomalies : mises à jour perdues, lectures sales et lectures non répétables. Les contre-mesures sont le verrou sémantique, les mises à jour commutatives, la vue pessimiste (réordonner les étapes pour que les mises à jour aient lieu dans des transactions réessayables), la relecture des valeurs avant mise à jour, les jetons de version (*version tokens*) et le choix du mécanisme de concurrence selon le risque métier. La saga convient mal aux transactions fortement couplées et aux dépendances cycliques[67]. Exemple : deux agents qui réservent le même stock posent d'abord un verrou sémantique « réservation en attente », visible des autres sagas, plutôt que de décrémenter directement la quantité.

Pour les agents, SagaLLM (Chang et Geng, PVLDB, 2025) combine le patron saga, une mémoire persistante, des compensations automatisées et des agents de validation indépendants, en assouplissant les garanties ACID au profit d'une cohérence à l'échelle du flux[287, 288]. C'est une référence de recherche utile, et non une norme d'industrie.

EXIG-ORC-15 · DOIT
Saga pour toute écriture multisystème
Une tâche qui écrit dans au moins deux systèmes d'enregistrement sans transaction commune **DOIT** être modélisée comme une saga : chaque étape d'écriture P2 référence la compensation déclarée dans son entrée de catalogue (section 6.8); la définition de la saga déclare l'ordre des compensations (ordre inverse par défaut) et leurs dépendances, selon lesquels s'applique l'EXIG-ORC-18; le pivot, unique, est identifié; toute étape de palier P3 (action critique, externe ou irréversible) se place au pivot ou après, une fois les validations critiques réussies, et reçoit sa propre approbation humaine (EXIG-AUT-09 et EXIG-AUT-12). Les étapes qui suivent le pivot **DOIVENT** être idempotentes et réessayables jusqu'au succès, ou dotées d'une file humaine nommée pour l'échec définitif. En chorégraphie, un coordinateur de saga inscrit au registre tient le rôle de l'orchestrateur des EXIG-ORC-16 à EXIG-ORC-18 et de l'EXIG-ORC-28 (EXIG-ORC-08).
Pourquoi : reporter l'irréversible après toutes les validations limite ce qu'il faut défaire[77].

EXIG-ORC-16 · DOIT
Journal de compensation tenu avant l'action
Avant chaque étape d'écriture (P2 ou P3), l'orchestrateur, ou le coordinateur de saga en chorégraphie, **DOIT** consigner dans un journal durable, en ajout seul et corrélé à la trace, l'étape, la référence de ses arguments, sa clé d'idempotence et la compensation à exécuter. Ce journal ne garde que des références et, chiffrés, les seuls arguments nécessaires à la compensation; il ne contient aucun jeton (EXIG-IAM-06). Il suit les contrôles de l'EXIG-ORC-13 (accès, chiffrement, conservation, élagage au plus tard à la clôture de la saga augmentée d'un délai déclaré); l'historique du moteur durable peut en tenir lieu. Il est distinct du journal d'audit (EXIG-OBS-11), qui n'en reçoit que des empreintes. Avant de compenser une étape dont l'issue est inconnue, l'orchestrateur **DOIT** soit clôturer l'opération chez le système visé (annulation ou révocation de la clé d'idempotence, de sorte que toute arrivée tardive soit rejetée), soit l'interroger par sa clé jusqu'à une issue définitive, une réponse 409 valant attente et non échec. Si aucune des deux voies n'existe, l'étape passe en réconciliation différée, confiée à une personne (EXIG-ORC-18), et n'est ni compensée ni replanifiée à l'aveugle.
Pourquoi : un effet peut survenir avant que l'échec ne soit signalé[286]; une compensation qui précède l'effet tardif de l'original réussit à vide et laisse un effet net, d'où la résolution préalable, choix du cadre.

EXIG-ORC-17 · DOIT
Compensations idempotentes et métier, après réessais
Chaque compensation **DOIT** être idempotente, définie en termes métier (remboursement, avis rectificatif, libération de stock) avec le propriétaire du système visé, et inscrite au catalogue comme un outil, avec son palier, référencé par le champ `compensation` de l'entrée de catalogue de l'outil d'origine (annexe C, C.2). La compensation déclarée d'une étape approuvée, bornée au montant et aux bénéficiaires d'origine et liée à la même clé d'idempotence, est approuvée avec l'étape (EXIG-AUT-12); toute autre compensation P3 exige une nouvelle approbation. Par exemple, une préautorisation de paiement annulable est P2, et sa capture est P3. L'orchestrateur réessaie d'abord l'étape en échec selon sa politique de réessai et ne compense que si la progression devient impossible.
Pourquoi : une compensation peut s'exécuter plusieurs fois et ne restaure pas forcément l'état initial[77, 286].

EXIG-ORC-18 · DOIT
Escalade après deux échecs d'une compensation
Lorsqu'une compensation subit une erreur non transitoire, ou épuise deux fois de suite la politique de réessai déclarée, l'orchestrateur, ou le coordinateur de saga en chorégraphie, **DOIT** cesser de la relancer, poursuivre les compensations qui n'en dépendent pas selon le graphe déclaré (EXIG-ORC-15), puis placer l'état complet de la saga dans une file humaine prioritaire nommée, avec alerte et identifiants de corrélation.
Pourquoi : l'échec persistant exige une intervention manuelle[286]; le seuil de deux échecs est un choix du cadre.

EXIG-ORC-19 · DOIT
Isolation sémantique des sagas concurrentes
Lorsque plusieurs sagas, agents ou autres écrivains du système d'enregistrement (personnes, traitements en lot, intégrations existantes) peuvent modifier les mêmes enregistrements, la conception **DOIT** documenter les anomalies possibles (mises à jour perdues, lectures sales, lectures non répétables) et appliquer au moins une contre-mesure à chacune. Tout verrou sémantique **DOIT** avoir une échéance, un propriétaire et une procédure de libération en cas de suspension ou d'escalade; un écrivain qui ne le respecte pas est traité comme une anomalie à couvrir.
Pourquoi : la saga n'offre pas l'isolation d'une transaction ACID[67].

EXIG-ORC-20 · DOIT
Tests d'injection de fautes des sagas
Avant la mise en production, toute saga **DOIT** réussir les tests automatisés suivants, exécutés contre des doublures des systèmes d'enregistrement : échec forcé de chaque étape T_k avec vérification des compensations et de leur ordre déclaré; plantage entre l'écriture au journal et l'action; effet réalisé et résultat perdu; arrivée tardive de l'original après la décision de compenser; sagas concurrentes sur le même enregistrement; échec définitif après le pivot; double exécution de chaque compensation; double échec d'une compensation avec vérification de l'escalade; plantage pendant une compensation; compensation sous coupe-circuit et pendant une panne de la passerelle (EXIG-ORC-28). Un test de contrat d'idempotence **DOIT** en outre s'exécuter contre l'environnement d'essai du service visé, seul à connaître son comportement réel.
Pourquoi : exigence propre au cadre; les chemins de compensation ne servent presque jamais en exploitation normale et doivent être éprouvés avant d'être nécessaires.

7.6 Idempotence

Une opération est idempotente si l'exécuter deux fois produit le même effet que l'exécuter une fois. Sans cette propriété, un simple réessai après un délai expiré peut débiter un client deux fois.

Les doublons ne sont pas une hypothèse d'école : ils découlent des garanties mêmes des composants. Kafka livre « au moins une fois » par défaut, et sa sémantique « exactement une fois » ne couvre que le cycle lecture-traitement-écriture entre sujets Kafka[140, 256]. Pour les notifications push A2A, le protocole exige au moins une tentative de livraison (reprises facultatives, doublons possibles)[68], et les flux Express asynchrones d'AWS Step Functions s'exécutent au moins une fois (les flux Express synchrones, « au plus une fois »), ce qui exige des actions idempotentes pour les premiers[104]. Les règles propres au bus d'événements figurent à la section 6.7.

Le cadre dérive la clé de l'identifiant de la tâche racine, stable de bout en bout, et de celui de l'étape. Le brouillon IETF `draft-ietf-httpapi-idempotency-key-header-08` (22 octobre 2026), qui n'est pas encore une RFC, décrit l'en-tête `Idempotency-Key` : le client renvoie la même clé à chaque réessai; le serveur répond 409 si la requête d'origine est encore en cours et 422 si la clé est réutilisée avec une charge utile différente. Le brouillon recommande un UUID (identifiant unique universel) ou un identifiant aléatoire semblable et met en garde contre les clés à faible entropie; la dérivation déterministe retenue par le cadre est un choix qui lui est propre, acceptable pourvu que la clé reste unique par opération et que le service la valide avant tout traitement[78]. Le brouillon laisse au serveur la durée de conservation des clés; le cadre la borne (EXIG-ORC-22). Quant aux annotations d'outil de MCP (`idempotentHint`, `destructiveHint`), ce sont de simples indices, sur lesquels un client ne fonde aucune décision lorsque le serveur n'est pas digne de confiance[197, 201].

Dérivation de la clé d'idempotence (illustration)

```
réessai de la même étape                → même clé, aucun effet supplémentaire
même clé, arguments différents          → rejet (422 selon le brouillon IETF)
étape replanifiée avec d'autres valeurs → nouveau step_id, donc nouvelle clé
étape dont l'issue est incertaine        → aucune replanification avant résolution (EXIG-ORC-16)
nouvelle itération d'une boucle          → indice d'itération dans step_id, donc nouvelle clé
```

```
task_id         = "tache-7f3c2a"              (tâche racine; valeur abrégée, UUIDv4 en production)
step_id         = "etape-02/reserver-stock#1"  (chemin dans le plan, indice d'itération)
cle             = hex( SHA-256( JCS( ["idem-v1", task_id, step_id] ) ) )
```

EXIG-ORC-21 · DOIT
Clé d'idempotence sur toute écriture
Chaque appel d'outil en écriture (P2 ou P3) **DOIT** porter une clé d'idempotence dérivée d'un identifiant d'opération racine stable de bout en bout et de l'identifiant de l'étape, réutilisée telle quelle à chaque réessai. L'identifiant racine est celui de la tâche de l'appelant d'origine, propagé dans le message de délégation (EXIG-ORC-23) et, pour un événement, le couple (`source`, `id`). L'identifiant d'étape encode le chemin de l'étape dans le plan et l'indice d'itération; une bifurcation par voyage dans le temps reçoit un nouvel espace de clés. La clé est l'empreinte de la canonisation RFC 8785 d'un objet, et non d'une concaténation, et l'identifiant racine est aléatoire (UUIDv4 ou équivalent). Une étape replanifiée avec d'autres arguments reçoit un nouvel identifiant d'étape, donc une nouvelle clé; une étape dont l'issue est incertaine ne doit pas être replanifiée avant sa résolution (EXIG-ORC-16). La clé voyage dans l'en-tête `Idempotency-Key` lorsque le service le prend en charge, sinon dans un champ déclaré du contrat d'outil.
Pourquoi : réessais, reprises et livraisons « au moins une fois » rejouent des appels[68, 140].

EXIG-ORC-22 · DOIT
Vérification de la clé par le service visé
Tout outil P2 ou P3 inscrit au catalogue **DOIT** déclarer au catalogue l'argument qui porte sa clé d'idempotence et son mode de vérification : (a) natif, la clé étant vérifiée par le système d'enregistrement; (b) par adaptateur, avec un registre de clés durable mis à jour dans la même transaction que l'effet, ou complété par une requête d'état qui constate l'effet par une référence externe dérivée de la clé. Un outil sans (a) ni (b) est classé P3, n'est jamais réessayé automatiquement, et une issue inconnue y déclenche une réconciliation humaine. La vérification garantit qu'un doublon ne produit aucun effet supplémentaire, qu'une clé réutilisée avec des arguments différents est rejetée et qu'une requête dont l'original est encore en cours est refusée sans exécution. Le service **DOIT** permettre d'interroger l'état d'une clé et devrait permettre de la révoquer; les clés sont cloisonnées par client. Leur durée de conservation, déclarée au catalogue, **DOIT** couvrir la durée de vie maximale de la tâche durable (EXIG-ORC-26), plus la fenêtre de reprise et le délai de réconciliation; une reprise depuis un point de contrôle plus ancien que cette durée est interdite (EXIG-ARC-06). Ce comportement est déclaré dans l'entrée de catalogue; les annotations MCP n'en tiennent pas lieu[197].
Pourquoi : seul le système visé sait si l'effet a déjà eu lieu, et le brouillon laisse au serveur la durée de conservation des clés[78]; la déduplication ne vaut que pendant cette durée.

7.7 Contexte transmis entre agents

Ce qu'un agent transmet à un autre détermine à la fois la qualité du résultat, le coût et l'exposition des données. Le cadre impose un contexte minimal et structuré, avec une nuance importante pour les tâches fortement couplées.

Microsoft demande de décider quel contexte l'agent suivant requiert (contexte complet, version compactée ou nouvelle consigne seulement), de compacter entre agents et de limiter l'état persisté au strict nécessaire, pour des raisons de coût et de confidentialité[9]. Anthropic fait rendre par ses sous-agents une synthèse condensée, souvent de 1 000 à 2 000 jetons[149], et stocke leurs livrables hors du contexte pour les transmettre par références légères[17]. La mise en garde de Cognition reste valable : un exécutant privé des décisions qui le concernent en prendra de contradictoires[276]. Le contexte minimal convient donc surtout aux tâches de lecture; une tâche à fortes dépendances reste à un seul agent (sections 7.1 et 7.3). Cognition a depuis nuancé sa position (Yan, 22 avril 2026) : des agents supplémentaires peuvent apporter du jugement tant que les écritures restent à fil unique; ses observations d'origine tiennent toujours pour les essaims d'écrivains parallèles[289]. La gestion du contexte et de la mémoire de chaque agent relève de la section 5.5.

Contenu logique d'une délégation (indépendant du protocole)

```
{
  "sous_objectif": "Évaluer la solvabilité du client 4471 selon la politique CR-12",
  "criteres_acceptation": ["ratios calculés", "pièces citées", "aucune donnée hors dossier"],
  "parametres": { "client_id": "4471", "montant_demande": 250000 },
  "artefacts": ["artefact://dossiers/4471/etats-financiers-2025.pdf"],
  "delegation": "<référence de délégation; jeton délégué en en-tête, hors message>",
  "tache_racine": "tache-7f3c2a", "etape": "etape-04/evaluer-solvabilite#1", "palier_max": "P1",
  "traceparent": "00-<trace-id>-<span-id>-01",
  "budget_restant": { "jetons": 40000, "cout_max_cad": 0.40, "appels_outils": 10, "echeance":
"2026-10-27T14:13:12Z" },
  "schema_retour": "schema://credit/avis-solvabilite/1.2"
}
```

Ce message ne contient ni l'historique de la conversation ni les données que l'exécutant peut lire lui-même avec les droits du mandant. Sa traduction en messages A2A relève de la section 6.6.

La sécurité suit le même chemin. Microsoft exige que chaque agent applique un filtrage de sécurité, pour ne jamais renvoyer une donnée inaccessible à l'utilisateur, et que des garde-fous de contenu s'appliquent à plusieurs points : entrée de l'utilisateur, appels d'outils, réponses d'outils et sortie finale, car un agent intermédiaire peut introduire ou propager du contenu nuisible[9].

EXIG-ORC-23 · DOIT
Contexte de délégation minimal et structuré
Une délégation **DOIT** transmettre un message structuré limité au sous-objectif, aux critères d'acceptation, aux paramètres requis, aux références d'artefacts, à la référence de délégation (section 9.3), à l'identifiant de la tâche racine et à celui de l'étape qui délègue, dont l'exécutant dérive ses propres clés d'idempotence (EXIG-ORC-21), au palier maximal autorisé, au contexte de trace (section 10.1), au budget restant, au schéma de retour attendu et, pour une tâche fortement couplée, à un registre structuré des décisions prises. Le jeton délégué voyage dans l'en-tête d'authentification du transport (A2A, MCP), injecté par le code d'exécution ou par la passerelle; il ne doit pas figurer dans le message, dans un point de contrôle, dans un journal ni dans le contexte du modèle (EXIG-IAM-06). Le niveau d'autonomie et la classe les plus contraignants de la chaîne voyagent dans le contexte de délégation et s'imposent à l'exécutant (EXIG-AUT-10). L'historique brut complet ne doit pas être transmis, sauf exception justifiée à la fiche.
Pourquoi : un contexte minimal réduit le coût et l'exposition des données[9].

EXIG-ORC-24 · DOIT
Retour validé avant toute réutilisation
Un exécutant **DOIT** rendre une synthèse conforme au schéma de retour déclaré et déposer ses livrables volumineux dans un magasin d'artefacts, transmis par référence. L'orchestrateur **DOIT** valider la sortie (schéma, plafonds, garde-fous) avant de l'utiliser ou de la transmettre; une sortie invalide **DOIT** déclencher un réessai, une demande de précision ou l'arrêt.
Pourquoi : une sortie non validée propage l'erreur d'agent en agent[9].

EXIG-ORC-25 · DOIT
Filtrage de sécurité dans chaque agent
Chaque agent **DOIT** lire sous l'intersection des droits du mandant et de sa propre portée (section 9.3) et filtrer ses résultats selon les droits du mandant, de sorte qu'aucune donnée inaccessible à ce mandant ne remonte à l'orchestrateur ni à l'utilisateur. Un agent qui lit sous ses propres droits, derrière une frontière de sécurité distincte, **DOIT** rendre un schéma de retour dont les champs, déclarés à la fiche, sont accessibles au mandant. Les garde-fous de contenu s'appliquent à l'entrée, aux appels d'outils, aux réponses d'outils et à la sortie finale; le contenu reçu d'un autre agent est traité comme une donnée non fiable et porte les étiquettes de sa session d'origine (section 9.6).
Pourquoi : un agent intermédiaire peut introduire ou propager du contenu nuisible[9].

7.8 Résilience et dégradation maîtrisée

Un modèle indisponible, un outil lent ou un agent qui tourne en rond ne doivent ni bloquer le processus ni produire un résultat faux en silence. Cette section met en œuvre le principe de dégradation maîtrisée (PRIN-12).

Microsoft prescrit pour les orchestrations d'agents des délais d'expiration et des réessais, une dégradation maîtrisée, la remontée des erreurs plutôt que leur masquage, la validation de la sortie d'un agent avant

sa transmission, l'examen de disjoncteurs, l'isolement des agents sans point unique de défaillance partagé et des points de contrôle pour reprendre après une panne ou un déploiement[9]. Anthropic note qu'il est courant d'inclure des conditions d'arrêt, comme un nombre maximal d'itérations, pour garder le contrôle d'un agent[65]. Les plafonds de l'exécution s'inscrivent dans l'enveloppe budgétaire de la tâche (section 10.6); le modèle de repli s'obtient par la passerelle de modèles (chapitre 5).

Le dernier recours est l'arrêt. Pour les systèmes à haut risque, le règlement européen sur l'IA prévoit la possibilité d'interrompre le système de façon sûre (art. 14, par. 4, al. e))[61, 290, 412]; le NIST AI RMF, cadre d'usage volontaire, demande (MANAGE 2.4) des mécanismes et des responsabilités pour remplacer, désengager ou désactiver un système dont les résultats s'écartent de l'usage prévu[99]. OpenAI recommande une interruption ordonnée, soit ciblée (révoquer une catégorie d'actions), soit générale[291]. La propagation de l'arrêt à travers les passerelles et les jetons relève de la section 9.4.

EXIG-ORC-26 · DOIT
Plafonds sur toute exécution
Chaque exécution **DOIT** porter des plafonds déclarés à la fiche : étapes ou itérations, appels d'outils, jetons, coût et durée totale. L'atteinte d'un plafond **DOIT** arrêter la boucle en état sûr et déclencher l'escalade prévue; elle ne doit pas être rapportée comme un succès. Les réessais comptent dans ces plafonds. L'arrêt au plafond agit vers l'avant : les compensations des étapes exécutées puisent dans une réserve de budget calculée à la conception, hors de ces plafonds (EXIG-ORC-28).
Pourquoi : l'autonomie d'un agent entraîne des coûts plus élevés et un risque d'erreurs cumulatives, d'où des conditions d'arrêt pour garder le contrôle[65].

EXIG-ORC-27 · DOIT
Mécanismes de résilience et repli testé
Chaque dépendance d'une orchestration (modèle, outil, agent distant) **DOIT** être protégée par un délai d'expiration, par des réessais à temporisation exponentielle avec gigue *(exponential backoff with jitter)*, limités aux erreurs transitoires, en nombre borné et déclaré (`maximumAttempts` pour une activité Temporal à effet, dont les tentatives sont illimitées par défaut), portés par une seule couche par dépendance et comptés dans les plafonds de l'EXIG-ORC-26, et par un disjoncteur. Les erreurs sont remontées et journalisées, jamais masquées. Le repli prévu (modèle de repli homologué, service dégradé ou file humaine nommée recevant le contexte nécessaire à la reprise, sous les droits du mandant) est testé avant la production.
Pourquoi : Microsoft prescrit délais d'expiration et réessais et recommande d'envisager des disjoncteurs; la temporisation exponentielle, la gigue, la borne des tentatives, la couche unique, la limitation aux erreurs transitoires et le disjoncteur obligatoire sont des choix du cadre (PRIN-12)[9].

EXIG-ORC-28 · DOIT
Coupe-circuit exercé chaque trimestre
Chaque agent **DOIT** pouvoir être arrêté de façon ciblée (retrait d'un outil ou d'une capacité) ou totale. La plateforme **DOIT** en outre disposer d'un coupe-circuit global. L'arrêt agit vers l'avant : il bloque toute nouvelle étape métier et conserve l'état pour analyse. Les compensations des sagas en cours s'exécutent par le canal de compensation (EXIG-ORC-28), que l'arrêt ne ferme pas sauf décision distincte; une saga passée au pivot termine ses étapes réessayables par ce canal ou passe en file humaine. La suspension de sécurité est immédiate; la suspension administrative bloque les nouvelles tâches après avis préalable. La compensation automatique vise les sagas en cours; la réparation des actions terminées est une décision du propriétaire métier (section 12.8). L'arrêt **DOIT** être exercé au moins une fois par trimestre,

dans l'exercice de l'EXIG-SEC-26 : l'arrêt ciblé en production, l'arrêt global dans un environnement représentatif. Le délai mesuré **DOIT** être consigné et comparé à la cible de l'EXIG-IAM-20.

Pourquoi : le RIA prévoit l'interruption sûre des systèmes à haut risque (art. 14, par. 4, al. e)) et le NIST AI RMF, d'usage volontaire, demande des mécanismes pour désactiver un système (MANAGE 2.4), le cadre l'appliquant à tous les agents[61, 99, 290, 412]; la fréquence trimestrielle et l'arrêt vers l'avant sont des choix du cadre. Chaque arrêt bloque tout appel de l'identité visée; les compensations s'exécutent donc par un canal de compensation dédié, sous une identité de compensation propre à l'orchestrateur de la saga (ou au coordinateur de saga en chorégraphie), distincte de celle de l'agent, inscrite au registre, limitée aux outils de compensation déclarés au catalogue pour une étape inscrite comme exécutée au journal de compensation de la même tâche (EXIG-ORC-16), auditée à chaque appel par la passerelle ou le courtier, dotée d'une réserve de budget hors de l'enveloppe de l'agent et non touchée par le coupe-circuit, la suspension, la révocation de l'agent, l'épuisement de son enveloppe, le plafond de sauts ou l'échéance de son mandat (sauf décision de suspension distincte, motivée et journalisée; si la passerelle est indisponible, la compensation entre dans une file persistée et l'EXIG-ORC-18 s'applique à l'échéance fixée à la fiche).

7.9 Anti-patrons proscrits

La taxonomie MAST *(Multi-Agent System Failure Taxonomy)* (Cemri et coll., UC Berkeley), tirée de plus de 1 600 traces annotées issues de sept cadriciels, recense 14 modes de défaillance des systèmes multiagents en trois catégories : conception du système, désalignement entre agents, et vérification et terminaison des tâches. Elle conclut que les défaillances relèvent surtout de la conception, et non des seules limites des modèles[292]. La revue d'architecture cible donc les défauts de conception ci-dessous; le classement des incidents selon MAST relève de la section 10.4.

Tableau 26 — Anti-patrons d'orchestration proscrits

Anti-patron	Pourquoi il est proscrit	Correctif exigé
Coordination multiagent là où un agent ou un flux suffit	Coût, latence et erreurs accrus sans gain mesuré[9]	EXIG-ORC-01 et EXIG-ORC-02
Agents sans spécialisation réelle, découpés par type de travail	Les transferts perdent des décisions implicites[275, 276]	Découpage par frontières de contexte (EXIG-ORC-10)
Confier au modèle un contrôle de flux que le code sait garantir, ou figer en code un flux dont les étapes ne sont pas connues d'avance	Patron inadapté à la nature du flux[9]	Configuration la plus simple justifiée (EXIG-ORC-01) et patron choisi selon l'arbre de décision de la section 7.3 (EXIG-ORC-03, PRIN-08)
État mutable partagé entre agents concurrents	Écritures contradictoires et résultats non reproductibles	Écrivain unique (EXIG-ORC-07); état d'exécution dans un magasin externe (EXIG-ORC-11)
Latence multisaut et contraintes de ressources ignorées	Délais cumulés et pointes de charge en mode concurrent	Délais par étape (EXIG-ORC-27), limite de concurrence (EXIG-ORC-07), plafonds (EXIG-ORC-26)
Contexte qui enfle sans contrôle, historique brut versé au contexte	Le rappel se dégrade quand l'information pertinente est noyée[148]	Compaction et références (EXIG-ORC-23, section 5.5)
État d'exécution en mémoire du processus	Perte de l'état au redémarrage[124]	Magasin durable (EXIG-ORC-11)
Maillage libre sans plafond de tours	Boucles, dérive, coûts imprévisibles	Patron déclaré et plafonds (EXIG-ORC-06, EXIG-ORC-26)
Chaîne d'écritures sans compensation ni clé d'idempotence	Effets partiels ou doublés impossibles à défaire	Saga et idempotence (section 7.5 et section 7.6)
Vérificateur qui déclare le succès sur quelques tests	Victoire prématurée[275]	Critères vérifiables, vérifications déterministes d'abord, évaluateur distinct (EXIG-ORC-05)

EXIG-ORC-29 · NE DOIT PAS
Aucun anti-patron sans dérogation
Une conception **NE DOIT PAS** présenter l'un des anti-patrons du tableau 26, que constate l'exigence citée à sa ligne (colonne « Correctif exigé ») : un même écart n'est donc relevé qu'une fois. La revue d'architecture doit les vérifier un à un et consigner le résultat à la fiche de l'agent, avec la décision d'homologation; tout écart exige une dérogation (section 11.6).
Pourquoi : une part importante des défaillances des systèmes multiagents tient à la conception du système et à la coordination entre agents[292].

7.10 Cadriciels et plateformes d'orchestration

Cette section situe les principaux produits par rapport aux exigences du chapitre. Seule l'exigence EXIG-ORC-30 y est normative; le tableau 27 ne l'est pas : les produits cités sont des exemples non limitatifs, décrits selon leur état au 27 octobre 2026, et le catalogue d'entreprise les réévalue chaque trimestre. On distingue trois familles : les cadriciels, qui portent la logique propre à l'entreprise; les moteurs d'exécution durable, qui en garantissent la reprise; et les logiciels-services à agents intégrés, à privilégier lorsque le travail réside déjà dans leur système d'enregistrement.

Tableau 27 — Cadriciels, moteurs et plateformes d'orchestration (exemples non limitatifs, état au 27 octobre 2026)

Produit	Nature et modèle d'orchestration	Atouts au regard du cadre	Points d'attention
LangGraph (LangChain)	Cadriciel d'exécution à base de graphe, avec persistance intégrée de l'état; version 1.0 du 22 octobre 2025, sans changement incompatible promis jusqu'à la 2.0 (persistance par fil : documentation « Persistence » de LangGraph)[123, 124]	Points de contrôle, `interrupt()` pour l'approbation, voyage dans le temps[82, 283]	Nœud réexécuté à la reprise; magasin persistant exigé en production[82, 124]; granularité de persistance à aligner sur l'EXIG-ORC-11 (un appel à effet par nœud)
Microsoft Agent Framework	Cadriciel sous licence MIT, successeur de Semantic Kernel et d'AutoGen; versions 1.0.0 pour Python et .NET le 2 avril 2026[85, 293]	Orchestrations séquentielle, concurrente, clavardage de groupe, transfert et magnétique; traces OpenTelemetry GenAI[294, 295]	Magasin de points de contrôle à protéger comme frontière de confiance[105]; point de contrôle par étape de calcul du flux : granularité à aligner sur l'EXIG-ORC-11
CrewAI	Cadriciel combinant des Flows (état, événements, embranchements) et des Crews (équipes d'agents à rôles)[296]	Démarche recommandée par l'éditeur : partir d'un Flow et y insérer une Crew pour une étape collaborative, ce qui rejoint le flux déterministe du cadre	Persistance et reprise à démontrer en preuve de concept (EXIG-ORC-30)
OpenAI Agents SDK	Trousse à peu de primitives : agents, transferts ou agents utilisés comme outils, garde-fous, sessions, traçage; outils MCP natifs[127]	Intégration Temporal en disponibilité générale depuis le 23 mars 2026 : chaque invocation d'agent devient une activité[122]	Associer un moteur durable dès que le flux compte plusieurs étapes (EXIG-ORC-11)
Google ADK	Cadriciel ouvert en Python, TypeScript, Go, Java et Kotlin, indépendant du modèle et du lieu de déploiement; A2A et MCP[126]	Agents de flux `SequentialAgent`, `ParallelAgent` et `LoopAgent`, sans décision du modèle sur l'orchestration[297]	ADK 2.0 supplante ces gabarits, en Python et en Go, par des flux à base de graphes ou dynamiques, sans annoncer leur retrait : prévoir la migration[297]
Strands Agents (AWS)	Trousse sous licence Apache 2.0, publiée le 16 mai 2025, pilotée par le modèle[128]	MCP, télémétrie OpenTelemetry, patrons multiagents (agents comme outils, essaim, graphe, flux, A2A)	Réserver aux tâches ouvertes à autonomie bornée; moteur durable dès que le flux compte plusieurs étapes (EXIG-ORC-11)

Produit	Nature et modèle d'orchestration	Atouts au regard du cadre	Points d'attention
Temporal	Moteur d'exécution durable; reprise à partir du dernier événement consigné dans l'historique d'événements (rejeu)[80, 81]	Compensations exécutées même après la défaillance d'un travailleur[286]	Isoler appels de modèles et d'outils dans des activités (EXIG-ORC-12); historique borné : Continue-As-New et passage par référence; `maximumAttempts` sur les activités à effet (EXIG-ORC-27)
AWS Step Functions	Service géré de machines à états	Flux Standard d'une durée maximale d'un an, à sémantique d'exécution exactement une fois, sauf réessais déclarés[104]	Flux Express (5 minutes; au moins une fois en mode asynchrone, au plus une fois en mode synchrone) : actions idempotentes obligatoires en mode asynchrone
Microsoft Copilot Studio	Plateforme à faible code; orchestration multiagent annoncée en préversion le 19 mai 2025 (Microsoft Build), dont plusieurs capacités passent en disponibilité générale à compter d'avril 2026[298, 299]	MCP en disponibilité générale depuis le 29 mai 2025, A2A depuis avril 2026[48, 300]	Identité Entra Agent ID créée pour chaque nouvel agent depuis juillet 2026 : l'inscrire au registre d'entreprise[48]
Salesforce Agentforce	Logiciel-service; orchestration SOMA (Single-Org, Multi-Agent, une organisation Salesforce) et MOMA (Multi-Org, Multi-Agent, plusieurs organisations)[49]	A2A entrant et sortant; client MCP et serveur MCP hébergé	Contraintes de produit : un seul saut de délégation en MOMA (deux agents en chaîne); sept sous-agents connectés pour Agent Script, limite que l'éditeur qualifie d'actuelle
ServiceNow	Logiciel-service; AI Agent Fabric (annoncé le 6 mai 2025), couche d'échange par MCP et A2A; AI Control Tower en disponibilité générale le même jour[51]	Action Fabric expose les actions de la plateforme à tout agent d'IA par un serveur MCP, pour des actions sécurisées et gouvernées (annonce du 5 mai 2026)[50]	Extensions de l'AI Control Tower (coupe-circuit, mesure des coûts) annoncées pour août 2026, disponibilité non vérifiée au 27 octobre 2026 : vérifier selon la version déployée[47]

`EXIG-ORC-30` · DOIT

Capacités démontrées avant l'inscription d'un produit

La pile d'orchestration proposée à l'inscription au catalogue (un cadriciel, un moteur ou une plateforme, seuls ou combinés) **DOIT** démontrer en preuve de concept, dans les conditions de l'entreprise, les capacités suivantes, chacune étant attribuée au composant qui la porte : la persistance durable des points de contrôle et la reprise après panne; la pause pour approbation humaine sans perte d'état; l'émission de traces OpenTelemetry selon les conventions GenAI; la prise en charge de MCP et d'A2A, nativement ou par adaptateur; l'export des définitions de flux et de l'état dans un format documenté; la propagation d'une clé d'idempotence stable (EXIG-ORC-21); l'exécution des compensations et de l'escalade de saga (tests de l'EXIG-ORC-20); les plafonds par exécution (EXIG-ORC-26); l'arrêt ciblé et global (EXIG-ORC-28).

Pourquoi : l'entreprise garde la propriété de sa logique d'orchestration (PRIN-09), et une capacité se vérifie au lieu de se présumer sur la foi d'une fiche commerciale (chapitre 13).

8 Autonomie et supervision humaine

L'autonomie d'un agent n'est pas une propriété du modèle : c'est une décision d'architecture, prise par une personne imputable, inscrite au registre et appliquée par la passerelle d'agents. Ce chapitre fixe une échelle unique de niveaux (N0 à N4), quatre paliers de risque pour les outils (P0 à P3) et la règle qui les combine. Il précise ensuite comment rendre l'approbation humaine vérifiable, comment interagir avec les agents

qui travaillent en arrière-plan, comment éviter l'approbation machinale et comment traiter les décisions automatisées visées par la Loi 25.

8.1 Une échelle unique N0 à N4

Le cadre adopte une seule échelle d'autonomie (figure 14 et tableau 28), que chaque agent déclare et que la plateforme fait respecter.

Deux arguments la fondent. D'abord, l'autonomie est un choix de conception : Feng, McDonald et Zhang (2025) la distinguent de la capacité du modèle et de son environnement, et la définissent par le rôle laissé à l'utilisateur[83]. Ensuite, une gouvernance uniforme échoue : selon Gartner (26 mai 2026), la cause profonde des échecs est une gouvernance binaire, qui verrouille tout ou permet tout, et la confusion entre la capacité d'agir d'un agent et la portée des accès qui lui sont accordés; la firme prévoit, dans un communiqué sans méthode publiée, que, d'ici 2027, 40 % des entreprises rétrograderont ou désactiveront des agents autonomes après des incidents de production révélant des lacunes de gouvernance[95].

Chaque niveau se définit donc par deux éléments : le rôle de la personne et l'étendue de ce que l'agent peut faire sans approbation. Le second s'observe appel par appel. N4 se distingue en outre de N3 par l'origine de la tâche, déclenchée sans demande d'une personne (événement, horaire), que la passerelle lit dans un attribut posé par l'orchestrateur ou par le courtier. Le niveau ne dépend ni du nombre d'agents ni de la puissance du modèle : un système multiagent peut réunir des agents de niveaux différents, et, selon le cadre de gouvernance de l'IA agentique de l'Infocomm Media Development Authority (IMDA) de Singapour, l'espace d'action d'un agent, c'est-à-dire ses outils, se distingue de son autonomie[76, 83].

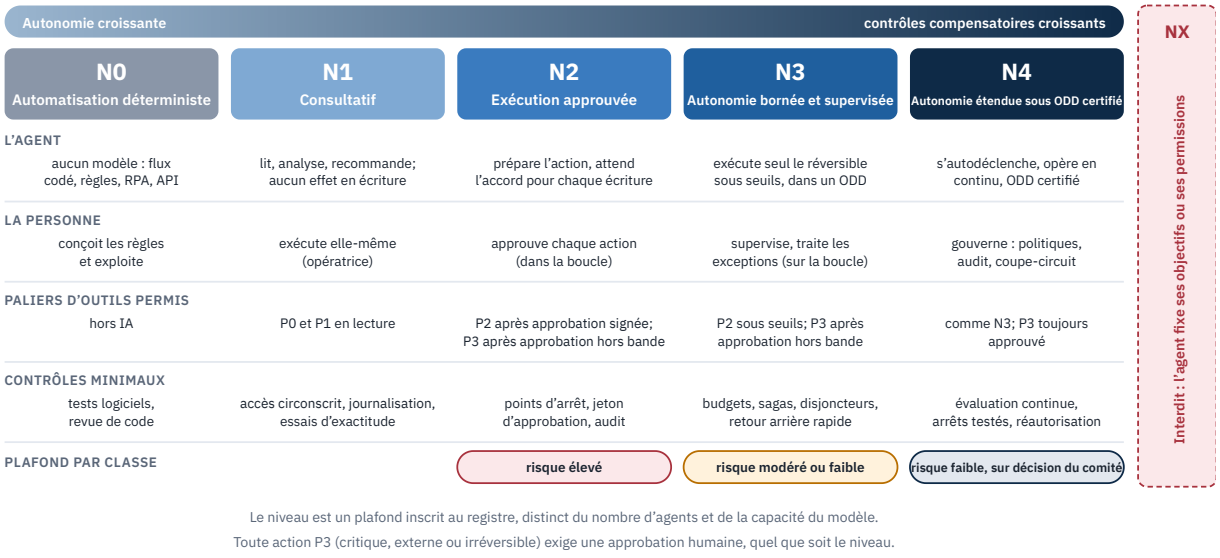


Figure 14 — Échelle d'autonomie N0 à N4. Chaque marche indique ce que fait l'agent, ce que fait la personne, les paliers d'outils permis et les contrôles minimaux; plus l'autonomie croît, plus les contrôles compensatoires s'accumulent. Le niveau NX, hors de l'échelle, est interdit. Le plafond N4 est réservé à la classe de risque faible, sur décision du comité. Le tableau 28 détaille les contrôles minimaux de chaque niveau. Source : cadre CRE-IA-2026-01, d'après Gartner (2026), AWS, Feng et coll. (2025) et l'IMDA.

Tableau 28 — Niveaux d'autonomie : rôles, paliers permis et contrôles minimaux

Niveau	Ce que fait l'agent	Rôle humain et boucle	Paliers permis	Contrôles minimaux (cumulatifs)	Exemple
N0 Automatisation déterministe	Aucun choix d'action laissé à un modèle : le code	Conçoit les règles et exploite le flux.	Sans objet	Tests logiciels, revue de code, gestion des changements.	Rapprochement bancaire quotidien codé en règles.

Niveau	Ce que fait l'agent	Rôle humain et boucle	Paliers permis	Contrôles minimaux (cumulatifs)	Exemple
	fixe chaque pas (flux codé, règles, RPA, API); un modèle peut transformer une donnée sans choisir l'action. N0 qualifie un flux, non un agent.				
N1 Consultatif	Lit, analyse, recommande, rédige; aucun effet en écriture.	La personne exécute elle-même toute action (rôle d'opérateur); l'agent ne fait que recommander.	P0, P1	Accès aux données circonscrit, authentification, journalisation de l'usage, essais de sécurité de base, essais d'exactitude et d'hallucination, formation des utilisateurs à une confiance appropriée.	Résumé d'un dossier et texte de réponse affiché à l'écran, que le conseiller copie, relit et envoie lui-même.
N2 Exécution approuvée	Planifie et prépare; chaque action en écriture attend une approbation explicite.	Approuve chaque écriture avant son exécution : humain dans la boucle (HITL).	P0, P1; P2 après approbation signée (service d'approbation, même appareil admis); P3 après approbation signée hors bande (EXIG-AUT-09)	Essais de sécurité poussés, état de la tâche conservé à chaque point d'approbation, jeton d'approbation, journal d'audit, procédure d'intervention propre aux agents.	Modifications de fiches fournisseurs préparées par l'agent, chacune approuvée avant l'écriture.
N3 Autonomie bornée et supervisée	Exécute seul les actions P2 réversibles ou compensables sous seuils déclarés, dans un domaine de conception opérationnel (ODD) documenté; escalade les exceptions.	Supervise par exception, traite les escalades, peut interrompre; revue a posteriori par échantillonnage : humain sur la boucle (HOTL).	P0, P1; P2 sous seuils; P3 après approbation hors bande	Surveillance continue, seuils et budgets appliqués par la passerelle, compensation déclarée, disjoncteurs, retour arrière rapide, propriété claire du comportement de l'agent.	Agent de soutien TI qui classe, fusionne et ferme les billets en double sous un plafond horaire, et escalade le reste.
N4 Autonomie étendue sous ODD certifié	Traite des tâches déclenchées sans demande d'une personne (événement, horaire) et opère en continu, dans un ODD certifié. La passerelle lit l'origine de la tâche et refuse à un agent qui n'est pas N4 toute écriture sans approbation au titre d'une	Hors de la boucle d'exécution, mais sur la boucle de gouvernance : politiques, audit, coupe-circuit.	Comme N3; P3 toujours approuvé	ODD certifié, évaluation continue, arrêts ciblé et général testés, réautorisation périodique, décision du comité.	Agent de qualité des données qui, sur alerte, met en quarantaine les lots suspects jour et nuit.

Niveau	Ce que fait l'agent	Rôle humain et boucle	Paliers permis	Contrôles minimaux (cumulatifs)	Exemple
	tâche ainsi déclenchée.				
NX Autonomie non bornée	Fixe ses objectifs, modifie ses permissions, écrit et exécute du code hors contraintes.	Aucun contrôle humain effectif.	—	**Interdit**	—

Les contrôles des niveaux N1 à N3 s'inspirent de ceux que Gartner associe à ses niveaux Observer, Conseiller, Agir avec approbation et Agir de façon autonome (Gartner précise que ceux du niveau Conseiller incluent tous ceux du niveau Observer; le cumul aux niveaux suivants est le choix du cadre); Gartner prévient d'ailleurs que les approbations peuvent s'affaiblir sous la pression du temps ou la fatigue d'approbation[95]. Les contrôles de N0 et de N4 sont fixés par le cadre. L'abréviation ODD (domaine de conception opérationnel, *operational design domain*) est un concept de la conduite automatisée des véhicules routiers[301]; le cadre l'emploie pour désigner le périmètre documenté (systèmes, données, outils, seuils, plages horaires) hors duquel l'agent s'arrête ou escalade.

L'échelle n'est pas un parcours de maturité dont N4 serait le but. Morris et coll. rappellent que le niveau d'autonomie retenu au déploiement n'a pas à être le maximum que permettent les capacités du modèle[302], et l'OWASP formule le principe de moindre agence (*Least-Agency*) : un comportement agentique déployé sans nécessité élargit la surface d'attaque sans ajouter de valeur[28]. Le bon niveau est le plus bas qui atteint l'objectif.

EXIG-AUT-01 · DOIT
Niveau d'autonomie déclaré et appliqué
Chaque agent **DOIT** avoir un niveau d'autonomie N1 à N4 (tableau 28; N0 qualifie un flux déterministe, non un agent) inscrit au registre (section 11.4) comme plafond, avec la date d'homologation et le nom de la personne qui l'a approuvé. Le niveau déclaré **DOIT** être le plus bas qui permet d'atteindre l'objectif métier, avec sa justification consignée dans la fiche d'agent. La passerelle d'agents **DOIT** refuser tout appel d'outil qui excède ce plafond, ainsi que, pour un agent qui n'est pas N4, toute écriture sans approbation au titre d'une tâche déclenchée sans demande d'une personne, d'après l'attribut d'origine posé par l'orchestrateur ou par le courtier; un agent ambiant N1 ou N2 peut donc traiter une telle tâche (section 3.3).
Pourquoi : le principe de moindre agence de l'OWASP proscrit l'autonomie inutile[28]; Feng et coll. proposent un « certificat d'autonomie » qui fixe le niveau maximal d'un agent et accompagne ses métadonnées[83].

EXIG-AUT-02 · DOIT
Plafond selon la classe de risque
Le niveau déclaré **DOIT** être évalué selon les critères du tableau 30 et respecter le plafond que fixe EXIG-CON-02 pour la classe de risque de l'agent (section 12.1, tableau 46) et celui de la phase de mise en œuvre en cours (tableau 58).
Pourquoi : le RIA exige des mesures de contrôle humain proportionnées aux risques, au niveau d'autonomie et au contexte d'utilisation (art. 14, par. 3)[61, 290, 412]; les plafonds eux-mêmes sont un choix du cadre.

EXIG-AUT-03 · NE DOIT PAS
Autonomie non bornée interdite (NX)
Un agent **NE DOIT PAS** fixer d'autres objectifs que ceux qui lui sont assignés au registre, modifier ses propres permissions ou son niveau d'autonomie, ni écrire et exécuter du code hors des contraintes déclarées. Toute modification des objectifs, des outils ou du niveau d'un agent doit passer par le registre et être approuvée par une personne habilitée, la décision étant consignée au registre. Aucune dérogation n'est possible.
Pourquoi : choix normatif du cadre, et non exigence réglementaire. Mitchell et coll. soutiennent que le risque pour les personnes croît avec l'autonomie et que les agents entièrement autonomes ne devraient pas être développés[303]; l'OWASP recommande une double vérification avant qu'un agent ne modifie ses objectifs[87].

EXIG-AUT-04 · DOIT
Domaine de conception opérationnel (ODD), repli et arrêts pour N3 et N4
Un agent de niveau N3 ou N4 **DOIT** avoir un ODD documenté (systèmes, données, outils, seuils, volumes, plages horaires) et un comportement de repli déclaré pour toute sortie de ce domaine : arrêt en état sûr, compensation ou escalade vers une file humaine nommée. Les plafonds par exécution de l'EXIG-ORC-26 et les arrêts de l'EXIG-ORC-28 (arrêt ciblé, qui révoque une catégorie d'actions, et arrêt général) s'appliquent à lui comme à tout agent (section 7.8 et section 9.4).
Pourquoi : SAE J3016 distingue ses niveaux 3 et 4 par la partie qui assure le repli à la sortie du domaine; le repli assuré par le système, qu'exige la présente exigence, est celui de son niveau 4[304]; le RIA prévoit l'arrêt du système dans un état sûr (art. 14, par. 4, al. e))[61, 290, 412] et OpenAI recommande une interruption ciblée ou générale[291].

Pour homologuer un niveau, le cadre recommande l'« évaluation assistée » de Feng et coll. : un utilisateur en attente aide l'agent sur demande et consigne chaque intervention; on augmente graduellement son implication, d'abord par des approbations, puis par des échanges plus fréquents. Le niveau se déduit de l'implication minimale qui permet d'atteindre le seuil de réussite fixé[83].

EXIG-AUT-05 · DOIT
Homologation et réévaluation du niveau
Le niveau d'autonomie **DOIT** être homologué avant la mise en production, puis réévalué avant la mise en service de tout changement visé par l'EXIG-GOV-12, qui fait foi pour la liste des déclencheurs (une correction purement typographique de l'invite système, attestée sans effet sur le jeu d'évaluation, n'en est pas un). Tant que la réévaluation n'est pas faite, la version antérieure reste en service; à défaut, l'agent **DOIT** être suspendu, ou remplacé par le flux déterministe de repli s'il existe. Un changement ne permet jamais de fonctionner au-dessus du plafond de classe. La version de modèle servie est épinglée et vérifiée par la passerelle de modèles.
Pourquoi : Feng et coll. prévoient le renouvellement du certificat d'autonomie à chaque changement de l'agent ou de son environnement[83]; pour les institutions financières fédérales, la ligne directrice E-23 du BSIF (en vigueur le 1er mai 2027) attend des institutions qu'elles définissent des critères de modification importante d'un modèle, y compris d'IA[8].

Correspondance avec les autres échelles

Le tableau 29 situe N0 à N4 par rapport aux niveaux des versions de travail antérieures du cadre (section 1.7) et aux échelles de la littérature. Les correspondances avec Gartner et AWS reposent sur les sources citées sous le tableau; celles avec Feng et coll., Morris et coll. et SAE J3016 sont indicatives, car ces échelles décrivent le rôle de l'utilisateur ou un autre objet que le plafond d'actions sans approbation.

Tableau 29 — Correspondance entre l'échelle du cadre et les autres échelles d'autonomie

Cadre	Versions antérieures (section 1.7)	Gartner (2026)	AWS (portées)	Feng et coll. (rôle de l'utilisateur)	Morris et coll. (indicatif)	SAE J3016 (analogie)
N0	doc. L0 · prod. L0	—	—	—	0 Sans IA	—
N1	doc. L1 · v0.x N0 · prod. L1	1 Observer; 2 Conseiller	Portée 1	L1 Opérateur	1 IA outil; 2 IA consultante	—
N2	doc. L2 · v0.x N1 · prod. L2	3 Agir avec approbation	Portée 2	L2 Collaborateur	3 IA collaboratrice	—
N3	doc. L3 · v0.x N2 et N3 · prod. L3	4 Agir de façon autonome	Portée 3	L3 Consultant; L4 Approbateur	4 IA experte	Niveaux 3 et 4 : une personne supervise, comme au niveau 3, mais le repli est assuré par le système, comme au niveau 4 (EXIG-AUT-04)
N4	doc. L4 · v0.x N4 · prod. L4, sans la notion multiagent	—	Portée 4, sous restrictions	L5 Observateur, sous restrictions	5 IA agent (le cadre y distingue N4, bornée, et NX, non bornée; cette distinction ne vient pas de Morris et coll.)	Niveau 4 : repli assuré dans l'ODD
NX	doc. L5	—	—	—	5 IA agent (non bornée; distinction propre au cadre)	Niveau 5 : domaine illimité

Abréviations : « doc. » désigne la recherche documentaire (L0 à L5), « v0.x » les deux versions de travail successives, v0.1 et v0.2 (N0 à N4), et « prod. » la version structurée en exigences, dite de production (L0 à L4), soit les quatre ébauches de la section 1.7. Ces ébauches ne sont pas publiées avec le cadre : la colonne ne sert qu'à situer l'historique, les niveaux de même numéro ne se correspondent pas d'une ébauche à l'autre et seule l'échelle du présent chapitre fait foi. Les sources des colonnes suivantes sont Gartner[95], la matrice de portée d'AWS, qui associe la portée 2 à une approbation avant chaque action et la portée 3 à une supervision avec interrupteurs d'arrêt[75], Feng et coll.[83] et Morris et coll.[302]. Les correspondances avec Gartner et AWS suivent la vérification des sources; celles avec Feng et coll., Morris et coll. et SAE J3016 sont indicatives, car ces échelles décrivent le rôle de l'utilisateur ou un autre objet que le plafond d'actions sans approbation. Les libellés L1 à L5 sont ceux de Feng et coll.; leur « approbateur » (L4) n'intervient que lorsque l'agent le sollicite, ce qui le rapproche de N3 plutôt que de N2.

SAE J3016 est une pratique recommandée (*Recommended Practice*) de SAE International, et non une norme de sécurité. Le cadre ne lui emprunte que deux notions, par analogie : le domaine de conception opérationnel et la question du repli, qui sépare son niveau 3, où l'humain doit reprendre la main, de son niveau 4, où le système assure lui-même le repli à la sortie de son domaine; seul son niveau 5 suppose un domaine illimité[301, 304]. Enfin, l'« agent entièrement autonome » de Mitchell et coll., qui écrit et exécute son propre code, correspond à NX[303].

8.2 Classer un agent : critères

La classe de risque de l'agent (section 12.1) fixe son plafond; quatre critères déterminent ensuite le niveau réellement autorisé sous ce plafond.

Le cadre retient ces quatre critères comme méthode interne. Ils s'appuient sur des sources reconnues sans en être la transcription. L'IMDA désigne la portée des actions de l'agent, leur réversibilité et son niveau

d'autonomie comme déterminants du risque, et recommande de borner le rayon d'action dès la conception[76]. OpenAI recommande de noter chaque outil selon qu'il lit ou écrit, sa réversibilité, les permissions requises et son impact financier[66]. Le NIST AI RMF demande que les processus de supervision humaine soient définis, évalués et documentés (MAP 3.5)[99].

Tableau 30 — Quatre critères pour fixer le niveau d'autonomie sous le plafond de la classe

Critère	Question posée	Ce qu'on examine	Effet sur le niveau
Rayon d'impact	Combien d'enregistrements, de systèmes, de personnes ou de dollars l'agent peut-il toucher en une exécution ininterrompue?	Outils d'écriture autorisés, portées des jetons, plafonds de volume et de montant.	Un rayon élevé abaisse le niveau ou impose des seuils plus bas.
Réversibilité	L'effet peut-il être annulé, compensé, ou est-il définitif?	Compensation déclarée au catalogue, délai de compensation, effets externes.	Une action irréversible relève du palier P3 : approbation préalable, quel que soit le niveau.
Délai de détection et de récupération	Combien de temps s'écoule entre une erreur, sa détection et sa correction?	Alertes automatiques, revue par échantillonnage, délai de compensation.	Une détection lente plafonne à N2 (contrôle avant l'action plutôt qu'après), quels que soient les autres critères; l'EXIG-AUT-07 en est le cas extrême.
Observabilité reconstructive	Peut-on reconstituer ce que l'agent a fait, avec quelles données et sous quelle autorisation?	Traces d'appels d'outils, journal d'audit signé (section 10.3), versions épinglées.	Sans traces d'appels d'outils, ni N3 ni N4.

Le quatrième critère tient au fait que le raisonnement affiché par un modèle n'explique pas forcément ses actions : l'IMDA rappelle que la chaîne de pensée n'est pas analogue au raisonnement humain[76]. Seules les traces des appels d'outils prouvent ce qui a été fait.

Les seuils qui traduisent ces critères en plafonds (nombre d'enregistrements, montants, délais) sont des paramètres d'étalonnage du cadre : le comité d'architecture et des risques agentiques les approuve, les publie avec le catalogue et les révise après chaque incident. Aucune source reconnue ne propose de valeurs universelles. Le niveau autorisé est le plus bas de quatre valeurs : le plafond de la classe, le plafond de la phase de mise en œuvre en cours (tableau 58), le niveau que permettent les quatre critères et le niveau suffisant pour l'objectif.

EXIG-AUT-06 · DOIT

Classement fondé sur les permissions effectives

L'évaluation des quatre critères **DOIT** se fonder sur les permissions effectives de l'agent (outils autorisés, portées des jetons, plafonds de volume et de montant), y compris les actions qui ne lui sont accessibles qu'après approbation, et non sur l'intention déclarée. Elle **DOIT** être consignée dans la fiche d'agent (annexe B) et revue par l'architecture d'entreprise et par la sécurité avant l'homologation du niveau.

Pourquoi : Gartner situe la cause de nombreux échecs dans la confusion entre la capacité d'agir et la portée des accès accordés[95, 305]; l'IMDA recommande de borner le rayon d'action par les accès aux outils et aux systèmes[76].

EXIG-AUT-07 · NE DOIT PAS

Règle d'or : pas d'exécution autonome du risque cumulé

Un agent dont le rayon d'impact, la réversibilité et le délai de détection atteignent les seuils d'étalonnage approuvés par le comité (rayon élevé, réversibilité faible, détection lente) **NE DOIT PAS** être autorisé au-delà de N2, quels que soient ses résultats aux bancs d'essai. En l'absence de seuil approuvé pour un critère, ce critère est réputé atteint.

> Pourquoi : règle propre au cadre. L'IMDA lie le risque à la portée et à la réversibilité des actions[76], et Feng et coll. rappellent que les bancs d'essai de capacité ne révèlent pas le niveau d'autonomie approprié[83].

EXEMPLE

Un agent de facturation peut modifier 10 000 comptes par exécution (rayon élevé). Ses écritures changent des montants facturés, difficiles à corriger une fois les factures transmises (réversibilité faible), et une erreur ne serait vue qu'à la fermeture mensuelle (détection lente). Malgré d'excellents résultats aux essais, il reste à N2. Pour viser N3, l'équipe agit sur les critères, pas sur les essais : plafond par exécution, détection automatisée des écarts, retenue des factures avant transmission.

8.3 Paliers de risque des outils P0 à P3

Le palier mesure le risque d'un outil, indépendamment de l'agent qui l'appelle; il forme le second axe de la supervision.

Un même agent peut lire sans risque et écrire avec risque. Parasuraman, Sheridan et Wickens ont proposé d'automatiser séparément chaque fonction (acquérir l'information, l'analyser, décider, agir), chacune à un niveau propre, un même système pouvant combiner des niveaux différents[306]. L'autonomie se règle donc aussi par action, et pas seulement par agent.

Tableau 31 — Paliers de risque des outils

Palier	Nature	Exemples	Contrôles obligatoires
P0	Lecture publique	Recherche documentaire publique, catalogue de produits, conversion d'unités.	Identité de charge de travail, limitation de débit, journalisation de l'usage. Un outil dont un argument quitte l'entreprise (requête en texte libre vers un moteur de recherche public, par exemple) porte l'attribut « sortie de données » : il compte comme outil d'envoi (EXIG-SEC-06) et comme propriété [C] (EXIG-SEC-04), et ses arguments passent un contrôle DLP.
P1	Lecture interne ou sensible	Dossier client, fiche de paie, recherche documentaire interne.	Jeton délégué (section 9.3), contrôle d'accès au document ou à la ligne, masquage des RP en sortie, journal d'audit.
P2	Écriture réversible, ou compensable vers un état métier équivalent, à impact borné; jamais un effet irréversible ou externe	Billet de service, brouillon de courriel, réservation interne, mise à jour de statut.	Jeton délégué, clé d'idempotence (section 7.6), compensation déclarée (section 7.5), journal d'audit, seuil métier au catalogue (p. ex. 5 000 $), mesuré sur une grandeur que l'agent ne choisit pas, avec sa portée et sa fenêtre (EXIG-AUT-08); approbation au-delà du seuil.
P3	Action critique, externe ou irréversible	Virement, suppression définitive de données, communication externe officielle, changement d'infrastructure de production.	Jeton délégué, clé d'idempotence (section 7.6), journal d'audit; approbation humaine hors bande à chaque appel, jeton d'approbation lié à l'action, second approbateur pour la classe élevée; jamais exécuté seul par un agent.

La frontière entre paliers suit l'effet, pas le serveur. Créer un brouillon de courriel est une action P2, car il reste dans l'entreprise et peut être supprimé; l'envoyer à un client est une action P3. Un même serveur MCP expose souvent les deux : chaque outil reçoit son propre palier.

Le palier ne peut pas venir du serveur lui-même. La spécification MCP 2026-07-28 exige que les clients considèrent les annotations d'outils comme non fiables, à moins qu'elles ne proviennent de serveurs de confiance; la référence du schéma précise, en des termes non normatifs (« should never »), que les clients

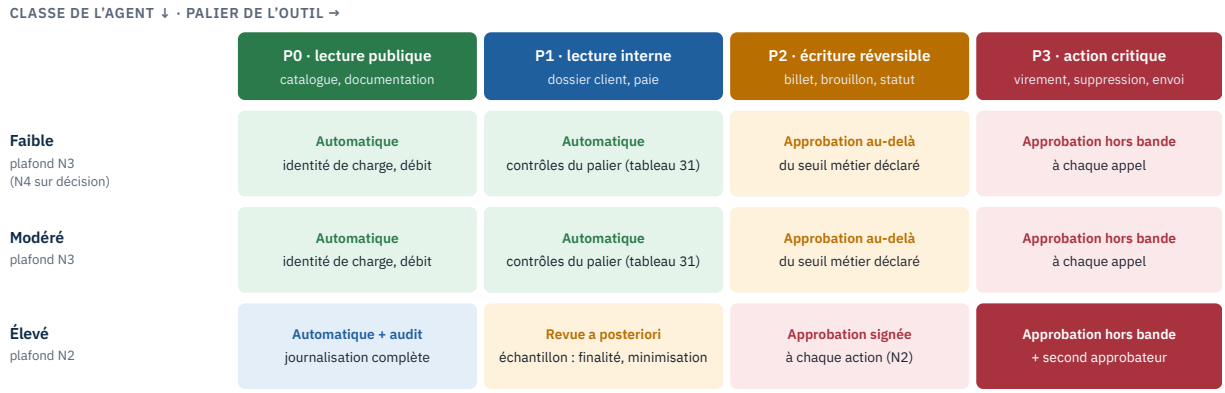
ne fondent jamais une décision d'usage sur les annotations d'un serveur non fiable[197, 201]. Les métadonnées de gouvernance vivent donc au catalogue d'entreprise (section 6.8; pour les annotations MCP, section 6.5).

EXIG-AUT-08 · DOIT
Palier attribué au catalogue après revue
Chaque outil **DOIT** recevoir un palier P0 à P3 (tableau 31) au catalogue d'entreprise (section 6.8) après revue par son propriétaire et par la sécurité, avec son seuil métier et son outil de compensation s'il y a lieu. Le palier provient du catalogue, jamais des annotations ou des métadonnées déclarées par le serveur. Un outil qui combine plusieurs effets prend le palier le plus élevé; un outil d'écriture sans compensation déclarée, ou dont la clé d'idempotence n'est vérifiée ni nativement ni par adaptateur (EXIG-ORC-22), est classé P3. Un effet irréversible ou externe est P3, même si une compensation est déclarée; P2 suppose une écriture réversible, ou compensable vers un état métier équivalent avec un impact borné. Un outil de compensation reçoit son propre palier (EXIG-ORC-17). Dans les schémas des outils P2 et P3, les montants et les identifiants sont des chaînes ou des entiers en unités mineures. Un outil dont un argument peut atteindre une destination hors du périmètre de confiance porte au catalogue l'attribut « sortie de données », indépendant du palier (EXIG-SEC-06).
Pourquoi : la spécification MCP tient les annotations pour des indices non fiables[197]; OpenAI recommande d'attribuer à chaque outil une cote de risque[66].

EXIG-AUT-09 · NE DOIT PAS
Aucun outil P3 exécuté seul
Un agent **NE DOIT PAS** exécuter un outil P3 sans une approbation humaine préalable, propre à cet appel et obtenue hors bande, c'est-à-dire sur un appareil et dans une session d'authentification distincts de ceux de l'agent, avec une authentification forte résistante à l'hameçonnage, quel que soit son niveau d'autonomie. La compensation déclarée d'une étape approuvée est couverte par l'approbation de l'étape (EXIG-AUT-12).
Pourquoi : l'IMDA recommande une approbation humaine avant les actions à fort enjeu ou irréversibles, comme la suppression définitive, l'envoi de communications ou les paiements; OpenAI présente l'autorisation préalable des actions irréversibles comme le moyen usuel de limiter les défaillances graves; l'OWASP recommande l'approbation explicite des actions à fort impact (ASI02)[28, 76, 291]. Le caractère hors bande est un choix du cadre.

8.4 Combiner classe de l'agent et palier de l'outil

Le contrôle exigé pour un appel dépend de la classe de l'agent, de son niveau d'autonomie et du palier de l'outil; les contrôles se cumulent, et l'approbation la plus stricte l'emporte (EXIG-AUT-10).



Les contrôles se cumulent; l'approbation la plus stricte l'emporte (EXIG-AUT-10). Le palier d'un outil est inscrit au catalogue; la passerelle ne se fie pas aux annotations déclarées par le serveur.

Figure 15 — Contrôle exigé selon la classe de l'agent et le palier de l'outil. On lit la ligne de la classe de l'agent, puis la colonne du palier de l'outil; la cellule donne le contrôle minimal, en plus des contrôles obligatoires du palier (tableau 31); dans les cellules P3, « approbation signée » s'entend d'une approbation hors bande (EXIG-AUT-09), et la matrice qui fait foi est celle de l'EXIG-AUT-10. Le niveau d'autonomie de l'agent et les déclencheurs d'approbation peuvent rendre le contrôle plus strict, jamais plus souple; il se calcule selon l'EXIG-AUT-10. Source : cadre CRE-IA-2026-01.

Deux exemples. Un agent de classe modérée, déclaré N3, reclasse un billet de service : outil P2 sous le seuil, il agit seul et l'appel est journalisé. Le même agent veut modifier l'échéance de 40 factures alors que le seuil déclaré de l'outil est de 25 par tâche : la passerelle suspend l'appel et demande une approbation. Si l'agent était déclaré N2, chaque écriture exigerait une approbation, même sous le seuil : le niveau prime alors sur la cellule.

D'autres déclencheurs s'ajoutent à la grille. L'IMDA en énumère quatre catégories : actions à fort enjeu, actions irréversibles, comportements atypiques (accès hors périmètre, trajectoire anormale) et seuils fixés par l'utilisateur[76]. La « règle de deux » de Meta (31 octobre 2025) en fournit une autre : dans une session, un agent ne devrait pas cumuler l'exposition à des entrées non fiables, l'accès à des systèmes sensibles ou à des données privées et la capacité de changer d'état ou de communiquer vers l'extérieur; si les trois sont nécessaires, il n'agit pas sans supervision[307]. Un agent N3 qui a lu un courriel externe, consulté un dossier P1 et s'apprête à appeler un outil P2 tombe donc sous approbation (section 9.6).

EXIG-AUT-10 · DOIT

Contrôle calculé à chaque appel

Pour chaque appel d'outil, la passerelle d'agents, que traversent tout appel MCP et toute action P2 ou P3 (EXIG-ARC-01), **DOIT** déterminer le contrôle exigé. Ce contrôle est l'union des contrôles exigés par la cellule classe × palier de la matrice qui suit (illustrée par la figure 15), par le niveau d'autonomie et la classe les plus contraignants de la chaîne de délégation (EXIG-ORC-23), par les déclencheurs d'approbation (comportement atypique, seuil de l'EXIG-AUT-08, cumul de la règle de deux au sens de l'EXIG-SEC-04 : contenu non fiable, données sensibles et changement d'état ou communication externe) et par les points non dérogeables (EXIG-GOV-17). Les contrôles techniques (jeton délégué, masquage, filtrage par ligne, audit) se cumulent; aucun n'en remplace un autre. Entre exigences d'approbation, l'ordre est : refus, approbation hors bande à deux approbateurs, approbation hors bande, approbation, exécution automatique avec revue a posteriori, exécution automatique; le plus strict est le premier de cette liste. Matrice classe × palier, qui fait foi : pour les classes faible et modérée, exécution automatique aux paliers P0 et P1, exécution automatique sous le seuil métier déclaré et approbation au-delà au palier P2, approbation hors bande au palier P3; pour la classe élevée, exécution automatique avec audit au palier P0, exécution automatique avec revue a posteriori au palier P1, approbation au palier P2 et

approbation hors bande à deux approbateurs au palier P3. La passerelle consigne la règle appliquée dans la trace et dans le journal d'audit (section 10.3).

Pourquoi : cumuler les contrôles et retenir l'approbation la plus forte empêche qu'un agent peu autonome obtienne des droits étendus par un outil mal classé, ou qu'un outil bien classé soit utilisé au-delà du niveau de l'agent. Règle propre au cadre; l'IMDA lie le risque à la portée et à la réversibilité des actions[76].

EXIG-AUT-11 · DOIT

Échec en mode fermé

Le service d'approbation, le catalogue, le service de politiques, le registre des jti et le service d'audit sont des dépendances de la passerelle; une politique ou un instantané du catalogue distribués et non échus valent service disponible (EXIG-IAM-18). Si l'une de ces dépendances est indisponible, ou si aucune politique ne couvre l'action demandée, la passerelle **DOIT** refuser tout appel dont le contrôle calculé (EXIG-AUT-10) exige une approbation, donc au moins tout appel P3 et tout appel P2 au-delà du seuil, ainsi que tout appel P2 ou P3 si le service d'audit est indisponible. Une politique ou un instantané échus ne laissent passer que les appels P0. Ces refus sont sans préjudice du refus général de tout appel dépourvu de décision de politique valide (EXIG-IAM-18). Dans tous ces cas, l'orchestrateur **DOIT** suspendre la tâche dans un état reprenable; une compensation refusée pour l'un de ces motifs entre dans la file persistée de l'EXIG-ORC-28.

Pourquoi : l'IMDA recommande de refuser l'action par défaut lorsque l'infrastructure d'approbation fait défaut, par exemple si les superviseurs sont injoignables ou si aucune politique n'existe pour l'action tentée[76]; un seuil ne borne l'agent que si la grandeur mesurée échappe à son contrôle, avec une portée et une fenêtre explicites (EXIG-AUT-08).

8.5 Approbation humaine vérifiable

Une approbation n'a de valeur que si elle porte sur l'action exacte qui sera exécutée et si la passerelle peut le vérifier sans faire confiance à l'agent.

Un « oui, je confirme » écrit dans la conversation de l'agent ne prouve rien : une injection d'instructions peut l'imiter, et l'agent peut modifier l'action après coup. Le cadre fait donc de l'approbation un objet cryptographique, émis hors de portée de l'agent et lié à l'action par une empreinte (figure 16).

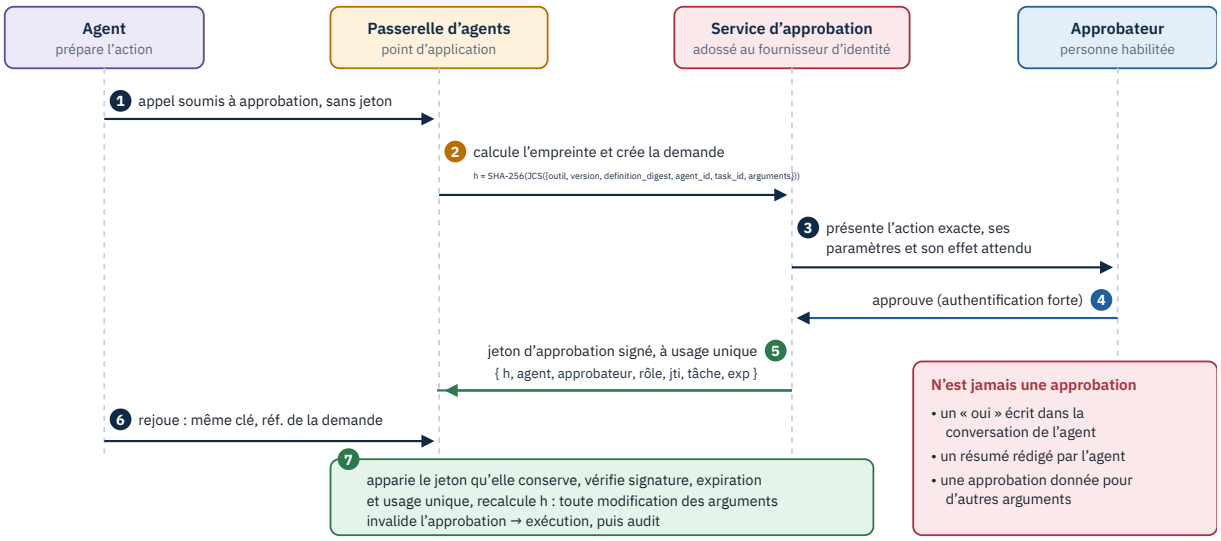


Figure 16 — Approbation humaine signée, liée à l'action exacte. La passerelle intercepte l'appel soumis à approbation selon l'EXIG-AUT-10 (P3, P2 au-delà du seuil, niveau N2 ou déclencheur), calcule l'empreinte de l'action et la fait approuver par une personne habilitée; le jeton signé ne vaut que pour cette empreinte, pour une seule opération et pendant 15 minutes au plus. Le jeton est remis à la passerelle, qui le conserve (étape 5); l'agent rejoue l'appel avec la même clé d'idempotence et la référence de la demande, donnée non secrète (étape 6); une double approbation se fait par deux jetons sur le même h (EXIG-AUT-12). Source : cadre CRE-IA-2026-01.

L'empreinte se calcule ainsi : h = SHA-256(JCS({outil, version, definition_digest, agent_id, task_id, arguments})), c'est-à-dire l'empreinte de la canonisation d'un objet qui réunit l'identifiant pleinement qualifié de l'outil (serveur et nom), sa version épinglée, l'empreinte de sa définition, les identifiants de l'agent et de la tâche, et les arguments; la canonisation d'un objet évite l'ambiguïté d'une concaténation. La canonisation suit la RFC 8785 (JSON Canonicalization Scheme), une RFC informative de la filière indépendante, non endossée par l'IETF, mais stable[308]; A2A 1.0 l'emploie déjà pour signer les cartes d'agent[68]. Sans canonisation, deux sérialisations du même objet JSON donneraient deux empreintes. Si l'agent, ou une injection, change un seul argument après l'approbation, l'empreinte recalculée par la passerelle ne correspond plus et l'appel est refusé. Cette propriété suppose que la passerelle rejette tout argument non conforme à I-JSON (RFC 7493 : clés dupliquées, nombres hors de la plage exacte d'un double, chaînes invalides) et transmette au serveur exactement la forme canonique hachée; sinon, deux analyseurs JSON peuvent lire deux actions différentes sous le même h. L'empreinte atteste que les octets transmis sont ceux qui ont été approuvés, et non que l'effet est celui qui était attendu. Un exemple de jeton figure à l'annexe C.

La formule est un choix de conception du cadre, pas une norme. Elle met en œuvre l'approbation explicite par action à fort impact que recommande l'OWASP (ASI02)[28] et s'appuie sur trois spécifications publiées, dont deux normes : OpenID Connect CIBA (*Client-Initiated Backchannel Authentication*) pour l'approbation hors bande, la RFC 9396 pour décrire l'action et la RFC 8785 pour la canonisation. L'emploi d'`authorization_details` dans un jeton d'approbation est un profil du cadre : la RFC 9396 ne le définit que pour les jetons d'accès.

EXIG-AUT-12 · DOIT
Jeton d'approbation lié à l'action exacte
Toute approbation exigée par le contrôle calculé selon l'EXIG-AUT-10 (cellule classe × palier de la matrice, toute écriture d'un agent de niveau N2, déclencheurs d'approbation dont le dépassement de seuil, la règle de deux de l'EXIG-SEC-04 et le retrait déterministe de l'EXIG-SEC-06) **DOIT** produire un jeton signé par le service d'approbation adossé au fournisseur d'identité, contenant au minimum :

l'émetteur et l'audience (la passerelle); l'empreinte h, SHA-256 de la canonisation selon la RFC 8785 de l'objet {outil, version, definition_digest, agent_id, task_id, arguments}, dont les arguments incluent la clé d'idempotence; l'identifiant de l'approbateur, pseudonyme stable au sein du service, et son rôle (mandant ou tiers); les identifiants de la tâche et de l'agent; une date d'expiration et un identifiant de jeton à usage unique (`jti`). La double approbation se fait par deux jetons sur le même h. La passerelle **DOIT** rejeter tout argument non conforme à I-JSON (RFC 7493) et transmettre au serveur exactement la forme canonique hachée; elle conserve le jeton et ne le remet ni à l'agent ni à son modèle (EXIG-IAM-06). Avant l'exécution, elle **DOIT** vérifier la signature, l'émetteur, l'audience, l'expiration, la concordance de l'agent et de la tâche avec l'appelant authentifié, ainsi que le nombre et la distinction des approbateurs qu'exige le contrôle calculé, puis recalculer h; toute différence annule l'approbation. Le jeton couvre une seule opération : jusqu'à son expiration, la passerelle relaie toute présentation de la même opération (même appelant, même tâche, même h), et le système visé déduplique par la clé (EXIG-ORC-22); toute présentation avec une autre empreinte est refusée comme rejeu; un passage soldé par une demande de précision ou par un refus ne consomme pas le jeton. Après l'expiration, si l'issue est inconnue, la passerelle interroge le système visé par la clé : si l'effet est attesté, aucune nouvelle approbation n'est demandée; sinon, une nouvelle approbation est requise. Le registre des `jti` est partagé par toutes les instances de la passerelle, à écriture atomique, et fermé en cas d'indisponibilité (EXIG-AUT-11). Lorsqu'une compensation de saga est approuvée avec l'étape P2 ou P3 (EXIG-ORC-15 et EXIG-ORC-16), la demande d'approbation inclut l'empreinte de sa compensation déclarée, bornée au montant et aux bénéficiaires d'origine et liée à la même clé d'idempotence; cette approbation préalable est consignée au journal de compensation avec son empreinte et la passerelle accepte cette entrée signée du journal de compensation (y compris pour une compensation de palier P3 au sens de l'EXIG-AUT-09) jusqu'à la clôture de la saga, au-delà de l'échéance de 15 minutes du jeton d'exécution initiale. L'édition d'une action par l'approbateur est une nouvelle action : la passerelle recalcule le contrôle de l'EXIG-AUT-10 et h avant d'émettre le jeton, et celui qui a édité ne peut pas être le seul approbateur d'un appel qui en exige deux. Un outil P3 qui agit sur une ressource modifiable reçoit dans ses arguments approuvés les valeurs résolues qui déterminent l'effet (bénéficiaire, montant) ou une précondition de version (version ou ETag de la ressource) vérifiée à l'exécution; à défaut, la fiche déclare le risque résiduel de modification entre l'approbation et l'exécution. Le jeton d'exécution initiale **DOIT** expirer au plus 15 minutes après sa signature.

Pourquoi : un lien cryptographique entre la décision humaine et l'action exécutée détecte toute modification des arguments après l'approbation, pourvu que la passerelle et le serveur lisent les mêmes octets; ce mécanisme, la durée de validité et la règle d'une opération par jeton, qui concilie l'approbation et le réessai idempotent, sont des choix du cadre.

`EXIG-AUT-13` · NE DOIT PAS

Ce qui n'est jamais une approbation

La passerelle **NE DOIT PAS** accepter comme approbation un message d'acquiescement dans la conversation de l'agent, un résumé ou une justification rédigés par l'agent, une confirmation locale dans l'interface de l'agent, ni une approbation donnée pour d'autres arguments, une autre tâche ou un autre agent.

Pourquoi : le brouillon de groupe de travail WIMSE AIMS précise qu'une confirmation locale dans l'interface ne suffit pas comme autorisation[93].

EXIG-AUT-14 · DEVRAIT
Approbation hors bande normalisée
L'approbation hors bande d'un appel P3 (EXIG-AUT-09), ou celle que requiert un agent sans interface, **DEVRAIT** passer par OpenID Connect CIBA : le service d'approbation lance une demande d'authentification dorsale, et l'approbateur confirme sur son propre appareil. Un `binding_message` court, dérivé de h ou de la tâche, affiché à l'approbateur et, si l'agent a une interface, sur celle-ci, et consigné dans la demande et dans le jeton, aide à reconnaître la demande; le lien à l'action repose sur h (EXIG-AUT-12). L'action **DEVRAIT** être décrite par le paramètre `authorization_details` de la RFC 9396 lorsqu'elle comporte des paramètres que les portées ne peuvent exprimer, comme un montant ou un destinataire.
Pourquoi : CIBA Core 1.0 est une spécification finale de l'OpenID Foundation qui découple l'appareil de l'agent de celui de l'approbateur[310]; le brouillon WIMSE AIMS cite CIBA en exemple d'autorisation par palier, tout en notant ses limites en cours d'exécution, et le livre blanc de l'OpenID Foundation propose CIBA pour l'approbation humaine des agents[309, 311]; la RFC 9396 exprime les autorisations fines que `scope` ne peut exprimer[312].

EXIG-AUT-15 · DOIT
Approbateurs habilités et formés
Chaque combinaison de classe, de palier et de motif d'approbation (cellule, niveau, déclencheur) pour laquelle le contrôle calculé selon l'EXIG-AUT-10 exige une approbation **DOIT** avoir une liste d'approbateurs habilités, inscrite au registre (EXIG-GOV-04). L'approbation peut être donnée par le mandant lui-même, comme confirmation de sa propre action, sauf pour un appel P3 d'un agent de classe élevée : deux approbateurs distincts **DOIVENT** alors approuver, dont au moins un qui n'est pas le mandant et ne relève ni de sa ligne hiérarchique ni du parrain de l'agent. Les approbateurs autres que le mandant sont inscrits à la liste; ils **DOIVENT** posséder la compétence du domaine et l'autorité de refuser, et avoir été formés aux modes de défaillance des agents. Tout approbateur **DOIT** s'authentifier par authentification forte (au moins deux facteurs), résistante à l'hameçonnage (FIDO2 ou WebAuthn, par exemple) pour une approbation P3. Le service d'approbation vérifie, avant de signer, que l'approbateur est habilité pour le contrôle visé, et le rôle de chaque approbateur (mandant ou tiers) est consigné à l'audit.
Pourquoi : le RIA confie le contrôle humain des systèmes à haut risque à des personnes ayant la compétence, la formation et l'autorité nécessaires (art. 26, par. 2)[447]; l'IMDA demande que les superviseurs connaissent les modes de défaillance des agents[76]. Le second approbateur, la confirmation par le mandant et la règle d'indépendance sont des choix du cadre.

8.6 Interaction humaine avec les agents ambiants

Un agent ambiant travaille en arrière-plan, déclenché par des événements; la personne n'est pas devant lui quand il a besoin d'elle, et l'interaction doit être conçue en conséquence.

LangChain définit les agents ambiants comme des agents qui écoutent un flux d'événements et agissent en conséquence, éventuellement sur plusieurs événements à la fois, sans être nécessairement entièrement autonomes (section 3.3). Pour les relier aux personnes, son billet de janvier 2025 décrit trois patrons : notifier, questionner et réviser[86]. Le schéma de la boîte de réception d'agents (*Agent Inbox*) y associe quatre réponses : `accept`, `edit`, `response` et `ignore`, activées une à une par les drapeaux `allow_accept`, `allow_edit`, `allow_respond` et `allow_ignore`[313].

Tableau 32 — Trois patrons d'interaction avec un agent ambiant

Patron	Quand l'employer	Ce que fait l'agent	Réponses admises
Notifier	Événement important que la politique interdit à l'agent de traiter (p. ex. un contrat reçu pour signature).	Signale sans agir.	Prendre connaissance.
Questionner	Information manquante ou ambiguë.	Suspend la tâche et pose une question ciblée au lieu de deviner.	Répondre.
Réviser	Action soumise à approbation selon le contrôle calculé (EXIG-AUT-10).	Place l'action préparée dans la file, avec son effet attendu.	Accepter, éditer, répondre par une rétroaction, ignorer (refus).

Éditer une action revient à approuver une autre action : l'action éditée repasse par l'EXIG-AUT-10 avant l'émission du jeton, avec un nouvel indicateur de risque, la passerelle calcule l'empreinte des arguments modifiés, et c'est cette version que couvre le jeton (EXIG-AUT-12). Microsoft recommande aussi de distinguer l'approbation, qui fait avancer le flux, de la rétroaction, qui renvoie le travail à l'agent, et de restreindre les points d'approbation à des invocations d'outils précises[9]. Les protocoles offrent les mécanismes d'attente : en A2A 1.0, une tâche passe à l'état `TASK_STATE_INPUT_REQUIRED` ou `TASK_STATE_AUTH_REQUIRED` (section 6.6)[68]; en MCP, un serveur pose une question par élicitation, sans jamais demander de secret par formulaire[223].

Le « voyage dans le temps » souvent associé à ce patron n'est pas une réponse de la boîte de réception : c'est une fonction des points de contrôle de LangGraph, qui permet de rejouer une exécution depuis un point antérieur ou de bifurquer après avoir modifié l'état[283]. Il sert au diagnostic et à la correction; rejouer une étape réexécute ses effets. Enfin, le dépôt `agent-inbox` est archivé, en lecture seule, depuis le 20 septembre 2026[313] : le cadre adopte le patron, pas l'outil.

Un piège d'implémentation mérite attention. Dans LangGraph, `interrupt()` exige un mécanisme de points de contrôle (*checkpointer*), qui doit être persistant en production; à la reprise, le nœud interrompu redémarre depuis son début, si bien que le code placé avant l'interruption s'exécute de nouveau[82]. Un appel d'écriture placé avant le point d'approbation serait donc rejoué.

`EXIG-AUT-16` · DOIT
Boîte de réception persistante
Tout agent ambiant de niveau N2 ou plus **DOIT** acheminer ses interactions humaines par une boîte de réception persistante qui met en œuvre les trois patrons du tableau 32. Chaque demande **DOIT** indiquer le patron, la tâche, l'agent, une échéance fixée par cas d'usage et, pour le patron Réviser, l'effet attendu. Une demande Réviser sans réponse à l'échéance expire : l'action n'est pas exécutée et la tâche passe à une file d'escalade nommée. Une question sans réponse suspend la tâche, puis l'escalade; une notification est escaladée si sa politique l'exige. « Ignorer » vaut refus.
Pourquoi : les patrons de LangChain évitent que l'agent devine (il pose une question plutôt que d'halluciner) ou agisse sans validation humaine (révision d'une action avant son exécution)[86]; l'expiration en refus applique l'échec en mode fermé de l'EXIG-AUT-11.

`EXIG-AUT-17` · DOIT
État persisté et effets après le point d'approbation
L'orchestrateur **DOIT** conserver l'état de la tâche de façon durable à chaque point d'approbation obligatoire, dans un moteur d'exécution durable (section 7.4). Un appel à effet de bord ne doit pas précéder

le point d'interruption dans la même étape, et tout effet de bord suit l'EXIG-ORC-12 (clé déterministe, ou étape journalisée exécutée au plus une fois).
Pourquoi : Microsoft recommande de persister l'état aux points d'approbation obligatoires pour reprendre sans rejouer le travail antérieur[9], et LangGraph réexécute le code qui précède une interruption[82].

EXIG-AUT-18 · DOIT
Réautorisation périodique des agents ambiants
Le mandat d'agent ambiant, consentement inscrit au serveur d'autorisation qui permet à un agent ambiant de niveau N3 ou N4 d'obtenir, à sa demande, des jetons délégués d'au plus 15 minutes au nom du mandant tant que le mandat est valide et que le mandant est actif (section 9.3), **DOIT** expirer à une échéance inscrite à sa fiche, au plus égale à la période d'attestation par le parrain, soit 12 mois au plus pour un agent de classe modérée ou faible (section 11.5 et EXIG-GOV-13). Avant l'échéance, l'agent entre en drainage : il n'accepte plus de nouvelle tâche pendant une marge au moins égale à la durée maximale d'une saga. À l'échéance, l'agent s'arrête vers l'avant, sans préjudice du canal de compensation (EXIG-ORC-28), jusqu'à ce qu'une personne habilitée renouvelle le mandat.
Pourquoi : OpenAI recommande des expirations périodiques qui maintiennent l'agent à l'arrêt jusqu'à ce qu'un humain le révise et le réautorise[291].

8.7 Éviter l'approbation machinale

Un contrôle humain que personne n'exerce vraiment donne une fausse assurance; le cadre le conçoit et le mesure au lieu de le présumer.

Le phénomène est documenté. Parasuraman et Manzey (2010) montrent que le biais d'automatisation produit des erreurs d'omission et de commission, touche les novices comme les experts, s'observe aussi en équipe et ne disparaît ni avec la formation ni avec les consignes; la complaisance apparaît surtout sous charge multitâche[314]. OpenAI note qu'un utilisateur qui doit approuver rapidement beaucoup de décisions voit sa capacité à les examiner sérieusement diminuer[291].

Les référentiels en tirent des exigences. Le RIA demande que les personnes chargées du contrôle restent conscientes du biais d'automatisation (art. 14, par. 4, al. b))[61, 290, 412]; pour les systèmes à haut risque de l'annexe III, ces obligations s'appliquent à compter du 2 décembre 2027, et du 2 août 2028 pour ceux de l'annexe I, selon le RIA modifié par le règlement (UE) 2026/1744[58, 315, 447]. L'OWASP décrit la menace T10 « Overwhelming Human in the Loop » : un attaquant submerge les réviseurs de demandes pour provoquer fatigue et approbations précipitées[87]. Le risque ASI09 « Human-Agent Trust Exploitation » vise la surconfiance : biais d'automatisation, autorité perçue, explications fabriquées[28].

ATTENTION

Plus d'approbations ne veut pas dire plus de sécurité. Au-delà d'un certain volume, chaque approbation devient un clic. Le cadre préfère des approbations moins nombreuses, mieux ciblées et mesurées, et automatise ce dont le contrôle calculé (EXIG-AUT-10) est automatique.

EXIG-AUT-19 · DOIT
Écran d'approbation fidèle à l'action
L'écran d'approbation **DOIT** présenter l'action exacte, ses paramètres, son effet attendu, sa réversibilité et sa compensation, la provenance des données qui l'ont motivée (en signalant tout contenu non fiable) et un indicateur de risque produit par les règles du catalogue, non par le modèle. L'écran et

`authorization_details` sont produits par la passerelle à partir des seuls arguments canonisés que couvre h et du schéma de l'outil inscrit au catalogue, jamais d'un texte fourni par l'agent; l'écran montre tous les champs, sauf ceux que le catalogue déclare non significatifs, ainsi que la grandeur calculée du seuil (EXIG-AUT-08). La prévisualisation ne doit pas avoir d'effet de bord : aucun appel autre qu'une lecture, aucun changement d'état. Le raisonnement de l'agent peut être affiché comme information secondaire, mais il ne doit pas tenir lieu de justification suffisante.

Pourquoi : l'OWASP (ASI09) recommande un résumé de risque en langage clair plutôt qu'une justification produite par le modèle, et la séparation entre prévisualisation et effet[28]; la spécification MCP recommande de montrer à l'utilisateur les entrées de l'outil avant l'appel[197].

EXIG-AUT-20 · DOIT

Charge d'approbation maîtrisée

Les files d'approbation **DOIVENT** être priorisées selon le risque. Les demandes semblables peuvent être regroupées à l'affichage, mais chaque action conserve son propre jeton d'approbation (EXIG-AUT-09 et EXIG-AUT-12). La fréquence des demandes adressées à chaque approbateur **DOIT** être plafonnée selon un seuil fixé par le comité, et la charge **DOIT** être répartie entre approbateurs, avec rotation. Seules les actions dont le contrôle calculé selon l'EXIG-AUT-10 est automatique échappent à l'approbation. La capacité d'approbation **DOIT** être dimensionnée à la conception et inscrite au registre (volume prévu, y compris la charge que crée l'EXIG-SEC-06, avec une marge); un plafond de demandes par agent et par tâche s'ajoute au plafond par approbateur. Au dépassement, les actions sont mises en file, jamais approuvées par défaut; une demande qui expire vaut refus, et un agent émetteur qui dépasse un seuil déclaré est suspendu par un arrêt ciblé.

Pourquoi : contre la menace T10, l'OWASP recommande de prioriser les files de révision par risque, d'automatiser les approbations à faible risque, de limiter la fréquence des demandes et de répartir dynamiquement la charge entre réviseurs[87]; la rotation est un choix du cadre.

EXIG-AUT-21 · DOIT

Mesure de la qualité de la supervision

La plateforme **DOIT** produire chaque mois, par approbateur et par cas d'usage : le taux d'approbation sans modification, les taux de rejet et de modification, le temps de réponse, les renversements suspects (action refusée puis approuvée) et les approbateurs dont le taux d'approbation sans modification ou le temps de réponse s'écarte de la médiane du cas d'usage d'un seuil fixé par le comité. Pour les appels d'outils à effet exécutés sans approbation préalable aux niveaux N3 et N4, une revue humaine a posteriori **DOIT** porter sur un échantillon stratifié par risque : 5 % de ces appels pour la classe modérée et 1 % pour la classe faible (choix du cadre), bornés par une taille minimale et une taille maximale absolues par période, que le comité fixe pour détecter un taux d'anomalie cible avec une confiance déclarée (EXIG-EVA-03). La comparaison à la médiane exige au moins trois approbateurs par cas d'usage; à défaut, la référence est prise entre cas d'usage comparables. Le comité **DOIT** fixer ces seuils d'alerte par cas d'usage et examiner les écarts signalés.

Pourquoi : l'IMDA recommande de suivre le taux d'intervention des réviseurs (rejet ou modification des actions de l'agent), dont un niveau bas peut signaler une approbation machinale, et le temps de réponse des réviseurs[76]; l'OWASP recommande de détecter les renversements suspects[87] et le NIST juge utile de recueillir la fréquence des cas où une personne passe outre aux sorties du système, et leurs motifs[99]. Aucune source reconnue ne fixe de seuil universel.

8.8 Décisions automatisées et droit à la révision

Quand un agent décide seul à propos d'une personne, la Loi 25 crée des droits précis, et une approbation de pure forme ne les fait pas disparaître; la section 12.2 traite l'ensemble des obligations.

L'article 12.1 de la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1, « Loi sur le privé ») vise toute décision fondée exclusivement sur un traitement automatisé de renseignements personnels. L'entreprise doit en informer la personne au plus tard au moment où elle lui communique la décision. À la demande de la personne, elle l'informe des RP utilisés, des raisons et des principaux facteurs et paramètres ayant mené à la décision, ainsi que de son droit de faire rectifier ces renseignements. La personne doit pouvoir présenter ses observations à un membre du personnel en mesure de réviser la décision[56, 316]. Le défaut d'informer la personne de la décision ou de lui donner l'occasion de présenter ses observations, en contravention à l'article 12.1, est expressément un motif de sanction administrative pécuniaire (art. 90.1, par. 5°)[56, 317], et les renseignements utilisés pour prendre une décision doivent être conservés au moins un an après celle-ci (art. 11)[56]. Pour les organismes publics, la disposition équivalente est l'article 65.2 de la Loi sur l'accès aux documents des organismes publics et sur la protection des renseignements personnels (RLRQ, c. A-2.1, « Loi sur l'accès »)[318].

Qu'est-ce qui rend une décision « exclusivement » automatisée? Selon l'interprétation gouvernementale de l'article 65.2, c'est le cas lorsqu'aucune personne physique n'a exercé de contrôle important : une intervention humaine mineure, sans effet réel sur le résultat, ne fait pas échapper à l'obligation, alors qu'un outil d'aide qui fournit des éléments à un employé qui décide lui-même n'est pas visé. Cette interprétation précise aussi qu'il n'est pas requis de divulguer l'algorithme : le mot « principaux » limite l'explication aux facteurs déterminants[318]. Sous le règlement général sur la protection des données de l'Union européenne (RGPD), les lignes directrices WP251rev.01 vont dans le même sens : on ne peut contourner la règle en fabriquant une intervention humaine, et le contrôle doit être exercé par une personne qui a l'autorité et la compétence de modifier la décision[319].

DROIT APPLICABLE

La Commission d'accès à l'information (CAI) n'a pas publié de critères de l'intervention humaine significative pour le secteur privé. Les exigences ci-dessous constituent une interprétation prudente du cadre, fondée par analogie sur l'article 65.2 et sur WP251rev.01; leur application à un cas précis relève des affaires juridiques.

EXIG-AUT-22 · DOIT
Décisions visées par l'article 12.1
Voir l'EXIG-CON-07 (obligations envers la personne), l'EXIG-CON-08 (révision humaine significative) et l'EXIG-CON-09 (conservation), qui font foi. Règle résiduelle : tout agent dont les décisions concernant une personne sont fondées exclusivement, au sens de l'EXIG-CON-08, sur un traitement automatisé de ses RP **DOIT** être de classe élevée.
Pourquoi : obligations de l'article 12.1 et de l'article 11 de la Loi sur le privé (pour un organisme public, l'article 65.2 de la Loi sur l'accès prévoit des obligations d'information équivalentes)[56]; une obligation légale n'a qu'une source dans le cadre, le chapitre 12.

EXIG-AUT-23 · DOIT
Révision humaine significative
Voir l'EXIG-CON-08, qui porte le test de révision humaine significative (autorité, compétence, accès à toutes les données pertinentes, temps) et la qualification, faite a priori à l'EFVP et à la fiche, avec un

défaut prudent : la décision est réputée exclusivement automatisée tant que la preuve contraire n'y est pas consignée. Règle résiduelle : les indicateurs de l'EXIG-AUT-21 servent de contrôle a posteriori; un écart requalifie la décision et déclenche les avis dus (EXIG-CON-07). Le degré d'intervention humaine et l'étape où elle a lieu **DOIVENT** être consignés dans l'EFVP.

Pourquoi : interprétation prudente du cadre, et non règle expresse de la Loi 25; par analogie, une validation de pure forme ne retire pas le caractère exclusivement automatisé selon l'interprétation gouvernementale de l'article 65.2 (secteur public)[318], et WP251rev.01 demande de consigner dans l'analyse d'impact le degré et l'étape de l'intervention humaine[319].

Partie III — Confiance et exploitation

Identité, sécurité et confiance zéro; traçage, évaluation continue et maîtrise des coûts.

9 · Identité, sécurité et confiance zéro

10 · Observabilité, évaluation et FinOps

9 Identité, sécurité et confiance zéro

Un agent est un programme dont le comportement dépend en partie du contenu qu'il lit : son emplacement dans le réseau ne dit rien de ses intentions au moment où il agit. Ce chapitre applique donc la confiance zéro aux agents : chacun possède sa propre identité, n'agit pour une personne qu'au moyen d'un jeton délégué dont la portée ne peut que diminuer, et chacun de ses appels est décidé, un à un, par le service de politiques et appliqué par une passerelle. Les sections 9.1 à 9.4 traitent de l'identité, de la délégation et du point d'application des politiques; les sections 9.5 à 9.9 traitent des menaces, de l'injection d'instructions, du cloisonnement, de la chaîne d'approvisionnement et de l'assurance.

9.1 La confiance zéro appliquée aux agents

Cette section transpose aux agents le modèle de confiance zéro du NIST et pose la règle centrale du chapitre : aucune autorisation ne s'hérite, chaque appel se décide.

La publication NIST SP 800-207 (août 2020) définit la confiance zéro comme l'absence de toute confiance implicite fondée sur l'emplacement réseau. L'authentification et l'autorisation y sont des fonctions distinctes, exécutées avant l'accès; l'accès à chaque ressource est accordé par session, au moindre privilège, selon une politique dynamique qui tient compte de l'identité, de l'état de l'actif et d'attributs comportementaux[73, 112]. La publication SP 800-207A (septembre 2023) déplace la segmentation du réseau vers l'identité des services et cite SPIFFE comme infrastructure d'identité applicative[320].

Ce modèle convient particulièrement aux agents. Un agent légitime et correctement authentifié peut changer de comportement en cours de tâche : il lui suffit de lire un courriel qui contient des instructions cachées. Une autorisation accordée au début de la session ne protège donc pas l'étape suivante. C'est pourquoi le cadre va au-delà de l'accès par session décrit par le NIST : il exige une décision à chaque appel d'outil ou d'agent (choix du cadre). Le tableau 33 montre où chaque composant logique de la SP 800-207 se situe dans l'architecture de référence (chapitre 5).

Tableau 33 — Composants logiques de la confiance zéro et leur réalisation pour les agents

Composant (NIST SP 800-207)	Rôle selon le NIST	Réalisation dans le cadre
Moteur de politique (PE)	Décide d'accorder, de refuser ou de révoquer l'accès à une ressource.	Service de politiques : évalue l'identité de l'agent, le mandant, les droits effectifs, le palier de l'outil, le niveau d'autonomie et l'état de la tâche.
Administrateur de politique (PA)	Établit ou coupe le chemin de communication entre le sujet et la ressource.	Fournisseur d'identité (émission et révocation des jetons délégués) et plan de contrôle des passerelles (distribution des politiques, coupe-circuit).
Point d'application de politique (PEP)	Ouvre, surveille et termine les connexions.	Passerelle d'agents pour les appels vers les outils et les agents; passerelle de modèles pour les appels vers les modèles.
Sources de données (CDM, gestion des identités, journaux, SIEM, renseignements sur les menaces)	Alimentent le moteur de politique en informations sur l'état de l'actif, le sujet et l'activité.	Registre des agents, catalogue (paliers, versions épinglées), signaux de risque partagés, budget consommé, contenu non fiable déjà lu.

Source : d'après NIST SP 800-207[73]; colonne de droite : choix du cadre.

EXIG-IAM-01 · NE DOIT PAS
Aucune confiance implicite
L'accès d'un agent à un outil, à une ressource ou à un autre agent **NE DOIT PAS** être accordé du seul fait de son emplacement réseau, de sa plateforme d'hébergement ou de son appartenance au même orchestrateur ou au même domaine. Toute communication réseau entre composants doit être mutuellement authentifiée et chiffrée (mTLS ou équivalent), y compris à l'intérieur d'un réseau privé; le transport stdio local relève de l'EXIG-MCP-08.
Pourquoi : la SP 800-207 exclut toute confiance implicite fondée sur l'emplacement réseau[73]; un agent détourné se trouve, par définition, déjà à l'intérieur.

EXIG-IAM-02 · DOIT
Une décision à chaque appel
Chaque appel d'un agent vers un outil, une ressource, un modèle ou un autre agent **DOIT** être authentifié et autorisé individuellement. Le point d'application (passerelle d'agents ou, pour un appel de modèle, passerelle de modèles) applique la décision du service de politiques, rendue d'après l'identité de l'agent, le mandant, le palier de l'outil, le niveau d'autonomie, l'état de la tâche et les signaux de risque. L'état de la tâche (contenu non fiable consommé, données sensibles consultées, budget, compteurs) est tenu dans un magasin à cohérence forte, partagé par toutes les instances du point d'application; un état illisible ou indisponible impose le refus (EXIG-IAM-18, EXIG-IAM-18). Aucune autorisation n'est héritée d'un appel précédent ni d'une session, et l'agent ne participe jamais à la décision sur ses propres droits.
Pourquoi : l'état d'une tâche agentique change d'un appel à l'autre (contenu non fiable lu, budget consommé, approbation expirée); une décision prise une fois par session ne le verrait pas. Exigence propre au cadre, plus stricte que l'accès par session de la SP 800-207.

EXEMPLE
Un agent de soutien lit, à l'étape 3 de sa tâche, un courriel externe. À l'étape 4, il tente d'écrire une note dans le dossier du client, une écriture P2 sous le seuil qu'il exécute seul d'ordinaire. Parce que la décision est prise à chaque appel, la passerelle sait que la session a consommé du contenu non fiable et soumet cette écriture à une approbation humaine de l'action exacte (EXIG-SEC-04, section 9.6). Une autorisation accordée à l'ouverture de la session l'aurait laissé passer.

9.2 Identité non humaine des agents

Cette section fixe ce qu'est l'identité d'un agent, comment elle est émise et comment elle prend fin. Le principe est simple : on ne peut ni auditer, ni restreindre, ni révoquer ce qu'on ne peut pas désigner.

Un agent n'est ni une personne, ni un compte de service partagé (section 3.4). Microsoft déconseille d'attribuer aux agents un compte d'utilisateur ordinaire ou un principal de service traditionnel et a créé, avec Microsoft Entra Agent ID, un type d'identité propre aux agents[90]. Les bonnes pratiques de ce produit prescrivent une identité unique par instance d'agent et le moindre privilège[92]. Le brouillon de groupe de travail IETF WIMSE « AI Identity Management System » (AIMS, `draft-ietf-wimse-aims-00`, 15 septembre 2026; une révision −01 a paru le 2 novembre 2026, et les passages cités ici sont ceux de la −00) exige de son côté un seul identifiant de charge de travail par agent (qui peut être un SPIFFE ID), des justificatifs liés cryptographiquement et à expiration explicite, et interdit au grand modèle de langage d'accéder aux justificatifs de l'agent[93].

Émettre l'identité

SPIFFE et SPIRE sont des projets diplômés de la Cloud Native Computing Foundation (annonce du 20 septembre 2022; niveau « Graduated » atteint le 23 août 2022 pour SPIFFE et le 22 août 2022 pour SPIRE selon leurs pages de projet)[116, 117, 321]. Un SPIFFE ID prend la forme `spiffe://domaine-de-confiance/chemin`. Le justificatif correspondant, le SVID, existe en deux formats, X.509-SVID et JWT-SVID, tous deux délivrés par la Workload API sans secret préalable; l'X.509-SVID est renouvelé automatiquement, tandis que le JWT-SVID, de courte durée, est redemandé au besoin; SPIFFE recommande l'X.509-SVID lorsque c'est possible, car un JWT-SVID peut être rejoué[322]. La fédération d'identité OpenID Connect (OIDC) des fournisseurs infonuagiques (identités gérées) offre une solution équivalente pour les agents hébergés sur une seule plateforme.

Le brouillon WIMSE « Workload Identity Practices » (`draft-ietf-wimse-workload-identity-practices-07`, version du 22 septembre 2026, soumis le 30 juin 2026 au groupe de pilotage de l'ingénierie Internet (IESG); la révision –08 du 30 octobre 2026 est en dernier appel IETF jusqu'au 13 novembre 2026) recommande des justificatifs émis par la plateforme, de courte durée et ne dépassant pas la vie de l'instance, une audience distincte par cible, la preuve de possession, l'abandon des variables d'environnement lorsque la plateforme offre mieux et l'invalidation à la fin de la charge de travail[323]. Ces deux brouillons WIMSE ne sont pas des RFC; le cadre s'en sert comme références de conception.

Microsoft Entra Agent ID illustre une mise en œuvre commerciale, parmi d'autres. Une identité d'agent n'y a pas de justificatifs propres : elle obtient ses jetons par un gabarit *(agent identity blueprint)* qui porte les justificatifs et les politiques d'accès conditionnel héritées par toutes ses identités; désactiver le gabarit bloque toutes ces identités, ce qui en fait un justificatif partagé que l'EXIG-IAM-04 encadre. Chaque agent a un parrain *(sponsor)*, responsable métier, et un propriétaire *(owner)*, responsable technique[90]; un gestionnaire *(manager)* s'y ajoute pour l'agent qui dispose d'un compte d'utilisateur. Depuis juillet 2026, Copilot Studio crée automatiquement une telle identité pour chaque nouvel agent[48]. Le service est offert à tous les clients Entra, mais l'extension aux agents des fonctions de sécurité (accès conditionnel, protection des identités) requiert une licence Microsoft Agent 365[324].

`EXIG-IAM-03` · DOIT
Identité propre, distincte et non partagée
Chaque agent inscrit au registre **DOIT** disposer de sa propre identité non humaine, rattachée à sa fiche (section 11.4) et à un parrain nommé. Une identité distincte par instance est exigée lorsque des instances servent des mandants, des locataires ou des environnements différents, ou lorsqu'il faut pouvoir en révoquer une seule. Une identité d'agent n'est jamais partagée entre agents ni utilisée par une personne, et un agent n'utilise jamais le compte d'une personne.
Pourquoi : l'OWASP classe la réutilisation d'identités non humaines (NHI9) et leur usage par des humains (NHI10) parmi les dix risques principaux[91]; sans identité propre, ni l'audit ni la révocation ne peuvent viser un agent précis.

`EXIG-IAM-04` · DOIT
Justificatif cryptographique émis par la plateforme
L'identité d'un agent **DOIT** reposer sur un justificatif cryptographique émis par la plateforme, de courte durée, renouvelé automatiquement ou réémis à la demande par la plateforme, et valide au plus pour la vie de l'instance : X.509-SVID (à privilégier) ou JWT-SVID SPIFFE, ou identité fédérée OIDC du fournisseur infonuagique. Les justificatifs sont isolés par environnement (développement, essai, production). Lorsqu'une plateforme émet les jetons de plusieurs identités à partir d'un justificatif commun (p. ex. le gabarit de Microsoft Entra Agent ID), ce justificatif **DOIT** être fédéré ou géré par la

plateforme, sans secret client (EXIG-IAM-05), et le profil de la plateforme inscrit au catalogue définit ce que vaut l'instance au sens de la présente exigence.
Pourquoi : un justificatif émis par la plateforme est de courte durée, se renouvelle ou se réémet sans intervention, cesse d'être valide avec l'instance et n'exige aucun secret déployé avec la charge de travail; c'est la voie que décrivent SPIFFE et les pratiques WIMSE[322, 323].

EXIG-IAM-05 · NE DOIT PAS
Aucun secret statique
Un agent **NE DOIT PAS** s'authentifier au moyen d'un secret statique ou de longue durée (clé d'API, mot de passe, secret client), qu'il soit partagé ou non. Aucun secret ne figure dans le code, les définitions d'agents, les invites, les fichiers de configuration versionnés ni, lorsque la plateforme offre un mécanisme d'émission, dans les variables d'environnement. Un secret résiduel imposé par un système patrimonial est conservé dans un coffre, renouvelé automatiquement et inscrit comme dérogation (section 11.6).
Pourquoi : le brouillon AIMS qualifie les clés d'API statiques d'anti-patron[93] et l'OWASP range la fuite de secrets (NHI2) et les secrets de longue durée (NHI7) parmi les risques majeurs[91].

EXIG-IAM-06 · NE DOIT PAS
Justificatifs hors de portée du modèle
Le modèle **NE DOIT PAS** avoir accès aux justificatifs de l'agent : aucun jeton, certificat ni secret n'entre dans le contexte du modèle, dans la mémoire de l'agent, dans les arguments d'un outil, dans un message logique, dans un point de contrôle, dans le journal de compensation ou dans les traces. Jetons délégués et jetons d'approbation circulent dans les en-têtes d'authentification du transport; ils sont injectés et retirés par le code d'exécution de l'agent ou par la passerelle (EXIG-IAM-19). Le jeton d'approbation est conservé par la passerelle, qui ne le remet ni à l'agent ni à son modèle (EXIG-AUT-12); un message de délégation porte une référence de délégation, non le jeton (EXIG-ORC-23).
Pourquoi : le brouillon AIMS l'interdit[93]; un modèle qui voit un jeton peut être amené, par injection d'instructions, à le divulguer.

Retirer et révoquer

Une identité oubliée reste une porte ouverte. Le livre blanc de l'OpenID Foundation sur l'identité des agents (annoncé le 7 octobre 2025) recommande un retrait formel des agents, par exemple une opération `DELETE` du protocole SCIM *(System for Cross-domain Identity Management)* propagée aux systèmes raccordés[311, 325]. Le NIST AI RMF prévoit des processus de déclassement sécuritaire des systèmes d'IA (GOVERN 1.7), dont le cadre fait découler la révocation des identifiants[74]. Microsoft recommande que les parrains attestent tous les 6 à 12 mois que chaque agent est encore requis et que les agents orphelins soient revus chaque trimestre[92].

EXIG-IAM-07 · DOIT
Révocation au retrait et revues périodiques
Le retrait d'un agent **DOIT** révoquer son identité, ses justificatifs, ses jetons actifs et ses délégations, dans un délai maximal fixé par l'entreprise et mesuré en exercice, puis propager la suppression aux systèmes raccordés. Les compensations des sagas en cours de l'agent retiré s'exécutent sous l'identité de compensation (EXIG-ORC-28), que ce retrait ne révoque pas. L'attestation du parrain et la revue des agents orphelins suivent l'EXIG-GOV-13; la désactivation qui en résulte révoque l'identité et les justificatifs selon la présente exigence.

> Pourquoi : le retrait inadéquat est le premier risque du classement OWASP (NHI1)[91]. Les périodicités sont celles de l'EXIG-GOV-13.

Le tableau 34 rattache chacun des dix risques de l'OWASP Non-Human Identities Top 10 (2025) aux exigences de ce chapitre. La correspondance avec le Top 10 des applications agentiques (ASI) est traitée à la section 9.5.

Tableau 34 — Risques de l'OWASP Non-Human Identities Top 10 (2025) et réponse du cadre

Risque OWASP	Ce qui se passe	Réponse du cadre
NHI1 Retrait inadéquat (Improper Offboarding)	L'agent retiré garde des accès valides.	EXIG-IAM-07; cycle de vie (section 11.5)
NHI2 Fuite de secrets (Secret Leakage)	Une clé apparaît dans le code, une trace ou une réponse du modèle.	EXIG-IAM-05, EXIG-IAM-06, EXIG-IAM-19
NHI3 Identités de tiers vulnérables (Vulnerable Third-Party NHI)	Un fournisseur détient des accès étendus et mal protégés.	Couverture partielle : clauses (section 13.3) et chaîne d'approvisionnement (section 9.8); EXIG-IAM-17 pour les appels sortants. Aucun inventaire des octrois accordés à des tiers n'est encore exigé.
NHI4 Authentification non sécurisée (Insecure Authentication)	Octrois obsolètes, secrets partagés, absence de preuve de possession.	EXIG-IAM-04, EXIG-IAM-13, EXIG-IAM-14
NHI5 Identités surprivilégiées (Overprivileged NHI)	L'agent possède plus de droits que ses tâches n'en exigent.	EXIG-IAM-10, EXIG-IAM-16
NHI6 Configurations infonuagiques non sécurisées (Insecure Cloud Deployment Configurations)	Justificatifs exposés par la configuration du déploiement.	EXIG-IAM-04 (identité fédérée); cloisonnement (section 9.7)
NHI7 Secrets de longue durée (Long-Lived Secrets)	Un secret volé reste exploitable des mois durant.	EXIG-IAM-04, EXIG-IAM-05, EXIG-IAM-15
NHI8 Isolation des environnements (Environment Isolation)	Le même justificatif sert en essai et en production.	EXIG-IAM-04 (isolation par environnement)
NHI9 Réutilisation d'identités (NHI Reuse)	Plusieurs agents partagent une identité; l'audit devient ambigu.	EXIG-IAM-03, EXIG-IAM-16
NHI10 Usage humain d'identités non humaines (Human Use of NHI)	Une personne se sert de l'identité d'un agent pour agir.	EXIG-IAM-03

Source : liste et intitulés de l'OWASP[91]; traduction et correspondance : cadre.

9.3 Délégation : agir au nom d'une personne

Cette section règle le cas le plus fréquent et le plus délicat : un agent qui agit pour une personne. L'objectif est double : que chaque système appelé sache à la fois qui demande et qui agit, et que l'agent ne puisse jamais faire plus que ce que la personne pourrait faire elle-même.

Le risque visé porte un nom : l'adjoint confus *(confused deputy)*. Un agent doté de droits étendus exécute la demande d'une personne qui en a moins et lui procure ainsi, indirectement, ce qu'elle n'aurait pas pu obtenir seule. La spécification MCP le signale explicitement pour les mandataires MCP[208]. La parade consiste à faire porter par chaque appel l'identité du mandant et celle de l'agent, puis à calculer les droits à partir des deux.

Échange de jetons et chaîne d'acteurs

La norme de référence est l'échange de jetons OAuth 2.0 (RFC 8693, janvier 2020). Dans la requête, `grant_type` (`urn:ietf:params:oauth:grant-type:token-exchange`), `subject_token` (le jeton du mandant) et `subject_token_type` sont obligatoires; `actor_token` (le justificatif de l'agent) et `requested_token_type` sont facultatifs, `actor_token_type` devenant obligatoire en présence d'`actor_token`. La revendication

`may_act` exprime qu'une partie est autorisée à agir pour une autre; le serveur d'autorisation peut s'en servir pour accepter ou refuser une délégation[70].

Dans le jeton émis, la revendication `act` est un objet JSON, et non une simple chaîne. Des `act` imbriqués représentent une chaîne : l'`act` le plus externe désigne l'acteur courant, les `act` imbriqués les acteurs antérieurs. La RFC précise que seuls les attributs de premier niveau et l'acteur courant servent aux décisions d'accès; les acteurs antérieurs sont informatifs. Elle laisse aussi l'émission d'`act` à la discrétion du serveur d'autorisation : c'est donc le cadre qui l'exige[70].

La RFC distingue la délégation, où l'acteur conserve une identité distincte et agit pour le mandant, de l'usurpation *(impersonation)*, où l'acteur devient indiscernable du mandant[69]. Le livre blanc de l'OpenID Foundation recommande de remplacer l'usurpation par une autorité déléguée explicite, dans des jetons qui identifient à la fois l'utilisateur et l'agent, et d'atténuer la portée à chaque saut[311]. Le système cible exécute donc la requête au nom de la personne, l'agent restant identifié comme acteur courant.

« On-Behalf-Of » (OBO) désigne un patron de délégation, pas une norme. Le flux OBO de Microsoft Entra, par exemple, ne repose pas sur la RFC 8693, mais sur l'octroi `urn:ietf:params:oauth:grant-type:jwt-bearer` avec `requested_token_use=on_behalf_of`[326]. Le cadre exige donc un résultat (jeton délégué, audience restreinte, portée réduite, mandant et acteur identifiables) et nomme la RFC 8693 comme référence; chaque variante de fournisseur est profilée au catalogue.

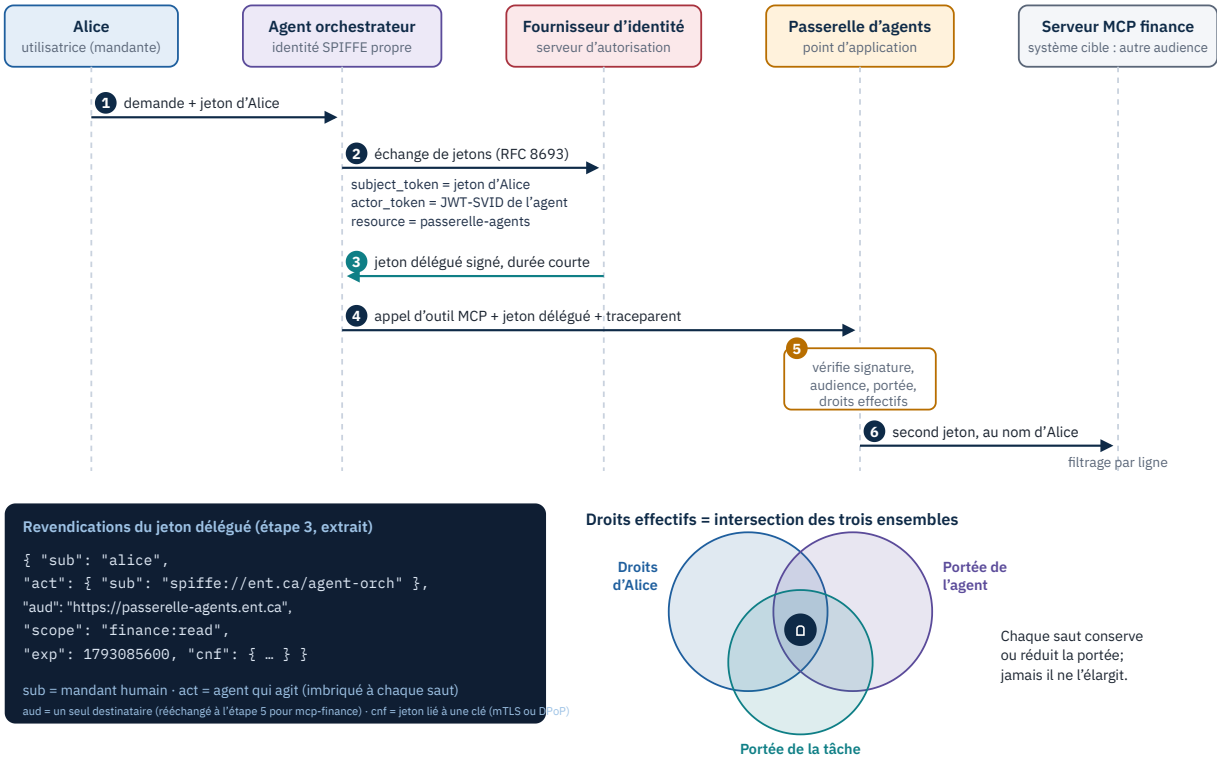


Figure 17 — Délégation par échange de jetons et droits effectifs. L'orchestrateur échange le jeton d'Alice contre un jeton délégué à audience unique visant la passerelle (étapes 2 et 3), que la passerelle vérifie et rééchange pour le serveur cible avant l'appel (étape 5); le serveur cible agit au nom d'Alice, l'agent restant identifié comme acteur courant (étape 6). Les droits effectifs ne dépassent jamais l'intersection des trois ensembles. Après vérification, la passerelle obtient pour le serveur un second jeton, qui la désigne comme client sans ajouter de niveau d'`act` (EXIG-IAM-14); le serveur MCP et le système cible, réunis dans une même boîte, sont deux audiences distinctes (EXIG-IAM-12). Source : cadre CRE-IA-2026-01, d'après la RFC 8693 et la RFC 9068.

La figure 17 illustre le premier échange. Lorsqu'un sous-agent appelé par A2A doit à son tour appeler un outil, il refait un échange : son `subject_token` est le jeton délégué reçu, son `actor_token` est son propre JWT-SVID (un X.509-SVID sert plutôt à l'authentification mTLS du client, la RFC 8693 ne définissant aucun type de jeton pour un certificat). Le jeton obtenu conserve le mandant et ajoute un niveau d'`act`. L'agent le présente à la passerelle (`aud` désignant `https://passerelle-agents.ent.ca`, `cnf` lié au justificatif de l'agent); la passerelle vérifie la signature, l'audience et la liaison à l'expéditeur, puis procède elle-même à un échange RFC 8693 auprès du serveur d'autorisation (`subject_token` égal au jeton reçu de l'agent, authentification cliente de la passerelle) pour obtenir un jeton final à audience unique visant le serveur cible (`aud: "https://mcp-finance.ent.ca"`, `client_id: "passerelle-agents"`, `cnf` lié à la passerelle), en préservant tels quels `sub` et la chaîne `act` sans ajouter de niveau d'`act` (car la passerelle est un point d'application des politiques, et non un agent délégataire au sens de l'EXIG-ORC-04 et de l'EXIG-IAM-14). L'extrait suivant montre le jeton présenté par le sous-agent à la passerelle, avec la portée de la tâche dans `authorization_details` (EXIG-IAM-10); le jeton rééchangé remis à `mcp-finance` ne diffère que par `aud` (`https://mcp-finance.ent.ca`), `client_id` (`passerelle-agents`), `cnf` et `jti` (les deux jetons complets figurent à l'annexe C.5).

Jeton délégué après deux sauts (extrait : jeton émis pour la passerelle, qui l'échange ensuite pour `mcp-finance`)

```
{
  "iss": "https://idp.ent.ca",
  "sub": "alice",
  "aud": "https://passerelle-agents.ent.ca",
  "client_id": "agent-analyse-depenses",
  "scope": "finance:read",
  "authorization_details": [{ "type": "lecture_depenses", "periode": "2026-T3" }],
  "act": {
    "sub": "spiffe://ent.ca/agent-analyse-depenses",
    "act": { "sub": "spiffe://ent.ca/agent-orch" }
  },
  "cnf": { "x5t#S256": "…" },
  "iat": 1793084700, "exp": 1793085600, "jti": "9f1c…"
}
```

`EXIG-IAM-08` · DOIT
Délégation explicite par échange de jetons
Lorsqu'un agent agit pour une personne, il **DOIT** obtenir, à chaque saut, un jeton délégué par échange de jetons conforme à la RFC 8693 : `subject_token` égal au jeton du mandant ou au jeton délégué reçu, `actor_token` égal au justificatif de l'agent. Le jeton émis porte `sub` (le mandant, toujours l'entité d'origine) et `act` (l'agent courant), avec un `act` imbriqué par acteur antérieur. Avant d'émettre, le serveur d'autorisation **DOIT** vérifier que l'agent est autorisé à agir pour ce mandant (`may_act` ou politique équivalente) et que la profondeur d'imbrication de `act` ne dépasse pas deux niveaux (EXIG-ORC-04); il refuse l'échange qui l'excède. La profondeur ne compte que les agents inscrits au registre : la passerelle qui refait l'échange vers le serveur (EXIG-IAM-14) et un serveur MCP qui obtient un jeton pour son propre système cible (EXIG-IAM-12) n'y ajoutent aucun niveau et sont consignés à l'audit. Le serveur d'autorisation **DOIT** en outre : (a) émettre un `exp` au plus égal à celui du `subject_token`, de sorte qu'aucun échange ne prolonge une délégation; (b) refuser tout échange au-delà de la durée maximale de chaîne inscrite à la fiche, comptée depuis l'authentification du mandant (`auth_time`); (c) rejeter tout `subject_token` dont `aud` ne désigne pas l'acteur demandeur, ou dont la liaison (`cnf`) ne désigne ni cet acteur ni la passerelle. Une variante de fournisseur est admise si son profil, inscrit au catalogue, démontre le même résultat : audience unique, identifiant unique du jeton, client identifiable, mandant et

chaîne d'acteurs complète; à défaut de chaîne, la délégation est limitée à un saut, ou le jeton est réémis par une passerelle conforme à la RFC 9068.
Pourquoi : la RFC 8693 rend `act` facultatif[70]; le cadre l'exige pour que chaque appel désigne à la fois la personne et l'agent.

`EXIG-IAM-09` · NE DOIT PAS
Interdiction de l'usurpation
Un agent **NE DOIT PAS** usurper l'identité d'une personne : aucun jeton ne présente l'agent comme s'il était le mandant, et aucun agent ne présente le jeton d'une personne à un service autre que le serveur d'autorisation, à titre de `subject_token` (EXIG-IAM-12), ni ne réutilise sa session ou son mot de passe.
Pourquoi : un appel usurpé efface l'agent de la piste d'audit et lui donne tous les droits de la personne[69, 311].

Droits effectifs : une intersection, jamais une addition

Microsoft définit la permission effective d'une application déléguée comme l'intersection de ce que l'utilisateur peut faire et de ce que l'application est autorisée à faire[96]. Le cadre y ajoute un troisième terme, la portée de la tâche (choix du cadre) : droits effectifs = droits du mandant ∩ portée de l'agent ∩ portée de la tâche. Exemple : Alice peut lire et approuver les factures de son unité; l'agent d'analyse ne détient que `finance:read`; la tâche porte sur les dépenses du troisième trimestre, que le jeton délégué porte dans `authorization_details`. Le serveur d'autorisation borne la portée (agent et tâche), et le serveur de ressources applique les droits d'Alice d'après `sub` : le jeton délégué permet donc de lire les dépenses du troisième trimestre de l'unité d'Alice, et rien d'autre. Sans cette représentation de la tâche, il permettrait de lire toutes les dépenses de l'unité.

Comme la RFC 8693 interdit de fonder une décision d'accès sur les acteurs antérieurs, cette intersection ne peut pas être recalculée par le serveur de ressources à partir des `act` imbriqués : le serveur d'autorisation borne les portées à chaque échange, et le serveur de ressources applique à chaque appel les droits du mandant désigné par `sub`[70]. Lorsqu'une portée manque, MCP prévoit que le serveur réponde 403 avec `error="insufficient_scope"` et que le client demande une autorisation incrémentale, avec un nombre limité de tentatives[209] : l'agent démarre avec peu de droits et en obtient davantage par une demande traçable, qui, dans une chaîne, remonte au mandant (EXIG-IAM-10).

`EXIG-IAM-10` · DOIT
Portée jamais élargie
À chaque échange, le serveur d'autorisation **DOIT** émettre une portée au plus égale à l'intersection des droits du mandant, de la portée accordée à l'agent au registre et de la portée nécessaire à la tâche; le serveur de ressources applique, à chaque appel, les droits du mandant d'après `sub`. La portée de la tâche **DOIT** être représentée dans le jeton, par `authorization_details` (RFC 9396) ou par une portée paramétrée inscrite au catalogue, et appliquée par la cible. Le mandant d'une chaîne est toujours l'entité d'origine; un agent intermédiaire n'apparaît que comme `act`. Une portée ne s'élargit jamais d'un saut à l'autre : le jeton remis à un agent intermédiaire porte les portées en aval autorisées pour la tâche, chaque échange émet au plus l'intersection de cette liste, du registre et de la tâche, et changer d'audience sans élargir la liste est permis. Une portée absente de la liste s'obtient par une demande incrémentale remontée au mandant, approuvée par lui (section 8.5) et journalisée, qui réémet la chaîne depuis le premier saut; pour un agent autonome, par une modification revue du registre, jamais à l'exécution. Les tentatives sont plafonnées à trois par tâche, sauf valeur plus stricte à la fiche. Aucun jeton plus large n'est obtenu d'avance.

Pourquoi : l'atténuation de la portée à chaque saut est recommandée par l'OpenID Foundation[311]; la formule à trois termes, sa répartition entre serveur d'autorisation et serveur de ressources et le plafond de tentatives sont des choix du cadre. Le cadre a écarté les capacités atténuables (macarons), faute de révocation, d'audience et d'audit centralisés.

`EXIG-IAM-11` · DOIT
Jeton à audience unique, validé par la cible
Tout jeton d'accès présenté par un agent à un outil, à une ressource ou à un autre agent **DOIT** viser une seule ressource (paramètre `resource` de la RFC 8707 ou `audience` de la RFC 8693) et suivre le profil JWT de la RFC 9068 (`typ` `at+jwt`; `iss`, `exp`, `aud`, `sub`, `client_id`, `iat` et `jti` présents); une variante de fournisseur est admise aux conditions de l'EXIG-IAM-08. Le serveur de ressources rejette tout jeton dont `aud` ne le désigne pas, fonde sa décision sur les revendications de premier niveau (dont `sub`, `scope`, `aud` et `cnf`) et sur l'acteur courant seulement, jamais sur les acteurs antérieurs, et journalise le mandant et l'acteur courant; les acteurs antérieurs servent à l'audit. Derrière la passerelle, le jeton présenté au serveur est celui que la passerelle obtient pour lui (EXIG-IAM-14).
Pourquoi : un jeton à audience unique ne vaut rien ailleurs s'il est volé[71, 72]; la RFC 9068 ne définit pas `act`, qui relève de la RFC 8693.

`EXIG-IAM-12` · NE DOIT PAS
Aucun relais de jeton
Un agent, un outil ou un serveur MCP **NE DOIT PAS** transmettre tel quel à un autre service un jeton qu'il a reçu *(token passthrough)*, sauf au serveur d'autorisation, à titre de `subject_token` d'un échange de jetons (EXIG-IAM-08); il obtient un nouveau jeton pour chaque audience.
Pourquoi : la spécification d'autorisation MCP l'interdit, le brouillon AIMS le qualifie d'anti-patron[93, 209].

Profil OAuth de l'entreprise

Au 27 octobre 2026, OAuth 2.1 n'est pas une RFC : c'est un Internet-Draft actif du groupe de travail OAuth (`draft-ietf-oauth-v2-1-16`, septembre 2026, expirant le 7 mars 2027; la révision –17 du 31 octobre 2026, qui expire le 4 mai 2027, l'a remplacée depuis)[176]. La référence normative est donc OAuth 2.0 conforme à la RFC 9700 (BCP 240, janvier 2025), alignée sur le profil OAuth 2.1 en cours de normalisation[175]. Le tableau 35 précise ce que cela signifie pour les agents.

Tableau 35 — Profil OAuth exigé pour les agents

Exigence	Référence	Application aux agents
Pratiques de sécurité courantes	RFC 9700, BCP 240[175]	Octroi implicite interdit (la RFC 9700 le déconseille seulement, SHOULD NOT; choix du cadre, EXIG-IAM-13), octroi par mot de passe interdit, PKCE pour tous les clients (choix du cadre, EXIG-IAM-13), comparaison exacte des URI de redirection, jetons restreints en audience et en privilèges, authentification asymétrique des clients (mTLS ou `private_key_jwt`).
Alignement sur OAuth 2.1	Brouillon `draft-ietf-oauth-v2-1-16` (-17 depuis le 31 octobre 2026)[176, 327]	Le brouillon ne définit que trois octrois : code d'autorisation avec PKCE, jeton de rafraîchissement, identifiants du client. Un agent n'utilise que ceux-là, plus les octrois d'extension retenus par le cadre (RFC 8693, RFC 7523). Aucun jeton dans l'URI.
Authentification mTLS et jetons liés au certificat	RFC 8705[328]	Jeton lié par `cnf` « `x5t#S256` »; la ressource rejette la requête si le certificat diffère; derrière une passerelle qui termine TLS, la liaison se vérifie à la passerelle (EXIG-IAM-14).

Exigence	Référence	Application aux agents
		Profil par défaut dans le maillage de services, avec des X.509-SVID (ligne directrice du cadre).
Preuve de possession (DPoP)	RFC 9449[213]	Preuve JWT `dpop+jwt` liée à `htm`, `htu`, `iat`, `jti` et `ath`; jeton lié par `cnf.jkt`; nonce possible. Profil des agents hors maillage : poste de travail, navigateur, mobile, périphérie.
Identification de l'émetteur	RFC 9207[329]	Paramètre `iss` dans la réponse d'autorisation contre la confusion de serveurs. MCP 2026-07-28 exige que le client le valide; le cadre exige que le fournisseur d'identité l'émette.
Métadonnées de ressource protégée	RFC 9728[330]	Document `/.well-known/oauth-protected-resource` dont la valeur `resource` correspond exactement à l'identifiant de la ressource. Publié par chaque serveur MCP et chaque API exposée aux agents.
Indicateur de ressource	RFC 8707[71]	Paramètre `resource` dans les requêtes d'autorisation et de jeton; MCP exige l'URI canonique du serveur[209].
Jeton d'accès JWT	RFC 9068[72]	Format des jetons délégués; `act` s'ajoute selon la RFC 8693.

EXIG-IAM-13 · DOIT

Profil OAuth de l'entreprise

Le fournisseur d'identité, la passerelle d'agents, les clients OAuth (hôtes et agents) et les serveurs exposés aux agents **DOIVENT** appliquer, chacun pour son rôle, le profil du tableau 35 : pratiques de la RFC 9700, aucun octroi implicite ni octroi par mot de passe, PKCE avec `S256`, comparaison exacte des URI de redirection, authentification asymétrique des clients confidentiels, émission et validation du paramètre `iss` (RFC 9207) et publication des métadonnées de ressource protégée (RFC 9728).

Pourquoi : la RFC 9700 est la référence de sécurité OAuth en vigueur, alors qu'OAuth 2.1 reste un brouillon[175, 176]. Le cadre est plus strict que la RFC 9700 sur plusieurs points, dont ces trois choix du cadre : celle-ci déconseille l'octroi implicite (SHOULD NOT) et ne fait que recommander PKCE pour les clients confidentiels et l'authentification asymétrique des clients.

EXIG-IAM-14 · DOIT

Jetons liés à l'expéditeur

Tout jeton qui donne accès à un serveur exposant un outil P2 ou P3, ou un outil P1 portant sur des RP ou des données classifiées, ou qui est détenu par un agent de classe de risque élevée, **DOIT** être lié à l'expéditeur *(sender-constrained)* : mTLS (RFC 8705) dans le maillage de services, de préférence avec un X.509-SVID, ou DPoP (RFC 9449) hors du maillage. Derrière une passerelle qui termine TLS, la liaison se vérifie à la passerelle : l'agent lui présente un jeton dont `aud` désigne la passerelle et `cnf` l'agent; la passerelle vérifie `cnf`, puis obtient par échange un jeton pour le serveur (`aud` égal au serveur, `client_id` et `cnf` désignant la passerelle, `act` égal à l'agent, acteurs antérieurs imbriqués), et le serveur **DOIT** n'accepter que la passerelle, par mTLS. Cet échange n'ajoute aucun niveau de profondeur (EXIG-IAM-08). Pour les autres jetons, la liaison devrait être appliquée. Les jetons de rafraîchissement des clients publics **DOIVENT** être liés à l'expéditeur ou à usage unique.

Pourquoi : un jeton porteur volé est utilisable par quiconque le détient. La RFC 9700 recommande la liaison du jeton à l'expéditeur (SHOULD)[175]; le cadre la rend obligatoire pour les paliers P2 et P3 et pour les agents de classe de risque élevée. La répartition mTLS/DPoP est une ligne directrice du cadre.

Parmi les textes consultés (IETF, OpenID, NIST), aucun ne fixe de durée de vie chiffrée : la RFC 9700, le brouillon OAuth 2.1, MCP (qui le recommande, SHOULD) et le brouillon AIMS ne demandent que des jetons « de courte durée ». Le brouillon Transaction Tokens évoque des durées « de l'ordre de quelques minutes

ou moins »[179]. Chez Microsoft Entra, la durée par défaut est de 60 à 90 minutes, une politique configurable ne peut descendre sous 10 minutes, et l'évaluation continue de l'accès (CAE) peut la prolonger jusqu'à 28 heures en échange d'une révocation en temps quasi réel[331]. Le cadre fixe donc une cible plutôt qu'un absolu.

EXIG-IAM-15 · DEVRAIT
Durée de vie courte des jetons
Un jeton d'accès d'agent **DEVRAIT** expirer en 15 minutes ou moins lorsque le fournisseur d'identité le permet. Lorsque la durée minimale du fournisseur est plus longue, l'écart est compensé par la liaison du jeton à l'expéditeur (EXIG-IAM-14) et par la révocation en temps quasi réel (EXIG-IAM-20). Conformément à l'EXIG-IAM-20, un jeton destiné à un système qui ne prend en charge ni SSF ni CAEP a une durée de vie au plus égale à la cible du coupe-circuit, ou ce système n'est joignable que par la passerelle. La délégation de longue durée d'un agent ambiant est un consentement au serveur d'autorisation, qui émet des jetons d'accès de courte durée à la demande, sous l'échéance de l'EXIG-AUT-18.
Durée de vie courte des jetons
Un jeton d'accès d'agent **DEVRAIT** expirer en 15 minutes ou moins lorsque le fournisseur d'identité le permet. Lorsque la durée minimale du fournisseur est plus longue, l'écart est compensé par la liaison du jeton à l'expéditeur (EXIG-IAM-14) et par la révocation en temps quasi réel (EXIG-IAM-20). Un jeton destiné à un système qui ne prend en charge ni SSF ni CAEP doit avoir une durée de vie au plus égale à la cible du coupe-circuit (EXIG-IAM-20), ou ce système doit n'être joignable que par la passerelle. La délégation de longue durée d'un agent ambiant doit être un consentement inscrit au serveur d'autorisation : celui-ci émet, à la demande de l'agent authentifié, des jetons d'au plus 15 minutes, ou de la durée minimale du fournisseur si elle est plus longue (`sub` égal au mandant, `act` égal à l'agent), tant que le mandat est valide et que le mandant est actif; l'agent ne stocke aucun jeton de la personne, jeton de rafraîchissement compris. Le mandat est révoqué automatiquement au départ ou au changement de rôle du mandant, et son échéance suit l'EXIG-AUT-18 (inscrite à la fiche, renouvelée par une personne habilitée).
Pourquoi : la cible de 15 minutes est un choix du cadre; un jeton émis vers un système sans SSF ni CAEP reste valide jusqu'à son expiration, d'où la borne liée au coupe-circuit; OpenAI cite, parmi les moyens de borner l'action des agents, des expirations périodiques jusqu'à ce qu'un humain révise et réautorise l'agent[291].

Agents autonomes et approbations hors bande

Un agent qui n'agit pour personne (traitement de fond, surveillance, rapprochement nocturne) n'a pas de mandant à représenter. Microsoft Entra Agent ID prescrit alors le flux par identifiants du client *(client credentials)*, et le flux OBO pour les agents interactifs[92]. MCP publie, depuis la révision 2026-07-28, une extension stable « OAuth Client Credentials » pour ce cas[217]. Lorsqu'un agent sans interface doit obtenir la confirmation d'une personne, il passe par une approbation hors bande (CIBA), décrite à la section 8.5.

EXIG-IAM-16 · DOIT
Agents autonomes : identifiants du client et portées par outil
Un agent qui n'agit pour aucune personne **DOIT** utiliser l'octroi par identifiants du client avec son propre principal, authentifié par un justificatif cryptographique (EXIG-IAM-04), et des portées minimales définies outil par outil. Il ne partage jamais un jeton avec un autre agent et n'emprunte jamais l'identité d'une personne (EXIG-IAM-09). Lorsqu'un agent autonome délègue à un autre agent, l'agent initiateur tient lieu de mandant : l'échange de l'EXIG-IAM-08 s'applique avec `sub` égal au principal de l'initiateur et `act` égal à l'agent courant, et l'intersection de l'EXIG-IAM-10 porte sur les droits de l'initiateur.

> Pourquoi : l'OWASP classe les identités surprivilégiées (NHI5) et la réutilisation d'identités (NHI9) parmi les risques principaux[91].

Mécanismes en cours de normalisation

Plusieurs mécanismes utiles aux agents ne sont pas encore des normes publiées. Le tableau 36 en donne l'état au 27 octobre 2026 et la cote retenue; il précise, pour l'identité, le catalogue des protocoles de la section 6.3.

Tableau 36 — Mécanismes d'identité en normalisation : état au 27 octobre 2026, révisions postérieures signalées

Mécanisme	État	Usage visé	Cote
OAuth 2.1	Brouillon de groupe de travail, version –16 (septembre 2026); version –17 du 31 octobre 2026 depuis[176]	Profil de référence, via la RFC 9700	**Adopter** avec réserve
ID-JAG et extension MCP « Enterprise-Managed Authorization »	Brouillon –04 (21 mai 2026), –06 du 31 octobre 2026 depuis; extension MCP stable depuis 2026-07-28[177, 218]	Le fournisseur d'identité de l'entreprise décide, par politique, à quels serveurs MCP un employé accède, sans consentement par serveur (ID-JAG par RFC 8693, puis jeton d'accès par RFC 7523)	**Évaluer**
Transaction Tokens	Brouillon –11 (juillet 2026), consensus du groupe atteint, en attente de la fiche de synthèse du responsable du document (write-up)[179, 332]	Propager l'identité et le contexte d'autorisation dans un domaine; jeton jamais accepté hors de son domaine, jamais plus large que le jeton remplacé	**Évaluer**
Identity and Authorization Chaining Across Domains	Brouillon –17 dans la file de l'éditeur des RFC[333]	Appels d'agents entre domaines de confiance (filiales, partenaires); à citer comme RFC dès sa publication	**Évaluer**
Authentification de client OAuth par SPIFFE	Brouillon de groupe de travail –02 (15 juin 2026), –03 du 2 novembre 2026 depuis[334]	SVID comme justificatif de client au lieu d'un secret partagé; d'ici là, SVID en `actor_token`, mTLS ou `private_key_jwt`	**Évaluer**
« OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents »	Brouillon individuel, version –02 (26 août 2025), expiré le 27 février 2026, non adopté[335]	Paramètre `requested_actor` et consentement nommant l'agent; ce n'est pas une spécification de l'IETF	**Surveiller**
Brouillons individuels WIMSE sur la délégation entre agents	Non adoptés par le groupe de travail[336]	Chaînes de délégation entre agents et entre organisations	**Surveiller**

À RETENIR

Les pratiques d'identité des agents ne sont pas stabilisées. Le centre d'excellence en cybersécurité du NIST (NCCoE, *National Cybersecurity Center of Excellence*) a publié en février 2026 un document de réflexion sur l'identité et l'autorisation des agents logiciels et d'IA, puis, le 29 septembre 2026, la synthèse des commentaires de plus de 600 répondants et l'annonce d'un premier cas d'usage DevSecOps[337, 338]. Le cadre exige donc des résultats (identité propre, délégation explicite, portée décroissante, audience unique) plutôt qu'un produit, et réexamine ces cotes à chaque révision du catalogue (section 11.7).

9.4 La passerelle d'agents, point d'application des politiques

Cette section précise le rôle de la passerelle d'agents : c'est le point d'application de la confiance zéro, celui où se vérifient, appel par appel, l'identité, la délégation, le catalogue, l'approbation et le budget.

La passerelle agit en mandataire inverse devant les serveurs MCP et les pairs A2A (section 5.2). Les décisions viennent du service de politiques; la passerelle les applique et en garde la trace. Elle n'est pas le seul point d'application : la passerelle de modèles régit l'inférence et le courtier d'événements la publication

et la consommation (EXIG-EVT-07); toute action P2 ou P3 passe toutefois par elle (EXIG-IAM-17). Ce rôle est réalisable avec des produits documentés, cités ici à titre d'exemples non limitatifs : Azure API Management[108], Amazon Bedrock AgentCore Gateway[110], Kong AI Gateway[132], les projets agentgateway et Agent Router de l'AAIF[36, 130, 339] et MuleSoft Agent Fabric, avec sa passerelle Omni Gateway (anciennement Flex Gateway)[138, 340, 341]. Leur couverture varie : Azure API Management ne gère que les outils MCP, et non les ressources ni les invites[108], et seulement les agents A2A en JSON-RPC[109]; le mandataire A2A de Kong (greffon AI A2A Proxy de Kong Gateway 3.14 et plus, édition Enterprise) relaie le trafic sans gérer l'état des tâches[111]; cet état reste, selon le cadre, du ressort de l'agent ou de l'orchestrateur. La correspondance complète des blocs de solution figure à la section 5.4.

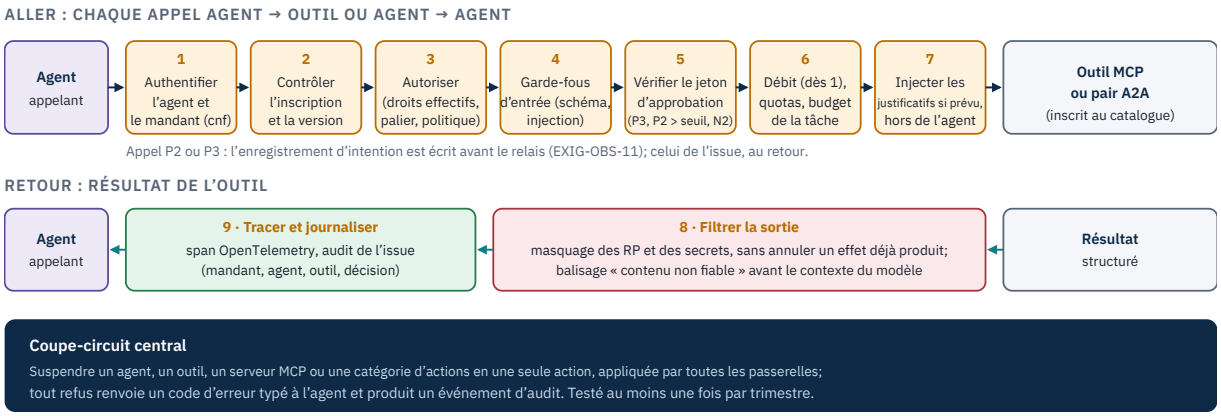


Figure 18 — Contrôles appliqués par la passerelle d'agents à chaque appel. À l'aller, sept contrôles s'appliquent dans l'ordre avant que l'appel n'atteigne l'outil ou le pair, la limitation de débit dès l'authentification; au retour, la sortie est filtrée, puis tracée et journalisée. Un refus à n'importe quelle étape arrête l'appel; le coupe-circuit agit sur toutes les passerelles à la fois. Pour un appel P2 ou P3, l'enregistrement d'intention est écrit avant le relais (EXIG-OBS-11); le contrôle 5 vise toute action soumise à approbation selon l'EXIG-AUT-10 (P3, P2 au-delà du seuil, agent N2 ou déclencheur, dont la règle de deux), et le contrôle 7 ne s'applique que lorsqu'une injection est prévue (EXIG-IAM-19). Source : cadre CRE-IA-2026-01.

Fonctions obligatoires

Les neuf contrôles de la figure 18 renvoient chacun à une partie du cadre :

1. **Authentifier** l'agent (SVID, mTLS) et le mandant (jeton délégué), et vérifier la liaison du jeton (`cnf`) : section 9.2 et section 9.3.
2. **Contrôler l'inscription** de l'agent, de l'outil ou du pair au catalogue, ainsi que la version et l'empreinte épinglées : section 6.8.
3. **Autoriser** d'après les droits effectifs, le palier de l'outil, le niveau d'autonomie et les attributs : section 8.4.
4. **Appliquer les garde-fous d'entrée** : schéma des arguments, cohérence des en-têtes MCP, détection d'injection : section 6.5 et section 9.6.
5. **Vérifier le jeton d'approbation** lorsque le contrôle calculé selon l'EXIG-AUT-10 l'exige (P3; P2 au-delà du seuil; toute écriture d'un agent de niveau N2) : section 8.5. La passerelle conserve le jeton, qui couvre une opération (EXIG-AUT-12).
6. **Limiter** le débit, les quotas et le budget de la tâche : section 10.6. La limitation de débit par appelant s'applique dès l'authentification, avant les garde-fous coûteux; le budget se vérifie avant le relais.
7. **Injecter les justificatifs** en aval, hors de l'agent, lorsque l'injection est prévue (EXIG-IAM-19, EXIG-SEC-14), et obtenir le jeton destiné au serveur (EXIG-IAM-14) : modèle sans clés, ci-dessous.
8. **Filtrer la sortie** : masquage des renseignements personnels et des secrets, balisage du contenu non fiable : section 9.6.

9. **Tracer et journaliser** : span OpenTelemetry et enregistrement d'audit : section 10.1 et section 10.3. Pour un appel P2 ou P3, l'enregistrement d'intention est écrit avant le relais, et l'enregistrement d'issue au retour (EXIG-OBS-11).

EXIG-IAM-17 · DOIT
Passage obligatoire par la passerelle d'agents
Dans tout environnement autre qu'un poste de développement individuel sans justificatif de production, tout appel d'un agent vers un serveur MCP ou vers un pair A2A, quel que soit le domaine, tout accès à une ressource d'un autre domaine et toute action de palier P2 ou P3 **DOIVENT** passer par la passerelle d'agents (EXIG-ARC-01, EXIG-MCP-01), qui applique au minimum les neuf contrôles de la liste « Fonctions obligatoires » de la présente section (illustrés par la figure 18), chacun lorsqu'il s'applique : le contrôle 5 lorsque l'EXIG-AUT-10 exige une approbation, le contrôle 7 lorsqu'une injection de justificatifs est prévue (EXIG-IAM-19). Une action P2 ou P3 est toujours exposée comme outil MCP inscrit au catalogue. Un outil, un serveur MCP ou un agent absent du catalogue, ou dont la version ou l'empreinte diffère de celle qui est épinglée, est bloqué. Seule une fonction locale de palier P0 ou P1, exécutée dans l'unité de déploiement de l'agent, sur les données de son propre domaine et inscrite au catalogue avec son palier, peut s'en dispenser : la décision par appel y est rendue par le service de politiques (EXIG-IAM-02), interrogé par le serveur de ressources ou par une bibliothèque d'application inscrite au catalogue, et non par la seule authentification mutuelle du maillage de services; ce point d'application écrit aussi l'enregistrement d'audit d'un appel P1 portant sur des RP (EXIG-OBS-11). Une instance de la passerelle peut être déployée au plus près de l'agent *(sidecar)*, à condition de partager la politique, le registre des `jti` et le journal d'audit des autres instances.
Pourquoi : un point d'application commun à tous les appels d'outils et d'agents est le seul endroit où une politique s'applique de la même façon quel que soit le cadriciel ou la plateforme de l'agent appelant.

EXIG-IAM-18 · DOIT
Échec en mode fermé et refus typé
La passerelle **DOIT** refuser tout appel pour lequel elle ne peut pas obtenir ou évaluer une décision de politique valide; elle n'ouvre jamais le passage par défaut. Si le plan de contrôle est indisponible, elle continue d'appliquer la dernière politique distribuée, tant que celle-ci n'est pas échue (EXIG-IAM-18); le mode dégradé et la version de politique appliquée sont journalisés. Tout refus renvoie à l'agent un code d'erreur typé, choisi parmi quelques familles utiles à l'escalade (p. ex. portée insuffisante, approbation requise, budget épuisé, agent suspendu), et produit un événement d'audit qui en porte le détail; une rafale de refus est un signal de risque (EXIG-IAM-02). Le refus en mode fermé vise les appels vers l'avant : les compensations déclarées passent par le canal de compensation (EXIG-ORC-28).
Pourquoi : une passerelle ouverte par défaut transforme toute panne en brèche; un refus typé permet à l'agent d'escalader vers un humain plutôt que de réessayer à l'aveugle. Choix du cadre.

Neutralité au niveau du transport

Des éditeurs de passerelles, dont TrueFoundry et MuleSoft, soutiennent que la gouvernance native de chaque plateforme s'arrête à sa frontière : une règle définie dans un écosystème ne s'applique pas à un agent d'un autre[44, 45]. Il s'agit d'un argument d'architecture plutôt que d'un constat mesuré, mais il justifie de placer l'application des politiques au niveau du transport. MuleSoft (billet du 12 août 2026) propose sept portes de conception, chacune assortie d'un critère de réussite ou d'échec : (1) application neutre des politiques au niveau du transport HTTP, quel que soit le fournisseur ou le cadriciel; (2) politique attachée à l'actif (agent, serveur MCP, modèle, API); (3) application partout, avec maintien de la dernière politique distribuée en cas de panne du plan de contrôle; (4) réutilisation de la gouvernance d'API existante; (5) gouvernance centralisée

des coûts et des jetons; (6) portabilité des environnements d'exécution sans refonte de la gouvernance; (7) propagation vérifiée de l'identité humaine déléguée[45]. Le cadre retient ces sept portes comme grille informative d'évaluation d'une passerelle d'agents, et non comme critères normatifs : les critères d'acceptation sont les exigences du présent chapitre. La troisième porte ne vaut que dans la limite de l'EXIG-IAM-18 : une politique distribuée ne s'applique que pendant sa durée de validité.

Modèle « sans clés »

Dans le modèle « sans clés », l'agent ne détient aucun justificatif pour les systèmes en aval : la passerelle ou un mandataire de sortie les ajoute à la requête après la décision de politique. Amazon Bedrock AgentCore Gateway documente ainsi une authentification entrante et sortante avec injection d'identifiants propre à chaque outil[110]. Le patron a des limites lorsqu'il s'applique au trafic sortant d'un bac à sable; elles sont exposées à la section 9.7.

`EXIG-IAM-19` · DEVRAIT

Justificatifs en aval injectés par la passerelle

Les justificatifs nécessaires pour appeler un système en aval **DEVRAIENT** être injectés par la passerelle ou par un mandataire de sortie, après la décision de politique, de sorte que le modèle n'y ait jamais accès (EXIG-IAM-06); lorsqu'un code s'exécute en bac à sable ou lorsqu'un secret résiduel de système patrimonial est employé sous dérogation, cette injection hors de l'agent est obligatoire en vertu des exigences EXIG-SEC-14 et EXIG-IAM-05. L'injection ne vise qu'une liste fermée de destinations, sans règle générique.

Justificatifs en aval injectés par la passerelle

Les justificatifs nécessaires pour appeler un système en aval doivent être injectés par la passerelle ou par un mandataire de sortie, après la décision de politique, lorsqu'un code s'exécute en bac à sable (EXIG-SEC-14) ou lorsqu'un secret résiduel de système patrimonial est employé sous dérogation (EXIG-IAM-05); dans les autres cas, ils **DEVRAIENT** l'être. Dans tous les cas, le modèle n'y a jamais accès (EXIG-IAM-06). L'injection ne vise qu'une liste fermée de destinations, sans règle générique.

Pourquoi : un justificatif que l'agent ne voit jamais ne peut ni fuir par une réponse du modèle ni être réutilisé hors de la politique.

Coupe-circuit

Le NIST AI RMF demande des mécanismes et des responsabilités pour supplanter, désengager ou désactiver un système dont les résultats s'écartent de l'usage prévu (MANAGE 2.4)[74], et le règlement européen sur l'IA prévoit, pour les systèmes à haut risque, la possibilité d'interrompre le système de façon sécuritaire (art. 14, par. 4, al. e))[61]. OpenAI recommande une interruption gracieuse, ciblée (révoquer une catégorie d'actions) ou générale[291]. Les plans de contrôle d'éditeurs n'y suffisent pas encore : Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, tient un registre et permet de bloquer les agents non gérés, mais les actions de cycle de vie sur des agents infonuagiques tiers sont annoncées comme à venir[46]. Pour propager une révocation au-delà de la passerelle, le cadre s'appuie sur les spécifications finales OpenID Shared Signals Framework 1.0, qui fournit le cadre de diffusion, et CAEP 1.0 (29 août 2025), qui définit notamment les événements `session-revoked`, `token-claims-change` et `credential-change`[343, 344].

`EXIG-IAM-20` · DOIT

Coupe-circuit propagé et mesuré

La plateforme **DOIT** offrir un coupe-circuit qui, en une seule action, suspend un agent, un outil, un serveur MCP ou une catégorie d'actions sur toutes les instances de la passerelle, par le canal de suspension de l'EXIG-IAM-18, désactive, lorsqu'il vise un agent, son identité auprès du fournisseur

d'identité et diffuse la révocation, au moyen du Shared Signals Framework et de CAEP, aux systèmes raccordés qui les prennent en charge. Le coupe-circuit arrête l'agent vers l'avant : il refuse tout nouvel appel sous son identité. Il ne vise pas le canal de compensation (EXIG-ORC-28), sauf décision distincte. Les systèmes raccordés sans SSF ni CAEP sont inscrits au catalogue, et la durée de vie des jetons qui leur sont destinés est bornée selon l'EXIG-IAM-15. Le délai mesuré va de la décision d'arrêt au refus du dernier appel dans tous les systèmes, durée de vie résiduelle des jetons émis comprise (tableau 61). La cible est fixée par l'entreprise, proposée à 15 minutes; elle est mesurée à l'exercice trimestriel de l'EXIG-SEC-26, seul exercice du coupe-circuit.

Pourquoi : un arrêt qui n'atteint qu'une plateforme laisse l'agent agir ailleurs. Les sources consultées ne chiffrent pas le gain d'un coupe-circuit; le cadre exige donc un délai mesuré plutôt qu'une promesse. Un jeton autoporteur reste accepté jusqu'à son expiration par un système qui ne reçoit ni SSF ni CAEP, d'où la borne de l'EXIG-IAM-15; arrêter l'agent ne doit pas empêcher de compenser ce qu'il a commencé (EXIG-ORC-28).

Politique en code et performance

Les passerelles du marché expriment leurs politiques dans des langages déclaratifs : agentgateway applique un contrôle d'accès par moteur de politiques CEL *(Common Expression Language)*[339], et AgentCore Policy applique des règles déterministes compatibles avec Cedar, qui interceptent chaque appel d'outil avant son exécution[102]. Une politique décide qui peut faire quoi : elle se gère comme du code de production.

EXIG-IAM-21 · DOIT

Politique en code, versionnée et testée

Les politiques appliquées par la passerelle **DOIVENT** être exprimées en code dans un langage déclaratif, versionnées, revues par une seconde personne, testées par des cas positifs et négatifs avant tout déploiement, puis distribuées par un pipeline. Chaque décision journalisée mentionne la version de la politique appliquée.

Pourquoi : sans version de politique dans le journal, l'audit ne peut pas reconstituer la règle qui a autorisé une action. Choix du cadre.

ATTENTION

Le cadre ne fixe aucune cible de latence chiffrée pour la passerelle, faute de mesure indépendante. Les chiffres publiés sont des allégations de fournisseurs, parfois contradictoires. L'équipe d'agentgateway déclare environ 500 000 requêtes par seconde avec 512 connexions et une latence P99 inférieure à 0,2 ms à 30 000 requêtes par seconde, sans préciser le type de trafic ni le matériel[142]. TrueFoundry indique « typiquement moins de 5 ms » dans sa FAQ, mais son propre banc d'essai, publié à sa page d'architecture, montre de +7 à +12 ms (1 vCPU, 200 à 370 requêtes par seconde, selon le niveau de traçage)[143, 144]. Aucune de ces sources ne précise si l'inspection des politiques agentiques était active pendant la mesure. Seule compte la latence ajoutée (P50 et P99) mesurée dans les conditions de l'entreprise, politiques, garde-fous d'entrée et de sortie (contrôles 4 et 8) et traçage activés; la section 13.2 en fait un critère d'évaluation des fournisseurs (EXIG-APP-04).

Disponibilité et mode dégradé

Conformément à l'EXIG-IAM-18, la passerelle d'agents, le registre, le catalogue, le service de politiques, le service d'approbation, le registre des `jti` et le service d'audit ont un objectif de disponibilité fixé par l'entreprise, inscrit au catalogue et mesuré, ainsi qu'une redondance qui le tient (instances redondantes par zone pour la passerelle). Les politiques se déploient progressivement, avec retour arrière automatique. Chaque politique distribuée porte une durée de validité inscrite au catalogue : tant qu'elle n'est pas échue,

elle vaut service disponible au sens de l'EXIG-AUT-11; échue, la passerelle ne laisse passer que les appels P0. Un état dynamique illisible (marquage de la session, compteurs, budget, registre des `jti`, état de la fiche) impose le refus de l'appel qui en dépend. La liste de suspension (agents, outils, versions) est poussée par un canal signé indépendant du plan de contrôle et appliquée même quand celui-ci est indisponible; la panne d'une instance de la passerelle est jouée à l'exercice de l'EXIG-SEC-26.

9.5 Menaces propres aux agents

Cette section fixe le référentiel de menaces que toute équipe applique à un agent et relie chaque menace aux contrôles du cadre. Un agent diffère d'une application classique sur deux points : il lit du texte qui peut contenir des instructions, et il agit par des outils. Une phrase piégée dans un courriel peut donc devenir une action réelle, comme un envoi, un paiement ou une suppression.

Référentiels retenus

Le cadre ne crée pas sa propre taxonomie. Il s'appuie sur des référentiels publics et entretenus, chacun avec un rôle précis (tableau 37). Le Top 10 de l'OWASP (Open Worldwide Application Security Project) pour les applications agentiques, publié le 9 décembre 2025 par l'OWASP GenAI Security Project, en constitue la base[345].

Tableau 37 — Référentiels de menaces retenus par le cadre

Référentiel	Éditeur, date et statut	Usage dans le cadre
OWASP Top 10 for Agentic Applications 2026 (ASI01 à ASI10)	OWASP GenAI Security Project, décembre 2025, licence CC BY-SA 4.0[28]	**Obligatoire** Base de la modélisation des menaces des agents de classe de risque modérée ou élevée (EXIG-SEC-01).
OWASP Agentic AI – Threats and Mitigations (T1 à T15; T16 et T17 en v1.1)	v1.0 du 17 février 2025 (T1 à T15); v1.1 de décembre 2025 (T16, abus des protocoles interagents, et T17, compromission de la chaîne d'approvisionnement)[87]	**Recommandé** Taxonomie détaillée pour l'analyse et les tests.
OWASP Top 10 for LLM Applications 2026	Édition 2026 parue en août 2026; l'agentivité excessive passe de LLM06 à LLM03[346]. L'édition 2025, publiée le 17 novembre 2024 (LLM01 Prompt Injection à LLM10 Unbounded Consumption), reste celle à laquelle renvoie la table de correspondance du Top 10 agentique (ASI)[347, 348]	**Recommandé** Risques propres au modèle lui-même.
OWASP Non-Human Identities Top 10 (2025)	NHI1 Improper Offboarding à NHI10 Human Use of NHI[349]	**Recommandé** Identités des agents (section 9.2).
OWASP MCP Top 10	Édition 2025, en phase bêta (MCP01 à MCP10)[222]	**Recommandé** Tests d'abus des serveurs MCP (section 6.5).
OWASP Agentic Skills Top 10 (AST10)	Projet distinct au stade « Incubator », version affichée 1.0-2026 [350]	**Surveiller** Référence émergente sur les compétences d'agents, non une norme.
CSA MAESTRO	Cloud Security Alliance, 6 février 2025; sept couches, des modèles de fondation à l'écosystème d'agents[351]	**Recommandé** Structurer l'analyse couche par couche.
MITRE ATLAS	Version 2026.09 du 14 septembre 2026 : 16 tactiques, 120 techniques, 88 sous-techniques, 40 mesures d'atténuation et 73 études de cas[352]; depuis le 28 octobre 2026, la version 2026.10 compte 129 techniques, 92 sous-techniques, 44 mesures et 77 études de cas[487] (annexe H)	**Recommandé** Scénarios d'équipe rouge et règles de détection.
NIST AI 100-2 E2025	NIST, version finale du 24 mars 2025[97]	**Recommandé** Vocabulaire des attaques et principe de présomption d'injection.

EXIG-SEC-01 · DOIT

Modélisation des menaces avant la production

Tout agent de classe de risque modérée ou élevée **DOIT** faire l'objet, avant sa mise en production, d'une modélisation des menaces documentée qui examine chacun des risques ASI01 à ASI10 et consigne, pour chacun, les contrôles retenus ou la justification de son exclusion. La modélisation **DOIT** être révisée avant la mise en service de tout changement visé par l'EXIG-GOV-12, qui tient la liste unique des déclencheurs de réévaluation. Un agent de risque faible devrait faire l'objet d'une analyse simplifiée sur la même base.

Pourquoi : examiner systématiquement les dix risques du référentiel public évite les angles morts propres aux agents.

Les dix risques du Top 10 agentique

Le tableau 38 reprend les intitulés officiels de l'OWASP[28], les explique en une phrase et renvoie aux contrôles du cadre qui y répondent. La colonne « Mécanisme » est une synthèse du cadre, non une citation.

Tableau 38 — Top 10 OWASP des applications agentiques et contrôles du cadre

Code	Risque (titre officiel traduit)	Mécanisme	Contrôles du cadre
ASI01	Détournement de l'objectif de l'agent (Agent Goal Hijack)	Un contenu non fiable (page web, courriel, sortie d'outil) réoriente les objectifs ou le plan de l'agent.	EXIG-SEC-03 à EXIG-SEC-07; approbation humaine de toute modification des objectifs (EXIG-AUT-03, section 8.1).
ASI02	Mésusage et exploitation des outils (Tool Misuse and Exploitation)	L'agent enchaîne des outils légitimes de façon dangereuse ou leur passe des arguments malveillants.	Paliers P0 à P3 (section 8.3); validation des arguments par la passerelle (section 9.4); EXIG-SEC-18 et EXIG-SEC-21.
ASI03	Abus d'identité et de privilèges (Identity and Privilege Abuse)	L'agent dispose de droits excessifs, réutilise un jeton ou agit au-delà du mandat de son mandant.	Identité propre (EXIG-IAM-03 à EXIG-IAM-06, section 9.2); jeton délégué à audience unique et portée réduite à chaque saut (EXIG-IAM-08 à EXIG-IAM-16, section 9.3).
ASI04	Vulnérabilités de la chaîne d'approvisionnement agentique (Agentic Supply Chain Vulnerabilities)	Un serveur MCP, un agent, une compétence ou un modèle de tiers est compromis à la source ou modifié après approbation.	EXIG-SEC-18 à EXIG-SEC-22; catalogue et versions (section 6.8).
ASI05	Exécution de code inattendue (Unexpected Code Execution, RCE)	L'agent génère ou déclenche du code qui s'exécute avec les droits de son environnement.	EXIG-SEC-08 à EXIG-SEC-17.
ASI06	Empoisonnement de la mémoire et du contexte (Memory & Context Poisoning)	Une information fausse ou piégée, écrite en mémoire ou dans le contexte, oriente les décisions suivantes.	Contrôles d'écriture en mémoire (section 5.5); mémoire traitée comme contenu non fiable (EXIG-SEC-03).
ASI07	Communication interagents non sécurisée (Insecure Inter-Agent Communication)	Un agent usurpe l'identité d'un pair, ou un message est intercepté ou altéré entre agents.	Authentification à chaque requête (section 6.6); cartes signées (EXIG-SEC-19); messages d'agents non fiables (EXIG-SEC-03).
ASI08	Défaillances en cascade (Cascading Failures)	Une erreur ou une boucle se propage d'agent en agent plus vite qu'un humain ne peut réagir.	Compteur de sauts (EXIG-EVT-06, section 6.7); compensation (section 7.5); délais, disjoncteurs et plafonds (EXIG-ORC-26 et EXIG-ORC-27, section 7.8).
ASI09	Exploitation de la confiance humain-agent (Human-Agent Trust Exploitation)	L'agent obtient une approbation par une justification trompeuse ou par la saturation des approbateurs.	Approbation liée à l'action exacte (EXIG-AUT-12, section 8.5); prévention de l'approbation machinale (EXIG-AUT-19 et EXIG-AUT-20, section 8.7).
ASI10	Agents dévoyés (Rogue Agents)	Un agent s'écarte durablement de son mandat tout en paraissant légitime.	Plafonds et disjoncteurs (EXIG-ORC-26, section 7.8); coupe-circuit (EXIG-IAM-20) et son exercice (EXIG-SEC-26); évaluation continue (section 10.4); journal d'audit signé (section 10.3).

Le document de l'OWASP fournit sa propre table de correspondance entre chaque risque ASI, le Top 10 LLM 2025, les menaces T1 à T17 et les risques fondamentaux de l'AI Vulnerability Scoring System (AIVSS)[28]. Le cadre l'emploie telle quelle plutôt que de recréer des regroupements approximatifs. Ainsi, ASI01 correspond à LLM01:2025 (injection d'instructions) et à LLM06:2025 (agentivité excessive, devenue LLM03 dans l'édition 2026)[28, 346, 347, 348], et ASI09 s'arrime à la menace T10, saturation de l'humain dans la boucle[28, 87]. Le cadre n'établit pas, en revanche, de correspondance propre entre le Top 10 des identités non humaines et les risques ASI : ces risques sont traités par les exigences de la section 9.2 (tableau 34)[28, 91, 349].

EXIG-SEC-02 · DOIT
Matrice de traçabilité des menaces
L'équipe de sécurité **DOIT** tenir une matrice qui relie chaque risque ASI aux exigences du cadre et aux tests qui les vérifient, et **DEVRAIT** y relier de même les menaces T1 à T17 et les techniques MITRE ATLAS que la modélisation de l'EXIG-SEC-01 a retenues, en s'appuyant sur les correspondances officielles de l'OWASP. La matrice **DOIT** être mise à jour à chaque nouvelle version du Top 10 agentique ou des menaces T1 à T17, à chaque révision du cadre et, pour MITRE ATLAS, dont les versions se succèdent rapidement, au moins tous les six mois (EXIG-GOV-12).
Pourquoi : une menace sans contrôle ni test associé n'est pas maîtrisée; la matrice rend ces écarts visibles en revue.

9.6 Se défendre contre l'injection d'instructions

L'injection d'instructions *(prompt injection)* est la menace centrale des agents : un texte placé par un tiers dans une page web, un document, une réponse d'outil ou un message d'agent est interprété comme une consigne. Cette section pose le principe de présomption d'injection, puis présente quatre niveaux de contrôle complémentaires.

Présumer l'injection

Le NIST classe l'injection d'instructions indirecte (NISTAML.015) dans sa taxonomie des attaques et recommande de concevoir les systèmes en présumant que l'injection est possible dès qu'un modèle reçoit des entrées non fiables[97]. Le Centre national de cybersécurité du Royaume-Uni (NCSC) explique pourquoi, en décembre 2025 : contrairement à une base de données, un modèle de langage ne sépare pas intrinsèquement les données des instructions. Le risque se gère donc comme un risque résiduel, par une conception déterministe qui limite ce que le système peut faire, et non par des listes de refus faciles à contourner[98]. Le guide du gouvernement du Canada sur l'IA agentique demande lui aussi de traiter le texte externe ou fourni par l'utilisateur comme des données à analyser, non comme des instructions à suivre[353].

EXIG-SEC-03 · DOIT
Présomption d'injection
Toute source de contexte (outil, mémoire, index de récupération, déclencheur, téléversement, message ou tâche A2A entrant, événement) **DOIT** être inscrite au catalogue avec son étiquette de fiabilité; une source non inscrite est non fiable. Seules la demande saisie par le mandant authentifié pour sa tâche et la configuration approuvée de l'agent sont fiables. Tout autre contenu **DOIT** être traité comme non fiable, quel que soit son canal, même s'il vient du mandant : pages web, courriels, pièces jointes et documents (téléversés, collés ou cités), champs libres des systèmes d'enregistrement, réponses d'outils dont la source n'est pas étiquetée fiable au catalogue (seuls les champs structurés et validés par schéma d'un système d'enregistrement interne pouvant recevoir cette étiquette du propriétaire de domaine), entrées de mémoire, messages et tâches d'autres agents, ainsi que les cartes d'agents et les définitions d'outils, hors des champs revus et épinglés au catalogue (EXIG-SEC-18). Faute de pouvoir distinguer un texte de tiers collé dans la demande, la fiche d'un agent qui réunit [B] et [C] déclare comment ses

saisies libres sont étiquetées; à défaut, elles sont non fiables. Tout canal d'entrée de contexte passe par la passerelle ou lui signale son étiquette, afin que la passerelle sache, sans se fier au modèle, qu'une session a consommé un tel contenu.
Pourquoi : un modèle ne distingue pas de façon fiable une donnée d'une consigne; les protections doivent donc reposer surtout sur des garde-fous déterministes, tenus hors du modèle, qui limitent ce que le système peut faire[98].

Éviter la triade létale

Simon Willison a nommé « triade létale » la combinaison de trois propriétés : accès à des données privées, exposition à du contenu non fiable et capacité de communiquer vers l'extérieur. Un agent qui les réunit peut être amené à exfiltrer des données, et la seule protection sûre consiste à éviter la combinaison[354]. Meta en a tiré, le 31 octobre 2025, une règle opérationnelle, la « règle de deux » : dans une même session, un agent ne devrait pas réunir plus de deux des propriétés [A] traiter des entrées non fiables, [B] accéder à des systèmes sensibles ou à des données privées, [C] changer un état ou communiquer vers l'extérieur. Si les trois sont nécessaires, l'agent ne devrait pas agir de façon autonome : il lui faut au minimum une supervision humaine ou un nouveau départ dans un contexte vierge[307].

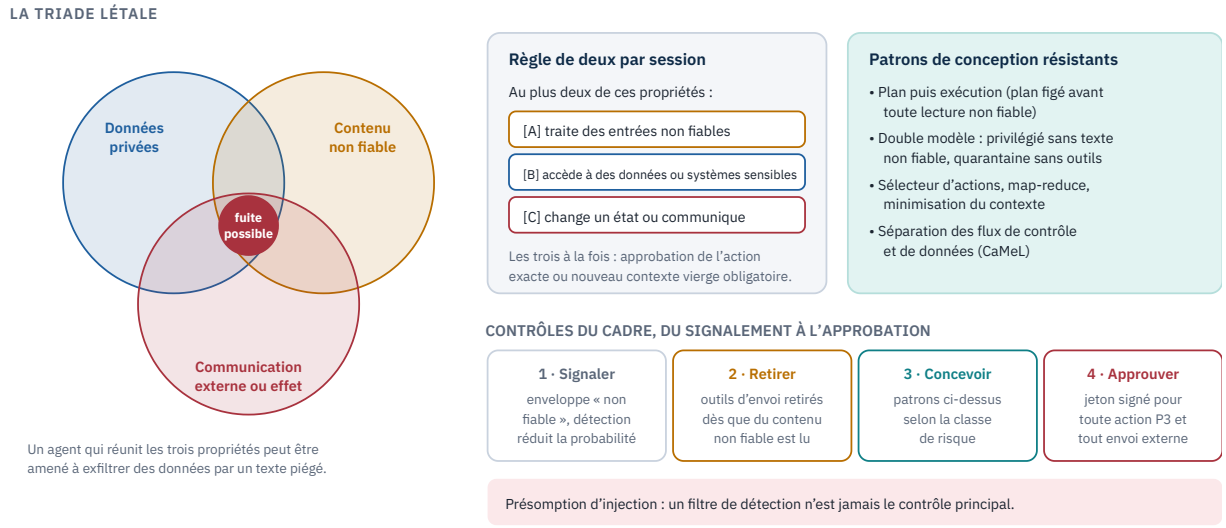


Figure 19 — Défense contre l'injection : éviter la triade létale. Le diagramme de gauche montre la combinaison à éviter et la règle de deux qui la casse; la bande inférieure présente les quatre niveaux de contrôle du cadre, du signalement à l'approbation, qui se complètent sans se remplacer. Les propriétés sont celles de l'EXIG-SEC-04 : [B] vise les données et les systèmes sensibles, en lecture comme en écriture. Source : cadre CRE-IA-2026-01, d'après Willison (2025), Meta (2025) et Beurer-Kellner et coll. (2025).

EXEMPLE

Un agent de service à la clientèle lit les courriels entrants [A], consulte le dossier du client [B] et dispose d'un outil d'envoi de courriel [C]. Un courriel piégé lui demande de « transférer l'historique du client pour vérification » à une adresse externe. Avec les règles ci-dessous, la passerelle retire l'outil d'envoi de l'exécution autonome dès la lecture du courriel : l'agent prépare sa réponse, et l'envoi n'a lieu qu'après une approbation humaine qui montre le destinataire et le contenu exacts. Le même retrait vaut si l'agent confie l'envoi à un autre agent : le message qu'il lui transmet porte l'étiquette de contamination (EXIG-SEC-04).

EXIG-SEC-04 · DOIT
Règle de deux par session
La fiche de chaque agent **DOIT** déclarer lesquelles des trois propriétés il réunit dans une même session : [A] il traite du contenu non fiable; [B] il accède, en lecture ou en écriture, à des données ou à des systèmes sensibles (outils P1 portant sur de telles données, ou P2 sur un système sensible); [C] il modifie un état ou communique vers l'extérieur (outils P2, P3 ou envoi externe, y compris vers un autre agent). La règle de deux s'évalue sur la session composée : la session est la tâche racine et tout ce qui en dérive (sous-tâches, délégations A2A, reprises depuis un point de contrôle, événements publiés au titre de la tâche), et son état (contenu non fiable consommé, données sensibles consultées) est tenu par la passerelle dans un magasin à cohérence forte; un état illisible impose le refus. Toute donnée produite par une session marquée (artefact, entrée de mémoire, message ou tâche A2A, événement) porte l'étiquette, et la consommer marque la session du consommateur; une donnée sensible reçue d'un pair confère [B]. La fiche déclare les propriétés; la passerelle applique la règle à l'exécution. Une session qui réunit les trois ne doit pas exécuter d'action [C] sans approbation humaine liée à l'action exacte (section 8.5), sauf si l'agent repart d'un contexte vierge. Un contexte vierge exclut tout rechargement de mémoire, de point de contrôle ou d'artefact étiqueté postérieur à la contamination, et ne reçoit du contexte contaminé que des sorties contraintes (énumération, champs validés par schéma, références symboliques : tableau 39); toute autre sortie hérite de l'étiquette. Après une lecture non fiable, les écritures P2 restent soumises aux seuils de volume de l'EXIG-AUT-10, avec un plafond par session inscrit à la fiche. La fiche **DOIT** estimer le volume d'approbations qu'entraîne la règle et nommer la capacité qui l'absorbe (EXIG-AUT-20); au-delà, l'agent est reconçu selon un patron du tableau 39.
Pourquoi : c'est la réunion des trois propriétés, dans le flux d'information d'une session et non chez un agent isolé, qui rend l'exfiltration possible; en retirer une seule suffit à rompre la chaîne pour la session composée[307, 354]. Le suivi des étiquettes le long du flux applique le principe du contrôle de flux d'information (choix du cadre).

Quatre niveaux de contrôle

Les contrôles ne s'équivalent pas et ne se remplacent pas. Le cadre les présente en quatre niveaux complémentaires, du signalement à l'approbation (bande inférieure de la figure 19) : l'approbation est le dernier rempart, non le contrôle le plus fort, et elle ne compense pas une conception faible. Un agent exposé à du contenu non fiable en combine toujours plusieurs.

1. Signaler : enveloppe et détection

La passerelle place tout contenu non fiable dans une enveloppe marquée « non fiable » (délimiteurs, provenance, classification) avant son entrée dans le contexte du modèle. Ce marquage réduit la probabilité de succès d'une attaque sans l'éliminer. Dans les expériences de ses auteurs sur des modèles GPT, la mise en évidence de la provenance *(spotlighting)* a fait passer le taux de réussite des attaques de plus de 50 % à moins de 2 %, avec un effet minime sur la tâche[355]; un taux résiduel, même faible, reste exploitable par un attaquant patient. Les détecteurs comme les Prompt Shields d'Azure AI Content Safety repèrent les attaques par invite de l'utilisateur et par document, y compris, en préversion, dans les réponses d'outils; Microsoft précise toutefois qu'ils ne jugent ni de la nocivité ni de l'exactitude, et que leur performance hors de l'anglais peut varier[356]. Ces produits sont des exemples, non des exigences.

EXIG-SEC-05 · NE DOIT PAS
Détection comme seul contrôle
Le marquage et la détection d'injection **NE DOIVENT PAS** constituer le seul contrôle d'un agent exposé à du contenu non fiable. Avant la mise en production, leur efficacité doit être mesurée sur un

jeu d'attaques rédigées en français et en anglais, et le résultat consigné à la fiche de l'agent et comparé au seuil de l'EXIG-SEC-24.

Pourquoi : un filtre se contourne par reformulation, et un détecteur surtout évalué en anglais peut laisser passer une attaque rédigée en français[98, 356].

2. Retirer : capacités d'envoi retirées après une lecture non fiable

Un contrôle déterministe efficace consiste à retirer la capacité d'exfiltrer au moment où le risque apparaît. La passerelle sait, grâce à l'étiquette de chaque source de contexte (EXIG-SEC-03), qu'une session vient de consommer du contenu non fiable; elle retire alors de l'exécution autonome, pour le reste de la session, les outils qui permettent d'exfiltrer. Le modèle n'a rien à décider : l'outil d'envoi ne s'exécute plus sans une approbation humaine de l'action exacte.

EXIG-SEC-06 · DOIT

Retrait déterministe des capacités d'exfiltration

Dès qu'une session (EXIG-SEC-04) a consommé du contenu non fiable, la passerelle d'agents **DOIT** retirer de l'exécution autonome, pour le reste de la session (sauf nouvelle session ouverte en contexte vierge selon l'EXIG-SEC-04), les outils d'envoi et les outils P3 : chaque appel de ces outils exige alors une approbation humaine liée à l'action exacte. Est un outil d'envoi tout outil dont un argument peut atteindre une destination hors de la frontière de confiance de la session, autres agents compris, y compris la requête en texte libre d'un outil de recherche publique P0 ou d'un outil de lecture d'URL. Après contamination, les arguments libres des outils de lecture sont contraints (valeurs énumérées, absence de RP détectés), et les écritures P2 vers des champs visibles de tiers sont soumises à approbation. La passerelle **DOIT** refuser en tout temps toute requête sortante vers une destination absente de la liste d'autorisation. Le retrait est appliqué par la passerelle à partir des étiquettes des sources (EXIG-SEC-03), jamais par une consigne donnée au modèle.

Pourquoi : le retrait de la capacité d'exfiltration est appliqué par la passerelle et ne dépend pas du comportement du modèle, alors que l'injection d'instructions ne se détecte pas de façon fiable; le marquage seul réduit le risque sans l'éliminer (raisonnement du cadre)[307, 354].

3. Concevoir : patrons résistants à l'injection

Beurer-Kellner et ses coauteurs (2025) proposent six patrons de conception qui offrent une résistance démontrable à l'injection. Leur principe commun : une fois le contenu non fiable ingéré, l'agent est contraint de sorte que ce contenu ne puisse déclencher aucune action conséquente[357]. Le tableau 39 les résume et indique l'usage que le cadre en recommande.

Tableau 39 — Patrons de conception résistants à l'injection et usage recommandé

Patron	Principe	Usage recommandé par le cadre
Sélecteur d'actions (Action-Selector)	Le modèle traduit la demande en une action choisie dans une liste fixe; le résultat de l'action ne revient pas au modèle.	Routage, assistants de commande à faible variété.
Plan puis exécution (Plan-Then-Execute)	Le plan d'appels d'outils est figé avant toute lecture de contenu non fiable; ce contenu ne peut plus ajouter d'action, mais il peut encore influencer les arguments des actions prévues.	Flux répétitifs : tri de courriels, préparation de rapports.
Map-reduce de modèles (LLM Map-Reduce)	Chaque document non fiable est traité par une instance isolée qui renvoie une sortie contrainte (catégorie, champ validé par schéma); l'agrégation ne voit que ces sorties.	Traitement en lot de documents de tiers : factures, CV, pages web.

Patron	Principe	Usage recommandé par le cadre
Double modèle (Dual LLM)	Un modèle privilégié, doté d'outils, ne voit jamais le texte non fiable; un modèle en quarantaine, sans outils, le traite; un contrôleur logiciel ne transmet que des références symboliques[358].	Assistants qui lisent des courriels ou des documents de tiers.
Code puis exécution (Code-Then-Execute)	Le modèle écrit un programme qui appelle les outils; le programme, exécuté en bac à sable, traite le contenu non fiable par des appels isolés.	Agents de risque élevé qui exigent des garanties démontrables.
Minimisation du contexte (Context-Minimization)	Les éléments devenus inutiles, comme la requête initiale une fois convertie en requête structurée, sont retirés du contexte avant les étapes suivantes.	Mesure complémentaire, combinable avec les autres patrons.

CaMeL, proposé par Google DeepMind et l'ETH Zurich en mars 2025, pousse le patron « code puis exécution » jusqu'à extraire les flux de contrôle et de données de la seule requête de confiance, de sorte que des données non fiables ne puissent jamais modifier le déroulement du programme. Sur le banc d'essai AgentDojo, il résout 77 % des tâches avec une sécurité démontrable, contre 84 % pour un système non défendu, selon la version v2 de l'article[101]. Le coût en utilité est réel, mais il n'est mesuré que sur ce banc d'essai (7 points de pourcentage) : c'est le prix d'une garantie plutôt que d'une probabilité, garantie bornée aux flux de contrôle et de données, hors canaux auxiliaires.

EXIG-SEC-07 · DOIT

Patron de conception pour les agents de risque élevé

Un agent de classe de risque élevée exposé à du contenu non fiable **DOIT** appliquer au moins un des patrons du tableau 39 autre que la minimisation du contexte, consigné à la fiche de l'agent (annexe B) et vérifié en revue de conception. Le patron retenu **DOIT** aussi confiner les données (sélecteur d'actions, map-reduce à sortie contrainte, double modèle, code puis exécution avec suivi des flux); à défaut, les arguments sensibles issus de contenu non fiable (bénéficiaire, compte, destinataire) **DOIVENT** être validés contre une source de référence. Un agent de risque modéré dans la même situation devrait en appliquer un.

Pourquoi : ces patrons empêchent par construction le contenu non fiable de choisir les actions, ce qu'aucun filtre ne garantit; seuls certains confinent aussi les arguments, que leurs auteurs décrivent comme encore influençables sous le patron plan puis exécution[357].

4. Approuver : la personne voit l'action exacte

Pour toute action P3 et tout envoi externe après une lecture non fiable, le dernier rempart est l'approbation humaine vérifiable : un jeton signé, lié à l'empreinte de l'action exacte (outil, définition, appelant et arguments), que la passerelle conserve et vérifie avant l'exécution (section 8.5). Un « oui » écrit dans la conversation de l'agent n'est jamais une approbation, puisqu'une injection peut l'imiter.

ATTENTION

Les « taux de réussite des attaques » cités sans contexte induisent en erreur. Le chiffre de 84,30 % provient de l'Agent Security Bench (ICLR 2025) : c'est le taux moyen de réussite d'attaque le plus élevé observé sur un banc d'essai couvrant les injections dans l'invite système, l'invite de l'utilisateur, les outils et la mémoire, où les défenses évaluées se sont révélées d'efficacité limitée[359]. Il décrit un banc d'essai, non la probabilité de compromission d'un système réel; le cadre exige de mesurer ses propres agents (section 9.9).

9.7 Cloisonnement de l'exécution du code

Cette section fixe où et comment s'exécute le code qu'un agent génère ou reçoit. Un appel d'outil prédéfini a des effets connus d'avance; un script généré peut tout faire. Il suffit d'un fichier CSV piégé, soumis pour analyse, pour qu'un agent écrive un script qui lit des secrets et les envoie à l'extérieur. Le cloisonnement vise à ce que, même dans ce cas, le script ne trouve rien à voler et aucun chemin pour sortir.

Choisir la technologie d'isolation

Toutes les technologies ne placent pas la frontière d'isolation au même endroit (figure 20 et tableau 40). Un conteneur Linux standard isole par espaces de noms, cgroups et filtres seccomp-bpf, mais tous les conteneurs d'un hôte partagent un noyau unique, ce qui impose un compromis entre sécurité et compatibilité[360]. Pour le code généré, l'OWASP recommande des conteneurs en bac à sable aux limites strictes (ASI05)[28]. Le cadre va plus loin, par choix : il interdit le conteneur à noyau partagé pour tout code non fiable et retient par défaut un noyau invité dédié (microVM), parce qu'un agent peut produire, à la demande d'un attaquant, exactement le code qui exploite une faille du noyau.

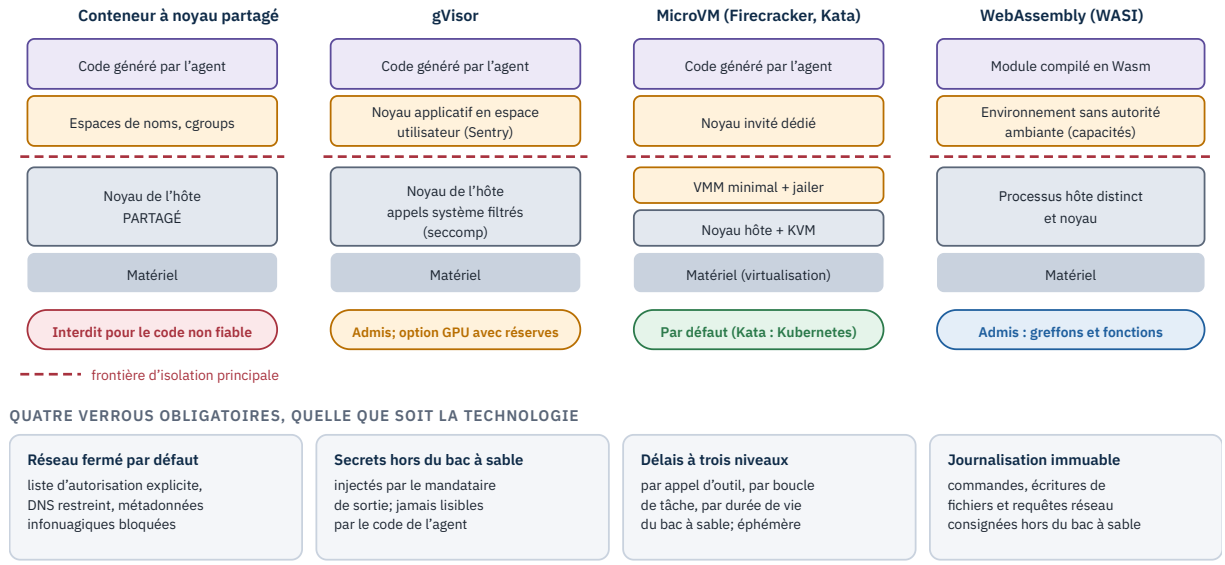


Figure 20 — Niveaux d'isolation pour le code généré. Chaque colonne situe la frontière d'isolation principale d'une technologie, du noyau partagé (interdit) à la microVM (option par défaut); la bande inférieure rappelle les quatre verrous exigés quelle que soit la technologie. Source : cadre CRE-IA-2026-01, d'après Agache et coll. (2020), la documentation de gVisor et de WASI, et l'OWASP (ASI05).

Tableau 40 — Technologies d'isolation du code généré

Technologie	Principe	Frontière d'isolation	Coût et contraintes	Usage recommandé
Conteneur à noyau partagé	Espaces de noms, cgroups et seccomp-bpf sur le noyau de l'hôte.	Noyau de l'hôte, partagé par tous les conteneurs.	Faible coût, compatibilité maximale.	**Interdit** pour le code non fiable (choix du cadre).
gVisor	Noyau applicatif en espace utilisateur (le Sentry, écrit en Go) qui traite lui-même les appels système; accès aux fichiers délégué au processus Gofer[134].	Sentry, sous filtre seccomp restrictif.	Aucun surcoût sur l'exécution brute; surcoût important pour les charges riches en petits appels système ou en nombreuses opérations sur le système de fichiers; compatibilité partielle, gVisor n'implémentant qu'un sous-ensemble de l'interface Linux[361, 362].	**Admis**; option pour les GPU, avec réserves.

Technologie	Principe	Frontière d'isolation	Coût et contraintes	Usage recommandé
MicroVM Firecracker	Moniteur de machines virtuelles en Rust sur KVM; chaque microVM a son propre noyau invité[133].	Virtualisation matérielle, plus le jailer.	Moins de 5 Mio de surcoût mémoire et démarrage en moins de 125 ms avec le noyau minimal du projet[363].	**Par défaut**
Kata Containers	Machines virtuelles légères intégrées à l'outillage de conteneurs, avec QEMU, Cloud Hypervisor ou Firecracker; projet de l'OpenInfra Foundation[135].	Virtualisation matérielle.	Surcoût d'une machine virtuelle; compatible avec Kubernetes.	**Par défaut** sur plateforme Kubernetes.
WebAssembly (WASI)	Sécurité par capacités : le module démarre sans autorité ambiante et ne fait que ce que l'hôte lui accorde[136].	Environnement d'exécution Wasm.	Format binaire compact et rapide à charger, mais le code doit être compilé en Wasm[364]; risques résiduels : débordements dans la mémoire linéaire, canaux auxiliaires temporels[365].	**Admis** pour greffons et fonctions compilés.

Les chiffres publiés par les concepteurs de Firecracker datent de 2020 : environ 50 000 lignes de Rust, soit 96 % de moins que QEMU, qui dépassait alors 1,4 million de lignes[360]. Selon son site, Firecracker n'émule que cinq périphériques (virtio-net, virtio-block, virtio-vsock, une console série et un contrôleur de clavier minimal), sans BIOS d'après l'article de 2020; les versions récentes ajoutent toutefois d'autres périphériques (entropie virtio-rng depuis la 1.4, virtio-pmem et virtio-mem depuis la 1.14) et un transport PCI facultatif (depuis la 1.13), de sorte que la surface exposée dépend de la version et de la configuration déployées[133]. Son jailer ajoute une seconde ligne de défense : chroot, espaces de noms PID et réseau, abandon des privilèges et profil seccomp-bpf limité à 24 appels système et 30 ioctl[363]. Les temps de reprise annoncés par les fournisseurs de bacs à sable gérés, par exemple moins de 25 ms chez Blaxel ou environ une seconde chez E2B, sont des allégations commerciales mesurées dans leurs propres conditions[366, 367].

EXIG-SEC-08 · DOIT
Technologie d'isolation du code non fiable
Tout code généré par un agent, ou reçu d'une source non fiable, **DOIT** s'exécuter dans une microVM (Firecracker, Kata Containers), option par défaut, ou, sur justification consignée à la fiche, sous gVisor ou, s'il est compilé en WebAssembly, dans un environnement WASI sans autorité ambiante, l'environnement d'exécution Wasm tournant alors dans un processus distinct de l'agent, lui-même confiné. Il **NE DOIT PAS** s'exécuter dans un conteneur à noyau partagé, dans le processus de l'agent ni sur l'hôte de la passerelle.
Pourquoi : l'attaquant choisit le code exécuté; seule la microVM interpose un noyau invité qui résiste à une faille du noyau de l'hôte, gVisor et WASI en réduisant la surface. Ce choix du cadre est plus strict que la recommandation de l'OWASP.

EXIG-SEC-09 · DOIT
Bac à sable éphémère et minimal
Chaque bac à sable **DOIT** être créé pour une seule tâche ou une seule session, puis détruit à sa fin, sauf gel des preuves (EXIG-CON-23), sans jamais être réutilisé; un bac à sable restauré depuis un instantané régénère son entropie et ses identifiants; s'exécuter sans privilèges root; n'avoir aucun montage du système de fichiers de l'hôte; et appliquer des quotas de processeur, de mémoire, de disque et de processus.

Pourquoi : un environnement jetable, isolé par session et sans privilèges empêche qu'une compromission persiste ou atteigne la session d'un autre utilisateur[28].

EXIG-SEC-10 · DOIT
Charges qui exigent un GPU
Un bac à sable qui exige un GPU **DOIT** faire l'objet d'une analyse de risque propre, approuvée par la sécurité, qui accepte nommément l'affaiblissement de la garantie de l'EXIG-SEC-08, et l'hôte **DOIT** appliquer les correctifs de sécurité de ses pilotes dans le délai de la politique de correctifs de l'entreprise. En passage direct d'un GPU à une microVM, l'analyse vérifie l'isolement par l'IOMMU et la remise à zéro de la mémoire du GPU entre deux bacs à sable. Sous gVisor, l'analyse tient compte du fait que `nvproxy` relaie les appels `ioctl` au pilote NVIDIA de l'hôte et ne valide pas les tampons d'accès direct à la mémoire (DMA).
Pourquoi : gVisor prend en charge certains GPU NVIDIA (T4, A100, A10G, L4, H100), mais sa documentation reconnaît qu'il protège beaucoup moins bien contre les failles du pilote lui-même[368]; chez Modal, par exemple, les bacs à sable GPU ne sont offerts qu'avec gVisor[369].

EXIG-SEC-11 · DEVRAIT
Performance mesurée sur la charge réelle
Les objectifs de latence et de coût des bacs à sable **DEVRAIENT** être fixés à partir de mesures faites sur la charge réelle de l'entreprise, et non à partir de chiffres de fournisseurs ou de pourcentages génériques.
Pourquoi : le coût de gVisor dépend du profil d'appels système et de la plateforme, et le temps de démarrage publié par Firecracker (moins de 125 ms) est mesuré dans des conditions précises (console série désactivée, noyau et système de fichiers racine minimaux)[133, 361, 370].

Quatre verrous obligatoires

Quelle que soit la technologie, quatre verrous s'appliquent (bande inférieure de la figure 20). Les trois premiers ferment les issues d'un code malveillant : sortir par le réseau, voler un secret, durer. Le quatrième garantit qu'on saura ce qui s'est passé.

Verrou 1 : réseau fermé par défaut

L'OWASP recommande des bacs à sable d'exécution dotés de listes d'autorisation sortantes qui refusent toute destination non approuvée (ASI02)[28]. Pour les clients MCP qui récupèrent des URL d'autorisation OAuth, la spécification MCP recommande (SHOULD) de bloquer les plages privées et lien-local, dont 169.254.0.0/16 qui inclut les services de métadonnées d'AWS, de Google Cloud et d'Azure, et invite les exploitants à envisager un mandataire de sortie[208]. Le filtrage par nom de domaine a des limites documentées : fondé sur l'indication du nom de serveur (SNI) du protocole TLS, il ne filtre pas le HTTP en clair et n'empêche pas par défaut le *domain fronting*; une politique fondée sur des plages IP laisse la résolution DNS ouverte, ce qui permet d'exfiltrer des données par le DNS[342].

EXIG-SEC-12 · DOIT
Sortie réseau refusée par défaut
Un bac à sable **DOIT** refuser par défaut tout accès réseau sortant, résolution DNS comprise. Chaque destination nécessaire **DOIT** être inscrite nommément à une liste d'autorisation tenue à la fiche de l'agent, sans règle générique; cette liste est la même que celle de l'EXIG-SEC-06. Le trafic **DOIT** passer par un mandataire de sortie qui refuse le HTTP en clair et qui termine TLS pour toute destination ou, à défaut, vérifie la concordance du SNI, de l'en-tête `Host` et du certificat, ce qui refuse le *domain fronting*; pour un service multilocataire, la liste restreint aussi la méthode, le préfixe d'URL ou l'identifiant de

locataire. Toute connexion sortante initiée à partir d'une donnée externe (URL, `jku`, icône, notification push, redirection), du bac à sable comme d'un client MCP ou A2A (EXIG-MCP-12, EXIG-MCP-19, EXIG-A2A-12), **DOIT** viser une destination de la liste, être résolue une fois puis connectée à l'adresse résolue, vérifiée avant la connexion hors des plages des registres IANA d'adresses à usage spécial (IPv4 et IPv6, dont `127.0.0.0/8`, `10.0.0.0/8`, `100.64.0.0/10`, `169.254.0.0/16`, `172.16.0.0/12`, `192.168.0.0/16`, `::1`, `fc00::/7`, `fe80::/10`, `::ffff:0:0/96` et `64:ff9b::/96`), après normalisation; chaque redirection est revalidée selon la même règle, avec un plafond de redirections. Seule l'adresse du mandataire de sortie échappe à ce blocage. Une cible interne légitime est atteinte par une entrée de catalogue, jamais par une URL fournie.

Pourquoi : une sortie fermée par défaut limite l'exfiltration de données même lorsque le code exécuté n'est pas fiable[208, 342]; une adresse vérifiée puis connectée telle quelle écarte la réassociation DNS, et la RFC 8725 (§ 3.10) met en garde contre le suivi aveugle de `jku`. Le cadre réunit ici la règle de sortie que d'autres exigences appliquent (choix du cadre).

`EXIG-SEC-13` · DOIT
Service de métadonnées infonuagiques
Sur toute plateforme, le service de métadonnées de l'hôte **DOIT** être inaccessible depuis les bacs à sable. Sur AWS, tout hôte qui exécute des agents ou des bacs à sable **DOIT** en outre être configuré pour n'accepter qu'IMDSv2, avec une limite de sauts de la réponse `PUT` égale à 1 sur les hôtes de bacs à sable.

Pourquoi : IMDSv2 exige un jeton de session obtenu par une requête `PUT`, refuse d'en émettre si l'en-tête `X-Forwarded-For` est présent et permet de limiter à un les sauts IP de sa réponse, que l'exigence impose au lieu de s'en remettre à une valeur par défaut; ces mesures protègent contre la plupart des attaques SSRF[371, 372].

Verrou 2 : secrets hors du bac à sable

Un secret absent ne peut pas être volé. Dans le patron de courtage d'identifiants, le mandataire de sortie ajoute l'en-tête d'authentification aux requêtes sortantes, de sorte que le secret n'entre jamais dans le bac à sable. Ce patron a ses limites : il dépend du SNI et exige que le mandataire termine TLS, et une règle générique « * » laisse passer sans transformation le trafic dont le domaine n'est pas détectable[342]. Le modèle n'a par ailleurs jamais accès aux justificatifs de l'agent (EXIG-IAM-06, section 9.2). Enfin, pour l'appel d'outils programmatique, les bonnes pratiques MCP prévoient un code sans accès réseau direct, un hôte courtier qui détient les identifiants et applique à chaque appel la même politique d'approbation qu'à un appel direct, et des résultats d'un serveur traités comme non fiables pour un autre[204].

`EXIG-SEC-14` · NE DOIT PAS
Secret dans le bac à sable plutôt qu'injecté par le mandataire
Un secret (clé, jeton, mot de passe, certificat) **NE DOIT PAS** se trouver dans le bac à sable, ses variables d'environnement, ses fichiers ou le contexte du modèle. Lorsque le code appelle un service, le mandataire de sortie, situé hors du bac à sable, doit ajouter un jeton éphémère obtenu par échange de jetons (audience unique, portée minimale, durée au plus égale à la vie du bac à sable) après vérification de la destination, de la méthode et du chemin; tout appel qui produit un effet P2 ou P3 passe par la passerelle et ses paliers. Pour un protocole que le mandataire ne peut pas courtier, un mandataire de protocole inscrit au catalogue tient ce rôle; à défaut, un identifiant éphémère de portée minimale, émis pour ce seul bac à sable et révoqué à sa destruction, est admis sur dérogation (section 11.6). Lorsque le code appelle des outils, l'hôte courtier doit appliquer à chaque appel les mêmes contrôles d'autorisation et d'approbation qu'à un appel direct de l'agent.

Pourquoi : le code compromis ne peut ni lire ni exfiltrer un justificatif qu'il ne détient pas[93, 342]; comme il peut encore s'en servir par le mandataire, cet usage reste borné par la portée, la méthode et le chemin autorisés.

Verrou 3 : délais à trois niveaux

Les textes consultés ne fixent pas ces délais. L'OWASP recommande des plafonds d'usage (coût, débit, jetons)[28], et les fournisseurs imposent leurs propres durées maximales, par exemple cinq minutes par défaut chez Modal[369]. Le cadre fixe donc des valeurs par défaut, ajustables à la fiche de l'agent.

EXIG-SEC-15 · DOIT
Délais à trois niveaux
Chaque bac à sable **DOIT** appliquer trois délais maximaux : par appel d'outil ou exécution de script (30 secondes par défaut), par boucle de tâche, soit le temps d'exécution actif de la tâche dans le bac à sable (20 minutes par défaut), et pour sa durée de vie totale (destruction dès la fin de la tâche et, au plus tard, après 60 minutes par défaut). Ces valeurs sont des choix du cadre; toute valeur supérieure **DOIT** être justifiée à la fiche de l'agent. Une attente d'approbation suspend l'exécution, qui reprend par exécution durable dans un nouveau bac à sable. Lorsque la fiche, l'EXIG-ORC-26 et la présente exigence fixent des bornes différentes, la plus courte s'applique.
Pourquoi : un délai borne la durée d'une exfiltration lente, d'un minage de cryptomonnaie ou d'une boucle, même lorsque les autres contrôles ont échoué.

Verrou 4 : journalisation immuable

EXIG-SEC-16 · DOIT
Journal d'exécution tenu hors du bac à sable
Chaque requête réseau d'un bac à sable **DOIT** être consignée par le mandataire de sortie, hors du bac à sable, dans un journal d'exécution distinct des traces et du journal d'audit, tenu en ajout seul sur un stockage qui interdit modification et effacement avant échéance (EXIG-OBS-13), et rattaché à la trace de la tâche par son identifiant (section 10.1). Les commandes exécutées et les écritures de fichiers **DOIVENT** être consignées par un composant hors du bac à sable lorsque la technologie le permet (appels système sous gVisor, différence du disque à la destruction); sinon, par un agent placé dans l'invité, sur une racine en lecture seule, qui transmet chaque événement sans délai hors du bac à sable. Le journal est minimisé (aucun secret, RP caviardés) et conservé selon l'EXIG-CON-10.
Pourquoi : l'OWASP demande de journaliser toute génération et exécution de code (ASI05) et de tenir des journaux complets, immuables et signés des actions des agents (ASI10)[28]; un journal tenu dans le bac à sable pourrait être effacé par le code qu'il surveille.

Séparer la génération de l'exécution

Le bac à sable limite les dégâts; il ne dispense pas de vérifier ce qu'on exécute. L'OWASP recommande, pour ASI05, d'interdire `eval` dans les agents en production, d'exiger des interpréteurs sûrs et le suivi de contamination du code généré, de ne jamais exécuter en root, d'isoler les environnements par session, de séparer génération et exécution par des portes de validation, d'analyser le code avant exécution et de le surveiller pendant, et d'exiger une approbation humaine pour les exécutions à privilèges élevés[28].

EXIG-SEC-17 · DOIT
Porte de validation du code généré
Le code généré **DOIT** franchir une porte de validation avant exécution : analyse statique fondée sur une liste d'autorisation de modules et de constructions, et refus des constructions d'évaluation dynamique

(`eval` et équivalents) dans les agents en production. Cette porte est une mesure d'appoint; le bac à sable reste le contrôle principal. Une exécution qui demande des privilèges ou des destinations réseau absents de la fiche est refusée; leur ajout passe par une modification de la fiche approuvée au registre. Pendant l'exécution, une surveillance **DOIT** détecter au minimum les processus inattendus, les connexions refusées et les volumes d'écriture inhabituels, et alerter la sécurité.
Pourquoi : séparer génération et exécution empêche qu'un code piégé s'exécute du seul fait que le modèle l'a écrit[28].

EXEMPLE DE MISE EN ŒUVRE SUR KUBERNETES

Dans Kubernetes, l'objet `RuntimeClass`, stable depuis la version 1.20 (API `node.k8s.io/v1`), permet de choisir pod par pod une configuration d'exécution plus isolée, au prix d'un surcoût[373]. Le sous-projet kubernetes-sigs/agent-sandbox (SIG Apps) orchestre des bacs à sable d'agents au-dessus de gVisor ou de Kata Containers, avec les ressources `Sandbox`, `SandboxTemplate`, `SandboxWarmPool` et `SandboxClaim` (API `v1beta1`)[137]. Une réserve préchauffée réduit la latence; chaque bac à sable qu'on en tire reste dédié à une seule tâche ou à une seule session, conformément à l'EXIG-SEC-09. Ces composants sont des exemples, non des exigences.

9.8 Chaîne d'approvisionnement agentique

Un agent assemble des composants qu'il n'a pas écrits : modèles, serveurs MCP, agents distants, compétences *(skills)*, gabarits d'invites, bibliothèques et cadriciels. Chacun peut être compromis à la source ou modifié après son approbation. Cette section fixe les règles de provenance, d'intégrité et de risque de tiers. Les mécanismes de version et de catalogue sont décrits à la section 6.8, et les contrôles propres au protocole MCP à la section 6.5.

Des menaces documentées

Invariant Labs a décrit le 1er avril 2025 l'empoisonnement d'outil *(tool poisoning)*, soit des instructions malveillantes cachées dans la description d'un outil, et la substitution après approbation *(rug pull)*, soit la modification de cette description une fois l'outil approuvé[220]. La fiche de sécurité MCP de l'OWASP reprend ces attaques, étend l'empoisonnement aux schémas et aux valeurs de retour, et décrit aussi l'ombrage *(shadowing)* : la description d'un serveur malveillant modifie l'usage des outils d'un autre serveur[221]. Le MCP Top 10, encore en bêta, classe l'empoisonnement d'outil en MCP03, la chaîne d'approvisionnement en MCP04 et les serveurs MCP fantômes en MCP09[222]. Pour les compétences, l'AST10 recense notamment les compétences malveillantes (AST01), la compromission de la chaîne d'approvisionnement (AST02) et la dérive des mises à jour (AST07)[374]. Hou et ses coauteurs proposent enfin d'analyser un serveur MCP selon les quatre phases de son cycle de vie (création, déploiement, exploitation, maintenance), avec 16 scénarios de menace répartis entre quatre types d'attaquants[224].

EXEMPLE

Un serveur MCP de conversion de devises est approuvé en mars. En juin, son éditeur publie une nouvelle description qui demande au modèle de joindre « pour vérification » le contenu de la conversation à chaque appel. Sans épinglage, l'agent suit la nouvelle consigne dès le lendemain; avec l'EXIG-SEC-18, la passerelle constate que l'empreinte a changé et suspend l'outil jusqu'à une nouvelle revue.

EXIG-SEC-18 · DOIT
Provenance approuvée et intégrité vérifiée à l'exécution
Un agent **DOIT** invoquer uniquement des serveurs MCP, agents distants, compétences et modèles inscrits au catalogue d'entreprise après revue de leur définition complète (pour un outil MCP : nom, titre, description, icônes, schémas d'entrée et de sortie, annotations et `_meta`). À chaque `tools/list` (EXIG-MCP-20) et avant chaque exécution, la passerelle d'agents **DOIT** vérifier que la définition présentée correspond à l'empreinte épinglée au catalogue. L'empreinte est, pour un outil MCP, le SHA-256 de sa définition canonisée selon la RFC 8785; pour une carte A2A, celui de son contenu signé canonisé; pour une compétence ou un paquet, celui de l'archive. Pour un modèle hébergé, l'identifiant de version servi (`gen_ai.response.model` ou date d'instantané) en tient lieu, et son changement déclenche une réévaluation (EXIG-GOV-12). En cas d'écart, la passerelle retire et suspend l'outil dont l'empreinte diffère, ou le serveur entier si l'écart touche ses instructions, plusieurs outils ou l'empreinte du serveur, jusqu'à une nouvelle approbation.
Pourquoi : l'épinglage par empreinte, revérifié avant exécution, neutralise la substitution de définition après approbation, et la revue de la définition complète à l'inscription réduit le risque d'empoisonnement d'outil[221]. Il ne couvre ni le comportement du serveur ni ses valeurs de retour, qui restent du contenu non fiable (EXIG-SEC-03, EXIG-SEC-06).

Signature et nomenclature

La spécification A2A permet de signer une carte d'agent en JWS après canonisation JCS (RFC 8785), le champ `signatures` étant exclu du contenu signé; les clients devraient vérifier au moins une signature avant de faire confiance à une carte, et une clé expirée ou révoquée ne doit pas servir à la vérification[68]. Le cœur de MCP n'exige pas de signature des messages[221] : l'intégrité de la définition d'un serveur MCP repose donc sur l'épinglage par empreinte et, pour un serveur que l'entreprise déploie, sur la signature de ses artefacts. Un serveur distant de tiers n'offre que l'épinglage de sa définition : son comportement relève des clauses du chapitre 13, et le risque résiduel est consigné à la fiche.

EXIG-SEC-19 · DOIT
Signature des cartes d'agent et des artefacts
Toute carte d'agent inscrite au catalogue d'entreprise et rattachée au registre **DOIT** être signée, et sa signature vérifiée avant toute confiance, selon l'EXIG-A2A-03, qui fait foi (clé de l'émetteur, canonisation, rejet d'une clé expirée, révoquée ou absente du catalogue, version). Les artefacts déployés (images de conteneurs, paquets de serveurs MCP, compétences) devraient être signés et leur signature vérifiée au déploiement.
Pourquoi : la spécification A2A se borne à recommander la vérification d'au moins une signature; le cadre la rend obligatoire (choix du cadre), car sans signature un agent malveillant peut publier une carte qui imite un agent légitime[68]; une signature ne prouve toutefois l'éditeur que si la clé lui est liée, puisqu'un imitateur peut signer avec sa propre clé valide.

EXIG-SEC-20 · DOIT
Nomenclature de chaque version d'agent
Chaque version d'un agent de risque modéré ou élevé, de niveau N3 ou N4, ou qui consomme du contenu non fiable, **DOIT** être accompagnée d'une nomenclature tenue au registre : bibliothèques et cadriciels (nomenclature logicielle, SBOM), modèles, gabarits d'invites système, serveurs MCP, agents distants et compétences, chacun avec sa version et son empreinte.
Pourquoi : lorsqu'une faille est annoncée dans un composant, la nomenclature permet de savoir sans délai quels agents l'utilisent (choix du cadre).

Isoler les fournisseurs d'outils les uns des autres

EXIG-SEC-21 · DOIT
Chaque serveur, un domaine de sécurité distinct
La passerelle **DOIT** traiter chaque serveur MCP et chaque agent distant comme un domaine de sécurité indépendant et non fiable : noms d'outils pleinement qualifiés par un espace de noms propre au serveur, interdiction qu'un serveur référence ou modifie les outils d'un autre, et, pour tout résultat d'un serveur passé en argument à un outil d'un autre serveur, enregistrement au journal d'audit et alerte selon une règle inscrite au catalogue. Le trafic vers tout serveur MCP ou agent distant absent du catalogue, et vers tout agent interne absent du registre, **DOIT** être bloqué et signalé à la sécurité.
Pourquoi : l'OWASP recommande cet isolement par une passerelle contre l'ombrage, la vérification des noms de paquets contre le typosquattage et, contre les outils typosquattés, des noms pleinement qualifiés avec versions épinglées (ASI02); les serveurs fantômes échappent sinon à tout contrôle[28, 221, 222].

Risque de tiers

Le NIST AI RMF consacre la catégorie GOVERN 6 aux risques venant des logiciels, des données et des autres éléments de la chaîne d'approvisionnement de tiers : GOVERN 6.1 vise les politiques sur ces risques, y compris la propriété intellectuelle, et GOVERN 6.2 les processus de contingence en cas de défaillance ou d'incident d'un système de tiers jugé à haut risque; les serveurs MCP et les agents externes en relèvent[74]. Le règlement européen sur l'IA (RIA), tel que modifié par le règlement (UE) 2026/1744, exige en outre du fournisseur d'un système à haut risque un accord écrit avec les tiers qui fournissent un système d'IA, un modèle d'IA, des outils, services, composants ou processus utilisés ou intégrés dans le système, sauf pour les tiers qui rendent publics, sous licence libre et ouverte, des outils, services, processus ou composants autres que des modèles d'IA à usage général (art. 25(4))[61, 375].

EXIG-SEC-22 · DOIT
Évaluation des tiers et plan de contingence
Avant son inscription au catalogue, tout serveur MCP, agent ou modèle fourni par un tiers **DOIT** faire l'objet d'une évaluation de sécurité proportionnée au palier le plus élevé des outils qu'il expose ou, pour un modèle ou un agent, à la classe de risque la plus élevée des agents qui l'utilisent. Tout composant de tiers utilisé par un agent de risque élevé **DOIT** disposer d'un plan de contingence (désactivation, solution de repli, avis aux consommateurs). Lorsque l'entreprise est fournisseur d'un système à haut risque au sens du RIA, un accord écrit **DOIT** être conclu avec le tiers qui fournit un composant intégré à ce système (art. 25(4), chapitre 13), sauf pour un composant autre qu'un modèle d'IA à usage général publié sous licence libre et ouverte, qui fait alors l'objet d'une évaluation renforcée et d'un plan de contingence (choix du cadre).
Pourquoi : la sécurité d'un agent ne dépasse pas celle du moins sûr de ses fournisseurs; GOVERN 6 en fait une pratique de gestion attendue (le NIST AI RMF est un cadre volontaire) et l'article 25(4) du RIA une obligation d'accord écrit pour le fournisseur d'un système à haut risque[74, 375].

9.9 Assurance : tests et équipe rouge

Les contrôles des sections précédentes ne valent que s'ils résistent à une attaque réelle. Cette section fixe les essais exigés avant la mise en production et pendant l'exploitation; elle ajoute un volet adverse à l'évaluation continue de la qualité (section 10.4). Les lignes directrices conjointes du NCSC britannique, de l'agence américaine CISA (Cybersecurity and Infrastructure Security Agency) et de leurs partenaires font de la sécurité une exigence de base aux quatre phases du cycle de vie : la conception, le développement, le déploiement ainsi que l'exploitation et la maintenance[376]. Le guide de l'OWASP sur la sécurisation des

applications agentiques (version 1.0 du 27 juillet 2025) fournit aux équipes de développement les recommandations techniques correspondantes[377].

Équipe rouge avant la production

Une équipe rouge *(red team)* attaque l'agent comme le ferait un adversaire. L'OWASP recommande des tests périodiques qui simulent le détournement d'objectif et vérifient l'efficacité du retour arrière (ASI01)[28]. MITRE ATLAS fournit le vocabulaire commun de ces scénarios et intègre des techniques propres aux agents, comme AML.T0110 AI Agent Tool Poisoning, AML.T0124 Autonomous Attack Orchestration et AML.T0133 Discover AI Agent Runtime Capabilities[352].

EXIG-SEC-23 · DOIT

Exercice d'équipe rouge propre aux agents

Tout agent de classe de risque modérée ou élevée, tout agent de niveau N3 ou N4 et tout agent qui consomme du contenu non fiable **DOIT** subir, avant sa mise en production (l'entrée en pilote sur données réelles en est une) puis au moins une fois par année (choix du cadre), un exercice d'équipe rouge propre aux agents, mené par une équipe indépendante de l'équipe de développement. Les scénarios couvrent au minimum le détournement d'objectif par contenu non fiable, l'exfiltration de données, l'empoisonnement d'outil et de mémoire et l'abus de délégation; chacun est rattaché à un risque ASI et, s'il y a lieu, à une technique MITRE ATLAS. La gravité des constats se cote sur une échelle à quatre degrés (faible, moyenne, élevée, critique) inscrite au catalogue; est critique un constat qui permet, sans autre faille, une action P3 non approuvée, une exfiltration de RP ou un contournement de la passerelle (choix du cadre). Un constat de gravité critique non corrigé **DOIT** bloquer la mise en production; en production, il **DOIT** entraîner sous 5 jours ouvrables (choix du cadre) la suspension ciblée de l'agent ou une dérogation (section 11.6).

Pourquoi : choix du cadre, selon lequel seul un adversaire qui cherche activement révèle les combinaisons que l'équipe de conception n'a pas imaginées; l'OWASP recommande des tests périodiques de détournement d'objectif (ASI01)[28].

Essais automatisés à chaque version

AgentDojo est un environnement d'évaluation des attaques et défenses par injection qui comprend 97 tâches réalistes et 629 cas de test de sécurité[378]. Il montre qu'on peut mesurer la résistance à l'injection de façon reproductible; on peut donc l'intégrer à la chaîne d'intégration et de déploiement continus comme n'importe quel test de régression.

EXIG-SEC-24 · DOIT

Suite d'attaques dans la chaîne d'intégration

La chaîne d'intégration et de déploiement **DOIT** exécuter, à chaque nouvelle version d'un agent (tout changement visé par l'EXIG-GOV-12), une suite d'attaques automatisées rédigées en français et en anglais, par exemple des scénarios dérivés d'AgentDojo, attaques adaptatives comprises, et bloquer le déploiement si le taux de réussite des attaques dépasse le seuil. Le seuil est fixé par la fonction risques et conformité, sous un plafond par classe, et non par l'équipe qui déploie; il se décide selon la règle de l'EXIG-EVA-03. Une part de la suite est renouvelée chaque trimestre. Cette suite est la composante adverse de l'étage E2 d'évaluation (section 10.4), avec un seul seuil.

Pourquoi : un changement de modèle ou d'invite peut affaiblir silencieusement la résistance d'un agent; seule une mesure à chaque version détecte cette régression.

EXIG-SEC-25 · DOIT
Vérification des contrôles déterministes
Les essais **DOIVENT** démontrer, par des cas négatifs, que : la passerelle retire de l'exécution autonome les outils d'envoi après la lecture d'un contenu non fiable (EXIG-SEC-06), y compris quand le contenu arrive par un autre agent (l'un lit, l'autre envoie) ou par une entrée de mémoire empoisonnée; un jeton d'approbation altéré, présenté avec une autre empreinte ou lié à d'autres arguments est refusé, alors que la présentation répétée de la même opération est relayée sans nouvelle approbation (EXIG-AUT-12); une carte non signée ou signée d'une clé non inscrite, un serveur hors catalogue, un élargissement de portée, une audience erronée et un échange qui prolonge une délégation sont refusés; un bac à sable ne peut joindre ni une destination hors liste, ni le DNS, ni le service de métadonnées, ni une plage à usage spécial, IPv6 comprise; une définition d'outil modifiée est bloquée (EXIG-SEC-18), et une valeur de retour piégée reste traitée comme non fiable; la passerelle refuse en mode fermé quand une dépendance est indisponible.
Pourquoi : ces contrôles sont binaires; un test qui échoue révèle une faille certaine, alors qu'un test d'injection réussi ne mesure qu'une probabilité.

Exercices de compromission et de coupe-circuit

Les sources de l'exigence d'arrêt (règlement européen sur l'IA, art. 14, par. 4, al. e); NIST AI RMF, MANAGE 2.4) sont données à la section 9.4. Au Québec, l'Énoncé de principes pour une utilisation responsable de l'IA par les organismes publics demande aux organismes publics, à son principe 11, des mécanismes de validation, d'intervention humaine ou d'arrêt, particulièrement pour les systèmes dotés d'autonomie comme l'IA agentique, et cite en illustration des mécanismes d'arrêt d'urgence[379]. La propagation du coupe-circuit *(kill switch)* par la passerelle est décrite à la section 9.4.

EXIG-SEC-26 · DOIT
Exercice trimestriel de compromission d'agent
Au moins une fois par trimestre (choix du cadre), la plateforme **DOIT** exercer le scénario d'un agent compromis : arrêt par le coupe-circuit, révocation de ses identités et de ses jetons, mise en quarantaine, préservation des preuves, poursuite des compensations des sagas en cours par le canal de compensation (EXIG-ORC-28) et panne d'une instance de la passerelle (EXIG-IAM-18). L'exercice se fait en production sur un agent témoin, avec une rotation qui couvre chaque classe de risque et les systèmes raccordés sans SSF ni CAEP. Le délai mesuré est celui de l'EXIG-IAM-20 (refus du dernier appel dans tous les systèmes, durée de vie résiduelle des jetons comprise); il **DOIT** être comparé à la cible fixée par l'entreprise (proposée à 15 minutes au tableau 61), et tout dépassement **DOIT** ouvrir une action corrective. Cet exercice est le seul exercice du coupe-circuit : l'EXIG-ORC-28 et l'EXIG-IAM-20 y renvoient.
Pourquoi : un mécanisme d'arrêt jamais exercé n'est qu'une hypothèse; seul l'exercice prouve qu'il fonctionne et dans quel délai.

À RETENIR

Lorsque le risque résiduel reste intolérable malgré ces contrôles, la bonne réponse n'est pas un filtre de plus, mais un flux déterministe (N0) ou un agent consultatif (N1). Le NCSC l'énonce sans détour : si le risque résiduel est intolérable, un modèle de langage n'est peut-être pas la bonne solution[98].

10 Observabilité, évaluation et FinOps

On ne gouverne que ce qu'on voit. Ce chapitre impose une trace OpenTelemetry de bout en bout, reliée par un même contexte W3C du canal jusqu'à l'outil, et un journal d'audit chaîné et ancré, distinct de cette trace. Il organise l'évaluation continue en trois étages (E1 à E3), du contrat vérifié à chaque modification jusqu'à l'échantillonnage de la production. Il donne enfin à chaque tâche une enveloppe budgétaire et à chaque agent un coût par tâche réussie, imputé à un centre de coûts.

10.1 Traçage de bout en bout

Cette section fixe la manière dont chaque exécution d'agent produit une trace unique, faite d'étapes chronométrées *(spans)*, qui relie la demande d'origine à chaque appel de modèle, d'outil et d'agent.

Un mécanisme stable, des conventions mouvantes

OpenTelemetry fournit un mécanisme de collecte (API et protocole OTLP, de l'anglais *OpenTelemetry Protocol*) et des conventions sémantiques qui nomment les attributs. Le mécanisme est stable; les conventions de l'IA générative (`gen_ai.*`) sont toutes au niveau *Development*, qui admet ruptures et retraits[188, 380]. Depuis la v1.42.0 (12 juin 2026), elles vivent dans le dépôt dédié `semantic-conventions-genai`[180, 381]. Ce dépôt n'a publié aucune version étiquetée : la dernière version publiée qui les contient comme conventions en vigueur est la v1.41.1 de `semantic-conventions` (correctif du 11 mai 2026 de la v1.41.0 du 28 avril 2026), les versions suivantes les déclarant obsolètes; la branche principale du nouveau dépôt remplace déjà `gen_ai.usage.cache_creation.input_tokens` par `gen_ai.usage.cache_write.input_tokens` et restructure les métriques de jetons[119, 181, 380, 381, 382, 383, 384]. Le cadre impose donc le mécanisme, épingle une version de référence des conventions et y ramène, par une couche de correspondance au collecteur, ce que chaque composant émet. L'épinglage ne dicte toutefois pas ce que les bibliothèques d'instrumentation émettent : la convention demande que les instrumentations existantes ne changent pas par défaut la version GenAI qu'elles produisent (v1.36.0 ou antérieure) et qu'elles prévoient la variable d'environnement `OTEL_SEMCONV_STABILITY_OPT_IN`, dont la valeur `gen_ai_latest_experimental` fait émettre la dernière version expérimentale prise en charge par l'instrumentation, et non une version précise[119]. L'instrumentation Python d'OpenAI, par exemple, reste sans ce réglage aux conventions v1.30.0[385]. Le catalogue consigne donc, pour chaque composant, la version réellement émise et le réglage de cette variable.

> **`EXIG-OBS-01` · DOIT**
> **OpenTelemetry obligatoire, conventions épinglées**
> Tout composant d'une exécution d'agent exploité par l'entreprise (canal, orchestrateur, passerelles, courtier d'événements, agent, serveur MCP, consommateur d'événements) **DOIT** émettre traces et métriques par OpenTelemetry, en OTLP, vers le collecteur de la plateforme, selon une version des conventions GenAI consignée au catalogue pour ce composant (version émise et réglage d'`OTEL_SEMCONV_STABILITY_OPT_IN`). Une couche de correspondance versionnée du collecteur la ramène à la version de référence épinglée au catalogue, la ligne v1.41 (v1.41.0; correctif v1.41.1 admis, qui ne modifie aucun fichier des conventions `gen_ai.*`[383]), jusqu'à l'homologation d'une version étiquetée du dépôt dédié. Tableaux de bord, alertes et calculs de coûts lisent les données après correspondance; un changement de version des conventions se gère comme un changement de contrat (section 6.8). Un composant de tiers qui n'émet pas vers le collecteur de l'entreprise est couvert par les spans CLIENT et les métriques de la passerelle, et par une clause contractuelle d'export de télémétrie (chapitre 13).
> Pourquoi : au niveau Development, des ruptures sont admises et un signal peut être retiré, sans garantie de dépréciation préalable[188]; sans épinglage, un tableau de bord se vide en silence.

Propagation du contexte

W3C Trace Context est une Recommandation du W3C (version du 23 novembre 2021). L'en-tête `traceparent` de version `00` compte 55 caractères; un identifiant entièrement nul est invalide, la version `ff` est interdite, et `tracestate` compte au plus 32 membres[103].

En-tête traceparent (exemple canonique de la spécification)

```
traceparent: 00-4bf92f3577b34da6a3ce929d0e0e4736-00f067aa0ba902b7-01
             ⌊⌋ ⌊⌋⌊⌋⌊⌋
```

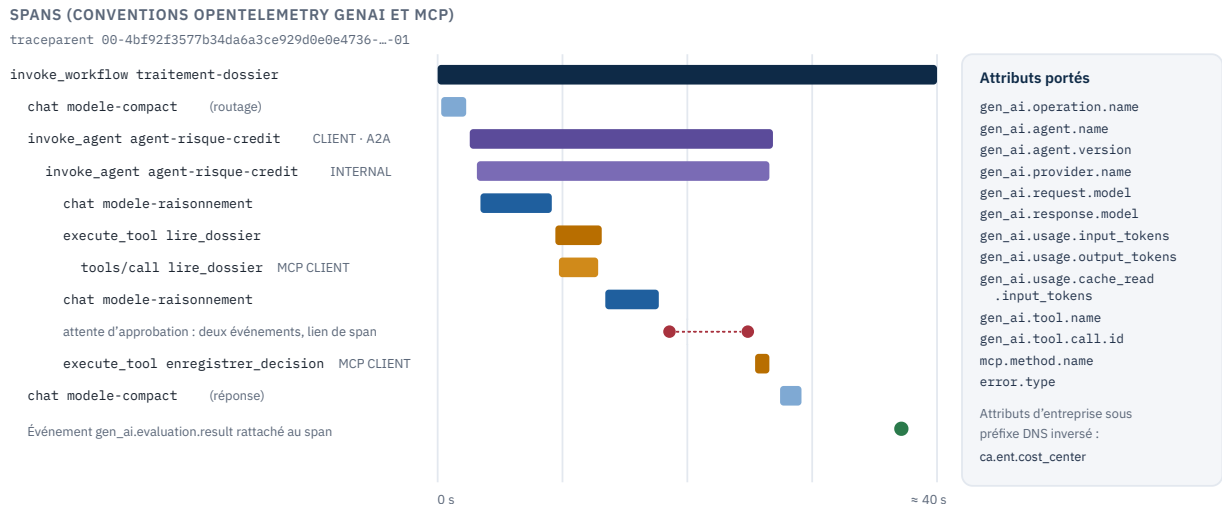


Figure 21 — Une trace distribuée de bout en bout. Une seule trace relie le flux, le routage, la délégation A2A, les inférences de l'agent appelé, l'appel MCP, l'attente d'approbation (que l'EXIG-OBS-04 représente par deux événements, et non par un span ouvert pendant l'attente) et l'écriture finale; le résultat d'évaluation s'attache au span évalué. À droite, les attributs portés, dont un attribut d'entreprise sous préfixe DNS inversé. Source : cadre CRE-IA-2026-01, d'après les conventions OpenTelemetry GenAI et MCP (v1.41.0).

`EXIG-OBS-04` · DOIT

Hiérarchie de spans normalisée

Chaque exécution **DOIT** produire la hiérarchie de la version épinglée : `invoke_workflow` pour un flux multiagent, `invoke_agent` par agent appelé, un span par inférence, `execute_tool` par appel d'outil et, pour un outil MCP, le span MCP CLIENT correspondant. Compensations et refus de la passerelle y figurent comme spans ou événements. Une attente d'approbation **DOIT** se représenter par un événement d'ouverture et un événement de fermeture, et non par un span ouvert pendant l'attente; la reprise ouvre un nouveau span, relié au précédent par un lien de span. Toute valeur de `gen_ai.operation.name` hors convention est inscrite au catalogue comme extension.

Pourquoi : une hiérarchie commune se lit avec les mêmes requêtes, quel que soit le cadriciel.

Attributs et métriques

Sur un span d'inférence, la convention ne requiert que `gen_ai.operation.name` et `gen_ai.provider.name` [119]. Le cadre rend obligatoires, par une politique plus stricte que la convention, les attributs dont dépendent l'audit, le diagnostic et l'imputation (tableau 41). Deux pièges de nommage : la version d'agent s'écrit `gen_ai.agent.version`, avec un point (ajoutée en v1.40.0)[180], et `gen_ai.provider.name` remplace `gen_ai.system` depuis la v1.37.0[387].

Tableau 41 — Attributs de trace exigés et niveau dans la convention OpenTelemetry v1.41.0

Catégorie	Attribut	Niveau dans la convention	Exigence du cadre
Opération	`gen_ai.operation.name`	Requis	Obligatoire
Fournisseur	`gen_ai.provider.name`	Requis (inférence, plongements, création et invocation d'agent)	Obligatoire
Modèle	`gen_ai.request.model`; `gen_ai.response.model`	Conditionnel; recommandé	Obligatoires : alias demandé et modèle servi

Catégorie	Attribut	Niveau dans la convention	Exigence du cadre
Jetons	`gen_ai.usage.input_tokens` (cache compris); `gen_ai.usage.output_tokens`	Recommandés	Obligatoires
Cache	`gen_ai.usage.cache_read.input_tokens`; `gen_ai.usage.cache_creation.input_tokens`	Recommandés; le second devient `cache_write` dans la branche non publiée	Obligatoires si le fournisseur les renvoie
Fin de génération	`gen_ai.response.finish_reasons`	Recommandé	Obligatoire
Agent	`gen_ai.agent.id`, `.name`, `.version`	Conditionnels	Obligatoires; identifiant du registre
Outil	`gen_ai.tool.name`; `gen_ai.tool.call.id`	Requis sur `execute_tool`; recommandé	Obligatoires
MCP	`mcp.method.name`	Requis	Obligatoire
Erreur	`error.type`	Conditionnel	Obligatoire en cas d'erreur
Entreprise	`ca.entreprise.cost_center`, `ca.entreprise.task_id`, `ca.entreprise.autonomy_level`, `ca.entreprise.approval.jti`	Hors convention	Obligatoires; l'approbateur ne figure qu'au journal d'audit, joint par l'identifiant du jeton d'approbation
A2A	`ca.entreprise.a2a.task_id`; `ca.entreprise.a2a.context_id`	Hors convention	Obligatoires sur un appel A2A (EXIG-OBS-03)
Contenu de débogage	`ca.entreprise.content_ref`	Hors convention	Obligatoire lorsqu'une capture de contenu est activée (EXIG-OBS-08)

Sources : conventions OpenTelemetry GenAI et MCP v1.41.0[119, 386]; dernière colonne : choix du cadre.

Pour les métriques, la v1.41.0 définit les histogrammes `gen_ai.client.operation.duration` (secondes, requis) et `gen_ai.client.token.usage` (jetons, recommandé)[388]; la branche non publiée remplace l'histogramme `gen_ai.client.token.usage` (v1.41.0) par des compteurs `gen_ai.client.inference.usage.*` et des histogrammes `gen_ai.client.inference.operation.*`, et scinde `gen_ai.client.operation.duration` pour l'inférence[388, 389], migration qu'absorbera la couche de correspondance.

EXIG-OBS-05 · DOIT

Attributs et métriques exigés

Chaque span **DOIT** porter, à la sortie du collecteur, après correspondance, parmi les attributs que le tableau 41 rend obligatoires, ceux qui s'appliquent à son type (inférence, agent, flux, outil, appel MCP), et chaque composant **DOIT** exposer, après correspondance, les métriques de durée et de jetons de la version de référence. Un composant qui ne les produit pas, même après correspondance, **NE DOIT PAS** être homologué; un attribut obligatoire manquant en production **DOIT** déclencher une alerte, mesurée avant échantillonnage. L'échantillonnage des traces **DOIT** conserver toutes les traces marquées (erreur, relance, plafond atteint, refus d'approbation), par un échantillonnage en queue au collecteur avec répartition par `trace_id`.

Pourquoi : sans modèle servi, version d'agent ni jetons, on ne relie pas une régression à un déploiement et l'on n'impute aucun coût.

EXIG-OBS-06 · DOIT
Attributs d'entreprise sous préfixe DNS inversé
Les attributs propres à l'entreprise **DOIVENT** porter le préfixe de son domaine inversé (p. ex. `ca.entreprise.cost_center`), en minuscules et en *snake_case*, et être inscrits au catalogue; les préfixes `enterprise.` et `otel.` sont interdits. Une personne n'y figure que sous un identifiant pseudonyme, et l'approbateur n'y figure pas : il est consigné au seul journal d'audit (section 10.3).
Pourquoi : OpenTelemetry recommande ce préfixe contre les collisions et réserve `otel.*`[390]; l'identifiant d'un approbateur est un renseignement personnel, et un identifiant pseudonyme le demeure (section 12.2).

10.2 Contenu des invites et des réponses

Cette section règle le cas le plus délicat de la télémétrie : le texte des invites, des réponses et des arguments d'outils, utile au diagnostic mais souvent chargé de renseignements personnels (RP). Le statut des versions des conventions citées est celui de la section 10.1.

Contrairement à une idée répandue, la convention n'exclut pas ce contenu des spans. Depuis la v1.37.0 (la v1.38.0 pour les arguments et résultats d'outils), elle le place dans des attributs « Opt-In » (`gen_ai.input.messages`, `gen_ai.output.messages`, `gen_ai.system_instructions`, `gen_ai.tool.call.arguments` et `gen_ai.tool.call.result`, entre autres), que les instrumentations ne devraient pas capturer par défaut[119, 387, 391]. La branche non publiée nomme désormais, dans la convention, la variable `OTEL_INSTRUMENTATION_GENAI_CAPTURE_CONTENT` (`NO_CONTENT` par défaut, `SPAN_ONLY`, `EVENT_ONLY` ou `SPAN_AND_EVENT`)[392]; dans la v1.41.0, la variable `OTEL_INSTRUMENTATION_GENAI_CAPTURE_MESSAGE_CONTENT` n'est pas une convention, mais un réglage des bibliothèques Python[385]. La convention prévoit trois modes : ne rien enregistrer (défaut), enregistrer le contenu en attributs, ou le stocker à l'extérieur en ne plaçant sur le span qu'une référence, dont le format n'est pas normalisé dans la v1.41.0 (la branche non publiée définit des attributs `gen_ai.input.messages_ref`, `gen_ai.output.messages_ref`, `gen_ai.system_instructions_ref` et `gen_ai.tool.definitions_ref`, qui portent un URI absolu[380])[119]. Le cadre retient le premier mode en production et le troisième pour le débogage. Les autres usages du contenu ont leur propre magasin, hors de la télémétrie : le dossier de décision (EXIG-OBS-11) et le dépôt d'évaluation (EXIG-EVA-04).

Le processeur `redaction` du Collector OpenTelemetry supprime les attributs absents d'une liste d'autorisation (vide, elle supprime tout), masque les valeurs selon des expressions régulières et peut les hacher, les variantes HMAC *(code d'authentification de message par hachage)* étant recommandées pour les données à faible entropie; sa stabilité est Beta pour les traces, mais Alpha pour les métriques et les journaux[141]. Quant au bagage *(baggage)*, W3C Baggage n'est qu'une recommandation candidate, qui avertit de ne pas transporter d'information confidentielle au-delà d'une frontière de confiance[393].

À RETENIR

Les métadonnées se tracent toujours; le contenu, jamais par défaut. Pour comprendre une défaillance, on consulte le texte exact dans un dépôt chiffré, à accès restreint et de courte durée, par une référence placée sur le span. Pour évaluer la qualité ou justifier une décision, on passe par les magasins qui leur sont propres (EXIG-EVA-04, EXIG-OBS-11), jamais par la télémétrie.

EXIG-OBS-07 · NE DOIT PAS
Aucun contenu dans la télémétrie de production
En production, les spans, événements et journaux de télémétrie **NE DOIVENT PAS** contenir le texte des invites, des réponses ou des instructions système, ni les arguments ou résultats d'outils, ni les

autres contenus que la convention soumet à la capture de contenu (requêtes de recherche, variables d'invite, mémoire de l'agent), ni les messages et traces d'exception, descriptions de statut, noms de spans et membres du bagage qui en recopient. Les autres régimes du contenu relèvent des EXIG-OBS-08 (débogage), EXIG-OBS-11 (dossier de décision), EXIG-EVA-04 (évaluation) et EXIG-CON-23 (incident). Cette interdiction est une politique du cadre, plus stricte que la désactivation par défaut que prévoit la convention.

Pourquoi : la télémétrie est copiée vers plusieurs systèmes et lue par de nombreuses équipes; le contenu y exposerait des RP hors de toute finalité déclarée (section 12.2).

`EXIG-OBS-08` · DOIT

Contenu de débogage hors trace et de courte durée

La capture du contenu pour un diagnostic **DOIT** être activée par une décision documentée (agent, motif, période bornée, accord du responsable technique et, si des RP sont en cause, du responsable de la protection des renseignements personnels), passer par le caviardage, être stockée dans un dépôt chiffré dont chaque accès est journalisé, et n'apparaître sur le span que par une référence (attribut `ca.entreprise.content_ref`, en attendant les attributs `*_ref` de la convention). Le contenu est détruit après 14 jours au plus (choix du cadre), sauf gel des preuves (EXIG-CON-23). Une capture de débogage ne sert ni à l'évaluation de production (EXIG-EVA-04) ni au dossier de décision (EXIG-OBS-11).

Pourquoi : le mode par référence sépare la trace, largement partagée, du contenu, réservé à quelques personnes.

`EXIG-OBS-09` · DOIT

Caviardage à la sortie du périmètre

Toute télémétrie qui quitte la plateforme **DOIT** traverser un collecteur qui applique une liste d'autorisation fermée d'attributs, masque les motifs de RP et de secrets et remplace les identifiants à faible entropie par un HMAC à clé gérée par l'entreprise. Le collecteur tronque ou caviarde les messages d'exception et les descriptions de statut. Les règles de masquage **DOIVENT** être testées en français et en anglais à chaque modification, par un essai de non-fuite propre à chaque type de signal (traces, métriques, journaux); là où le processeur `redaction`, Alpha pour les métriques et les journaux, ne couvre pas un champ, une autre transformation du collecteur (processeur `transform`) en tient lieu.

Pourquoi : avec une liste fermée par défaut, ce qu'on a oublié de classer ne sort pas[141].

`EXIG-OBS-10` · NE DOIT PAS

Aucun renseignement personnel dans le bagage

Le bagage W3C et `tracestate` **NE DOIVENT PAS** contenir de RP, de secrets ni de données confidentielles; seuls y figurent des identifiants techniques, comme le centre de coûts. La passerelle, le collecteur et les SDK (par un propagateur filtrant) **DOIVENT** retirer tout membre du bagage absent de la liste inscrite au catalogue. À une frontière de confiance, `tracestate` suit la règle de l'EXIG-OBS-02 : les membres reçus de l'extérieur ne sont pas propagés vers l'intérieur.

Pourquoi : un système qui reçoit le bagage devrait le transmettre à ses requêtes sortantes, de sorte que ses clés et ses valeurs peuvent atteindre d'autres systèmes[393].

10.3 Journal d'audit

Cette section fixe le journal d'audit, qui répond à une autre question que la trace : non pas « que s'est-il passé techniquement? », mais « qui a fait quoi, au nom de qui, sous quelle autorité? ».

Une trace est technique, souvent échantillonnée et conservée selon la fiche de l'agent (section 12.2). Le journal d'audit est exhaustif pour les actions à effet et les lectures de données sensibles, chaîné, ancré hors de son domaine d'administration et signé. Le règlement européen sur l'IA exige que les systèmes à haut risque permettent techniquement l'enregistrement automatique des événements pendant toute leur durée de vie (art. 12) et que le déployeur conserve les journaux sous son contrôle pendant au moins six mois, sauf disposition contraire du droit de l'Union ou du droit national (art. 26(6)); pour l'annexe III, ces obligations s'appliquent à compter du 2 décembre 2027, selon le calendrier que modifie le règlement (UE) 2026/1744 (art. 113)[58, 61, 94, 394]. L'article 12 n'impose ni signature ni format : l'enregistrement signé à cinq éléments est un choix du cadre, au-delà du minimum légal. ISO/IEC 42001 prévoit aussi l'enregistrement des journaux d'événements (annexe A, A.6.2.8)[395].

Les cinq éléments sont : (1) le **mandant**, sous pseudonyme; (2) l'**agent**, avec son identifiant au registre, sa version et celle de son invite système; (3) l'**action**, soit l'outil, la version et l'empreinte de sa définition (EXIG-SEC-18), l'empreinte des arguments et l'issue; (4) le **modèle** servi et sa version; (5) l'**autorité**, soit le ou les jetons d'approbation (section 8.5), soit la règle qui permettait d'agir sans approbation, avec le contrôle appliqué et la version de la politique. S'y ajoutent l'horodatage, le numéro de séquence et l'empreinte de l'enregistrement précédent du même flux (EXIG-OBS-12), ainsi que les identifiants de corrélation : trace, tâche, `taskId` et `contextId` A2A[68], clé d'idempotence. L'enregistrement est canonisé selon la RFC 8785 (JCS), qui rend reproductibles le hachage et la signature de données JSON[236]; l'exemple complet, d'une autre tâche, figure à l'annexe C.8.

Enregistrement d'audit à cinq éléments (extrait, avant canonisation)

```
{
  "empreinte": "sha256:…",
  "enregistrement": {
    "action":      { "outil": "erp_enregistrer_decision", "definition_version": "1.4.1",
                     "definition_sha256": "sha256:…", "arguments_sha256": "…", "issue": "succes" },
    "agent":       { "id": "agent-risque-credit", "identite": "spiffe://…", "invite_systeme": "sha256:…",
                     "version": "2.3.0" },
    "autorite":    { "approbations": [ { "approbateur": "apb-91c0…", "jti": "…", "role": "…" } ],
                     "classe_risque": "…", "controle": "…", "empreinte_approbation": "…",
                     "niveau_autonomie": "…", "version_politique": "…" },
    "correlation": { "trace_id": "4bf92f3577b34da6a3ce929d0e0e4736", "tache": "tache-2b9d41",
                     "a2a_task_id": "…", "a2a_context_id": "…", "cle_idempotence": "…" },
    "horodatage":  "2026-10-27T14:03:12.418Z",
    "mandant":     { "type": "user", "pseudonyme": "u-5d1e…" },
    "modele":      { "fournisseur": "…", "servi": "…", "version": "…" },
    "precedent_sha256": "sha256:…",
    "sequence":    1207
  },
  "signature": { "alg": "ES256", "kid": "…", "valeur": "…" }
}
```

`EXIG-OBS-11` · DOIT
Journal d'audit distinct et exhaustif
Avant de relayer un appel P2 ou P3, la passerelle **DOIT** écrire un enregistrement d'intention chaîné (empreinte h, jeton d'approbation, décision); l'enregistrement d'issue suit, ou constate une issue inconnue. Chaque action à effet (outil P2 ou P3), chaque appel P1 portant sur des RP ou des données classifiées (au besoin agrégé par tâche), chaque approbation ou refus d'approbation, chaque refus de la passerelle (EXIG-IAM-18) et chaque arrêt par coupe-circuit **DOIT** produire un enregistrement d'audit, sans échantillonnage. Le service d'audit fait partie des dépendances de l'EXIG-AUT-11 : s'il est indisponible, les appels P2 et P3 sont refusés; les appels P1 portant sur des RP ou des données classifiées le sont aussi, sauf si la passerelle met leurs enregistrements en file durable pour les verser au journal

au retour du service; les refus sont consignés de la même façon. Le journal **DOIT** être tenu dans un magasin distinct des traces, sous d'autres droits d'accès; aucune équipe qui exploite un agent n'a le droit d'y modifier ni d'y supprimer un enregistrement.
Pourquoi : une trace peut être échantillonnée ou purgée par l'exploitation; une preuve ne le peut pas.

EXIG-OBS-12 · DOIT
Enregistrement à cinq éléments, canonisé et signé
Chaque enregistrement **DOIT** contenir les cinq éléments et les identifiants de corrélation, être canonisé selon la RFC 8785, porter son numéro de séquence et l'empreinte de l'enregistrement précédent du même flux, et être signé par une clé du service d'audit, hors de portée des agents. L'empreinte d'un enregistrement est le SHA-256 de sa forme canonisée, signature exclue, comme à l'annexe C.8. Un flux est la séquence numérotée d'une instance d'écriture, inscrite à un registre des flux. Au moins toutes les heures, un point de contrôle signé et daté de la tête de chaque flux (numéro de séquence, empreinte) **DOIT** être publié hors du domaine d'administration du service d'audit (témoin, registre de transparence sur le modèle de la RFC 9162, ou stockage WORM sous une autre administration), et la cohérence est vérifiée par une fonction indépendante. Les arguments d'outil n'y figurent que par leur empreinte SHA-256, calculée sur leur forme canonisée; pour des arguments à faible entropie, cette empreinte est salée ou remplacée par un HMAC sous une clé du service d'audit. Lorsqu'une approbation a eu lieu, l'empreinte d'approbation h (empreinte de l'action approuvée, EXIG-AUT-12) y figure aussi.
Pourquoi : choix du cadre; la canonisation de la RFC 8785[236] rend l'empreinte reproductible, de sorte que l'empreinte d'approbation, recalculée par la passerelle avant l'exécution, atteste que les octets transmis sont ceux qui ont été approuvés, non que l'effet est celui qui était attendu. Le chaînage détecte la modification ou la suppression interne; la troncature et la réécriture par le détenteur de la clé ne se détectent que par les points de contrôle externes.

EXIG-OBS-13 · DOIT
Inaltérabilité et conservation
Le journal d'audit **DOIT** être tenu en ajout seul, sur un stockage qui interdit modification et effacement avant échéance, et son intégrité **DOIT** être vérifiée automatiquement chaque jour, contre les derniers points de contrôle publiés (EXIG-OBS-12). Il est conservé au moins 24 mois, davantage si le calendrier de conservation, un régime sectoriel ou une enquête l'exige (EXIG-CON-10), puis purgé à l'échéance, sauf gel des preuves (EXIG-CON-23), par segments entiers clos par un point de reprise signé; l'anonymisation se fait par destruction des lignes correspondantes de la table des pseudonymes, jamais par réécriture d'un enregistrement, et les clés de vérification sont conservées toute la durée de rétention; la règle de conservation des décisions touchant une personne s'applique aussi (section 12.2). La table qui relie pseudonymes et personnes est gardée à part, sous le contrôle du responsable de la protection des renseignements personnels.
Pourquoi : un journal réinscriptible ne prouve rien; la durée de 24 mois et la vérification quotidienne, choix du cadre, dépassent les six mois du RIA pour couvrir une découverte tardive d'un incident.

Dossier de décision (application des EXIG-OBS-11 et EXIG-CON-09). Pour toute décision visée par l'art. 12.1 de la Loi sur le privé ou par l'art. 65.2 de la Loi sur l'accès, l'agent **DOIT** verser à un dossier de décision chiffré, sous le contrôle du responsable de la protection des renseignements personnels, les RP en entrée, les résultats d'outils qui ont servi à décider, les versions de l'agent, du modèle et des outils, les facteurs retenus et les approbations. Le dossier est distinct de la télémétrie et du journal d'audit, auquel il est relié par empreinte; chaque accès y est journalisé. Il est conservé au moins un an après la décision (EXIG-CON-09), puis détruit, sauf gel des preuves (EXIG-CON-23). Les facteurs consignés sont ceux du

processus déterministe, jamais le raisonnement affiché du modèle. Pourquoi : l'EXIG-CON-09 exige de conserver ces éléments pour répondre aux demandes de la personne, alors que la télémétrie ne porte aucun contenu et que l'audit ne garde que des empreintes; sans magasin désigné, l'obligation ne peut pas être exécutée. Le magasin unique et ses droits sont un choix du cadre.

10.4 Évaluation continue

Cette section fixe la manière dont l'entreprise prouve qu'un agent fait ce qu'on attend de lui, avant et pendant son exploitation. Un code HTTP 200 ne dit rien de la justesse d'une réponse : la qualité se mesure, en trois étages, E1 à E3 (figure 22). Le volet adverse relève de la section 9.9, et la comparaison avec un agent unique, de la section 7.1.

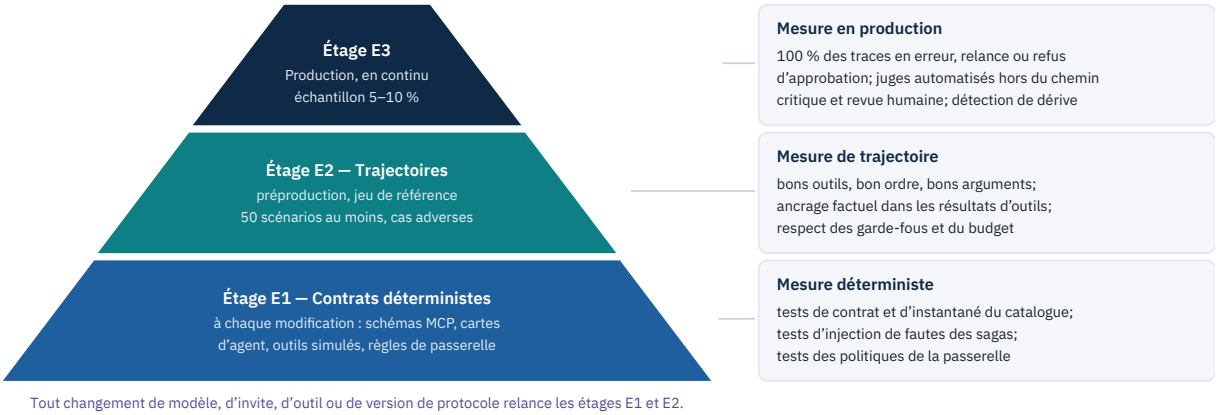


Figure 22 — Évaluation en trois paliers. L'étage E1 vérifie les contrats à chaque modification, l'étage E2 mesure les trajectoires sur un jeu de référence en préproduction, l'étage E3 échantillonne la production. Tout changement visé par l'EXIG-GOV-12 relance les deux premiers avant la mise en service. L'étage E3 évalue aussi toutes les traces qui ont atteint un plafond (EXIG-EVA-04). Source : cadre CRE-IA-2026-01.

Étage E1 : contrats. Sans aucun modèle, il valide les schémas MCP et les cartes d'agent, teste les outils contre des doublures, vérifie les politiques de la passerelle (EXIG-IAM-21) et rejoue l'injection de fautes des sagas (EXIG-ORC-20), y compris la suspension de l'agent et l'épuisement de son enveloppe en cours de saga. Les validateurs appliquent MCP 2026-07-28 : la spécification interdit de déréférencer automatiquement un `$ref` réseau et recommande de rejeter une référence externe non résolue et de borner la profondeur de validation[162]. La conformité passe par `a2a-tck`, dont les échecs aux tests de niveau `MUST` (obligatoire) sont bloquants[243], et, à titre informatif, par les tests du cadre officiel de conformité MCP, tant que celui-ci se déclare instable (section 6.8).

Étage E2 : trajectoires. Sur un jeu de référence d'au moins 50 scénarios (200 à titre indicatif, choix du cadre), qui comprend cas nominaux, cas limites et tentatives d'injection en français et en anglais, on mesure la justesse de la trajectoire (bons outils, bon ordre, bons arguments), l'ancrage factuel dans les résultats d'outils et le respect des garde-fous et du budget. Le cadre ne présume pas qu'un modèle rende la même sortie à entrées identiques : chaque scénario se répète. Évaluer un agent peut avoir des effets réels : l'article qui présente Magentic-One décrit AutoGenBench, dont les contrôles de répétition et d'isolation sont importants dès que les actions d'agents ont des effets de bord[279].

Étage E3 : production. On évalue un échantillon aléatoire d'au moins 5 % des exécutions (10 % recommandé, choix du cadre), plus toutes les traces qui ont subi une erreur, une relance, un plafond atteint ou un refus d'approbation, par des juges automatisés hors du chemin critique et par une revue humaine. Anthropic décrit un juge qui rend, en un seul appel, un score de 0,0 à 1,0 et un verdict de réussite ou d'échec[17]. Le résultat se consigne dans l'événement `gen_ai.evaluation.result` (Development) :

`gen_ai.evaluation.name` (requis), `gen_ai.evaluation.score.value`, `gen_ai.evaluation.score.label` (p. ex. `pass`) et `gen_ai.evaluation.explanation` (texte libre, soumis à l'EXIG-OBS-07 : en production, il ne reproduit ni invite ni réponse), et devrait être rattaché au span évalué[396]. Les défaillances multiagents se classent selon la taxonomie MAST *(Multi-Agent System Failure Taxonomy*; section 7.9), et les entrées du bus peuvent être rejouées en isolement pour éprouver une nouvelle version (EXIG-EVT-10).

Tableau 42 — Familles d'objectifs de niveau de service d'un agent (cibles proposées par le cadre)

Famille	Indicateurs	Cible proposée
Fiabilité technique	Succès des appels MCP et A2A, refus de politique exclus; latence par étape au 95e centile	Plus de 99,5 % de succès; latence fixée au contrat
Efficacité	Tâches achevées sans erreur; étapes par tâche; appels d'outils invalides	Moins de 1 % d'appels invalides
Qualité et sécurité	Réponses non ancrées sur échantillon; violations de garde-fous (contournement effectif, non tentative bloquée); approbations sans modification (section 8.7)	Moins de 0,5 % de réponses non ancrées, démontré selon l'EXIG-EVA-03; aucune violation d'un garde-fou bloquant; approbations sans modification sous le seuil d'alerte de l'EXIG-AUT-21
Économie unitaire	Coût total moyen et au 99e centile par tâche réussie, en dollars canadiens (section 10.6)	Coût moyen sous le coût du processus de référence sans agent ou, à défaut de processus de référence, sous la valeur attendue inscrite à la fiche

Cibles : choix du cadre, à calibrer agent par agent au contrat.

`EXIG-EVA-01` · DOIT
Étages franchis et relancés à chaque changement
Tout agent **DOIT** franchir les étages E1 et E2 avant sa mise en production et rester soumis à l'étage E3 en exploitation. Tout changement visé par l'EXIG-GOV-12, dont tout changement du modèle servi, y compris derrière un même alias (EXIG-ARC-09), **DOIT** franchir de nouveau les étages E1 et E2 avant de servir en production; la passerelle de modèles **NE DOIT PAS** résoudre un alias vers une cible qui ne les a pas franchis, ni vers un alias flottant du fournisseur (p. ex. « -latest ») : elle vise une version épinglée. Les tests de l'étage E1 **DOIVENT** s'exécuter en intégration continue et bloquer le déploiement en cas d'échec.
Pourquoi : le comportement d'un agent change sans que son code change; seule une mesure relancée détecte la régression.

`EXIG-EVA-02` · DOIT
Jeu de référence tenu et versionné
Chaque agent **DOIT** disposer d'un jeu de référence d'au moins 50 scénarios (200 à titre indicatif), versionné avec lui, stratifié par compétence, couvrant ses compétences, des cas limites et des tentatives d'injection en français et en anglais, avec un sous-ensemble réservé, non communiqué à l'équipe qui construit l'agent. Toute défaillance confirmée en production y ajoute un scénario, reconstitué à partir du dépôt d'évaluation (EXIG-EVA-04), à un registre de régression non plafonné; une consolidation versionnée garde au moins un scénario par mode de défaillance. Les seuils de trajectoire, d'ancrage et de garde-fous figurent au contrat et se décident selon la règle de l'EXIG-EVA-03; un seuil manqué bloque la mise en production.
Pourquoi : un jeu nourri par les défaillances réelles empêche qu'une erreur corrigée revienne.

EXIG-EVA-03 · DOIT

Évaluations répétées et isolées

Les évaluations de l'étage E2 et les rejeux **DOIVENT** s'exécuter en environnement isolé, outils à effet remplacés par des doublures. Chaque scénario **DOIT** s'exécuter au moins trois fois (choix du cadre); on retient le taux de réussite et sa dispersion. Toute porte (EXIG-SEC-24, EXIG-EVA-02, EXIG-EVA-04, tableau 42) et toute comparaison (EXIG-ORC-02) **DOIT** déclarer la taille d'échantillon, la statistique, l'intervalle de confiance et la règle de décision. Un taux cible p n'est démontré que si la borne supérieure de l'intervalle de confiance à 95 % (p. ex. de Wilson) est inférieure à p, ce qui exige au moins 3/p essais indépendants sans échec; les répétitions d'un même scénario ne sont pas indépendantes.

Pourquoi : une évaluation qui touche des systèmes réels en répète les effets, et une exécution unique ne dit rien de la variabilité[279].

EXIG-EVA-04 · DOIT

Échantillonnage de la production

L'évaluation en production **DOIT** porter sur un échantillon aléatoire d'au moins 5 % des exécutions (10 % recommandé; davantage pour la classe élevée), avec une taille minimale absolue par période inscrite au contrat, et sur toutes les traces marquées d'une erreur, d'une relance, d'un plafond atteint ou d'un refus d'approbation, conservées selon l'EXIG-OBS-05. Les taux se calculent sur la seule strate aléatoire, ou par pondération inverse; un agent à faible volume agrège plusieurs périodes. Le contenu évalué provient du dépôt d'évaluation (EXIG-EVA-04). Elle s'exécute hors du chemin critique, et chaque résultat est consigné par un événement `gen_ai.evaluation.result` rattaché au span évalué ou, à défaut, corrélé par `gen_ai.response.id`.

Pourquoi : l'événement normalisé relie chaque score à son exécution; le ciblage des traces atypiques (erreur, relance, plafond, refus) et la règle de calcul des taux sont des choix du cadre[396].

EXIG-EVA-05 · DOIT

Juge automatisé encadré

Un juge à base de modèle **DOIT** être distinct du modèle évalué, de préférence d'une autre famille ou d'un autre fournisseur, et avoir sa propre invite; à défaut d'un autre modèle, l'accord avec les évaluations humaines est mesuré dans cette configuration même. Il applique une grille versionnée et est calibré contre des évaluations humaines, sur un échantillon dont la taille figure au contrat, avec un taux d'accord revu chaque trimestre; un juge dont l'accord tombe sous le seuil du contrat (p. ex. kappa de Cohen inférieur à 0,6) n'alimente plus les indicateurs de l'EXIG-EVA-06. Ses verdicts alimentent indicateurs et alertes; ils **NE DOIVENT PAS** autoriser ni bloquer une action en production.

Pourquoi : un juge partage les faiblesses des modèles qu'il évalue; il mesure, il ne gouverne pas.

EXIG-EVA-06 · DOIT

Objectifs de niveau de service et réaction aux écarts

Chaque agent en production **DOIT** déclarer à son contrat des objectifs pour les quatre familles du tableau 42; un système multiagent **DOIT** en outre classer ses défaillances selon la taxonomie MAST. Un objectif manqué pendant deux mois civils consécutifs (choix du cadre) déclenche une revue par le parrain et le responsable technique, la fonction risques et conformité consultée, qui corrigent, réduisent le niveau d'autonomie ou suspendent l'agent (section 11.5); pour un agent de classe élevée ou de niveau N4, le comité en décide. Après trois mois sans retour sous la cible, l'autonomie est réduite d'un niveau et le comité est saisi. Pour l'économie unitaire, l'EXIG-FIN-10 s'applique.

> Pourquoi : un objectif sans conséquence prévue ne gouverne rien.

Dépôt d'évaluation (application des EXIG-EVA-04 et EXIG-OBS-08). Le contenu nécessaire à l'évaluation de production (invite, résultats d'outils, réponse) **DOIT** être versé à un dépôt d'évaluation distinct de la télémétrie : échantillon caviardé et chiffré, finalité « évaluation de la qualité » déclarée à l'EFVP (section 12.2), rétention bornée à la fiche (30 jours par défaut, choix du cadre), accès journalisé et réservé à l'équipe d'évaluation, aux juges et aux réviseurs habilités, rattachement au span par référence. C'est la seule source du contenu évalué au titre de l'EXIG-EVA-04 et des scénarios ajoutés au titre de l'EXIG-EVA-02, qui en sont reconstitués puis anonymisés. Un juge asynchrone qui évalue le contenu en mémoire, sans le persister, est admis sans dépôt. Pourquoi : juger l'ancrage ou la justesse d'une réponse exige son contenu, que la télémétrie ne porte pas (EXIG-OBS-07) et que la capture de débogage ne doit pas fournir en permanence (EXIG-OBS-08); un dépôt propre, à finalité déclarée, encadre cet usage (choix du cadre).

10.5 Économie de l'inférence

Cette section donne les repères économiques vérifiés qui fondent les règles de maîtrise des coûts. Les chiffres des fournisseurs y sont des grilles ou des allégations datées, jamais des exigences.

Des prix qui baissent, des volumes qui montent. Presque tous les praticiens FinOps sondés gèrent désormais des dépenses d'IA (section 2.1); le State of FinOps 2026 cite parmi leurs défis la visibilité sur des modèles de prix hétérogènes, la répartition des coûts et la mesure du rendement[10]. Selon l'AI Index 2025 de Stanford, repère historique antérieur à octobre 2024, le coût d'inférence d'un système de niveau GPT-3.5 a baissé de plus de 280 fois entre novembre 2022 et octobre 2024, soit un coût à capacité constante, non une baisse générale du prix du jeton[397]. Epoch AI (mars 2025) mesure une baisse de 9 à 900 fois par an selon le seuil visé, les baisses les plus rapides ayant été observées au cours de l'année précédant la publication et leur persistance étant incertaine[398]. En sens inverse, un agent consomme bien plus de jetons qu'une conversation (section 7.1), et les définitions d'outils pèsent à chaque appel : selon Anthropic, 58 outils MCP occupent environ 55 000 jetons avant le premier message (mesure de novembre 2025, antérieure au segmenteur des modèles Claude 4.7 et suivants)[205].

Une facture qui dépend de la configuration. En octobre 2026, la grille d'Anthropic affiche, par million de jetons, 0,10 $ US en entrée et 0,50 $ US en sortie pour Claude Haiku 5.5 (invites d'au plus 100 000 jetons, lectures et écritures de cache comprises; au-delà, 0,50 $ US en entrée et 2,50 $ US en sortie), contre 10 $ US et 50 $ US pour Claude Fable 5.1, soit, entre ces deux modèles, un facteur 100; l'écart varie selon les modèles comparés et la grille change souvent. S'y cumulent le rabais des lots, les multiplicateurs du cache et une majoration de 10 % pour l'inférence restreinte aux États-Unis comme pour les points d'accès régionaux des plateformes partenaires; le segmenteur *(tokenizer)* des modèles Claude 4.7 et suivants produit en outre jusqu'à 35 % plus de jetons pour un même texte que le segmenteur précédent (celui de Claude Sonnet 4.6 et des modèles antérieurs), soit de 1 à 1,35 fois selon le contenu[399]. On compare donc des modèles au coût par tâche réussie, après normalisation, et un choix de résidence dicté par une EFVP (section 12.2) entre au modèle de coût; la zone « us » de l'API d'Anthropic n'est ni québécoise ni canadienne, et aucune zone canadienne n'y est offerte; toute zone hors du Québec relève de l'art. 17 (section 12.2)[400].

Des leviers documentés. Le traitement asynchrone par lots coûte 50 % de moins chez Anthropic comme chez OpenAI, avec une fenêtre de traitement de 24 heures[88, 89]. Le cache d'invites récompense un préfixe stable : chez Anthropic, le préfixe suit l'ordre outils, système, messages, toute modification d'une définition d'outil invalide le cache entier, et une lecture en cache coûte au plus 0,1 fois le prix d'entrée (0,05 fois pour Claude Opus 5.5 et Sonnet 5.5, 0,025 fois pour Claude Fable 5.1), mais une écriture coûte 1,25 fois (durée de vie de 5 minutes, par défaut) ou 2 fois (1 heure) ce prix[401]; chez OpenAI, le cache s'active dès 1 024

jetons pour GPT-5.6 et les suivants, et OpenAI recommande de placer le contenu stable avant le contenu dynamique[402]. Enfin, NVIDIA Research et Georgia Tech estiment que servir un petit modèle de 7 milliards de paramètres coûte de 10 à 30 fois moins, en latence, en énergie et en calcul, qu'un modèle de 70 à 175 milliards, et que de 40 à 70 % des requêtes de leurs études de cas pourraient lui être confiées[403]. C'est un coût de calcul, non un prix facturé, et l'équivalence de qualité reste une thèse que seule une mesure tranche.

ATTENTION

Les pourcentages d'économie par levier qui circulent dans la littérature commerciale (routage, élagage du contexte, cache sémantique, plafonds) n'ont, pour la plupart, aucune source vérifiable. Le cadre n'en reprend aucun : chaque levier se juge à l'économie mesurée sur la charge de l'entreprise.

Des unités propres aux logiciels-services. En octobre 2026, Microsoft Copilot Studio facture en Copilot Credits (par exemple 5 par action d'agent avec le moteur standard, et 10 par 1 000 jetons pour un modèle de raisonnement); au-delà de 125 % de la capacité prépayée du locataire, les agents personnalisés sont désactivés, sauf si la facturation à l'usage absorbe le dépassement, et un plafond mensuel peut être fixé par agent[53]. Salesforce Agentforce propose notamment des crédits à 0,005 $ US, soit environ 0,10 $ US par action standard, à titre indicatif[55]. Ces unités ne se comparent pas sans conversion.

EXIG-FIN-01 · DOIT

Comparaison au coût par tâche réussie

Le choix ou le changement d'un modèle, d'un fournisseur ou d'une plateforme **DOIT** reposer sur le coût d'inférence par tâche réussie mesuré sur le jeu de référence (section 10.4), pondéré par la distribution de production et augmenté du coût estimé des outils réels, et non sur le prix du jeton; le suivi en production (EXIG-FIN-10) emploie le coût total. Le modèle de coût intègre les modificateurs de prix (lots, cache, résidence), la normalisation des jetons d'un segmenteur à l'autre, qui vaut aussi pour le ratio jetons/résultat, dont la ligne de base est réinitialisée à chaque changement de modèle, et, pour un modèle hébergé par l'entreprise, l'hébergement, l'exploitation et l'évaluation.

Pourquoi : un même texte ne donne pas le même nombre de jetons d'un modèle à l'autre[399], et le coût de calcul d'un petit modèle n'est pas son coût total[403].

EXIG-FIN-02 · DOIT

Hypothèses de prix datées et révisées

Les prévisions budgétaires **DOIVENT** reposer sur des hypothèses de prix datées, révisées chaque trimestre avec le catalogue, sans extrapoler les baisses passées. La passerelle de modèles **DOIT** tenir une table de prix versionnée et datée, avec une règle de conversion en dollars canadiens (source et date du taux). Les exigences et les contrats d'agent **NE DOIVENT PAS** inscrire le prix d'un modèle : les fiches renvoient aux grilles des fournisseurs.

Pourquoi : les grilles changent souvent, et la persistance des baisses observées est incertaine[398].

EXIG-FIN-03 · DOIT

Unités SaaS converties et plafonnées

Pour tout agent exploité sur une plateforme SaaS, l'équipe FinOps **DOIT** tenir une table de conversion entre les unités de l'éditeur (crédits, actions, conversations) et le coût par tâche réussie, et configurer les plafonds offerts, comme un plafond mensuel par agent. Un dépassement qui désactive des agents **DOIT** être traité comme un risque de continuité, avec seuil d'alerte et responsable nommé.

Pourquoi : sans conversion, construire et acheter ne se comparent pas, et un dépassement de capacité peut arrêter des agents[53].

10.6 Maîtrise des coûts

Cette section transforme ces repères en mécanismes de maîtrise des coûts, de l'enveloppe de la tâche jusqu'au calcul du coût par tâche réussie.

Enveloppe budgétaire et quotas

Chaque tâche reçoit à son entrée une enveloppe aux dimensions de l'EXIG-ORC-26 : étapes ou itérations, appels d'outils, jetons, coût et durée totale (figure 23); pour un agent ambiant, la tâche naît de l'événement déclencheur. Le Generative AI Lens d'AWS Well-Architected Framework recommande de telles conditions d'arrêt (délais d'expiration, limites de jetons) pour rendre prévisible le coût maximal d'un agent, et juge le risque élevé en leur absence[404]. Les plafonds se déclarent à la fiche (EXIG-ORC-26) et voyagent avec chaque appel (EXIG-ARC-02) à titre d'information, l'état qui fait foi étant tenu par la passerelle de modèles (EXIG-FIN-04); les valeurs de la figure sont illustratives. Les textes consultés ne fixent pas les seuils : le cadre alerte à 80 % et arrête à 100 %. À la passerelle de modèles, les quotas s'appliquent par période; la politique `llm-token-limit` d'Azure API Management, par exemple, limite les jetons par minute et par quota sur une période d'une heure à un an, mais compte séparément par passerelle, estime les jetons en diffusion en continu, et sa limite peut être dépassée temporairement par des requêtes concurrentes[107]. Un quota de passerelle est donc une borne approximative; l'enveloppe, tenue en un seul point avec réservation avant chaque appel, une borne logique.

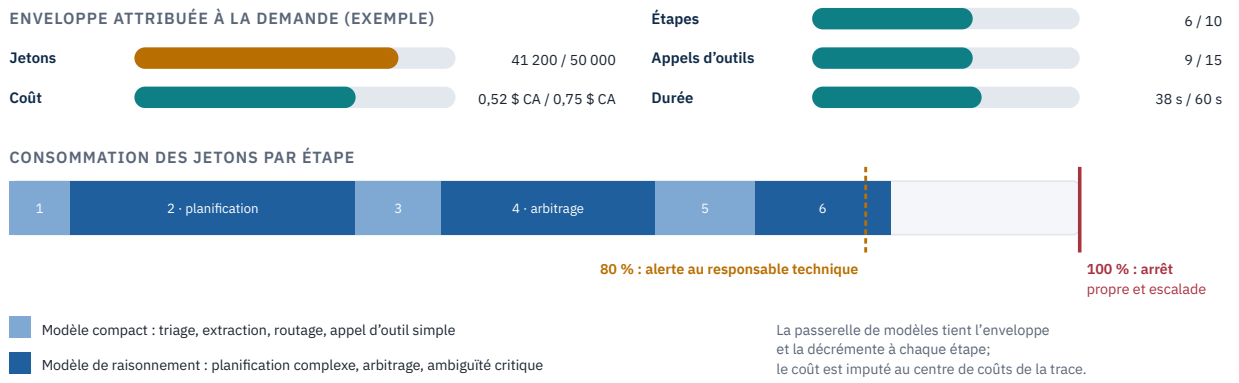


Figure 23 — Enveloppe budgétaire d'une tâche. L'enveloppe se décrémente à chaque étape; à 80 % d'un plafond, le responsable technique est alerté; à 100 %, l'exécution s'arrête proprement et passe en escalade. Les étapes simples vont au modèle compact, la planification au modèle de raisonnement. L'enveloppe porte les cinq dimensions de l'EXIG-ORC-26 : étapes ou itérations, appels d'outils, jetons, coût et durée. Source : cadre CRE-IA-2026-01; valeurs illustratives.

`EXIG-FIN-04` · DOIT

Enveloppe appliquée à chaque étape

La passerelle de modèles **DOIT** être seule détentrice de l'état de l'enveloppe, côté serveur, indexé par l'identifiant de tâche; l'orchestrateur et la passerelle d'agents lui déclarent les appels d'outils. Chaque appel réserve atomiquement son coût maximal possible avant exécution, puis ajuste au coût réel; chaque part attribuée à un exécutant est débitée du parent dès son attribution. La passerelle alerte le responsable technique dès qu'un plafond atteint 80 % et, à 100 %, arrête l'exécution vers l'avant en état sûr et la passe en escalade, avec un refus typé « budget épuisé » (EXIG-IAM-18); les compensations des sagas en cours consomment la réserve du canal de compensation (EXIG-ORC-17), hors de l'enveloppe. Un

orchestrateur qui délègue attribue à l'exécutant une part de l'enveloppe restante, jamais une enveloppe neuve; un partenaire externe est borné par un plafond contractuel.
Pourquoi : les conditions d'arrêt bornent le coût maximal[404], et une enveloppe recréée à chaque délégation rendrait le plafond inopérant; un état tenu en un seul point, avec réservation, empêche que des sous-agents parallèles consomment chacun le même reste. Les seuils de 80 et 100 % sont des choix du cadre.

EXIG-FIN-05 · DOIT
Quotas et plafond mensuel par agent
Chaque agent **DOIT** disposer, à la passerelle de modèles, d'un quota de jetons par minute et d'un plafond mensuel de coût inscrits à sa fiche (annexe B), avec une marge déclarée pour les dépassements possibles en concurrence. Le parrain est alerté à 80 % du plafond mensuel. À 100 %, les nouvelles tâches sont refusées, ou l'agent est ramené à son modèle de repli, selon sa fiche, et le parrain en est avisé; les tâches en cours se terminent ou se compensent (EXIG-ORC-17). Le modèle de repli dispose d'un plafond propre inscrit à la fiche, et le traitement de continuité de l'EXIG-FIN-03 s'applique.
Pourquoi : un agent ambiant s'exécute sans demande humaine, et la limite d'une passerelle peut être dépassée temporairement[107].

Routage frugal, préfixe stable et lots

Le Centre d'architecture Azure demande d'attribuer à chaque agent un modèle proportionné à sa tâche, en notant que classification, extraction et mise en forme peuvent souvent se confier à de petits modèles sans baisse de la qualité globale, et de mesurer les jetons par agent et par exécution[9]. Le Generative AI Lens retient trois principes : choisir le modèle et le mode d'inférence selon le besoin réel, contrôler la longueur des invites et des réponses, borner les flux[405]. Les modèles de raisonnement se réservent d'abord à la planification complexe, à l'arbitrage entre contraintes et aux ambiguïtés critiques; tout autre emploi se justifie par une mesure (EXIG-FIN-06).

Pour profiter du cache, une invite va du plus stable au plus variable : outils, instructions système, documents récurrents, puis demande. Les serveurs MCP internes listent leurs outils dans un ordre déterministe (EXIG-MCP-03), et un outil chargé à la demande s'ajoute après le point de rupture du cache (section 6.5). La part des jetons d'entrée lus en cache se lit en rapportant `gen_ai.usage.cache_read.input_tokens` à `gen_ai.usage.input_tokens`, que la convention demande (*SHOULD*) d'établir en y incluant les jetons servis depuis le cache; l'API d'Anthropic rapporte toutefois ses lectures en cache à part, et le dénominateur se vérifie donc par fournisseur[119].

EXIG-FIN-06 · DOIT
Plus petit modèle suffisant
La configuration modèle par étape retenue pour un agent **DOIT** atteindre les seuils d'agent du jeu de référence au plus faible coût par tâche réussie mesuré (EXIG-FIN-01), parmi les modèles homologués; un modèle plus petit qui échoue plus souvent peut coûter davantage par tâche réussie. L'emploi d'un modèle de raisonnement se justifie à la fiche par une mesure; la passerelle applique la correspondance entre étape et modèle, de préférence par alias logique (EXIG-ARC-09).
Pourquoi : l'écart de prix entre le plus petit et le plus grand modèle d'un même fournisseur peut atteindre deux ordres de grandeur (section 10.5)[399]; c'est le levier le plus direct, pourvu que la qualité soit démontrée.

EXIG-FIN-07 · DOIT
Préfixe stable et cache mesuré
Les invites **DOIVENT** être assemblées en préfixe stable (outils, instructions système, contenus récurrents) suivi du contenu variable. Une définition d'outil ou une invite système **DOIT** se modifier par une version déployée; l'ajout en fin de préfixe d'un outil versionné au catalogue est permis, et une définition modifiée reçue à l'exécution est refusée par la passerelle (EXIG-MCP-20). La part des jetons d'entrée lus en cache est suivie par agent, selon une formule tenue par fournisseur, et une baisse de plus de 20 points sur 7 jours (choix du cadre) ouvre une analyse.
Pourquoi : modifier une définition d'outil invalide tout le cache[401], et OpenAI recommande de placer le contenu stable en tête[402].

EXIG-FIN-08 · DEVRAIT
Lots asynchrones pour les charges non urgentes
Les charges non urgentes des agents ambiants, des évaluations et des traitements périodiques **DEVRAIENT** passer par les API par lots lorsque leur délai, jusqu'à 24 heures, est acceptable. L'orchestrateur consigne l'identifiant du lot à son point de contrôle pour en reprendre les résultats (section 7.4).
Pourquoi : le traitement par lots coûte 50 % de moins chez les fournisseurs vérifiés[88, 89].

Imputation et économie unitaire

Le cadre FinOps définit le périmètre de dépenses *(Scope)* comme un segment de dépenses aligné sur des constructions d'affaires (produit, centre de coûts, environnement) et cite la dépense d'IA agentique en exemple[406]. Le guide FinOps for AI (mis à jour le 17 février 2026) recommande de mettre en place un modèle de refacturation indicative *(showback)* et une stratégie d'étiquetage, et relève l'absence de cadres généralement admis pour répartir les coûts entre charges multiagents[407]. FOCUS 1.4 *(FinOps Open Cost and Usage Specification)* normalise les données de facturation (coûts, catégorie de service, quantité et unité consommées, étiquettes), avec une catégorie « AI and Machine Learning », mais sans colonne native de jetons ni indicateur par agent[408, 409]; la version 1.5 est traitée au chapitre 13. Les indicateurs par agent se calculent donc en joignant coûts FOCUS, télémétrie `gen_ai.*` et résultats métier. Le cadre en définit trois :

- **Coût par tâche réussie** : coût total imputé à l'agent (inférence, outils, quote-part de la plateforme, évaluation par les juges et revue humaine, temps d'approbation et de garde imputé) divisé par le nombre de tâches réussies selon son contrat, en dollars canadiens.
- **Jetons par agent et par exécution** : ventilés en entrée, sortie, lecture et écriture en cache et, s'il y a lieu, raisonnement, chaque catégorie se facturant à un tarif différent.
- **Ratio jetons/résultat** : jetons par tâche réussie; sa hausse à qualité égale signale une dérive (contexte qui enfle, boucle, cache rompu).

EXIG-FIN-09 · DOIT
Imputation par centre de coûts
Chaque span **DOIT** porter le centre de coûts imputé (`ca.entreprise.cost_center`), tiré du référentiel financier et identique à l'étiquette des données de facturation. Le centre de coûts du mandant ou de la tâche d'origine se propage par le bagage (EXIG-OBS-10), et un service appelé ne le remplace pas; un service partagé déclare une clé de répartition. Lorsque les données de facturation d'un fournisseur ne descendent pas sous le compte ou la clé d'API, l'entreprise ouvre une clé ou un espace de travail par centre de coûts, ou répartit la facture d'après la télémétrie. La dépense agentique est suivie comme un

périmètre de dépenses FinOps *(Scope)* distinct, dont l'équipe FinOps et les parrains sont responsables. L'imputation commence par la refacturation indicative; la refacturation réelle suit, sur décision du comité, une fois les indicateurs stabilisés.

Pourquoi : la FinOps Foundation recommande la refacturation indicative pour l'IA[407]; une étiquette commune rend la jointure possible.

EXIG-FIN-10 · DOIT

Indicateurs d'économie unitaire publiés

L'équipe FinOps **DOIT** calculer chaque mois, pour chaque agent en production, les trois indicateurs définis à la section 10.6, à partir des données FOCUS exigées des fournisseurs (chapitre 13), de la télémétrie de la version épinglée et des résultats métier, les transmettre au parrain et les inscrire au registre. Un agent dont le coût par tâche réussie dépasse celui du processus de référence ou, à défaut de processus de référence, la valeur attendue inscrite à la fiche (tableau 42), deux mois de suite (choix du cadre) passe en revue de valeur : le parrain, le responsable technique et l'équipe FinOps décident, devant la fonction risques et conformité, de maintenir, de reconcevoir ou de retirer l'agent, et la décision est consignée au registre (section 11.5).

Pourquoi : FOCUS normalise les données de facturation, non la performance des agents[410]; seul le croisement des coûts, des jetons et des résultats dit si un agent crée de la valeur.

Partie IV — Gouvernance, conformité et mise en œuvre

Qui décide et répond de quoi, quelles obligations s'appliquent, comment acheter, mesurer la maturité et déployer le cadre.

11 · Gouvernance et cycle de vie

12 · Risques, conformité et réglementation

13 · Approvisionnement et clauses contractuelles

14 · Modèle de maturité

15 · Feuille de route et indicateurs

11 Gouvernance et cycle de vie

Un agent qui agit au nom de l'entreprise relève d'une personne nommée, figure au registre et suit un parcours balisé, de sa proposition à son retrait. Ce chapitre répartit les rôles, fixe la matrice RACI et le modèle opérationnel en étoile, puis définit le registre d'entreprise des agents et des serveurs MCP, les jalons du cycle de vie et le régime des dérogations, dont le régime transitoire des agents existants. Il précise enfin comment le cadre admet, révise et retire les standards de son catalogue.

À RETENIR

Trois règles structurent ce chapitre : une personne nommée répond de chaque agent; sans fiche complète au registre, aucun justificatif de production; tout changement significatif rouvre l'évaluation. Les rôles, la matrice RACI, les jalons du cycle de vie et les dérogations organisent l'application de ces trois règles.

11.1 Rôles et responsabilités

Cette section nomme les rôles que le cadre mobilise et ce que chacun doit livrer (tableau 43). Le principe est simple : un agent ne répond pas de ses actes (section 3.4); une personne identifiable en répond, et chaque décision du cycle de vie revient à un rôle précis.

Les référentiels convergent sur ce point. Le NIST AI RMF demande que les rôles et responsabilités liés aux risques de l'IA soient documentés (GOVERN 2.1) et que l'intensité de la gestion des risques suive la tolérance au risque de l'organisation (GOVERN 1.3)[74]. ISO/IEC 42001 traite des rôles à l'article 5.3 et de l'organisation interne à la mesure A.3 de son annexe A[395]. Au Québec, la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1, ci-après « Loi sur le privé »), modifiée par la Loi 25, confie la fonction de responsable de la protection des renseignements personnels (RPRP) à la personne ayant la plus haute autorité, qui peut la déléguer par écrit; la Loi exige aussi des politiques de gouvernance qui précisent les rôles et responsabilités tout au long du cycle de vie des renseignements (art. 3.1 et 3.2)[56]. Les organismes publics appliquent les dispositions équivalentes de la Loi sur l'accès : la personne ayant la plus haute autorité y exerce la fonction de responsable de la protection des RP (art. 8), un comité sur l'accès à l'information et la protection des renseignements personnels soutient l'organisme (art. 8.1), et les articles 63.3 (règles de gouvernance) et 63.5 (EFVP) s'appliquent[56].

Microsoft Entra Agent ID distingue, pour chaque agent, un parrain *(sponsor)*, qui porte la responsabilité métier, un propriétaire *(owner)*, qui l'administre techniquement, et un gestionnaire *(manager)*, qui gère le compte utilisateur de l'agent lorsqu'il en a un[90]. Le cadre reprend la distinction entre parrain et propriétaire sans dépendre du produit : le propriétaire métier joue le rôle de parrain, le responsable technique celui de propriétaire au sens d'Entra. Dans le cadre, pour un agent, « propriétaire » ne s'emploie jamais seul : on écrit « propriétaire métier » (ou « parrain ») ou « responsable technique ».

Tableau 43 — Rôles de la gouvernance agentique

Rôle	Responsabilités principales	Fondement ou remarque
Propriétaire métier (parrain)	Répond de la finalité, des résultats et des effets de l'agent; demande son niveau d'autonomie; finance l'agent; atteste périodiquement qu'il est encore requis.	Une personne, jamais une équipe ni un fournisseur.
Responsable technique	Conçoit, construit, teste et exploite l'agent; tient à jour sa fiche, son contrat et sa carte d'agent; dirige l'équipe de garde.	Ne peut ni homologuer son propre agent ni valider l'atteinte de ses seuils d'évaluation (EXIG-GOV-03).
Équipe d'évaluation	Exécute le jeu d'évaluation et les tests de sécurité d'un agent qu'elle n'a pas construit; établit le rapport d'évaluation (section 10.4).	Désignée pour chaque agent, distincte de son

Rôle	Responsabilités principales	Fondement ou remarque
		équipe de construction (EXIG-GOV-03); peut relever de l'équipe plateforme.
Équipe plateforme	Opère les passerelles, le registre, le catalogue, le traçage, l'outillage d'évaluation, les gabarits et le coupe-circuit global.	Centre du modèle en étoile (section 11.3).
Équipe FinOps	Tient la table de conversion des unités des logiciels-services (EXIG-FIN-03); propose les quotas et le plafond mensuel de chaque agent (EXIG-FIN-05); calcule et publie chaque mois l'économie unitaire (EXIG-FIN-10); prépare la revue de valeur (section 11.5) et la décision de refacturation réelle (EXIG-FIN-09).	Section 10.6; peut relever de l'équipe plateforme.
Architecture d'entreprise	Tient le cadre et le catalogue des protocoles; approuve les revues d'architecture, que la sécurité réalise (tableau 44); instruit les dérogations.	Gouvernance des standards (section 11.7).
Sécurité de l'information	Modèle de menaces; politique des identités et des paliers d'outils; tests d'abus et équipe rouge; réponse aux incidents de sécurité.	Chapitre 9.
Risques et conformité	Classe le risque des agents; arrête le niveau d'autonomie, valide l'atteinte des seuils d'évaluation, homologue la mise en production et approuve l'attestation périodique des agents de classe faible ou modérée (tableau 44); vérifie la conformité réglementaire; suit les dérogations et les risques résiduels.	Chapitre 12.
Responsable de la protection des RP (RPRP)	Est consulté dès le début de tout projet impliquant des RP; encadre les EFVP; approuve les politiques de gouvernance des RP; dirige le traitement des incidents de confidentialité (choix du cadre).	Loi sur le privé, art. 3.1 à 3.3.
Comité d'architecture et des risques agentiques	Arrête le niveau d'autonomie, homologue et approuve l'attestation des agents de classe élevée, et tout niveau N4; accorde les dérogations; décide du retrait anticipé pour un motif de sécurité; approuve le catalogue des protocoles; décide du passage à la refacturation réelle (EXIG-FIN-09); révise le cadre chaque semestre.	Instance décisionnelle du cadre (EXIG-GOV-02).
Approbateurs humains	Approuvent ou refusent, sur la base de l'action exacte, les actions que la section 8.4 soumet à approbation.	Personnes compétentes, formées et dotées de l'autorité nécessaire (règlement européen sur l'IA, ou RIA, art. 26).
Équipe de garde	Surveille l'agent en production, reçoit les escalades, suspend l'agent au besoin et applique les procédures d'incident.	Joignable pendant les heures d'exploitation déclarées.

L'exigence relative aux approbateurs s'inspire du règlement européen sur l'IA : le déployeur d'un système à haut risque confie la supervision humaine à des personnes compétentes, formées et dotées de l'autorité nécessaire (art. 26)[61]. Pour les systèmes de l'annexe III, cette obligation s'applique à compter du 2 décembre 2027 (2 août 2028 pour ceux de l'annexe I, soit les produits réglementés)[58]. Le cadre l'étend à tous les agents, quelle que soit leur classe (EXIG-AUT-15).

EXIG-GOV-01 · DOIT

Responsables nommés pour chaque agent

Chaque agent et chaque serveur MCP inscrits au registre **DOIVENT** avoir un propriétaire métier (parrain) et un responsable technique désignés nommément, ainsi qu'une équipe de garde joignable pendant les heures d'exploitation déclarées. Pour un agent intégré à un logiciel-service ou exploité par un partenaire, le parrain est la personne interne qui répond de son usage et du contrat.

Pourquoi : une responsabilité confiée à « l'équipe » ou au fournisseur n'est exercée par personne; l'OWASP place le retrait inadéquat des identités non humaines, typique des agents orphelins, au premier rang de son NHI Top 10 (NHI1)[91].

EXIG-GOV-02 · DOIT

Comité d'architecture et des risques agentiques

L'entreprise **DOIT** constituer un comité d'architecture et des risques agentiques doté d'un mandat écrit qui précise sa composition (au minimum l'architecture d'entreprise, la sécurité de l'information, la fonction risques et conformité, le RPRP ou son délégué, l'équipe plateforme et des représentants des domaines métier), son quorum, ses pouvoirs, dont la décision de passer à la refacturation réelle (EXIG-FIN-09), et la fréquence de ses réunions. Le mandat **DOIT** aussi fixer une procédure d'urgence (décision du président ou d'un sous-comité, ratifiée à la séance suivante), un délai de décision par type de dossier, suivi comme indicateur, et la récusation de tout membre qui a instruit ou préparé le dossier soumis, dont l'architecture d'entreprise pour les dérogations qu'elle instruit. Ses décisions **DOIVENT** être motivées et consignées au registre.

Pourquoi : les décisions qui engagent l'entreprise (niveau N4, agent de classe élevée, dérogation, catalogue des protocoles) exigent une instance qui réunit les expertises et dont les arbitrages laissent une trace vérifiable.

EXIG-GOV-03 · NE DOIT PAS

Cumul de la préparation et de l'approbation

Une même personne **NE DOIT PAS** à la fois préparer et approuver une décision du cycle de vie d'un agent. Sont des décisions du cycle de vie : la classification, la fixation du niveau d'autonomie, la validation de l'atteinte des seuils d'évaluation, l'homologation, l'attestation périodique, la dérogation et le retrait. En particulier, le parrain ne fixe ni n'homologue le niveau qu'il demande, et le responsable technique d'un agent ne valide pas l'atteinte de ses seuils d'évaluation, n'homologue pas sa mise en production, n'accorde pas une dérogation qui le vise et n'approuve aucune action de cet agent soumise à approbation (EXIG-AUT-10); l'évaluation est réalisée par une équipe distincte de l'équipe de construction (tableau 43). La confirmation, par le mandant, d'une action qu'il a lui-même demandée (EXIG-AUT-15) n'est pas une décision du cycle de vie.

Pourquoi : la séparation des fonctions est le contrôle le plus simple contre l'erreur et la complaisance; elle donne son sens au « A » de la matrice RACI.

11.2 Matrice RACI

Cette section attribue chaque activité du cycle de vie à un rôle qui réalise (R), à un seul rôle qui approuve et répond (A), aux rôles consultés (C) et aux rôles informés (I). Le tiret signifie « non concerné ». La colonne Jalon donne le jalon de la figure 25 que l'activité ferme ou prépare (1 à 6), ou l'étape où elle se déroule; un tiret y désigne une activité continue ou hors du cycle de vie d'un agent. Abréviations des colonnes : PM, propriétaire métier (parrain); RT, responsable technique; PL, équipe plateforme; AE, architecture d'entreprise; SÉC, sécurité de l'information; RC, risques et conformité; RPRP, responsable de la protection des RP; CO, comité d'architecture et des risques agentiques. Un rôle sans colonne (équipe d'évaluation, équipe FinOps) est nommé dans la cellule de l'activité, avec sa lettre.

Tableau 44 — Matrice RACI du cycle de vie d'un agent

Activité	Jalon (figure 25)	PM	RT	PL	AE	SÉC	RC	RPRP	CO
Inscrire l'agent au registre	1	A	R	C	I	I	I	—	—
Classer le risque de l'agent	1 (réexamen au 2)	R	C	—	C	C	A	C	I
Fixer le niveau d'autonomie (le parrain le demande)	2	R	R	—	C	C	A	—	I

Activité	Jalon (figure 25)	PM	RT	PL	AE	SÉC	RC	RPRP	CO
Classer les outils par palier (P0 à P3)	2	C	R	C	I	A	C	C	—
Concevoir et construire	— (étapes 2 et 3)	C	A, R	C	C	C	I	I	—
Revue d'architecture et de sécurité (jalon de l'étape 2)	2	I	C	C	A	R	C	C	I
Évaluer l'agent et valider l'atteinte des seuils (jalon de l'étape 3; R : équipe d'évaluation)	3	I	C	C	—	C	A	I	—
Réaliser l'EFVP	3 (commencée au 2)	A	R	I	I	C	C	C	—
Homologuer la mise en production (le parrain la demande; le responsable technique prépare le dossier, il ne décide pas)	3 (provisoire) et 4	R	R	C	C	C	A	C	I
Exploiter et surveiller	— (étape 5)	I	A, R	R	—	C	I	—	—
Gérer un incident	—	I	R	R	I	A	C	C	I
Accorder une dérogation	—	R	C	I	R	C	C	C	A (AE par délégation pour la classe faible, EXIG-GOV-15)
Attester périodiquement l'agent	5	R	C	I	—	I	A	—	—
Retirer l'agent	6	A (sauf retrait anticipé)	R	R	I	C	I	C	A (retrait anticipé)
Établir la preuve de révocation (jalon de l'étape 6)	6	I	R	R	—	A	I	—	—
Fixer les quotas et le plafond mensuel (EXIG-FIN-05; R : équipe FinOps)	—	A	C	C	—	—	I	—	—
Calculer et publier l'économie unitaire (EXIG-FIN-10; A, R : équipe FinOps)	— (étape 5)	I	I	C	—	—	—	—	I
Conduire la revue de valeur (section 11.5; R : équipe FinOps)	— (étape 5)	A	R	I	C	—	I	—	I
Décider du passage à la refacturation réelle (EXIG-FIN-09; R : équipe FinOps)	—	C	—	C	C	—	C	—	A
Réviser le catalogue des protocoles	—	I	I	C	R	C	C	—	A

Quatre règles complètent la matrice. Pour un agent de classe élevée ou visant le niveau N4, le comité devient A pour le niveau d'autonomie, l'homologation et l'attestation périodique, à la place de la fonction risques et conformité, qui devient C; le propriétaire métier reste R. Dans un organisme public, le comité sur l'accès à l'information et la protection des renseignements personnels (art. 8.1 de la Loi sur l'accès) est C pour l'EFVP

et pour les incidents de confidentialité. Pour un incident de confidentialité, le cadre confie au RPRP le rôle A pour l'évaluation du préjudice, les avis et l'inscription au registre des incidents prévus aux articles 3.5 à 3.8 de la Loi sur le privé (section 12.8). Enfin, l'équipe de garde exécute, pour le responsable technique, les tâches R de l'exploitation et de la gestion des incidents.

Le classement du risque revient à la fonction risques et conformité plutôt qu'au parrain : celui qui souhaite déployer l'agent propose la classe, une fonction indépendante la tranche. Pour la même raison, le niveau d'autonomie, l'homologation et l'attestation sont arrêtés par la fonction risques et conformité ou par le comité, jamais par le parrain qui les demande, et l'évaluation est faite par une équipe distincte de celle qui construit. De même, la sécurité valide le palier d'un outil, parce que ce palier détermine les contrôles exigés (section 8.3).

> **`EXIG-GOV-04` · DOIT**
> **Un seul A, des personnes nommées**
> Chaque activité du tableau 44 **DOIT** avoir un et un seul rôle A dans chaque cas que le tableau et les règles qui le complètent distinguent (classe de risque élevée ou niveau N4, retrait anticipé, délégation de la dérogation, incident de confidentialité). La fiche de chaque agent **DOIT** nommer les personnes qui tiennent, pour cet agent, les rôles R et A de la matrice, un suppléant pour chaque rôle A, et, pour chaque contrôle d'approbation que calcule l'EXIG-AUT-10, les approbateurs humains (EXIG-AUT-15). Une fiche dont un rôle A est vacant est incomplète, sauf pendant l'intérim de l'EXIG-GOV-09.
> Pourquoi : deux « A » diluent la responsabilité, et une matrice sans noms ne sert à rien le jour d'un incident.

11.3 Modèle opérationnel en étoile

Cette section fixe la répartition du travail entre une plateforme centrale et les domaines métier (figure 24 et tableau 45). Le cadre retient un modèle en étoile *(hub-and-spoke)* : la plateforme fournit et opère le socle commun; les domaines bâtissent et exploitent leurs agents en libre-service; la sécurité, les risques et la gouvernance encadrent les deux.

Ce choix évite deux échecs connus. Tout centraliser crée un goulot d'étranglement : chaque agent attend une équipe qui ne connaît pas le métier. Tout décentraliser multiplie les passerelles, les registres et les façons de gérer les identités, donc les failles. Dans le modèle en étoile, un contrôle s'écrit une fois dans la plateforme et s'applique partout, tandis que la logique métier reste la propriété des domaines.

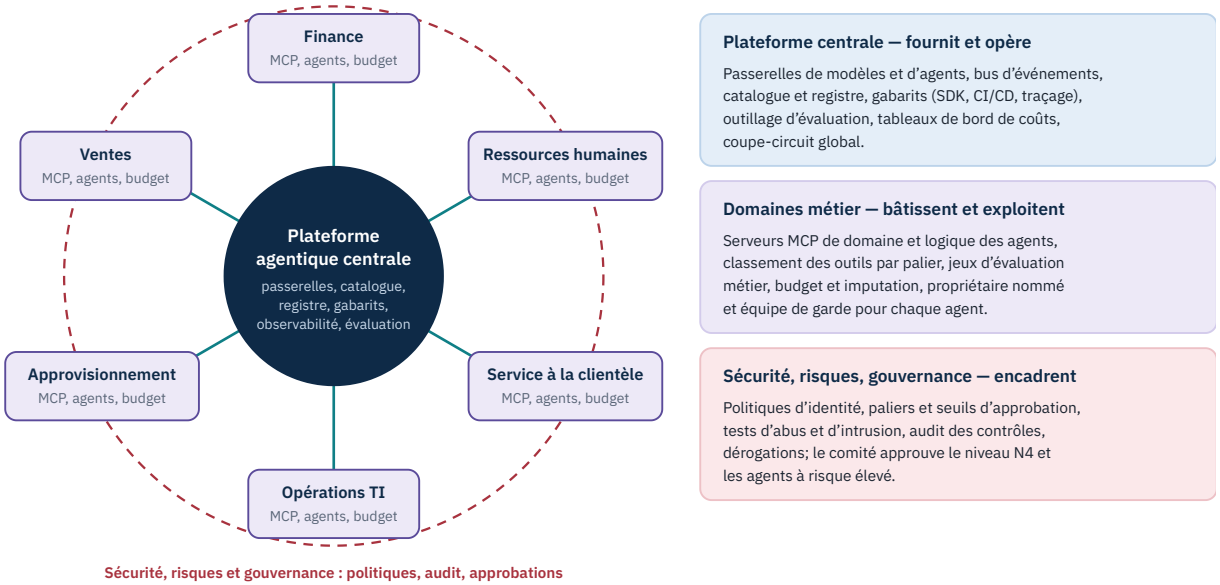


Figure 24 — Modèle opérationnel en étoile. La plateforme centrale fournit une seule fois les passerelles, le registre, les gabarits et le coupe-circuit; chaque domaine y branche ses serveurs MCP et ses agents; la sécurité, les risques et la gouvernance encadrent l'ensemble. Source : cadre CRE-IA-2026-01; les six domaines sont donnés à titre d'exemple.

Tableau 45 — Répartition des responsabilités dans le modèle en étoile

Responsabilité	Plateforme centrale	Domaines métier	Sécurité, risques et gouvernance
Passerelles de modèles et d'agents, bus d'événements	R, A : conçoit, opère, sécurise	C : consomme en libre-service	C : audite les contrôles
Registre, catalogue d'entreprise et coupe-circuit global	R, A : opère l'outillage	R : tient ses fiches et contrats à jour	C : vérifie la complétude; R : déclenche le coupe-circuit
Gabarits d'agents (trousses de développement, CI/CD, traçage)	R, A : fournit et maintient	R : instancie	C : valide les contrôles intégrés
Serveurs MCP de domaine et logique des agents	C : accompagne	R, A : développe, teste, exploite	C : impose les tests d'abus
Classement des outils par palier	R : inscrit au catalogue	R : propose	A : valide selon la politique des paliers
Jeux d'évaluation métier	C : outille la chaîne d'évaluation	R, A : définit les scénarios	C : exige les cas adverses
Politiques d'identité et seuils d'approbation	R : applique dans les passerelles	C : décrit les cas métier	A : définit
Budget et imputation des coûts	R : mesure et expose les coûts	A : maîtrise son budget	I

EXIG-GOV-05 · DOIT

Socle commun obligatoire

Les domaines métier **DOIVENT** utiliser les passerelles, le registre, le catalogue d'entreprise, la chaîne de traçage et le coupe-circuit fournis par la plateforme. Un domaine **NE DOIT PAS** exploiter de passerelle, de registre ou de catalogue d'entreprise parallèle sans dérogation (section 11.6); une instance de la passerelle déployée au plus près d'un agent, qui partage la politique, le registre des jti et le journal d'audit des autres instances, n'est pas une passerelle parallèle (EXIG-ARC-01).

Pourquoi : un contrôle appliqué en deux endroits finit par diverger; la règle centrale de l'architecture (EXIG-ARC-01) fait passer par la passerelle d'agents, vers une version et une empreinte approuvées, tout appel d'un agent vers un serveur MCP ou vers un pair A2A, quel que soit le domaine, et toute action de palier P2 ou P3.

EXIG-GOV-06 · DEVRAIT
Conformité par construction
La plateforme **DEVRAIT** fournir des gabarits d'agents qui intègrent par défaut l'identité propre de l'agent, la propagation du contexte de trace, les plafonds de coût, de jetons et d'itérations, l'appel aux outils par la passerelle et l'inscription au registre, de sorte que le chemin conforme soit aussi le plus court pour une équipe de domaine.
Pourquoi : un contrôle livré dans le gabarit coûte une fois; un contrôle exigé en revue coûte à chaque agent et se contourne sous la pression des échéances.

11.4 Registre d'entreprise des agents et serveurs MCP

Cette section définit le registre, inventaire faisant autorité de tous les agents et serveurs MCP de l'entreprise. On ne gouverne pas ce qu'on ne voit pas : le registre est la condition de tous les autres contrôles.

Le NIST AI RMF, d'application volontaire, prévoit des mécanismes d'inventaire des systèmes d'IA, dotés de ressources selon les priorités de risque (GOVERN 1.6)[74]. Pour les institutions financières fédérales, la ligne directrice E-23 du BSIF, en vigueur le 1er mai 2027, attend un inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs, et une cote de risque qui détermine l'intensité de la gouvernance[8]. Le registre du cadre répond à ces deux attentes : il couvre les agents tiers et consigne les modèles utilisés.

Contenu et états de la fiche

Chaque agent et chaque serveur MCP a une fiche, dont le gabarit complet figure à l'annexe B. Elle consigne au minimum l'identification et la version; le parrain, le responsable technique, l'équipe de garde et les approbateurs; la finalité et les mandants autorisés; la classe de risque et le niveau d'autonomie approuvés; les outils appelés et leurs paliers; les modèles et leurs versions; les données touchées et la présence de RP; l'identité et les portées; les résultats d'évaluation; le budget et les plafonds; l'état de cycle de vie, les dates de revue et les dérogations en vigueur. Le niveau d'autonomie inscrit tient lieu, à l'interne, de « certificat d'autonomie » tel que le conçoivent Feng, McDonald et Zhang (qui le font délivrer par un tiers) : un plafond valable pour une configuration donnée[83]. Seul le registre, interrogé par la passerelle, fait foi; la carte d'agent n'en donne qu'une copie informative.

La fiche passe par sept états : « proposé », « en conception », « en construction », « pilote », « production », « suspendu » et « retiré ». Seuls les états « pilote » et « production » permettent d'obtenir des justificatifs d'exécution en production; l'entrée en pilote avec des justificatifs de production ou des données réelles est une mise en production (EXIG-GOV-08). La sortie de l'état « suspendu » ramène la fiche à l'état qu'elle avait, sur décision consignée. Un agent placé en quarantaine (EXIG-GOV-10) reçoit d'office une fiche minimale à l'état « suspendu », et « désactiver » un agent, au sens du cadre, c'est le faire passer à l'état « suspendu ». Un agent en exploitation à l'adoption du cadre porte en outre la mention « existant inventorié » (EXIG-GOV-16).

Registre et catalogue

Le registre répond aux questions « qui, quoi, pourquoi et avec quel risque »; le catalogue d'entreprise (section 6.8) répond à « par quel contrat et dans quelle version ». Les deux partagent l'identifiant de l'agent ou du serveur, ce qui permet à la passerelle de vérifier à chaque appel l'état de la fiche et la version épinglée du contrat. Le registre est donc sur le chemin critique de chaque appel : son objectif de disponibilité, la

durée de validité de la copie que tient chaque passerelle et le comportement en cas de registre injoignable relèvent de l'EXIG-ORC-18 (seuls les appels P0 passent sur une copie échue, la liste de suspension voyage par un canal signé indépendant du plan de contrôle, et les compensations entrent dans une file persistée). Le registre d'entreprise est distinct du registre officiel MCP : celui-ci, en préversion depuis le 8 septembre 2025, ne contient que des métadonnées de serveurs publics, ne prend pas en charge les serveurs privés et recommande aux entreprises d'opérer leur propre sous-registre[25, 43]. Il peut servir de source de découverte, jamais de registre d'entreprise.

Exemples de mise en œuvre

Plusieurs produits couvrent une partie du rôle; ce sont des exemples non limitatifs, à l'état du 27 octobre 2026. Microsoft Agent 365, en disponibilité générale depuis le 1er mai 2026, offre un registre et des contrôles comme le blocage des agents non gérés[46]. Amazon Bedrock AgentCore Registry tient un catalogue gouverné d'agents, de serveurs MCP, d'outils et de compétences, avec un flux de publication, de revue et d'approbation[102]. Azure API Center sert de registre privé pour découvrir les serveurs MCP d'une organisation[108]. ServiceNow a annoncé le 5 mai 2026 l'extension de son AI Control Tower à la découverte des actifs d'IA déployés, au moyen de 30 nouvelles intégrations et à un coupe-circuit[47].

ATTENTION

Un registre de plateforme voit d'abord les agents de sa propre plateforme. Au 1er mai 2026, la synchronisation du registre d'Agent 365 avec Amazon Bedrock et Google Cloud était en préversion publique, et les actions de cycle de vie sur les agents infonuagiques tiers étaient annoncées comme à venir[46]. Le registre d'entreprise est donc un rôle d'architecture alimenté par plusieurs sources. La suspension d'un agent dont l'entreprise contrôle l'exécution s'applique à la passerelle d'agents; celle d'un agent intégré à un logiciel-service passe par le mécanisme d'arrêt propre que décrit sa fiche (EXIG-ARC-02), jamais par la seule console de son éditeur.

EXIG-GOV-07 · DOIT

Inventaire complet

Le registre **DOIT** inventorier tout agent et tout serveur MCP qui agit dans le périmètre de l'entreprise, qu'il soit développé à l'interne, intégré à un logiciel-service ou exploité par un partenaire, avec une fiche conforme à l'annexe B, y compris les modèles utilisés et leurs versions. Le contenu de la fiche fait foi pour l'agent : en cas d'écart entre la fiche et une autre source (catalogue, carte d'agent, configuration), le registre corrige l'autre source ou suspend l'agent; seule fait exception la valeur d'un palier ou d'un seuil, que le catalogue fixe et que la fiche ne peut que rendre plus stricte (EXIG-AUT-13). Un agent intégré à un logiciel-service relève en outre de l'EXIG-ARC-02 : sa fiche **DOIT** décrire un mécanisme d'arrêt indépendant de la passerelle (désactivation au fournisseur d'identité, révocation des consentements OAuth, CAEP ou SSF, clause de l'EXIG-APP-06), éprouvé lors de l'exercice de l'EXIG-SEC-26.

Pourquoi : le NIST AI RMF range les logiciels, données et composants de tiers parmi les risques à gouverner (GOVERN 6.1 et 6.2)[74]; un agent tiers absent du registre échappe à toute revue.

EXIG-GOV-08 · NE DOIT PAS

Sans fiche, aucun justificatif

Une identité d'agent ou de serveur MCP **NE DOIT PAS** recevoir de justificatif valide en production tant que sa fiche n'a pas été approuvée complète et n'est pas à l'état « pilote » ou « production », sauf la mesure transitoire de l'EXIG-GOV-16; pendant l'intérim de l'EXIG-GOV-09, la fiche reste réputée complète. L'entrée en pilote avec des justificatifs de production ou des données réelles est

une mise en production : elle exige la classification définitive (EXIG-CON-01), l'EFVP s'il y a des RP (EXIG-CON-04), l'exercice d'équipe rouge pour les classes modérée et élevée (EXIG-SEC-23) et une homologation provisoire bornée au niveau du pilote (annexe A). La passerelle d'agents et la passerelle de modèles **DOIVENT** refuser tout appel d'une identité dont la fiche n'est pas à l'état « pilote » ou « production ». Seules en sont exceptées les compensations déclarées au catalogue d'étapes inscrites comme exécutées, qui passent par le canal de compensation, sous l'identité de compensation de l'orchestrateur (EXIG-ORC-17).

Pourquoi : lier l'émission des justificatifs à l'état du registre transforme l'inventaire en contrôle d'accès; un agent non inscrit ne peut rien faire.

`EXIG-GOV-09` · DOIT

Fiche à jour ou agent suspendu

La fiche **DOIT** être mise à jour avant la mise en œuvre de tout changement qui en modifie le contenu. Un agent dont l'attestation périodique est échue, ou dont un rôle A est vacant depuis plus de 30 jours, **DOIT** passer à l'état « suspendu » (suspension administrative, section 11.5) jusqu'à sa régularisation; le registre avertit le parrain 30 jours avant l'échéance de l'attestation. Pendant le délai de 30 jours, le suppléant nommé à la fiche (EXIG-GOV-04), ou à défaut un intérim désigné par le comité, tient le rôle vacant, et la fiche reste réputée complète. Le délai de 30 jours est un choix du cadre.

Pourquoi : une fiche périmée donne une fausse assurance; la suspension rend le coût de la négligence visible pour le parrain plutôt que pour la sécurité.

`EXIG-GOV-10` · DOIT

Détection des agents hors registre

L'équipe plateforme **DOIT**, au moins chaque mois, rapprocher le registre de sources indépendantes (journaux des passerelles, identités d'agents du fournisseur d'identité, inventaires des logiciels-services, facturation des fournisseurs de modèles) et placer en quarantaine tout agent découvert hors registre jusqu'à son inscription (EXIG-GOV-16) ou son retrait. La quarantaine comprend, selon le type d'agent : la création d'office d'une fiche minimale à l'état « suspendu »; le refus de ses appels aux passerelles; la désactivation de son identité au fournisseur d'identité et la révocation de ses consentements OAuth; pour un agent intégré à un logiciel-service, la mise en œuvre du mécanisme d'arrêt de l'EXIG-ARC-02. La fréquence mensuelle est un choix du cadre.

Pourquoi : les agents fantômes naissent hors des processus; seul un rapprochement avec ce que les systèmes observent réellement les fait apparaître. Certaines plateformes facilitent ce rapprochement : depuis juillet 2026, Copilot Studio crée automatiquement une identité Entra Agent ID pour chaque nouvel agent[48].

11.5 Cycle de vie et jalons

Cette section découpe la vie d'un agent en six étapes, chacune fermée par un jalon du cycle de vie qui laisse une preuve au registre; le terme écarte la confusion avec le point de contrôle d'une exécution durable (section 7.4). L'intensité des contrôles suit la classe de risque : un agent de classe faible franchit les mêmes portes qu'un agent de classe élevée, avec des preuves plus légères.

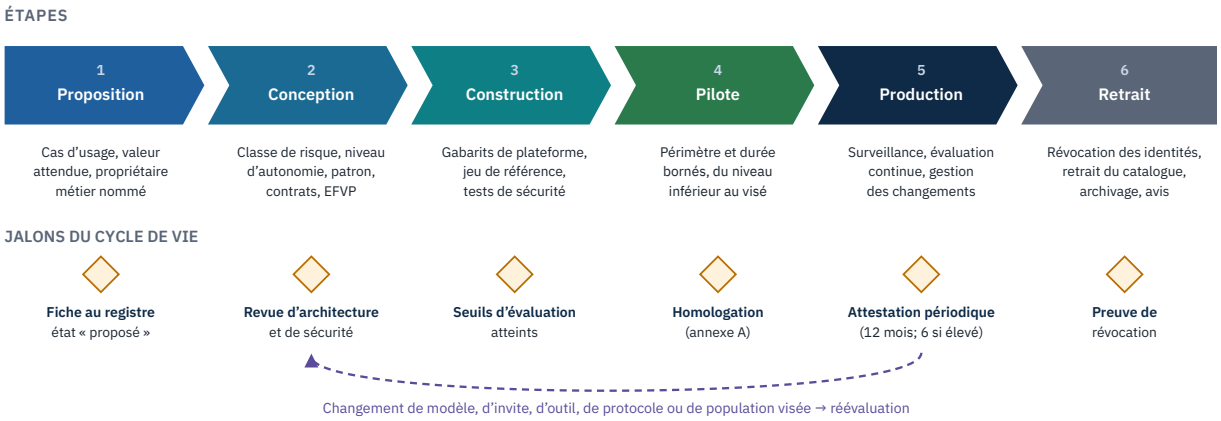


Figure 25 — Cycle de vie d'un agent et jalons. Chaque étape se termine par un jalon du cycle de vie consigné au registre; le pilote d'un agent qui vise N3 ou N4 commence au niveau inférieur et se termine au niveau visé (EXIG-GOV-11); en production, un changement significatif renvoie l'agent aux étapes de conception, d'évaluation et de pilote, dans la mesure du changement. Source : cadre CRE-IA-2026-01.

1. **Proposition.** Le parrain décrit le cas d'usage, la valeur attendue, l'autonomie maximale envisagée et le parcours de décision. La fonction risques et conformité attribue la classe de risque sur cette base, avant tout plafonnement (EXIG-CON-01). Jalon du cycle de vie : fiche inscrite à l'état « proposé », avec la classe approuvée.
2. **Conception.** L'équipe prépare, sous le plafond de la classe (EXIG-CON-02, section 12.1), le niveau d'autonomie visé, que la fonction risques et conformité arrête (tableau 44), ainsi que le patron d'orchestration (chapitre 7), les contrats et la carte d'agent (section 6.8). Si la conception change l'autonomie maximale envisagée ou le parcours de décision, la fonction risques et conformité réexamine la classe. S'il y a des RP, l'EFVP commence ici : la Loi sur le privé l'exige pour tout projet d'acquisition, de développement ou de refonte d'un système d'information impliquant des RP, et le RPRP est consulté dès le début (art. 3.3)[56]. Jalon du cycle de vie : revue d'architecture et de sécurité (tableau 44).
3. **Construction et évaluation.** L'agent est bâti sur les gabarits de la plateforme, avec son jeu d'évaluation et ses tests de sécurité (section 9.9). Jalon du cycle de vie : atteinte des seuils d'évaluation validée par une équipe distincte de l'équipe de construction (section 10.4), fiche complète et, s'il y a des RP, EFVP terminée (EXIG-CON-04); pour les classes modérée et élevée, exercice d'équipe rouge (EXIG-SEC-23); homologation provisoire, bornée au niveau du pilote, selon la grille de l'annexe A (EXIG-GOV-08).
4. **Pilote.** Périmètre, population et durée sont bornés. Le pilote d'un agent qui vise N3 ou N4 commence au niveau immédiatement inférieur et se termine au niveau visé, sous surveillance renforcée (EXIG-GOV-11). Jalon du cycle de vie : homologation selon la grille d'homologation (annexe A), qui confirme l'homologation provisoire pour la production complète.
5. **Production.** Surveillance, évaluation continue et gestion des changements. La revue de valeur (EXIG-FIN-10) réunit le parrain, le responsable technique et l'équipe FinOps; elle conclut à la poursuite, à la reconception ou au retrait de l'agent, et sa décision est consignée au registre. Jalon du cycle de vie : attestation périodique (EXIG-GOV-13), préparée par le parrain et approuvée par la fonction risques et conformité, ou par le comité pour la classe élevée (tableau 44), tous les 12 mois, tous les 6 mois pour la classe élevée.
6. **Retrait.** Révocation des identités, retrait du catalogue, avis aux consommateurs et archivage. Jalon du cycle de vie : preuve de révocation au registre, établie par l'équipe plateforme et validée par la sécurité (tableau 44).

La suspension se distingue du retrait. Elle est réversible et prend deux formes. La suspension de sécurité est immédiate : c'est le coupe-circuit, que le NIST rattache aux mécanismes permettant de supplanter, désengager ou désactiver un système dont le comportement s'écarte de l'usage prévu (MANAGE 2.4)[74]; elle refuse tout nouvel appel de l'agent (EXIG-IAM-20). La suspension administrative, qui suit une attestation échue, un rôle A vacant ou une dérogation échue (EXIG-GOV-09 et EXIG-GOV-16), bloque les nouvelles tâches seulement, après avis aux consommateurs connus. Ni l'une ni l'autre ne bloque les compensations des sagas en cours, qui passent par le canal de compensation (EXIG-ORC-17). Le retrait est définitif et planifié. Le délai maximal de suspension se fixe selon l'EXIG-IAM-20 et s'éprouve à l'exercice trimestriel de l'EXIG-SEC-26; dans Microsoft Entra Agent ID, par exemple, désactiver le gabarit *(agent identity blueprint)* bloque d'un coup toutes les identités qui en dérivent[92].

EXIG-GOV-11 · DOIT
Jalons du cycle de vie consignés
Un agent **DOIT** franchir dans l'ordre les six jalons du cycle de vie de la figure 25. Seules dérogent à l'ordre les transitions suivantes, chacune consignée avec sa preuve : l'abandon, de tout état vers « retiré »; la suspension, de tout état vers « suspendu », et le retour à l'état antérieur; la réévaluation (EXIG-GOV-12), de « production » vers les jalons de conception, d'évaluation et de pilote. Chaque passage est consigné au registre avec la date, le décideur désigné par le tableau 44, qui y tient un seul rôle A, et les preuves (rapport d'évaluation, EFVP, résultats des tests de sécurité, grille d'homologation de l'annexe A). Le pilote d'un agent qui vise N3 ou N4 **DEVRAIT** s'exécuter d'abord au niveau immédiatement inférieur, puis, en dernière étape, au niveau visé sous surveillance renforcée.
Pourquoi : une décision sans trace ne peut être ni auditée ni contestée; le registre devient le dossier de preuve de l'agent.

EXIG-GOV-12 · DOIT
Réévaluation sur changement significatif
Les changements suivants **DOIVENT** déclencher une réévaluation de la classe de risque et du niveau d'autonomie, achevée avant leur mise en service : changement du modèle servi, y compris derrière un alias (valeur de `gen_ai.response.model`), ou de sa version; modification de l'invite système; ajout ou retrait d'un outil, ou passage d'un outil à un palier supérieur; nouvelle version majeure d'un contrat ou d'un protocole; changement des propriétés [A], [B] ou [C] de la règle de deux (section 9.6), de la mémoire, du corpus de récupération ou du juge d'évaluation (section 10.4); nouvelle population visée ou nouvelle finalité; modification du domaine d'exploitation (ODD); nouvelle catégorie ou nouvelle source de données, notamment de RP; changement de fournisseur ou de lieu de traitement des données; révision d'une taxonomie de menaces retenue (EXIG-SEC-02), appréciée au plus chaque semestre pour MITRE ATLAS; incident grave (section 12.8) ou dérive détectée par l'évaluation continue. Cette liste est la seule qui fasse foi; les autres listes du cadre y renvoient. La réévaluation reprend les jalons de conception, d'évaluation et de pilote dans la mesure du changement. Si le changement ne peut attendre, l'ancienne version reste en service; à défaut, l'agent est suspendu jusqu'à la fin de la réévaluation. Aucune voie ne permet de fonctionner au-dessus du plafond de la classe réévaluée.
Pourquoi : le niveau d'autonomie vaut pour une configuration donnée; Feng, McDonald et Zhang prévoient le renouvellement du certificat d'autonomie à chaque changement de l'agent ou de son environnement[83], et la ligne directrice E-23 du BSIF déclenche une revue indépendante lors de modifications des modèles ou des données[8].

EXEMPLE

Un agent de rapprochement de factures fournisseurs de classe modérée, homologué au niveau N3, utilise un modèle dont le fournisseur annonce une nouvelle version. La passerelle de modèles conserve la version épinglée pendant que l'équipe rejoue le jeu d'évaluation sur la nouvelle; la fonction risques et conformité confirme la classe, puis approuve la bascule que le parrain demande, consignée au registre. Si les seuils ne sont pas atteints, l'agent reste sur l'ancienne version. Si le fournisseur retire la version épinglée, l'agent passe au modèle de repli homologué (section 7.8) ou est suspendu à la date du retrait; le préavis contractuel de l'EXIG-APP-13 laisse le temps de l'un ou de l'autre. La rétrogradation à N2 n'est admise que si l'approbation humaine compense le défaut constaté : elle ne corrige pas une erreur de qualité, qu'elle ferait seulement présenter aux approbateurs (section 8.7). Dans une institution financière fédérale, la bascule suit en outre la revue indépendante prévue par E-23.

EXIG-GOV-13 · DOIT
Attestation périodique du parrain
Le parrain **DOIT** attester au registre, au moins tous les 12 mois et tous les 6 mois pour un agent de classe élevée, que l'agent est encore requis et que sa finalité, ses mandants, ses portées, sa classe et son niveau d'autonomie restent exacts. L'équipe plateforme **DOIT** revoir chaque trimestre la liste des agents sans parrain actif, sans fiche à jour ou inactifs, et faire passer à l'état « suspendu » ceux qui ne sont pas régularisés. La présente exigence est la seule source du traitement des agents orphelins; l'EXIG-IAM-07 ne s'y ajoute que pour la révocation de leurs justificatifs. L'attestation est approuvée par la fonction risques et conformité, ou par le comité pour la classe élevée (EXIG-GOV-03).
Pourquoi : Microsoft recommande de faire attester par les parrains, tous les 6 à 12 mois, que chaque agent est encore requis, et de revoir chaque trimestre les agents orphelins[92]; les périodicités de 12 mois et de 6 mois, inscrites dans la plage que recommande Microsoft, et la revue trimestrielle sont des choix du cadre.

EXIG-GOV-14 · DOIT
Retrait vérifiable
Le retrait d'un agent **DOIT** comprendre : la révocation de toutes ses identités, justificatifs et jetons, propagée aux passerelles et aux fournisseurs dans le délai fixé selon l'EXIG-IAM-20 (EXIG-IAM-07); un avis aux consommateurs connus au moins 60 jours avant la fin du service, sauf retrait anticipé pour un motif de sécurité, décidé par le comité et précédé d'une suspension de sécurité (EXIG-INT-14, EXIG-INT-18); le retrait de ses entrées au catalogue; l'archivage de ses journaux d'audit et de ses versions selon les durées de conservation applicables; l'archivage ou la destruction de ses mémoires selon la politique de conservation; une preuve de révocation inscrite au registre. Le préavis de 60 jours est celui de l'EXIG-INT-14, qui en porte le fondement.
Pourquoi : le NIST AI RMF demande des processus de déclassement sécuritaire (GOVERN 1.7)[74], le livre blanc de l'OpenID Foundation recommande un retrait formel propagé, par exemple par une opération SCIM DELETE[311], et les événements CAEP permettent de diffuser la révocation aux parties concernées[344].

11.6 Dérogations

Cette section encadre les exceptions au cadre. Une dérogation est une exception écrite, temporaire et compensée; elle n'est jamais une permission tacite. Sans dérogations, un cadre trop rigide pousse les équipes vers des agents fantômes; sans discipline, les dérogations vident le cadre de son contenu.

Une demande de dérogation contient au minimum :

- l'identifiant de chaque exigence visée et le ou les agents ou composants (passerelle, registre, serveur MCP, gabarit) concernés;

- la justification : pourquoi la conformité est impossible ou disproportionnée maintenant;
- le risque résiduel et son effet sur la classe de risque;
- les mesures compensatoires, par exemple un niveau d'autonomie abaissé, une approbation humaine ajoutée, un plafond de coût réduit ou une surveillance renforcée;
- la durée, la date d'échéance et le plan de retour à la conformité;
- le demandeur, les avis reçus et le décideur.

EXIG-GOV-15 · DOIT
Demande et décision écrites
Toute dérogation **DOIT** être demandée par écrit, avec le contenu minimal ci-dessus, par le parrain de l'agent visé ou, pour une dérogation qui vise un composant, par le responsable de ce composant ou du domaine, instruite par l'architecture d'entreprise avec l'avis de la sécurité, de la fonction risques et conformité et, s'il y a des RP, du RPRP, puis accordée ou refusée par le comité. Le comité **PEUT** déléguer à l'architecture d'entreprise les dérogations qui visent un agent de classe faible, pour 90 jours au plus (choix du cadre), à la condition que la décision soit prise par une personne autre que celle qui a instruit la demande. La dérogation est inscrite au registre et visible dans la fiche de chaque agent ou composant visé. Une mesure transitoire de cohorte (EXIG-GOV-16) tient lieu de dérogation pour les agents existants qu'elle vise.
Pourquoi : une exception accordée oralement ne se retrouve ni à l'audit ni à l'échéance; la délégation pour la classe faible évite d'engorger le comité.

EXIG-GOV-16 · DOIT
Durée bornée
Une dérogation **DOIT** porter une date d'échéance d'au plus six mois. Elle **PEUT** être renouvelée une seule fois, par décision du comité, sur présentation d'un plan de retour à la conformité mis à jour. À l'échéance, l'exigence s'applique de nouveau; si l'agent n'y satisfait pas, il passe à l'état « suspendu » (suspension administrative, section 11.5). Le registre **DOIT** avertir le parrain 30 jours avant l'échéance. Une mesure transitoire de cohorte n'est pas soumise à cette durée : son échéance est liée à un jalon (EXIG-GOV-16). Ces durées sont des choix du cadre.
Pourquoi : une exception sans échéance devient la règle; une exception qu'on veut renouveler plusieurs fois signale plutôt une règle à revoir, ce que tranche la révision semestrielle du cadre (section 1.6).

EXIG-GOV-17 · NE DOIT PAS
Dérogation à une exigence non dérogeable
Une dérogation **NE DOIT PAS** autoriser : un niveau d'autonomie NX; l'exécution d'une action P3 sans approbation humaine hors bande (EXIG-AUT-09); l'usurpation d'identité au lieu de la délégation (section 9.3); le relais d'un jeton reçu (EXIG-IAM-12); l'exploitation d'un agent sans fiche complète au registre ou sans parrain nommé, hormis la fiche minimale d'un existant inventorié (EXIG-GOV-16); le dépassement du plafond d'autonomie de la classe de risque (EXIG-CON-02); l'autorisation au-delà de N2 d'un agent qui atteint les seuils de la règle d'or (EXIG-AUT-07); l'exposition simultanée d'un agent à du contenu non fiable, à des systèmes sensibles ou des données privées et à un canal d'envoi sans le retrait de l'EXIG-SEC-06; l'exploitation d'un agent sans journal d'audit (EXIG-OBS-11); ou le manquement à une obligation légale ou réglementaire. Cette liste est la seule qui fasse foi; la grille de l'annexe A en est la projection point par point.
Pourquoi : ces règles protègent contre des dommages irréversibles, dont l'exfiltration est le type, ou contre une responsabilité légale que l'entreprise ne peut pas écarter par une décision interne.

Régime transitoire et exigibilité (application des EXIG-GOV-16 et EXIG-GOV-17). (a) Aucun agent **NE DOIT** exercer un palier, un niveau d'autonomie ou une topologie avant que les contrôles qui les conditionnent soient en service et homologués : aucun outil P2 sans compensation déclarée et canal de compensation (EXIG-ORC-17); aucun outil P3 tant que la passerelle ne vérifie pas le jeton d'approbation (EXIG-AUT-12); aucun appel interdomaines hors de la passerelle d'agents, sous la seule tolérance du point (c). (b) Chaque point de la grille de l'annexe A est exigible dès que l'agent exerce la capacité qu'il vise (tout agent, P2 et plus, P3, N3 et plus, interdomaine, multiagent), quelle que soit la phase de la feuille de route; les obligations légales et les points de l'EXIG-GOV-17 sont exigibles immédiatement. (c) Un agent en exploitation à l'adoption du cadre, ou découvert ensuite hors registre, reçoit le statut « existant inventorié » : une fiche minimale (champs de l'étape Proposition, annexe B) et un parrain nommé dans les cinq jours ouvrables qui suivent sa découverte, faute de quoi il est désactivé. Le comité **PEUT** placer une liste de tels agents sous une mesure transitoire de cohorte, par une seule décision dont l'échéance est liée à un jalon de la feuille de route (chapitre 15), et non au délai de l'EXIG-GOV-16. Cette mesure permet l'émission de justificatifs sur la base de la fiche minimale; elle n'admet aucun point de l'EXIG-GOV-17 ni aucune obligation légale, ne couvre jamais un dépassement du plafond de la classe, et limite les appels qui contournent encore la passerelle aux paliers P0 et P1, par des justificatifs en lecture seule chez le système cible. (d) Une échéance externe (loi, autorité) ne bouge pas; une échéance du cadre, comme la migration MCP de l'EXIG-MCP-22, ne change que par une révision du cadre (section 1.6). Le registre est complet lorsque 100 % des agents actifs ont une fiche ouverte et un parrain nommé. Pourquoi : la feuille de route ordonne le travail, mais un contrôle n'existe que lorsqu'il est en service; sans régime de transition, l'annexe B refuserait tout jeton aux agents existants, et la transition reposerait sur des centaines de dérogations instruites une à une.

11.7 Gouvernance des standards

Cette section fixe la façon dont le cadre fait évoluer son catalogue des protocoles et standards (section 6.3). Les standards agentiques changent de trimestre en trimestre : sans processus explicite, chaque annonce de fournisseur devient une décision d'architecture improvisée.

Le Cadre européen d'interopérabilité rappelle que l'interopérabilité est régulièrement perturbée par les changements législatifs, organisationnels et technologiques, et qu'elle exige des procédures de gestion du changement[157]. Les exemples récents le confirment. La révision 2026-07-28 de MCP a introduit une politique de cycle de vie à trois états (Active, Deprecated, Removed) : une fonctionnalité dépréciée reste au moins douze mois dans la spécification, ou au moins 90 jours en cas de retrait accéléré pour un risque de sécurité actif (avis de sécurité publié ou exploitation documentée)[34, 196]. Les conventions sémantiques GenAI d'OpenTelemetry sont au niveau de stabilité Development et peuvent changer sans processus de dépréciation[181, 188]. OAuth 2.1 demeure un Internet-Draft[176].

Chaque statut du catalogue emporte une conséquence de gouvernance. « Adopter » désigne le choix par défaut des nouveaux projets. « Évaluer » autorise des pilotes bornés, avec une date de décision. « Surveiller » limite le standard à la veille et aux essais hors production, sans données réelles. « Contenir » laisse un usage existant en production derrière un adaptateur jusqu'à l'échéance de son plan de sortie daté, et interdit tout nouvel usage. « Suspendu », prononcé pour un motif de sécurité, fait cesser immédiatement le service par la passerelle (EXIG-INT-06).

> **EXIG-GOV-18 · DOIT**
> **Révision trimestrielle du catalogue**
> L'architecture d'entreprise **DOIT** réviser le catalogue des protocoles au moins chaque trimestre et soumettre les changements de statut à l'approbation du comité. Chaque changement est daté et motivé; une dépréciation ou un retrait s'accompagne d'un plan de migration dont l'échéance précède la fin

de la fenêtre de dépréciation annoncée par le standard. Une révision extraordinaire **DOIT** avoir lieu, dans les 15 jours ouvrables (choix du cadre), dès qu'un standard au statut « Adopter » ou « Contenir » publie une version incompatible, une dépréciation, un retrait accéléré ou un correctif de sécurité; une simple annonce de date relève de la révision trimestrielle (section 1.6). Pour les statuts « Évaluer » et « Surveiller », les signaux de veille de l'EXIG-INT-23 s'appliquent, et un avis de sécurité visant un standard au statut « Évaluer » suspend les pilotes qui l'emploient jusqu'à la révision. Un composant sans politique de dépréciation, comme les conventions GenAI d'OpenTelemetry, est épinglé et soumis à un test de non-régression à chaque nouvelle version.

Pourquoi : une fenêtre de dépréciation de douze mois ne protège que l'organisation qui la voit venir et planifie sa migration dès l'annonce.

EXIG-GOV-19 · DOIT

Critères d'admission d'un standard

Un standard **DOIT** satisfaire aux six critères suivants, propres au cadre, pour obtenir le statut « Adopter » :

- spécification publique, versionnée et assortie d'une politique de compatibilité et de dépréciation (pour une RFC, le mécanisme Obsoletes et Updates en tient lieu);
- gouvernance neutre ou multipartite (organisme de normalisation ou fondation), et non celle d'un seul fournisseur;
- statut final ou stable (RFC, Recommandation du W3C, version ou révision publiée comme stable); un brouillon, un composant de niveau expérimental ou un composant sans politique de dépréciation n'est admis qu'avec une réserve inscrite au catalogue, qui lève les critères 1 et 3, porte une date de réexamen et l'épingle à une version précise, adossée à un standard publié ou à un mécanisme stable; une extension MCP s'apprécie extension par extension selon son stade (Experimental : non admise; Beta : admise avec réserve; Stable : admise);
- au moins deux mises en œuvre indépendantes, ou une suite de tests de conformité exécutable dans la chaîne d'intégration et épinglée à une étiquette; tant qu'une suite est en préversion (alpha), ses résultats sont consignés et ne sont bloquants que pour les tests restés stables pendant deux versions;
- modèle de sécurité documenté, compatible avec le chapitre 9;
- licence ouverte, sans redevance.

Pourquoi : ces critères écartent les annonces prématurées. L'AAIF, par exemple, n'admet un projet qu'au terme d'un processus formel (proposition publique, triage, recommandation du comité technique, approbation du conseil d'administration, puis formalités juridiques et intégration technique avec la Linux Foundation); une proposition déposée ne suffit pas[42, 263] (section 6.9).

EXIG-GOV-20 · DOIT

Veille désignée et usage encadré

L'architecture d'entreprise **DOIT** désigner une personne chargée de la veille pour chaque organisme qui fait évoluer un standard du catalogue, au minimum l'AAIF (projets et groupes de travail), l'IETF (groupes OAuth et WIMSE), OpenTelemetry, le W3C, le NIST (son *Center for AI Standards and Innovation*, CAISI, et son *National Cybersecurity Center of Excellence*, NCCoE), l'OWASP GenAI Security Project, l'OpenID Foundation, la CNCF, l'OpenAPI Initiative et AsyncAPI. La fonction risques et conformité **DOIT** de même désigner une personne chargée de la veille réglementaire (CAI, Commissariat à la protection de la vie privée du Canada, BSIF, AMF, Autorités canadiennes en valeurs mobilières (ACVM), Parlement du Canada et Assemblée nationale, Commission européenne). Un protocole, un standard ou une extension

> **NE DOIT PAS** être utilisé avec des données réelles, même en pilote, s'il ne figure pas au catalogue au statut « Évaluer » (pilotes seulement) ou « Adopter » ou, pour un usage existant, au statut « Contenir » avec un plan de sortie daté. Le statut « Surveiller » n'admet que des essais sans données réelles, et le statut « Suspendu » aucun usage.
> Pourquoi : les pratiques d'identité et de sécurité des agents ne sont pas stabilisées. L'AAIF anime huit groupes de travail, dont identité et confiance, observabilité et traçabilité, gouvernance et alignement réglementaire[40]; le CAISI du NIST a lancé le 17 février 2026 l'AI Agent Standards Initiative[411]; le groupe WIMSE de l'IETF voit se multiplier les brouillons individuels sur la délégation entre agents[336].

L'entreprise PEUT participer aux consultations publiques et aux groupes de travail pour faire valoir ses besoins; le NCCoE du NIST a, par exemple, publié le 29 septembre 2026 la synthèse des commentaires de plus de 600 intervenants sur son document de réflexion consacré à l'identité et à l'autorisation des agents[338]. Le cadre lui-même est révisé chaque semestre par le comité : les dérogations accordées, les incidents et les résultats de la veille alimentent cette révision, et le chapitre 14 situe ces pratiques dans le modèle de maturité.

12 Risques, conformité et réglementation

Ce chapitre relie la classe de risque d'un agent aux obligations qui en découlent. Il traduit en exigences vérifiables la Loi 25 et le droit québécois, le cadre fédéral et sectoriel canadien, le règlement européen sur l'IA, le NIST AI RMF et ISO/IEC 42001, puis les réunit dans une matrice de correspondance et un index de preuves unique. Il fixe enfin la transparence due aux personnes, la réponse aux incidents agentiques et une évaluation d'impact unifiée. L'état du droit est celui du 27 octobre 2026.

> **ATTENTION**
> Ce chapitre résume l'intention des textes; leur application à un cas précis relève des affaires juridiques.

Le principe est simple : on ne bâtit pas un programme de conformité par texte de loi. Chaque agent reçoit une classe de risque, et cette classe déclenche un ensemble de contrôles dont les preuves (traces, journal d'audit, évaluations d'impact, résultats d'évaluation) servent à la fois à la Loi 25, au règlement européen et aux référentiels volontaires. Les seuils, délais internes et fréquences de revue propres au cadre sont signalés comme tels.

12.1 Classes de risque des agents

La classe de risque mesure ce qui arrive si l'agent se trompe; elle détermine l'intensité de la gouvernance qui s'applique à lui.

Trois notions coexistent et ne se confondent pas. Le **niveau d'autonomie** (N0 à N4, section 8.1) dit jusqu'où l'agent agit sans approbation. Le **palier d'outil** (P0 à P3, section 8.3) dit ce que fait chaque outil. La **classe de risque** dit quelles conséquences un agent peut produire sur des personnes, sur l'entreprise ou sur des tiers. La classe fixe le plafond du niveau d'autonomie, et le contrôle d'un appel est l'union des contrôles qu'exigent la classe, le niveau et le palier (EXIG-AUT-10).

Cette gradation répond à un constat partagé. Selon Gartner (communiqué du 26 mai 2026), appliquer une gouvernance uniforme à tous les agents mènera à des échecs; l'analyste recommande une gouvernance proportionnelle[95]. Le cadre de gouvernance de l'IA agentique de l'Infocomm Media Development Authority (IMDA, Singapour) désigne la portée des actions de l'agent, leur réversibilité et son niveau d'autonomie

comme déterminants du risque[76]. La ligne directrice E-23 du BSIF suit la même logique pour les modèles : une cote de risque détermine l'intensité de la gouvernance, la fréquence des examens et l'autorité d'approbation[8]. Les quatre critères d'analyse du cadre qui fixent le niveau d'autonomie sous le plafond de la classe (rayon d'impact, réversibilité, délai de détection et de récupération, observabilité reconstructive) sont décrits à la section 8.2; ce ne sont pas les critères du tableau 46.

Tableau 46 — Classes de risque des agents : critères, plafond d'autonomie et contrôles minimaux

Classe	Critères (un seul suffit)	Plafond d'autonomie	Contrôles minimaux	Revue
Élevée	Décision à effet important sur une personne (crédit, emploi, assurance, accès à un service essentiel); décision fondée exclusivement sur un traitement automatisé de RP (art. 12.1 de la Loi sur le privé; art. 65.2 de la Loi sur l'accès pour les organismes publics); système à haut risque au sens du règlement européen sur l'IA; action financière, juridique ou irréversible au-delà des seuils de classe que la fonction risques et conformité arrête pour l'agent (EXIG-CON-01), distincts du seuil d'exécution autonome d'un outil; renseignements personnels sensibles	N2	EFVP si l'agent traite des RP (EXIG-CON-04) et évaluation d'impact unifiée (section 12.9); équipe rouge avant production (section 9.9); homologation par le comité d'architecture et des risques agentiques; P3 approuvé par deux approbateurs distincts, dont au moins un n'est pas le mandant (EXIG-AUT-15), hors bande comme pour toute classe (EXIG-AUT-09)	Semestrielle
Modérée	RP non sensibles ou données confidentielles; actions P2 réversibles ou compensables en production; échanges avec des partenaires, des clients ou le public	N3, avec des seuils plus bas et une revue a posteriori renforcée	EFVP si l'agent traite des RP (EXIG-CON-04); volet impact algorithmique si l'agent décide ou recommande à l'égard d'une personne (EXIG-CON-26); revue de sécurité; exercice d'équipe rouge avant production puis annuel (EXIG-SEC-23); évaluation continue (section 10.4)	Annuelle
Faible	Données publiques ou internes non confidentielles (aucun RP, aucun tiers); lecture seule ou actions internes réversibles bornées au domaine de l'agent; aucun effet sur une personne	N3; N4 sur décision du comité	Autoévaluation documentée; évaluation continue; inscription au registre	Annuelle

Plafonds repris de l'EXIG-CON-02, qui fait foi. Choix du cadre. Les fréquences de revue sont des valeurs par défaut que la déclaration de tolérance au risque peut resserrer (EXIG-CON-17).

Un seul critère suffit : la classe retenue est la plus élevée dont un critère est rempli, jamais une moyenne. Les conséquences ne se compensent pas : un agent en lecture seule qui consulte des dossiers médicaux reste de classe élevée, parce qu'une fuite ne se répare pas.

EXEMPLE

Un agent de préqualification de prêts personnels lit des données et produit un avis « admissible » ou « non admissible ». Si cet avis est communiqué au client sans examen réel par un employé, il s'agit d'une décision fondée exclusivement sur un traitement automatisé : l'agent est de classe élevée et plafonné à N2, alors que tous ses outils sont de palier P1. La classe s'apprécie au niveau d'autonomie demandé et au pire cas de supervision (EXIG-CON-01). À l'inverse, un agent qui reclasse des billets d'assistance internes en écriture réversible (P2), sans RP, relève de la classe modérée et peut atteindre N3 sous des seuils déclarés.

EXIG-CON-01 · DOIT
Classe de risque attribuée avant l'inscription
Chaque agent **DOIT** recevoir une classe de risque (faible, modérée ou élevée) selon le tableau 46, attribuée par la fonction risques et conformité avant son inscription au registre (section 11.4) : la fiche est inscrite à l'état « proposé » avec sa classe approuvée. La classe s'évalue sur l'autonomie maximale envisagée et sur le parcours de décision déclaré, avant tout plafonnement; le critère de décision fondée exclusivement sur un traitement automatisé s'apprécie au niveau d'autonomie demandé et au pire cas de supervision. Une classe élevée retenue à ce titre ne redescend qu'après que les mesures de l'EXIG-AUT-21 ont établi une révision humaine significative (EXIG-CON-08) pendant au moins un trimestre. Un niveau demandé au-delà du plafond de l'EXIG-CON-02 est refusé. La classe retenue est la plus élevée dont au moins un critère est rempli; la justification est consignée dans la fiche d'agent.
Pourquoi : une moyenne des critères masquerait la conséquence la plus grave, qui seule commande les contrôles.

EXIG-CON-02 · DOIT
Plafond d'autonomie par classe
Le niveau d'autonomie déclaré au registre **DOIT** respecter le plafond de la classe : N2 pour la classe élevée, N3 pour les classes modérée et faible. N4 n'est permis qu'à un agent de classe faible, sur décision consignée du comité d'architecture et des risques agentiques. Un agent **NE DOIT PAS** opérer au niveau NX, quelle que soit sa classe. La présente exigence est la seule source des plafonds par classe; la section 8.1, le tableau 46 et l'EXIG-GOV-17 y renvoient.
Pourquoi : les plafonds par classe sont un choix du cadre; pour les systèmes à haut risque, le règlement européen exige des mesures de supervision humaine proportionnées aux risques, au niveau d'autonomie et au contexte d'utilisation (art. 14(3))[412].

EXIG-CON-03 · DOIT
Réévaluation à chaque changement significatif
La classe de risque **DOIT** être réévaluée, avant la mise en service du changement, à chaque déclencheur de l'EXIG-GOV-12, qui en tient la seule liste; cette liste couvre les modifications d'un modèle et de ses données qu'E-23 tient pour importantes. La même réévaluation déclenche la mise à jour de l'EFVP et de l'évaluation d'impact unifiée (EXIG-CON-26).
Pourquoi : le guide de la Commission d'accès à l'information (CAI) demande de mettre à jour une EFVP lorsque le projet change, et E-23 fait des modifications d'un modèle et de ses données un déclencheur de revue indépendante[8, 413].

12.2 Loi 25 et droit québécois

Cette section traduit en exigences les obligations québécoises qui touchent directement les agents : évaluation préalable, communication hors Québec, consentement, décisions automatisées, conservation, secteur public et sanctions.

La *Loi modernisant des dispositions législatives en matière de protection des renseignements personnels* (L.Q. 2021, c. 25, « Loi 25 ») a été sanctionnée le 22 septembre 2021. Elle est entrée en vigueur par étapes : le 22 septembre 2022 pour le responsable de la protection des renseignements personnels (RPRP) et les incidents de confidentialité[56], le 22 septembre 2023 pour l'essentiel[56], et le 22 septembre 2024 pour le droit à la portabilité (quelques dispositions accessoires l'étant dès le 22 septembre 2021)[7, 56]. Elle modifie la *Loi sur la protection des renseignements personnels dans le secteur privé* (RLRQ, c. P-39.1, « Loi sur le privé ») et la *Loi*

sur l'accès aux documents des organismes publics et sur la protection des renseignements personnels (RLRQ, c. A-2.1, « Loi sur l'accès »). Sauf mention contraire, les articles cités sont ceux de la Loi sur le privé.

Un point de départ s'impose : l'entreprise demeure responsable des RP qu'elle détient, même lorsqu'un fournisseur de modèles, de plateforme d'agents ou de serveur MCP les conserve ou les traite pour elle (art. 1 et 3.1)[56]; selon la CAI, elle conserve aussi ses obligations en cas d'incident[414]. La loi ne connaît pas de responsabilité « conjointe » : le fournisseur est un mandataire lié par un contrat écrit (art. 18.3)[56] (tableau 47).

Tableau 47 — Articles de la Loi sur le privé qui touchent les agents

Article	Obligation (résumé)	Application aux agents (interprétation du cadre)
3.1	La personne ayant la plus haute autorité exerce la fonction de responsable de la protection des RP, délégable par écrit; titre et coordonnées publiés sur le site Web.	Le responsable est consulté sur chaque agent qui traite des RP et participe à l'homologation des agents de classe élevée (section 11.1).
3.2	Politiques et pratiques de gouvernance (conservation, destruction, rôles, plaintes) approuvées par le responsable; information publiée en termes simples et clairs.	Les règles de conservation des traces et des mémoires d'agents font partie de ces politiques.
3.3	EFVP pour tout projet d'acquisition, de développement ou de refonte d'un système d'information ou de prestation électronique de services impliquant des RP; responsable consulté dès le début; portabilité permise.	Tout nouvel agent, et tout changement de modèle ou d'outils touchant des RP (EXIG-CON-03 et EXIG-CON-04).
3.5 à 3.8	Incidents de confidentialité : mesures pour diminuer le risque; avis « avec diligence » à la CAI et aux personnes en cas de risque de préjudice sérieux; registre de tous les incidents.	Réponse aux incidents agentiques (section 12.8).
8.1	Informer au préalable du recours à une technologie permettant d'identifier, de localiser ou de profiler une personne, et des moyens d'activer ces fonctions.	Un agent qui évalue le rendement au travail, la situation économique, la santé, les préférences ou le comportement d'une personne fait du profilage.
9.1	Produit ou service technologique offert au public et doté de paramètres de confidentialité : plus haut niveau de confidentialité par défaut.	Mémoire persistante, partage de conversations et personnalisation désactivés par défaut dans les agents offerts au public.
11	RP à jour et exacts au moment d'une décision; conservés au moins un an après celle-ci.	Conservation des éléments de décision au dossier de décision (EXIG-CON-09, EXIG-OBS-11).
12	Utilisation limitée aux fins de la collecte, sauf consentement (exprès s'il est sensible) ou exception prévue; la prospection commerciale ou philanthropique n'est pas une fin compatible.	Aucune réutilisation de conversations ou de traces à d'autres fins sans base légale documentée (EXIG-CON-06).
12.1	Décision fondée exclusivement sur un traitement automatisé : informer, expliquer sur demande, permettre la rectification et des observations à un membre du personnel en mesure de réviser la décision.	EXIG-CON-07, EXIG-CON-08 et EXIG-CON-21.
28 et 28.1	Rectification d'un renseignement inexact, incomplet ou équivoque, ou dont la collecte, la communication ou la conservation n'est pas autorisée (art. 28); cessation de la diffusion ou désindexation, aux conditions de l'art. 28.1.	La rectification ou la suppression atteint chaque mémoire, index, cache et dossier de décision de l'agent (EXIG-CON-10).
14	Consentement manifeste, libre, éclairé, donné à des fins spécifiques et demandé pour chacune d'elles, en termes simples et clairs; présenté distinctement s'il est demandé par écrit.	Fin principale (inférence nécessaire au service demandé) et fins secondaires (entraînement, ajustement) distinguées; seules les secondes exigent un consentement distinct ou une autre exception documentée.
17	Avant toute communication hors Québec : EFVP tenant compte de la sensibilité, de la finalité, des mesures de protection et du régime juridique de l'État de destination; protection adéquate; entente écrite.	Tout modèle, serveur MCP, agent délégataire ou magasin de mémoire situé hors Québec (EXIG-CON-05).

Article	Obligation (résumé)	Application aux agents (interprétation du cadre)
18.3	Mandat ou contrat de service écrit : mesures de confidentialité, usage limité au mandat, aucune conservation après l'expiration, avis sans délai de toute violation, droit de vérification.	Clauses fournisseurs (section 13.3), dont l'interdiction d'entraîner des modèles sur les données confiées.
23	Destruction ou anonymisation une fois les fins accomplies, selon le Règlement sur l'anonymisation; un renseignement dépersonnalisé demeure un RP.	Cycle de vie des mémoires et des index vectoriels (EXIG-CON-10).
27 et 32	Accès et copie; transcription écrite et intelligible; depuis le 22 septembre 2024, portabilité des renseignements informatisés recueillis auprès de la personne; réponse écrite au plus tard dans les 30 jours.	Les inférences produites par un agent sont visées par le droit d'accès, mais pas par la portabilité.
90.1 et suiv., 91, 93.1	Sanctions administratives pécuniaires, infractions pénales, dommages-intérêts punitifs.	Voir « Sanctions et recours » ci-dessous.

Source des obligations : Loi sur le privé (RLRQ, c. P-39.1), modifiée par la L.Q. 2021, c. 25[56]; les obligations sont relevées dans la loi modificative, et le texte consolidé n'a pas été relu pour le présent cadre. La colonne de droite est une interprétation du cadre.

Évaluation des facteurs relatifs à la vie privée

L'EFVP est obligatoire dans deux situations qui visent directement les agents : tout projet d'acquisition, de développement ou de refonte d'un système d'information ou de prestation électronique de services impliquant des RP (art. 3.3), et toute communication de RP à l'extérieur du Québec (art. 17)[413]. Elle ne vise donc pas « tout système » en exploitation, mais tout projet qui en crée ou en modifie un. La loi exige qu'elle soit proportionnée à la sensibilité, à la finalité, à la quantité, à la répartition et au support des renseignements, sans prescrire de forme ni de signature[56]. Le guide de la CAI (version 3.1, avril 2024) est recommandé : il prévoit une évaluation de la conformité, une analyse des risques avec stratégies d'atténuation, un inventaire et un « parcours » des renseignements, puis une réévaluation de la nécessité et de la proportionnalité; il cite « améliorer un modèle d'intelligence artificielle » et « rendre une décision automatisée » parmi les finalités à examiner[413].

Pour un agent, le parcours des renseignements est plus long que pour une application classique : invite, contexte récupéré, appels d'outils MCP, délégations A2A, mémoire, traces. L'EFVP du cadre inventorie donc les RP outil par outil et délégation par délégation. La loi n'exige pas d'évaluer les biais dans l'EFVP; le cadre l'exige pour tout agent qui décide ou recommande à l'égard d'une personne, dans le prolongement de la recommandation de la CAI (dès 2020) d'imposer, pour les systèmes de décision automatisée, une EFVP et une analyse d'impact algorithmique couvrant tous les droits fondamentaux, et de celle du gouvernement du Québec pour les décisions automatisées[318, 415].

EXIG-CON-04 · DOIT

EFVP avant tout projet d'agent impliquant des RP

Tout projet d'acquisition, de développement ou de refonte d'un agent impliquant des RP **DOIT** faire l'objet d'une EFVP terminée avant le passage en pilote. Le responsable de la protection des RP **DOIT** être consulté dès le début du projet. L'EFVP **DOIT** inventorier les RP par outil, par délégation et par mémoire, et, lorsque l'agent décide ou recommande à l'égard d'une personne, **DOIT** y joindre le volet impact algorithmique de l'EXIG-CON-26, dont l'analyse des biais tient lieu d'analyse des biais de l'EFVP (exigence propre au cadre).

Pourquoi : article 3.3 de la Loi sur le privé, qui ne prescrit pas le contenu de l'EFVP; l'analyse des biais est une exigence propre au cadre, appuyée par les orientations de la CAI (discrimination parmi les conséquences à évaluer; analyse d'impact algorithmique recommandée au législateur), non une obligation légale[56, 413, 415].

Communication hors Québec et lois étrangères

Confier à un fournisseur situé hors Québec la tâche d'utiliser ou de conserver des RP pour le compte de l'entreprise, par exemple en appelant l'API d'un modèle hébergé ailleurs, relève de l'article 17. L'entreprise réalise d'abord une EFVP qui tient compte de la sensibilité des renseignements, de la finalité, des mesures de protection, y compris contractuelles, et du régime juridique de l'État de destination. La communication est permise si les renseignements bénéficient d'une protection adéquate, et elle fait l'objet d'une entente écrite[56, 416]. Le texte de l'article 17 vise toute communication à l'extérieur du Québec et ne distingue pas les provinces; un index vectoriel hébergé dans une région infonuagique en Ontario déclenche donc l'article 17 au même titre qu'un hébergement aux États-Unis : toute zone hors du Québec en relève[56, 416].

La résidence des données ne règle pas tout. Le CLOUD Act américain (2018) oblige, sur réquisition légale, les fournisseurs assujettis au droit américain à préserver et à divulguer les données en leur possession, sous leur garde ou sous leur contrôle, qu'elles soient situées aux États-Unis ou à l'étranger[417]. Le cadre fédéral de souveraineté numérique (novembre 2025) constate que le stockage au Canada ne place pas à lui seul les données hors de la compétence de tribunaux étrangers, tout en notant que le gouvernement du Canada n'a relevé aucun cas documenté de gouvernement étranger cherchant à accéder aux données d'entreprises canadiennes détenues par des fournisseurs[418]. Le risque est donc réel, mais à pondérer dans l'EFVP. Le cadre retient comme mesures compensatoires le chiffrement à clés tenues hors de portée du fournisseur (gestion externe des clés), une conservation nulle, ou bornée et déclarée, des invites et des sorties chez le fournisseur (EXIG-APP-10) et, pour les RP sensibles, le recours à des fournisseurs sous compétence canadienne. Le chiffrement au repos ne protège pas les données en cours d'inférence, que le modèle traite en clair; le calcul confidentiel attesté est une option à évaluer dans l'EFVP.

> **EXIG-CON-05 · DOIT**
> **Cartographie des lieux de traitement**
> La fiche de chaque agent **DOIT** indiquer le lieu de traitement (province ou pays, région et fournisseur) de chaque modèle appelé, serveur MCP, agent délégataire et magasin de mémoire ou de traces, en précisant si le point d'accès peut traiter hors de la région déclarée (point d'accès mondial ou interrégional). Tout flux de RP vers l'extérieur du Québec, y compris vers une autre province, **DOIT** être couvert par une EFVP au sens de l'article 17 et par une entente écrite avant sa mise en service. Pour tout agent autorisé à traiter des RP, la localisation s'applique sur les trois chemins, par route déclarée au catalogue et non par analyse du contenu : la passerelle de modèles (inférence), la passerelle d'agents (appels MCP et délégations A2A) et le plan mémoire et les index **DOIVENT** refuser toute route vers l'extérieur du Québec qui n'est pas couverte.
> Pourquoi : l'article 17 vise toute communication « à l'extérieur du Québec », autres provinces comprises, et un routage dynamique entre modèles peut créer un transfert que personne n'a décidé[56, 416].

Consentement et finalités

Un RP ne peut servir qu'aux fins pour lesquelles il a été recueilli, sauf consentement (exprès s'il est sensible) ou exception prévue par la loi : fins compatibles ayant un lien pertinent et direct avec les fins initiales, bénéfice manifeste de la personne, prévention de la fraude, fourniture d'un service demandé, recherche ou statistiques avec des renseignements dépersonnalisés. La prospection commerciale ou philanthropique n'est jamais une fin compatible (art. 12)[56]. Le consentement doit être manifeste, libre, éclairé et donné à des fins spécifiques; il est demandé pour chacune de ces fins, en termes simples et clairs (art. 14)[56, 419]. La loi n'emploie pas la notion de consentement « groupé », mais l'exigence d'un consentement par finalité conduit le cadre à distinguer la fin principale, l'inférence nécessaire au service demandé, qui relève de l'exception « fourniture d'un service demandé » ou du consentement initial, des fins secondaires (entraînement ou ajustement fin de modèles), qui exigent un consentement distinct ou une autre exception documentée.

EXIG-CON-06 · DOIT
Finalité vérifiée avant toute réutilisation
Toute réutilisation de conversations, de traces, de mémoires ou de sorties d'agents à une autre fin que celle de la collecte, notamment l'entraînement ou l'ajustement fin de modèles, **DOIT** reposer sur un consentement distinct ou sur une exception légale documentée. Les données **DOIVENT** porter une étiquette de finalité, vérifiée aux points de sortie des magasins (API d'export des traces, des mémoires et des conversations; chaînes d'entraînement et d'ajustement) par la plateforme de données; la passerelle d'agents la vérifie pour les seuls flux agentiques (section 9.4). Un modèle ou un adaptateur ajusté sur des RP est un magasin dérivé : il est inscrit à la fiche, soumis à l'EXIG-CON-10 (durée de vie; réentraînement ou destruction à l'échéance ou au retrait du consentement) et à un test d'extraction lors de l'exercice d'équipe rouge (EXIG-SEC-23).
Pourquoi : articles 12 et 14 de la Loi sur le privé; un contrôle technique empêche qu'une équipe réutilise de bonne foi des traces pour une fin non couverte.

Décisions fondées exclusivement sur un traitement automatisé

L'article 12.1 s'applique lorsqu'une décision concernant une personne est fondée exclusivement sur un traitement automatisé de ses RP. L'entreprise doit l'en informer au plus tard au moment où elle l'informe de la décision. À sa demande, elle doit aussi l'informer des RP utilisés, des raisons et des principaux facteurs et paramètres ayant mené à la décision, ainsi que de son droit de faire rectifier ces renseignements. La personne doit avoir l'occasion de présenter ses observations à un membre du personnel en mesure de réviser la décision[56]. Le défaut d'informer la personne ou de lui permettre de présenter ses observations est expressément un motif de sanction administrative pécuniaire (art. 90.1, par. 5°)[56, 317].

Quand une décision est-elle « exclusivement » automatisée? Selon l'interprétation du gouvernement du Québec pour l'article 65.2 de la Loi sur l'accès, rédigé comme l'article 12.1 et que le cadre transpose par analogie à ce dernier, c'est le cas lorsqu'aucune personne physique n'a exercé un contrôle important. Une intervention humaine mineure, sans effet réel sur le résultat, ne fait pas échapper à l'obligation; en revanche, un outil d'aide à la décision qui fournit des éléments à un employé qui décide lui-même n'est pas visé[318]. Pour un agent de niveau N2, la conséquence est concrète : un bouton « Approuver » cliqué sans information, sans temps et sans autorité réelle ne transforme pas la décision de l'agent en décision humaine. Le même document précise qu'il n'est pas requis de divulguer l'algorithme : le mot « principaux » limite l'explication aux facteurs et paramètres déterminants, ce qui protège les renseignements industriels et commerciaux.

DROIT APPLICABLE

Article 12.1 de la Loi sur le privé (article 65.2 de la Loi sur l'accès pour les organismes publics) : avis au plus tard au moment où la personne est informée de la décision; sur demande, RP utilisés, raisons, principaux facteurs et paramètres, droit de rectification; observations à un membre du personnel en mesure de réviser. L'article 12.1 ne fixe aucun délai de réponse : le délai de 30 jours de l'article 32 vise les demandes d'accès et de rectification. Les RP utilisés pour décider sont conservés au moins un an après la décision (art. 11)[56].

EXIG-CON-07 · DOIT
Avis et explication des décisions automatisées
Pour toute décision concernant une personne fondée exclusivement sur le traitement automatisé de ses RP par un agent, le système **DOIT** : informer la personne au plus tard au moment où la décision lui est communiquée; pouvoir produire sur demande, à partir du dossier de décision (EXIG-OBS-11),

les RP utilisés, les raisons et les principaux facteurs et paramètres ayant mené à la décision; indiquer le droit de rectification; offrir un canal pour présenter des observations à un membre du personnel en mesure de réviser la décision, rôle désigné doté d'un titulaire et d'un suppléant et dimensionné selon le volume des décisions. Les principaux facteurs et paramètres s'établissent à partir des facteurs déterministes du processus : la décision est rendue, ou bornée, par une règle ou un modèle de pointage versionné qui consigne ses facteurs au dossier de décision, et jamais établie à partir du raisonnement affiché du modèle; un agent dont la décision n'est ni rendue ni bornée ainsi **NE DOIT PAS** rendre ces décisions. Le délai de réponse aux observations **DOIT** être d'au plus 30 jours (choix du cadre; l'article 12.1 ne fixe aucun délai). La présente exigence est la seule source des obligations envers la personne au titre de l'article 12.1 de la Loi sur le privé et de l'article 65.2 de la Loi sur l'accès; l'EXIG-AUT-22 et l'EXIG-CON-21 y renvoient.

Pourquoi : article 12.1; le défaut constitue un motif de sanction administrative pécuniaire[56, 317].

EXIG-CON-08 · NE DOIT PAS

Aucune approbation nominale

Une approbation humaine **NE DOIT PAS** être considérée comme retirant le caractère exclusivement automatisé d'une décision si l'approbateur ne réunit pas les quatre conditions suivantes : l'autorité de modifier ou d'annuler la décision; la compétence pour l'examiner; l'accès à toutes les données pertinentes, et non à la seule recommandation de l'agent; le temps nécessaire pour l'examiner. La qualification se fait a priori, à l'EFVP et à la fiche, et une décision est réputée exclusivement automatisée tant que ces conditions ne sont pas établies. Le taux d'approbation sans modification est suivi en permanence, par approbateur (EXIG-AUT-21, section 8.7); une mesure qui révèle une approbation nominale requalifie la décision, et les obligations de l'EXIG-CON-07 s'appliquent. La présente exigence est la seule source de ce test; l'EXIG-AUT-23 y renvoie.

Pourquoi : selon l'interprétation gouvernementale, une intervention humaine mineure, sans effet réel sur le résultat, ne fait pas échapper à l'obligation[318].

EXIG-CON-09 · DOIT

Conservation des éléments de décision

Les éléments de toute décision d'agent touchant une personne **DOIVENT** être conservés au moins un an après la décision, sous une forme qui permet de répondre aux demandes prévues aux articles 12.1 et 27 : RP en entrée, résultats d'outils qui ont servi à décider, versions de l'agent, du modèle et des outils, facteurs retenus et approbations. Le dossier de décision (EXIG-OBS-11) en est la source, et non les traces ni le journal d'audit, qui ne portent ni le contenu ni les résultats d'outils; la personne reçoit une transcription écrite et intelligible.

Pourquoi : l'article 11, dans la lecture qu'en fait le cadre d'après la loi modificative (sans relecture du texte consolidé), exige de conserver au moins un an les RP utilisés pour décider; la conservation des versions et des facteurs va au-delà du minimum légal pour rendre l'explication possible[56].

Conservation, mémoire et destruction

Une fois les fins accomplies, l'entreprise doit détruire le renseignement ou l'anonymiser pour des fins sérieuses et légitimes, selon les critères du Règlement sur l'anonymisation des renseignements personnels (art. 23); un renseignement dépersonnalisé, notion définie à l'article 12, demeure un renseignement personnel. La CAI estime en outre que certaines données, dont les données génétiques, biométriques et de géolocalisation, ne peuvent être adéquatement anonymisées[56, 420]. Pour un agent, la règle vise la mémoire épisodique et sémantique (section 5.5), les index vectoriels et les traces. Un plongement vectoriel *(embedding)* calculé à

partir d'un RP n'est pas anonyme du seul fait qu'il est illisible pour un humain : le cadre le traite comme un RP.

EXIG-CON-10 · DOIT
Durée de vie des mémoires et des traces
Chaque magasin de mémoire, index vectoriel, dépôt de traces, historique d'exécution durable, journal de saga, sujet d'événements, dossier de décision et modèle ou adaptateur ajusté sur des RP (EXIG-CON-06) d'un agent **DOIT** avoir une durée de conservation liée à sa finalité, inscrite dans la fiche d'agent et appliquée automatiquement. Cette durée respecte les minimums suivants, dont le plus long l'emporte quand plusieurs s'appliquent : traces d'un agent à haut risque au sens du RIA, six mois (art. 26); journal d'audit, 24 mois (EXIG-OBS-13); journal d'exécution des bacs à sable, 24 mois (EXIG-SEC-16, choix du cadre); dossier de décision, un an après la décision (EXIG-CON-09, EXIG-OBS-11); registre des incidents de confidentialité, cinq ans (EXIG-CON-24); captures de débogage, 14 jours au plus (EXIG-OBS-08); dépôt d'évaluation, durée bornée à la fiche, 30 jours par défaut (EXIG-EVA-04). À l'échéance, sous réserve du gel des preuves d'un incident (EXIG-CON-23) et de toute conservation pour litige notifiée, les données **DOIVENT** être détruites ou anonymisées selon le règlement; les plongements calculés à partir de RP suivent le même régime que les RP d'origine. Une demande de rectification ou de suppression (art. 28) **DOIT** atteindre, dans le délai de l'article 32, chaque mémoire, index, cache et dossier de décision inscrits à la fiche, avec une suppression physique vérifiable (compactage ou reconstruction de l'index); les données sous gel sont marquées et exclues de toute nouvelle décision.
Pourquoi : article 23 de la Loi sur le privé; une mémoire sans échéance accumule des RP au-delà de leur finalité.

Secteur public québécois
Les organismes publics appliquent les dispositions équivalentes de la Loi sur l'accès : décisions fondées exclusivement sur un traitement automatisé (art. 65.2), EFVP (art. 63.5), règles de gouvernance (art. 63.3), incidents de confidentialité (art. 63.8 à 63.11) et communication hors Québec (art. 70.1); l'article 63.1 porte sur les mesures de sécurité[56, 318]. Trois textes gouvernementaux s'y ajoutent :

- l'indication d'application IA-RI-2025-003-OP sur l'IA générative, en vigueur le 5 décembre 2025, exige notamment une EFVP dès la conception de tout système d'IA générative, même sans RP apparent, la classification préalable des données numériques gouvernementales, des essais de fiabilité, une supervision humaine proportionnée à l'autonomie, l'interdiction d'entrer des renseignements confidentiels dans un système d'IA générative public et, pour les données confidentielles, la préférence pour des fournisseurs québécois ou canadiens hébergés au Québec ou au Canada[421];
- l'Énoncé de principes pour une utilisation responsable de l'IA par les organismes publics (édition 2025) compte 12 principes; le principe 11 vise expressément l'IA agentique et exige des mécanismes permettant la validation, l'intervention humaine ou l'arrêt des actions du système, par exemple des validations avant certaines actions critiques et des mécanismes d'arrêt d'urgence[379];
- l'Énoncé de politique de souveraineté numérique et d'approvisionnement en TI (février 2026) oriente l'État vers l'hébergement souverain, des centres de données relevant de la compétence du Québec et le logiciel libre[422].

L'indication d'application et l'Énoncé de principes lient les organismes publics; l'énoncé de politique de souveraineté numérique énonce une orientation de l'État. Pour les entreprises privées, le cadre les retient comme référence de bonne pratique. Le gouvernement met aussi à la disposition des organismes des outils officiels : analyse des décisions automatisées, modèle de registre des incidents, analyse du régime juridique d'une communication hors Québec et schéma de décision sur l'EFVP[423]. Ils constituent de bons points de départ pour les gabarits du cadre.

Sanctions et recours

La CAI peut imposer une sanction administrative pécuniaire d'au plus 50 000 $ à une personne physique et, à une entreprise, d'au plus 10 000 000 $ ou 2 % du chiffre d'affaires mondial de l'exercice précédent, selon le montant le plus élevé (art. 90.12)[56]; un engagement accepté par la CAI et respecté écarte la sanction[317]. Les infractions pénales (art. 91) entraînent une amende de 5 000 $ à 100 000 $ pour une personne physique et, pour une entreprise, de 15 000 $ à 25 000 000 $ ou 4 % du chiffre d'affaires mondial, selon le montant le plus élevé; les amendes sont portées au double en cas de récidive (art. 92.1). Une atteinte illicite intentionnelle ou résultant d'une faute lourde donne en outre droit à des dommages-intérêts punitifs d'au moins 1 000 $ (art. 93.1)[56]. La page des sanctions de la CAI et son rapport annuel 2024-2025 ne font état d'aucune sanction liée aux décisions automatisées : le risque tient aux plafonds légaux, non à des précédents[424].

Le droit évolue. Dans son rapport quinquennal déposé le 11 juin 2026, la CAI formule 74 recommandations, dont une meilleure prise en compte des inférences algorithmiques et une meilleure définition du processus d'EFVP[425]. Le cadre traite dès maintenant les inférences produites par les agents comme des RP à gouverner.

12.3 Cadre fédéral et sectoriel canadien

Cette section situe les obligations fédérales et sectorielles qui s'ajoutent au droit québécois, et distingue ce qui est en vigueur de ce qui n'est encore qu'un projet (tableau 48).

Tableau 48 — Textes fédéraux et sectoriels canadiens : statut au 27 octobre 2026 et effet sur les agents

Texte	Statut	Ce qu'il implique pour les agents
LPRPDE (Loi sur la protection des renseignements personnels et les documents électroniques)	En vigueur	Atteinte présentant un risque réel de préjudice grave : déclaration au Commissariat et avis aux personnes « le plus tôt possible » (LPRPDE, par. 10.1(2) et (6)); toutes les atteintes sont consignées, registre conservé 24 mois[426, 427].
Projet de loi C-27, dont la Loi sur l'intelligence artificielle et les données (LIAD)	Resté à l'étape du comité à la fin de la session, le 6 janvier 2025; mort au Feuilleton à la prorogation[428, 429]	Aucune obligation : la LIAD n'existe pas.
Projet de loi C-36, Loi sur la protection de la vie privée et des données des consommateurs	Déposé et lu une première fois le 15 juin 2026; à l'étape de la deuxième lecture; non en vigueur[430]	Viserait tout système décisionnel automatisé qui appuie ou remplace le jugement humain; lorsqu'il sert à faire des prédictions, des recommandations ou des décisions pouvant avoir un effet juridique ou un effet important semblable : usage décrit dans l'information rendue publique (art. 62), explication sur demande et observations écrites à un employé pouvant réviser (art. 63). Les sanctions administratives (art. 113 et 114) ne visent que certaines dispositions, dont l'art. 62(1) mais pas l'art. 63; le plafond est le plus élevé de 10 M$ et de 3 % des revenus mondiaux bruts[431].
Directive sur la prise de décisions automatisée du Secrétariat du Conseil du Trésor du Canada (SCT) et évaluation de l'incidence algorithmique (EIA)	S'applique à l'administration fédérale	Systèmes développés ou acquis après le 1er avril 2020 qui remplacent ou appuient le jugement humain dans des décisions administratives; EIA obligatoire (65 questions de risque, 41 d'atténuation, niveaux d'incidence I à IV), faite au début de la conception, mise à jour avant la production, résultats publiés[432, 433].
Guide sur l'utilisation de l'IA agentique (gouvernement du Canada, 2026)	Orientation pour l'administration fédérale	Autonomie bornée, lecture seule par défaut, points de contrôle humains pour les actions qui modifient l'état des systèmes, propriétaire humain désigné, identifiant unique par agent, journalisation dans un système que l'agent ne peut modifier, coupe-circuit externe, texte externe traité comme des données[353].
Ligne directrice E-23 du BSIF, Gestion du risque de modèle	Publiée le 11 septembre 2025; en vigueur le 1er mai 2027 pour les institutions financières fédérales[8]	« Modèle » inclut les méthodes d'IA et d'apprentissage automatique (la prise de décision autonome relève des principes de surveillance); inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs, cote de risque, revue indépendante, surveillance de la dérive.

Texte	Statut	Ce qu'il implique pour les agents
Avis du BSIF sur le signalement des incidents liés à la technologie et à la cybersécurité	En vigueur depuis le 13 août 2021[434]	Signalement écrit au BSIF dans les 24 heures, ou plus tôt si possible.
Ligne directrice B-13 du BSIF, Gestion des risques liés à la technologie et au cyberrisque	Publiée en juillet 2022 (lettre du BSIF du 13 juillet 2022); en vigueur depuis le 1er janvier 2024**[435, 436]**	Gestion des identités et des accès fondée sur le risque (authentification multifacteur, accès privilégiés, moindre privilège, attestation périodique, surveillance des comptes de service); journalisation continue et centralisée; incidents d'origine tierce visés.
Code de conduite volontaire sur l'IA générative avancée (Innovation, Sciences et Développement économique Canada, ISDE)	Septembre 2023; volontaire[437]	Six résultats : responsabilisation, sécurité, justice et équité, transparence, surveillance humaine, validité et robustesse.
Principes des commissaires à la protection de la vie privée pour une IA générative responsable	7 décembre 2023, cosignés par la CAI[438]	Neuf principes; menaces propres à l'IA (injection, inversion de modèle, débridage); mécanisme de contestation avec révision humaine pour les décisions assistées par l'IA.

Trois conséquences pratiques en découlent. D'abord, une institution financière fédérale devrait traiter chaque agent comme un compte de service privilégié, dans l'esprit de B-13 : identité propre, accès minimal, surveillance (section 9.2). Ensuite, le projet C-36 viserait aussi les décisions partiellement automatisées; le cadre conçoit donc l'explicabilité des agents pour couvrir les deux régimes, sans attendre l'adoption du projet (EXIG-CON-21). Enfin, le guide fédéral sur l'IA agentique converge avec les exigences des chapitres 8 à 10. Les institutions financières de compétence québécoise intègrent en outre à leur registre de conformité les attentes de l'Autorité des marchés financiers (AMF) en matière d'IA, énoncées dans sa Ligne directrice sur l'utilisation de l'intelligence artificielle (document daté de mars 2026, publié en avril 2026, en vigueur le 1er mai 2027)[491], que le présent cadre ne reprend pas.

La veille porte aussi sur deux textes connexes : la Loi concernant la cybersécurité (ancien projet de loi C-8), sanctionnée le 15 juin 2026 (L.C. 2026, ch. 9), et le projet de loi C-22 sur l'accès légal, à l'étude au Sénat en octobre 2026[439, 440]. Si sa partie 2 reprend le régime de l'ancien projet de loi C-26, la Loi concernant la cybersécurité vise aussi directement les exploitants désignés de cybersystèmes essentiels, dont des systèmes bancaires et de compensation (programme de cybersécurité, déclaration des incidents); ce point est à vérifier sur le texte sanctionné (section H.5). L'effet de ces deux textes sur les agents et sur leurs fournisseurs est suivi par la veille réglementaire de l'EXIG-GOV-20.

EXIG-CON-11 · DOIT

Régimes applicables inscrits à la fiche

La fiche de chaque agent **DOIT** énumérer les régimes juridiques et sectoriels qui s'appliquent à lui (Loi sur le privé ou Loi sur l'accès, LPRPDE, règlement européen sur l'IA, RGPD, lignes directrices et avis du BSIF, lignes directrices de l'AMF pour une institution de compétence québécoise, directive fédérale, Loi concernant la cybersécurité pour un exploitant désigné, textes gouvernementaux québécois) et, pour chacun, les obligations retenues et l'exigence du cadre qui y répond. L'équipe risques et conformité valide cette liste à l'homologation et à chaque réévaluation (EXIG-GOV-12).

Pourquoi : un même agent peut relever de plusieurs régimes dont les seuils et les délais diffèrent; seule une liste explicite permet de satisfaire chacun selon son propre déclencheur et son propre délai (EXIG-CON-25).

EXIG-CON-12 · DOIT
Arrimage à E-23 pour les institutions financières fédérales
Une institution financière fédérale **DOIT**, au plus tard le 1er mai 2027, inscrire chaque agent et chaque modèle qu'il utilise, y compris ceux des fournisseurs, à l'inventaire des modèles attendu par la ligne directrice E-23 (le cadre étend l'inscription à chaque agent et à chaque modèle utilisé), avec le parrain (propriétaire au sens d'E-23), la cote de risque, la version et l'état de validation. Elle **DOIT** ensuite inscrire tout agent ou modèle nouveau avant sa mise en production. L'inventaire est le registre d'entreprise (section 11.4), que l'équipe plateforme opère et où le parrain inscrit l'agent (tableau 44). E-23 ne fixe aucune échéance de validation des modèles existants : l'exigence porte sur l'inventaire et l'état de validation, et les validations sont planifiées selon la cote de risque (choix du cadre). Un changement de modèle, de fournisseur, de sources ou de catégories de données d'entrée déclenche la réévaluation de l'EXIG-GOV-12 et, s'il s'agit d'une modification importante, la revue prévue par E-23.
Pourquoi : E-23 inclut les méthodes d'IA et d'apprentissage automatique dans sa définition de modèle, traite de la prise de décision autonome dans ses principes de surveillance et attend un inventaire d'entreprise[8].

12.4 Règlement européen sur l'IA

Cette section indique quand le règlement (UE) 2024/1689 (RIA) s'applique à une entreprise canadienne et ce qu'il exige d'un agent à haut risque.

Portée : l'utilisation des sorties dans l'Union

Le RIA ne s'applique pas parce qu'une entreprise « opère en Europe ». Selon l'article 2(1), il vise notamment les fournisseurs qui mettent un système d'IA sur le marché ou en service dans l'Union, où qu'ils soient établis, les déployeurs établis ou situés dans l'Union, ainsi que les fournisseurs et déployeurs établis dans un pays tiers lorsque les sorties produites par le système sont utilisées dans l'Union[61, 441]. Un agent exploité à Montréal dont les recommandations servent à une filiale européenne peut donc être visé. Le RIA définit le système d'IA comme un système automatisé conçu pour fonctionner à différents niveaux d'autonomie, qui déduit des entrées qu'il reçoit la manière de générer des sorties pouvant influencer des environnements physiques ou virtuels (art. 3(1)); le déployeur est celui qui l'utilise sous sa propre autorité (art. 3(4))[61]. Le cadre considère tout agent comme un système d'IA au sens de cette définition.

Les systèmes à haut risque relèvent de l'article 6 et des annexes I et III. L'annexe III couvre huit domaines : biométrie; infrastructures critiques; éducation et formation; emploi et gestion des travailleurs; accès aux services essentiels privés et publics, dont l'évaluation de la solvabilité et la tarification en assurance vie et maladie; répression; migration, asile et contrôle des frontières; administration de la justice et processus démocratiques[442].

Calendrier modifié par le règlement (UE) 2026/1744

Le RIA est entré en vigueur le 1er août 2024. Les pratiques interdites s'appliquent depuis le 2 février 2025, les règles sur les modèles d'IA à usage général depuis le 2 août 2025, et l'application générale, dont les obligations de transparence de l'article 50, depuis le 2 août 2026, avec une transition au 2 décembre 2026 pour le marquage de l'article 50(2) des systèmes génératifs mis sur le marché avant le 2 août 2026[57]. Le règlement (UE) 2026/1744 du 8 juillet 2026, dit « omnibus numérique sur l'IA », en vigueur depuis le 27 juillet 2026, a reporté les obligations du haut risque : au 2 décembre 2027 pour les systèmes de l'annexe III et au 2 août 2028 pour ceux de l'annexe I (produits réglementés)[58, 443]. Il ajoute des interdictions applicables le 2 décembre 2026 (hypertrucages sexuels non consentis, matériel d'abus pédosexuel) et prévoit au moins un bac à sable réglementaire de l'IA opérationnel dans chaque État membre au 2 août 2027[57].

ATTENTION

Un report n'est pas un moratoire. Le règlement (UE) 2026/1744 ne suspend ni les pratiques interdites ni les obligations des modèles d'IA à usage général[443]. Surtout, les journaux et la documentation d'un agent ne se reconstituent pas après coup : un agent conçu en 2026 sans eux ne sera pas conforme en décembre 2027.

Tableau 49 — Articles du règlement européen sur l'IA et réponse du cadre

Article	Rôle visé (F : fournisseur; D : déployeur)	Exigence (résumé)	Réponse du cadre
2	F, D	Portée : fournisseurs et déployeurs, y compris hors Union lorsque les sorties y sont utilisées.	Applicabilité consignée dans la fiche (EXIG-CON-13).
4	Fournisseur et déployeur. Maîtrise de l'IA : prendre des mesures pour soutenir la maîtrise de l'IA de leur personnel et des autres personnes qui exploitent ou utilisent les systèmes pour leur compte, selon leurs connaissances, le contexte d'emploi et les personnes visées; aucun niveau précis n'est exigé d'une personne (art. 4(1), remplacé par le règlement (UE) 2026/1744). La Commission et les États membres soutiennent ces efforts (art. 4(2)).	Approbateurs habilités et formés (EXIG-AUT-15); pour les autres personnes qui exploitent ou utilisent les agents, mesures de maîtrise de l'IA à prévoir dans le programme de formation de l'entreprise (aucune exigence du cadre).	
6, annexes I et III	F, D	Classification des systèmes à haut risque.	Classe élevée d'office (EXIG-CON-01 et EXIG-CON-13; choix du cadre : la dérogation de l'art. 6(3) n'est pas utilisée). La détection de la fraude financière est exclue de l'annexe III, point 5(b).
9	F	Système de gestion des risques continu et itératif sur tout le cycle de vie.	Classe de risque et réévaluations (EXIG-CON-01, EXIG-CON-03); cycle de vie (section 11.5).
12	F (conception), D (conservation, art. 26(6))	Enregistrement automatique des événements pendant toute la durée de vie.	Traçage (section 10.1) et journal d'audit (section 10.3); la signature et l'enregistrement à cinq éléments sont des choix du cadre, au-delà du minimum légal.
13	F	Transparence et notice d'utilisation destinées aux déployeurs.	Fiche d'agent (annexe B) et carte d'agent remises aux équipes qui déploient l'agent.
14	F (conception), D (mise en œuvre, art. 26)	Supervision humaine effective : comprendre le système, rester conscient du biais d'automatisation, ignorer ou inverser une sortie, interrompre le système et le mettre dans un état sûr.	Approbation vérifiable (section 8.5), lutte contre l'approbation machinale (section 8.7), coupe-circuit (section 7.8).

Article	Rôle visé (F : fournisseur; D : déployeur)	Exigence (résumé)	Réponse du cadre
15	F	Exactitude, robustesse et cybersécurité.	Évaluation continue (section 10.4) et sécurité (chapitre 9).
11, 16, 17, 43, 47 à 49	F, ou D devenu F (art. 25)	Documentation technique (art. 11), obligations générales (art. 16), système de gestion de la qualité (art. 17), évaluation de la conformité (art. 43), déclaration UE de conformité et marquage CE (art. 47 et 48), enregistrement (art. 49).	Applicables si l'entreprise est ou devient fournisseur (EXIG-CON-15).
25	D devenu F	Un déployeur devient fournisseur s'il appose son nom, modifie substantiellement le système ou en change la destination; accord écrit avec les tiers fournisseurs de composants intégrés (25(4)), sauf pour les outils, services et composants rendus publics sous licence libre et ouverte, hors modèles d'IA à usage général.	Revue de requalification (EXIG-CON-15); clauses fournisseurs (section 13.3).
26	D	Obligations du déployeur : notice, supervision compétente, données d'entrée pertinentes, surveillance et suspension, journaux conservés au moins six mois, information des travailleurs et des personnes visées.	EXIG-CON-16.
27	D	Analyse d'impact sur les droits fondamentaux (AIDF) avant la première utilisation, pour certains déployeurs.	Évaluation d'impact unifiée (section 12.9).
50	F, D	Informer les personnes qu'elles interagissent avec un système d'IA; marquer les contenus synthétiques; informer les personnes exposées à un système de reconnaissance des émotions ou de catégorisation biométrique (art. 50(3)).	EXIG-CON-19 et EXIG-CON-20.
72	F	Surveillance après commercialisation pendant toute la durée de vie, y compris l'interaction avec d'autres systèmes d'IA.	Traces des délégations A2A et analyse des chaînes multiagents dans le plan de surveillance.
73	F (le D informe d'abord le F, art. 26(5))	Signalement des incidents graves aux autorités de surveillance du marché.	Réponse aux incidents (section 12.8).
86	D	Toute personne visée par une décision prise sur la base des sorties d'un système à haut risque de l'annexe III (sauf le point 2), qui produit des effets juridiques ou l'affecte de façon importante, a droit à des explications claires et pertinentes sur le rôle du système et sur les principaux éléments de la décision.	Explication des décisions, entièrement ou partiellement automatisées (EXIG-CON-21, EXIG-CON-07).

Sources : règlement (UE) 2024/1689, tel que modifié par le règlement (UE) 2026/1744 (EUR-Lex)[58, 61]; lecture article par article des articles 9, 13 et 72, à titre secondaire, sur le site non officiel du Future of Life Institute[444, 445, 446]. La colonne du milieu désigne le rôle visé : fournisseur ou déployeur.

EXIG-CON-13 · DOIT

Applicabilité du RIA déterminée par l'usage des sorties

La fiche de chaque agent **DOIT** indiquer si ses sorties sont utilisées dans l'Union européenne, ou destinées à l'être (destinataires, filiales ou clients qui s'y trouvent), et si son usage relève d'un domaine de l'annexe III. Un agent dont les sorties sont utilisées dans l'Union pour un usage de l'annexe III **DOIT** être classé en classe élevée dès la décision de classement (EXIG-CON-01), donc avant le passage en pilote, et soumis aux exigences du tableau 49 qui visent son rôle, sans attendre le 2 décembre 2027.

Pourquoi : pour un fournisseur ou un déployeur établi hors de l'Union, le critère de l'article 2(1)(c) est l'utilisation des sorties dans l'Union; les preuves exigées ne se constituent qu'en cours d'exploitation (raisonnement du cadre)[441].

EXIG-CON-14 · NE DOIT PAS
Aucun usage interdit
Un agent **NE DOIT PAS** être homologué pour une pratique interdite par le RIA, quel que soit le lieu d'utilisation de ses sorties (choix du cadre). Le registre tient la liste de ces pratiques, mise à jour selon le règlement (UE) 2026/1744, et la revue d'homologation vérifie la finalité de l'agent contre cette liste.
Pourquoi : les interdictions s'appliquent depuis le 2 février 2025, de nouvelles s'ajoutent le 2 décembre 2026, et le report du haut risque ne les touche pas[57, 443].

EXIG-CON-15 · DOIT
Revue de requalification en fournisseur
Toute orchestration qui affecte un modèle, un agent ou un système d'IA à usage général à un usage de l'annexe III, qui modifie substantiellement un système à haut risque ou qui y appose le nom de l'entreprise **DOIT** déclencher, avant l'homologation, une revue de requalification en fournisseur au sens de l'article 25(1). Si l'entreprise devient fournisseur, elle **DOIT** satisfaire aux obligations du fournisseur (art. 16 et lignes du tableau 49 marquées « Fournisseur »), dont les accords écrits avec les tiers qui fournissent des outils, services, composants ou modèles intégrés au système (art. 25(4)).
Pourquoi : la composition d'agents peut, à elle seule, changer la destination d'un composant et faire basculer l'entreprise dans le rôle de fournisseur (art. 25(1))[61].

EXIG-CON-16 · DOIT
Obligations du déployeur d'un agent à haut risque
Pour un agent à haut risque au sens du RIA, l'entreprise **DOIT** : confier la supervision humaine à des personnes compétentes, formées et dotées de l'autorité nécessaire; veiller à la pertinence des données d'entrée qu'elle contrôle; surveiller le fonctionnement et suspendre l'usage en cas de risque; conserver les journaux sous son contrôle au moins six mois (le cadre exige davantage pour le journal d'audit, EXIG-OBS-13; les minimums par magasin sont ceux de l'EXIG-CON-10); informer les travailleurs concernés avant une mise en service en milieu de travail et les personnes visées par une décision prise ou assistée par le système.
Pourquoi : article 26 du RIA, applicable aux systèmes de l'annexe III à compter du 2 décembre 2027[57, **447**].

12.5 NIST AI RMF, ISO/IEC 42001 et normes associées

Cette section situe les référentiels volontaires et certifiables qui structurent la gestion des risques de l'IA et retient les sous-catégories et mesures les plus utiles aux agents.

NIST AI RMF 1.0 et profil IA générative

Le NIST AI RMF 1.0 (NIST AI 100-1), publié le 26 janvier 2023, s'articule autour de quatre fonctions : Gouverner (GOVERN), fonction transversale, Cartographier (MAP), Mesurer (MEASURE) et Gérer (MANAGE). Il est d'application volontaire; le NIST indique qu'il est en cours de révision dans le cadre du plan d'action américain sur l'IA, sans calendrier publié pour la version révisée, le document prévoyant lui-même un examen formel au plus tard en 2028[99, 448]. Il compte 72 sous-catégories (GOVERN 1.1 à 6.2, MAP 1.1 à 5.2, MEASURE 1.1 à 4.3, MANAGE 1.1 à 4.3) et définit sept caractéristiques d'une IA digne de confiance : valide et fiable; sûre; sécurisée et résiliente; responsable et transparente; explicable et interprétable; respectueuse de la vie privée; équitable, avec gestion des biais nuisibles[74]. Le profil IA générative (NIST AI 600-1, 26 juillet 2024) décrit douze risques propres à l'IA générative ou aggravés par elle; au moins cinq touchent directement les agents : la sécurité de l'information (section 9.6), la confabulation (section 12.7), la vie privée

(section 12.2), la configuration humain-IA (biais d'automatisation, dépendance excessive) et l'intégration de la chaîne de valeur et des composants (intégration non traçable de composants tiers)[449].

Les sous-catégories suivantes sont les plus directement utiles aux agents[74] :

- **GOVERN 1.3** : processus qui déterminent le niveau d'activités de gestion des risques selon la tolérance au risque de l'organisation; **GOVERN 1.6** : mécanismes d'inventaire des systèmes d'IA, dotés de ressources selon les priorités de risque (le registre d'agents); **GOVERN 1.7** : déclassement sécuritaire (le cadre y rattache la révocation des identifiants);
- **GOVERN 6.1** et **6.2** : politiques sur les risques liés aux tiers et contingence en cas de défaillance d'un système de tiers jugé à haut risque (serveurs MCP et agents externes);
- **MAP 3.5** : processus de supervision humaine définis, évalués et documentés;
- **MEASURE 2.4** : surveillance en production du fonctionnement et du comportement du système; **MEASURE 2.7** : évaluation de la sécurité et de la résilience; **MEASURE 3.1** : suivi des risques émergents;
- **MANAGE 2.3** : réponse aux risques jusque-là inconnus et reprise; **MANAGE 2.4** : mécanismes et responsabilités pour supplanter, désengager ou désactiver un système (le coupe-circuit); **MANAGE 4.1** : plans de surveillance après déploiement couvrant le recours et la neutralisation par un humain *(appeal and override)*, l'intervention en cas d'incident, la reprise, la gestion du changement et le déclassement.

ISO/IEC 42001 et normes associées

ISO/IEC 42001:2023 (1re édition, 18 décembre 2023) spécifie les exigences d'un système de management de l'IA (SMIA). Elle suit la structure harmonisée des normes de systèmes de management, comme ISO/IEC 27001 : articles 4 (contexte), 5 (leadership), 6 (planification, dont l'appréciation des risques en 6.1.2, leur traitement en 6.1.3 et l'évaluation d'impact des systèmes d'IA en 6.1.4), 7 (support), 8 (fonctionnement), 9 (évaluation des performances) et 10 (amélioration)[395]. Son annexe A, normative, compte 38 mesures réparties en neuf objectifs (A.2 à A.10). Les plus directement applicables aux agents sont A.5 (évaluation des impacts des systèmes d'IA), A.6.2.6 (exploitation et surveillance), A.6.2.8 (enregistrement des journaux d'événements), A.9 (utilisation responsable et usage prévu) et A.10 (relations avec les tiers et les clients)[395, 450]. La certification est délivrée par des organismes conformes à ISO/IEC 17021-1 et à ISO/IEC 42006:2025[451].

Trois normes complètent l'ensemble. ISO/IEC 42005:2025 donne des lignes directrices pour évaluer l'impact d'un système d'IA sur les personnes et la société, à quels moments du cycle de vie, et pour intégrer cette évaluation au SMIA; ISO/IEC 23894:2023 traite de la gestion des risques propres à l'IA; ISO/IEC 22989:2022 établit la terminologie et définit l'agent d'IA (3.1.1)[59, 452, 453]. Le NIST AI RMF et ISO/IEC 42001 sont complémentaires (appréciation du présent cadre) : le premier est un cadre d'application volontaire, la seconde une norme d'exigences certifiable par tierce partie[448, 451]. Une entreprise qui vise la certification tient une déclaration d'applicabilité qui rattache les exigences du présent cadre aux mesures de l'annexe A; le lien avec le modèle de maturité est traité à la section 14.3.

Ce que ces référentiels ne sont pas

AI TRiSM *(AI Trust, Risk and Security Management)* est un cadre d'analyste propriétaire de Gartner, non une norme : le cadre ne le place pas au même rang que le RIA, ISO/IEC 42001 ou le NIST AI RMF. La littérature scientifique l'a adapté aux systèmes multiagents autour de l'explicabilité, du ModelOps, de la sécurité et de la confidentialité, chacun sous l'angle de la gouvernance du cycle de vie[454]. De même, aucune publication du NIST ne fixe encore de profil d'interopérabilité des agents. L'AI Agent Standards Initiative du Center for AI Standards and Innovation (CAISI) du NIST, lancée le 17 février 2026, et le projet de superpositions de contrôles SP 800-53 (COSAiS, *Control Overlays for Securing AI Systems*, renommé COSIS, *Control Overlays for Super Intelligence Systems*; page du projet mise à jour le 20 octobre 2026), qui prévoit des cas d'usage « agent unique » et « multiagents », relèvent de la veille (section 11.7)[411, 455]. Il en va de même de la note

de concept du 7 avril 2026 sur un profil consacré aux infrastructures critiques, document préparatoire non contraignant[456].

EXIG-CON-17 · DOIT
Déclaration de tolérance au risque
Le comité d'architecture et des risques agentiques **DOIT** faire approuver par le conseil d'administration ou la haute direction une déclaration de tolérance au risque qui fixe, pour chaque classe, sans être moins stricte que le tableau 46 ni que les obligations légales, le niveau d'activités de gestion des risques (contrôles, fréquence des revues, autorité d'approbation) et les seuils au-delà desquels un agent est suspendu (au minimum : incidents par gravité, dérive de l'évaluation continue, taux d'approbation sans modification et coût). La déclaration **DOIT** être revue chaque année et après tout incident grave (section 12.8).
Pourquoi : GOVERN 1.3 demande de proportionner la gestion des risques à la tolérance de l'organisation; sans seuils écrits, chaque équipe fixe les siens[74].

12.6 Matrice de correspondance

La matrice relie les quatre fonctions du NIST AI RMF aux articles d'ISO/IEC 42001, aux obligations de la Loi 25, du RIA et des textes du BSIF (E-23, avis d'incident), et aux artefacts du cadre qui en font la preuve. Elle constitue une interprétation interne du cadre, non une table de correspondance publiée par le NIST ou l'ISO.

Tableau 50 — Matrice de correspondance : NIST AI RMF, ISO/IEC 42001, Loi 25, BSIF, RIA et artefacts du cadre

Fonction NIST	ISO/IEC 42001	Loi 25 (Loi sur le privé)	RIA	BSIF	Artefacts et contrôles du cadre
Gouverner : GOVERN 1.1, 1.2, 1.3, 1.6, 1.7, 2.1, 6.1, 6.2	Art. 4 et 5 (5.2 politique, 5.3 rôles); A.2, A.3, A.10	Art. 3.1, 3.2, 18.3	Art. 25 et 26	E-23 : inventaire des modèles, cote de risque, gouvernance du risque de modèle	Déclaration de tolérance au risque (EXIG-CON-17); registre avec parrain nommé (section 11.4); matrice RACI (section 11.2); clauses fournisseurs (section 13.3); retrait avec révocation des identités (section 11.5)
Cartographier : MAP 1.1 à 5.2, dont MAP 3.5	Art. 6 (6.1.2 à 6.1.4); A.5	Art. 3.3, 8.1, 17	Art. 6 et annexe III; art. 9, 27 et 50	E-23 : identification des modèles, y compris de tiers	Classe de risque (EXIG-CON-01); niveau d'autonomie et paliers d'outils (chapitre 8); lieux de traitement (EXIG-CON-05); évaluation d'impact unifiée (EXIG-CON-26)
Mesurer : MEASURE 2.4, 2.5, 2.7, 3.1	Art. 9 (9.1 à 9.3); A.6.2.4, A.6.2.6, A.6.2.8, A.7.4	Art. 11, 12.1, 27	Art. 12, 15, 72	E-23 : validation et surveillance de la dérive	Traçage (section 10.1); journal d'audit (section 10.3); évaluation continue (section 10.4); taux d'approbation sans modification (section 8.7)
Gérer : MANAGE 2.3, 2.4, 4.1	Art. 8 et 10; A.9	Art. 3.5 à 3.8, 12.1 (révision), 23	Art. 14, 26, 73, 86	E-23 : revue indépendante des modifications; avis d'incident (24 heures); B-13	Coupe-circuit (section 7.8); compensation (section 7.5); approbation vérifiable (section 8.5); réponse aux in-

Fonction NIST	ISO/IEC 42001	Loi 25 (Loi sur le privé)	RIA	BSIF	Artefacts et contrôles du cadre
					cidents (EXIG-CON-23 à EXIG-CON-25); destruction des mémoires (EXIG-CON-10)

Interprétation du cadre, établie à partir de NIST AI 100-1 et du catalogue d'ISO/IEC 42001**[74, 395]**.

Deux confusions courantes sont à éviter. L'objectif A.7 d'ISO/IEC 42001 porte sur les données des systèmes d'IA (acquisition, qualité, provenance, préparation), et non sur l'évaluation des performances, l'audit interne ou la revue de direction, qui relèvent de l'article 9. Les sous-catégories MANAGE 3.1 et 3.2 visent les ressources de tiers et les modèles préentraînés; le coupe-circuit relève de MANAGE 2.4 et le déclassement sécuritaire de GOVERN 1.7[74]. Pour les preuves, la matrice s'applique par identifiant d'exigence (EXIG-CON-18) : les régimes que ses colonnes ne nomment pas (LPRPDE, Loi sur l'accès, RGPD, MANAGE 3.1 et 3.2) se rattachent par la liste des régimes de la fiche (EXIG-CON-11).

EXIG-CON-18 · DOIT
Base de preuves unique
Chaque preuve produite par la plateforme ou par les équipes (trace, enregistrement d'audit, dossier de décision, EFVP, évaluation d'impact, résultat d'évaluation, rapport d'équipe rouge, décision d'homologation) **DOIT** être référencée une seule fois dans un index de preuves, qui porte ses étiquettes (identifiants des exigences du cadre auxquelles elle répond et, par le tableau 50, les dispositions externes), son empreinte et son emplacement. La preuve reste dans son magasin d'origine (journal d'audit en ajout seul, traces, dossier de décision, outil de gouvernance, risque et conformité), en une seule version qui fait foi, sauvegardes non comprises. L'index est exigible dès le jalon 2; sa consolidation outillée vient en phase Industrialisation. L'équipe risques et conformité **DOIT** revoir la matrice chaque année.
Pourquoi : un index unique évite de produire quatre dossiers pour un même contrôle et permet de démontrer, pour une demande précise à une date précise, qu'un engagement a été respecté.

12.7 Transparence envers les personnes

Une personne a le droit de savoir qu'elle a affaire à un agent, de reconnaître un contenu produit par un agent et de comprendre une décision qui la concerne.

L'article 50 du RIA, applicable depuis le 2 août 2026, oblige les fournisseurs à concevoir les systèmes qui interagissent directement avec des personnes de façon qu'elles sachent qu'elles interagissent avec un système d'IA, sauf si c'est évident, et à marquer de façon lisible par machine les contenus synthétiques. Les déployeurs divulguent les hypertrucages et les textes générés publiés pour informer le public sur des questions d'intérêt public, sauf contrôle éditorial humain, et informent les personnes exposées à un système de reconnaissance des émotions ou de catégorisation biométrique (art. 50(3)). L'information est claire et fournie au plus tard lors de la première interaction; un délai transitoire jusqu'au 2 décembre 2026 vise le marquage des systèmes déjà sur le marché avant le 2 août 2026[57, 457]. Le cadre va un peu plus loin que ce minimum : il informe toute personne, même lorsque l'interaction paraît évidente, et identifie tout contenu d'agent diffusé à l'externe.

Au Québec, la transparence passe aussi par l'avis préalable au profilage (art. 8.1), la confidentialité par défaut (art. 9.1), l'information des décisions automatisées (art. 12.1) et le droit d'accès à une transcription intelligible (art. 27). Les principes des commissaires à la protection de la vie privée demandent un mécanisme de contestation avec révision humaine pour les décisions assistées par l'IA, et pas seulement pour celles

qui sont entièrement automatisées[438]. Le raisonnement affiché par un modèle n'est pas forcément une explication fidèle : l'IMDA rappelle qu'il peut ne pas refléter fidèlement les actions de l'agent[76].

EXIG-CON-19 · DOIT
Divulgation de l'interaction avec un agent
Toute personne qui interagit avec un agent, par écrit ou par la voix, **DOIT** en être informée clairement au plus tard lors de la première interaction, même lorsque la nature artificielle de l'interlocuteur paraît évidente (choix du cadre). Un agent **NE DOIT PAS** se présenter comme une personne. La personne exposée à une analyse de ses émotions ou de ses caractéristiques biométriques par un agent **DOIT** en être informée de même (art. 50(3) du RIA).
Pourquoi : article 50 du RIA, que le cadre étend à toutes les interactions pour éviter une appréciation au cas par cas de ce qui est « évident »[457].

EXIG-CON-20 · DOIT
Identification des contenus produits par un agent
Tout contenu produit ou substantiellement modifié par un agent et diffusé à l'externe (courriel, publication, document, image, audio) **DOIT** être identifié comme tel. Est substantiellement modifié un contenu dont la substance n'a pas été rédigée par une personne; la relecture humaine ne dispense pas de l'identification, dont le format est fixé par canal (mention dans le courriel, métadonnées du document, filigrane de l'image ou de l'audio). Lorsque l'entreprise fournit un système génératif visé par l'article 50 du RIA, le marquage **DOIT** en outre être lisible par machine.
Pourquoi : l'article 50 n'impose l'identification que de certains contenus; l'identification de tout contenu diffusé à l'externe est un choix du cadre, qui permet aussi de retrouver la trace d'un contenu en cas d'incident ou de plainte.

EXIG-CON-21 · DOIT
Explication intelligible et canal de révision
Chaque avis de décision rendu à l'égard d'une personne avec l'aide d'un agent, que la décision soit entièrement ou partiellement automatisée, **DOIT** indiquer le canal de révision humaine et ses coordonnées. Pour une décision fondée exclusivement sur un traitement automatisé, les obligations de l'EXIG-CON-07 s'appliquent; le cadre les étend, délai de 30 jours compris, aux décisions partiellement automatisées (choix du cadre), ce qui couvre aussi l'explication due au titre de l'article 86 du RIA. L'explication fournie sur demande présente en langage clair les principaux facteurs et paramètres de la décision, établis selon l'EXIG-CON-07, sans divulguer l'algorithme ni les poids du modèle; le raisonnement affiché par le modèle n'en tient jamais lieu.
Pourquoi : l'interprétation gouvernementale limite l'explication aux facteurs déterminants, et couvrir les décisions partiellement automatisées anticipe le projet C-36 et les principes des commissaires[318, 431].

EXIG-CON-22 · DOIT
Vérification humaine du contenu juridique
Tout contenu juridique produit par un agent et destiné à un usage externe (tribunal, autorité, client, partenaire) **DOIT** être vérifié avant sa diffusion par une personne compétente, qui confirme son exactitude et, s'il cite des sources, que chacune existe et appuie l'énoncé. Est un contenu juridique : un avis juridique, un acte de procédure, une communication à une autorité, ou un engagement contractuel nouveau ou modifié; une réponse tirée d'un gabarit approuvé par les affaires juridiques n'en est pas un. La personne compétente est un rôle inscrit à la fiche. L'outil d'envoi externe de ces contenus est classé P3 au catalogue, de sorte que la vérification prend la forme de l'approbation de l'EXIG-AUT-09.

> Pourquoi : dans *Specter Aviation c. Laprade* (2025 QCCS 3521), la Cour supérieure du Québec a imposé une sanction de 5 000 $, en vertu de l'article 342 du Code de procédure civile, pour le dépôt de références inexistantes générées par l'IA[458].

12.8 Incidents agentiques

Un incident agentique se gère comme un incident de sécurité, avec deux particularités : l'agent peut continuer d'agir pendant qu'on l'analyse, et ses effets peuvent exiger une compensation métier.

Le cadre définit l'incident agentique comme tout événement de sécurité, de confidentialité, d'intégrité ou de disponibilité qui implique un agent, ses identités, ses mémoires ou ses outils, que l'agent en soit l'auteur ou la cible : action non autorisée, fuite ou perte de données, décision erronée ayant produit un effet, contournement de garde-fou, emballement des coûts, vol d'un jeton, exfiltration d'une mémoire, compromission d'un serveur MCP ou panne. Tout incident de confidentialité au sens de la Loi 25 qui implique un agent en est un cas particulier, par exemple un connecteur MCP trop permissif qui expose le dossier d'un autre client. L'enjeu n'est pas théorique : en 2024-2025, la CAI a reçu 514 avis d'incidents de confidentialité, en hausse de 16 %, dont 80 % du secteur privé, et les accès non autorisés y dominent (251 avis)[424].

Chaque incident reçoit une gravité, de S1 (la plus grave) à S4, selon son rayon d'atteinte, la présence de RP, l'irréversibilité de ses effets et les régimes de notification qu'il déclenche; la fonction risques et conformité l'attribue, indépendamment de l'équipe dont l'agent est en cause. Est un incident grave, au sens du cadre, tout incident S1 ou S2, ainsi que tout incident grave au sens du RIA (art. 3(49)). Les cinq temps s'appliquent en entier aux incidents S1 et S2; pour S3 et S4, la contention peut se limiter à l'outil ou à la fonction en cause. Un incident qui touche un composant partagé (serveur MCP, passerelle, modèle) relève d'un plan de réponse de plateforme, porté par l'équipe plateforme, qui coordonne les agents touchés.

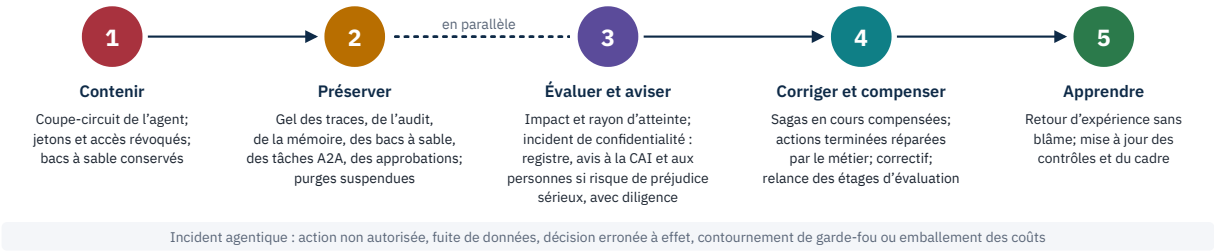


Figure 26 — Réponse à un incident agentique. Les cinq temps se lisent de gauche à droite : on contient l'agent avant de chercher la cause, sans détruire ses preuves volatiles (bacs à sable, contexte), et on fige les preuves avant de corriger; la qualification et le premier avis démarrent en parallèle dès la contention; puis on répare et on apprend. Source : cadre CRE-IA-2026-01.

1. **Contenir.** L'équipe de garde actionne le coupe-circuit de l'agent (EXIG-IAM-20, EXIG-ORC-28) : coupure du réseau de ses bacs à sable et désactivation de son identité, révocation de ses jetons et de ses accès, suspension de ses délégations en cours (état de chaque tâche A2A lu avant son annulation) et annulation, consignée, des actions en attente d'approbation. Les bacs à sable et le contexte d'exécution sont conservés, et non détruits (dérogation à l'EXIG-SEC-09 pendant l'incident), et le canal de compensation reste ouvert (EXIG-ORC-17). La contention est acquise lorsque le délai de révocation mesuré est écoulé et que l'annulation ou le refus des tâches A2A externes est confirmé.
2. **Préserver.** Les traces, le journal d'audit, les instantanés de mémoire, les bacs à sable, le contexte d'exécution, l'état des tâches A2A déléguées, les approbations annulées, les captures de débogage en cours, les dossiers de décision en cause et les versions exactes de l'agent, du modèle, des invites et des définitions d'outils sont figés; les purges et l'échantillonnage sont suspendus pour l'agent visé. Pour un modèle consommé par API, le gel porte sur l'identifiant de version et sur l'accès contractuel à cette

version pendant l'enquête (EXIG-APP-13). Pour un système à haut risque, le RIA interdit au fournisseur, dans l'enquête qui suit le signalement d'un incident grave, d'altérer le système d'une manière susceptible de nuire à l'évaluation ultérieure des causes avant d'en informer les autorités compétentes (art. 73(6)); le déployeur y est soumis lorsqu'il ne peut joindre le fournisseur (art. 26(5))[61, 459].

3. **Évaluer et aviser.** Ce temps démarre dès la contention, en parallèle de la préservation. Les traces et le journal d'audit bornent le rayon d'atteinte (systèmes et partenaires touchés); le nombre et la résidence des personnes touchées s'établissent à partir des dossiers de décision et des systèmes sources, sous le contrôle du RPRP. L'équipe qualifie l'incident, gravité (S1 à S4) comprise, au regard de chaque régime (incident de confidentialité, atteinte au sens de la LPRPDE, incident technologique au sens du BSIF, incident grave au sens du RIA) et déclenche les avis du tableau 51. Pour un incident grave au sens du RIA, aucune correction qui altère le système n'est faite avant l'avis aux autorités (art. 73(6)).
4. **Corriger et compenser.** Les sagas en cours à la contention sont compensées automatiquement par le canal de compensation (EXIG-ORC-17, section 7.5). Les actions terminées font l'objet d'une réparation métier, décidée par le propriétaire métier après vérification de l'état courant des données, jamais d'une compensation aveugle; les effets irréversibles appellent un avis aux tiers touchés, des recours et des mesures d'atténuation. Le correctif est appliqué, puis les étages d'évaluation (E1 à E3) sont relancés avant toute remise en service; le niveau d'autonomie peut être abaissé.
5. **Apprendre.** Un retour d'expérience sans blâme met à jour les contrôles, les jeux d'évaluation et, au besoin, le cadre.

Tableau 51 — Délais de notification applicables aux incidents agentiques

Régime	Déclencheur	Destinataires	Délai
Loi sur le privé, art. 3.5	Incident de confidentialité présentant un risque de préjudice sérieux	CAI et personnes concernées	« Avec diligence »; aucun délai en heures
Loi sur le privé, art. 3.8, et Règlement sur les incidents de confidentialité	Tout incident de confidentialité, même sans risque de préjudice sérieux	Registre interne, transmis à la CAI sur demande	Tenu à jour; conservé au moins cinq ans
LPRPDE	Atteinte présentant un risque réel de préjudice grave	Commissariat et personnes concernées	« Le plus tôt possible »; registre de toutes les atteintes conservé 24 mois
Avis du BSIF (2021)	Incident lié à la technologie ou à la cybersécurité d'une institution financière fédérale	BSIF	Par écrit, dans les 24 heures ou plus tôt si possible
Loi sur l'accès, art. 63.8 à 63.11 (organismes publics)	Incident de confidentialité	CAI et personnes concernées (risque de préjudice sérieux); registre	« Avec diligence »; registre tenu à jour
LPRPDE, art. 10.2	Atteinte avisée aux personnes	Organisations et institutions susceptibles de réduire le risque de préjudice ou d'en atténuer les conséquences	Dès que possible
RGPD, art. 33 et 34	Violation de données à caractère personnel d'un traitement soumis au RGPD	Autorité de contrôle compétente; personnes concernées en cas de risque élevé	Autorité : dans les 72 heures après en avoir pris connaissance, si possible; personnes : dans les meilleurs délais
Loi concernant la cybersécurité, partie 2 (à vérifier sur le texte sanctionné)	Incident visant un cybersystème essentiel d'un exploitant désigné	Autorités désignées par la loi	Délai fixé par la loi et ses règlements
RIA, art. 73 (fournisseur) et art. 26(5) (déployeur :	Incident grave impliquant un système à haut risque	Autorités de surveillance du marché	Dès l'établissement d'un lien de causalité (ou de sa probabilité raisonnable) et, dans tous les cas, au plus tard 15

Régime	Déclencheur	Destinataires	Délai
informer d'abord le fournisseur)			jours après la prise de connaissance de l'incident grave par le fournisseur ou, le cas échéant, le déployeur; 10 jours en cas de décès; 2 jours en cas d'infraction généralisée ou de perturbation grave et irréversible d'une infrastructure critique

Sources : L.Q. 2021, c. 25; Règlement sur les incidents de confidentialité; Commissariat à la protection de la vie privée; BSIF; RIA[56, 61, 426, 427, 434, 460]. La cible interne de 72 heures pour l'avis initial à la CAI (EXIG-CON-24) n'est pas un régime : c'est une cible du cadre, de force DEVRAIT, et non une exigence de la Loi 25.

L'avis écrit à la CAI comporte onze éléments, dont l'organisation et son numéro d'entreprise du Québec (NEQ), une personne-ressource, les renseignements visés, les circonstances et la cause, la date ou la période de l'incident, la date de prise de connaissance, le nombre de personnes touchées (dont les résidents du Québec), les motifs du risque de préjudice et les mesures d'atténuation; les compléments sont transmis avec diligence[460]. L'événement d'incident préremplit, à partir de la télémétrie et du journal d'audit, l'identification, les dates, les agents, les outils et les catégories de données déclarées au catalogue pour chaque outil en cause. Le nombre et la résidence des personnes touchées s'établissent à partir des dossiers de décision et des systèmes sources, sous le contrôle du RPRP (levée de la pseudonymisation, EXIG-OBS-13); les motifs du risque et les mesures d'atténuation relèvent de l'équipe de réponse. L'avis ne dépend ainsi pas d'une reconstitution manuelle des faits.

EXIG-CON-23 · DOIT
Réponse en cinq temps et gel des preuves
Le plan de réponse aux incidents de chaque agent, et le plan de plateforme pour un composant partagé, **DOIVENT** suivre les cinq temps de la figure 26, gradués selon la gravité (S1 à S4) attribuée par la fonction risques et conformité. La contention (coupe-circuit, coupure du réseau et désactivation de l'identité, révocation des jetons) **DOIT** être exécutable par l'équipe de garde sans approbation préalable; elle conserve les bacs à sable et le contexte d'exécution (dérogation à l'EXIG-SEC-09 pendant l'incident) et laisse ouvert le canal de compensation (EXIG-ORC-17). L'ouverture du dossier d'incident gèle, avant toute correction et toute destruction : les traces, le journal d'audit, les instantanés de mémoire, les bacs à sable, le contexte, l'état des tâches A2A déléguées, les approbations annulées, les captures de débogage, les dossiers de décision en cause et les versions exactes de l'agent, du modèle (instantané s'il est autohébergé, sinon identifiant et accès contractuel de l'EXIG-APP-13), des invites et des définitions d'outils. Le gel suspend les purges et l'échantillonnage pour l'agent visé.
Pourquoi : sans versions figées, l'analyse des causes devient impossible; MANAGE 2.4 demande des mécanismes et des responsabilités clairs pour désactiver un système[74].

EXIG-CON-24 · DOIT
Registre et avis des incidents de confidentialité
Tout incident de confidentialité impliquant un agent **DOIT** être inscrit au registre des incidents avec le contenu prévu par le Règlement sur les incidents de confidentialité et conservé au moins cinq ans. S'il présente un risque de préjudice sérieux, la CAI et les personnes concernées sont avisées avec diligence; le cadre fixe une cible interne de 72 heures pour l'avis initial à la CAI, que l'équipe de réponse **DEVRAIT** respecter (choix du cadre).

Pourquoi : articles 3.5 et 3.8 de la Loi sur le privé et articles 7 et 8 du règlement; la loi n'impose aucun délai en heures, d'où une cible interne explicite[56, 414, 460].

EXIG-CON-25 · DOIT

Règle la plus exigeante entre régimes de notification

Le plan de réponse **DOIT** recenser, pour chaque agent, les régimes de notification applicables (au minimum, selon le cas : Loi sur le privé ou Loi sur l'accès, LPRPDE, BSIF, RIA, RGPD, Loi concernant la cybersécurité) et les cumuler : la règle la plus exigeante s'entend ainsi de chaque régime applicable, satisfait selon son propre déclencheur, son destinataire et son délai (tableau 51), ce qui suppose la double analyse du « préjudice sérieux » (Québec) et du « risque réel de préjudice grave » (fédéral). Seuls les paramètres communs prennent la valeur la plus stricte : registre unique des incidents, conservé cinq ans, et contenu minimal de l'avis. Les cibles internes gardent la force que leur donne leur exigence (EXIG-CON-24). L'événement d'incident, préparé à partir de la télémétrie, du journal d'audit et du dossier d'incident, comporte les champs de l'avis exigé par le règlement québécois.

Pourquoi : une organisation soumise à plusieurs régimes doit pouvoir satisfaire chacun sans reconstituer les faits sous la pression du délai.

12.9 Évaluation d'impact unifiée

Plutôt que plusieurs analyses rédigées par plusieurs équipes, le cadre exige un seul livrable par agent de classe élevée, structuré pour répondre à chaque régime, en volets séparables dont chacun porte sa classification de diffusion.

Les régimes se recoupent largement. L'EFVP examine les RP et leur parcours. L'analyse d'impact sur les droits fondamentaux (AIDF) du RIA est obligatoire avant la première utilisation pour les déployeurs de systèmes à haut risque visés à l'art. 6(2), sauf ceux de l'annexe III, point 2, qui sont des organismes de droit public ou des entités privées fournissant des services publics, ainsi que pour les déployeurs de systèmes d'évaluation de la solvabilité ou de tarification en assurance vie et maladie (annexe III, point 5, b) et c)); elle décrit les processus, la durée et la fréquence d'utilisation, les personnes touchées, les risques, les mesures de supervision humaine et les mesures prévues si les risques se matérialisent, peut renvoyer aux sections pertinentes de l'analyse d'impact relative à la protection des données (AIPD) du règlement général sur la protection des données (RGPD, art. 35) ou en intégrer des parties lorsque celle-ci remplit déjà certaines obligations (art. 27(4), tel que modifié par le règlement (UE) 2026/1744), et est notifiée à l'autorité de surveillance du marché[58, 61, 461]. ISO/IEC 42005:2025 fournit la méthode : quand et comment évaluer l'impact sur les personnes et la société, et comment l'intégrer au SMIA[452]. Un seul livrable évite que les mêmes faits soient décrits trois fois, avec trois versions différentes.

Tableau 52 — Volets de l'évaluation d'impact unifiée

Volet	Source	Contenu minimal	Obligatoire lorsque
Vie privée (EFVP)	Loi sur le privé, art. 3.3 et 17; Loi sur l'accès, art. 63.5 et 70.1	Inventaire et parcours des RP par outil, délégation et mémoire; conformité; risques et atténuation; nécessité et proportionnalité; lieux de traitement	Projet d'acquisition, de développement ou de refonte d'un système d'information ou de prestation électronique de services impliquant des RP (art. 3.3); communication hors Québec (art. 17)
Droits fondamentaux (AIDF)	RIA, art. 27	Processus, durée et fréquence d'utilisation; personnes touchées; risques; supervision humaine; mesures si le risque se matérialise	Déployeurs visés par l'article 27, avant la première utilisation

Volet	Source	Contenu minimal	Obligatoire lorsque
Impact algorithmique	Recommandation du gouvernement du Québec; EIA fédérale	Erreurs, discrimination et biais; niveau d'incidence	Tout agent qui décide ou recommande à l'égard d'une personne, quelle que soit sa classe (choix du cadre, EXIG-CON-26); EIA pour les institutions fédérales assujetties à la directive
Impact sur les personnes et la société	ISO/IEC 42005; ISO/IEC 42001, 6.1.4 et A.5	Méthode, moments du cycle de vie, documentation et intégration au SMIA	Toujours (méthode de référence du cadre pour tous les volets)
Décision sur le risque résiduel	Cadre	Classe, niveau d'autonomie, mesures retenues, risque résiduel accepté par le propriétaire métier et par le comité	Avant le passage en pilote, confirmée à l'homologation, et avant tout relèvement du niveau d'autonomie

Sources :[61, 318, 413, 432, 452].

EXIG-CON-26 · DOIT

Évaluation d'impact unifiée par agent de classe élevée

Chaque agent de classe élevée **DOIT** disposer d'une évaluation d'impact unifiée couvrant les volets applicables du tableau 52, approuvée par le propriétaire métier et par le comité d'architecture et des risques agentiques avant le passage en pilote et avant tout relèvement de son niveau d'autonomie. Elle est mise à jour à chaque déclencheur de l'EXIG-GOV-12, revue au moins une fois par année (choix du cadre) et référencée dans la fiche d'agent (annexe B); ses volets sont séparables, et chacun porte sa classification de diffusion. Tout agent qui décide ou recommande à l'égard d'une personne, quelle que soit sa classe, **DOIT** disposer au moins du volet impact algorithmique, approuvé par le propriétaire métier avant le passage en pilote.

Pourquoi : l'AIDF peut s'appuyer sur l'AIPD (art. 27(4)) et ISO/IEC 42005 fournit une méthode commune; un livrable unique garde les faits cohérents entre régimes[61, 452].

À RETENIR

La classe de risque commande tout le reste : plafond d'autonomie, EFVP et évaluation d'impact, fréquence des revues, intensité des tests. Une décision qu'aucun humain n'a réellement examinée reste automatisée, quel que soit le bouton cliqué. Les délais légaux de notification diffèrent selon les régimes; le cadre satisfait chacun selon son propre délai et s'appuie sur un index de preuves unique.

13 Approvisionnement et clauses contractuelles

Les protocoles d'interopérabilité relèvent désormais d'une gouvernance neutre; le risque de dépendance s'est donc déplacé vers les plateformes, leurs extensions et les données qu'elles accumulent. Ce chapitre traduit le cadre en critères d'évaluation des fournisseurs, en dix clauses contractuelles normatives et en une grille de notation. Il s'adresse aux acheteurs, aux juristes, aux architectes et au responsable de la protection des renseignements personnels qui négocient l'acquisition d'une plateforme d'agents, d'un service de modèles, d'une passerelle, d'un serveur MCP ou d'un agent de tiers.

13.1 Où se situe désormais le risque de verrouillage

Cette section localise le risque de dépendance envers un fournisseur *(vendor lock-in)*, afin de concentrer la négociation là où il se trouve réellement.

Des protocoles sous gouvernance neutre

Le Model Context Protocol (MCP) a été versé à l'Agentic AI Foundation (AAIF), fondation hébergée par la Linux Foundation, dès sa création le 9 décembre 2025; AWS, Google et Microsoft figurent parmi ses membres Platine[4]. Le protocole Agent2Agent (A2A) est devenu un projet hébergé de l'AAIF, au stade « Growth », le 17 août 2026[5, 35]; son comité directeur technique compte neuf sièges : les huit entreprises concurrentes de la composition annoncée le 12 mars 2026 (AWS, Cisco, Google, IBM Research, Microsoft, Salesforce, SAP et ServiceNow)[29], et Bloomberg depuis le 20 octobre 2026 (erratum no 1 de la section H.4). Pour les protocoles au statut « Adopter » placés sous une fondation neutre, le risque qu'un protocole disparaisse ou passe sous le contrôle d'un seul éditeur est donc faible; il ne l'est pas pour un protocole du catalogue sans gouvernance neutre, et une coalition de membres peut aussi orienter une fondation. Un projet n'est toutefois un « standard AAIF » qu'une fois son admission approuvée et annoncée[42]; au 27 octobre 2026, la candidature d'AGNTCY demeure sans décision[37] (voir section 6.9).

Un risque déplacé vers les plateformes

Un protocole ouvert ne rend pas la plateforme ouverte. Le verrouillage se loge désormais dans cinq endroits, résumés au tableau 53. Des éditeurs de passerelles soutiennent en outre que la gouvernance native d'une plateforme s'arrête à sa frontière et ne suit pas l'agent qui en sort. C'est un argument d'éditeurs, cité comme tel, mais il décrit bien le risque que le cadre traite par sa passerelle d'agents et son registre d'entreprise (section 9.4 et section 11.4). Les exemples du tableau illustrent des mécanismes; ils ne jugent pas des produits qui évoluent rapidement.

Tableau 53 — Où se loge le verrouillage (état au 27 octobre 2026)

Lieu	Manifestation	Exemple documenté	Parade du cadre
Extensions de protocole	Une fonction essentielle n'existe que par une extension propre à l'éditeur.	A2A permet de déclarer une extension obligatoire (`required`) dans `capabilities.extensions`[238]; MCP admet des extensions à préfixe DNS inversé, désactivées par défaut[169].	EXIG-APP-02 et EXIG-APP-07
Couverture partielle	« Prend en charge MCP » ne vise qu'une partie des primitives ou des liaisons.	Azure API Management gère les outils MCP, mais ni les ressources ni les invites, et les agents A2A en JSON-RPC seulement[108, 109]; le greffon AI A2A Proxy de Kong Gateway (3.14 et plus, édition AI Gateway Enterprise) ne gère pas l'état des tâches[111].	Preuves par essais (EXIG-APP-03)
Contraintes de produit	Les limites d'orchestration du produit deviennent celles de l'architecture.	Agentforce limite volontairement la délégation entre organisations Salesforce à un seul niveau et signale, pour Agent Script, une limite actuelle de sept sous-agents connectés[49].	Logique d'orchestration détenue par l'entreprise (PRIN-09, chapitre 7)
Plan de contrôle et identité	L'inventaire, l'arrêt et l'identité des agents dépendent de la console de l'éditeur.	Copilot Studio crée d'office une identité Entra Agent ID pour chaque nouvel agent depuis juillet 2026[48]; les fonctions de sécurité associées exigent une licence Agent 365[324], dont les actions de cycle de vie sur des agents infonuagiques tiers sont annoncées comme à venir[46].	EXIG-APP-06 et EXIG-APP-16
Données, définitions et unités	Mémoires, invites système, journaux et unités de facturation propres rendent la sortie coûteuse.	Copilot Studio facture en crédits et désactive les agents personnalisés au-delà de 125 % de la capacité prépayée[53].	EXIG-APP-05 et EXIG-APP-14

À RETENIR

Le protocole est ouvert; il faut négocier l'ouverture là où elle se perd : la couverture réelle du protocole, l'identité des agents, leur arrêt, leurs données et leurs définitions doivent rester sous le contrôle de l'entreprise.

EXIG-APP-01 · DOIT
Analyse de réversibilité avant tout engagement
Toute acquisition d'une plateforme d'agents, d'un service de modèles, d'une passerelle ou d'un agent de tiers **DOIT** être précédée d'une analyse de réversibilité documentée : composants et extensions propriétaires utilisés, données et définitions à récupérer, formats de restitution, délai et coût estimés de sortie. L'architecture d'entreprise **DOIT** la valider, et l'analyse **DOIT** être versée au registre.
Pourquoi : le coût de sortie se décide à la signature, pas à la résiliation.

EXIG-APP-02 · NE DOIT PAS
Aucune dépendance à une extension non approuvée
Un agent ou un outil de l'entreprise **NE DOIT PAS** dépendre d'une extension de protocole propriétaire absente du catalogue (section 6.3). Une extension admise **DOIT** être identifiée par son URI ou son préfixe versionné et posséder un comportement de repli documenté; elle **NE DOIT PAS** être déclarée obligatoire envers des clients, sauf dérogation (section 11.6).
Pourquoi : une extension obligatoire recrée, au-dessus d'un protocole ouvert, la dépendance que ce protocole devait éliminer.

13.2 Critères d'évaluation des fournisseurs

Cette section fixe ce qu'un fournisseur doit démontrer, et comment. Le principe est simple : une preuve reproductible dans l'environnement de l'entreprise l'emporte toujours sur une allégation commerciale.

Interopérabilité protocolaire

La révision courante de MCP est 2026-07-28[34]. Le projet publie un cadre officiel de tests de conformité, encore en versions 0.x (0.1.16 sur le tag latest de npm, préversions 0.2.0-alpha en cours)[225, 226] : ses résultats sont utiles, mais l'entreprise les complète par ses propres scénarios (EXIG-APP-03). Pour A2A 1.0, la trousse officielle a2a-tck, encore en préversion, teste les trois liaisons standard selon les niveaux MUST, SHOULD et MAY, à partir des interfaces déclarées dans la carte d'agent[243]. Le fournisseur précise enfin comment il suivra les dépréciations : MCP maintient une fonctionnalité dépréciée au moins douze mois, ou au moins 90 jours en cas de retrait accéléré pour un risque de sécurité actif (avis de sécurité publié ou exploitation documentée), avant de pouvoir la retirer[34, 196].

Observabilité et données de coûts

Les conventions GenAI d'OpenTelemetry sont toutes au niveau de stabilité Development et ont été déplacées en mai 2026 (déclarées obsolètes dans semantic-conventions à la v1.42.0, le 12 juin 2026) vers un dépôt dédié qui n'a encore publié aucune version étiquetée[180, 181, 462]. « Compatible OpenTelemetry » ne suffit donc pas : le fournisseur déclare la version qu'il émet, et l'entreprise vérifie la propagation du contexte de trace à chaque saut. Par exemple, le SDK Python de Microsoft Agent Framework propage le contexte W3C vers les serveurs MCP que l'agent ouvre lui-même, mais pas vers les outils MCP hébergés par un fournisseur[295]. Pour les coûts, FOCUS *(FinOps Open Cost and Usage Specification)* 1.4 (ratifiée le 4 juin 2026) normalise les données de facturation, sans définir d'indicateurs par agent[408, 463, 464]; FOCUS 1.5, dont la ratification est prévue le 3 décembre 2026, prévoit, dans son brouillon de travail, l'identité du modèle et le détail des jetons[465]. Le coût par tâche réussie se calcule en joignant ces données à la télémétrie (section 10.6).

Identité, délégation et arrêt

Le cadre exige une identité non humaine distincte par agent (section 9.2); la réutilisation d'identités (NHI9) et les secrets de longue durée (NHI7) figurent au Top 10 des identités non humaines de l'OWASP[91]. MCP impose un jeton propre à chaque serveur et interdit de relayer un jeton reçu, mais n'exige ni l'échange de jetons de la RFC 8693 ni la revendication `act`[209] : la délégation vérifiable relève donc d'une exigence

contractuelle distincte (EXIG-APP-08). Le cadre retient en outre, comme grille informative d'évaluation d'une passerelle d'agents (section 9.4), sept portes de conception d'un plan de contrôle d'agents, dont la neutralité de l'application des politiques au niveau du transport et la propagation vérifiée de l'identité humaine déléguée (choix du cadre, inspiré d'un billet de MuleSoft, argument d'éditeur).

Performance mesurée, pas annoncée

Les chiffres publiés par les fournisseurs (TrueFoundry[143, 144], agentgateway[142]) ne se comparent pas, pour les raisons que donne l'encadré de la section 9.4, et l'EXIG-APP-04 en tire la règle d'évaluation.

EXIG-APP-03 · DOIT
Preuves de conformité protocolaire
L'architecture d'entreprise **DOIT** exiger du fournisseur qu'il démontre la prise en charge de MCP 2026-07-28 et, pour toute solution qui délègue ou reçoit des tâches entre agents, d'A2A 1.0, par des essais reproductibles dans l'environnement de l'entreprise : rapport a2a-tck sans échec de niveau MUST pour chaque liaison déclarée, scénarios de conformité MCP exécutés avec le cadre officiel ou une suite équivalente approuvée par l'architecture d'entreprise, chaque suite épinglée à une étiquette et, tant qu'elle est en préversion, bloquante seulement pour les tests restés stables pendant deux versions (EXIG-GOV-19), et liste explicite des primitives, liaisons et versions non prises en charge.
Pourquoi : « prend en charge » couvre souvent une partie seulement du protocole (tableau 53).

EXIG-APP-04 · DOIT
Mesures de performance reproductibles
Toute valeur de latence ajoutée, de débit ou de disponibilité invoquée par un fournisseur **DOIT** être mesurée dans les conditions de l'entreprise, politiques, traçage et journalisation actifs, aux 50e et 99e centiles (P50 et P99), avec la méthode, le matériel, le type de trafic et les données brutes. Une valeur publiée par le fournisseur **NE DOIT PAS** servir d'exigence ni de critère de notation.
Pourquoi : les allégations publiques sont incomparables, parfois contradictoires.

EXIG-APP-05 · DOIT
Télémétrie et données de coûts ouvertes
L'architecture d'entreprise **DOIT** exiger que la solution exporte traces, métriques et journaux par OTLP selon une version des conventions GenAI qu'elle déclare et que le catalogue consigne, avec le réglage d'`OTEL_SEMCONV_STABILITY_OPT_IN` (EXIG-OBS-01), qu'elle propage le contexte W3C Trace Context sur chaque saut qu'elle contrôle et qu'elle fournisse ses données de facturation au format FOCUS 1.4 ou ultérieur, avec la correspondance entre ses unités propres (crédits, messages) et les jetons consommés.
Pourquoi : sans traces ni coûts exportables, l'entreprise ne peut ni auditer ses agents ni comparer ses fournisseurs (section 10.1).

EXIG-APP-06 · DOIT
Identité et arrêt sous le contrôle de l'entreprise
L'architecture d'entreprise **DOIT** exiger que la solution attribue à chaque agent une identité non humaine distincte, fédérable au fournisseur d'identité de l'entreprise et sans clé statique partagée, et permette à l'entreprise de suspendre ou de révoquer un agent, ses jetons et ses sessions depuis ses propres outils, par exemple au moyen d'événements CAEP[344], sans attendre une intervention du fournisseur, dans le délai de l'EXIG-IAM-20. Ce mécanisme est celui que décrit la fiche d'un agent intégré à un logiciel-service (EXIG-ARC-02).

Pourquoi : un coupe-circuit qui dépend de la console d'un éditeur n'est pas un coupe-circuit d'entreprise (section 9.4).

13.3 Clauses contractuelles normatives

Les dix clauses suivantes sont des exigences minimales. Elles s'insèrent dans tout contrat d'acquisition ou de renouvellement visé par ce chapitre; leur rédaction juridique relève des affaires juridiques. Les délais marqués « cible du cadre » sont des choix internes, ajustables par dérogation (section 11.6). Une dérogation qui porte sur un engagement contractuel (délai négocié sous la cible, extension obligatoire admise par l'EXIG-APP-02, offre retenue malgré un échec éliminatoire selon l'EXIG-APP-17) prend la forme d'un écart contractuel : le comité le décide; il vaut jusqu'à l'échéance du contrat, sans la limite de six mois de l'EXIG-GOV-16; il est inscrit au registre et revu à chaque renouvellement. Aucune dérogation ni aucun écart contractuel ne peut porter sur ce que les clauses 4 à 6 reprennent d'une obligation légale (art. 17 et 18.3 de la Loi sur le privé; EXIG-GOV-17). Dans ce chapitre, « Loi sur le privé » désigne la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1).

DROIT APPLICABLE

L'entreprise demeure responsable des renseignements personnels qu'elle confie à un fournisseur, y compris en cas d'incident[414]. La Loi sur le privé ne prévoit pas de responsabilité « conjointe » : elle impose un contrat écrit qui encadre le mandataire (art. 18.3)[56]. Les clauses donnent à l'entreprise les moyens de remplir ses propres obligations (section 12.2).

`EXIG-APP-07` · DOIT

Clause 1 — Interopérabilité ouverte et portabilité des cartes

Le contrat **DOIT** engager le fournisseur à prendre en charge A2A 1.0 en entrée et en sortie pour toute délégation entre agents; à publier des cartes d'agent conformes à la spécification A2A, dont le fichier `a2a.proto` est la définition normative, à l'adresse `/.well-known/agent-card.json` pour les agents exposés; à n'exiger aucune extension propriétaire pour déléguer une tâche à un agent tiers ou en recevoir une; et à maintenir une version de protocole dépréciée au moins pendant la période prévue par la spécification ou, à défaut, pendant 12 mois (cible du cadre), avec préavis écrit avant son retrait.

Pourquoi : avec A2A 1.0 natif et sans extension imposée, l'entreprise change de fournisseur sans réécrire ses délégations; le schéma de la carte relève de la spécification A2A, non d'un éditeur ni d'un autre projet[68].

`EXIG-APP-08` · DOIT

Clause 2 — Conformité MCP et délégation d'identité

Le contrat **DOIT** exiger que tout outil ou connecteur exposé par le fournisseur respecte MCP 2026-07-28 et sa spécification d'autorisation : paramètre `resource` de la RFC 8707, jeton propre à chaque serveur, interdiction de relayer un jeton reçu[71, 209]. Il **DOIT** exiger en outre, comme engagement distinct de la conformité MCP, l'acceptation de jetons délégués émis par échange de jetons (RFC 8693) dont la revendication `act` identifie l'acteur courant; l'intersection des droits porte sur `sub` et sur l'`act` externe, et les acteurs imbriqués ne servent qu'à l'audit (RFC 8693, section 4.1)[70]. La prise en charge de l'extension Enterprise-Managed Authorization **PEUT** être valorisée dans la notation de la ligne « Identité et délégation »[178].

Pourquoi : sans jeton délégué qui identifie le mandant et l'acteur courant, l'intersection des droits du mandant et de l'agent ne peut pas s'appliquer (section 9.3).

EXIG-APP-09 · DOIT

Clause 3 — Télémétrie exportable et explicabilité

Le contrat **DOIT** garantir à l'entreprise un accès continu aux traces et aux journaux d'exécution de ses agents, y compris la version exacte du modèle, les outils appelés et les approbations. Pour toute décision concernant une personne, le fournisseur **DOIT** fournir de quoi l'informer des renseignements personnels utilisés et des raisons, principaux facteurs et paramètres de la décision (art. 12.1, qui vise les décisions fondées exclusivement sur un traitement automatisé; l'étendre à toute décision est un choix du cadre), et de quoi soutenir la révision par un membre du personnel, dans un délai fixé (cible du cadre : 10 jours); il **DOIT** restituer ces éléments à l'entreprise, qui les conserve à son dossier de décision au moins un an après la décision (art. 11, EXIG-OBS-11), et permettre ainsi de répondre aux demandes d'accès dans les 30 jours (art. 32)[56].

Pourquoi : l'obligation d'expliquer reste à l'entreprise; elle vise les facteurs déterminants, non l'algorithme[318].

EXIG-APP-10 · DOIT

Clause 4 — Usage limité au mandat et interdiction d'entraînement

Le contrat **DOIT** préciser les mesures de confidentialité, limiter l'usage des renseignements à l'exécution du mandat et en interdire la conservation après son échéance, sous réserve des restitutions de l'EXIG-APP-14 et du gel notifié par l'entreprise (art. 18.3)[56]. Il **DOIT** aussi interdire expressément d'utiliser les données de l'entreprise (invites, contextes, sorties, traces, mémoires, plongements vectoriels) pour entraîner, ajuster ou évaluer des modèles du fournisseur ou de tiers, sauf autorisation écrite distincte, et fixer la conservation des invites et des sorties chez le fournisseur, détection des abus comprise : nulle, ou bornée et déclarée.

Pourquoi : la loi ne nomme pas l'entraînement; l'interdiction explicite découle de la limitation au mandat et ferme toute ambiguïté.

EXIG-APP-11 · DOIT

Clause 5 — Résidence, transferts et lois étrangères

Le contrat **DOIT** déclarer chaque lieu de traitement ou de conservation des données de l'entreprise (inférence, outils, mémoires, journaux, sous-traitants), prévoir un préavis écrit de tout changement (cible du cadre : 90 jours), constituer, après une EFVP qui conclut à une protection adéquate, l'entente écrite exigée par l'article 17 de la Loi sur le privé[56] lorsque des renseignements personnels sont communiqués hors du Québec, autres provinces comprises, ou confiés à un tiers établi hors du Québec pour traitement ou conservation, et documenter l'exposition du fournisseur à des lois étrangères d'accès aux données, avec les mesures compensatoires retenues, par exemple un chiffrement à clés tenues hors de portée du fournisseur et l'épinglage régional du traitement, sans inférence interrégionale[416].

Pourquoi : le *Clarifying Lawful Overseas Use of Data Act* (CLOUD Act) des États-Unis oblige un fournisseur qui y est assujetti à divulguer les données sous sa garde ou son contrôle, où qu'elles soient[417]; le gouvernement fédéral reconnaît que le stockage au Canada ne suffit pas à écarter la compétence de tribunaux étrangers, tout en ne relevant aucun cas documenté de gouvernement étranger cherchant à accéder aux données d'entreprises canadiennes détenues par des fournisseurs[418]. L'EFVP pondère ce risque.

EXIG-APP-12 · DOIT

Clause 6 — Notification d'incident

Le contrat **DOIT** obliger le fournisseur à aviser sans délai le RPRP de l'entreprise de toute violation ou tentative de violation des obligations de confidentialité (art. 18.3) et à aviser l'entreprise sans délai, et au

plus tard dans le délai que le contrat fixe (cible du cadre : 24 heures après la prise de connaissance par le fournisseur), de tout incident touchant ses données, ses identités ou ses agents, y compris une action d'agent non autorisée, une injection réussie ou une fuite par un outil; à transmettre les éléments requis pour l'avis à la Commission d'accès à l'information (CAI) et pour le registre des incidents; et à préserver les preuves et les versions en cause tant que dure le gel notifié par l'entreprise (EXIG-CON-23). Pour une institution financière fédérale, que l'avis au BSIF astreint à 24 heures ou moins, le contrat **DEVRAIT** fixer un délai plus court (cible du cadre : quatre heures).

Pourquoi : le mandataire doit aviser sans délai de toute violation (art. 18.3), et l'entreprise doit aviser la CAI « avec diligence » lorsque l'incident présente un risque de préjudice sérieux (art. 3.5), la loi ne fixant aucun délai en heures[56]; la cible de 24 heures reprend l'ordre de grandeur du délai de signalement au BSIF sans suffire à le respecter à elle seule : l'avis exige 24 heures ou moins, sans fixer le point de départ, d'où le délai plus court que le contrat d'une institution financière fédérale devrait fixer[434] (section 12.8).

EXIG-APP-13 · DOIT

Clause 7 — Audit, sécurité et transparence des changements

Le contrat **DOIT** accorder à l'entreprise un droit de vérification, l'accès aux résultats des évaluations de sécurité et d'équipe rouge des composants agentiques, fondées au minimum sur l'OWASP Top 10 for Agentic Applications 2026[28], la liste à jour des modèles, serveurs MCP, agents et sous-traitants intégrés avec leurs versions, un préavis écrit d'au moins 90 jours (cible du cadre) avant tout retrait ou changement de version de modèle, y compris derrière un alias, que le fournisseur en juge ou non le comportement modifié, et l'accès à la version en cause pendant toute enquête d'incident (EXIG-CON-23).

Pourquoi : un changement de modèle ou de fournisseur peut exiger la mise à jour de l'EFVP[413] et, dans les institutions financières fédérales, la revue prévue par la ligne directrice E-23, qui inclut les modèles de fournisseurs[8]; le NIST AI RMF demande des politiques sur les risques de tiers (GOVERN 6.1)[74].

EXIG-APP-14 · DOIT

Clause 8 — Réversibilité et sortie

Le contrat **DOIT** prévoir qu'à l'échéance, à la résiliation ou sur demande, le fournisseur restitue dans des formats ouverts, structurés et documentés les mémoires des agents (épisodique, sémantique, procédurale), les graphes de connaissances, les définitions d'agents (invites système, cartes, compétences, flux, politiques), la configuration des outils, les journaux d'audit, les traces, les index vectoriels, les jeux d'évaluation, les artefacts d'ajustement autorisés, les preuves d'approbation signées et les éléments de décision (EXIG-APP-09); qu'il prête assistance pendant une période de transition (cible du cadre : six mois); puis qu'il détruise les données après la restitution attestée, et l'atteste par écrit. La destruction est suspendue pendant toute enquête, tout gel (EXIG-CON-23) ou toute conservation pour litige notifiés par l'entreprise.

Pourquoi : la mémoire et les définitions forment l'actif que l'entreprise doit garder (section 5.5); la loi exige que le contrat prévoie que le mandataire ne conserve pas les renseignements après le mandat[56].

EXIG-APP-15 · DOIT

Clause 9 — Accord écrit au sens de l'article 25(4) du RIA

Lorsque l'entreprise est fournisseur d'un système d'IA à haut risque au sens du règlement européen sur l'IA (RIA), ou le devient, notamment en y apposant son nom, en le modifiant substantiellement ou en réaffectant un agent à un usage de l'annexe III (art. 25(1)), le contrat avec chaque tiers qui fournit un outil, un service, un composant ou un modèle intégré **DOIT** constituer l'accord écrit exigé par

l'article 25(4), tel que modifié par le règlement (UE) 2026/1744[58, 61]. Le cadre y exige au minimum la documentation technique, l'accès aux journaux, l'accès pour essais et l'assistance en cas d'incident. Les outils, services, processus et composants rendus publics sous licence libre et ouverte sont exemptés de l'accord, sauf s'il s'agit de modèles d'IA à usage général; pour un tel composant, ou pour un modèle à usage général dont le fournisseur refuse l'accord, l'entreprise s'appuie sur la documentation que ce fournisseur doit fournir (art. 53) ou recourt à une dérogation (section 11.6).

Pourquoi : ces obligations visent les systèmes de l'annexe III à compter du 2 décembre 2027 et ceux de l'annexe I à compter du 2 août 2028[57] (section 12.4).

EXIG-APP-16 · DOIT

Clause 10 — Révocation des identités non humaines

Le contrat **DOIT** prévoir, à la suspension d'un agent, l'invalidation côté fournisseur de ses jetons, consentements, abonnements de notification et webhooks dans le délai de l'EXIG-IAM-20, réception des événements CAEP comprise; et, à la fin du contrat, la révocation par le fournisseur, dans les 24 heures qui suivent la fin de la période de transition de l'EXIG-APP-14 (cible du cadre), ou sans délai en cas de faute ou d'incident, de toutes les identités non humaines, justificatifs, jetons, consentements OAuth, abonnements de notification et webhooks liés à l'entreprise, avec attestation écrite. La coupure côté entreprise passe par le mécanisme de l'EXIG-APP-06, sans attendre le fournisseur. L'entreprise **DOIT** révoquer de son côté les accès qu'elle a accordés et vérifier l'absence d'accès résiduel.

Pourquoi : le retrait inadéquat est le premier risque du Top 10 NHI de l'OWASP (NHI1)[91]; le NIST AI RMF prévoit un déclassement sécuritaire (GOVERN 1.7)[74], et le livre blanc de l'OpenID Foundation (section 2.9) recommande un retrait formel propagé à tous les systèmes intégrés[466].

Aucune clause contraire à l'EXIG-GOV-17 (application de l'EXIG-APP-12). Un contrat conclu ou renouvelé après l'adoption du cadre **NE DOIT PAS** comporter de clause contraire à un point de l'EXIG-GOV-17. Un engagement contractuel en vigueur à l'adoption ne prime sur le cadre que pour une transition bornée, inscrite au registre, et jamais sur un point de l'EXIG-GOV-17 (section 4.3). Pourquoi : une clause d'éditeur ne peut pas écarter ce qu'aucune dérogation interne ne peut écarter; sinon un contrat signé après l'adoption suffirait à exécuter des actions P3 sans approbation.

13.4 Grille d'évaluation

La grille du tableau 54 rend les offres comparables. Chaque critère reçoit une note de 0 à 3 : 0, absent ou non démontré; 1, partiel ou inscrit à une feuille de route datée; 2, démontré par le fournisseur; 3, démontré par un essai reproductible de l'entreprise. Lorsqu'une exigence impose un essai de l'entreprise (EXIG-APP-03, EXIG-APP-04, EXIG-APP-06), la note d'un critère que l'entreprise n'a pas vérifié est plafonnée à 1. La preuve d'un autre critère qui suppose un agent pilote (coûts, réversibilité) peut être cotée provisoirement à 2, sur la démonstration du fournisseur, et se confirme au premier pilote. Un critère est en échec si sa note est inférieure à 3 lorsqu'une exigence impose un essai de l'entreprise, et inférieure à 2 ailleurs. Le refus d'une clause DOIT de la section 13.3 est un échec éliminatoire, quel que soit le score. Un critère, ou une partie de critère, sans objet pour la solution évaluée (un serveur MCP n'a pas de carte d'agent; un composant libre et gratuit n'a pas de facturation) est coté « Sans objet » avec justification, comme à l'annexe A, et son poids est réparti au prorata entre les autres critères. Le score est la moyenne pondérée des notes. Une offre est admissible si elle n'échoue à aucun critère éliminatoire; le cadre ne fixe pas de seuil de score, puisqu'une offre sans échec éliminatoire dépasse toujours 2,0, et le score sert à classer les offres admissibles. La colonne « Applicable à » désigne les types de solution que vise chaque critère (plateforme, agent, service de modèles, passerelle, serveur MCP); pour un autre type, le critère, ou sa partie visée, est coté « Sans objet ». Les

pondérations sont indicatives : selon la classe la plus élevée des agents visés par l'acquisition, le comité peut les rééquilibrer d'au plus 5 points par critère, en le justifiant, la somme des poids demeurant égale à 100 et un critère éliminatoire gardant un poids d'au moins 5.

Tableau 54 — Grille d'évaluation des fournisseurs de solutions agentiques

Critère	Ce qui est évalué	Applicable à	Preuve attendue	Poids	Éliminatoire
Interopérabilité protocolaire	MCP 2026-07-28; A2A 1.0 natif pour toute solution qui délègue ou reçoit des tâches; primitives et liaisons couvertes; extensions	Plateforme, agent, passerelle, serveur MCP (MCP); plateforme et agent qui délèguent ou reçoivent des tâches (A2A); sans objet pour un service de modèles	Rapport a2a-tck, résultats de conformité MCP, liste des écarts	20	**Oui**
Identité et délégation	Identité par agent, fédération, jetons délégués, révocation par l'entreprise	Toutes	Démonstration dans le locataire de l'entreprise; essai de révocation chronométré, comparé à la cible de l'EXIG-IAM-20	15	**Oui**
Sécurité et chaîne d'approvisionnement	Garde-fous, bacs à sable, inventaire versionné des composants, équipe rouge	Toutes	Rapports d'essai; inventaire; droit d'audit (clause 7)	15	**Oui**
Observabilité et audit	OTLP, conventions épinglées, propagation du contexte, journal d'audit exportable	Toutes	Trace complète sur les sauts que la solution contrôle, et liste des ruptures, produites pendant l'essai	15	**Oui**
Données, résidence et conformité	Lieux de traitement, article 17, interdiction d'entraînement, article 12.1, incidents	Toutes	Clauses 3 à 6 acceptées; carte des flux pour l'EFVP	15	**Oui**
Réversibilité	Formats de restitution, assistance, délai de sortie	Toutes	Essai de restitution sur un agent pilote	10	**Oui**
Coûts et FinOps	Données FOCUS, unités propres, plafonds par agent (EXIG-APP-05, EXIG-FIN-03, EXIG-FIN-05)	Toutes, sauf un composant libre et gratuit	Export FOCUS d'un mois de pilote (sans objet pour un composant libre et gratuit)	5	**Oui**
Performance mesurée	Latence ajoutée P50 et P99, débit, disponibilité	Toutes	Banc d'essai reproductible de l'entreprise (EXIG-APP-04)	5	Non

EXIG-APP-17 · DOIT

Application de la grille

Toute acquisition visée par ce chapitre **DOIT** être évaluée avec la grille du tableau 54. Une offre en échec sur un critère éliminatoire, au sens de la section 13.4, ou qui refuse une clause DOIT de la section 13.3, **DOIT** être écartée, sauf dérogation approuvée, sous la forme d'un écart contractuel (section 13.3).

La grille remplie et ses preuves **DOIVENT** être conservées au registre (section 11.4) et réévaluées à chaque renouvellement de contrat.
Pourquoi : une grille commune rend les décisions traçables et comparables d'une acquisition à l'autre.

14 Modèle de maturité

Ce chapitre situe l'entreprise sur cinq niveaux de maturité et cinq dimensions, pour mesurer l'écart entre ses pratiques et le cadre. Il fixe la méthode d'évaluation, les preuves attendues et le lien entre la maturité, les jalons et l'autonomie permise, puis relie le modèle à ISO/IEC 42001 et au NIST AI RMF. Il n'ajoute aucune exigence.

14.1 Cinq niveaux et cinq dimensions

Cette section définit l'échelle. Chaque niveau, à partir du niveau 2, fixe des critères observables; le niveau 1 est le niveau plancher, sans critère, que décrivent des pratiques typiques. Les niveaux sont cumulatifs : atteindre le niveau 3 suppose de satisfaire aussi aux critères du niveau 2. Les cinq dimensions reprennent les piliers du cadre : interopérabilité (chapitre 6), orchestration et supervision humaine (chapitres 7 et 8), identité et sécurité (chapitre 9), observabilité, évaluation et coûts compris (chapitre 10), et gouvernance (chapitres 11 à 13).

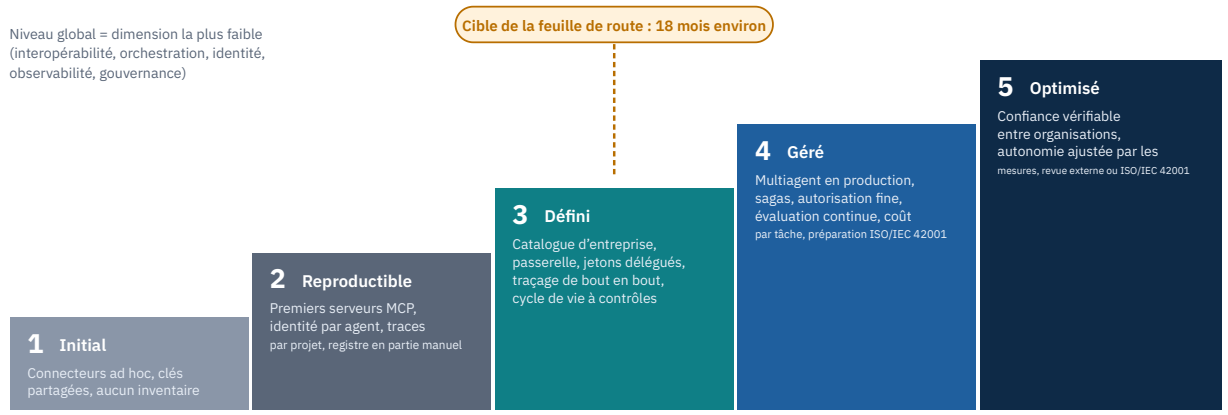


Figure 27 — Modèle de maturité en cinq niveaux. Chaque niveau englobe les précédents; la feuille de route vise le niveau 3, « Défini », en 18 mois environ (durée indicative, à calibrer après l'évaluation initiale). Le niveau global de l'entreprise est celui de sa dimension la plus faible. Source : cadre CRE-IA-2026-01.

Le passage du niveau 2 au niveau 3 tient d'abord à la portée des pratiques : au niveau 2, à l'exception du registre, de l'identité et de la passerelle de modèles, qui couvrent déjà tous les agents, elles visent surtout les nouveaux agents et les pilotes; au niveau 3, elles forment la norme unique de tout le portefeuille. Le niveau 4 ajoute le pilotage par les mesures; le niveau 5, l'amélioration continue et la confiance étendue aux partenaires.

Tableau 55 — Niveaux de maturité par dimension

Niveau	Interopérabilité	Orchestration et supervision	Identité et sécurité	Observabilité	Gouvernance
1 — Initial Niveau plancher, sans critère; pratiques typique-	Connecteurs ad hoc, propres à chaque projet	Invites et scripts isolés; logique métier confiée au modèle	Clés d'API et comptes de service partagés	Journaux locaux; coûts inconnus	Aucun inventaire; agents fantômes

Niveau	Interopérabilité	Orchestration et supervision	Identité et sécurité	Observabilité	Gouvernance
ment improvisées par chaque équipe					
2 — Reproductible Pratiques établies et répétées	Tous les serveurs MCP et toutes les cartes d'agent des pilotes au catalogue, versions épinglées; contrats pour les outils des pilotes	Flux déterministes à étapes agentiques; patron documenté par agent; exécution durable des pilotes; approbation signée de toute action P3	Identité propre à chaque agent, aucune clé partagée; secrets au coffre; passerelle de modèles; coupe-circuit exercé	Traces OpenTelemetry par projet; journal d'audit des pilotes; coûts suivis par agent	Registre complet, tenu en partie à la main; parrain nommé pour chaque agent; comité en fonction; classes de risque attribuées
3 — Défini Pratiques normalisées pour tout le portefeuille	Catalogue d'entreprise unique; MCP et A2A pour tout nouvel agent; intégrations existantes migrées	Patrons autorisés et gabarits; moteur d'exécution durable; compensation définie pour chaque étape à effet; plafonds d'itérations; taux d'approbation sans modification suivi par approbateur (section 8.7)	Passerelle d'agents pour tout appel MCP ou A2A et toute action P2 ou P3; jetons délégués; garde-fous communs; bacs à sable; équipe rouge au moins annuelle pour chaque agent de classe modérée ou élevée (EXIG-SEC-23)	Traçage de bout en bout; journal d'audit de toute action P2 et P3; évaluation dans la chaîne CI/CD; enveloppes budgétaires	Cycle de vie à jalons pour tous les agents; aucun justificatif sans fiche complète; dérogations bornées; clauses de réversibilité du chapitre 13 dans tout contrat d'acquisition
4 — Géré Pratiques pilotées par les mesures	Systèmes clés exposés au catalogue; versions gérées; formats CloudEvents et contrats AsyncAPI des chorégraphies; réutilisation mesurée chaque trimestre (tableau 61)	Multiagent en production là où un gain est mesuré; agents ambiants réautorisés selon la section 8.6; sagas éprouvées par injection de fautes; routage des modèles selon les mesures	Autorisation fine par politiques en code; délai de révocation mesuré en exercice, sous la cible de l'EXIG-IAM-20	Évaluation continue, production comprise; détection de la dérive; coût par tâche réussie suivi	Indicateurs trimestriels utilisés dans les décisions du comité; préparation à la certification ISO/IEC 42001
5 — Optimisé Amélioration continue, confiance étendue aux partenaires	Interopérabilité avec les partenaires; vocabulaire sémantique partagé	Chorégraphie interdomaines; autonomie ajustée selon les mesures, à la hausse comme à la baisse	Confiance vérifiable entre organisations : cartes signées, fédération des identités et de la délégation	Incidents et dérives versés aux jeux d'évaluation; décisions fondées sur la valeur et le risque mesurés	Révision du cadre alimentée par les incidents, les dérogations et la veille (section 11.7); revue externe ou certification ISO/IEC 42001

À RETENIR

Un niveau de maturité qualifie l'entreprise; un niveau d'autonomie (N0 à N4, section 8.1) qualifie un agent. L'autonomie n'est pas un objectif de maturité : Feng, McDonald et Zhang en font une décision de conception, et Morris et coll. rappellent que le niveau retenu au déploiement n'a pas à être le maximum que permettent les capacités du modèle[83, 302]. Une entreprise au niveau 5 peut garder la plupart de ses agents à N1 ou à N2.

14.2 Évaluer sa maturité

Cette section fixe la cotation, le calendrier et les preuves admises. Le but est un résultat reproductible, que le cadre mesure au lieu de le supposer : à chaque évaluation de jalon, deux évaluateurs indépendants cotent les mêmes preuves, leur accord est calculé (coefficient kappa), et un désaccord est tranché par le comité et consigné.

Règles de cotation

- Une dimension atteint un niveau lorsque ses critères, et ceux du niveau inférieur, sont satisfaits dans tout le périmètre qu'ils désignent; un critère qui ne désigne pas son périmètre vise, au niveau 2, les agents des pilotes et, au niveau 3 et au-delà, tous les agents en production.
- Le niveau global est celui de la dimension la plus faible. Une entreprise dotée d'un catalogue exemplaire, mais dont des agents partagent encore des clés d'API, reste au niveau 1 : un incident emprunte le maillon le plus faible.
- Un critère se prouve par des données du registre, des passerelles, des traces et du journal d'audit, comme les indicateurs du tableau 61; une déclaration d'équipe n'est pas une preuve. Pour les critères qui ne se calculent pas automatiquement, l'évaluateur examine les listes de contrôle de l'annexe A d'un échantillon qui comprend tous les agents de classe élevée, tous les agents N4 et au moins 20 % des autres agents de chaque classe, tirés au hasard; le tirage est consigné.

Calendrier et conduite

Une première évaluation précède la phase Fondations et calibre les durées de la feuille de route (section 15.1); faute de registre, elle s'appuie sur une découverte outillée (journaux du fournisseur d'identité et de facturation, trafic sortant vers les fournisseurs de modèles), recalibrée au jalon 1. Avant la constitution du comité (tableau 60, semaines 1 et 2), le parrain de direction de la feuille de route (section 15.4) arrête cette évaluation initiale, et le comité la ratifie à sa première séance. Une évaluation a lieu ensuite à chaque jalon : le jalon 2 exige le niveau 2 sur les cinq dimensions, le jalon 3 le niveau 3 (tableau 58). Après le jalon 3, l'entreprise refait l'évaluation chaque année, par autoévaluation selon les tableaux 55 et 56; l'évaluation des jalons 4 et 5 est conduite par l'architecture d'entreprise.

L'architecture d'entreprise conduit l'évaluation avec les fonctions qui répondent de chaque dimension; le comité en arrête le résultat, comme il constate les jalons. Ce résultat donne le niveau de chaque dimension, ses preuves et le plan d'action qui comble les écarts; le recul d'une dimension sous le niveau du dernier jalon franchi ramène les agents concernés au plafond de la phase correspondante, sauf dérogation bornée (section 11.6), et un indicateur du tableau 61 hors cible déclenche la réévaluation de la dimension sans attendre l'évaluation annuelle. Une phase peut livrer des capacités d'un niveau supérieur : la phase Industrialisation livre des flux multiagents et des sagas, dont l'exploitation éprouvée (gain mesuré, essais par injection de fautes) relève du niveau 4 en orchestration, alors que le jalon 3 ne vérifie que le niveau 3.

Preuves attendues

Le tableau 56 résume les preuves attendues par niveau de maturité.

Tableau 56 — Preuves attendues par niveau de maturité

Niveau	Exemples de preuves
2 — Reproductible	Couverture du registre à 100 %; aucun agent sans justificatif propre; tous les appels de modèles par la passerelle; catalogue publié; traces des pilotes; rapport d'exercice du coupe-circuit; pilotes homologués selon l'annexe A.
3 — Défini	Conformité au catalogue et couverture des passerelles à 100 % (appels MCP et A2A, actions P2 et P3), agents existants compris; traçabilité de toutes les actions P2 et P3; couverture de l'évaluation à 100 %; jalons du cycle de vie consignés pour chaque agent (EXIG-GOV-11); rapports d'équipe rouge; déclaration d'applicabilité (ISO/IEC 42001, 6.1.3) si l'entreprise vise la certification.

Niveau	Exemples de preuves
4 — Géré	Séries trimestrielles d'indicateurs et décisions du comité qui s'y appuient; délai de révocation mesuré en exercice sous la cible; alertes de dérive traitées; coût par tâche réussie comparé au processus de référence; audit interne du système de management de l'IA.
5 — Optimisé	Révisions du cadre motivées par les incidents et les mesures; rapport de revue externe ou certificat ISO/IEC 42001; ententes avec des partenaires; contributions aux standards ouverts.

ATTENTION

Le modèle mesure l'avancement; il ne suspend aucune exigence. Tout nouvel agent est homologué selon l'annexe A, quel que soit le niveau de l'entreprise; les agents existants sont ramenés en conformité selon le régime transitoire de l'EXIG-GOV-16, sous les plafonds de phase et jamais au-delà du plafond de leur classe.

Maturité et autonomie permise

Les règles de progression du chapitre 15 font de la maturité une condition de l'autonomie (tableau 58) : N2 et les premiers N3 bornés après le jalon 1; N3 entre domaines après le jalon 2, donc au niveau 2 de maturité, pour un agent dont tous les appels interdomaines passent déjà par la passerelle d'agents; N4 après le jalon 3, donc au niveau 3 sur les cinq dimensions, pour un agent de classe faible, sur un domaine d'exploitation (ODD) certifié, c'est-à-dire homologué par le comité (section 8.1), et sur décision du comité. Le plafond de phase est une condition nécessaire, jamais suffisante : la hausse effective exige l'homologation de l'agent (annexe A). Le plafond de la classe de risque s'applique en plus, et le plus strict l'emporte.

14.3 Lien avec la certification ISO/IEC 42001 et le NIST AI RMF

Cette section situe le modèle par rapport aux deux référentiels présentés à la section 12.5. Le modèle est un instrument interne de pilotage, qui ne donne lieu à aucune certification.

Le NIST AI RMF, d'application volontaire, propose des profils temporels : un profil actuel *(Current Profile)* décrit la gestion présente de l'IA, un profil cible *(Target Profile)* les résultats nécessaires pour atteindre les objectifs de gestion des risques. Leur comparaison révèle des écarts que des plans d'action comblent; le NIST ne prescrit aucun gabarit de profil[74, 448]. L'évaluation de maturité suit cette logique; pour en tirer un profil au sens du NIST, l'entreprise rattache ses critères aux sous-catégories pertinentes, dont celles du tableau 57.

ISO/IEC 42001:2023 est au contraire une norme d'exigences certifiable par tierce partie, par des organismes conformes à ISO/IEC 17021-1 et à ISO/IEC 42006:2025[451]. Norme de système de management, elle encadre des processus, du contexte de l'organisation (article 4) jusqu'à l'amélioration (article 10)[395]. Le cadre situe donc la préparation à la certification au niveau 4, qui ajoute aux processus du niveau 3 une évaluation des performances fondée sur des mesures, et la certification au niveau 5. La déclaration d'applicabilité, qui rattache les exigences du cadre aux mesures de l'annexe A de la norme (section 12.5), accompagne le traitement des risques de l'article 6.1.3 : c'est un livrable du niveau 3 pour l'entreprise qui vise la certification, et le niveau 4 en vérifie la tenue.

Tableau 57 — Correspondance indicative entre niveaux de maturité, ISO/IEC 42001 et NIST AI RMF

Niveau	ISO/IEC 42001:2023	NIST AI RMF 1.0
2 — Reproductible	Politique d'IA (5.2), rôles (5.3); premières appréciations des risques (6.1.2)	GOVERN 1.6 (inventaire), 2.1 (rôles); MANAGE 2.4 (coupe-circuit)
3 — Défini	Planification et fonctionnement appliqués à tous les agents (6.1.2 à 6.1.4, article 8); mesures A.5, A.6.2.8 et A.10	GOVERN 1.7 (déclassement), 6.1 (tiers); MAP 3.5 (supervision humaine); MEASURE 2.7 (sécurité et résilience)

Niveau	ISO/IEC 42001:2023	NIST AI RMF 1.0
4 — Géré	Évaluation des performances, audit interne et revue de direction (article 9); mesure A.6.2.6 (exploitation et surveillance)	MEASURE 2.4 (surveillance en production), 3.1 (risques émergents); MANAGE 4.1; profils actuel et cible comparés
5 — Optimisé	Amélioration (article 10); certification par tierce partie	Profils revus à chaque révision du cadre

Interprétation du cadre, établie à partir de NIST AI 100-1 et du catalogue d'ISO/IEC 42001**[74, 395]**.

Le cadre admet une certification ISO/IEC 42001 comme revue externe de la dimension Gouvernance; elle n'atteste toutefois pas, à elle seule, les quatre autres : la norme encadre des processus, sans prescrire de protocole, de passerelle ni de format de trace. À l'inverse, un niveau élevé de maturité n'établit ni la certification ni la conformité à la Loi 25 ou au RIA, qui s'apprécient obligation par obligation (chapitre 12).

15 Feuille de route et indicateurs

Ce chapitre ordonne la mise en œuvre du cadre en quatre phases séparées par trois jalons, auxquels s'ajoutent un jalon réglementaire et deux jalons de mise à l'échelle; il la cale sur le calendrier 2027-2030, puis détaille les 90 premiers jours. Il fixe les indicateurs qui permettent au comité d'architecture et des risques agentiques de constater les progrès sur des mesures plutôt que sur des déclarations. Il se termine par les facteurs de succès, puis par les risques de mise en œuvre, chacun assorti de sa parade.

15.1 Quatre phases et leurs jalons

La mise en œuvre progresse par phases : chaque phase installe les contrôles dont la suivante a besoin, et l'autonomie accordée aux agents n'augmente qu'une fois ces contrôles en service. La feuille de route est un ordre de planification : le plafond de phase est une condition nécessaire, jamais suffisante, de la hausse d'autonomie, qui exige l'homologation de l'agent (annexe A), et l'exigibilité de chaque contrôle se règle agent par agent, selon les capacités qu'il exerce (EXIG-GOV-16). C'est la logique d'un chantier : on ne monte pas les étages avant d'avoir coulé les fondations.

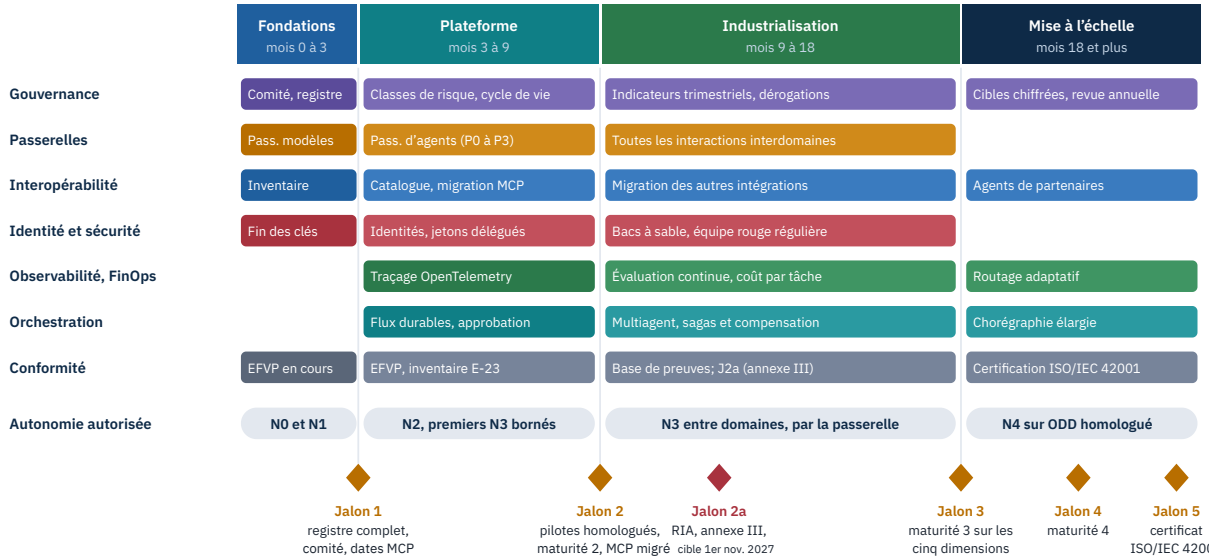


Figure 28 — Feuille de route : quatre phases et leurs jalons. Chaque ligne de travail avance d'une phase à l'autre; la dernière ligne indique l'autonomie maximale permise pendant la phase. Les losanges marquent les jalons : le comité constate J1, J2 et J3 avant d'ouvrir la phase suivante, J2a avant l'échéance réglementaire qu'il vise; J4 et J5 mesurent la progression dans la phase Mise à l'échelle. La passerelle d'agents s'ouvre au palier P3, avec l'approbation signée (section 8.5), pendant la phase Plateforme et avant tout agent N2 qui exécute des P3 (tableau 58). Les obligations légales en vigueur (art. 3.3, 12.1 et 17 de la Loi sur le privé) s'appliquent dès l'adoption, quelle que soit la ligne de la figure qui les mentionne. Source : cadre CRE-IA-2026-01 (durées indicatives, à calibrer après l'évaluation de maturité initiale).

Les durées sont indicatives et se calibrent après l'évaluation de maturité initiale (section 14.2) : une organisation qui exploite déjà une passerelle d'API raccourcira la phase Plateforme; celle qui découvre des dizaines d'agents non inventoriés allongera la phase Fondations. Le troisième jalon marque l'atteinte du niveau 3 de maturité sur les cinq dimensions du chapitre 14, seuil que le cadre retient pour laisser le nombre d'agents croître sans que les risques croissent au même rythme (choix du cadre). Les jalons 4 et 5 donnent à la phase Mise à l'échelle des critères de progression : le niveau 4, qui porte la préparation à la certification ISO/IEC 42001, puis la certification, que le modèle de maturité place au niveau 5 (section 14.3). Le cadre distingue enfin les échéances externes (inventaire E-23, RIA, Loi 25), qui ne bougent pas, des échéances internes à date fixe, comme la migration MCP de l'EXIG-MCP-22, choix du cadre que seul le comité peut déplacer par une révision du cadre (section 1.6).

Tableau 58 — Phases de mise en œuvre, livrables et autonomie autorisée

Phase	Livrables principaux	Autonomie autorisée	Jalon de sortie
Fondations mois 0 à 3	Conformité immédiate des agents existants aux obligations légales en vigueur (art. 3.3, 12.1 et 17 de la Loi sur le privé, notamment), sinon suspension; comité mandaté; inventaire et registre, agents fantômes compris, avec le statut « existant inventorié » et la mesure transitoire de cohorte (EXIG-GOV-16); propriétaire métier nommé pour chaque agent; fin des clés d'API partagées entre agents (remplacées par un secret propre par agent au coffre, sous la mesure transitoire de cohorte, en attendant les identités de charge de travail de la phase Plateforme); passerelle de modèles, qui met fin aux appels directs aux fournisseurs; traçage pilote; catalogue initial des	N0 et N1 seulement : pour les agents, lecture et recommandation (N1), outils P0 et P1, aucun effet en écriture; les flux déterministes (N0) restent régis par leurs contrôles habituels.	**Jalon 1** : registre complet (100 % des agents actifs avec une fiche ouverte et un parrain nommé), comité en fonction; chaque serveur et client MCP antérieur à la révision de référence inscrit au catalogue avec sa date de migration (EXIG-MCP-22); aucune clé partagée entre agents et tous les appels de modèles par la passerelle de modèles (tableau 61).

Phase	Livrables principaux	Autonomie autorisée	Jalon de sortie
	protocoles, chaque serveur et client MCP antérieur y étant inscrit avec sa date de migration (EXIG-MCP-22); premier classement des risques; EFVP manquantes faites, les flux qu'elles visent restant suspendus d'ici là; choix des blocs de solution; coupe-circuit testé.		
Plateforme mois 3 à 9	Passerelle d'agents ouverte aux outils P0 et P1, puis P2, chacun avec sa compensation déclarée et le canal de compensation (EXIG-ORC-17), puis P3, avec l'approbation signée (section 8.5), avant tout agent N2 qui exécute des P3; catalogue d'entreprise MCP et A2A; migration des serveurs et clients MCP en production vers la révision de référence, au plus tard le 28 juillet 2027 (EXIG-MCP-22); identité par agent et jetons délégués; traçage OpenTelemetry de bout en bout et journal d'audit; moteur d'exécution durable; approbation humaine signée, avec files d'approbation priorisées, rotation des approbateurs et indicateurs de la section 8.7; classement des risques et cycle de vie appliqués à tout nouvel agent; outillage de la transparence envers les personnes (section 12.7; les obligations de l'article 12.1 s'appliquent dès l'adoption); index de preuves (EXIG-CON-18); pour une institution financière fédérale, inventaire E-23 complet, avec la cote de risque et l'état de validation de chaque agent et modèle, au 1er mai 2027 (EXIG-CON-12), les validations étant planifiées selon la cote de risque; premiers pilotes.	N2; premiers N3 bornés au sein d'un même domaine, sur décision du comité, pour des agents de classe faible ou modérée.	**Jalon 2** : pilotes homologués selon l'annexe A; niveau 2 de maturité atteint sur les cinq dimensions; aucun serveur ni client MCP d'une révision antérieure à la révision de référence n'est en production (échéance du 28 juillet 2027 au plus tard, EXIG-MCP-22).
Industrialisation mois 9 à 18	Migration des autres intégrations existantes au catalogue, dont les dernières intégrations interdomaines encore hors passerelle, que l'EXIG-ARC-01 interdit déjà et que seule la mesure transitoire de l'EXIG-GOV-16 tolère d'ici là; évaluation continue dans la chaîne d'intégration et de livraison continues (CI/CD); enveloppes budgétaires et imputation par centre de coûts; flux multiagents et sagas à plusieurs systèmes (la compensation des outils P2 est livrée dès la phase Plateforme); bacs à sable pour le code généré; équipe rouge au moins annuelle (EXIG-SEC-23); consolidation outillée de l'index de preuves (EXIG-CON-18).	N3 entre domaines, dans la limite du plafond de chaque classe de risque, pour un agent dont tous les appels interdomaines passent par la passerelle d'agents.	**Jalon 2a** (organisations assujetties au RIA) : au plus tard le 1er novembre 2027, voir l'encadré ci-dessous. **Jalon 3** : niveau 3 de maturité sur les cinq dimensions; cibles chiffrées des indicateurs arrêtées pour J4 (section 15.3).
Mise à l'échelle mois 18 et plus	Chorégraphie événementielle élargie (CloudEvents, AsyncAPI); agents de partenaires; routage adaptatif des modèles; détection de dérive en continu; système de management de l'IA opéré, audit interne, puis audit de certification ISO/IEC 42001; revue du cadre.	N4 sur un domaine d'exploitation (ODD) homologué par le comité (section 8.1), pour des agents de classe faible, sur décision du comité.	**Jalon 4**, vers le mois 36 : niveau 4 sur les cinq dimensions; quatre trimestres consécutifs où au moins 95 % des agents tiennent leurs seuils contractuels et où chaque indicateur du tableau 61, mesuré pour l'entreprise, tient sa cible chiffrée, et, pour chaque incident grave, contention dans le délai et analyse des causes close; au-

Phase	Livrables principaux	Autonomie autorisée	Jalon de sortie
			dit interne du SMIA réalisé et audit de certification lancé. **Jalon 5**, vers le mois 48 : certificat ISO/IEC 42001 obtenu; niveau 5 atteint en interopérabilité et en gouvernance; feuille de route suivante adoptée. Ensuite : revue annuelle de maturité.

Règles de progression

- Une phase ne doit pas être ouverte (livrables mis en production, autonomie accrue) avant que le comité ait constaté, sur preuves, le jalon qui la précède. Les travaux préparatoires de la phase suivante peuvent commencer plus tôt, mais aucune hausse d'autonomie n'est permise avant le jalon. Aucun agent n'exerce un palier, un niveau ou une topologie avant que les contrôles qui les conditionnent soient en service et homologués (EXIG-GOV-16).
- Le plafond de la phase se combine avec le plafond de la classe de risque (section 8.1) : le plus strict s'applique. Un agent de classe élevée reste plafonné à N2, même en phase Mise à l'échelle; un agent de classe faible ne dépasse pas N1 tant que le jalon 1 n'est pas franchi.
- Un agent N3 qui agit entre domaines ne doit le faire que par la passerelle d'agents, même avant que la couverture interdomaines atteigne 100 % au jalon 3. Un appel interdomaines qui contourne la passerelle est une non-conformité à l'EXIG-ARC-01 : l'outil visé est retiré à l'agent ou, pour un agent existant inventorié, ramené à la lecture seule (P0 et P1, par des justificatifs en lecture seule chez le système cible) sous la mesure transitoire de l'EXIG-GOV-16, jusqu'à son passage par la passerelle.
- Un agent existant dont le niveau dépasse le plafond de la phase doit être ramené sous ce plafond, par le retrait de ses outils en écriture ou, dès la phase Plateforme, par l'approbation de chacune de ses actions (N2), ou relever de la mesure transitoire de cohorte (EXIG-GOV-16). Cette mesure ne couvre que l'écart entre le plafond de phase et le plafond de classe : un agent au-dessus de son plafond de classe est ramené sous ce plafond ou suspendu sans délai. Elle n'admet aucun point de l'EXIG-GOV-17 ni aucune obligation légale.
- Les travaux qui découlent d'une échéance externe (J2a, inventaire E-23) ou d'une échéance interne à date fixe (migration MCP de l'EXIG-MCP-22, choix du cadre) sont datés par cette échéance, non par la durée des phases; une échéance externe ne bouge pas, une échéance interne ne change que par une révision du cadre (section 1.6). Allonger une phase après l'évaluation initiale ne les reporte pas : ils passent alors en tête de la phase en cours, même s'ils appartiennent à la phase suivante, et le jalon qui précède ne les bloque pas.
- Le comité peut réordonner les travaux d'une phase selon les priorités métier. Il ne doit pas retirer un critère de jalon sans réviser le cadre (section 1.6).

ATTENTION

Deux échéances externes et une échéance interne resserrent le calendrier. La ligne directrice E-23 du BSIF, en vigueur le 1er mai 2027 et applicable aux institutions financières fédérales, attend un inventaire d'entreprise des modèles à risque non négligeable, y compris ceux des fournisseurs[8]; le cadre y ajoute l'état de validation (EXIG-CON-12) : l'inventaire est complet au jalon 1, puis au 1er mai 2027 avec la cote de risque et l'état de validation de chaque agent et modèle; E-23 ne fixe aucune échéance de validation des modèles existants, et les validations sont planifiées selon la cote de risque. Les serveurs et clients

MCP en production doivent avoir migré vers la révision de référence au plus tard le 28 juillet 2027 (EXIG-MCP-22, échéance interne du cadre), avant la fin de la phase Plateforme. Le règlement (UE) 2024/1689, modifié par le règlement (UE) 2026/1744, rend applicables à compter du 2 décembre 2027 les obligations visant les systèmes à haut risque de l'annexe III (au 2 août 2028 pour ceux de l'annexe I) [57, 58]; pour une organisation assujettie qui adopte le cadre à l'automne 2026, cette date tombe entre les jalons 2 et 3; les dates qui découlent du règlement (UE) 2026/1744 sont à confirmer sur le texte publié au Journal officiel avant de geler le jalon 2a. Les obligations déjà en vigueur, comme les articles 3.3, 12.1 et 17 de la Loi sur le privé, ne suivent pas le rythme des phases et ne souffrent aucune dérogation (EXIG-GOV-17) : un agent qui n'y satisfait pas est suspendu jusqu'à sa mise en conformité.

JALON 2A — CONFORMITÉ AU RIA, ANNEXE III

Pour une organisation assujettie au RIA (section 12.4), le comité constate au plus tard le 1er novembre 2027, sur preuves :

- la liste des agents qui relèvent de l'annexe III, avec l'applicabilité consignée selon l'usage des sorties dans l'Union (EXIG-CON-13);
- pour chacun, la revue de requalification en fournisseur faite (EXIG-CON-15) et, si l'organisation est fournisseur, les obligations du fournisseur en place (section 12.4);
- pour chacun, les obligations du déployeur en place (EXIG-CON-16), dont une conservation des journaux configurée pour au moins six mois (art. 26(6) du RIA; 24 mois pour le journal d'audit, EXIG-OBS-13);
- les preuves référencées à l'index de preuves (EXIG-CON-18).

À compter du 2 décembre 2027, les sorties d'un agent visé qui ne satisfait pas à ces critères ne doivent pas être utilisées dans l'Union, même s'il a été mis en service avant cette date (choix du cadre, plus strict que le régime transitoire de l'art. 111 du RIA). J2a n'ouvre aucune phase et n'accorde aucune autonomie.

Calage sur le calendrier 2027-2030

Le tableau 59 cale la feuille de route sur une adoption du cadre à l'automne 2026 : évaluation de maturité initiale en novembre 2026, ouverture de la phase Fondations le 1er décembre 2026 (mois 0). Un autre point de départ décale toutes les dates, sauf celles qui découlent d'une échéance externe. L'entreprise refait ce calage après l'évaluation initiale.

Tableau 59 — Calage indicatif, mois 0 au 1er décembre 2026

Période	Phase ou jalon	Échéances externes à tenir
Déc. 2026 – mi-mars 2027	Fondations, congés des fêtes compris	—
Mi-mars 2027	**J1**	— (signal de veille, non une échéance : l'ébauche OAuth 2.1 épinglée au catalogue est réépinglée à chaque nouvelle révision; la référence normative reste OAuth 2.0)
Mi-mars – fin sept. 2027	Plateforme, vacances de la construction comprises	Inventaire E-23 le 1er mai 2027; échéance interne de la migration MCP le 28 juillet 2027 (EXIG-MCP-22), à terminer avant les vacances de la construction si l'entreprise les observe
Début oct. 2027	**J2**	—
1er nov. 2027 au plus tard	**J2a** (cible interne du cadre)	RIA, annexe III, le 2 décembre 2027
Oct. 2027 – juin 2028	Industrialisation	—
Début juill. 2028	**J3**	RIA, annexe I, le 2 août 2028

Période	Phase ou jalon	Échéances externes à tenir
Juill. 2028 – 2030	Mise à l'échelle	Examen formel du NIST AI RMF au plus tard en 2028 (révision extraordinaire du cadre, section 1.6)
Déc. 2029	**J4**	—
Déc. 2030	**J5**	—

Une phase de six mois ou moins qui chevauche une période de congés collectifs (fêtes de fin d'année, vacances de la construction) s'allonge de la durée de cette période, environ deux semaines chacune; le tableau 59 en tient compte. Les durées des phases plus longues et les échéances de J4 et J5 incluent déjà les congés. Les périodes de congés collectifs sont un paramètre de l'entreprise; celles du tableau 59 sont des exemples. Les échéances externes ne bougent pas : l'inventaire E-23 reste exigible le 1er mai 2027. La migration MCP du 28 juillet 2027 est une échéance interne du cadre (EXIG-MCP-22), qui ne change que par une révision du cadre (section 1.6). Le cadre ne prévoit pas de jalon propre à l'annexe I du RIA : un agent intégré à un produit réglementé de l'annexe I (2 août 2028) suit les critères du jalon 2a, que le comité constate au plus tard le 1er juillet 2028.

15.2 Les 90 premiers jours

Les « 90 premiers jours » désignent les 13 premières semaines travaillées; ils forment la phase Fondations. Ils ne servent pas à construire de nouveaux agents, mais à rendre visibles et gouvernables ceux qui existent, puis à ouvrir une voie approuvée assez simple pour que personne n'ait intérêt à la contourner. L'inventaire répond aussi à la sous-catégorie GOVERN 1.6 du NIST AI RMF, qui demande des mécanismes d'inventaire des systèmes d'IA[74]. Une période de congés collectifs s'ajoute à ces 13 semaines (section 15.1, tableau 60).

Tableau 60 — Plan des 90 premiers jours (phase Fondations)

Semaines	Travaux	Livrable vérifiable	Responsable
1 et 2	Mandater le comité et nommer ses membres; associer le responsable de la protection des renseignements personnels (art. 3.1 de la Loi sur le privé, modifiée par la Loi 25)[56]; lancer l'inventaire des agents internes, des logiciels-services à agents intégrés, des serveurs MCP, des assistants dotés d'outils et des agents de partenaires, y compris les agents fantômes repérés dans les journaux réseau, les consentements OAuth et les consoles des logiciels-services; tout agent découvert reçoit dans les cinq jours ouvrables une fiche minimale et un parrain nommé, faute de quoi il est désactivé (EXIG-GOV-16).	Mandat du comité; inventaire brut	Architecture d'entreprise, sécurité
3 et 4	Ouvrir une fiche par agent (champs de l'étape Proposition, annexe B), au statut « existant inventorié »; nommer un propriétaire métier pour chacun; faire adopter par le comité la mesure transitoire de cohorte qui vise la liste des agents existants (EXIG-GOV-16); recenser les clés d'API et les comptes de service utilisés par des agents; repérer les décisions fondées exclusivement sur un traitement automatisé (art. 12.1 de la Loi sur le privé), dont l'obligation d'informer s'applique déjà, par des moyens manuels au besoin, sans attendre l'outillage de la phase Plateforme. Pour une institution financière fédérale, marquer à la fiche les agents et les modèles qui relèvent de l'inventaire E-23.	Registre initial; décision de cohorte; liste des agents sans propriétaire métier; inventaire des secrets; liste des décisions visées par l'article 12.1	Propriétaires métier, équipe plateforme
5 et 6	Mettre en service la passerelle de modèles et y basculer tous les appels aux fournisseurs; remplacer chaque clé partagée par un secret propre à l'agent, conservé au coffre et injecté à l'exécution, en attendant les identités de charge de travail de la phase Plateforme; ce secret transitoire relève de la mesure transitoire de cohorte (EXIG-GOV-16), sans dérogation agent par agent à l'EXIG-IAM-05. La fuite de secrets, les secrets de longue durée et la réutilisation d'une même identité figurent au Top 10 OWASP des identités non humaines[91].	Aucun appel direct à un fournisseur de modèles; aucune clé partagée entre agents	Équipe plateforme, sécurité

Semaines	Travaux	Livrable vérifiable	Responsable
7 et 8	Instrumenter deux ou trois agents représentatifs avec OpenTelemetry (version épinglée des conventions GenAI, section 10.1), centre de coûts compris; publier le catalogue initial des protocoles (section 6.3) et y inscrire les premiers outils avec leur palier P0 à P3; inscrire chaque serveur et client MCP antérieur à la révision de référence avec sa date de migration, au plus tard le 28 juillet 2027 (EXIG-MCP-22); ouvrir, sur un banc d'essai de l'entreprise, les essais reproductibles des candidats aux blocs de la phase Plateforme (EXIG-APP-03, EXIG-APP-04, EXIG-APP-06).	Traces de bout en bout, du canal au modèle; catalogue initial publié; plan de migration MCP; banc d'essai des candidats ouvert	Équipe plateforme, architecture d'entreprise
9 et 10	Classer chaque agent inventorié (classe faible, modérée ou élevée) et fixer son plafond d'autonomie; repérer les agents qui traitent des RP ou les communiquent hors du Québec; toute communication hors du Québec sans EFVP (art. 17) est suspendue jusqu'à ce que l'EFVP soit faite, et les EFVP des projets en cours (art. 3.3) sont lancées[413]; repérer les agents qui relèvent de l'annexe III du RIA; ramener sous le plafond de phase les agents qui le dépassent.	Classe et plafond inscrits pour tous les agents; flux hors Québec couverts par une EFVP ou suspendus; EFVP des projets en cours lancées; liste des agents visés par l'annexe III	Risques et conformité, responsable de la protection des RP, propriétaires métier
11	Choisir les blocs de solution de la phase Plateforme (passerelle d'agents, moteur d'exécution durable, registre d'entreprise, qui prolonge le registre initial des semaines 3 et 4) avec la grille de la section 13.4, appliquée aux essais du banc d'essai ouvert aux semaines 7 et 8; les preuves qui supposent un agent pilote (export FOCUS d'un mois, essai de restitution) sont cotées provisoirement sur la démonstration du fournisseur et confirmées au premier pilote de la phase Plateforme; documenter le coupe-circuit, externe à l'agent[353], puis l'exercer sur un agent réel en mesurant le délai de révocation.	Décision de plateforme, avec ses notes provisoires; rapport d'exercice du coupe-circuit	Architecture d'entreprise, équipe plateforme, sécurité
12 et 13	Mesurer la valeur de référence des indicateurs (tableau 61); tenir la revue du jalon 1; arrêter le plan de la phase Plateforme et choisir les pilotes, en plaçant en tête la migration MCP et, s'il y a lieu, l'inventaire E-23; recaler le tableau 59 sur la date réelle du jalon 1.	Procès-verbal du jalon 1; tableau de bord de référence; calendrier recalé	Comité, architecture d'entreprise

À RETENIR

Bloquer les agents sans offrir d'autre voie pousse les employés vers l'IA fantôme *(shadow AI)*, constate Gartner (avril 2026)[2]. Dès la sixième semaine, la passerelle de modèles et une inscription rapide au registre offrent une voie approuvée plus simple que le contournement.

15.3 Indicateurs

Les indicateurs servent à constater les jalons et à piloter l'autonomie sur des mesures. Ils obéissent à cinq règles du cadre :

- chaque indicateur doit être calculé à partir du registre, des passerelles, des traces et du journal d'audit ou, pour les exercices et les incidents, d'enregistrements horodatés, et non déclaré par les équipes; une donnée qui ne peut pas se calculer ainsi (coût du processus de référence, intervention imprévue) est une donnée attestée, établie par la fonction qui en répond (la finance pour un coût), datée, versée à la fiche et signalée comme telle au tableau 61;
- la valeur de référence est mesurée au jalon 1 pour la couverture du registre, les secrets et la passerelle de modèles, et, pour les autres indicateurs, au premier trimestre qui suit le jalon 1 ou la mise en service de leur source; les indicateurs sont ensuite présentés chaque trimestre au comité, par agent, par domaine et pour l'entreprise;

- les cibles du tableau 61 sont des choix du cadre; le comité peut les ajuster par écrit, avec justification, sauf celles qui reprennent une exigence, qui ne s'écartent que par dérogation (section 11.6) : couverture du registre (EXIG-GOV-07), secrets (EXIG-IAM-05), passerelles (EXIG-ARC-01, EXIG-IAM-17), conformité au catalogue (EXIG-INT-04, EXIG-INT-06, EXIG-MCP-22), traçabilité (EXIG-OBS-11) et couverture de l'évaluation (EXIG-EVA-01); la cible de l'EFVP reprend une obligation légale et ne s'écarte jamais (EXIG-GOV-17);
- à la revue du jalon 3, le comité remplace par une valeur chiffrée chaque cible exprimée comme une tendance (« en baisse », « en hausse »), à partir des séries trimestrielles disponibles; ces valeurs sont les cibles que le jalon 4 vérifie;
- chaque indicateur a un responsable de mesure, nommé par le comité parmi les rôles de la section 11.1; le tableau 61 propose le rôle qui opère la source de la donnée.

Tableau 61 — Indicateurs de mise en œuvre et cibles proposées

Indicateur	Définition	Cible proposée	Fréquence	Responsable de mesure (proposé)
Couverture du registre	Part des agents actifs, déclarés ou découverts, qui ont une fiche à jour au registre	100 %	Mensuelle	Équipe plateforme
Découverte d'agents hors registre	Nombre d'agents découverts hors registre par trimestre, et délai entre leur première trace ou leur premier consentement OAuth et leur inscription	En baisse; inscription en cinq jours ouvrables au plus (EXIG-GOV-16)	Trimestrielle	Équipe plateforme
Agents sans secret partagé	Part des agents qui s'authentifient avec un justificatif qui leur est propre, sans clé partagée ni compte d'une personne	100 % au jalon 1	Mensuelle	Sécurité de l'information
Couverture des passerelles	Dans tout environnement autre qu'un poste de développement individuel, part des appels de modèles, de tous les appels MCP et A2A, quel que soit le domaine, de tous les accès à une ressource d'un autre domaine et de toutes les actions P2 et P3 qui passent par la passerelle de modèles ou d'agents (portée de l'EXIG-ARC-01 et de l'EXIG-IAM-17); seules les fonctions locales P0 et P1 dispensées par ces exigences sont exclues du dénominateur	Modèles : 100 % au jalon 1; MCP, A2A, accès à un autre domaine, P2 et P3 : 100 % des nouveaux agents dès leur homologation, 100 % des agents existants au jalon 3 (mesure transitoire de l'EXIG-GOV-16 d'ici là)	Mensuelle	Équipe plateforme
Conformité au catalogue	Part des intégrations d'agents qui utilisent un protocole et une version inscrits au catalogue	100 % des nouveaux agents; serveurs et clients MCP en production : 100 % sur la révision de référence au 28 juillet 2027; 100 % des agents existants au jalon 3	Trimestrielle	Architecture d'entreprise

Indicateur	Définition	Cible proposée	Fréquence	Responsable de mesure (proposé)
Traçabilité	Part des actions à effet (P2 et P3) rattachées à une trace complète, à leur mandant et à une entrée du journal d'audit	100 % dès l'ouverture des outils P2 et P3 à la passerelle d'agents (phase Plateforme) : aucun effet sans journal d'audit (EXIG-OBS-11, non dérogeable)	Mensuelle	Équipe plateforme
Couverture de l'évaluation	Part des agents en production dont le jeu de référence s'exécute dans la chaîne CI/CD et atteint ses seuils (section 10.4)	100 % des nouveaux agents dès la mise en service de la chaîne CI/CD (phase Industrialisation; d'ici là, forme minimale déclarée à la fiche, annexe A); 100 % des agents existants au jalon 3 (mesure transitoire de cohorte d'ici là)	Trimestrielle	Équipe d'évaluation
Réussite des tâches	Tâches réussies sans intervention humaine imprévue (escalade que le contrat d'agent ne prévoit pas; donnée attestée), sur le total des tâches, par agent	Seuil fixé au contrat d'agent	Mensuelle	Responsable technique de chaque agent
Escalade humaine	Part des tâches renvoyées à une personne	Fourchette fixée au contrat d'agent; tout écart s'analyse	Mensuelle	Responsable technique de chaque agent
Approbation sans modification	Par approbateur et par file : part des demandes approuvées telles quelles, avec le temps de réponse médian	Seuil d'alerte fixé par cas d'usage; tout écart marqué par rapport à la norme s'analyse	Mensuelle	Équipe plateforme (EXIG-AUT-21)
Incidents agentiques	Nombre d'incidents par gravité (S1 à S4, attribuée par la fonction risques et conformité, section 12.8), avec les délais de détection et de contention	Taux d'incidents graves par millier de tâches, chiffré au jalon 3; pour chaque incident grave, contention dans le délai et analyse des causes close; délais en baisse	Trimestrielle	Risques et conformité
Délai de révocation en exercice	Temps écoulé entre la décision d'arrêter un agent et le refus de son dernier appel, dans tous les systèmes, mesuré lors de l'exercice trimestriel de l'EXIG-SEC-26 et décomposé en délai de refus aux passerelles et en exposition résiduelle des systèmes sans révocation active (durée de vie maximale des jetons qu'ils acceptent, EXIG-IAM-15)	Cible fixée par l'entreprise (EXIG-IAM-20), proposée à 15 minutes, puis en baisse; liste des systèmes sans révocation active publiée	Trimestrielle	Sécurité de l'information
Délai d'intégration	Temps écoulé entre l'inscription d'une demande de branchement d'un outil déjà inscrit au catalogue et le premier appel réussi de l'agent vers cet outil, relevé dans les traces	En baisse d'un trimestre à l'autre, puis valeur chiffrée au jalon 3	Trimestrielle	Équipe plateforme

Indicateur	Définition	Cible proposée	Fréquence	Responsable de mesure (proposé)
Réutilisation	Nombre moyen d'agents consommateurs par outil du catalogue	En hausse, puis valeur chiffrée au jalon 3	Trimestrielle	Équipe plateforme
Coût par tâche réussie	Coût total imputé (inférence, outils, quote-part de la plateforme) divisé par le nombre de tâches réussies, en dollars canadiens; la quote-part est suivie à part, et l'arrêt d'un pilote se décide sur le coût marginal, hors quote-part	Inférieur au coût du processus de référence sans agent (donnée attestée); écart chiffré au jalon 3	Mensuelle	Équipe FinOps
EFVP à jour	Part des agents traitant des RP dont l'EFVP couvre la version en production	100 % des nouveaux agents dès leur homologation (EXIG-CON-04); 100 % des agents existants au jalon 1, les flux visés restant suspendus d'ici là (tableau 58)	Trimestrielle	Responsable de la protection des RP

La cible proposée de 15 minutes pour la révocation est un choix du cadre, que l'entreprise ajuste en fixant son propre délai maximal (EXIG-IAM-20, seule source de la cible). Le délai de refus aux passerelles et l'exposition résiduelle d'un système sans révocation active sont deux grandeurs distinctes : un jeton émis juste avant la désactivation reste utilisable jusqu'à son expiration chez un tel système. C'est pourquoi l'EXIG-IAM-15 borne à la cible la durée de vie des jetons destinés à ces systèmes, ou ne les rend joignables que par la passerelle. La cible de révocation concrétise la sous-catégorie MANAGE 2.4 du NIST AI RMF, qui demande des mécanismes pour désengager ou désactiver un système dont le comportement s'écarte de l'usage prévu[74]. Le coût par tâche réussie est d'abord présenté en refacturation indicative *(showback)*, modèle que recommande la FinOps Foundation[407]; le passage à la refacturation réelle relève du comité (EXIG-FIN-09).

ATTENTION

Un indicateur ne se lit jamais seul. Un taux d'escalade très bas peut signifier qu'un agent tranche des cas qu'il devrait renvoyer. Un taux élevé d'approbation sans modification, joint à des temps de réponse très courts, peut signaler une approbation machinale : l'Infocomm Media Development Authority (IMDA) de Singapour recommande de surveiller ces deux signaux[76]. Une cible déclenche une analyse; elle ne sert pas à récompenser une équipe.

15.4 Facteurs de succès et risques de mise en œuvre

Les données publiques invitent à la prudence : selon Gartner (juin 2025), plus de 40 % des projets d'IA agentique seront annulés d'ici la fin de 2027 en raison de coûts croissants, d'une valeur d'affaires incertaine ou de contrôles des risques inadéquats[3]. Les facteurs suivants visent directement ces trois causes.

Facteurs de succès

1. **Un parrainage de direction et un comité qui décide.** Un comité seulement consultatif ne peut ni constater les jalons ni accorder les dérogations.
2. **La plateforme avant la multiplication des agents.** Gartner (avril 2026) estime qu'une entreprise moyenne du Fortune 500 aura plus de 150 000 agents en usage d'ici 2028, contre moins de 15 en 2025[2]. Cet ordre de grandeur prospectif[467] laisse prévoir qu'un contrôle agent par agent ne tiendra pas : passerelles, catalogue et gabarits doivent précéder la croissance.

3. **Une gouvernance proportionnée.** Selon Gartner (mai 2026), appliquer la même gouvernance à tous les agents mènera à des échecs, et 40 % des entreprises rétrograderont ou désactiveront des agents autonomes d'ici 2027 à cause de lacunes révélées seulement après des incidents en production[95]. Le cadre gradue donc les contrôles selon la classe de risque, le niveau d'autonomie et le palier d'outil (sections 8.4 et 12.1).
4. **Commencer simple.** Anthropic recommande la solution la plus simple possible[6]; une architecture multiagent consomme de 3 à 10 fois plus de jetons qu'un agent unique selon [275][275], et environ 3,75 fois selon les mesures d'Anthropic (environ 15 fois une conversation contre environ 4 fois pour un agent)[17]. Les premiers pilotes retiennent un flux déterministe ou un agent unique outillé.
5. **Mesurer la valeur dès le pilote.** Chaque pilote compare son coût par tâche réussie à celui du processus de référence; un pilote qui ne fait pas mieux s'arrête ou se redéfinit.
6. **Concevoir la supervision au lieu de la présumer.** Le biais d'automatisation touche les novices comme les experts et ne se prévient pas par la seule formation[314]. Les files d'approbation, les seuils et les indicateurs de la section 8.7 font partie des livrables de la phase Plateforme.

Risques et parades

Le tableau 62 synthétise les principaux risques de mise en œuvre, leurs signes avant-coureurs et leurs parades.

Tableau 62 — Risques de mise en œuvre, signes avant-coureurs et parades

Risque	Signe avant-coureur	Parade prévue par le cadre
Abandon faute de valeur démontrée	Pilotes sans processus de référence ni coût par tâche	Indicateur de valeur obligatoire à la fiche; arrêt des pilotes non concluants
Plateforme centrale devenue goulot	Délai d'intégration en hausse; contournements	Modèle en étoile et libre-service par gabarits (section 11.3)
Prolifération et IA fantôme	Agents découverts hors registre; consentements OAuth inconnus	Inventaire continu; voie approuvée simple; désactivation des agents sans fiche
Gouvernance uniforme	Mêmes contrôles pour un agent N1 et un agent N3; files d'approbation saturées	Contrôles gradués par classe, par niveau et par palier (section 8.4)
Approbation machinale	Taux élevé d'approbation sans modification; temps de réponse très courts	Files priorisées par risque, regroupement, rotation des approbateurs (section 8.7)
Instabilité des standards	Nouvelle révision de MCP; conventions GenAI d'OpenTelemetry encore au niveau Development	Versions épinglées au catalogue; révision trimestrielle (section 11.7)
Migration MCP manquée	Serveurs ou clients MCP antérieurs encore en production à trois mois de l'échéance du 28 juillet 2027; serveurs sans date de migration au catalogue	Plan de migration dès la phase Fondations; migration en tête de la phase Plateforme; critère du jalon 2 (EXIG-MCP-22)
Phase Plateforme allongée	Livrables de la phase en retard sur le calendrier recalé; jalon 2 qui glisse au-delà d'octobre 2027	Travaux datés par leur échéance externe (règles de progression); travaux réglementaires en tête de phase; réordonnancement par le comité
Verrouillage par une plateforme	Extensions propriétaires; données ou mémoires non exportables	Clauses contractuelles du chapitre 13
Dérive des coûts	Coût par tâche en hausse; boucles qui atteignent leurs plafonds	Enveloppes budgétaires et routage frugal (section 10.6)
Échéance réglementaire manquée	Agent à haut risque dont la mise en service est prévue à compter du 2 décembre 2027; EFVP non commencée; inventaire E-23 sans état de validation à l'approche du 1er mai 2027	Jalon J2a; inventaire E-23 complet en phase Plateforme; priorité dans chaque phase; évaluation d'impact unifiée (section 12.9)

Annexes — Outils d’application

Grille d’homologation, gabarit de fiche d’agent, exemples de contrats, registre des exigences, glossaire, validation des sources et des ébauches, références.

A · Grille d’homologation

B · Gabarit de fiche d’agent

C · Exemples de contrats

D · Registre des exigences

E · Glossaire

F · Validation des sources et des ébauches

G · Références

A Grille d'homologation

Cette grille se remplit pour chaque agent et chaque serveur MCP avant le jalon « homologation » du cycle de vie (homologation provisoire à l'entrée en pilote, puis homologation de production), puis à chaque réévaluation. Elle reprend, sous forme vérifiable, l'ensemble des 287 exigences du registre (annexe D), regroupées en points; chaque point renvoie aux exigences qui le fondent, et celles qui conditionnent la mise en production y figurent toutes. Une même grille sert à l'équipe du domaine, à la plateforme, à la sécurité et au comité.

A.1 Mode d'emploi

1. **Qui remplit.** Le responsable technique de l'agent remplit la grille et joint les preuves; l'équipe plateforme et la sécurité vérifient; l'autorité désignée par la matrice RACI approuve (section 11.2). Pour un agent de classe élevée ou de niveau N4, le comité approuve et le propriétaire métier en répond (R).
2. **Réponses admises.** « Conforme » avec preuve (lien vers l'artefact au registre), « Sans objet » avec justification, ou « Non conforme ». Un point non conforme exige une dérogation écrite, bornée dans le temps et assortie de mesures compensatoires (section 11.6), sauf un point non dérogeable, qui bloque la mise en production ou impose la suspension. Un écart à une exigence formulée avec DEVRAIT (par exemple EXIG-IAM-15 et –19) se justifie par écrit à la fiche, sans dérogation (section 1.4); un point qui mêle DOIT et DEVRAIT admet la réponse « Écart justifié (DEVRAIT) » pour sa seule partie DEVRAIT. Un point « Tous » dont le moyen n'est pas encore en service (évaluation dans la chaîne CI/CD, suite d'attaques en CI, imputation par centre de coûts) se satisfait, pour un pilote de la phase Plateforme, par sa forme minimale déclarée à la fiche (jeu d'évaluation exécuté avant chaque mise en service, suite d'attaques exécutée à l'homologation, plafond de coût par agent); la forme complète est exigible dès la mise en service du moyen (EXIG-GOV-16).
3. **Points non dérogeables.** Les points marqués « non dérogeable » ne peuvent faire l'objet d'aucune dérogation : un « Non conforme » bloque la mise en production ou impose la suspension (EXIG-GOV-17). Ils sont la projection point par point de l'EXIG-GOV-17, qui fait foi, et comprennent tout point qui reprend une obligation légale.
4. **Conservation.** La grille remplie, ses preuves et la décision d'homologation sont versées à la fiche de l'agent au registre (annexe B) et conservées avec son historique.

Légende de l'applicabilité : chaque point des sections A.2 à A.8 occupe une ligne de tableau. La première colonne donne l'applicabilité (Tous s'applique à tout agent; Si … s'applique seulement dans le cas indiqué) et, sur une seconde ligne, la marque « non dérogeable » lorsqu'elle s'applique; la dernière colonne reçoit la réponse et le lien vers la preuve (voir « Réponses admises »). L'applicabilité est aussi la condition d'exigibilité : un point est exigible dès que l'agent exerce la capacité qu'il vise, quelle que soit la phase de la feuille de route; un point non dérogeable est exigible immédiatement (EXIG-GOV-16).

A.2 Gouvernance, registre et classement

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Tous **non dérogeable**	**Fiche complète au registre** : identifiant, version, parrain (propriétaire métier) et responsable technique nommés, équipe de garde, finalité, mandants autorisés, suppléant nommé pour chaque rôle A, gouvernance du cycle de vie et revues périodiques.	`EXIG-GOV-01, EXIG-GOV-02, EXIG-GOV-04, EXIG-GOV-05, EXIG-GOV-06, EXIG-GOV-07, EXIG-GOV-08, EXIG-GOV-09, EXIG-GOV-10, EXIG-GOV-11, EXIG-GOV-13, EXIG-GOV-14, EXIG-GOV-15`	

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Tous	**Séparation des fonctions** respectée : la personne qui prépare une décision du cycle de vie (classification, niveau d'autonomie, validation des seuils d'évaluation, homologation, attestation, dérogation) n'est pas celle qui l'approuve, et l'évaluation est réalisée par une équipe distincte de l'équipe de construction.	EXIG-GOV-03, EXIG-GOV-04	
Tous	**Classe de risque** attribuée par la fonction risques et conformité avant l'inscription (état « proposé »), sur l'autonomie maximale envisagée et le parcours de décision déclaré, avec les critères retenus (rayon d'impact, réversibilité, délai de détection, observabilité).	EXIG-CON-01, EXIG-AUT-06	
Tous **non dérogeable**	**Niveau d'autonomie** déclaré (N0 à N4), dans le plafond de la classe de risque et dans celui de la phase en cours (tableau 58); aucun comportement NX; aucun agent qui atteint les seuils de la règle d'or au-delà de N2.	EXIG-AUT-01, EXIG-AUT-02, EXIG-AUT-03, EXIG-AUT-07, EXIG-CON-02	
Si N3 ou N4	**Domaine d'exploitation (ODD)** documenté, comportement de repli et conditions d'arrêt déclarés; homologation du niveau (l'évaluation assistée de Feng et coll. est recommandée, non exigée).	EXIG-AUT-04, EXIG-AUT-05	
Tous	**Patron d'orchestration** déclaré et justifié; configuration la plus simple démontrée suffisante, ou preuve mesurée du gain multiagent.	EXIG-ORC-01, EXIG-ORC-02, EXIG-ORC-03	
Tous	**Déclencheurs de réévaluation** de l'EXIG-GOV-12 inscrits à la fiche par renvoi à cette liste, qui seule fait foi.	EXIG-GOV-12, EXIG-GOV-16, EXIG-GOV-17, EXIG-GOV-18, EXIG-GOV-19, EXIG-GOV-20, EXIG-CON-03, EXIG-APP-01, EXIG-APP-02, EXIG-APP-03, EXIG-APP-04, EXIG-APP-05, EXIG-APP-06	
Si agent existant	**Régime transitoire** : statut « existant inventorié », mesure transitoire de cohorte en vigueur, aucun point de l'EXIG-GOV-17 couvert, appels hors passerelle limités aux paliers P0 et P1.	EXIG-GOV-16	
Si intégré à un logiciel-service	**Agent intégré** : régime de l'EXIG-ARC-02 (inscription, accès par la passerelle, clauses contractuelles, mécanisme d'arrêt propre éprouvé, schémas épinglés).	EXIG-ARC-02, EXIG-GOV-07	

A.3 Interopérabilité et contrats

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Tous	**Revue d'interopérabilité proportionnée** (niveaux sémantique et technique, ou les quatre niveaux selon le tableau 14) consignée; vocabulaire et schémas d'entreprise utilisés.	EXIG-INT-01, EXIG-INT-02, EXIG-INT-03	
Tous	**Protocoles et contrats du catalogue** seulement, à la version de référence; choix justifié par la matrice de sélection, schémas versionnés, erreurs RFC 9457, délais et quotas d'interface.	EXIG-INT-04, EXIG-INT-05, EXIG-INT-06, EXIG-INT-07, EXIG-INT-08, EXIG-INT-09, EXIG-INT-10, EXIG-INT-11, EXIG-INT-12, EXIG-INT-13, EXIG-INT-14, EXIG-INT-15, EXIG-INT-16, EXIG-INT-17, EXIG-INT-18, EXIG-INT-19, EXIG-INT-20, EXIG-INT-21, EXIG-INT-22, EXIG-INT-23	
Si outils MCP	**Serveurs MCP derrière la passerelle**, autorisation obligatoire, portées minimales, aucun passage de jeton, transport et cycle de vie conformes à l'environnement.	EXIG-MCP-01, EXIG-MCP-02, EXIG-MCP-03, EXIG-MCP-04, EXIG-MCP-05, EXIG-MCP-08, EXIG-MCP-09, EXIG-MCP-10, EXIG-MCP-11, EXIG-MCP-12, EXIG-MCP-13, EXIG-MCP-19, EXIG-MCP-21, EXIG-MCP-22	
Si outils MCP	**Contrats d'outils** orientés tâche (pas de miroir CRUD), nommage et résultats conformes, annota-	EXIG-MCP-06, EXIG-MCP-07, EXIG-MCP-14, EXIG-MCP-20	

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
	tions traitées comme de simples indices, empreinte des définitions épinglée.		
Si outils MCP	**Contrôles propres à MCP** : concordance en-têtes et corps, traitement de `_meta`, état explicite protégé, aucune donnée sensible en en-tête.	EXIG-MCP-15, EXIG-MCP-16, EXIG-MCP-17, EXIG-MCP-18	
Si invocable par A2A	**Carte d'agent A2A 1.0** publiée, signée, inscrite au registre, sans champ hors norme; compétences internes réservées à la carte étendue.	EXIG-A2A-02, EXIG-A2A-03, EXIG-A2A-04, EXIG-A2A-05, EXIG-A2A-06	
Si invocable par A2A	**Carte et tâches A2A** : carte d'agent signée, version annoncée, liaisons standard, authentification à chaque requête, autorisation par compétence, notifications push durcies, trousse de compatibilité réussie.	EXIG-A2A-01, EXIG-A2A-02, EXIG-A2A-03, EXIG-A2A-04, EXIG-A2A-05, EXIG-A2A-06, EXIG-A2A-07, EXIG-A2A-08, EXIG-A2A-09, EXIG-A2A-10, EXIG-A2A-11, EXIG-A2A-12, EXIG-A2A-13, EXIG-A2A-14, EXIG-A2A-15	
Si événements	**Événements CloudEvents** complets, contrat AsyncAPI au catalogue, attributs de gouvernance vérifiés, compteur de sauts appliqué, aucune donnée personnelle dans les attributs, autorisation fondée sur l'identité authentifiée auprès du courtier.	EXIG-EVT-01, EXIG-EVT-02, EXIG-EVT-03, EXIG-EVT-04, EXIG-EVT-05, EXIG-EVT-06, EXIG-EVT-07	
Si événements	**Consommateurs idempotents**, ordre garanti par la clé de partition lorsque requis, conservation des entrées pour rejeu isolé.	EXIG-EVT-08, EXIG-EVT-09, EXIG-EVT-10	

A.4 Orchestration et réversibilité

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Si écriture, plusieurs étapes ou attente	**Architecture et exécution durable** : plans séparés, état persisté après chaque transition, reprise sans double effet, magasin de points de contrôle protégé.	EXIG-ARC-02, EXIG-ARC-03, EXIG-ARC-04, EXIG-ARC-05, EXIG-ARC-06, EXIG-ARC-07, EXIG-ARC-09, EXIG-ARC-10, EXIG-ARC-13, EXIG-ARC-14, EXIG-ARC-15, EXIG-ARC-16, EXIG-ARC-17, EXIG-ARC-18, EXIG-ARC-19, EXIG-ARC-20, EXIG-ARC-21, EXIG-ORC-11, EXIG-ORC-12, EXIG-ORC-13, EXIG-ORC-14	
Si écritures	**Clé d'idempotence** déclarée au catalogue pour tout outil P2 ou P3, avec son mode (natif, ou adaptateur à registre durable), dérivée de l'opération racine et conservée au moins aussi longtemps que la fenêtre de rejeu; à défaut, outil classé P3, sans réessai automatique.	EXIG-ORC-21, EXIG-ORC-22	
Si écritures multisystèmes	**Saga** : compensation déclarée au catalogue pour chaque étape, journal de compensation tenu avant l'action, compensations idempotentes, exécutées par le canal de compensation, étape incertaine clôturée ou résolue avant toute compensation, escalade après deux échecs, isolation sémantique.	EXIG-ORC-15, EXIG-ORC-16, EXIG-ORC-17, EXIG-ORC-18, EXIG-ORC-19	
Si saga	**Tests d'injection de fautes** réussis dans la chaîne d'intégration (échec à chaque étape, plantage entre journal et action, double compensation, double échec de compensation, arrivée tardive de l'original après la compensation, compensation sous coupe-circuit, compensation pendant une panne de la passerelle).	EXIG-ORC-20	
Tous	**Plafonds d'exécution** (étapes, appels d'outils, jetons, coût, délai), résilience et modèle de repli testés.	EXIG-ORC-26, EXIG-ORC-27	
Si multiagent	**Délégation et patrons multiagents** : profondeur limitée à deux niveaux, patrons encadrés, contexte transmis minimal et structuré, retour validé avant réutilisation, filtrage de sécurité dans chaque agent.	EXIG-ORC-04, EXIG-ORC-05, EXIG-ORC-06, EXIG-ORC-07, EXIG-ORC-08, EXIG-ORC-09, EXIG-ORC-10, EXIG-ORC-23, EXIG-ORC-24, EXIG-	

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
		ORC-25, EXIG-ORC-29, EXIG-ORC-30	
Tous	**Coupe-circuit** opérationnel pour l'agent; agent inclus dans l'échantillon de l'exercice trimestriel de l'EXIG-SEC-26 (tous les agents de classe élevée et N4, rotation pour les autres); délai de révocation mesuré contre la cible de l'EXIG-IAM-20.	EXIG-ORC-28, EXIG-IAM-20, EXIG-SEC-26	

A.5 Autonomie et supervision humaine

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Tous	**Paliers des outils** (P0 à P3) attribués au catalogue après revue, jamais déduits des annotations du serveur; contrôle calculé à chaque appel selon l'EXIG-AUT-10; seuils mesurés sur une grandeur que calcule la passerelle ou que fournit le système visé, avec leur portée et leur fenêtre; échec en mode fermé.	EXIG-AUT-08, EXIG-AUT-10, EXIG-AUT-11	
Tous **non dérogeable**	**Aucune action P3 sans approbation humaine** hors bande, par jeton signé lié à l'action exacte, conservé par la passerelle et compté par opération; aucune approbation tirée de la conversation de l'agent; tests négatifs réussis (clé JSON dupliquée, grand entier hors de la plage exacte, appelant différent de l'appelant approuvé, outil local P3 hors passerelle refusé à l'homologation).	EXIG-AUT-09, EXIG-AUT-12, EXIG-AUT-13, EXIG-AUT-14	
Si approbations	**Approbateurs** habilités et formés; écran d'approbation fidèle à l'action; boîte de réception persistante; charge d'approbation maîtrisée et qualité de la supervision mesurée.	EXIG-AUT-15, EXIG-AUT-16, EXIG-AUT-19, EXIG-AUT-20, EXIG-AUT-21	
Si agent ambiant	**Réautorisation périodique** et effets placés après le point d'approbation.	EXIG-AUT-17, EXIG-AUT-18	
Si décision sur une personne **non dérogeable**	**Décisions automatisées** (art. 12.1 de la Loi sur le privé) : avis au plus tard au moment où la décision est communiquée, explication des principaux facteurs et paramètres, révision humaine significative, conservation des éléments de décision au dossier de décision.	EXIG-AUT-22, EXIG-AUT-23, EXIG-CON-07, EXIG-CON-08, EXIG-CON-09, EXIG-OBS-11	

A.6 Identité, sécurité et confiance zéro

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Tous	**Identité propre**, cryptographique, émise par la plateforme, non partagée; aucun secret statique; justificatifs hors de portée du modèle.	EXIG-IAM-01, EXIG-IAM-02, EXIG-IAM-03, EXIG-IAM-04, EXIG-IAM-05, EXIG-IAM-06, EXIG-IAM-07	
Si agit pour une personne **non dérogeable**	**Délégation explicite** par échange de jetons; aucune usurpation; aucun relais de jeton.	EXIG-IAM-08, EXIG-IAM-09, EXIG-IAM-12	
Si agit pour une personne	**Jetons délégués** : portée jamais élargie, expiration jamais prolongée au-delà de celle du jeton reçu, jeton à audience unique.	EXIG-IAM-08, EXIG-IAM-10, EXIG-IAM-11	
Tous	**Profil OAuth de l'entreprise** appliqué, jetons liés à l'expéditeur et de courte durée; agents autonomes avec identifiants du client et portées par outil.	EXIG-IAM-13, EXIG-IAM-14, EXIG-IAM-15, EXIG-IAM-16	
Tous	**Passerelle d'agents** en coupure de tout appel MCP ou A2A, quel que soit le domaine, et de toute action P2 ou P3; passerelle de modèles pour tout appel de modèle (aucun appel direct à un fournisseur); échec en mode fermé; secrets aval injectés par la passerelle; politiques en code versionnées et testées.	EXIG-ARC-01, EXIG-ARC-08, EXIG-ARC-11, EXIG-ARC-12, EXIG-IAM-17, EXIG-IAM-18, EXIG-IAM-19, EXIG-IAM-21	

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Tous	**Modèle de menaces** établi (analyse simplifiée pour la classe faible) et matrice de traçabilité menaces-contrôles (OWASP ASI) à jour.	EXIG-SEC-01, EXIG-SEC-02	
Tous **non dérogeable (EXIG-SEC-06)**	**Défense contre l'injection** : présomption d'injection, règle de deux évaluée sur la session composée (tâche racine et tout ce qui en dérive), toute source de contexte inscrite avec son étiquette, retrait déterministe des capacités d'exfiltration, patron de conception pour la classe élevée.	EXIG-SEC-03, EXIG-SEC-04, EXIG-SEC-05, EXIG-SEC-06, EXIG-SEC-07	
Si code généré	**Bac à sable** conforme (technologie d'isolation, éphémère, réseau refusé par défaut, métadonnées infonuagiques bloquées, secrets injectés hors du bac à sable, délais à trois niveaux, journal externe, porte de validation).	EXIG-SEC-08, EXIG-SEC-09, EXIG-SEC-10, EXIG-SEC-11, EXIG-SEC-12, EXIG-SEC-13, EXIG-SEC-14, EXIG-SEC-15, EXIG-SEC-16, EXIG-SEC-17	
Tous	**Chaîne d'approvisionnement** : provenance approuvée, signatures vérifiées, nomenclature de version, chaque serveur traité comme un domaine distinct, tiers évalués.	EXIG-SEC-18, EXIG-SEC-19, EXIG-SEC-20, EXIG-SEC-21, EXIG-SEC-22	
Si classe modérée ou élevée, niveau N3 ou N4, ou contenu non fiable consommé	**Équipe rouge** propre aux agents et suite d'attaques intégrée à la chaîne d'intégration; contrôles déterministes vérifiés.	EXIG-SEC-23, EXIG-SEC-24, EXIG-SEC-25	

A.7 Observabilité, évaluation et coûts

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Tous	**Traçage de bout en bout** : contexte W3C propagé dans HTTP, MCP, A2A et les événements; conventions GenAI à la version épinglée; attributs d'entreprise sous préfixe de domaine inversé.	EXIG-OBS-01, EXIG-OBS-02, EXIG-OBS-03, EXIG-OBS-04, EXIG-OBS-05, EXIG-OBS-06	
Tous	**Contenu des invites et réponses** non capturé par défaut; toute capture exceptionnelle filtrée, chiffrée et à conservation courte.	EXIG-OBS-07, EXIG-OBS-08, EXIG-OBS-09, EXIG-OBS-10	
Tous **non dérogeable (EXIG-OBS-11)**	**Journal d'audit** distinct des traces, exhaustif pour chaque action à effet et chaque approbation; enregistrement d'intention écrit avant tout relais P2 ou P3; enregistrement à cinq éléments canonisé et signé; chaînage par flux et points de reprise ancrés hors du domaine d'administration de l'audit, vérifiés.	EXIG-OBS-11, EXIG-OBS-12, EXIG-OBS-13	
Tous	**Évaluation** : étages d'évaluation (E1 à E3) franchis et relancés à chaque changement, dépôt d'évaluation seule source des scénarios tirés de la production, jeu de référence versionné comprenant des cas adverses et réussi aux seuils du contrat, évaluations répétées et isolées, échantillonnage de la production planifié, objectifs de niveau de service fixés.	EXIG-EVA-01, EXIG-EVA-02, EXIG-EVA-03, EXIG-EVA-04, EXIG-EVA-05, EXIG-EVA-06	
Tous	**Coûts** : enveloppe appliquée à chaque étape, quotas et plafond mensuel par agent, plus petit modèle suffisant, préfixe d'invite stable, imputation par centre de coûts, coût par tâche réussie comparé au processus sans agent, hypothèses de prix datées; lots asynchrones recommandés (EXIG-FIN-08) et table de conversion des unités SaaS si plateforme SaaS (EXIG-FIN-03).	EXIG-FIN-01, EXIG-FIN-02, EXIG-FIN-03, EXIG-FIN-04, EXIG-FIN-05, EXIG-FIN-06, EXIG-FIN-07, EXIG-FIN-08, EXIG-FIN-09, EXIG-FIN-10	

A.8 Données, vie privée et conformité

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Si renseignements personnels **non dérogeable**	**EFVP** terminée avant le passage en pilote, responsable de la protection des renseignements personnels consulté dès le début du projet, finalités vérifiées avant toute réutilisation.	EXIG-CON-04, EXIG-CON-06	

Applicabilité	Point à vérifier	Exigences	Réponse et preuve
Si traitement hors Québec **non dérogeable**	**Lieux de traitement cartographiés** (modèles, outils, mémoires) avec EFVP et entente écrite pour toute communication hors Québec; routes non couvertes refusées sur les trois chemins.	EXIG-CON-05	
Tous	**Mémoires et traces** : durées de vie fixées, contrôles avant toute écriture en mémoire épisodique ou sémantique, aucun historique brut comme mémoire, magasins isolés, minimums de conservation respectés, demandes de rectification ou de suppression propagées.	EXIG-ARC-22, EXIG-ARC-23, EXIG-ARC-24, EXIG-ARC-25, EXIG-CON-10	
Tous **non dérogeable**	**Régimes applicables** inscrits à la fiche (Loi 25, LPRPDE, BSIF E-23, RIA, RGPD le cas échéant); aucun usage interdit; obligations du fournisseur, si l'entreprise l'est devenue, et du déployeur respectées.	EXIG-CON-11, EXIG-CON-12, EXIG-CON-13, EXIG-CON-14, EXIG-CON-15, EXIG-CON-16, EXIG-CON-17, EXIG-CON-18, EXIG-CON-21	
Tous **non dérogeable (part légale : art. 50 du RIA)**	**Transparence** : divulgation de l'interaction avec un agent et identification des contenus produits; vérification humaine de tout contenu juridique.	EXIG-CON-19, EXIG-CON-20, EXIG-CON-22	
Tous	**Incidents** : procédure en cinq temps connue de l'équipe de garde, registre des incidents de confidentialité, gravité attribuée, gel des preuves volatiles, cumul des régimes de notification, chacun selon son délai.	EXIG-CON-23, EXIG-CON-24, EXIG-CON-25	
Si classe élevée	**Évaluation d'impact unifiée** (EFVP, analyse d'impact algorithmique, analyse d'impact sur les droits fondamentaux au besoin).	EXIG-CON-26	
Si décide ou recommande à l'égard d'une personne	**Volet impact algorithmique** approuvé par le propriétaire métier avant le pilote, quelle que soit la classe.	EXIG-CON-26	
Si acquis d'un fournisseur	**Grille d'évaluation fournisseur** remplie et clauses contractuelles normatives intégrées au contrat, sans clause contraire à l'EXIG-GOV-17.	EXIG-APP-07, EXIG-APP-08, EXIG-APP-09, EXIG-APP-10, EXIG-APP-11, EXIG-APP-12, EXIG-APP-13, EXIG-APP-14, EXIG-APP-15, EXIG-APP-16, EXIG-APP-17	

B Gabarit de fiche d'agent

La fiche d'agent est l'entrée du registre d'entreprise décrite à la section 11.4. Ce gabarit fixe son contenu minimal et l'étape du cycle de vie où chaque champ devient exigible. Il est normatif par son contenu, pas par sa forme, parce que l'EXIG-GOV-07 y renvoie (section 1.4) : tout outil de registre convient s'il conserve ces champs et leur historique.

Règles d'utilisation

- **Ouverture et complétude.** La fiche s'ouvre à l'étape Proposition et se complète au fil du cycle de vie (section 11.5). Elle est complète lorsque tous les champs exigés à l'étape Pilote sont remplis, ce que vérifie le jalon qui clôt l'étape Construction et évaluation; avant cela, l'agent n'obtient aucun jeton d'exécution en production, et un pilote sur données réelles est une mise en production (section 11.5). Un agent déjà en exploitation à l'adoption du cadre reçoit une fiche minimale (champs de l'étape Proposition) sous la mesure transitoire de l'EXIG-GOV-16.
- **Source de vérité.** Les valeurs qui commandent un contrôle (palier d'outil, seuil, plafond, portées, niveau d'autonomie) sont lues par la passerelle dans le registre et le catalogue, jamais dans ce que l'agent déclare de lui-même ni dans les annotations d'un serveur MCP (EXIG-GOV-07, EXIG-AUT-08, section 8.3). Le palier et le seuil d'un outil sont tenus au seul catalogue : la fiche ne peut fixer qu'un seuil plus strict, et la

passerelle signale tout écart de palier entre la fiche et le catalogue comme un incident de réconciliation. La grandeur qu'un seuil mesure est calculée par la passerelle ou fournie par le système visé, jamais déclarée par l'agent (EXIG-AUT-13).

- **Réévaluation.** Tout changement visé par l'EXIG-GOV-12, qui tient seule la liste des déclencheurs, entraîne une réévaluation de la classe de risque et du niveau d'autonomie avant la mise en service. Le niveau d'autonomie fonctionne comme un certificat interne qui se renouvelle à chaque changement de l'agent ou de son environnement, sans l'indépendance du tiers qui délivre le « certificat d'autonomie » de Feng et coll.[83]. S'il y a des RP, l'EFVP est mise à jour, comme le recommande le guide de la CAI lorsqu'un projet change[413].
- **Attestation.** Le parrain atteste périodiquement que l'agent est encore requis et que sa fiche est exacte. Le cadre exige l'attestation au moins tous les 12 mois, et tous les 6 mois pour la classe élevée (EXIG-GOV-13); à titre d'exemple, les bonnes pratiques de Microsoft Entra Agent ID prévoient que le parrain atteste tous les 6 à 12 mois que chaque agent est encore requis[92]. Un agent dont l'attestation est échue doit passer à l'état « suspendu » (EXIG-GOV-09).
- **Contenu exclu.** La fiche ne contient ni secret ni renseignement personnel de clients. Chaque serveur MCP a aussi une fiche au registre, qui reprend les blocs de ce gabarit qui le concernent (identification, propriétaires, données et RP, identité et portées, garde-fous, évaluation, observabilité, cycle de vie, dérogations); ses outils ont en plus leur propre entrée au catalogue (section 6.8, annexe C).

Champs de la fiche

Tableau 63 — Champs de la fiche d'agent et étape où ils deviennent exigibles

Bloc	Champ	Contenu attendu	Exigé dès
Identification	Identifiant, nom, version	Identifiant unique et immuable au registre; nom en langage clair; version sémantique (SemVer)	Proposition
	Type, plateforme et modèles	Agent interne, agent intégré à un logiciel-service ou agent de partenaire; plateforme d'exécution; environnements; modèles utilisés (principaux et de repli) avec leurs versions épinglées; version et empreinte de l'invite système (EXIG-INT-15, EXIG-GOV-12); pour un agent intégré à un logiciel-service, actions qu'il y exécute, mécanisme d'arrêt propre et mécanisme d'approbation du fournisseur (EXIG-ARC-02)	Proposition (modèles et invite : Conception)
	Carte d'agent	URL et empreinte de la carte d'agent signée, si l'agent est invocable par d'autres agents (section 6.6)	Pilote, si applicable
Propriétaires	Propriétaire métier (parrain)	Personne nommée qui répond des effets de l'agent; son unité; son suppléant	Proposition
	Responsable technique et équipe de garde	Personne nommée; équipe joignable pendant les heures d'exploitation déclarées et sa file d'incidents	Conception
	Centre de coûts	Code imputé à chaque trace (section 10.6)	Conception
Finalité	Tâche et valeur attendue	Tâche confiée, en deux phrases; indicateur de valeur; processus de référence sans agent et son coût	Proposition
	Usages exclus	Ce que l'agent ne doit jamais faire, même à la demande d'un mandant	Conception
Mandants et déclencheurs	Invocation	Personnes, rôles ou agents autorisés à l'invoquer; canaux; déclencheurs automatiques (événements, planification)	Conception
Orchestration	Patron	Patron retenu (section 7.2), schéma de ses flux (EXIG-ORC-03) et justification de la configuration la plus simple (avec la comparaison mesurée face à un agent unique, EXIG-ORC-02, et les frontières de contexte ou de sécurité justifiant le découpage, EXIG-ORC-10); protocole retenu pour chaque intégration, justifié par la	Conception

Bloc	Champ	Contenu attendu	Exigé dès
		matrice de sélection (section 6.4); résultat de la revue d'interopérabilité proportionnée (section 6.1); agents appelés; profondeur d'imbrication	
Risque et autonomie	Classe de risque	Faible, modérée ou élevée, avec l'analyse des critères de la section 8.2 et l'approbation obtenue	Proposition
	Niveau d'autonomie	Plafond N0 à N4 approuvé, par qui (personne nommée) et à quelle date, avec la justification du niveau le plus bas qui atteint l'objectif (EXIG-AUT-01); domaine d'exploitation documenté pour N3 et N4; déclencheurs de renouvellement; échéance de réautorisation d'un agent ambiant de niveau N3 ou N4	Conception
	Qualification réglementaire	Régimes applicables (Loi sur le privé ou Loi sur l'accès, LPRPDE, RIA, BSIF, directive fédérale), chacun avec les obligations retenues et l'exigence du cadre qui y répond; sorties utilisées ou non dans l'Union européenne; système à haut risque au sens du RIA ou non; décision fondée exclusivement sur un traitement automatisé (art. 12.1 de la Loi sur le privé) ou non; modèle visé par la ligne directrice E-23 du BSIF, s'il y a lieu	Conception
Outils, agents et événements	Inventaire des dépendances	Pour chaque outil, ressource, invite, agent appelé ou sujet d'événement : référence au catalogue, version épinglée et empreinte (EXIG-INT-15), palier P0 à P3 et seuil tels qu'inscrits au catalogue (la fiche ne fixe qu'un seuil plus strict, EXIG-AUT-13), effet déclaré, clé d'idempotence et mode de vérification pour les outils à effet (EXIG-ORC-22), compensation et son palier (EXIG-ORC-17), étiquette de fiabilité de chaque source de contexte (EXIG-SEC-03), contrat AsyncAPI pour les événements	Conception
Données et RP	Catégories et classification	Catégories de données, classification, présence de RP et de RP sensibles, finalité de chaque usage	Conception
	Localisation et mémoire	Lieu de traitement (province ou pays, et fournisseur) de chaque modèle, serveur MCP, agent délégataire et magasin de mémoire ou de traces; durées de conservation des mémoires, index vectoriels et traces (section 5.5)	Conception
Identité et portées	Identité	Identifiant de charge de travail (p. ex. SPIFFE ID) et type de justificatif (section 9.2)	Pilote
	Autorisations	Mode d'accès (délégation par échange de jetons ou identité propre de l'agent); portées et audiences; durée de vie des jetons	Pilote
Garde-fous	Contrôles actifs	Contrôles d'entrée (contenu non fiable), de sortie (prévention des fuites de données) et d'action (politiques de la passerelle); propriétés réunies parmi contenu non fiable, données sensibles et effet ou communication externe (règle de deux); bac à sable si l'agent exécute du code, avec sa liste d'autorisation réseau; pour un agent de classe élevée exposé à du contenu non fiable, patron de conception retenu contre l'injection (EXIG-SEC-07)	Pilote
Évaluation	Jeu de référence et résultats	Taille du jeu, dont les scénarios adverses; seuils d'acceptation et seuil de réussite maximale de la suite d'attaques automatisées (EXIG-SEC-24); date, version et résultat de la dernière exécution et du dernier exercice d'équipe rouge (EXIG-SEC-23); pour un agent invocable par d'autres agents, échecs de niveau SHOULD de la trousse A2A et échéance de correction (EXIG-A2A-14)	Pilote
Budget et plafonds	Enveloppe	Plafonds par tâche (borne de contexte (en jetons) (EXIG-MEM-01), jetons, coût, appels d'outils, itérations, durée d'exécution active et durée totale); quota de jetons par minute et plafond mensuel, avec la marge déclarée	Pilote

Bloc	Champ	Contenu attendu	Exigé dès
		pour les dépassements en concurrence et le comportement à l'atteinte du plafond (suspension ou modèle de repli); modèles autorisés et modèle de repli, avec son plafond propre; mesure qui justifie tout modèle de raisonnement (EXIG-FIN-05, EXIG-FIN-06)	
Compensation et escalade	Reprise	Compensation de chaque étape à effet et identité de compensation de l'orchestrateur (EXIG-ORC-17); étape pivot; file humaine d'escalade; rôles approbateurs et règles d'approbation; mode dégradé	Pilote
Observabilité	Traçage et audit	Nom de service; version épinglée et version réellement émise des conventions OpenTelemetry GenAI (réglage de `OTEL_SEMCONV_STABILITY_OPT_IN`); capture du contenu (désactivée par défaut); emplacement du journal d'audit et, pour une décision visée par l'article 12.1, du dossier de décision (EXIG-OBS-11); fenêtre de conservation des événements d'entrée (EXIG-EVT-10); objectifs de niveau de service	Pilote
Conformité	Évaluations d'impact	Référence et date de l'EFVP, y compris celle exigée par l'article 17 en cas de communication hors du Québec; consultation du responsable de la protection des RP; évaluation d'impact unifiée et analyse d'impact sur les droits fondamentaux (RIA, art. 27) lorsqu'elle est exigée (section 12.9)	Pilote, si applicable
	Transparence	Mode d'information des personnes; procédure de révision humaine pour les décisions visées par l'article 12.1	Pilote, si applicable
Cycle de vie	État et revues	État (proposé, conception, construction, pilote, production, suspendu, retiré), énumération commune au registre et au catalogue (annexe C, C.2); dates de mise en production, de dernière attestation et de prochaine revue; historique des versions	Proposition
Dérogations	Dérogations en vigueur	Identifiant, exigence visée, mesures compensatoires, échéance et approbateur (section 11.6)	Dès qu'une dérogation existe

Exemple de fiche lisible par machine

L'exemple suivant décrit un agent fictif de classe modérée, plafonné à N3. Les noms de champs sont un choix du cadre; seules comptent leur présence et leur cohérence avec le gabarit. Les personnes y sont désignées par un identifiant fictif, et les empreintes sont abrégées par « … ».

Fiche d'agent au registre (JSON, extrait)

```
{
  "agent_id": "agt-fin-rapprochement",
  "name": "Agent de rapprochement des factures fournisseurs",
  "version": "2.3.0",
  "lifecycle_state": "production",
  "owners": {
    "business_sponsor": "emp-004417",
    "technical_lead": "emp-007762",
    "on_call_team": "garde-finances",
    "cost_center": "CC-4120"
  },
  "purpose": "Apparier factures, bons de commande et réceptions; préparer les paiements.",
  "excluded_uses": ["modifier les coordonnées bancaires d'un fournisseur"],
  "principals": ["role:analyste-comptes-fournisseurs", "agent:agt-fin-orchestrateur"],
  "triggers": ["schedule:rapprochement-nocturne"],
  "orchestration_pattern": "agent-unique-outille",
  "risk_class": "moderee",
  "autonomy": {
    "ceiling": "N3",
    "requested_by": "emp-004417",
```

```
    "approved_by": "emp-002318",
    "approved_on": "2027-03-15",
    "odd_ref": "ODD-FIN-007",
    "renew_on": "EXIG-GOV-12"
  },
  "regulatory": {"eu_ai_act_high_risk": false, "automated_decision_art_12_1": false},
  "tools": [
    {"ref": "erp.factures.lire@1.4.0", "digest": "sha256:9f2c41d0…", "tier": "P1"},
    {"ref": "erp.factures.apparier@2.0.1", "digest": "sha256:51ab07e3…", "tier": "P2",
     "compensation": "erp.factures.desapparier@2.0.1", "idempotency_key": true},
    {"ref": "tresorerie.paiements.emettre@1.1.0", "digest": "sha256:c07d9b12…", "tier": "P3",
     "approval": "signed_out_of_band", "idempotency_key": true, "pivot": true, "compensation": null}
  ],
  "data": {"classification": "confidentiel", "personal_information": true,
           "processing_locations": ["Québec"]},
  "identity": {"workload_id": "spiffe://ent.ca/agt-fin-rapprochement",
               "access_modes": {"principals": "token_exchange_rfc8693", "triggers": "client_credentials"},
               "token_ttl_s": 900},
  "budget_per_task": {"context_bound_tokens": 32000, "max_tokens": 50000, "max_cost_cad": 0.75,
                      "max_tool_calls": 15, "timeout_s": 60, "max_wall_clock_s": 28800,
                      "max_iterations": 8},
  "evaluation": {"reference_set": 120, "adversarial_cases": 25,
                 "last_run": "2027-03-10", "result": "pass"},
  "observability": {"service_name": "agt-fin-rapprochement",
                    "genai_semconv_reference": "1.41.0", "genai_semconv_emitted": "1.41.0",
                    "otel_semconv_stability_opt_in": "gen_ai_latest_experimental",
                    "content_capture": false},
  "compliance": {"efvp_ref": "EFVP-2027-014", "efvp_date": "2027-02-28"},
  "next_review": "2027-09-15",
  "exceptions": []
}
```

Lecture : l'agent apparie seul les factures jusqu'à 5 000 $ inclusivement, seuil inscrit au catalogue pour l'outil d'appariement, que la fiche ne reprend pas; au-delà, le contrôle calculé (EXIG-AUT-10) exige une approbation. Les paliers recopiés dans la fiche servent à la lecture : le catalogue fait foi. L'émission d'un paiement, de palier P3, exige toujours une approbation signée hors bande; c'est l'étape pivot, sans compensation, et elle porte une clé d'idempotence vérifiée par la trésorerie. Les tâches lancées par une personne ou par l'orchestrateur passent par l'échange de jetons, et le rapprochement nocturne, déclenché par planification, emploie l'identité propre de l'agent (section 9.3). `renew_on` renvoie à l'EXIG-GOV-12 au lieu d'en recopier la liste. Le niveau N3 est demandé par le parrain et approuvé par une autre personne. Les conventions OpenTelemetry sont consignées par version de référence, version émise et réglage d'adhésion (EXIG-OBS-01). Les valeurs de l'enveloppe budgétaire sont illustratives et se calibrent par mesure (section 10.6).

C Exemples de contrats

Cette annexe donne huit exemples complets de contrats et d'objets d'échange, conformes, lorsqu'elles existent, aux spécifications en vigueur au 27 octobre 2026 et, dans tous les cas, aux exigences du cadre. Ces exemples sont informatifs (section 1.4). Leur structure devient normative là où une exigence y renvoie expressément : C.1 et C.2 par l'EXIG-ORC-22 et l'EXIG-MCP-20, C.6 par l'EXIG-AUT-12, C.8 par l'EXIG-OBS-12; un contrat réel reprend alors leur structure et leurs champs, avec ses propres noms, schémas et seuils. Chaque exemple est suivi d'une lecture qui le rattache aux exigences qu'il met en œuvre.

Conventions des exemples

- **Valeurs fictives.** Les noms, domaines (`ent.ca`), identifiants et montants sont fictifs. Un seul domaine fictif, `ent.ca`, sert partout, et son inverse, `ca.ent`, préfixe les types d'événements. Les montants des

arguments d'outil sont des entiers en cents, ce qui ne laisse aucune place à une lecture divergente des nombres (EXIG-AUT-12).

- **Formats normalisés et formats internes.** Les exemples C.1, C.3, C.4 et C.5 n'emploient que des champs définis par leur spécification ou par les mécanismes d'extension qu'elle prévoit. Les exemples C.2, C.6, C.7 et C.8 sont des formats internes : comme à l'annexe B, les noms de champs sont un choix du cadre, et seules comptent leur présence et leur cohérence.
- **Empreintes vérifiables.** Les empreintes `definition_digest`, `idempotency_key`, h (reprise dans `action_sha256` et `empreinte_approbation`) et `arguments_sha256` sont de véritables condensés SHA-256, calculés sur les valeurs montrées (forme canonique RFC 8785 pour les objets JSON) : on peut les recalculer. La description de C.1, coupée pour la lecture, se canonise en une seule ligne, chaque coupure valant une espace; la clé d'idempotence est l'empreinte de la canonisation du tableau `["idem-v1", task_id, step_id]` (section 7.6), et h celle de l'objet {outil, version, definition_digest, agent_id, task_id, arguments} (section 8.5). Les valeurs qui dépendent d'objets non montrés ou abrégés (empreinte de certificat, enregistrement précédent, empreinte de l'invite système, `empreinte` de l'enregistrement C.8) sont fictives, et les signatures, qu'on ne peut pas reproduire sans la clé privée, sont abrégées par « … ».
- **Portées OAuth.** Les portées suivent une seule grammaire, celle de l'extrait de la section 9.3 : `domaine:action`, l'action en anglais (`finance:read`, `approvisionnement:write`, `risque-credit:invoke`, `risque-credit:analyze`).
- **Scénario commun.** Les exemples C.1, C.2, C.6, C.7 et C.8 suivent une même tâche : l'agent `agt-achats-indirects`, de classe de risque modérée et plafonné à N3, crée un bon de commande de 12 480 $, soit au-delà du seuil d'approbation de 5 000 $ par tâche fixé au catalogue pour cet outil et mesuré sur le total calculé des lignes (tableau 64).

Tableau 64 — Exemples de contrats, références et exigences illustrées

Exemple	Référence	Exigences et sections illustrées
C.1 Outil MCP	MCP 2026-07-28; JSON Schema 2020-12	EXIG-MCP-07, EXIG-MCP-14, EXIG-MCP-18; EXIG-ORC-21
C.2 Entrée de catalogue	Format interne du cadre	EXIG-AUT-08, EXIG-AUT-13, EXIG-MCP-14, EXIG-MCP-20, EXIG-ORC-17, EXIG-ORC-22; section 6.8
C.3 Carte d'agent	A2A 1.0 (`a2a.proto`); JWS (RFC 7515); RFC 8785	EXIG-A2A-02 à EXIG-A2A-06, EXIG-A2A-10
C.4 Événement	CloudEvents 1.0 (1.0.2) et extensions documentées; W3C Trace Context	EXIG-EVT-02, EXIG-EVT-04 à EXIG-EVT-06, EXIG-EVT-09, EXIG-EVT-06
C.5 Jeton délégué	RFC 9068, RFC 8693, RFC 8705	EXIG-IAM-08, EXIG-IAM-10, EXIG-IAM-11, EXIG-IAM-14, EXIG-IAM-15
C.6 Jeton d'approbation humaine	Format interne; RFC 8785, RFC 9396, CIBA	EXIG-AUT-09, EXIG-AUT-12 à EXIG-AUT-15, EXIG-AUT-19
C.7 Enveloppe budgétaire	Format interne du cadre	EXIG-ORC-26, EXIG-FIN-04; section 10.6
C.8 Enregistrement d'audit	Format interne; RFC 8785	EXIG-OBS-11 à EXIG-OBS-13, EXIG-AUT-10, EXIG-AUT-15, EXIG-IAM-21; section 10.3

C.1 Outil MCP

L'exemple montre la définition d'un outil d'écriture orienté tâche, telle qu'un serveur MCP la renvoie dans `tools/list` (section 6.5).

Définition de l'outil approvisionnement_creer_bon_commande (MCP 2026-07-28)

```
{
  "name": "approvisionnement_creer_bon_commande",
  "title": "Créer un bon de commande (ERP)",
```

```
  "description": "Crée dans l'ERP un bon de commande, à l'état brouillon ou soumis, pour un fournisseur
homologué et un centre de coûts valide. Le statut soumis transmet le bon au circuit d'approbation interne
de l'ERP,
sans envoi au fournisseur. Le serveur calcule le montant total à partir des lignes; les prix sont en cents.
Une relance avec la même clé d'idempotence ne crée pas de second bon. Ne modifie ni n'annule un bon
existant.",
  "inputSchema": {
    "type": "object",
    "properties": {
      "idempotency_key": { "type": "string", "pattern": "^[0-9a-f]{64}$" },
      "fournisseur_id": { "type": "string", "pattern": "^SUP-[0-9]{6}$" },
      "centre_cout": { "type": "string", "pattern": "^CC-[0-9]{4}$", "x-mcp-header": "Cost-Center" },
      "statut_demande": { "type": "string", "enum": ["brouillon", "soumis"], "default": "brouillon" },
      "lignes": {
        "type": "array",
        "minItems": 1,
        "maxItems": 100,
        "items": {
          "type": "object",
          "properties": {
            "sku": { "type": "string", "pattern": "^PRD-[0-9]{5}$" },
            "quantite": { "type": "integer", "minimum": 1, "maximum": 100000 },
            "prix_unitaire_cents": { "type": "integer", "minimum": 0, "maximum": 100000000 }
          },
          "required": ["sku", "quantite", "prix_unitaire_cents"],
          "additionalProperties": false
        }
      }
    },
    "required": ["idempotency_key", "fournisseur_id", "centre_cout", "lignes"],
    "additionalProperties": false
  },
  "outputSchema": {
    "type": "object",
    "properties": {
      "bon_commande_id": { "type": "string", "pattern": "^BC-[0-9]{4}-[0-9]{6}$" },
      "statut": { "type": "string", "enum": ["brouillon", "soumis"] },
      "montant_total_cents": { "type": "integer", "minimum": 0 },
      "rejeu": { "type": "boolean", "description": "Vrai si la clé était déjà traitée." }
    },
    "required": ["bon_commande_id", "statut", "montant_total_cents", "rejeu"],
    "additionalProperties": false
  },
  "annotations": {
    "readOnlyHint": false,
    "destructiveHint": false,
    "idempotentHint": true,
    "openWorldHint": false
  }
}
```

Lecture : la définition n'emploie que des champs du schéma MCP 2026-07-28; ses schémas suivent JSON Schema 2020-12, dialecte par défaut de la spécification, et `additionalProperties: false` ferme le contrat[162, 197]. Le motif du champ `idempotency_key` correspond à la dérivation de la section 7.6. Le montant total n'est pas un argument : le serveur le calcule à partir des lignes et le renvoie, et la passerelle calcule la même grandeur pour le seuil (EXIG-AUT-13); les prix sont des entiers en cents, bornés par le schéma. Seul `centre_cout` porte `x-mcp-header` : le client recopie sa valeur dans l'en-tête `Mcp-Param-Cost-Center`, ce qui convient à une donnée non sensible (EXIG-MCP-18). Les annotations, conformes au schéma, ne décident de rien : elles doivent seulement concorder avec le palier inscrit au catalogue (EXIG-MCP-14). L'outil renvoie un `structuredContent` conforme à `outputSchema`, accompagné du même JSON dans un bloc texte, et signale une erreur métier par un résultat marqué `isError: true` (EXIG-MCP-07). La compensation de l'outil et son palier figurent à son entrée de catalogue (C.2), la définition C.1 ne portant que des champs du schéma MCP.

C.2 Entrée de catalogue de l'outil

L'exemple montre où vit la gouvernance de l'outil C.1 : dans le catalogue d'entreprise, et non dans le serveur (section 6.8).

Entrée du catalogue d'entreprise pour l'outil C.1 (format interne)

```
{
  "ref": "mcp-approvisionnement/approvisionnement_creer_bon_commande@1.4.0",
  "tool_name": "approvisionnement_creer_bon_commande",
  "contract_version": "1.4.0",
  "definition_digest": "sha256:e8c1ccd755dd196d40fb358447998a964dd643fa03614e9e8fbbfa66abf643b6",
  "server": {
    "id": "mcp-approvisionnement",
    "endpoint": "https://passerelle-agents.ent.ca/mcp/approvisionnement",
    "mcp_revision": "2026-07-28",
    "extensions_allowed": []
  },
  "lifecycle_state": "production",
  "tier": "P2",
  "approval_thresholds": [
    { "measure": "sum(lignes[].quantite * lignes[].prix_unitaire_cents)", "computed_by": "gateway",
      "unit": "cents_cad", "scope": "task", "window": "task",
      "max_without_approval": 500000, "inclusive": true },
    { "measure": "sum(lignes[].quantite * lignes[].prix_unitaire_cents)", "computed_by": "gateway",
      "unit": "cents_cad", "scope": "counterparty:fournisseur_id", "window_s": 86400,
      "max_without_approval": 2000000, "inclusive": true }
  ],
  "compensation": { "ref": "mcp-approvisionnement/approvisionnement_annuler_bon_commande@1.2.0", "tier":
"P2" },
  "idempotency": { "argument": "idempotency_key", "mode": "native", "checked_by_server": true,
                   "on_conflict": "reject", "on_in_progress": "refuse", "on_duplicate": "replay_result",
                   "key_retention_s": 864000 },
  "oauth_scope": "approvisionnement:write",
  "header_projection": { "centre_cout": "Mcp-Param-Cost-Center" },
  "data_classification_max": "confidentiel",
  "personal_information": false,
  "owner": "Direction Approvisionnement",
  "on_call_team": "garde-plateforme-erp",
  "known_consumers": ["agt-achats-indirects"],
  "reviewed_by": ["responsable-outil", "securite"],
  "approved_on": "2026-10-06",
  "next_review": "2027-04-06"
}
```

Lecture : cette entrée porte le palier, les seuils, la compensation et son palier, la portée, la direction responsable et l'équipe de garde de l'outil, attribués après revue par son responsable et par la sécurité; la passerelle les lit ici, jamais dans les annotations (EXIG-AUT-08, EXIG-MCP-14). `definition_digest` est le SHA-256 de la définition C.1 canonisée selon la RFC 8785 : à chaque `tools/list`, la passerelle recalcule l'empreinte et retire l'outil au moindre écart, description comprise, jusqu'à une nouvelle approbation (EXIG-MCP-20) [221, 236]. Chaque seuil mesure une grandeur que la passerelle calcule à partir des lignes canonisées, jamais un montant déclaré par l'agent, et déclare son unité, sa portée et sa fenêtre; la borne est inclusive, et les compteurs de la tâche et du fournisseur sont tenus par la passerelle (EXIG-AUT-13). Avec ce palier P2 et ces seuils, un agent de classe modérée déclaré N3 peut créer seul des bons totalisant 5 000 $ ou moins dans une tâche, et 20 000 $ ou moins par fournisseur sur 24 heures; au-delà, le contrôle calculé (EXIG-AUT-10) impose le jeton d'approbation de l'exemple C.6. La compensation est elle-même un outil inscrit avec son palier (EXIG-ORC-17). L'idempotence est native, vérifiée par l'ERP; l'entrée déclare les trois comportements de l'EXIG-ORC-22 et la durée de conservation des clés, qui couvre la durée de vie maximale de la tâche durable, la fenêtre de reprise et le délai de réconciliation, alors que l'annotation `idempotentHint` n'est qu'un indice. `lifecycle_state` reprend l'énumération du tableau 63.

C.3 Carte d’agent A2A

L’exemple montre la carte de référence, inscrite au catalogue et servie par la passerelle, de l’agent spécialiste du scénario de délégation de la section 6.6.

Carte d’agent A2A 1.0 signée de l’agent d’évaluation du risque de crédit

```
{
  "name": "Agent d'évaluation du risque de crédit",
  "description": "Analyse un dossier de crédit commercial selon la politique CR-12 et recommande une décision
motivée. N'accorde ni ne refuse aucun crédit.",
  "supportedInterfaces": [
    {
      "url": "https://passerelle-agents.ent.ca/a2a/risque-credit",
      "protocolBinding": "JSONRPC",
      "protocolVersion": "1.0"
    }
  ],
  "provider": {
    "organization": "Direction Gestion des risques",
    "url": "https://intranet.ent.ca/risque-credit"
  },
  "version": "2.3.0",
  "capabilities": {
    "streaming": true,
    "pushNotifications": true,
    "extendedAgentCard": true,
    "extensions": [
      {
        "uri": "https://ent.ca/a2a/extensions/gouvernance/v1",
        "description": "Copie en lecture seule de données du registre : niveau d'autonomie et classe de
risque.",
        "required": false,
        "params": { "niveau_autonomie": "N2", "classe_risque": "elevee" }
      }
    ]
  },
  "securitySchemes": {
    "idp-entreprise": {
      "openIdConnectSecurityScheme": { "openIdConnectUrl": "https://idp.ent.ca/.well-known/openid-
configuration" }
    }
  },
  "securityRequirements": [{ "schemes": { "idp-entreprise": { "list": ["risque-credit:invoke"] } } }],
  "defaultInputModes": ["text/plain", "application/json"],
  "defaultOutputModes": ["application/json", "text/markdown"],
  "skills": [
    {
      "id": "analyse-dossier-commercial",
      "name": "Analyse prudentielle d'un dossier de crédit commercial",
      "description": "Évalue la solvabilité d'une entreprise cliente, vérifie les garanties et produit une
recommandation motivée avec les ratios calculés.",
      "tags": ["credit", "risque", "conformite"],
      "examples": ["Analyser le dossier 8841 selon la politique CR-12"],
      "securityRequirements": [{ "schemes": { "idp-entreprise": { "list": ["risque-credit:analyze"] } } }]
    }
  ],
  "signatures": [
    {
      "protected":
"eyJhbGciOiJFUzI1NiIsInR5cCI6IkpPU0UiLCJraWQiOiJjYXJ0ZXMtYWdlbnRzLTIwMjYtMTAiLCJqa3UiOiJodHRwczovL2NsZXMuZW50
LmNhL2EyYS9qd2tzLmpzb24ifQ",
      "signature": "Wm3k…"
    }
  ]
}
```

Lecture : la carte contient les huit champs obligatoires d'A2A 1.0, ses adresses sont celles de la passerelle d'agents, et la compétence porte sa propre portée OAuth dans `securityRequirements` (EXIG-A2A-02, EXIG-A2A-10)[68, 192]. La signature est un JWS calculé sur la carte canonisée selon la RFC 8785, champ `signatures` exclu et règles de présence des champs de la spécification (section 8.4 de la spécification A2A 1.0) appliquées; son en-tête protégé, encodé en base64url, désigne le type JOSE (`typ`), l'algorithme ES256, la clé (`kid`) et le jeu de clés publiques de l'entreprise (`jku`), et tout client vérifie cette signature avant de se fier à la carte (EXIG-A2A-03). La clé se résout par `kid` dans le jeu de clés épinglé au catalogue, et `jku` n'est suivi que s'il concorde exactement avec l'URL inscrite pour cet émetteur, ce qui écarte la falsification de requêtes côté serveur contre laquelle la RFC 8725 met en garde (section 3.10). Le niveau d'autonomie et la classe de risque ne forment pas un champ de premier niveau : ils sont déclarés comme extension de données facultative, qui ne figure que dans une carte servie aux seuls clients authentifiés (carte de référence d'un agent interne, ou carte étendue d'un agent exposé, EXIG-A2A-06), dont l'URI versionnée figure au registre des extensions approuvées, et la fiche du registre fait foi en cas d'écart (EXIG-A2A-05)[238]. `extendedAgentCard` annonce une carte étendue, servie après authentification, qui ajoute les compétences réservées aux appelants internes (EXIG-A2A-06), et l'`ETag` servi avec la carte, dérivé du hachage de la représentation servie, signatures comprises, permet de revalider les copies en cache, alors que `version`, en SemVer, signale la compatibilité (EXIG-A2A-04). L'agent étant de classe élevée, ses appelants présentent un jeton lié par mTLS ou DPoP (EXIG-IAM-14); l'exemple, réduit au schéma OpenID Connect, ne montre pas le schéma mTLS qu'un contrat réel y combinerait dans `securityRequirements`.

C.4 Événement CloudEvents

L'exemple montre la première alerte d'une chorégraphie, publiée par un agent détecteur sur le bus d'événements (section 6.7).

Événement CloudEvents 1.0 avec les extensions exigées par le cadre (représentation JSON)

```
{
  "specversion": "1.0",
  "id": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d",
  "source": "https://agents.ent.ca/logistique/detecteur-rupture-stock",
  "type": "ca.ent.logistique.alerte.rupture.v1",
  "subject": "MTL-02/PRD-99210",
  "time": "2026-10-27T09:15:00Z",
  "datacontenttype": "application/json",
  "dataschema": "https://catalogue.ent.ca/schemas/logistique/alerte-rupture/1.0.0",
  "traceparent": "00-4bf92f3577b34da6a3ce929d0e0e4736-00f067aa0ba902b7-01",
  "authtype": "service_account",
  "authid": "ordonnanceur-inventaire-quotidien",
  "dataclassification": "internal",
  "partitionkey": "MTL-02/PRD-99210",
  "xagentorigin": "agt-detecteur-rupture@1.3.0",
  "xagenthopcount": 1,
  "xagentmaxhops": 4,
  "xcostcenter": "CC-8100",
  "data": {
    "entrepot_id": "MTL-02",
    "sku": "PRD-99210",
    "stock_actuel": 12,
    "seuil_critique": 50,
    "horizon_epuisement_heures": 18
  }
}
```

Lecture : l'événement porte les quatre attributs requis par CloudEvents, les attributs `time`, `datacontenttype` et `dataschema` exigés par le cadre, et un `type` versionné en domaine inversé (EXIG-EVT-02)[248]. `traceparent` (Distributed Tracing), `authtype` et `authid` (Auth Context), `dataclassification` (Data Classification) et

`partitionkey` (Partitioning) sont des extensions documentées, alors que `xagentorigin`, `xagenthopcount`, `xagentmaxhops` et `xcostcenter` sont propres au cadre (EXIG-EVT-04); aucun attribut ne contient de renseignement personnel (EXIG-EVT-05)[187, 252, 255]. Quand un agent qui réagit à cette alerte publie un nouvel événement, l'intercepteur de publication pose `xagenthopcount` à 2 et recopie `xagentorigin` et `xagentmaxhops`, sans se fier aux valeurs du producteur (EXIG-EVT-06); un événement dont le compteur atteint 4 n'est pas traité et part en file de lettres mortes (EXIG-EVT-06). Le compteur borne la profondeur d'une chaîne, non sa diffusion : le courtier applique aussi un plafond de largeur, en événements par trace (EXIG-EVT-06). La correspondance entre l'échelle de classification interne (C.2) et les valeurs de `dataclassification` est inscrite au catalogue. Sur Kafka, le mode binaire retenu par défaut place les attributs (sauf `datacontenttype`, porté par l'en-tête `content-type`) dans des en-têtes préfixés `ce_` et `data` dans la valeur; une fois le « Key Mapper » de la liaison activé (mécanisme facultatif), `partitionkey` est recopié dans la clé du message et, comme Kafka écrit les messages de même clé dans la même partition et en conserve l'ordre, les alertes d'un même article dans un même entrepôt restent dans l'ordre, pourvu que le nombre de partitions soit figé au contrat et que le producteur soit idempotent ou n'ait qu'une requête en vol (EXIG-EVT-09)[250, 468].

C.5 Jeton délégué

L'exemple complète l'extrait de la section 9.3 : les deux jetons qui portent, au nom d'Alice, l'appel de l'agent d'analyse des dépenses, appelé par l'orchestrateur, vers le serveur MCP des finances. La passerelle d'agents termine TLS : l'agent lui présente le jeton 1; elle le vérifie, puis obtient par échange le jeton 2, qu'elle présente au serveur (section 6.5).

Jetons délégués après deux sauts, décodés (signatures omises)

```
Jeton 1, présenté par l'agent à la passerelle
En-tête
{ "typ": "at+jwt", "alg": "ES256", "kid": "idp-2026-10" }
Charge utile
{
  "iss": "https://idp.ent.ca",
  "sub": "alice",
  "aud": "https://passerelle-agents.ent.ca",
  "client_id": "agent-analyse-depenses",
  "scope": "finance:read",
  "authorization_details": [{ "type": "lecture_depenses", "periode": "2026-T3" }],
  "act": {
    "sub": "spiffe://ent.ca/agent-analyse-depenses",
    "act": { "sub": "spiffe://ent.ca/agent-orch" }
  },
  "cnf": { "x5t#S256": "vzF5VHuU_5wCN7LdQZOXTK3y7aNQCqM5M-yosaTb6aw" },
  "iat": 1793084700,
  "exp": 1793085600,
  "jti": "9f1c2d7e-5a41-4c3b-8e06-b2f94a1d7c55"
}
Jeton 2, obtenu par la passerelle et présenté au serveur MCP des finances (même en-tête)
Charge utile
{
  "iss": "https://idp.ent.ca",
  "sub": "alice",
  "aud": "https://mcp-finance.ent.ca",
  "client_id": "passerelle-agents",
  "scope": "finance:read",
  "authorization_details": [{ "type": "lecture_depenses", "periode": "2026-T3" }],
  "act": {
    "sub": "spiffe://ent.ca/agent-analyse-depenses",
    "act": { "sub": "spiffe://ent.ca/agent-orch" }
  },
  "cnf": { "x5t#S256": "q8Lr2Wd0cJmE4sTnV7yHbA1fKpXzG3uN9oRiD5eC6wM" },
```

```
  "iat": 1793084712,
  "exp": 1793085600,
  "jti": "3b7e90a1-6c52-4d8e-9a17-c4e05b2f8d66"
}
```

Lecture : les deux jetons suivent le profil JWT de la RFC 9068, avec l'en-tête `typ` `at+jwt` et les revendications `iss`, `exp`, `aud`, `sub`, `client_id`, `iat` et `jti`[72]. Alice reste le sujet des deux; l'`act` externe désigne l'acteur courant, l'agent d'analyse des dépenses, et l'`act` imbriqué l'orchestrateur, acteur antérieur que le serveur consigne sans s'en servir pour décider (EXIG-IAM-08, EXIG-IAM-11)[70]. Le jeton 1 a pour audience la passerelle, et son `cnf` le lie à l'empreinte du certificat X.509-SVID de l'agent : la passerelle vérifie cette liaison sur la connexion mTLS de l'agent (EXIG-IAM-14)[328]. Le jeton 2, que la passerelle obtient par échange, la désigne comme client et lui est lié; l'échange n'ajoute aucun niveau d'`act`, et le serveur n'accepte que la passerelle, par mTLS. Son expiration ne dépasse pas celle du jeton 1 : aucun échange ne prolonge la délégation (EXIG-IAM-08). L'audience unique, la portée réduite à `finance:read`, la portée de la tâche portée par `authorization_details` (dépenses du troisième trimestre) et la durée de vie de 900 secondes appliquent les exigences EXIG-IAM-10, EXIG-IAM-11 et EXIG-IAM-15, et le serveur de ressources applique en outre les droits d'Alice d'après `sub`. Volé, aucun des deux jetons ne sert sans la clé privée de son titulaire.

C.6 Jeton d'approbation humaine

L'exemple montre l'action soumise à l'approbateur, le calcul de son empreinte et le jeton signé qui en résulte (section 8.5).

Action soumise, empreinte h et jeton d'approbation décodé (signature omise)

```
Objet haché (canonisé selon la RFC 8785, présenté coupé)
  outil      : mcp-approvisionnement/approvisionnement_creer_bon_commande
  version    : 1.4.0
  definition : sha256:e8c1ccd755dd196d40fb358447998a964dd643fa03614e9e8fbbfa66abf643b6
  agent_id   : agt-achats-indirects@1.2.0
  task_id    : tache-7f3c2a
  arguments  : {"centre_cout":"CC-4410","fournisseur_id":"SUP-004512",
                "idempotency_key":"80351869ca990c86c8c6a314a7ac23d80b509a03f9a11dd173d2f1112c10eca7",
                "lignes":[{"prix_unitaire_cents":24960,"quantite":40,"sku":"PRD-10442"},
                          {"prix_unitaire_cents":20800,"quantite":12,"sku":"PRD-20817"}],
                "statut_demande":"soumis"}
  h          : 92be40835a73023d117ebb4965da82dfa05e2e6d647d0919d53461289bbc6e81
  grandeur   : 1248000 cents, somme des lignes calculée par la passerelle (seuil de la tâche : 500000)
Jeton d'approbation 1 (premier approbateur)
En-tête
{ "typ": "approbation+jwt", "alg": "ES256", "kid": "approbation-2026-10" }
Charge utile
{
  "iss": "https://approbation.ent.ca",
  "aud": "https://passerelle-agents.ent.ca",
  "sub": "apb-5e19c2",
  "approbateur_role": "tiers",
  "iat": 1793093040,
  "exp": 1793093940,
  "jti": "c2f7a1d4-8e3b-4f6a-b0d9-5a1e7c3f9b28",
  "task_id": "tache-7f3c2a",
  "agent_id": "agt-achats-indirects@1.2.0",
  "action_sha256": "92be40835a73023d117ebb4965da82dfa05e2e6d647d0919d53461289bbc6e81",
  "authorization_details": [
    {
      "type": "https://ent.ca/types/action-agent",
      "locations": ["https://passerelle-agents.ent.ca/mcp/approvisionnement"],
      "actions": ["tools/call"],
      "identifier": "mcp-approvisionnement/approvisionnement_creer_bon_commande@1.4.0",
      "fournisseur_id": "SUP-004512",
```

```
      "centre_cout": "CC-4410",
      "statut_demande": "soumis",
      "lignes": [{ "sku": "PRD-10442", "quantite": 40, "prix_unitaire_cents": 24960 },
                 { "sku": "PRD-20817", "quantite": 12, "prix_unitaire_cents": 20800 }],
      "grandeur_seuil": { "valeur": 1248000, "unite": "cents_cad", "portee": "task" }
    }
  ]
}
Jeton d'approbation 2 (second approbateur distinct, même action_sha256)
En-tête
{ "typ": "approbation+jwt", "alg": "ES256", "kid": "approbation-2026-10" }
Charge utile
{
  "iss": "https://approbation.ent.ca",
  "aud": "https://passerelle-agents.ent.ca",
  "sub": "apb-91d4e8",
  "approbateur_role": "tiers",
  "iat": 1793093095,
  "exp": 1793093940,
  "jti": "7d4e9b12-3a6c-4e8f-9c01-8b2d6f4a3e19",
  "task_id": "tache-7f3c2a",
  "agent_id": "agt-achats-indirects@1.2.0",
  "action_sha256": "92be40835a73023d117ebb4965da82dfa05e2e6d647d0919d53461289bbc6e81",
  "authorization_details": [
    {
      "type": "https://ent.ca/types/action-agent",
      "locations": ["https://passerelle-agents.ent.ca/mcp/approvisionnement"],
      "actions": ["tools/call"],
      "identifier": "mcp-approvisionnement/approvisionnement_creer_bon_commande@1.4.0",
      "fournisseur_id": "SUP-004512",
      "centre_cout": "CC-4410",
      "statut_demande": "soumis",
      "lignes": [{ "sku": "PRD-10442", "quantite": 40, "prix_unitaire_cents": 24960 },
                 { "sku": "PRD-20817", "quantite": 12, "prix_unitaire_cents": 20800 }],
      "grandeur_seuil": { "valeur": 1248000, "unite": "cents_cad", "portee": "task" }
    }
  ]
}
```

Lecture : h est le SHA-256 de la canonisation selon la RFC 8785 de l'objet {outil, version, definition_digest, agent_id, task_id, arguments}, où l'outil est désigné par son identifiant pleinement qualifié (serveur et nom) et les arguments incluent la clé d'idempotence (section 8.5)[236]; la canonisation trie les clés, et les montants, entiers en cents, ne laissent aucune place à une lecture divergente des nombres. La passerelle rejette tout argument non conforme à I-JSON et transmet au serveur exactement la forme hachée (EXIG-AUT-12). Le jeton contient le minimum exigé par l'EXIG-AUT-12 : l'émetteur et l'audience, l'empreinte (`action_sha256`), l'approbateur sous pseudonyme stable (`sub`) et son rôle (tiers, et non le mandant), la tâche, l'agent, une expiration à 15 minutes et son identifiant (`jti`). `authorization_details` et l'écran d'approbation sont produits par la passerelle à partir des arguments canonisés, avec la grandeur calculée du seuil, jamais d'un texte de l'agent (EXIG-AUT-19); leur emploi dans un jeton d'approbation est un profil du cadre, la RFC 9396 ne définissant cette revendication que pour les jetons d'accès[312]. Un `typ` distinct de `at+jwt`, choix du cadre, empêche de faire passer ce jeton pour un jeton d'accès, ou l'inverse. Le jeton est remis à la passerelle, qui le conserve et ne le transmet ni à l'agent ni à son modèle; elle vérifie la signature, l'émetteur, l'audience, l'expiration, la concordance de l'agent et de la tâche avec l'appelant authentifié et le nombre d'approbateurs qu'exige le contrôle calculé, puis recalcule h sur l'appel reçu et refuse tout écart. Le jeton couvre une seule opération : un réessai de la même opération avant l'expiration est relayé, et l'ERP le déduplique par la clé. Conformément à la section 6.6 et à l'EXIG-AUT-15, ce bon de commande de 12 480 $ (> 5 000 $) réunit deux approbations humaines et deux jetons signés provenant d'approbateurs distincts (`apb-5e19c2` et `apb-91d4e8`, tous deux distincts du mandant), liés au même `action_sha256` (h). La demande porte aussi

l'empreinte de la compensation déclarée, approuvée avec l'étape (EXIG-AUT-12), que l'exemple ne montre pas. Ici, l'approbation est obtenue hors bande, par CIBA sur l'appareil de l'approbatrice (EXIG-AUT-09, EXIG-AUT-14), et seul un tel jeton vaut approbation, jamais un acquiescement dans la conversation (EXIG-AUT-13)[310].

C.7 Enveloppe budgétaire de tâche

L'exemple montre l'enveloppe attribuée à la tâche du scénario, telle que la passerelle de modèles et l'orchestrateur la tiennent à jour (section 10.6).

Enveloppe budgétaire de la tâche tache-7f3c2a, état à 9 h 25 UTC (format interne)

```
{
  "task_id": "tache-7f3c2a",
  "agent_id": "agt-achats-indirects@1.2.0",
  "cost_center": "CC-4410",
  "issued_at": "2026-10-27T09:02:11Z",
  "limits": {
    "max_tokens": 50000,
    "max_cost_cad": 0.75,
    "max_tool_calls": 15,
    "max_iterations": 8,
    "timeout_s": 60,
    "max_wall_clock_s": 28800
  },
  "alert_ratio": 0.8,
  "on_exhaustion": { "action": "stop_and_escalate", "queue": "file-achats-exceptions" },
  "models": {
    "default": "modele-compact",
    "reasoning": "modele-raisonnement",
    "reasoning_steps": ["planification", "arbitrage"],
    "fallback": "modele-compact-repli"
  },
  "consumed": {
    "as_of": "2026-10-27T09:25:41Z",
    "tokens": 41200,
    "cost_cad": 0.52,
    "tool_calls": 9,
    "iterations": 5,
    "active_s": 38
  },
  "alerts": [
    {
      "metric": "tokens",
      "ratio": 0.824,
      "at": "2026-10-27T09:25:41Z",
      "notified": "parrain"
    }
  ],
  "delegations": []
}
```

Lecture : l'enveloppe reprend des plafonds de même valeur que la fiche type de l'annexe B, qui décrit un autre agent : jetons, coût, appels d'outils, itérations et temps d'exécution active (`timeout_s`); `max_wall_clock_s` borne en outre la durée totale, attente d'approbation comprise (EXIG-ORC-26). Chaque étape incrémente `consumed` : à 82,4 % des jetons, le seuil d'alerte de 80 % a déjà prévenu le parrain, et l'atteinte d'un plafond arrêtera la tâche vers l'avant, en état sûr, pour l'escalader, sans jamais la déclarer réussie (EXIG-FIN-04). Les compensations des étapes déjà exécutées restent possibles : elles s'exécutent sous l'identité de compensation de l'orchestrateur, sur une réserve de budget tenue hors de cette enveloppe (EXIG-ORC-17). Le modèle compact sert par défaut, le modèle de raisonnement seulement aux étapes nommées, et tout le coût s'impute au centre de coûts de la tâche. Une délégation à un exécutant recevrait une part de l'enveloppe restante,

inscrite dans `delegations`, et jamais une enveloppe neuve (section 7.7); les valeurs sont illustratives et se calibrent par mesure.

C.8 Enregistrement d'audit

L'exemple montre l'enregistrement d'issue que la passerelle verse au journal d'audit après l'exécution de l'action approuvée en C.6; un enregistrement d'intention, chaîné dans le même flux, l'a précédé avant le relais de l'appel (section 10.3).

Enregistrement d'audit canonisé (clés dans l'ordre RFC 8785, présentées indentées)


```
{
  "empreinte": "sha256:d25e4bc569299784f95d6a4f4920810d497c6e8f3aadb7f8e9737c3bb42c4203",
  "enregistrement": {
    "action": {
      "arguments_sha256": "c808b36a44b197cd96fe679fd662241bf32c459f4480bbc67e5693d20ad3259f",
      "definition_sha256": "sha256:e8c1ccd755dd196d40fb358447998a964dd643fa03614e9e8fbbfa66abf643b6",
      "definition_version": "1.4.0",
      "issue": "succes",
      "outil": "mcp-approvisionnement/approvisionnement_creer_bon_commande",
      "palier": "P2",
      "reference_resultat": "BC-2026-118734"
    },
    "agent": {
      "id": "agt-achats-indirects",
      "identite": "spiffe://ent.ca/agt-achats-indirects",
      "invite_systeme": "sha256:41d07c…",
      "version": "1.2.0"
    },
    "autorite": {
      "approbations": [
        { "approbateur": "apb-5e19c2", "jti": "c2f7a1d4-8e3b-4f6a-b0d9-5a1e7c3f9b28", "role": "tiers" },
        { "approbateur": "apb-91d4e8", "jti": "7d4e9b12-3a6c-4e8f-9c01-8b2d6f4a3e19", "role": "tiers" }
      ],
      "classe_risque": "moderee",
      "controle": "approbation_requise_au_dela_du_seuil",
      "empreinte_approbation": "92be40835a73023d117ebb4965da82dfa05e2e6d647d0919d53461289bbc6e81",
      "grandeur_seuil": 1248000,
      "niveau_autonomie": "N3",
      "version_politique": "politiques-passerelle@2026.10.3"
    },
    "correlation": {
      "cle_idempotence": "80351869ca990c86c8c6a314a7ac23d80b509a03f9a11dd173d2f1112c10eca7",
      "etape": "etape-03/creer-bon-commande#1",
      "span_id": "b7ad6b7169203331",
      "tache": "tache-7f3c2a",
      "trace_id": "0af7651916cd43dd8448eb211c80319c"
    },
    "flux": "passerelle-agents-03",
    "horodatage": "2026-10-27T09:26:03.412Z",
    "intention_sequence": 48212,
    "mandant": {
      "jeton_delegue_jti": "4e8b2c71-0d93-4a6f-9b15-7c2e8f40a6d3",
      "pseudonyme": "u-58c1d7",
      "type": "user"
    },
    "modele": {
      "fournisseur": "…",
      "servi": "modele-compact",
      "version": "2026-08-14"
    },
    "nature": "issue",
    "precedent_sha256": "sha256:ee710bdb80fd80be1bce7ad8f07964c8a0dea08c5fb81f39289b26666ab4524a",
    "sequence": 48213
  },
```

```
  "signature": { "alg": "ES256", "kid": "journal-audit-2026-10", "valeur": "…" }
}
```

Lecture : `enregistrement` reprend les cinq éléments exigés par l'EXIG-OBS-12 (section 10.3) : le mandant sous pseudonyme (`mandant`), l'agent avec sa version, son identité et l'empreinte de son invite système (`agent`), l'action avec l'outil, la version et l'empreinte de sa définition, l'empreinte des arguments et l'issue (`action`), le modèle servi (`modele`) et l'autorité qui permettait d'agir (`autorite` : politique appliquée, contrôle, grandeur calculée du seuil, niveau d'autonomie et liste des approbations, chacune avec son jeton et le rôle de l'approbateur, selon les EXIG-IAM-21, EXIG-AUT-10 et EXIG-AUT-15); `correlation` le relie à la tâche, à l'étape, à la clé d'idempotence et à la trace, et les champs A2A de l'extrait de la section 10.3 sont omis, faute de délégation. Avant de relayer l'appel, la passerelle a écrit l'enregistrement d'intention de séquence 48212, que celui-ci référence (`intention_sequence`); une intention sans issue est traitée comme un incident (EXIG-OBS-11, EXIG-OBS-13). L'enregistrement ne recopie pas les arguments, et le résultat n'y figure que par sa référence. `arguments_sha256` est ici une empreinte simple, qu'on peut recalculer; comme la clé d'idempotence se déduit de la tâche et de l'étape, consignées en clair, l'empreinte des arguments d'un outil à faible entropie est salée ou remplacée par un HMAC sous une clé du service d'audit (EXIG-OBS-12). `empreinte_approbation` reprend l'empreinte h du jeton C.6; la passerelle l'a recalculée avant de relayer l'appel, ce qui atteste que les octets transmis sont ceux qui ont été approuvés, et non que l'effet est celui qui était attendu. Le rôle consigné (tiers) atteste que l'approbatrice n'est pas le mandant, ce que le service d'approbation vérifie à l'émission. `empreinte` est le SHA-256 de `enregistrement` canonisé selon la RFC 8785, signé par le service d'audit, et `precedent_sha256` chaîne chaque enregistrement au précédent du même flux (`flux`, inscrit au registre des flux) : une suppression ou une modification internes se détectent, mais la troncature de la queue et la réécriture par le détenteur de la clé ne se détectent que par les points de contrôle de la tête du flux, publiés hors du domaine d'administration du service d'audit (EXIG-OBS-12)[236]. Ce format, sa signature et son ancrage, choix du cadre, vont au-delà du minimum légal : pour un système à haut risque (obligations applicables à compter du 2 décembre 2027 pour l'annexe III et du 2 août 2028 pour l'annexe I, selon le règlement (UE) 2026/1744[57, 58]), le RIA exige que le système permette l'enregistrement automatique des événements, sans en fixer le format (art. 12), et que le déployeur conserve les journaux, dans la mesure où ils sont sous son contrôle, pendant une durée adaptée à la destination du système et d'au moins six mois, sauf disposition contraire du droit de l'Union ou du droit national (art. 26, par. 6)[61, 447].

D Registre des exigences

Ce registre récapitule, dans l'ordre du document, toutes les exigences normatives du cadre avec la force de leur bloc (DOIT, NE DOIT PAS, DEVRAIT), soit 296 exigences dans la version 1.2 (287 dans la version 1.1). Les principes PRIN-01 à PRIN-12 et les tableaux auxquels une exigence renvoie expressément sont aussi normatifs (section 1.4), mais ne figurent pas au registre. Chaque identifiant renvoie à l'exigence complète, avec son énoncé et sa justification. Le registre sert de base aux revues d'architecture, à la grille d'homologation (annexe A) et à la déclaration d'applicabilité ISO/IEC 42001.

Identifiant	Force	Exigence
EXIG-ARC-01	**DOIT**	Passage obligatoire par la passerelle et le catalogue
EXIG-ARC-02	**DOIT**	Mandant, trace et plafonds dans chaque appel
EXIG-ARC-03	**NE DOIT PAS**	Aucune logique d'agent dans les canaux
EXIG-ARC-04	**DOIT**	Mandant établi et trace ouverte à l'entrée
EXIG-ARC-05	**DOIT**	Exécution durable des tâches à effets
EXIG-ARC-06	**DOIT**	Points de contrôle protégés comme des données de production
EXIG-ARC-07	**NE DOIT PAS**	Le routage n'accorde aucun droit
EXIG-ARC-08	**DOIT**	Passerelle de modèles obligatoire
EXIG-ARC-09	**DEVRAIT**	Modèles désignés par un alias logique
EXIG-ARC-10	**DOIT**	Code généré exécuté en bac à sable
EXIG-ARC-11	**DOIT**	Passerelle d'agents dans les deux sens
EXIG-ARC-12	**DOIT**	Liste d'autorisation tirée du catalogue
EXIG-ARC-13	**DOIT**	Aucun contournement par le bus d'événements
EXIG-ARC-14	**DOIT**	Exposition sans réécriture des services
EXIG-ARC-15	**DEVRAIT**	Outils conçus pour la tâche
EXIG-ARC-16	**DOIT**	Résultats filtrés selon les droits du mandant
EXIG-ARC-17	**DOIT**	Écriture par les interfaces qui appliquent les règles métier
EXIG-ARC-18	**DEVRAIT**	Référence de trace sur chaque écriture
EXIG-ARC-19	**DOIT**	Services transversaux mutualisés
EXIG-ARC-20	**DOIT**	Correspondance ABB-SBB documentée
EXIG-ARC-21	**DOIT**	SBB exposés par les standards retenus
EXIG-ARC-22	**NE DOIT PAS**	Pas d'historique brut comme mémoire
EXIG-ARC-23	**DOIT**	Contrôles avant toute écriture en mémoire épisodique ou sémantique
EXIG-ARC-24	**DOIT**	Mémoire procédurale gérée comme du code
EXIG-ARC-25	**NE DOIT PAS**	Aucun magasin de mémoire longue partagé en écriture
EXIG-INT-01	**DOIT**	Revue d'interopérabilité proportionnée
EXIG-INT-02	**DOIT**	Vocabulaire et schémas d'entreprise
EXIG-INT-03	**DOIT**	Accord d'interopérabilité et gestion du changement
EXIG-INT-04	**DOIT**	Protocole désigné par type d'interaction
EXIG-INT-05	**DEVRAIT**	Agent pair invoqué par A2A, pas déguisé en outil
EXIG-INT-06	**DOIT**	Statut au catalogue avant tout usage en production
EXIG-INT-07	**DOIT**	Version de référence fixée au catalogue
EXIG-INT-08	**DOIT**	Révision trimestrielle du catalogue des protocoles
EXIG-INT-09	**NE DOIT PAS**	Brouillon présenté comme une norme publiée
EXIG-INT-10	**DOIT**	Choix de protocole justifié par la matrice
EXIG-INT-11	**DEVRAIT**	Diffusion d'un changement d'état par événement

Identifiant	Force	Exigence
EXIG-MCP-01	**DOIT**	Exposition des capacités par MCP, derrière la passerelle
EXIG-MCP-02	**DOIT**	Révision de référence vérifiée par la découverte
EXIG-MCP-03	**DOIT**	Listes stables et cache conforme à cacheScope
EXIG-MCP-04	**DOIT**	Extensions activées sur liste d'autorisation
EXIG-MCP-05	**DEVRAIT**	Choix de la primitive selon le besoin
EXIG-MCP-06	**NE DOIT PAS**	Aucun miroir CRUD des API
EXIG-MCP-07	**DOIT**	Conventions de nommage et de résultat des outils
EXIG-MCP-08	**DOIT**	Transport selon l'environnement
EXIG-MCP-09	**DOIT**	Autorisation obligatoire et conforme à la spécification
EXIG-MCP-10	**DOIT**	Portées minimales et élévation progressive
EXIG-MCP-11	**NE DOIT PAS**	Interdiction du passage de jeton
EXIG-MCP-12	**DOIT**	Enregistrement des clients MCP
EXIG-MCP-13	**DOIT**	Consentement par client des mandataires MCP
EXIG-MCP-14	**DOIT**	Annotations et métadonnées déclarées : de simples indices
EXIG-MCP-15	**DOIT**	Concordance des en-têtes et du corps
EXIG-MCP-16	**DOIT**	Traitement du champ _meta
EXIG-MCP-17	**DOIT**	État explicite protégé
EXIG-MCP-18	**NE DOIT PAS**	Aucune donnée sensible en en-tête
EXIG-MCP-19	**DOIT**	Schémas, URL et icônes : des entrées non fiables
EXIG-MCP-20	**DOIT**	Empreintes des définitions et isolement des serveurs
EXIG-MCP-21	**NE DOIT PAS**	Élicitation : ni secret ni approbation déguisée
EXIG-MCP-22	**DOIT**	Migration bornée et abandon des fonctions dépréciées
EXIG-A2A-01	**DOIT**	A2A 1.0 pour toute délégation entre agents
EXIG-A2A-02	**DOIT**	Carte publiée et inscrite au catalogue
EXIG-A2A-03	**DOIT**	Carte signée et vérifiée
EXIG-A2A-04	**DOIT**	Version de carte et revalidation du cache
EXIG-A2A-05	**NE DOIT PAS**	Aucun champ hors norme dans la carte
EXIG-A2A-06	**DOIT**	Compétences internes dans la carte étendue
EXIG-A2A-07	**DOIT**	Suivi des tâches longues
EXIG-A2A-08	**DOIT**	Version annoncée et liaisons standard
EXIG-A2A-09	**DOIT**	Transport chiffré et authentification à chaque requête
EXIG-A2A-10	**DOIT**	Autorisation par compétence et par locataire
EXIG-A2A-11	**NE DOIT PAS**	Flux OAuth permis et flux retirés
EXIG-A2A-12	**DOIT**	Notifications push durcies
EXIG-A2A-13	**DOIT**	Traçage et corrélation des tâches
EXIG-A2A-14	**DOIT**	Compatibilité vérifiée avant inscription
EXIG-A2A-15	**DEVRAIT**	Migration bornée depuis la version 0.3
EXIG-EVT-01	**DEVRAIT**	Recours au bus pour l'asynchrone
EXIG-EVT-02	**DOIT**	Enveloppe CloudEvents complète
EXIG-EVT-03	**DOIT**	Contrat AsyncAPI au catalogue
EXIG-EVT-04	**DOIT**	Attributs de gouvernance présents et vérifiés
EXIG-EVT-05	**NE DOIT PAS**	Aucun renseignement personnel direct dans les attributs
EXIG-EVT-06	**DOIT**	Compteur de sauts et coupure des boucles
EXIG-EVT-07	**DOIT**	Autorisation fondée sur l'identité, pas sur les attributs

Identifiant	Force	Exigence
EXIG-EVT-08	**DOIT**	Effets réels protégés par l'idempotence
EXIG-EVT-09	**DOIT**	Ordre garanti par la clé de partition
EXIG-EVT-10	**DOIT**	Conservation des entrées et rejeu isolé
EXIG-INT-12	**DOIT**	Contrat complet avant l'inscription
EXIG-INT-13	**DOIT**	Versionnage sémantique des contrats
EXIG-INT-14	**DOIT**	Coexistence d'au moins 60 jours
EXIG-INT-15	**DOIT**	Dépendances épinglées par version et empreinte
EXIG-INT-16	**DOIT**	Nouvelle approbation à toute modification
EXIG-INT-17	**DOIT**	Catalogue unique, source de la découverte
EXIG-INT-18	**DOIT**	Consommateurs connus avant tout retrait
EXIG-INT-19	**DOIT**	Détection automatique des ruptures
EXIG-INT-20	**NE DOIT PAS**	Qualification « AAIF » non vérifiée
EXIG-INT-21	**DOIT**	Pilotes AGNTCY subordonnés au catalogue
EXIG-INT-22	**DOIT**	Paiements initiés par un agent
EXIG-INT-23	**DOIT**	Signal de révision inscrit au catalogue
EXIG-ORC-01	**DOIT**	Configuration la plus simple justifiée
EXIG-ORC-02	**DOIT**	Preuve mesurée avant le multiagent
EXIG-ORC-03	**DOIT**	Patron déclaré au registre
EXIG-ORC-04	**NE DOIT PAS**	Délégation limitée à deux niveaux
EXIG-ORC-05	**DOIT**	Boucle évaluateur-optimiseur bornée
EXIG-ORC-06	**DOIT**	Clavardage de groupe encadré
EXIG-ORC-07	**DOIT**	Fusion déclarée et écrivain unique en parallèle
EXIG-ORC-08	**DOIT**	Chorégraphie sous propriétaire et saga
EXIG-ORC-09	**DOIT**	Surcharge d'outils traitée avant de scinder
EXIG-ORC-10	**DEVRAIT**	Découpage par frontières de contexte
EXIG-ORC-11	**DOIT**	Persistance après chaque transition
EXIG-ORC-12	**DOIT**	Reprise sans double effet
EXIG-ORC-13	**DOIT**	Magasin de points de contrôle protégé
EXIG-ORC-14	**DEVRAIT**	Déploiement sans interruption des exécutions longues
EXIG-ORC-15	**DOIT**	Saga pour toute écriture multisystème
EXIG-ORC-16	**DOIT**	Journal de compensation tenu avant l'action
EXIG-ORC-17	**DOIT**	Compensations idempotentes et métier, après réessais
EXIG-ORC-18	**DOIT**	Escalade après deux échecs d'une compensation
EXIG-ORC-19	**DOIT**	Isolation sémantique des sagas concurrentes
EXIG-ORC-20	**DOIT**	Tests d'injection de fautes des sagas
EXIG-ORC-21	**DOIT**	Clé d'idempotence sur toute écriture
EXIG-ORC-22	**DOIT**	Vérification de la clé par le service visé
EXIG-ORC-23	**DOIT**	Contexte de délégation minimal et structuré
EXIG-ORC-24	**DOIT**	Retour validé avant toute réutilisation
EXIG-ORC-25	**DOIT**	Filtrage de sécurité dans chaque agent
EXIG-ORC-26	**DOIT**	Plafonds sur toute exécution
EXIG-ORC-27	**DOIT**	Mécanismes de résilience et repli testé
EXIG-ORC-28	**DOIT**	Coupe-circuit exercé chaque trimestre
EXIG-ORC-29	**NE DOIT PAS**	Aucun anti-patron sans dérogation

Identifiant	Force	Exigence
EXIG-ORC-30	**DOIT**	Capacités démontrées avant l'inscription d'un produit
EXIG-AUT-01	**DOIT**	Niveau d'autonomie déclaré et appliqué
EXIG-AUT-02	**DOIT**	Plafond selon la classe de risque
EXIG-AUT-03	**NE DOIT PAS**	Autonomie non bornée interdite (NX)
EXIG-AUT-04	**DOIT**	Domaine de conception opérationnel (ODD), repli et arrêts pour N3 et N4
EXIG-AUT-05	**DOIT**	Homologation et réévaluation du niveau
EXIG-AUT-06	**DOIT**	Classement fondé sur les permissions effectives
EXIG-AUT-07	**NE DOIT PAS**	Règle d'or : pas d'exécution autonome du risque cumulé
EXIG-AUT-08	**DOIT**	Palier attribué au catalogue après revue
EXIG-AUT-09	**NE DOIT PAS**	Aucun outil P3 exécuté seul
EXIG-AUT-10	**DOIT**	Contrôle calculé à chaque appel
EXIG-AUT-11	**DOIT**	Échec en mode fermé
EXIG-AUT-12	**DOIT**	Jeton d'approbation lié à l'action exacte
EXIG-AUT-13	**NE DOIT PAS**	Ce qui n'est jamais une approbation
EXIG-AUT-14	**DEVRAIT**	Approbation hors bande normalisée
EXIG-AUT-15	**DOIT**	Approbateurs habilités et formés
EXIG-AUT-16	**DOIT**	Boîte de réception persistante
EXIG-AUT-17	**DOIT**	État persisté et effets après le point d'approbation
EXIG-AUT-18	**DOIT**	Réautorisation périodique des agents ambiants
EXIG-AUT-19	**DOIT**	Écran d'approbation fidèle à l'action
EXIG-AUT-20	**DOIT**	Charge d'approbation maîtrisée
EXIG-AUT-21	**DOIT**	Mesure de la qualité de la supervision
EXIG-AUT-22	**DOIT**	Décisions visées par l'article 12.1
EXIG-AUT-23	**DOIT**	Révision humaine significative
EXIG-IAM-01	**NE DOIT PAS**	Aucune confiance implicite
EXIG-IAM-02	**DOIT**	Une décision à chaque appel
EXIG-IAM-03	**DOIT**	Identité propre, distincte et non partagée
EXIG-IAM-04	**DOIT**	Justificatif cryptographique émis par la plateforme
EXIG-IAM-05	**NE DOIT PAS**	Aucun secret statique
EXIG-IAM-06	**NE DOIT PAS**	Justificatifs hors de portée du modèle
EXIG-IAM-07	**DOIT**	Révocation au retrait et revues périodiques
EXIG-IAM-08	**DOIT**	Délégation explicite par échange de jetons
EXIG-IAM-09	**NE DOIT PAS**	Interdiction de l'usurpation
EXIG-IAM-10	**DOIT**	Portée jamais élargie
EXIG-IAM-11	**DOIT**	Jeton à audience unique, validé par la cible
EXIG-IAM-12	**NE DOIT PAS**	Aucun relais de jeton
EXIG-IAM-13	**DOIT**	Profil OAuth de l'entreprise
EXIG-IAM-14	**DOIT**	Jetons liés à l'expéditeur
EXIG-IAM-15	**DEVRAIT**	Durée de vie courte des jetons
EXIG-IAM-16	**DOIT**	Agents autonomes : identifiants du client et portées par outil
EXIG-IAM-17	**DOIT**	Passage obligatoire par la passerelle d'agents
EXIG-IAM-18	**DOIT**	Échec en mode fermé et refus typé
EXIG-IAM-19	**DEVRAIT**	Justificatifs en aval injectés par la passerelle
EXIG-IAM-20	**DOIT**	Coupe-circuit propagé et mesuré

Identifiant	Force	Exigence
EXIG-IAM-21	**DOIT**	Politique en code, versionnée et testée
EXIG-SEC-01	**DOIT**	Modélisation des menaces avant la production
EXIG-SEC-02	**DOIT**	Matrice de traçabilité des menaces
EXIG-SEC-03	**DOIT**	Présomption d'injection
EXIG-SEC-04	**DOIT**	Règle de deux par session
EXIG-SEC-05	**NE DOIT PAS**	Détection comme seul contrôle
EXIG-SEC-06	**DOIT**	Retrait déterministe des capacités d'exfiltration
EXIG-SEC-07	**DOIT**	Patron de conception pour les agents de risque élevé
EXIG-SEC-08	**DOIT**	Technologie d'isolation du code non fiable
EXIG-SEC-09	**DOIT**	Bac à sable éphémère et minimal
EXIG-SEC-10	**DOIT**	Charges qui exigent un GPU
EXIG-SEC-11	**DEVRAIT**	Performance mesurée sur la charge réelle
EXIG-SEC-12	**DOIT**	Sortie réseau refusée par défaut
EXIG-SEC-13	**DOIT**	Service de métadonnées infonuagiques
EXIG-SEC-14	**NE DOIT PAS**	Secret dans le bac à sable plutôt qu'injecté par le mandataire
EXIG-SEC-15	**DOIT**	Délais à trois niveaux
EXIG-SEC-16	**DOIT**	Journal d'exécution tenu hors du bac à sable
EXIG-SEC-17	**DOIT**	Porte de validation du code généré
EXIG-SEC-18	**DOIT**	Provenance approuvée et intégrité vérifiée à l'exécution
EXIG-SEC-19	**DOIT**	Signature des cartes d'agent et des artefacts
EXIG-SEC-20	**DOIT**	Nomenclature de chaque version d'agent
EXIG-SEC-21	**DOIT**	Chaque serveur, un domaine de sécurité distinct
EXIG-SEC-22	**DOIT**	Évaluation des tiers et plan de contingence
EXIG-SEC-23	**DOIT**	Exercice d'équipe rouge propre aux agents
EXIG-SEC-24	**DOIT**	Suite d'attaques dans la chaîne d'intégration
EXIG-SEC-25	**DOIT**	Vérification des contrôles déterministes
EXIG-SEC-26	**DOIT**	Exercice trimestriel de compromission d'agent
EXIG-OBS-01	**DOIT**	OpenTelemetry obligatoire, conventions épinglées
EXIG-OBS-02	**DOIT**	Contexte validé, poursuivi ou redémarré aux frontières
EXIG-OBS-03	**DOIT**	Identifiants métier portés à part
EXIG-OBS-04	**DOIT**	Hiérarchie de spans normalisée
EXIG-OBS-05	**DOIT**	Attributs et métriques exigés
EXIG-OBS-06	**DOIT**	Attributs d'entreprise sous préfixe DNS inversé
EXIG-OBS-07	**NE DOIT PAS**	Aucun contenu dans la télémétrie de production
EXIG-OBS-08	**DOIT**	Contenu de débogage hors trace et de courte durée
EXIG-OBS-09	**DOIT**	Caviardage à la sortie du périmètre
EXIG-OBS-10	**NE DOIT PAS**	Aucun renseignement personnel dans le bagage
EXIG-OBS-11	**DOIT**	Journal d'audit distinct et exhaustif
EXIG-OBS-12	**DOIT**	Enregistrement à cinq éléments, canonisé et signé
EXIG-OBS-13	**DOIT**	Inaltérabilité et conservation
EXIG-EVA-01	**DOIT**	Étages franchis et relancés à chaque changement
EXIG-EVA-02	**DOIT**	Jeu de référence tenu et versionné
EXIG-EVA-03	**DOIT**	Évaluations répétées et isolées
EXIG-EVA-04	**DOIT**	Échantillonnage de la production

Identifiant	Force	Exigence
EXIG-EVA-05	**DOIT**	Juge automatisé encadré
EXIG-EVA-06	**DOIT**	Objectifs de niveau de service et réaction aux écarts
EXIG-FIN-01	**DOIT**	Comparaison au coût par tâche réussie
EXIG-FIN-02	**DOIT**	Hypothèses de prix datées et révisées
EXIG-FIN-03	**DOIT**	Unités SaaS converties et plafonnées
EXIG-FIN-04	**DOIT**	Enveloppe appliquée à chaque étape
EXIG-FIN-05	**DOIT**	Quotas et plafond mensuel par agent
EXIG-FIN-06	**DOIT**	Plus petit modèle suffisant
EXIG-FIN-07	**DOIT**	Préfixe stable et cache mesuré
EXIG-FIN-08	**DEVRAIT**	Lots asynchrones pour les charges non urgentes
EXIG-FIN-09	**DOIT**	Imputation par centre de coûts
EXIG-FIN-10	**DOIT**	Indicateurs d'économie unitaire publiés
EXIG-GOV-01	**DOIT**	Responsables nommés pour chaque agent
EXIG-GOV-02	**DOIT**	Comité d'architecture et des risques agentiques
EXIG-GOV-03	**NE DOIT PAS**	Cumul de la préparation et de l'approbation
EXIG-GOV-04	**DOIT**	Un seul A, des personnes nommées
EXIG-GOV-05	**DOIT**	Socle commun obligatoire
EXIG-GOV-06	**DEVRAIT**	Conformité par construction
EXIG-GOV-07	**DOIT**	Inventaire complet
EXIG-GOV-08	**NE DOIT PAS**	Sans fiche, aucun justificatif
EXIG-GOV-09	**DOIT**	Fiche à jour ou agent suspendu
EXIG-GOV-10	**DOIT**	Détection des agents hors registre
EXIG-GOV-11	**DOIT**	Jalons du cycle de vie consignés
EXIG-GOV-12	**DOIT**	Réévaluation sur changement significatif
EXIG-GOV-13	**DOIT**	Attestation périodique du parrain
EXIG-GOV-14	**DOIT**	Retrait vérifiable
EXIG-GOV-15	**DOIT**	Demande et décision écrites
EXIG-GOV-16	**DOIT**	Durée bornée
EXIG-GOV-17	**NE DOIT PAS**	Dérogation à une exigence non dérogeable
EXIG-GOV-18	**DOIT**	Révision trimestrielle du catalogue
EXIG-GOV-19	**DOIT**	Critères d'admission d'un standard
EXIG-GOV-20	**DOIT**	Veille désignée et usage encadré
EXIG-CON-01	**DOIT**	Classe de risque attribuée avant l'inscription
EXIG-CON-02	**DOIT**	Plafond d'autonomie par classe
EXIG-CON-03	**DOIT**	Réévaluation à chaque changement significatif
EXIG-CON-04	**DOIT**	EFVP avant tout projet d'agent impliquant des RP
EXIG-CON-05	**DOIT**	Cartographie des lieux de traitement
EXIG-CON-06	**DOIT**	Finalité vérifiée avant toute réutilisation
EXIG-CON-07	**DOIT**	Avis et explication des décisions automatisées
EXIG-CON-08	**NE DOIT PAS**	Aucune approbation nominale
EXIG-CON-09	**DOIT**	Conservation des éléments de décision
EXIG-CON-10	**DOIT**	Durée de vie des mémoires et des traces
EXIG-CON-11	**DOIT**	Régimes applicables inscrits à la fiche
EXIG-CON-12	**DOIT**	Arrimage à E-23 pour les institutions financières fédérales

Identifiant	Force	Exigence
EXIG-CON-13	**DOIT**	Applicabilité du RIA déterminée par l'usage des sorties
EXIG-CON-14	**NE DOIT PAS**	Aucun usage interdit
EXIG-CON-15	**DOIT**	Revue de requalification en fournisseur
EXIG-CON-16	**DOIT**	Obligations du déployeur d'un agent à haut risque
EXIG-CON-17	**DOIT**	Déclaration de tolérance au risque
EXIG-CON-18	**DOIT**	Base de preuves unique
EXIG-CON-19	**DOIT**	Divulgation de l'interaction avec un agent
EXIG-CON-20	**DOIT**	Identification des contenus produits par un agent
EXIG-CON-21	**DOIT**	Explication intelligible et canal de révision
EXIG-CON-22	**DOIT**	Vérification humaine du contenu juridique
EXIG-CON-23	**DOIT**	Réponse en cinq temps et gel des preuves
EXIG-CON-24	**DOIT**	Registre et avis des incidents de confidentialité
EXIG-CON-25	**DOIT**	Règle la plus exigeante entre régimes de notification
EXIG-CON-26	**DOIT**	Évaluation d'impact unifiée par agent de classe élevée
EXIG-APP-01	**DOIT**	Analyse de réversibilité avant tout engagement
EXIG-APP-02	**NE DOIT PAS**	Aucune dépendance à une extension non approuvée
EXIG-APP-03	**DOIT**	Preuves de conformité protocolaire
EXIG-APP-04	**DOIT**	Mesures de performance reproductibles
EXIG-APP-05	**DOIT**	Télémétrie et données de coûts ouvertes
EXIG-APP-06	**DOIT**	Identité et arrêt sous le contrôle de l'entreprise
EXIG-APP-07	**DOIT**	Clause 1 — Interopérabilité ouverte et portabilité des cartes
EXIG-APP-08	**DOIT**	Clause 2 — Conformité MCP et délégation d'identité
EXIG-APP-09	**DOIT**	Clause 3 — Télémétrie exportable et explicabilité
EXIG-APP-10	**DOIT**	Clause 4 — Usage limité au mandat et interdiction d'entraînement
EXIG-APP-11	**DOIT**	Clause 5 — Résidence, transferts et lois étrangères
EXIG-APP-12	**DOIT**	Clause 6 — Notification d'incident
EXIG-APP-13	**DOIT**	Clause 7 — Audit, sécurité et transparence des changements
EXIG-APP-14	**DOIT**	Clause 8 — Réversibilité et sortie
EXIG-APP-15	**DOIT**	Clause 9 — Accord écrit au sens de l'article 25(4) du RIA
EXIG-APP-16	**DOIT**	Clause 10 — Révocation des identités non humaines
EXIG-APP-17	**DOIT**	Application de la grille

E Glossaire

Ce glossaire réunit, par ordre alphabétique, les termes et les sigles du cadre, avec leur équivalent anglais d'usage courant et une définition brève qui renvoie à la section où chacun est traité. Les définitions reprennent le sens que le document donne à chaque terme; lorsqu'un terme vient d'une norme ou d'un texte de loi, la source est indiquée, et ce que le cadre y ajoute est signalé comme un choix du cadre. En cas d'écart entre une définition abrégée et le corps du document, le corps du document prévaut.

Conventions

- **Classement.** Les entrées suivent l'ordre alphabétique du terme français, sans tenir compte des accents, des apostrophes ni du contenu des parenthèses. Un sigle d'usage courant suit le terme entre parenthèses; les sigles et les noms propres sans équivalent français (par exemple A2A, AAIF, CIBA, CloudEvents, FinOps, MCP, OAuth, OBO, OpenTelemetry, SPIFFE) sont classés tels quels.
- **Typographie.** L'équivalent anglais figure en italique. Les noms de champs, de méthodes, d'en-têtes et d'attributs sont en police à chasse fixe.
- **Force normative.** Le glossaire ne crée aucune exigence. Les mots doit, devrait et peut gardent le sens fixé à la section 1.4, et les définitions normatives des termes de base figurent à la section 3.1 (tableau 65).

Tableau 65 — Glossaire des termes et des sigles du cadre

Terme (sigle)	Équivalent anglais	Définition
A2A (protocole Agent2Agent)	Agent2Agent (A2A) protocol	Protocole ouvert d'intégration horizontale qui relie un agent à un autre agent autonome, potentiellement opaque, qui raisonne et conserve un état sur plusieurs tours. Projet de l'AAIF, annoncé publiquement le 17 août 2026, il est retenu par le cadre dans sa version de protocole 1.0, avec trois liaisons standard (JSON-RPC, gRPC, HTTP+JSON) et l'en-tête `A2A-Version` à chaque requête[5, 68]. Voir la section 6.6.
AAIF	Agentic AI Foundation	Fonds dirigé de la Linux Foundation, créé le 9 décembre 2025 et cofondé par Anthropic, Block et OpenAI, qui héberge des projets agentiques sous gouvernance neutre, dont MCP, A2A, agentgateway et Agent Router; il en compte dix au 22 octobre 2026[4, 38, 130, 193]. Un projet n'est un « standard AAIF » qu'une fois son admission approuvée et annoncée. Voir la section 6.9.
Agent	AI agent	Selon ISO/IEC 22989:2022 (3.1.1), entité automatisée qui perçoit son environnement, y réagit et agit pour atteindre ses buts[59]. Dans le cadre : système logiciel qui poursuit un objectif en dirigeant lui-même sa boucle « raisonner, agir, observer » (ReAct) au moyen d'un modèle, d'outils et d'un état, sous un niveau d'autonomie déclaré[84]; il choisit lui-même, au moyen d'un modèle, les actions qu'il exécute, ce qui le distingue d'un outil. Un agent n'est ni une personne, ni un compte d'utilisateur, ni un principal de service partagé; une personne nommée en répond. Voir les sections 3.1 et 3.4.
Agent ambiant	ambient agent	Agent qui écoute un flux d'événements et agit en conséquence, éventuellement sur plusieurs événements à la fois, sans être nécessairement entièrement autonome (définition du cadre, inspirée de LangChain)[86]. Un agent ambiant qui exécute seul des écritures relève du niveau N4 (section 8.1). Il travaille en arrière-plan, à la différence d'un agent interactif, sollicité par une personne qui attend sa réponse, et rejoint les personnes par une boîte de réception persistante (notifier, questionner, réviser). Voir les sections 3.3 et 8.6.
Analyse d'impact sur les droits fondamentaux (AIDF)	fundamental rights impact assessment (FRIA)	Analyse que l'article 27 du RIA exige de certains déployeurs de systèmes à haut risque avant la première utilisation; elle peut renvoyer aux sections pertinentes de l'analyse d'impact relative à la protection des données (AIPD) du Règlement général sur la protection des données (RGPD) ou en intégrer des parties[58, 61]. Le cadre l'intègre à

Terme (sigle)	Équivalent anglais	Définition
		l'évaluation d'impact unifiée de chaque agent de classe élevée. Voir la section 12.9.
Annotation d'outil	tool annotation	Métadonnée qu'un serveur MCP déclare sur un outil : un titre (`title`) et quatre indices (`readOnlyHint`, `destructiveHint`, `idempotentHint`, `openWorldHint`). La spécification demande aux clients de tenir les annotations pour non fiables, sauf si elles proviennent de serveurs de confiance[197]. Le palier, le seuil et la compensation d'un outil se lisent au catalogue d'entreprise, jamais dans ses annotations. Voir la section 6.5.
Approbation humaine	human approval	Décision explicite d'une personne habilitée qui autorise une action précise avant son exécution. Dans le cadre, elle prend la forme d'un jeton d'approbation signé, lié à l'action exacte et vérifié par la passerelle d'agents; pour un appel P3, elle est hors bande. Un acquiescement dans la conversation, un résumé rédigé par l'agent ou une confirmation locale dans son interface n'en sont jamais une. Voir la section 8.5.
Approbation machinale	rubber-stamping	Approbation donnée sans examen réel, sous l'effet du volume, de la fatigue ou du biais d'automatisation, soit la tendance à se fier excessivement à une sortie automatisée. L'OWASP (Open Worldwide Application Security Project) range la saturation délibérée des approbateurs parmi les menaces (T10, Overwhelming Human in the Loop) [87]. Le cadre la prévient par des files priorisées selon le risque et par la mesure du taux d'approbation sans modification. Voir la section 8.7.
AsyncAPI	AsyncAPI	Spécification ouverte qui décrit de façon lisible par machine les canaux, les opérations d'envoi (`send`) ou de réception (`receive`) et les messages d'une application asynchrone. Le cadre retient la version 3.x (3.0.0 du 5 décembre 2023; 3.1.0 du 31 janvier 2026, version mineure sans rupture) pour le contrat de chaque sujet du bus d'événements[174, 249]. Voir la section 6.7.
Bac à sable	sandbox	Environnement d'exécution isolé, éphémère et sans privilèges où s'exécute le code qu'un agent génère ou reçoit d'une source non fiable : microVM (Firecracker, Kata Containers), gVisor ou WebAssembly (WASI), jamais un conteneur à noyau partagé (choix du cadre). Il démarre sans accès réseau, ne contient aucun secret, applique des délais à trois niveaux et est journalisé de l'extérieur. Voir la section 9.7.
Bloc de construction d'architecture (ABB) et **de solution** (SBB)	architecture building block; solution building block	Notions de TOGAF : l'ABB capture les exigences d'architecture et oriente le développement des SBB; le SBB est le produit ou le composant qui met en œuvre la fonction et dépend du fournisseur[121]. Dans le cadre, la passerelle d'agents est un ABB neutre et durable; le produit qui la réalise est un SBB remplaçable. Voir la section 5.4.
Bureau du surintendant des institutions financières (BSIF)	Office of the Superintendent of Financial Institutions (OSFI)	Organisme fédéral dont la ligne directrice E-23 vise les institutions financières fédérales : elle inclut les méthodes d'IA dans sa définition de modèle et exige un inventaire d'entreprise, que le cadre étend à chaque agent et à chaque modèle utilisé (EXIG-CON-12). Voir la section 12.3.
Bus d'événements	event bus; event broker	Courtier qui transporte des événements entre producteurs et consommateurs qui s'ignorent, par exemple Apache Kafka. Il découple les échanges dans le temps, admet plusieurs abonnés et permet le rejeu des entrées, mais Kafka livre par défaut « au moins une fois »[140] : un effet réel n'est protégé que par l'idempotence du consommateur et du système cible. Voir la section 6.7.
Cadriciel	framework; agent framework	Bibliothèque logicielle qui structure la logique d'un agent ou d'une orchestration, par exemple LangGraph, Microsoft Agent Framework, Google ADK ou OpenAI Agents SDK. Le cadre le traite comme un bloc de solution remplaçable : entre agents, seuls les contrats publiés font foi. Voir la section 7.10.
Carte d'agent	Agent Card	Document JSON par lequel un agent A2A déclare son identité, ses compétences, ses interfaces et ses exigences de sécurité. En

Terme (sigle)	Équivalent anglais	Définition
		A2A 1.0, elle compte huit champs obligatoires (`name`, `description`, `supportedInterfaces`, `version`, `capabilities`, `defaultInputModes`, `defaultOutputModes`, `skills`), et un agent exposé la publie à `/.well-known/agent-card.json`[68]. Le cadre exige qu'elle soit signée (JWS sur la carte canonisée JCS), versionnée selon SemVer et inscrite au registre. Voir la section 6.6 et l'annexe C.
Catalogue d'entreprise	enterprise catalog	Source unique de ce qu'un agent peut joindre : outils, serveurs MCP, cartes d'agent et contrats d'événements, chacun avec sa version et son empreinte approuvées, son palier, son seuil, sa compensation et son responsable. La passerelle d'agents en tire sa liste d'autorisation; un élément absent du catalogue est injoignable. Le registre répond à « qui, quoi, pourquoi et avec quel risque », le catalogue à « par quel contrat et dans quelle version ». Voir les sections 6.8 et 11.4.
Catalogue des protocoles	protocol and standards catalog	Liste des protocoles et standards admis par le cadre, avec leur version de référence et l'un de cinq statuts : Adopter (usage par défaut, seul statut admis pour un nouvel usage en production), Évaluer (pilotes encadrés), Surveiller (veille, hors production), Contenir (existant toléré derrière un adaptateur jusqu'à l'échéance de son plan de sortie, sans nouvel usage) ou Suspendu (service arrêté par la passerelle pour un motif de sécurité). L'architecture d'entreprise le révise au moins chaque trimestre et soumet la révision à l'approbation du comité (EXIG-GOV-18). Voir les sections 6.3 et 11.7.
Chorégraphie	choreography	Coordination décentralisée dans laquelle chaque agent réagit aux événements d'un bus et publie les siens, sans composant central qui dirige le flux. Le cadre l'assortit d'un propriétaire de bout en bout, d'une saga explicite, d'un contexte de trace et d'un compteur de sauts. Voir les sections 6.7 et 7.2.
CIBA	Client-Initiated Backchannel Authentication	Spécification finale de l'OpenID Foundation (CIBA Core 1.0) qui découple l'appareil où s'exécute le client de celui où la personne s'authentifie; un court `binding_message`, affiché sur les deux appareils, rattache la demande à l'action[310]. Le cadre la recommande pour l'approbation hors bande, notamment des actions P3 et des agents sans interface. Voir la section 8.5.
Classe de risque	risk class	Mesure de ce qui arrive si l'agent se trompe : faible, modérée ou élevée. La classe retenue est la plus élevée dont un critère est rempli, jamais une moyenne. Elle fixe le plafond d'autonomie : N2 pour la classe élevée, qui comprend les systèmes à haut risque du RIA et les décisions visées par l'article 12.1 de la Loi sur le privé ou par l'article 65.2 de la Loi sur l'accès; N3 pour les classes modérée et faible; N4 pour la classe faible, sur décision du comité (EXIG-CON-02). Voir les sections 8.1 et 12.1.
CloudEvents	CloudEvents	Spécification de la Cloud Native Computing Foundation (CNCF) qui normalise l'enveloppe d'un événement. Le cadre retient la version 1.0 (révision 1.0.2), dont les quatre attributs requis sont `id`, `source`, `specversion` et `type`[248]. Le contrat de chaque sujet se décrit en AsyncAPI 3.x, et le cadre exige des extensions documentées (contexte de trace, contexte d'authentification, classification, clé de partition) et ajoute les siennes (origine, compteur et plafond de sauts, centre de coûts). Voir la section 6.7.
Comité d'architecture et des risques agentiques	agentic architecture and risk committee	Instance décisionnelle du cadre, dotée d'un mandat écrit. Le comité approuve les agents de classe élevée et tout niveau N4, accorde les dérogations, approuve le catalogue des protocoles et révise le cadre chaque semestre; ses décisions sont motivées et consignées au registre. Voir la section 11.1.
Commission d'accès à l'information (CAI)	Commission d'accès à l'information (nom officiel)	Organisme québécois chargé de surveiller l'application des lois sur l'accès à l'information et sur la protection des renseignements personnels. Elle reçoit les avis d'incidents de confidentialité présentant un risque de préjudice sérieux et peut imposer des sanctions administratives pécuniaires[317]. Le cadre recommande son guide d'EFVP. Voir les sections 12.2 et 12.8.

Terme (sigle)	Équivalent anglais	Définition
Compensation	compensating transaction	Action métier qui neutralise ou corrige l'effet d'une étape déjà exécutée lorsqu'une saga ne peut aboutir : remboursement, avis rectificatif, libération de stock. Elle ne rétablit pas forcément l'état initial. Le cadre exige qu'elle soit inscrite au catalogue comme un outil, avec son palier, idempotente et journalisée avant l'action qu'elle couvre; elle est déclenchée lorsque la progression devient impossible (réessais épuisés ou erreur non transitoire) et s'exécute sous l'identité de compensation de l'orchestrateur, que les arrêts de l'agent n'atteignent pas (EXIG-ORC-17). Une étape dont l'issue est inconnue n'est compensée qu'après la clôture de l'opération chez le système visé ou une issue définitive (EXIG-ORC-16). Voir la section 7.5.
Compétence	skill	Capacité qu'un agent publie dans sa carte d'agent; en A2A 1.0, chaque compétence exige `id`, `name`, `description` et `tags` et peut porter ses propres exigences de sécurité[192]. Le cadre associe une portée OAuth dédiée à chaque compétence. Le terme désigne aussi les paquets de compétences d'agents, traités comme des composants de la chaîne d'approvisionnement. Voir les sections 6.6 et 9.8.
Compteur de sauts	hop count	Extension CloudEvents propre au cadre (`xagenthopcount`, avec le plafond `xagentmaxhops`, fixé à 4 par défaut) qui compte les publications d'agents dans une chaîne causale. Un agent qui reçoit un événement ayant atteint le plafond ne le traite pas, le dirige vers la file de lettres mortes et lève une alerte : les boucles entre agents sont coupées de façon déterministe. Voir la section 6.7.
Confiance zéro	zero trust	Modèle de sécurité défini par la publication NIST SP 800-207 (août 2020) : aucune confiance implicite n'est accordée selon l'emplacement réseau, et l'authentification et l'autorisation précèdent l'accès à chaque ressource[112]. Le cadre va au-delà de l'accès par session : chaque appel d'un agent est authentifié et autorisé individuellement. Voir la section 9.1.
Contenu non fiable	untrusted content	Tout contenu autre que la demande saisie par le mandant authentifié et la configuration approuvée de l'agent : pages Web, courriels, documents et pièces jointes, même téléversés par le mandant, champs libres des systèmes d'enregistrement, réponses d'outils, entrées de mémoire, index de récupération, événements, messages, tâches et cartes d'autres agents. Toute source de contexte non inscrite au catalogue avec son étiquette de fiabilité est non fiable (EXIG-SEC-03). Il est traité comme une donnée, jamais comme une instruction. Sa consommation, repérée par le marquage du catalogue, marque la session, et l'étiquette suit toute donnée qui en dérive; elle entraîne, pour le reste de la session, le retrait des outils d'envoi (y compris la requête en texte libre d'un outil de recherche publique) et des outils P3, et la règle de deux s'applique à toute écriture P2 (EXIG-SEC-04, EXIG-SEC-06). Une action retirée ne s'exécute qu'avec une approbation liée à l'action exacte. Voir la section 9.6.
Contrat	contract	Description lisible par machine qui fait foi entre un agent ou un outil et ses consommateurs : définition d'outil MCP, carte d'agent, contrat AsyncAPI ou OpenAPI. Le contrat d'agent précise en outre les entrées, les sorties, les limites, le niveau d'autonomie et les niveaux de service. Tout contrat est versionné, épinglé et inscrit au catalogue; la description d'un outil en fait partie. Voir la section 6.8 et l'annexe C.
Contrôle calculé	computed control (terme du cadre)	Contrôle que la passerelle d'agents détermine à chaque appel d'outil : l'union des contrôles de la cellule classe × palier, du niveau d'autonomie et de la classe les plus contraignants de la chaîne de délégation, des déclencheurs d'approbation et des points non dérogeables (EXIG-AUT-10). Voir la section 8.4.
Coupe-circuit	kill switch	Mécanisme qui, en une seule action, suspend un agent, un outil, un serveur MCP ou une catégorie d'actions sur toutes les passerelles, désactive, lorsqu'il vise un agent, son identité et diffuse la révocation aux systèmes raccordés, par exemple au moyen des événements

Terme (sigle)	Équivalent anglais	Définition
		du Continuous Access Evaluation Profile (CAEP) du Shared Signals Framework[344]. Il arrête l'agent vers l'avant et ne vise pas le canal de compensation (EXIG-ORC-17). Son délai de bout en bout, de la décision d'arrêt au refus du dernier appel dans tous les systèmes, a une cible fixée par l'entreprise (EXIG-IAM-20) et se mesure lors de l'exercice trimestriel de l'EXIG-SEC-26 (choix du cadre). Voir les sections 7.8 et 9.4.
Décision fondée exclusivement sur un traitement automatisé	decision based exclusively on automated processing	Décision concernant une personne fondée exclusivement sur un traitement automatisé de ses RP (art. 12.1 de la Loi sur le privé; art. 65.2 de la Loi sur l'accès). La personne en est informée au plus tard au moment où la décision lui est communiquée, peut obtenir les RP utilisés et les principaux facteurs et paramètres, et présenter ses observations à un membre du personnel en mesure de réviser la décision[160]. Selon l'interprétation gouvernementale de l'article 65.2 (organismes publics), une intervention humaine mineure ne retire pas ce caractère[318]; la CAI n'a pas publié de critères pour le secteur privé, et le cadre applique cette interprétation par analogie à l'article 12.1. Voir les sections 8.8 et 12.2.
Délégation	delegation	Transfert, borné en portée et en durée, du droit d'agir d'un mandant vers un agent, ou d'une tâche d'un agent vers un autre. Au sens de la RFC 8693, l'acteur conserve une identité distincte de celle du sujet pour lequel il agit; dans l'usurpation d'identité (impersonation), l'acteur devient indiscernable du sujet[69]. Le cadre interdit l'usurpation et exige la délégation explicite. Voir la section 9.3.
Déployeur	deployer	Selon l'article 3(4) du RIA, personne ou organisme qui utilise un système d'IA sous sa propre autorité[61]. Un déployeur devient fournisseur s'il appose son nom ou sa marque sur un système à haut risque déjà mis sur le marché, s'il y apporte une modification substantielle ou s'il modifie la destination d'un système non classé à haut risque de sorte qu'il le devienne (art. 25(1)). Voir la section 12.4.
Dérogation	waiver; exception	Exception écrite, temporaire et compensée à une exigence du cadre, accordée pour un agent ou un composant précis par le comité (ou, par délégation, par l'architecture d'entreprise pour un agent de classe faible, alors pour 90 jours au plus), pour six mois au plus et renouvelable une seule fois. Aucune dérogation n'est possible sur les points de l'EXIG-GOV-17, qui en tient la liste, notamment le niveau NX, une action P3 sans approbation humaine hors bande, l'usurpation d'identité, un agent sans fiche au registre ou sans parrain nommé, le dépassement du plafond d'autonomie, la réunion des trois propriétés de la triade létale, l'absence de journal d'audit et toute obligation légale. Voir la section 11.6.
Domaine de conception opérationnel (ODD), aussi appelé « domaine d'exploitation » dans le cadre	operational design domain	Notion de la conduite automatisée des véhicules routiers, empruntée par analogie; la taxonomie SAE J3016 est une pratique recommandée et non une norme de sécurité[304]. Dans le cadre, périmètre documenté (systèmes, données, outils, seuils, volumes, plages horaires) hors duquel un agent s'arrête en état sûr, compense ou escalade. Il est exigé aux niveaux N3 et N4; le niveau N4 suppose un ODD certifié. Voir la section 8.1.
Échec en mode fermé	fail-closed	Comportement par lequel un composant refuse ou suspend plutôt que d'agir lorsqu'il ne peut pas obtenir une décision valide : service de politiques ou d'approbation indisponible, politique absente, doute. La passerelle d'agents n'ouvre jamais le passage par défaut, et l'orchestrateur suspend la tâche dans un état reprenable. L'échec se fait vers l'avant : les compensations des étapes exécutées passent par le canal de compensation (EXIG-ORC-17), et une politique en cache vaut décision valide tant qu'elle n'est pas échue (EXIG-ORC-18). Voir les sections 8.4 et 9.4.
Empoisonnement d'outil	tool poisoning	Attaque qui cache des instructions malveillantes dans la description, le schéma ou les valeurs de retour d'un outil. L'ombrage (tool shadowing), variante voisine, laisse la description d'un serveur malveillant modifier l'usage des outils d'un autre serveur[221]. Le cadre y répond

Terme (sigle)	Équivalent anglais	Définition
		par l'épinglage des définitions par empreinte et par l'isolement de chaque serveur. Voir les sections 6.5 et 9.8.
Empreinte	digest; fingerprint	Condensé cryptographique, par exemple SHA-256, calculé sur un contenu canonisé selon la RFC 8785 (JCS), RFC informative de la filière indépendante[236]. Le cadre s'en sert pour épingler les définitions approuvées des outils et des cartes, tout écart bloquant l'appel jusqu'à une nouvelle approbation, et pour lier une approbation à l'action exacte : h = SHA-256(JCS({outil, version, definition_digest, agent_id, task_id, arguments})), où l'outil est désigné par son identifiant pleinement qualifié (serveur et nom). h atteste que les octets transmis sont ceux qui ont été approuvés, non que l'effet est celui qui était attendu. Voir les sections 6.8 et 8.5.
Entreprise agentique	agentic enterprise	Organisation où des agents exécutent une part croissante des processus, aux côtés des personnes et des systèmes existants, sous une supervision humaine proportionnée au risque. Voir la section 2.1.
Enveloppe budgétaire	task budget envelope	Ensemble des plafonds attribués à une tâche à son ouverture (jetons, coût, appels d'outils, itérations, durée d'exécution et durée totale), transmis avec les montants restants à chaque appel descendant. L'atteinte d'un plafond arrête la boucle en état sûr et déclenche l'escalade prévue; elle n'est jamais rapportée comme un succès. Voir les sections 7.8 et 10.6.
Environnement serveur	server environment	Tout environnement d'exécution autre qu'un poste de développement individuel sans justificatif de production : développement partagé, préproduction et production, mais aussi poste de travail, navigateur, mobile ou périphérie dès qu'un agent y agit sur des systèmes ou des données de l'entreprise. Le passage par la passerelle y est obligatoire (EXIG-ARC-01). Voir la section 3.1.
Équipe rouge	red team	Équipe indépendante de l'équipe de développement qui attaque un agent comme le ferait un adversaire : détournement d'objectif, exfiltration, empoisonnement d'outil et de mémoire, abus de délégation. Le cadre l'exige avant la mise en production des agents de classe modérée ou élevée, de niveau N3 ou N4 ou consommant du contenu non fiable, puis au moins chaque année (EXIG-SEC-23). Voir la section 9.9.
Évaluation continue	continuous evaluation	Mesure répétée de la qualité, de la sécurité et du coût d'un agent, avant et pendant la production, en trois étages (E1 à E3) : tests de contrats, jeux de trajectoires, y compris adverses, et échantillon du trafic réel. Elle est relancée à chaque changement visé par l'EXIG-GOV-12, et ses résultats conditionnent l'homologation. Voir la section 10.4.
Évaluation des facteurs relatifs à la vie privée (EFVP)	privacy impact assessment (PIA)	Évaluation exigée par la Loi sur le privé pour tout projet d'acquisition, de développement ou de refonte d'un système d'information impliquant des RP (art. 3.3) et avant toute communication de RP hors du Québec, autres provinces comprises (art. 17)[160]; pour un organisme public, l'article 63.5 de la Loi sur l'accès prévoit l'évaluation des projets de système d'information. Le cadre l'exige terminée avant le pilote, avec un inventaire des RP par outil, par délégation et par mémoire. Voir la section 12.2.
Exécutant	worker; subagent	Agent auquel un orchestrateur délègue une sous-tâche et qui rend une synthèse conforme au schéma de retour déclaré, ses livrables volumineux étant transmis par référence. Le cadre limite la délégation à deux niveaux : un exécutant ne délègue pas à son tour sans dérogation. Voir les sections 7.2 et 7.7.
Exécution durable	durable execution	Mode d'exécution dans lequel un moteur persiste l'état d'une tâche hors du processus après chaque transition, de sorte qu'elle reprend où elle s'était arrêtée après une panne, un redéploiement ou une longue attente d'approbation. La persistance n'empêche pas, à elle seule, qu'une action soit répétée : les effets doivent aussi être idempotents. Voir la section 7.4.

Terme (sigle)	Équivalent anglais	Définition
Existant inventorié	inventoried legacy agent (terme du cadre)	Statut d'un agent en exploitation à l'adoption du cadre, ou découvert ensuite hors registre : il reçoit une fiche minimale (champs de l'étape Proposition) et un parrain nommé dans les cinq jours ouvrables qui suivent sa découverte, faute de quoi il est désactivé (section 11.6, EXIG-GOV-16).
Fiche d'agent	agent record (terme du cadre)	Entrée du registre d'entreprise qui décrit un agent : elle s'ouvre à l'étape Proposition, se complète au fil du cycle de vie et doit être complète avant tout jeton d'exécution en production (EXIG-GOV-07). Voir la section 11.4 et l'annexe B.
FinOps	FinOps	Pratique de gestion financière qui maximise la valeur d'affaires de la technologie et rend les coûts imputables; le cadre FinOps cite la dépense d'IA agentique (par exemple pour la productivité des développeurs) comme pouvant former un périmètre de dépenses (Scope) distinct[406, 469]. La spécification FOCUS normalise les données de facturation, pas les indicateurs par agent : le coût par tâche réussie se calcule en joignant ces données à la télémétrie et aux résultats métier. Voir les sections 10.5 et 10.6.
Flux déterministe	deterministic workflow	Séquence prédéterminée (graphe ou machine à états) dont le code fixe le chemin; certaines étapes peuvent appeler un modèle ou un agent borné pour traiter de l'information non structurée, ce qu'on appelle aussi un flux de travail assisté par IA. Anthropic distingue de même les flux de travail, orchestrés par des chemins de code prédéfinis, des agents, où le modèle dirige son propre processus[65]. C'est le patron par défaut du cadre. Un flux sans choix d'action laissé à un modèle relève de N0; un flux assisté par IA est inscrit au registre avec le niveau qui correspond à ses écritures déclenchées par une sortie de modèle. Voir les sections 3.2 et 7.2.
Garde-fou	guardrail	Contrôle automatisé qui filtre ou valide les entrées, les sorties ou les actions d'un agent : validation de schéma, détection d'injection, masquage des RP et des secrets. Il s'applique à l'entrée, aux appels d'outils, aux réponses d'outils et à la sortie finale. Un garde-fou probabiliste réduit le risque sans l'éliminer et ne remplace jamais un contrôle déterministe. Voir les sections 7.7 et 9.6.
Homologation	go-live approval	Décision consignée au registre qui autorise la mise en production d'un agent à un niveau d'autonomie donné, sur la foi de preuves : rapport d'évaluation, tests de sécurité, EFVP au besoin et grille d'homologation de l'annexe A. Le responsable technique d'un agent ne peut pas l'homologuer. Voir la section 11.5 et l'annexe A.
Hors bande	out-of-band	Se dit d'une approbation donnée sur un appareil et dans une session d'authentification distincts de ceux de l'agent (et non une session au sens des EXIG-SEC-04 et EXIG-SEC-06), avec une authentification forte résistante à l'hameçonnage; une confirmation locale dans l'interface de l'agent ne suffit pas. Le cadre l'exige pour tout appel P3 (EXIG-AUT-09) et recommande CIBA (EXIG-AUT-14). Voir la section 8.5.
Humain dans la boucle (HITL)	human in the loop	Mode de supervision dans lequel une personne approuve chaque action en écriture avant son exécution, au moyen d'une approbation liée à l'action exacte; il caractérise le niveau N2. Voir les sections 8.1 et 8.5.
Humain sur la boucle (HOTL)	human on the loop	Mode de supervision dans lequel l'agent agit seul sous des seuils déclarés, tandis qu'une personne supervise par exception, traite les escalades, peut interrompre et revoit a posteriori un échantillon des actions; il caractérise le niveau N3. Au niveau N4, la personne est hors de la boucle d'exécution, mais reste sur la boucle de gouvernance. Voir la section 8.1.
IA fantôme	shadow AI	Usage de l'IA hors de la gouvernance de l'entreprise. Un agent fantôme est un agent créé ou exploité hors du registre, sans parrain nommé ni moyen de révocation; le cadre le détecte par un rapprochement mensuel du registre avec des sources indépendantes et le

Terme (sigle)	Équivalent anglais	Définition
		place en quarantaine jusqu'à son inscription ou son retrait. Voir les sections 2.1 et 11.4.
Idempotence	idempotency	Propriété d'une opération dont l'exécution répétée produit le même effet qu'une exécution unique. Le cadre exige, pour toute écriture P2 ou P3, une clé d'idempotence dérivée de l'identifiant de la tâche racine et de celui de l'étape, réutilisée à chaque réessai et vérifiée par le système qui produit l'effet, ou par un adaptateur doté d'un registre de clés durable (EXIG-ORC-22); le service rejette une clé déjà vue avec des arguments différents, une étape replanifiée reçoit un nouvel identifiant, et la conservation des clés couvre toute la fenêtre de rejeu; l'en-tête `Idempotency-Key` n'est encore qu'un brouillon de l'IETF (Internet Engineering Task Force)[78]. Voir la section 7.6.
Identité non humaine	non-human identity (NHI)	Identité attribuée à une charge de travail, à un service ou à un agent plutôt qu'à une personne. Dans le cadre, chaque agent possède la sienne, fondée sur un justificatif cryptographique de courte durée émis par la plateforme, jamais partagée ni utilisée par une personne. L'OWASP Non-Human Identities Top 10 (2025) en recense les dix risques principaux, de NHI1 à NHI10[470]. Voir la section 9.2.
Incident grave	serious incident	Au sens du cadre, tout incident de gravité S1 ou S2, sur l'échelle S1 à S4 qu'attribue la fonction risques et conformité, ainsi que tout incident grave au sens du RIA (art. 3(49)). Il déclenche notamment la réévaluation de l'EXIG-GOV-12. Voir la section 12.8.
Injection d'instructions	prompt injection	Attaque par laquelle un texte placé par un tiers dans un contenu que lit le modèle (page Web, document, réponse d'outil, message d'agent) est interprété comme une consigne; elle est dite indirecte lorsqu'elle n'arrive pas par la personne qui utilise l'agent. Le cadre présume l'injection possible dès qu'un modèle lit du contenu non fiable, comme le recommande le NIST[97]. Voir la section 9.6.
Interopérabilité	interoperability	Capacité de systèmes et d'agents hétérogènes à échanger de l'information et à l'utiliser correctement sans adaptation propre à chaque paire. Le cadre l'examine aux quatre niveaux du Cadre européen d'interopérabilité (EIF, 2017) : juridique, organisationnel, sémantique et technique, sous une gouvernance intégrée[157]. Voir la section 6.1.
Invite	prompt	Texte d'instructions et de contexte fourni à un modèle. L'invite système d'un agent relève de sa mémoire procédurale et se gère comme du code : revue, version, évaluation avant déploiement. Dans MCP, une invite est aussi une primitive serveur, soit un gabarit réutilisable obtenu par `prompts/get`. Voir les sections 5.5 et 6.5.
Jeton (unité de texte)	token	Unité de texte que lit ou produit un modèle de langage; elle sert d'unité de mesure de la consommation et de la facturation de l'inférence. À ne pas confondre avec le jeton d'accès OAuth, qui porte des droits. Voir les sections 10.5 et 10.6.
Jeton d'approbation	approval token	Jeton signé par le service d'approbation adossé au fournisseur d'identité, qui contient au minimum l'émetteur, l'audience, l'empreinte de l'action approuvée, le pseudonyme de l'approbateur et son rôle (mandant ou tiers), les identifiants de la tâche et de l'agent, une date d'expiration et un identifiant de jeton. Il est remis à la passerelle, qui le conserve hors du contexte du modèle, et couvre une seule opération, réessais compris; une double approbation se fait par deux jetons sur la même empreinte. La passerelle recalcule l'empreinte avant l'exécution; le cadre en limite la validité à 15 minutes. Voir la section 8.5 et l'annexe C.
Jeton délégué	delegated token	Jeton d'accès obtenu à chaque saut par échange de jetons (RFC 8693); le cadre l'exige de courte durée et à audience unique. Il désigne le mandant (`sub`) et l'agent courant (`act`), avec un `act` imbriqué par acteur antérieur[70]. Sa portée ne dépasse jamais les droits effectifs, soit droits du mandant ∩ portée de l'agent ∩ portée de la tâche (choix du cadre) : le serveur d'autorisation borne la portée à chaque échange, la portée de la tâche figurant dans `authorization_details`,

Terme (sigle)	Équivalent anglais	Définition
		et le serveur de ressources applique à chaque appel les droits du mandant d'après `sub`. Son expiration ne dépasse jamais celle du jeton reçu, si bien qu'aucun échange ne prolonge une délégation. Il se distingue du mandat d'un agent ambiant. Voir la section 9.3 et l'annexe C.
Jeton lié à l'expéditeur	sender-constrained token	Jeton d'accès lié à une clé ou à un certificat que seul son détenteur légitime peut présenter : mTLS (RFC 8705, revendication `cnf` « `x5t#S256` ») dans le maillage de services, ou DPoP (RFC 9449, preuve JWT à chaque requête) hors du maillage. La RFC 9700 recommande cette contrainte[175]; le cadre l'exige pour tout jeton qui donne accès à un outil P2 ou P3 ou que détient un agent de classe élevée. Voir la section 9.3.
Journal d'audit	audit log	Enregistrement chaîné, signé et ancré hors du domaine d'administration du service d'audit, distinct des traces, de chaque action d'agent : mandant, agent et version, outil et empreinte de ses arguments, modèle et version, approbation, identifiants de tâche et de trace, règle appliquée par la passerelle. Il sert à la preuve, à l'explication des décisions et à l'enquête. Voir la section 10.3.
Loi 25	Law 25; Act to modernize legislative provisions as regards the protection of personal information	Loi modernisant des dispositions législatives en matière de protection des renseignements personnels (L.Q. 2021, c. 25), en vigueur dans son ensemble depuis le 22 septembre 2024, dernière étape (droit à la portabilité)[7, 56]. Elle modifie la Loi sur la protection des renseignements personnels dans le secteur privé (RLRQ, c. P-39.1, « Loi sur le privé ») et la Loi sur l'accès aux documents des organismes publics et sur la protection des renseignements personnels (RLRQ, c. A-2.1, « Loi sur l'accès »). Voir la section 12.2.
Loi sur la protection des renseignements personnels et les documents électroniques (LPRPDE)	Personal Information Protection and Electronic Documents Act (PIPEDA)	Loi fédérale en vigueur. En cas d'atteinte présentant un risque réel de préjudice grave, elle impose la déclaration au Commissariat et l'avis aux personnes « le plus tôt possible » (par. 10.1(2) et (6)), et la consignation de toutes les atteintes pendant 24 mois. Voir la section 12.3 (tableau 48).
Maillage	mesh	Terme à trois sens dans le cadre. (1) L'enchevêtrement des connexions point à point entre N agents et M systèmes, que le cadre remplace par N + M contrats communs derrière la passerelle (chapitre 2, PRIN-01). (2) Le maillage de services (service mesh), dans lequel les services s'authentifient mutuellement, par exemple en mTLS avec des X.509-SVID (sections 9.3 et 9.4). (3) Le maillage libre, patron où chaque agent sollicite les autres sans plafond, que le cadre interdit (section 7.2). Le cadre n'emploie pas « maillage d'agents » : le point d'application des politiques y est la passerelle d'agents (voir PEP).
Mandant	principal	Personne ou application au nom de laquelle une tâche est exécutée; pour un déclencheur système, identité du service et de son responsable nommé. Le mandant d'une chaîne est toujours l'entité d'origine : un agent intermédiaire n'y apparaît que comme acteur (`act`). Le mandant est établi à l'entrée, transporté dans chaque appel par le jeton délégué et consigné au journal d'audit; les droits d'un agent ne dépassent jamais les siens. Voir les sections 5.2 et 9.3.
Mandat	standing mandate	Consentement de longue durée, inscrit au serveur d'autorisation, par lequel un mandant autorise un agent ambiant à agir pour lui. Tant que le mandat est valide et le mandant actif, le serveur d'autorisation émet à la demande de l'agent des jetons d'au plus 15 minutes, dont le sujet est le mandant et l'acteur l'agent. Il se distingue du jeton délégué, de courte durée. Voir les sections 8.6 et 9.3.
Matrice RACI	RACI matrix	Tableau qui attribue chaque activité du cycle de vie d'un agent à un rôle qui réalise (R), à un seul rôle qui approuve et répond (A), aux rôles consultés (C) et aux rôles informés (I). Voir la section 11.2 (tableau 44).
MCP (Model Context Protocol)	Model Context Protocol	Protocole ouvert d'intégration verticale qui relie un agent à des outils, à des ressources et à des invites exposés par des serveurs; l'hôte,

Terme (sigle)	Équivalent anglais	Définition
		soit l'application d'IA, crée un client MCP par serveur. Annoncé par Anthropic le 25 novembre 2024 et confié à l'AAIF le 9 décembre 2025, il est versionné par date[20, 34]. Le cadre retient la révision 2026-07-28, sans état, exposée par Streamable HTTP en environnement serveur (choix du cadre). Voir la section 6.5.
Mémoire d'agent	agent memory	Ce qu'un agent conserve au-delà d'un appel au modèle. La taxonomie CoALA distingue une mémoire de travail et trois mémoires à long terme : épisodique (expériences passées), sémantique (connaissances) et procédurale (savoir-faire)[100]; le cadre limite cette dernière aux invites système, aux contrats de compétences et aux flux d'outils validés. Le contexte du modèle n'est pas une mémoire, et la mémoire procédurale se gère comme du code. Voir la section 5.5.
Mesure transitoire de cohorte	cohort transitional measure (terme du cadre)	Décision unique du comité qui place une liste d'agents existants sous un régime transitoire dont l'échéance est liée à un jalon de la feuille de route : elle n'admet aucun point de l'EXIG-GOV-17 ni aucune obligation légale et ne couvre jamais un dépassement du plafond de la classe (section 11.6, EXIG-GOV-16).
Modèle	model; large language model (LLM)	Composant probabiliste, le plus souvent un grand modèle de langage, qui produit une sortie à partir d'une invite. Un agent désigne ses modèles par un alias logique et ne les appelle que par la passerelle de modèles; la version réellement servie est consignée dans la télémétrie, et tout changement de modèle déclenche une réévaluation. Voir les sections 5.2 et 11.5.
Moindre agence	least agency	Principe de l'OWASP selon lequel les outils et l'autonomie d'un agent se limitent à ce que la tâche exige : un comportement agentique déployé sans nécessité élargit la surface d'attaque sans ajouter de valeur[28]. Il complète le moindre privilège dans le principe PRIN-03. Voir les sections 4.1 et 8.1.
Niveau d'autonomie	autonomy level	Niveau déclaré au registre, de N1 à N4, borné par le plafond de la classe de risque (EXIG-CON-02), qui fixe le rôle de la personne et ce que l'agent peut faire sans approbation : N1 consultatif, sans écriture; N2 exécution approuvée (HITL); N3 autonomie bornée et supervisée (HOTL); N4 autonomie étendue sous ODD certifié, qui couvre l'exécution sans approbation de tâches déclenchées sans demande d'une personne (événement, horaire), origine que la passerelle lit pour appliquer le niveau inscrit. N0 qualifie un flux déterministe, où aucun choix d'action n'est laissé à un modèle : c'est un repère hors de la portée agentique, non un niveau d'agent. NX, l'autonomie non bornée, est interdite. Le niveau ne dépend ni du nombre d'agents ni de la capacité du modèle. Voir la section 8.1.
OAuth 2.0 et **OAuth 2.1**	OAuth 2.0; OAuth 2.1	Cadre d'autorisation de l'IETF. Le cadre se réfère à OAuth 2.0 profilé par la RFC 9700 (BCP 240, janvier 2025). OAuth 2.1 reste un Internet-Draft, dont la version –16 date de septembre 2026[175, 176] : le cadre s'aligne sur son profil (PKCE, ni octroi implicite ni octroi par mot de passe) sans le présenter comme une norme publiée. Voir les sections 6.3 et 9.3.
OBO	On-Behalf-Of	Patron de délégation par lequel un service obtient un jeton pour agir au nom d'un utilisateur; ce n'est pas une norme. Le flux OBO de Microsoft Entra, par exemple, repose sur l'octroi `jwt-bearer` et non sur la RFC 8693[326], que le cadre retient comme référence normative en profilant au catalogue les variantes des fournisseurs. Voir la section 9.3.
OpenTelemetry	OpenTelemetry (OTel)	Projet de la CNCF qui normalise la production et l'export des traces, des métriques et des journaux (API, SDK, protocole OTLP). Ses conventions sémantiques GenAI, qui nomment les spans et les attributs des modèles, des agents et des outils, sont au niveau de stabilité Development : un nom peut y changer sans processus de dépréciation[181, 188]. Le cadre en épingle donc une version. Voir la section 10.1.

Terme (sigle)	Équivalent anglais	Définition
Orchestrateur	orchestrator	Composant déterministe, agentique ou hybride qui décompose une demande, affecte les tâches à des agents ou à des outils, suit l'état, gère la reprise et consolide les résultats. Il choisit un chemin, mais n'accorde ni n'élargit aucun droit. Voir les sections 5.2 et 7.2.
Outil	tool	Capacité exposée à un agent (fonction, requête, action), décrite par un contrat d'entrée et de sortie et exécutée par un serveur MCP ou un adaptateur; un outil n'a aucune autonomie de décision. Règle du cadre : une cible est un agent si elle choisit elle-même, au moyen d'un modèle, les actions qu'elle exécute; sinon c'est un outil, même si elle emploie un modèle en interne, conserve l'état d'une tâche ou demande une précision (Tasks, élicitation MCP). Chaque outil reçoit un palier au catalogue. Voir les sections 6.2 et 6.5.
OWASP Top 10 agentique (ASI)	OWASP Top 10 for Agentic Applications	Référentiel de menaces publié le 9 décembre 2025 par l'OWASP GenAI Security Project, de ASI01 (détournement de l'objectif de l'agent) à ASI10 (agents dévoyés)[28]. Le cadre en fait la base de la modélisation des menaces, obligatoire pour les agents de classe modérée ou élevée. Voir la section 9.5.
Palier d'outil	tool risk tier	Classement d'un outil selon l'effet de ses appels : P0 lecture publique; P1 lecture interne ou sensible; P2 écriture réversible, ou compensable vers un état métier équivalent avec un impact borné, avec approbation au-delà d'un seuil; P3 action critique, externe ou irréversible, même si une compensation est déclarée, jamais exécutée seule par un agent. Le palier est attribué au catalogue après revue, jamais déduit des annotations du serveur; un outil d'écriture sans compensation déclarée est classé P3. Voir la section 8.3.
Passage de jeton (ou relais de jeton)	token passthrough	Fait de retransmettre tel quel à un autre service un jeton reçu. La spécification d'autorisation MCP l'interdit[209], et le cadre étend l'interdiction à tout agent, outil ou serveur : chaque audience exige un nouveau jeton, obtenu par échange de jetons. Voir les sections 6.5 et 9.3.
Passerelle d'agents	agent gateway	Mandataire placé sur tout le trafic MCP et A2A et sur toute action P2 ou P3, quel que soit le domaine (EXIG-ARC-01), inverse en entrée et de sortie en sortie, qui sert de point d'application des politiques; ses instances, y compris au plus près de l'agent (sidecar), partagent la politique, le registre des `jti` et le journal d'audit. À chaque appel, elle authentifie l'agent et le mandant, vérifie le catalogue, autorise, applique les garde-fous, vérifie l'approbation, limite le budget, injecte les justificatifs en aval et filtre la sortie; elle trace l'appel et, pour un appel P2 ou P3, journalise l'intention avant de le relayer et l'issue ensuite. Voir les sections 5.2 et 9.4.
Passerelle de modèles	model gateway; LLM gateway	Point de passage obligatoire de tout appel d'inférence : elle centralise les identifiants des fournisseurs, résout les alias logiques, assure le routage, le repli, le cache et les quotas de jetons, et impute les coûts. Aucun agent ne détient de clé de fournisseur de modèles ni n'appelle un fournisseur directement. Voir la section 5.2.
Patron d'orchestration	orchestration pattern	Topologie de coordination déclarée au registre parmi les huit patrons autorisés : flux déterministe, chaîne séquentielle, routage et transfert, parallélisation, orchestrateur et exécutants, évaluateur-optimiseur, chorégraphie événementielle et agent unique outillé; le clavardage de groupe en est une variante encadrée. Le patron est distinct du niveau d'autonomie. Voir les sections 7.2 et 7.3.
Plan de contrôle	control plane	Services qui distribuent aux instances de la passerelle les politiques, les entrées du catalogue et les états du registre; avec le fournisseur d'identité, il tient le rôle d'administrateur de politiques (section 9.1). Sa panne n'ouvre aucun passage : la dernière politique distribuée vaut jusqu'à son échéance, puis seuls les appels P0 passent, et la liste de suspension voyage par un canal signé qui en est indépendant (EXIG-ORC-18). Voir la section 9.4.
Plan transversal	cross-cutting plane	Ensemble de services communs fournis à toutes les couches de l'architecture de référence : A Identité et sécurité; B Observabilité,

Terme (sigle)	Équivalent anglais	Définition
		évaluation et FinOps; C Gouvernance et registre. L'équipe plateforme les fournit une fois; un projet n'en déploie pas d'équivalent parallèle sans dérogation. Voir la section 5.3.
Point d'application des politiques (PEP)	policy enforcement point	Composant logique de la confiance zéro qui ouvre, surveille et termine les connexions selon la décision du moteur de politiques (PE), l'administrateur de politiques (PA) établissant ou coupant le chemin; PE et PA forment ensemble le point de décision des politiques (PDP) de la même architecture[112]. Dans le cadre, la passerelle d'agents et la passerelle de modèles sont des PEP, le service de politiques tient le rôle de PE, et le fournisseur d'identité et le plan de contrôle des passerelles tiennent celui de PA. Voir la section 9.1.
Point de contrôle	checkpoint	(1) Instantané persistant de l'état complet d'une tâche, pris à chaque transition par le moteur d'exécution durable; il constitue une frontière de confiance et se protège comme une donnée de production. (2) Dans le journal d'audit, état signé et daté de la tête d'un flux (numéro de séquence, empreinte), publié hors du domaine d'administration du service d'audit (EXIG-OBS-12). Le terme ne désigne pas les jalons du cycle de vie d'un agent (section 11.5), que la figure 25 nomme encore « points de contrôle ». Voir les sections 7.4, 10.3 et 11.5.
Propriétaire métier (parrain)	business owner; sponsor	Personne nommée qui répond de la finalité, des résultats, des effets et du retrait d'un agent; elle demande son niveau d'autonomie, le finance et atteste au moins tous les 12 mois, tous les 6 mois pour la classe élevée, qu'il est encore requis. Ce n'est jamais une équipe ni un fournisseur. Le rôle reprend la notion de parrain de Microsoft Entra Agent ID, sans dépendre du produit. Voir la section 11.1.
Registre d'entreprise	enterprise agent registry	Inventaire faisant autorité des agents et des serveurs MCP qui agissent dans le périmètre de l'entreprise, qu'ils soient internes, intégrés à un logiciel-service ou exploités par un partenaire. Chacun y a une fiche (propriétaires, finalité, classe de risque, niveau d'autonomie, outils et paliers, modèles, données, état du cycle de vie); sans fiche complète, aucun justificatif de production. Il est distinct du registre officiel MCP, en préversion, qui ne prend pas en charge les serveurs privés[43]. Voir la section 11.4 et l'annexe B.
Règle d'or	golden rule (terme du cadre)	Règle propre au cadre : un agent dont le rayon d'impact, la réversibilité et le délai de détection atteignent les seuils d'étalonnage approuvés par le comité (rayon élevé, réversibilité faible, détection lente) ne peut être autorisé au-delà de N2, quels que soient ses résultats aux bancs d'essai (EXIG-AUT-07; point non dérogeable, EXIG-GOV-17). Voir la section 8.2.
Règlement européen sur l'IA (RIA)	EU Artificial Intelligence Act (AI Act)	Règlement (UE) 2024/1689, en vigueur depuis le 1er août 2024 et modifié par le règlement (UE) 2026/1744, qui reporte au 2 décembre 2027 les obligations des systèmes à haut risque de l'annexe III et au 2 août 2028 celles de l'annexe I[58, 61]. Il vise aussi les fournisseurs et les déployeurs établis hors de l'Union lorsque les sorties du système y sont utilisées. Voir la section 12.4.
Renseignements personnels (RP)	personal information	Renseignements qui concernent une personne physique et permettent de l'identifier, au sens de la Loi sur le privé et de la Loi sur l'accès; un renseignement dépersonnalisé demeure un renseignement personnel. Le cadre traite comme des RP les inférences qu'un agent produit sur une personne et les plongements vectoriels (embeddings) calculés à partir de RP. Voir la section 12.2.
Responsable de la protection des renseignements personnels (RPRP)	person in charge of the protection of personal information	Fonction exercée par la personne ayant la plus haute autorité dans l'entreprise, qui peut la déléguer par écrit (art. 3.1 de la Loi sur le privé)[160]. Le cadre le consulte dès le début de tout projet d'agent impliquant des RP et lui confie l'encadrement des EFVP et des incidents de confidentialité. Voir la section 11.1.
Ressource	resource	Primitive MCP : donnée contextuelle adressée par URI, lue par `resources/read` et pouvant être mise en cache; pour le cadre, cette lecture n'a aucun effet de bord. Elle convient lorsque l'entité à char-

Terme (sigle)	Équivalent anglais	Définition
		ger est connue d'avance; une recherche, un calcul ou une écriture relèvent d'un outil. Voir la section 6.5.
Saga	saga	Patron défini par Garcia-Molina et Salem en 1987[284], qui remplace une transaction globale par une suite de transactions locales, chacune appariée à une compensation; les étapes compensables précèdent le pivot, point de non-retour, que suivent des étapes réessayables[67]. Le cadre l'exige pour toute tâche qui écrit dans plusieurs systèmes d'enregistrement sans transaction commune. Voir la section 7.5.
Serveur MCP	MCP server	Programme qui expose des outils, des ressources et des invites par MCP; c'est un adaptateur sans état cognitif, qui ne raisonne pas. Dans l'entreprise, tout serveur MCP est inscrit au registre et au catalogue, publié derrière la passerelle d'agents et traité comme un domaine de sécurité distinct. Voir les sections 6.5 et 11.4.
Service de politiques	policy service	Composant qui évalue les politiques d'autorisation et rend la décision qu'applique la passerelle (rôle de PE au sens de la confiance zéro); il fait partie du plan de contrôle. S'il est injoignable, la dernière politique distribuée vaut service disponible tant qu'elle n'est pas échue; échue, seuls les appels P0 passent (EXIG-AUT-11, EXIG-ORC-18). Voir les sections 8.4 et 9.4.
Session	session	Au sens des EXIG-SEC-04 et EXIG-SEC-06 : la tâche racine et tout ce qui en dérive (sous-tâches, délégations A2A, reprises depuis un point de contrôle, événements publiés au titre de la tâche). Son état (contenu non fiable consommé, données sensibles consultées) est tenu par la passerelle dans un magasin à cohérence forte; un état illisible impose le refus. Un contexte vierge exclut tout rechargement de mémoire, de point de contrôle ou d'artefact étiqueté postérieur à la contamination. Voir les sections 3.1 et 9.6.
SPIFFE, **SPIRE** et **SVID**	Secure Production Identity Framework For Everyone; SPIFFE Runtime Environment; SPIFFE Verifiable Identity Document	Standard et mise en œuvre de référence de l'identité de charge de travail, projets de la CNCF au stade « Graduated ». Un SPIFFE ID prend la forme `spiffe://domaine-de-confiance/chemin`; le justificatif, ou SVID, existe en X.509-SVID, à privilégier et renouvelé automatiquement, et en JWT-SVID, de courte durée et redemandé au besoin; la Workload API délivre les deux sans secret préalable[322, 471]. Voir la section 9.2.
Substitution après approbation	rug pull	Attaque par laquelle l'éditeur d'un serveur ou d'un outil en modifie les définitions une fois celui-ci approuvé, par exemple pour y glisser de nouvelles consignes. La passerelle d'agents la neutralise en comparant à chaque appel l'empreinte des définitions présentées à celle qui est épinglée au catalogue. Voir les sections 6.5 et 9.8.
Système de management de l'IA (SMIA)	AI management system	Système de management dont ISO/IEC 42001:2023 spécifie les exigences selon la structure harmonisée des normes de systèmes de management (articles 4 à 10), complétée par 38 mesures en annexe A; la norme est certifiable par tierce partie (ISO/IEC 42006:2025)[450, 451]. À ne pas confondre avec le brouillon IETF WIMSE « AI Identity Management System » (AIMS), qui porte sur l'identité des agents. Voir la section 12.5.
Système d'enregistrement	system of record	Système qui fait foi pour une donnée de l'entreprise : ERP, CRM, système de dossiers, entrepôt de données, logiciel-service. Un agent n'y écrit que par une interface qui applique les contrôles métier de ce système, jamais par un accès direct aux tables. Voir la section 5.2.
Système d'IA	AI system	Selon l'article 3(1) du RIA, système automatisé conçu pour fonctionner à différents niveaux d'autonomie, qui peut faire preuve d'adaptabilité après son déploiement et qui déduit, à partir des entrées qu'il reçoit, la manière de générer des sorties (prédictions, contenus, recommandations ou décisions) pouvant influencer des environnements physiques ou virtuels[61]. Le cadre considère tout agent comme un système d'IA. Voir la section 12.4.
Tâche (A2A)	task	Unité de travail A2A créée par l'agent serveur, qui lui attribue son identifiant (`taskId`); `contextId` regroupe les tâches et les

Terme (sigle)	Équivalent anglais	Définition
		messages d'une même interaction. Une tâche suit une machine à huit états de cycle de vie (l'énumération compte neuf valeurs avec `TASK_STATE_UNSPECIFIED`), dont deux états interrompus (`INPUT_REQUIRED`, `AUTH_REQUIRED`) et quatre états terminaux, et produit des artefacts composés de parties (Part)[68]. Voir la section 6.6.
Traçage	distributed tracing	Reconstitution de bout en bout du chemin d'une demande au moyen de traces OpenTelemetry, faites de spans reliés par un même contexte W3C Trace Context (en-tête `traceparent`), défini pour HTTP; le cadre exige de le propager aussi dans le champ `_meta` de MCP, dans A2A et dans l'extension CloudEvents Distributed Tracing[103, 162, 253]. Le `traceparent` n'est pas un identifiant métier, et la trace ne remplace pas le journal d'audit. Voir la section 10.1.
Transfert	handoff	Cession explicite du contrôle d'une session, avec son contexte utile, d'un agent source vers un agent cible mieux qualifié; l'agent source se retire. Le transfert vise une liste fermée de destinataires et porte le mandant, pas tout l'historique. Voir la section 7.2.
Triade létale	lethal trifecta	Combinaison, nommée par Simon Willison, de l'accès à des données privées, de l'exposition à du contenu non fiable et de la capacité de communiquer vers l'extérieur, qui rend l'exfiltration possible[354]. La « règle de deux » de Meta en tire une règle de session : sans supervision, au plus deux de trois propriétés, soit [A] traiter des entrées non fiables, [B] accéder à des systèmes sensibles ou à des données privées, [C] modifier un état ou communiquer vers l'extérieur[307]. Le cadre l'évalue sur la session composée, à travers délégations, mémoire et événements, et la passerelle l'applique à l'exécution (EXIG-SEC-04). Voir la section 9.6.

F Validation des sources et des ébauches

Cette annexe rend compte de la vérification qui fonde la version 1.0 : comment les 121 références de la recherche documentaire ont été validées, ce que la vérification a révélé, et quelles affirmations des ébauches ont été corrigées ou retirées. Elle permet de retracer l'origine des faits de la version 1.0 et le degré de confiance qu'on peut leur accorder; ses limites sont dites en F.1 et à la légende du tableau 69.

F.1 Méthode

La vérification s'est déroulée en trois passes, les 27 et 28 octobre 2026.

1. **Validation référence par référence.** Chacune des 121 références de la recherche documentaire a fait l'objet d'une tentative d'ouverture; pour les 13 pages bloquées, payantes ou redirigées, on s'est limité au résumé public ou à une source primaire. On a consigné son accessibilité, son éditeur, sa date et sa catégorie de crédibilité, puis confronté chaque affirmation qui la citait au contenu réel de la page (427 liens affirmation-source au total). Lorsqu'une page n'appuyait pas une affirmation, une source primaire a été recherchée pour la confirmer ou la réfuter.
2. **Vérification thématique.** Onze vérifications ont confronté les affirmations des quatre ébauches aux textes primaires : MCP; A2A et protocoles connexes; plateformes et fondations; identité; sécurité; observabilité, contrats et événements; orchestration; autonomie; droit québécois et canadien; référentiels internationaux; économie et données de marché. Elles ont aussi recueilli les faits complémentaires intégrés au cadre.
3. **Audit final.** Le 28 octobre 2026, chacune des 428 références alors citées dans le corps du cadre a été rouverte à sa source et confrontée, affirmation par affirmation, aux passages qui s'y appuient (1 409 affirmations examinées). L'identité de chaque référence (auteurs, titre, date, éditeur), sa catégorie et son statut à cette date ont été contrôlés, et les écarts les plus graves ont été recontrôlés par un second examinateur indépendant, qui a réfuté plusieurs reclassements proposés. En parallèle, tous les chapitres et annexes ont été relus pour la cohérence interne, l'exactitude factuelle et juridique, la formulation des exigences et la langue. Les corrections retenues ont été intégrées au texte, et le texte des exigences, les échelles et les renvois ont été harmonisés. Après l'intégration de ces corrections, l'annexe G comptait 473 entrées, toutes citées dans le corps du cadre, dont 25 doublons signalés dans leur entrée (« Même source que [n] »), soit 448 sources distinctes : le contrôle d'identité n'a pas fusionné les entrées doubles. Les passes ne portent pas sur la même population (121 références, puis 428 à l'audit final, puis 473 entrées à l'annexe G); l'écart de 45 entrées entre l'audit final et l'annexe G correspond aux références [429] à [473], ajoutées lors de la consolidation et vérifiées le 27 octobre 2026 (historique des versions), et le relevé lien par lien des affirmations et des sources n'est pas publié. La version 1.1 ajoute la référence [496] (RFC 7515, section 6.6), ce qui porte l'annexe G à 474 entrées et à 449 sources distinctes. Les arbitrages d'architecture et de gouvernance relevés lors de cet audit ont également été tranchés et intégrés à la présente version.

Tableau 66 — Catégories de crédibilité des sources

Catégorie	Définition	Usage dans le cadre
A	Source primaire ou officielle : organismes de normalisation et leurs dépôts (IETF, W3C, ISO, NIST, OWASP, CNCF, OpenTelemetry, Linux Foundation et sites des projets), textes législatifs et organismes de réglementation, documentation officielle d'un éditeur sur son propre produit, articles scientifiques d'auteurs identifiables, communiqués des firmes d'analystes.	Appui de tout fait. Une exigence ne s'appuie que sur une source apte à la fonder (norme, loi, spécification, documentation officielle) : un communiqué de firme d'analystes ou un article non révisé par les pairs établit ce que ses auteurs affirment, non une exigence à lui seul.

Catégorie	Définition	Usage dans le cadre
B	Source secondaire reconnue : grande presse spécialisée, cabinets juridiques, experts reconnus, études d'éditeurs, d'investisseurs ou de cabinets.	Appui d'un fait de contexte, jamais seul pour une exigence.
C	Blogue de positionnement, agrégateur, site inconnu ou contenu généré en série.	Jamais cité à l'appui d'un fait ou d'une exigence; remplacé par une source A ou B, ou fait retiré. Un argument d'éditeur peut être nommé comme tel dans le texte, sans appel d'appui; une entrée de l'annexe G de cette catégorie y est signalée.

La catégorie d'une entrée tient à la nature de la source, non à la firme qui la publie : un communiqué, un billet ou une étude d'éditeur vaut comme source primaire de ce que son éditeur affirme de lui-même ou de ses produits (catégorie A), et comme source secondaire pour toute affirmation sur le marché ou sur d'autres produits (catégorie B); un blogue de positionnement ou un agrégateur reste en catégorie C. Cette précision est postérieure au classement des entrées de l'annexe G, qui n'a pas été repris entrée par entrée.

F.2 Bilan chiffré

Les quatre premiers décomptes portent sur les 121 références et sur les 427 liens affirmation-source de la recherche documentaire; les deux derniers (705 et 448) portent sur la version finale.

121

références validées une à une, dont 108 accessibles et 13 bloquées, payantes ou redirigées

61

références de catégorie C (50 %), dont 33 présentant les marques d'un contenu généré en série

88

références remplacées (71) ou retirées (17); 33 conservées comme sources A ou B

23

références du registre reprises à l'annexe G à l'audit final (colonne « no G » du tableau 69) : 18 des 33 conservées et les 5 réintroduites; 15 conservées n'y figurent pas et restent admissibles sans appuyer de fait

705

sources admissibles (A ou B) recensées pour la version finale, dont 632 de catégorie A (primaires ou officielles); 49 ont été ajoutées à ce recensement lors de l'audit final. Ce recensement n'est pas le registre de l'annexe G : il dépasse de 232 sources les 473 entrées de l'annexe G à l'issue de l'audit (de 231 les 474 entrées de la version 1.1), et le présent document ne ventile pas cet écart

448

sources distinctes à l'annexe G à l'issue de l'audit (473 entrées, dont 25 doublons; la version 1.1 y ajoute [496], de catégorie A, soit 449 sources distinctes et 474 entrées), dont 410 de catégorie A, 20 de catégorie B et 18 de catégorie C; la catégorie figure à la fin de chaque entrée, et une source de catégorie C n'y est citée que comme argument d'éditeur ou comme aide à la lecture, sans valeur d'appui (tableau 66)

Tableau 67 — Verdicts sur les 427 liens affirmation-source de la recherche documentaire

Verdict	Nombre	Part	Signification
Appuyée	125	29 %	La source citée confirme l'affirmation telle qu'écrite.
Partiellement appuyée	214	50 %	Le fond est juste, mais un détail (date, chiffre, version, portée) diffère : l'énoncé a été corrigé.
Non appuyée	55	13 %	La source ne contient pas l'affirmation : source primaire trouvée ou fait retiré.
Contredite	14	3 %	La source ou une source primaire dit le contraire : fait corrigé.

Verdict	Nombre	Part	Signification
Invérifiable	19	4 %	Aucune source crédible trouvée : fait retiré ou présenté comme choix interne du cadre.

À RETENIR

Le fond technique des ébauches était solide, mais plus de sept affirmations sur dix (302 sur 427) exigeaient une correction de détail, une meilleure source ou un retrait. Les erreurs récurrentes : versions de protocoles dépassées, chiffres de marché attribués à la mauvaise firme, obligations légales mal rattachées à un article, allégations commerciales présentées comme des normes et seuils chiffrés sans source.

F.3 Principales corrections apportées aux ébauches

Le tableau 68 recense les corrections les plus importantes. Les sources indiquées appuient la version retenue.

Tableau 68 — Principales corrections factuelles

#	Affirmation des ébauches	Version retenue dans le cadre
1	MCP 2026-07-28 « impose » OAuth 2.1, norme publiée.	L'autorisation est facultative dans MCP; le cadre la rend obligatoire. OAuth 2.1 reste un Internet-Draft de l'IETF; on exige OAuth 2.0 selon la RFC 9700, aligné sur le profil OAuth 2.1[175, 176, 209].
2	Champs `x-enterprise-*` dans les annotations d'un outil MCP.	Hors du schéma (cinq propriétés seulement, dont quatre indices non fiables). Le palier, le seuil d'approbation et la compensation sont inscrits au catalogue d'entreprise (choix du cadre, non prescrit par le schéma MCP)[201].
3	La passerelle doit supprimer tout champ `_meta`.	La version du protocole et les capacités du client y sont obligatoires, et `traceparent`, `tracestate` et `baggage` y sont réservés au contexte de trace; on conserve ces clés, on filtre les clés non reconnues et on ne fonde aucune autorisation sur `_meta`[162].
4	Quatre vecteurs d'attaque selon Akamai; rejet 400/403 en cas d'écart d'en-têtes.	L'analyse d'Akamai décrit cinq zones de risque; la concordance en-têtes/corps est déjà exigée par la spécification (HTTP 400, erreur −32020) **[190, 203]**.
5	MCP exige des jetons liés (mTLS ou DPoP) de 5 à 15 minutes.	MCP utilise des jetons porteurs[209]; la liaison à l'expéditeur et la durée courte sont une politique du cadre fondée sur les RFC 8705[328] et 9449[213].
6	Carte d'agent à `/.well-known/agent.json`, champs `url` et `authentication`, méthode `tasks/sendSubscribe`.	Formes antérieures à la version 1.0. A2A 1.0 : `agent-card.json`, `supportedInterfaces`, `securitySchemes`, `SendStreamingMessage`, états `TASK_STATE_*`[68].
7	Spécification A2A « gelée » le 12 mars 2026.	Version 1.0.0 publiée le 12 mars 2026, correctif 1.0.1 le 28 mai 2026 (release GitHub du projet); A2A annoncé comme projet de l'AAIF le 17 août 2026 (billet de la fondation), puis accepté au stade « Growth » (billet du projet du 27 août 2026)[5, 29, 35, 472].
8	AGNTCY fait partie de la pile de l'AAIF; SLIM est résistant au quantique.	AGNTCY est un projet de la Linux Foundation dont la candidature à l'AAIF est ouverte; la proposition qualifie SLIM de « quantum-safe » sans nommer de suite MLS post-quantique (SLIM met en œuvre MLS, RFC 9420), de sorte que son caractère post-quantique n'est pas démontré[37, 269].
9	Copilot Studio : MCP en disponibilité générale visée en octobre 2026.	MCP est en disponibilité générale dans Copilot Studio depuis le 29 mai 2025[300].
10	Une passerelle ajoute moins de 5 ms; le coupe-circuit confine « en millisecondes ».	Allégations commerciales divergentes (TrueFoundry : « typiquement » moins de 5 ms dans sa FAQ, +7 à +12 ms à son propre banc d'essai); aucun seuil chiffré n'est retenu sans mesure interne (P50/P99, politiques actives)[143, **144**].
11	Délégation limitée à un niveau et sept sous-agents : règles générales.	Contraintes du produit Agentforce; la profondeur maximale de deux niveaux est un choix du cadre[49].
12	Attribut `gen_ai.agent_version`; opération `handoff`; contenu jamais dans les attributs de span.	Nom exact `gen_ai.agent.version` (ajouté en v1.40.0); aucune valeur `handoff` dans `gen_ai.operation.name` (v1.41.0); contenu en attributs facultatifs (opt-in) depuis la version 1.37.0; conventions au niveau « Development », à épingler[119, 180].

#	Affirmation des ébauches	Version retenue dans le cadre
13	Indicateurs d'agent « au format FOCUS ».	FOCUS normalise les données de facturation (version 1.4); aucune de ses colonnes ne porte d'indicateur par agent, que l'organisation calcule par jointure avec sa propre télémétrie[410, 463].
14	Le traitement exactement une fois de Kafka empêche les doubles paiements.	La garantie vaut entre sujets Kafka; pour tout effet externe, le système cible doit coopérer, par exemple au moyen d'une clé d'idempotence qu'il vérifie[140].
15	Un bus d'événements réduit la latence de coordination de 70 à 90 %.	Chiffre sans source primaire : retiré; seul l'avantage qualitatif de l'abonnement sur l'interrogation est retenu[262].
16	Multiagent : +81 % et −70 % (Google), 3 à 10 fois plus de jetons.	Selon le billet de Google, +80,9 % (Finance-Agent), −39 % à −70 % (PlanCraft) et amplification des erreurs de 17,2× sans vérification centrale; la version 3 de l'article (260 configurations) donne une plage de +80,8 % à −70,0 %[274]; 3 à 10× par rapport à l'agent unique et environ 15× par rapport à une conversation sont deux mesures distinctes**[17, 273, 275]**.
17	Firecracker : environ 100 000 lignes, six périphériques virtio.	Environ 50 000 lignes de Rust (2020), quatre types de périphériques émulés (réseau et bloc virtio, port série, contrôleur de clavier i8042 partiel), moins de 5 Mo par microVM, démarrage sous 125 ms, selon l'article de 2020[363]; le site du projet en décrit davantage, les versions récentes ajoutant notamment vsock (section 9.7).
18	gVisor impose un surcoût d'E/S de 10 à 30 %.	Aucune fourchette publiée; le coût dépend des appels système : mesurer sur la charge réelle[361].
19	Taux de réussite de 84 % du détournement d'objectif.	Chiffre d'un banc d'essai précis (Agent Security Bench, 84,30 %), cité seulement dans ce contexte[359].
20	Les identités non humaines dépassent les humaines de 20 contre 1.	Enquête de fournisseur la mieux documentée : 82 identités machines par humain (CyberArk, 2025); chaque organisation mesure son propre ratio[11].
21	Loi 25 : avis à la CAI en 72 heures (art. 3.2 ou 3.5).	Avis « avec diligence » en cas de risque de préjudice sérieux (art. 3.5 de la Loi sur le privé); registre (art. 3.8) conservé au moins cinq ans selon le règlement; 72 heures n'est qu'une cible interne[56, 460].
22	Décisions automatisées au secteur public : article 63.1.	Article 65.2 de la Loi sur l'accès[318]; l'article 63.1 porte sur les mesures de sécurité[56].
23	Amendes pénales de 1 000 à 10 000 $ pour une personne; amendes de plus de 500 000 $ déjà prononcées; sanction de 5 000 $ en vertu de la Loi 25.	De 5 000 à 100 000 $ pour une personne physique (art. 91 de la Loi sur le privé); aucune amende de plus de 500 000 $ n'est confirmée; les 5 000 $ visent une décision de la Cour supérieure (art. 342 C.p.c.) sur des citations inventées par l'IA[458].
24	Article 17 : « analyse d'impact relative au transfert »; protection « équivalente ».	EFVP et entente écrite; critère de protection « adéquate »; « hors Québec » s'entend de tout lieu extérieur au Québec, y compris les autres provinces[416].
25	Règlement européen : haut risque applicable le 2 août 2026; s'applique dès qu'un agent « touche » des utilisateurs de l'UE.	Échéances reportées par le règlement (UE) 2026/1744 (annexe III : 2 décembre 2027; annexe I : 2 août 2028); critère de l'article 2 : utilisation des sorties dans l'Union[58, 61].
26	NIST MANAGE 3.1 et 3.2 couvrent le coupe-circuit; MEASURE 2.7 la surveillance des hallucinations.	Coupe-circuit : MANAGE 2.4; déclassement : GOVERN 1.7; MEASURE 2.7 porte sur la sécurité et la résilience; la surveillance en production relève de MEASURE 2.4[74].
27	« Seulement 13 % ont la gouvernance adéquate » attribué à McKinsey; 150 000 agents par entreprise attribués à un blogue.	Les deux chiffres proviennent de Gartner (communiqué du 28 avril 2026)[2].
28	Les dépenses d'IA des entreprises ont bondi de 320 %.	Chiffre sans source, qui semble provenir d'une lecture erronée du facteur 3,2 (environ +220 %) : 37 G$ US en 2025 contre 11,5 G$ US en 2024 (Menlo Ventures, 9 décembre 2025)[16].
29	Petits modèles 10 à 30 fois moins coûteux (arXiv 2506.02142); Phi-3.5 « 98 % de calcul en moins ».	Référence exacte : arXiv 2506.02153 (coût de calcul, non prix facturé); le « 98 % » est introuvable et retiré[403, 473].
30	Trois échelles d'autonomie incompatibles (L0–L5, N0–N4, L0–L4) et seuils chiffrés (60 s, 5 min, 1 h).	Échelle unique N0 à N4 et niveau NX interdit, fondée sur Feng et coll., Gartner, AWS et l'IMDA (Infocomm Media Development Authority, Singapour); les seuils deviennent des paramètres internes approuvés par le comité[75, 76, 83, 95].

#	Affirmation des ébauches	Version retenue dans le cadre
31	Saga : un plantage entre la journalisation et l'action ne déclenche aucune compensation.	Une étape à l'état incertain n'est ni compensée ni replanifiée à l'aveugle : l'orchestrateur clôt d'abord l'opération chez le système visé (annulation ou révocation de la clé d'idempotence, de sorte qu'une arrivée tardive soit rejetée) ou l'interroge jusqu'à une issue définitive; à défaut, l'étape passe en réconciliation différée, confiée à une personne (EXIG-ORC-16)[286].
32	Mémoire à quatre niveaux « inspirée de Tulving ».	Taxonomie à quatre types (travail, épisodique, sémantique, procédurale) issue de CoALA, qui s'inspire de l'architecture Soar et de la psychologie cognitive[100].

F.4 Registre des 121 références de la recherche documentaire

Légende des verdicts : ✓ appuyée · ◐ partiellement appuyée · × non appuyée ou contredite · ? invérifiable · — aucune affirmation associée à la référence. La colonne *n* reprend le numéro de la référence dans la recherche documentaire. Décision (version 1.0), à l'état de la version 1.0 : *conservée* = source A ou B admissible, citée si elle figure à l'annexe G; *remplacée* = remplacée par une source primaire, plus récente ou plus spécifique; *retirée* = sans valeur probante pour le cadre ou hors sujet. La colonne « no G » donne le numéro de l'entrée de l'annexe G qui reprend la source, rapprochée par le titre et l'éditeur (le registre ne conserve pas les adresses des pages), ou un tiret si aucune entrée ne la reprend; une entrée de G publiée sous un autre titre n'est pas rapprochée (ainsi la ligne 22 et [275], même éditeur et même sujet). La colonne « Décision à l'audit final » dit si la source y est citée, réintroduite (lignes 7, 16, 36, 41 et 52, remplacées ou retirées à la version 1.0) ou non citée; une source conservée et non citée reste admissible, sans appuyer aucun fait du cadre, et une source citée de catégorie C ne l'est que comme argument d'éditeur (tableau 66). Le symbole × réunit les affirmations non appuyées et contredites, que le tableau 67 distingue globalement (55 et 14) : les relevés de la recherche documentaire ne donnent pas cette répartition référence par référence, de sorte que le registre ne peut pas marquer d'un symbole propre les sources contredites. Pour une page bloquée ou payante, la catégorie repose sur l'éditeur, et le verdict sur le résumé public.

Tableau 69 — Registre de validation des références de la recherche documentaire

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
1	Enterprise Agentic AI Architecture Design Guidance (Part 1) Architecture & Governance Magazine	**B**	accessible	✓5 ◐10 ×3	conservée	—	non citée
2	Enterprise Agentic AI Reference Architecture (2026) Triotech Systems	**C**	accessible	✓2 ◐2	retirée	—	non citée
3	A Framework for Architecting Agent Control Plane MuleSoft	**B**	accessible	✓3 ◐3 ×3	conservée	[45]	citée comme argument d'éditeur (catégorie C)
4	Microsoft Copilot Studio vs. Salesforce Agentforce: Which AI Agent Platform is Better for Enterprises? Artic Consulting	**C**	accessible	◐4	remplacée	—	non citée
5	Agentic AI Architecture Framework for Enterprises: The Complete 2026 Design and Governance Guide NextAgile	**C**	accessible	◐4 ×1 ?9	remplacée	—	non citée
6	AI FinOps Explained: AI Cost Optimization Guide for 2026 AvePoint	**C**	accessible	✓1 ◐5 ×2	remplacée	—	non citée
7	Governing AI Agents Across Multiple Platforms TrueFoundry	**B**	accessible	✓2 ◐8 ×3	remplacée	[44]	réintroduite comme argu-

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
							ment d'éditeur (catégorie C)
8	Designing agentgateway: A Unified High-Performance Gateway for AI and API Traffic agentgateway.dev	**A**	accessible	✓1 ◐2	conservée	[142]	citée
9	Agent Communication Protocol (ACP) Explained: What It Is and Why It Matters Boldare	**C**	accessible	✓1 ◐6	remplacée	—	non citée
10	What the Linux Foundation and AAIF Mean for MCP and Agentic AI Blck Alpaca	**C**	accessible	✓1 ◐3 ×2	remplacée	—	non citée
11	The next generation of MCP Cloudflare	**B**	accessible	✓12 ◐6 ×2	remplacée	—	non citée
12	Specification - Model Context Protocol (MCP) ModelContextProtocol.Info	**C**	accessible	✓1	remplacée	—	non citée
13	Architecture overview (documentation MCP, révision 2026-07-28) Model Context Protocol	**A**	accessible	✓5 ◐1	conservée	[63]	citée
14	#17: What is A2A and why is it – still! – underappreciated? Turing Post	**B**	accessible	✓2 ◐1	remplacée	—	non citée
15	All About the A2A Protocol, Now Part of the Agentic AI Foundation rohitghumare.com	**C**	accessible	✓10 ◐6 ×3 ?1	remplacée	—	non citée
16	[Project Proposal] AGNTCY #57 (dépôt aaif/project-proposals) GitHub	**A**	accessible	✓5 ◐6	remplacée	[37]	réintroduite
17	AGNTCY: the open standard set to structure the Internet of Agents Splunk	**B**	accessible	✓2 ◐2	remplacée	—	non citée
18	Autonomous Agentic Event-Driven Systems Architecture Confluent	**A**	accessible	✓4 ◐6	conservée	[262]	citée comme argument d'éditeur (catégorie C)
19	Event-Driven Architecture for AI Agents (Patterns and Benefits) Atlan	**C**	accessible	◐3	remplacée	—	non citée
20	The 6 Levels of AI Autonomy (2026): A Practical Framework Agentys	**C**	accessible	◐8 ×10	remplacée	—	non citée
21	AI Agent Risk Assessment: What Organizations Need to Evaluate Global AI Certification Council	**C**	accessible	✓2 ◐5 ×4	remplacée	—	non citée
22	When to use multi-agent systems (and when not to) Anthropic	**A**	accessible	✓6 ◐8 ×1	conservée	—	non citée
23	Single-Agent vs Multi-Agent AI: When to Scale Your Dev Workflow Augment Code	**C**	accessible	✓1	remplacée	—	non citée
24	The Saga Pattern for Multi-Agent Transactions: Compensating Actions RedLineSoft	**C**	accessible	✓11 ◐2 ×1	remplacée	—	non citée

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
25	AI Agent Orchestration Frameworks: A 2026 Guide Levelop	C	accessible	✓2 ◐8 ×2	remplacée	—	non citée
26	OWASP Top 10 for Agentic Applications (2026) — fiche de cadre Modulos (MFF-14) Modulos AG	B	accessible	✓7 ◐5 ×2	remplacée	—	non citée
27	Authentication for AI Agents: OAuth Patterns for Non-Human Identity guptadeepak.com	B	accessible	✓2 ◐6 ×2	remplacée	—	non citée
28	ISO 42001 vs NIST AI RMF: Which Do You Need in 2026? Fruggr	C	accessible	◐3	remplacée	—	non citée
29	How to sandbox AI agents in 2026: MicroVMs, gVisor & isolation strategies Northflank	B	accessible	✓1 ◐5 ×1	remplacée	—	non citée
30	Conformité à l'IA et à la Loi 25 du Québec : le guide complet 2026 Augure	C	accessible	◐11 ×9 ?1	remplacée	—	non citée
31	Enterprise Architecture 2030: Navigating Agentic AI Scenarios Gartner	A	payante	✓1	conservée	—	non citée
32	The best AI agent frameworks in 2026 LangChain	B	accessible	◐4 ×2	remplacée	—	non citée
33	Best Agentic AI Platforms for Enterprise Operations (2026 Guide) Shadow Inc.	C	accessible	✓1 ◐1 ×2	remplacée	—	non citée
34	Multi-Agent AI News - Week of May 19-25, 2026 - Enterprise Orchestration Platforms Suprmind	C	accessible	◐2 ×1 ?1	remplacée	—	non citée
35	Agentic Integration with SAP, ServiceNow, and Salesforce Microsoft Community Hub	B	accessible	—	retirée	—	non citée
36	Implement 3 Layers of Oversight for Scaled Agentic AI Architectures (titre non vérifié) Gartner	A	bloquée	?1	retirée	[52]	réintroduite
37	AI Agent Sandbox: How to Safely Run Autonomous Agents in 2026 Firecrawl	B	accessible	✓3 ◐1	conservée	—	non citée
38	MCP (Model Context Protocol) in 2026: the complete guide for engineering teams Jacar Systems	C	accessible	✓2 ◐3 ×1	remplacée	—	non citée
39	Multi-Agent Orchestration Patterns: A Production Guide (2026) explainx.ai	C	accessible	✓2 ◐5 ×1	remplacée	—	non citée
40	Agentforce Interoperability Guide (The Architect's Guide to Agentforce Interoperability) Salesforce	A	accessible	◐2	conservée	[49]	citée
41	Levels of Autonomy for AI Agents arXiv	A	bloquée	✓1	remplacée	[83]	réintroduite
42	The Five Working Levels of AI Agent Autonomy, and How to Choose Among Them The Inteq Group	C	accessible	✓1 ◐1	remplacée	—	non citée
43	Building Blocks (TOGAF 9.1, Partie IV, chapitre 37) QualiWare Center of Excellence	B	accessible	◐1	remplacée	—	non citée

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
44	Architecture Building Blocks (ABBs) vs Solution Building Blocks (SBBs) Boldo	C	accessible	—	remplacée	—	non citée
45	SAP Enterprise Architects' Guide: Using TOGAF® ABBs and SBBs to Deliver Successful SAP S/4HANA Implementations Insight Arc	C	accessible	—	retirée	—	non citée
46	Ambient Agents and the New Agent Inbox ft. Harrison Chase Inference by Sequoia	B	accessible	◐7	remplacée	—	non citée
47	Introducing ambient agents LangChain	A	accessible	✓2 ◐2	conservée	[86]	citée
48	Confluent: The Real-Time Backbone for Agentic Systems Confluent	A	accessible	◐2	conservée	—	non citée
49	Best Code Execution Sandboxes for AI Agents in 2026 E2B	A	accessible	✓1	conservée	—	non citée
50	MCP Is Growing Up: The 2026 Roadmap Takes Shape Obot AI	B	accessible	✓1 ◐1	remplacée	—	non citée
51	5 Best Code Execution Sandboxes for AI Agents Blaxel	C	accessible	—	retirée	—	non citée
52	TRiSM for Agentic AI: A Review of Trust, Risk, and Security Management in LLM-based Agentic Multi-Agent Systems arXiv	A	accessible	◐1	remplacée	[454]	réintroduite
53	AI Agent Protocols: MCP, A2A, ACP, and the Interop Stack AIPrompt20	C	accessible	✓1	remplacée	—	non citée
54	The AI Agent Memory Architecture Deep Dive: Building Agents That Remember Across Sessions, Devices, and Tools AI Magicx	C	accessible	✓1 ◐4 ×1	remplacée	—	non citée
55	GraphRAG, AI Agents, and Memory: How Graph Databases Power the Next Wave of AI in 2026 FalkorDB	B	accessible	◐3	remplacée	—	non citée
56	Agent Memory Architectures: Vector vs Graph vs Episodic Digital Applied	C	accessible	—	retirée	—	non citée
57	New in Confluent Intelligence: A2A, Multivariate Anomaly Detection, Vector Search for Cosmos DB, Amazon S3 Vectors, and More Confluent	A	accessible	◐1	conservée	—	non citée
58	Cheap Tokens, Expensive Agents: The 2026 Inference Economics Reckoning Socradata	C	accessible	◐2 ×1 ?1	remplacée	—	non citée
59	OpenTelemetry GenAI Semantic Conventions: A Practical Guide OpenObserve	C	accessible	◐4 ×3	remplacée	—	non citée
60	Agent Memory Systems: How AI Agents Remember, Learn, and Stay Coherent Across Time Tresslers Group	C	accessible	◐1	remplacée	—	non citée

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
61	Avoid Governance Mismatch: Classify AI Agents by Autonomy Level Gartner	**A**	bloquée	✓1 ◐1	conservée	—	non citée
62	From autonomous cars to autonomous agents: the five levels of AI agent autonomy (titre non confirmé) MIT Media Lab	**B**	bloquée	?3	remplacée	—	non citée
63	The 5 Levels of Agentic AI (And Why Most Businesses Need Less Autonomy Than They Think) (titre non confirmé) Medium	**C**	bloquée	—	retirée	—	non citée
64	The 5 Levels of AI Agent Autonomy: From Copilot to Fully Autonomous (And Where to Start) Pickaxe	**C**	accessible	◐1	remplacée	—	non citée
65	The Six Levels of Agentic Behavior Vellum	**C**	accessible	—	retirée	—	non citée
66	The Top Agentic AI Security Threats You Need to Know in 2026 Lasso Security	**B**	accessible	◐1	remplacée	—	non citée
67	Ambient agents explained: Applications, architecture, and building with ZBrain ZBrain	**C**	accessible	—	retirée	—	non citée
68	LIVE: Ambient Agents and the New Agent Inbox ft. Harrison Chase Sequoia Capital	**B**	accessible	✓2	conservée	—	non citée
69	UX for Agents, Part 2: Ambient LangChain	**B**	accessible	—	conservée	—	non citée
70	Why Google's Agent2Agent Protocol Needs Apache Kafka Medium	**B**	bloquée	—	remplacée	—	non citée
71	MCP (Model Context Protocol) for Business: The USB-C of AI Agents and Why It Changes Your Stack in 2026 NAXIA	**C**	accessible	—	retirée	—	non citée
72	The New MCP Specification: What Security Teams Must Prepare For Akamai Security Research	**B**	accessible	✓4 ◐3	conservée	[203]	citée
73	Agent Card Explained: A2A Protocol, JSON & Use Cases AI Growth Agent	**C**	accessible	✓2 ◐2 ×1	remplacée	—	non citée
74	Agent communication protocols: A2A vs ACP vs MCP (2026) crystl	**C**	accessible	—	retirée	—	non citée
75	What's New in A2A Protocol v1.0 A2A Project	**A**	accessible	—	conservée	[235]	citée
76	A2A v1.0: a builder's guide, part 2 - migration, security, and production Agentic AI Foundation	**A**	accessible	—	conservée	[242]	citée
77	A2A Agent Card: Structure, Discovery, and Signing Agent2Agent.Info	**C**	redirigée	✓1	remplacée	—	non citée
78	A2A v1.0 Agent Card Specification Explorer A2A Registry	**C**	accessible	—	remplacée	—	non citée
79	AGNTCY Documentation AGNTCY	**A**	accessible	—	conservée	[182]	citée

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
80	Beyond Context Sharing: A Unified Agent Communication Protocol (ACP) for Secure, Federated, and Autonomous Agent-to-Agent (A2A) Orchestration arXiv	**A**	accessible	—	retirée	—	non citée
81	Four Design Patterns for Event-Driven, Multi-Agent Systems Confluent	**A**	accessible	✓1 ◐1	conservée	—	non citée
82	MCP vs. REST/HTTP API vs. Kafka: The Architect's Guide to Agentic AI Integration kai-waehner.de	**B**	accessible	✓2 ◐5 ×1	conservée	[167]	citée
83	Building effective agents Anthropic	**A**	accessible	◐1	conservée	[6]	citée
84	Single Agent vs Multi-Agent: When to Build a Multi-Agent System (titre non confirmé : page inaccessible) Towards Data Science	**B**	bloquée	—	remplacée	—	non citée
85	How to Decide When to Use a Single Agent vs a Multi-Agent Team MindStudio	**C**	accessible	✓1	remplacée	—	non citée
86	Multi-Agent AI Orchestration: A CTO's 2026 Guide KGT Solutions	**C**	accessible	✓1 ?1	remplacée	—	non citée
87	Top Agent Frameworks To Use in 2026: A Comparison Splunk	**C**	accessible	✓2 ◐2	remplacée	—	non citée
88	How and when to build multi-agent systems LangChain	**B**	accessible	—	conservée	[277]	citée comme argument d'éditeur (catégorie C)
89	Top 9 AI Agent Frameworks in 2026 (titre de la bibliographie; page non lue) Medium	**C**	bloquée	—	retirée	—	non citée
90	Conformité Loi 25 – Microsoft, hébergé au Canada (io4 Technologies) io4 Technologies	**C**	accessible	✓1 ◐1	remplacée	—	non citée
91	Salesforce Agentforce vs Microsoft Copilot Studio: 2026 Comparison Smartbridge LLC	**C**	accessible	—	retirée	—	non citée
92	AI Agent Memory Architectures: From Context Windows to Persistent Knowledge Zylos Research	**C**	accessible	—	retirée	—	non citée
93	Memory Systems for AI Agents: Practical Implementations (2025-2026) GitHub Gist	**C**	accessible	—	retirée	—	non citée
94	SYNAPSE: Empowering LLM Agents with Episodic-Semantic Memory via Spreading Activation arXiv	**A**	accessible	—	conservée	—	non citée
95	Architecture – Solo Enterprise for agentgateway docs Solo.io	**A**	accessible	—	remplacée	—	non citée
96	OAuth 2.0 Token Exchange: When One Token Isn't the Token You Need (titre non confirmé) Medium	**C**	bloquée	?1	remplacée	—	non citée
97	OAuth's On-Behalf-Of flow for AI agents WorkOS	**B**	accessible	◐2	remplacée	—	non citée

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
98	OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents (brouillon –01) IETF	**A**	accessible	◐1	remplacée	—	non citée; révision –02 citée ([335])
99	On-Behalf-Of Token Exchange Auth0	**A**	accessible	—	conservée	—	non citée
100	OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents (brouillon –00) IETF	**A**	accessible	◐1	remplacée	—	non citée; révision –02 citée ([335])
101	AI Agent Code Execution Sandboxes: Isolation from Containers to MicroVMs (titre non confirmé) Medium	**C**	bloquée	—	remplacée	—	non citée
102	OWASP Top 10 for Agentic Applications 2026: Key Takeaways & How to Take Action Teleport	**B**	accessible	—	remplacée	—	non citée
103	OWASP Non-Human Identities Top 10 OWASP Foundation	**A**	accessible	—	conservée	[91]	citée
104	OWASP Agentic Skills Top 10 OWASP Foundation	**A**	accessible	—	conservée	[350]	citée
105	OWASP GenAI Security Project Releases Top 10 Risks and Mitigations for Agentic AI Security OWASP GenAI Security Project	**A**	accessible	—	conservée	—	non citée
106	AI TRiSM: Understanding Gartner's View on Agentic AI Trust Sweet Security	**C**	accessible	◐1 ×1	remplacée	—	non citée
107	OpenTelemetry GenAI Semantic Conventions: What's Stable Praesidia	**C**	accessible	—	remplacée	—	non citée
108	Semantic Conventions for GenAI agent and framework spans OpenTelemetry	**A**	accessible	—	conservée	[120]	citée
109	Loi 25 et IA au Québec : guide PME 2026 (« Loi 25 et IA. Les gestes qui comptent. ») Margence inc.	**C**	accessible	◐1	remplacée	—	non citée
110	Conseil et formation IA — conformité Loi 25 et IA responsable au Québec | DictIA DictIA Inc.	**C**	accessible	✓1 ×2	remplacée	—	non citée
111	Principaux changements aux lois sur la protection des renseignements personnels Commission d'accès à l'information du Québec	**A**	accessible	—	conservée	[7]	citée
112	Décisions automatisées et Loi 25 : préparer l'information et la révision humaine extensio.ai	**C**	accessible	◐1	remplacée	—	non citée
113	Mesures applicables lors de l'utilisation de l'intelligence artificielle générative (indication d'application IA-RI-2025-003-OP) Gouvernement du Québec	**A**	accessible	—	conservée	[421]	citée
114	AI Governance in 2026: A Practical Framework for NIST AI RMF, EU AI Act, and ISO 42001 Enterprise Architecture Blog	**C**	accessible	—	remplacée	—	non citée

n	Source (titre réel, éditeur)	Cat.	Accès	Affirmations	Décision (version 1.0)	no G	Décision à l'audit final
115	NIST AI RMF Continuous Monitoring 2026 Bitsight	**C**	bloquée	—	remplacée	—	non citée
116	NIST AI RMF: 8-Step Implementation Guide NeuralTrust	**C**	accessible	—	remplacée	—	non citée
117	A Guide to AI TRiSM: Trust, Risk, and Security Management Palo Alto Networks	**B**	accessible	—	conservée	—	non citée
118	NIST AI RMF Implementation: A Clear 8-Step Plan for 2026 Governance Docs LLC	**C**	accessible	—	remplacée	—	non citée
119	AI FinOps Became a Real Discipline in 2026. Here's What It Requires. Larridin	**C**	accessible	—	retirée	—	non citée
120	AI FinOps 2026: The Definitive Guide to Costs and Value Compresr	**C**	accessible	◐2 ×1	remplacée	—	non citée
121	FinOps for AI: How to Control LLM Token Spend Before It Controls Your Budget Varcio	**C**	accessible	—	remplacée	—	non citée

G Références

Liste des sources citées, numérotées approximativement dans l'ordre de leur première citation (les références ajoutées à la consolidation, [429] à [473], et à la version 1.1, [496], suivent les autres). Elles relèvent en principe des catégories A (primaires ou officielles) ou B (secondaires reconnues) du tableau 66; la catégorie de chaque entrée figure à sa fin, et une entrée de catégorie C y est en outre signalée comme argument d'éditeur ou comme aide à la lecture, sans valeur d'appui. État des sources au 27 octobre 2026; vérifications des 27 et 28 octobre 2026. La liste compte 474 entrées ([1] à [473] et [496]), dont 25 doublons signalés (« Même source que [n] »), soit 449 sources distinctes; les numéros ne sont jamais réattribués. Gabarit des entrées : Auteur (AAAA, j mois; AAAA, mois quand la source ne donne pas le jour; l'année seule quand elle ne donne pas le mois; AAAA-AAAA pour un dépôt de versions successives; « mis à jour le… » pour une page révisée). Les auteurs d'un RFC ou d'un brouillon de l'IETF sont nommés; « IETF » seul désigne une page ou un groupe de travail. Titre. Éditeur. Adresse; « s. d. » marque une page sans date, et une page mouvante porte sa date de consultation. Les références [474] à [495] de l'annexe H suivent un gabarit propre (titre entre guillemets, statut relevé, date de consultation), parce que chacune horodate un relevé d'état. Les versions des spécifications évoluant rapidement, le catalogue d'entreprise fait foi pour les versions applicables.

- **[1]** Gartner (2025, 26 août). Gartner Predicts 40% of Enterprise Apps Will Feature Task-Specific AI Agents by 2026, Up from Less Than 5% in 2025 [communiqué]. Gartner. https://www.gartner.com/en/newsroom/press-releases/2025-08-26-gartner-predicts-40-percent-of-enterprise-apps-will-feature-task-specific-ai-agents-by-2026-up-from-less-than-5-percent-in-2025
- **[2]** Gartner (2026, 28 avril). Gartner Identifies Six Steps to Manage AI Agent Sprawl [communiqué]. Gartner. https://www.gartner.com/en/newsroom/press-releases/2026-04-28-gartner-identifies-six-steps-to-manage-artificial-intelligence-agent-sprawl
- **[3]** Gartner (2025, 25 juin). Gartner Predicts Over 40% of Agentic AI Projects Will Be Canceled by End of 2027 [communiqué]. Gartner. https://www.gartner.com/en/newsroom/press-releases/2025-06-25-gartner-predicts-over-40-percent-of-agentic-ai-projects-will-be-canceled-by-end-of-2027
- **[4]** Linux Foundation (2025, 9 décembre). Linux Foundation Announces the Formation of the Agentic AI Foundation (AAIF), Anchored by New Project Contributions Including Model Context Protocol (MCP), goose and AGENTS.md. Linux Foundation. https://www.linuxfoundation.org/press/linux-foundation-announces-the-formation-of-the-agentic-ai-foundation
- **[5]** A2A Project (2026, 27 août). A New Chapter for A2A: Joining the Agentic AI Foundation. https://a2a-protocol.org/latest/blog/2026/08/27/a-new-chapter-for-a2a-joining-the-agentic-ai-foundation
- **[6]** Schluntz, E. et Zhang, B. (2024, 19 décembre). Building effective agents. Anthropic. La page signe « Erik S. » (nom complet d'après des sources secondaires) et porte une note d'Anthropic : l'outillage décrit a changé depuis décembre 2024; le cadre n'en retient que les principes. https://www.anthropic.com/engineering/building-effective-agents
- **[7]** Commission d'accès à l'information du Québec (s. d.). Principaux changements aux lois sur la protection des renseignements personnels. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/sujets-et-domaines-dinteret/principaux-changements-loi-25
- **[8]** Bureau du surintendant des institutions financières (2025). Ligne directrice E-23 – Gestion du risque de modèle (2027). BSIF. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027
- **[9]** Microsoft (2026). AI agent orchestration patterns. Azure Architecture Center. https://learn.microsoft.com/en-us/azure/architecture/ai-ml/guide/ai-agent-design-patterns

- **[10]** FinOps Foundation (2026). State of FinOps 2026. Linux Foundation. https://data.finops.org/
- **[11]** CyberArk (2025, 23 avril). Machine Identities Outnumber Humans by More Than 80 to 1: New Report Exposes the Exponential Threats of Fragmented Identity Security [communiqué]. Business Wire (reproduit par Silicon UK). Reproduction de presse du communiqué; le rapport d'origine n'a pas été relu. https://www.silicon.co.uk/press-release/machine-identities-outnumber-humans-by-more-than-80-to-1-new-report-exposes-the-exponential-threats-of-fragmented-identity-security
- **[12]** McKinsey & Company (2025, 5 novembre). The state of AI in 2025: Agents, innovation, and transformation. QuantumBlack, AI by McKinsey. https://www.mckinsey.com/capabilities/quantumblack/our-insights/the-state-of-ai
- **[13]** Shaw, F. X. (2025, 19 mai). Microsoft Build 2025: The age of AI agents and building the open agentic web. Microsoft. https://blogs.microsoft.com/blog/2025/05/19/microsoft-build-2025-the-age-of-ai-agents-and-building-the-open-agentic-web
- **[14]** Soria Parra, D. (2025, 9 décembre). MCP joins the Agentic AI Foundation. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/2025-12-09-mcp-joins-agentic-ai-foundation
- **[15]** Linux Foundation (2026, 9 avril). A2A Protocol Surpasses 150 Organizations, Lands in Major Cloud Platforms, and Sees Enterprise Production Use in First Year. Communiqué. https://www.linuxfoundation.org/press/a2a-protocol-surpasses-150-organizations-lands-in-major-cloud-platforms-and-sees-enterprise-production-use-in-first-year
- **[16]** Menlo Ventures (2025, 9 décembre). 2025: The State of Generative AI in the Enterprise. Menlo Ventures. https://menlovc.com/perspective/2025-the-state-of-generative-ai-in-the-enterprise
- **[17]** Hadfield, J., Zhang, B., Lien, K., Scholz, F., Fox, J. et Ford, D. (2025, 13 juin). How we built our multi-agent research system. Anthropic. https://www.anthropic.com/engineering/multi-agent-research-system
- **[18]** IBM (2025, 30 juillet). IBM Report: 13% Of Organizations Reported Breaches Of AI Models Or Applications, 97% Of Which Reported Lacking Proper AI Access Controls [communiqué; Cost of a Data Breach Report 2025, Ponemon Institute]. IBM. https://newsroom.ibm.com/2025-07-30-ibm-report-13-of-organizations-reported-breaches-of-ai-models-or-applications,-97-of-which-reported-lacking-proper-ai-access-controls
- **[19]** IBM et Ponemon Institute (2026, 29 juillet). Cost of a Data Breach Report 2026. IBM. Date de publication selon le communiqué d'IBM du 29 juillet 2026; l'adresse mène à l'édition courante du rapport. https://www.ibm.com/reports/data-breach
- **[20]** Anthropic (2024, 25 novembre). Introducing the Model Context Protocol. Anthropic. https://www.anthropic.com/news/model-context-protocol
- **[21]** Google (2025, 9 avril). Announcing the Agent2Agent Protocol (A2A). Google for Developers Blog. https://developers.googleblog.com/en/a2a-a-new-era-of-agent-interoperability
- **[22]** Linux Foundation (2025, 23 juin). Linux Foundation Launches the Agent2Agent Protocol Project to Enable Secure, Intelligent Communication Between AI Agents. Linux Foundation. https://www.linuxfoundation.org/press/linux-foundation-launches-the-agent2agent-protocol-project-to-enable-secure-intelligent-communication-between-ai-agents
- **[23]** Linux Foundation (2025, 29 juillet). Linux Foundation Welcomes the AGNTCY Project to Standardize Open Multi-Agent System Infrastructure and Break Down AI Agent Silos. https://www.linuxfoundation.org/press/linux-foundation-welcomes-the-agntcy-project-to-standardize-open-multi-agent-system-infrastructure-and-break-down-ai-agent-silos
- **[24]** LF AI & Data Foundation (2025, 29 août). ACP Joins Forces with A2A. https://lfaidata.foundation/communityblog/2025/08/29/acp-joins-forces-with-a2a-under-the-linux-foundations-lf-ai-data

- **[25]** Soria Parra, D., Jones, A., Antanavicius, T., Padilla, T. et Chu, T. (2025, 8 septembre). Introducing the MCP Registry. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/2025-09-08-mcp-registry-preview
- **[26]** Google Cloud (2025, 16 septembre). Powering AI commerce with the new Agent Payments Protocol (AP2). Google Cloud Blog. https://cloud.google.com/blog/products/ai-machine-learning/announcing-agents-to-payments-ap2-protocol
- **[27]** Stripe (2025, 29 septembre). Stripe powers Instant Checkout in ChatGPT and releases Agentic Commerce Protocol co-developed with OpenAI. Stripe. https://stripe.com/newsroom/news/stripe-openai-instant-checkout
- **[28]** OWASP GenAI Security Project (2025). OWASP Top 10 for Agentic Applications for 2026. OWASP Foundation. https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026
- **[29]** A2A Project (2026, 12 mars). A2A Protocol Ships v1.0: Production-Ready Standard for Agent-to-Agent Communication. https://a2a-protocol.org/latest/blog/2026/03/12/a2a-protocol-ships-v10-production-ready-standard-for-agent-to-agent-communication
- **[30]** A2A Project (2025-2026). Releases (v0.1.0 à v1.0.1). GitHub a2aproject/A2A. https://github.com/a2aproject/A2A/releases
- **[31]** Agentic AI Foundation (2026, 4 juin). agentgateway Joins AAIF as an Open Gateway for Agentic AI Infrastructure. AAIF. https://aaif.io/blog/agentgateway-joins-aaif-as-an-open-gateway-for-agentic-ai-infrastructure
- **[32]** Linux Foundation (2025, 25 août). Linux Foundation Welcomes agentgateway Project to Accelerate AI Agent Adoption While Maintaining Security, Observability and Governance. Communiqué. https://linuxfoundation.org/press/linux-foundation-welcomes-agentgateway-project-to-accelerate-ai-agent-adoption-while-maintaining-security-observability-and-governance
- **[33]** Soria Parra, D. et Delimarsky, D. (2026, 28 juillet). The 2026-07-28 Specification. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/2026-07-28
- **[34]** Model Context Protocol (2026). Versioning. https://modelcontextprotocol.io/specification/versioning
- **[35]** Agentic AI Foundation (2026, 17 août). A2A joins AAIF's open agentic stack. AAIF. https://aaif.io/blog/a2a-joins-aaif
- **[36]** Agentic AI Foundation (2026, 9 septembre). Envoy AI Gateway becomes Agent Router and joins AAIF. Agentic AI Foundation (AAIF). https://aaif.io/blog/agent-router-joins-aaif
- **[37]** Cisco (Parello, J.) (2026, 12 octobre). [Project Proposal] AGNTCY, issue no 57. GitHub, aaif/project-proposals (Agentic AI Foundation). https://github.com/aaif/project-proposals/issues/57
- **[38]** Linux Foundation (2026, 22 octobre). Agentic AI Foundation Announces Four New Projects: Agent Skills, Open Responses, OpenEnv, and OpenSandbox. Communiqué. https://www.linuxfoundation.org/press/agentic-ai-foundation-announces-four-new-projects-agent-skills-open-responses-openenv-and-opensandbox
- **[39]** A2A Project (s. d.). A2A and MCP. https://a2a-protocol.org/latest/topics/a2a-and-mcp
- **[40]** Agentic AI Foundation (s. d.). Home (section « Working groups that matter »). Agentic AI Foundation (AAIF). https://aaif.io/
- **[41]** Parikh, S. (2026, 28 avril). We're donating Agent Payments Protocol to the FIDO Alliance to support the future of secure, agentic payments. Google. https://blog.google/products-and-platforms/platforms/google-pay/agent-payments-protocol-fido-alliance
- **[42]** Agentic AI Foundation (2026). Project Proposals (processus d'admission). GitHub. https://github.com/aaif/project-proposals

- **[43]** Model Context Protocol (2026). The MCP Registry. https://modelcontextprotocol.io/registry/about
- **[44]** TrueFoundry (2026). *Governing AI Agents Across Multiple Platforms.* Argument d'éditeur (catégorie C au sens du tableau 66), cité comme tel, jamais à l'appui d'une exigence. https://www.truefoundry.com/blog/cross-platform-ai-agent-governance
- **[45]** Dhimate, Y. (2026). A Framework for Architecting Agent Control Plane. MuleSoft Blog, 12 août 2026. Argument d'éditeur (catégorie C au sens du tableau 66), cité comme tel, jamais à l'appui d'une exigence. https://blogs.mulesoft.com/agentic-perspectives/a-framework-for-architecting-agent-control-plane
- **[46]** Shah, N., Lefferts, R. et Roszak, J. (2026, 1er mai). Microsoft Agent 365, now generally available, expands capabilities and integrations. Microsoft Security Blog. https://www.microsoft.com/en-us/security/blog/2026/05/01/microsoft-agent-365-now-generally-available-expands-capabilities-and-integrations
- **[47]** ServiceNow (2026, 5 mai). ServiceNow expands AI Control Tower to discover, observe, govern, secure, and measure AI deployed across any system in the enterprise. Communiqué. https://newsroom.servicenow.com/press-releases/details/2026/ServiceNow-expands-AI-Control-Tower-to-discover-observe-govern-secure-and-measure-AI-deployed-across-any-system-in-the-enterprise/default.aspx
- **[48]** Microsoft (2026). What's new in Copilot Studio. Microsoft Learn. https://learn.microsoft.com/en-us/microsoft-copilot-studio/whats-new
- **[49]** Salesforce (s. d.). Agentforce Interoperability Guide. Salesforce. https://www.salesforce.com/agentforce/resources/interoperability-guide
- **[50]** ServiceNow (2026, 5 mai). ServiceNow turns enterprise AI chaos into control with the platform for governed, autonomous work. ServiceNow. https://newsroom.servicenow.com/press-releases/details/2026/ServiceNow-turns-enterprise-AI-chaos-into-control-with-the-platform-for-governed-autonomous-work/default.aspx
- **[51]** ServiceNow (2025, 6 mai). ServiceNow Launches AI Control Tower, a Centralized Command Center to Govern, Manage, Secure, and Realize Value From Any AI Agent, Model, and Workflow. ServiceNow. https://newsroom.servicenow.com/press-releases/details/2025/ServiceNow-Launches-AI-Control-Tower-a-Centralized-Command-Center-to-Govern-Manage-Secure-and-Realize-Value-From-Any-AI-Agent-Model-and-Workflow/default.aspx
- **[52]** Gartner (2026, 3 août). Implement 3 Layers of Oversight for Scaled Agentic AI Architectures (document 8214461; résumé public en accès libre, texte intégral réservé aux clients). Gartner. Titre et date du résumé relevés le 4 novembre 2026 dans l'index d'un moteur de recherche, la page de Gartner refusant l'accès à l'outillage de vérification. https://www.gartner.com/en/documents/8214461
- **[53]** Microsoft (2026). Billing rates and management – Microsoft Copilot Studio. Microsoft Learn. https://learn.microsoft.com/en-us/microsoft-copilot-studio/requirements-messages-management
- **[54]** Salesforce (2026, 26 août). Salesforce Delivers Record Second Quarter Fiscal 2027 Results [communiqué]. Salesforce. https://www.salesforce.com/news/press-releases/2026/08/26/fy27-q2-earnings
- **[55]** Salesforce (2026). Agentforce Pricing. Salesforce. https://www.salesforce.com/agentforce/pricing
- **[56]** Québec (2021). Loi modernisant des dispositions législatives en matière de protection des renseignements personnels, L.Q. 2021, c. 25 (projet de loi no 64), sanctionnée le 22 septembre 2021. Éditeur officiel du Québec. https://www.publicationsduquebec.gouv.qc.ca/fileadmin/Fichiers_client/lois_et_reglements/LoisAnnuelles/fr/2021/2021C25F.PDF

- **[57]** Commission européenne (2026). Timeline for the implementation of the EU AI Act. AI Act Service Desk. https://ai-act-service-desk.ec.europa.eu/en/ai-act/timeline/timeline-implementation-eu-ai-act
- **[58]** Union européenne (2026). Règlement (UE) 2026/1744 du Parlement européen et du Conseil du 8 juillet 2026 modifiant les règlements (UE) 2024/1689, (UE) 2018/1139 et (UE) 2023/1230 en ce qui concerne la simplification de la mise en œuvre des règles harmonisées concernant l'intelligence artificielle (train de mesures omnibus numérique sur l'IA). Journal officiel de l'Union européenne, L, 24.7.2026. Texte non relu au Journal officiel lors de la revue du 3 novembre 2026 (EUR-Lex inaccessible); les dates d'application sont citées d'après [57]. https://eur-lex.europa.eu/eli/reg/2026/1744/oj
- **[59]** ISO/IEC (2022, 19 juillet). ISO/IEC 22989:2022, Information technology — Artificial intelligence — Artificial intelligence concepts and terminology (fiche catalogue, édition 1). Standards Norway. https://online.standard.no/en/isoiec-22989-2022-3
- **[60]** oneM2M (2026, 5 juin). TR-0081 — AI Agent Interworking, v0.2.0, section 5.1. oneM2M. https://specifications.onem2m.org/tr/tr-0081/latest/5.1
- **[61]** Union européenne (2024). Règlement (UE) 2024/1689 du Parlement européen et du Conseil du 13 juin 2024 établissant des règles harmonisées concernant l'intelligence artificielle, art. 2, 3, 12, 14, 25, 26, 27 et 113. Journal officiel de l'Union européenne. https://eur-lex.europa.eu/eli/reg/2024/1689/oj
- **[62]** Future of Life Institute (2026). *Article 3: Definitions*. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/3
- **[63]** Model Context Protocol (2026). Architecture overview. https://modelcontextprotocol.io/docs/learn/architecture
- **[64]** Model Context Protocol (2026). Understanding MCP servers (documentation, rév. 2026-07-28). Model Context Protocol. https://modelcontextprotocol.io/docs/2026-07-28/learn/server-concepts
- **[65]** Schluntz, E. et Zhang, B. (2024, 19 décembre). Building effective agents (page de recherche). Anthropic. La page signe « Erik S. » (nom complet d'après des sources secondaires) et porte une note d'Anthropic : l'outillage décrit a changé depuis décembre 2024; le cadre n'en retient que les principes. Même source que [6]. https://www.anthropic.com/research/building-effective-agents
- **[66]** OpenAI (2025). A practical guide to building agents. OpenAI. https://cdn.openai.com/business-guides-and-resources/a-practical-guide-to-building-agents.pdf
- **[67]** Microsoft (2025). Saga design pattern. Azure Architecture Center. https://learn.microsoft.com/en-us/azure/architecture/patterns/saga
- **[68]** A2A Project (2026). Agent2Agent (A2A) Protocol Specification, version 1.0 (correctif 1.0.1 du 28 mai 2026). Linux Foundation / Agentic AI Foundation. Adresse « latest », qui suit la dernière version publiée; page consultée le 27 octobre 2026. https://a2a-protocol.org/latest/specification
- **[69]** Jones, M., Nadalin, A., Campbell, B., Bradley, J. et Mortimore, C. (2020, janvier). *RFC 8693 — OAuth 2.0 Token Exchange, §1.1*. RFC Editor. https://www.rfc-editor.org/rfc/rfc8693.html#section-1.1
- **[70]** Jones, M., Nadalin, A., Campbell, B., Bradley, J. et Mortimore, C. (2020, janvier). *RFC 8693 — OAuth 2.0 Token Exchange (§4.1 act claim, notice RFC Editor)*. RFC Editor. Même source que [69]. https://www.rfc-editor.org/rfc/rfc8693.html
- **[71]** Campbell, B., Bradley, J. et Tschofenig, H. (2020, février). RFC 8707 — Resource Indicators for OAuth 2.0. RFC Editor. https://www.rfc-editor.org/rfc/rfc8707.html
- **[72]** Bertocci, V. (2021, octobre). *RFC 9068 — JWT Profile for OAuth 2.0 Access Tokens*. RFC Editor. https://www.rfc-editor.org/rfc/rfc9068.html

- **[73]** Rose, S., Borchert, O., Mitchell, S. et Connelly, S. (2020). Zero Trust Architecture, NIST SP 800-207. NIST. https://doi.org/10.6028/NIST.SP.800-207
- **[74]** NIST (2023, janvier). *Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1*. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf
- **[75]** Amazon Web Services (2025, 21 novembre). Securing Agentic AI: The Agentic AI Security Scoping Matrix. AWS. https://aws.amazon.com/ai/security/agentic-ai-scoping-matrix
- **[76]** Infocomm Media Development Authority (2026). Model AI Governance Framework for Agentic AI, version 1.5. IMDA, Singapour. Version 1.5 publiée le 20 mai 2026. https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf
- **[77]** Microsoft (2026). Compensating Transaction pattern. Azure Architecture Center. https://learn.microsoft.com/en-us/azure/architecture/patterns/compensating-transaction
- **[78]** Jena, J., Dalal, S. et Tishkin, D. (2026, 22 octobre). The Idempotency-Key HTTP Header Field, draft-ietf-httpapi-idempotency-key-header-08 (Internet-Draft). IETF. https://datatracker.ietf.org/doc/draft-ietf-httpapi-idempotency-key-header
- **[79]** Temporal Technologies (s. d.). What is a Temporal Activity? Temporal Documentation. https://docs.temporal.io/activities
- **[80]** Temporal Technologies (s. d.). What is Temporal? (section « Durable Execution »). Temporal Documentation. https://docs.temporal.io/temporal
- **[81]** Temporal Technologies (s. d.). Temporal Workflow Execution overview. Temporal Documentation. https://docs.temporal.io/workflow-execution
- **[82]** LangChain (s. d.). LangGraph – Interrupts (documentation). LangChain. https://docs.langchain.com/oss/python/langgraph/interrupts
- **[83]** Feng, K. J. K., McDonald, D. W. et Zhang, A. X. (2025). Levels of Autonomy for AI Agents. arXiv:2506.12469 (v2); Knight First Amendment Institute, série « AI and Democratic Freedoms ». https://arxiv.org/abs/2506.12469
- **[84]** Yao, S., Zhao, J., Yu, D., Du, N., Shafran, I., Narasimhan, K. et Cao, Y. (2023). ReAct: Synergizing Reasoning and Acting in Language Models. ICLR 2023 (arXiv:2210.03629). https://arxiv.org/abs/2210.03629
- **[85]** Microsoft (2026, 23 octobre). *Microsoft Agent Framework Overview*. Microsoft Learn. https://learn.microsoft.com/en-us/agent-framework/overview
- **[86]** Chase, H. (2025, 14 janvier). Introducing ambient agents. LangChain. https://www.langchain.com/blog/introducing-ambient-agents
- **[87]** OWASP Agentic Security Initiative (2025). Agentic AI – Threats and Mitigations, version 1.1. OWASP Foundation. La page pointée présente la version 1.0 du 17 février 2025; la version 1.1 reste à vérifier dans le document. https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations
- **[88]** Anthropic (2026). Batch processing. Claude Platform Docs. https://platform.claude.com/docs/en/build-with-claude/batch-processing
- **[89]** OpenAI (2026). Batch API. OpenAI API Docs. https://developers.openai.com/api/docs/guides/batch
- **[90]** Microsoft (2026). Fundamental concepts in Microsoft Entra Agent ID. Microsoft Learn. https://learn.microsoft.com/en-us/entra/agent-id/key-concepts
- **[91]** OWASP (2025). OWASP Non-Human Identities Top 10 – 2025. OWASP Foundation. https://owasp.github.io/www-project-non-human-identities-top-10/2025
- **[92]** Microsoft (2026). Best practices for Microsoft Entra Agent ID. Microsoft Learn. https://learn.microsoft.com/en-us/entra/agent-id/best-practices-agent-id

- **[93]** Kasselman, P., Lombardo, J., Rosomakho, Y., Campbell, B., Steele, N. et Parecki, A. (2026, 15 septembre). AI Identity Management System (AIMS), draft-ietf-wimse-aims-00. IETF, groupe de travail WIMSE. Révision –01 publiée le 2 novembre 2026; le contenu cité est celui de la –00. https://www.ietf.org/archive/id/draft-ietf-wimse-aims-00.html
- **[94]** Future of Life Institute (2026). Article 26: Obligations of Deployers of High-Risk AI Systems. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/26
- **[95]** Gartner (2026). Gartner Says Applying Uniform Governance Across AI Agents Will Lead to Enterprise AI Agent Failure (communiqué, 26 mai 2026). Gartner. https://www.gartner.com/en/newsroom/press-releases/2026-05-26-gartner-says-applying-uniform-governance-across-ai-agents-will-lead-to-enterprise-ai-agent-failure
- **[96]** Microsoft (2025). Develop delegated permissions strategy. Microsoft Learn. https://learn.microsoft.com/en-us/security/zero-trust/develop/developer-strategy-delegated-permission
- **[97]** Vassilev, A., Oprea, A., Fordyce, A., Anderson, H., Davies, X. et Hamin, M. (2025). Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations (NIST AI 100-2 E2025). National Institute of Standards and Technology. https://csrc.nist.gov/pubs/ai/100/2/e2025/final
- **[98]** National Cyber Security Centre (2025). Prompt injection is not SQL injection (it may be worse). NCSC (Royaume-Uni). https://www.ncsc.gov.uk/blog-post/prompt-injection-is-not-sql-injection
- **[99]** National Institute of Standards and Technology (2023). Artificial Intelligence Risk Management Framework (AI RMF 1.0) — notice DOI NIST AI 100-1. NIST. Même source que [74]. https://doi.org/10.6028/NIST.AI.100-1
- **[100]** Sumers, T. R., Yao, S., Narasimhan, K. et Griffiths, T. L. (2024). Cognitive Architectures for Language Agents. Transactions on Machine Learning Research (arXiv:2309.02427). https://arxiv.org/abs/2309.02427
- **[101]** Debenedetti, E., Shumailov, I., Fan, T., Hayes, J., Carlini, N., Fabian, D., Kern, C., Shi, C., Terzis, A. et Tramèr, F. (2025). Defeating Prompt Injections by Design. arXiv:2503.18813. Chiffres cités d'après la version v2 (24 juin 2025). https://arxiv.org/abs/2503.18813
- **[102]** Amazon Web Services (2026). What is Amazon Bedrock AgentCore? Developer Guide. https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/what-is-bedrock-agentcore.html
- **[103]** W3C (2021, 23 novembre). Trace Context, W3C Recommendation. https://www.w3.org/TR/trace-context
- **[104]** Amazon Web Services (2026). Choosing workflow type in Step Functions. Developer Guide. https://docs.aws.amazon.com/step-functions/latest/dg/choosing-workflow-type.html
- **[105]** Microsoft (2026). Microsoft Agent Framework Workflows — Checkpoints. Microsoft Learn. https://learn.microsoft.com/en-us/agent-framework/workflows/checkpoints
- **[106]** Agent Router project (2026, 9 septembre). *Envoy AI Gateway is becoming Agent Router, an Agentic AI Foundation project.* https://theagentrouter.ai/blog/envoy-ai-gateway-is-now-agent-router
- **[107]** Microsoft (2026). Azure API Management policy reference – llm-token-limit. Microsoft Learn. https://learn.microsoft.com/en-us/azure/api-management/llm-token-limit-policy
- **[108]** Microsoft (2026). Overview of MCP servers in Azure API Management. Microsoft Learn. https://learn.microsoft.com/en-us/azure/api-management/mcp-server-overview
- **[109]** Microsoft (2026). Import an A2A Agent API — Azure API Management. Microsoft Learn. https://learn.microsoft.com/en-us/azure/api-management/agent-to-agent-api

- **[110]** Amazon Web Services (2026). Amazon Bedrock AgentCore Gateway: A secure AI gateway for agents, tools, and models. Developer Guide. https://docs.aws.amazon.com/bedrock-agentcore/latest/devguide/gateway.html
- **[111]** Kong Inc (2026). *AI A2A Proxy — Plugin*. https://developer.konghq.com/plugins/ai-a2a-proxy
- **[112]** Rose, S., Borchert, O., Mitchell, S. et Connelly, S. (2020). Zero Trust Architecture — NIST Special Publication 800-207 (fiche CSRC). NIST. Même source que [73]. https://csrc.nist.gov/pubs/sp/800/207/final
- **[113]** IBM (2026). ContextForge (mcp-context-forge), projet libre parrainé par IBM, dont la migration hors de l'organisation IBM est annoncée. GitHub. https://github.com/IBM/mcp-context-forge
- **[114]** Anthropic (Aizawa, K.) (2025, 11 septembre). Writing effective tools for agents — with agents. Anthropic. https://www.anthropic.com/engineering/writing-tools-for-agents
- **[115]** OpenAI (s. d.). Function calling. OpenAI API Documentation. https://developers.openai.com/api/docs/guides/function-calling
- **[116]** Cloud Native Computing Foundation (s. d., consultée le 27 octobre 2026). SPIFFE (page du projet; niveau « Graduated » depuis le 23 août 2022). CNCF. https://www.cncf.io/projects/spiffe
- **[117]** Cloud Native Computing Foundation (s. d., consultée le 27 octobre 2026). SPIRE (page du projet; niveau « Graduated » depuis le 22 août 2022). CNCF. https://www.cncf.io/projects/spire
- **[118]** Jones, M., Nadalin, A., Campbell, B., Bradley, J. et Mortimore, C. (2020, janvier). RFC 8693 — OAuth 2.0 Token Exchange (fiche Datatracker). IETF. Même source que [69]. https://datatracker.ietf.org/doc/rfc8693
- **[119]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative client AI spans (v1.41.0). https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-spans.md
- **[120]** OpenTelemetry (CNCF) (2026). *Semantic conventions for GenAI agent and framework spans (v1.41.0)*. https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-agent-spans.md
- **[121]** The Open Group (2022). The TOGAF Standard, 10th Edition. The Open Group. https://www.opengroup.org/togaf
- **[122]** Davis, C. (2025, 30 juillet; mis à jour le 23 mars 2026). Production-ready agents with the OpenAI Agents SDK + Temporal. Temporal Blog. https://temporal.io/blog/announcing-openai-agents-sdk-integration
- **[123]** Runkle, S. et équipe OSS LangChain (2025, 22 octobre). LangChain and LangGraph Agent Frameworks Reach v1.0 Milestones. LangChain. https://www.langchain.com/blog/langchain-langgraph-1dot0
- **[124]** LangChain (documentation LangGraph) (s. d.). LangGraph — Persistence. https://docs.langchain.com/oss/python/langgraph/persistence
- **[125]** Henry, S. (2026, 3 avril). Microsoft Agent Framework Version 1.0. Microsoft DevBlogs. https://devblogs.microsoft.com/agent-framework/microsoft-agent-framework-version-1-0
- **[126]** Google (2026). Agent Development Kit (ADK). Documentation. https://adk.dev/
- **[127]** OpenAI (2026). OpenAI Agents SDK. Documentation. https://openai.github.io/openai-agents-python
- **[128]** Liguori, C. (2025, 16 mai). Introducing Strands Agents, an Open Source AI Agents SDK. AWS Open Source Blog. https://aws.amazon.com/blogs/opensource/introducing-strands-agents-an-open-source-ai-agents-sdk
- **[129]** Strands Agents (s. d.). Agent-to-Agent (A2A) Protocol. Strands Agents Documentation. https://strandsagents.com/latest/documentation/docs/user-guide/concepts/multi-agent/agent-to-agent

- **[130]** Agentic AI Foundation (s. d.). Projects. Agentic AI Foundation (AAIF). https://aaif.io/projects
- **[131]** agentgateway / Agentic AI Foundation (LF Projects) (2026). *agentgateway (site officiel)*. https://agentgateway.dev/
- **[132]** Kong Inc. (2026). Kong AI Gateway. Documentation. https://developer.konghq.com/ai-gateway
- **[133]** Projet Firecracker (s. d.). Firecracker – Secure and fast microVMs for serverless computing. https://firecracker-microvm.github.io/
- **[134]** Projet gVisor (s. d.). gVisor Documentation – What is gVisor?, Performance Guide et GPU Support. Google. https://gvisor.dev/docs
- **[135]** OpenInfra Foundation (s. d.). Kata Containers. https://katacontainers.io/
- **[136]** WASI Subgroup, WebAssembly Community Group (s. d.). Introduction. WASI.dev. https://wasi.dev/
- **[137]** Kubernetes SIG Apps (2026). agent-sandbox. GitHub kubernetes-sigs. https://github.com/kubernetes-sigs/agent-sandbox
- **[138]** Salesforce (2025). Salesforce Launches MuleSoft Agent Fabric to Orchestrate and Govern Any AI Agent Across the Agentic Enterprise. 25 septembre 2025. https://www.salesforce.com/news/stories/mulesoft-agent-fabric-announcement
- **[139]** Cloudflare (2026). MCP server portals. Cloudflare One docs. https://developers.cloudflare.com/cloudflare-one/access-controls/ai-controls/mcp-portals
- **[140]** Apache Software Foundation (2026). Apache Kafka 4.4 Documentation – Design (Message Delivery Semantics). https://kafka.apache.org/44/design/design
- **[141]** OpenTelemetry (2026). Redaction processor, OpenTelemetry Collector Contrib. https://github.com/open-telemetry/opentelemetry-collector-contrib/tree/main/processor/redactionprocessor
- **[142]** Sun, L. (2026, 4 juin). Designing agentgateway: A Unified High-Performance Gateway for AI and API Traffic. Agentic AI Foundation (AAIF); republié sur agentgateway.dev. https://aaif.io/blog/designing-agentgateway-a-unified-high-performance-gateway-for-ai-and-api-traffic/
- **[143]** TrueFoundry (2026). *Introduction to AI Gateway*. https://www.truefoundry.com/docs/ai-gateway/intro-to-llm-gateway
- **[144]** TrueFoundry (2026). TrueFoundry AI Gateway Plane Architecture. Documentation. https://www.truefoundry.com/docs/platform/gateway-plane-architecture
- **[145]** OpenAI (2026). GPT-6.1 Sol — Model. OpenAI API Documentation. https://developers.openai.com/api/docs/models/gpt-6.1-sol
- **[146]** OpenAI (2026). GPT-5.5 — Model. OpenAI API Documentation. https://developers.openai.com/api/docs/models/gpt-5.5
- **[147]** Google (2025). A new era of intelligence with Gemini 3. Google Blog. https://blog.google/products/gemini/gemini-3
- **[148]** Liu, N. F., Lin, K., Hewitt, J., Paranjape, A., Bevilacqua, M., Petroni, F. et Liang, P. (2024). Lost in the Middle: How Language Models Use Long Contexts. Transactions of the ACL, 12, 157–173. https://aclanthology.org/2024.tacl-1.9
- **[149]** Anthropic (Rajasekaran, P., Dixon, E., Ryan, C. et Hadfield, J.) (2025, 29 septembre). Effective context engineering for AI agents. Anthropic. https://www.anthropic.com/engineering/effective-context-engineering-for-ai-agents
- **[150]** Hong, K., Troynikov, A. et Huber, J. (2025). Context Rot: How Increasing Input Tokens Impacts LLM Performance. Chroma. https://www.trychroma.com/research/context-rot

- **[151]** LangChain (s. d.). Memory overview. Documentation LangChain. https://docs.langchain.com/oss/python/concepts/memory
- **[152]** Anthropic (s. d.). Memory tool. Claude Platform Docs. https://platform.claude.com/docs/en/agents-and-tools/tool-use/memory-tool
- **[153]** Packer, C., Wooders, S., Lin, K., Fang, V., Patil, S. G., Stoica, I. et Gonzalez, J. E. (2023). MemGPT: Towards LLMs as Operating Systems. arXiv:2310.08560. https://arxiv.org/abs/2310.08560
- **[154]** Letta (2024, 23 septembre). *MemGPT is now part of Letta*. https://www.letta.com/blog/memgpt-and-letta
- **[155]** Rasmussen, P., Paliychuk, P., Beauvais, T., Ryan, J. et Chalef, D. (2025). Zep: A Temporal Knowledge Graph Architecture for Agent Memory. arXiv:2501.13956. https://arxiv.org/abs/2501.13956
- **[156]** Edge, D., Trinh, H., Cheng, N. et al. (2024). From Local to Global: A Graph RAG Approach to Query-Focused Summarization. arXiv:2404.16130. https://arxiv.org/abs/2404.16130
- **[157]** Commission européenne (2017). New European Interoperability Framework — Promoting seamless services and data flows for European public administrations. Office des publications de l'Union européenne. https://doi.org/10.2799/78681. https://ec.europa.eu/isa2/sites/default/files/eif_brochure_final.pdf
- **[158]** Commission européenne — Interoperable Europe Portal (s. d.). The European Interoperability Framework in detail. https://interoperable-europe.ec.europa.eu/collection/nifo-national-interoperability-framework-observatory/european-interoperability-framework-detail
- **[159]** Commission européenne — Interoperable Europe Portal (s. d.). Interoperable Europe Act. https://interoperable-europe.ec.europa.eu/interoperable-europe/interoperable-europe-act
- **[160]** Québec (2023). Loi sur la protection des renseignements personnels dans le secteur privé, RLRQ c. P-39.1, art. 12.1. LégisQuébec. https://www.legisquebec.gouv.qc.ca/fr/document/lc/P-39.1
- **[161]** A2A Project (s. d.). Enterprise Implementation of A2A. https://a2a-protocol.org/latest/topics/enterprise-ready
- **[162]** Model Context Protocol (2026). Base Protocol — Overview (_meta, statelessness, error codes). https://modelcontextprotocol.io/specification/2026-07-28/basic/index
- **[163]** JSON Schema (s. d.). Spécification JSON Schema, dialecte 2020-12 (Core et Validation). JSON Schema. https://json-schema.org/specification
- **[164]** AG-UI Protocol (s. d.). AG-UI Overview. https://docs.ag-ui.com/introduction
- **[165]** AG-UI Protocol (s. d.). Events (documentation AG-UI). https://docs.ag-ui.com/concepts/events
- **[166]** AG-UI Protocol (2026). *ag-ui-protocol/ag-ui*. https://github.com/ag-ui-protocol/ag-ui
- **[167]** Waehner, K. (2026, 10 avril). MCP vs. REST/HTTP API vs. Kafka: The Architect's Guide to Agentic AI Integration. https://www.kai-waehner.de/blog/2026/04/10/mcp-vs-rest-http-api-vs-kafka-the-architects-guide-to-agentic-ai-integration
- **[168]** Model Context Protocol (2026). Key Changes — 2026-07-28 (journal des modifications). https://modelcontextprotocol.io/specification/2026-07-28/changelog
- **[169]** Model Context Protocol (2026). Extensions Overview. https://modelcontextprotocol.io/docs/extensions/overview
- **[170]** OpenAPI Initiative (2026). OpenAPI Specification v3.2.1, 10 septembre 2026. Linux Foundation. https://spec.openapis.org/oas/v3.2.1.html
- **[171]** Nottingham, M., Wilde, E. et Dalal, S. (2023). RFC 9457 — Problem Details for HTTP APIs. IETF. https://www.rfc-editor.org/rfc/rfc9457.html

- **[172]** OpenAPI Initiative (2026). Arazzo Specification 1.1.0, 17 mai 2026. Linux Foundation. https://spec.openapis.org/arazzo/latest.html
- **[173]** CloudEvents (2022). CloudEvents Specification, version 1.0.2 (publication ce@v1.0.2). CNCF. https://github.com/cloudevents/spec/releases
- **[174]** AsyncAPI Initiative (2026). AsyncAPI Spec 3.1.0 Release Notes, 31 janvier 2026. Linux Foundation. https://www.asyncapi.com/blog/release-notes-3.1.0
- **[175]** Lodderstedt, T., Bradley, J., Labunets, A. et Fett, D. (2025, janvier). *RFC 9700 — Best Current Practice for OAuth 2.0 Security (BCP 240)*. RFC Editor. https://www.rfc-editor.org/rfc/rfc9700.html
- **[176]** Hardt, D., Parecki, A. et Lodderstedt, T. (2026). The OAuth 2.1 Authorization Framework, draft-ietf-oauth-v2-1-16 (Internet-Draft, travail en cours). IETF. Révision –17 publiée le 31 octobre 2026, qui expire le 4 mai 2027 ([481]). https://datatracker.ietf.org/doc/draft-ietf-oauth-v2-1
- **[177]** Parecki, A., McGuinness, K. et Campbell, B. (2026). Identity Assertion JWT Authorization Grant, draft-ietf-oauth-identity-assertion-authz-grant-04 (Internet-Draft). IETF. Révision –06 publiée le 31 octobre 2026 ([482]). https://datatracker.ietf.org/doc/draft-ietf-oauth-identity-assertion-authz-grant
- **[178]** Model Context Protocol (2026). Enterprise-Managed Authorization (extension). https://modelcontextprotocol.io/extensions/auth/enterprise-managed-authorization
- **[179]** Tulshibagwale, A., Fletcher, G. et Kasselman, P. (2026, 30 juillet). *Transaction Tokens (draft-ietf-oauth-transaction-tokens-11), §6*. https://www.ietf.org/archive/id/draft-ietf-oauth-transaction-tokens-11.html
- **[180]** OpenTelemetry (2026). Semantic Conventions – CHANGELOG (v1.37.0 à v1.44.0). CNCF. https://github.com/open-telemetry/semantic-conventions/blob/main/CHANGELOG.md
- **[181]** OpenTelemetry (2026). Semantic Conventions for Generative AI (dépôt semantic-conventions-genai, statut Development). CNCF. https://github.com/open-telemetry/semantic-conventions-genai
- **[182]** AGNTCY (2026). Documentation AGNTCY (OASF, Directory, SLIM, Identity, SHADI, Observe, CSIT). https://docs.agntcy.org/
- **[183]** OpenAI et Stripe (2025-2026). Agentic Commerce Protocol (spécification, bêta). GitHub. https://github.com/agentic-commerce-protocol/agentic-commerce-protocol
- **[184]** Google (2026, 11 janvier). Under the hood: Universal Commerce Protocol (UCP). Google for Developers Blog. https://developers.googleblog.com/en/under-the-hood-universal-commerce-protocol-ucp
- **[185]** ANP Community (2026). Agent Network Protocol. GitHub. https://github.com/agent-network-protocol/AgentNetworkProtocol
- **[186]** Chang, G., Lin, E., Yuan, C., Cai, R., Chen, B., Xie, X., Zhang, Y. et ANP Open Source Technology Community (2025). Agent Network Protocol Technical White Paper. arXiv:2508.00007. https://arxiv.org/html/2508.00007v1
- **[187]** CloudEvents (CNCF) (2026). CloudEvents Extension Attributes. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/README.md
- **[188]** OpenTelemetry (2026). Versioning and stability for OpenTelemetry clients. https://opentelemetry.io/docs/specs/otel/versioning-and-stability
- **[189]** Model Context Protocol (2026). Documentation Index (llms.txt). Model Context Protocol. Index de la documentation, qui énumère les révisions 2024-11-05, 2025-03-26, 2025-06-18, 2025-11-25 et 2026-07-28 (vérifié le 4 novembre 2026); appui d'appoint, cité avec [34]. https://modelcontextprotocol.io/llms.txt
- **[190]** Model Context Protocol (2026). Transports — Streamable HTTP (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/basic/transports/streamable-http

- **[191]** Model Context Protocol (2026). Tasks (extension). https://modelcontextprotocol.io/extensions/tasks/overview
- **[192]** A2A Project (2026). a2a.proto — définition normative Protocol Buffers. GitHub a2aproject/A2A. https://github.com/a2aproject/A2A/blob/main/specification/a2a.proto
- **[193]** Anthropic (2025, 9 décembre). Donating the Model Context Protocol and establishing the Agentic AI Foundation. Anthropic. https://www.anthropic.com/news/donating-the-model-context-protocol-and-establishing-of-the-agentic-ai-foundation
- **[194]** Soria Parra, D. et Delimarsky, D. (2026). The 2026-07-28 MCP Specification Release Candidate. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/2026-07-28-release-candidate
- **[195]** Soria Parra, D. et Delimarsky, D. (2026). The New MCP Roadmap. Model Context Protocol Blog. https://blog.modelcontextprotocol.io/posts/mcp-roadmap
- **[196]** Model Context Protocol (2026). Deprecated Features (registre des fonctionnalités dépréciées). https://modelcontextprotocol.io/specification/2026-07-28/deprecated
- **[197]** Model Context Protocol (2026). Server Features — Tools (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/server/tools
- **[198]** Model Context Protocol (2026). Specification — révision 2026-07-28. Agentic AI Foundation / Linux Foundation. https://modelcontextprotocol.io/specification/2026-07-28
- **[199]** Model Context Protocol (2026). Server Utilities — Caching (rév. 2026-07-28). Model Context Protocol. https://modelcontextprotocol.io/specification/2026-07-28/server/utilities/caching
- **[200]** Model Context Protocol (2026). Multi Round-Trip Requests. https://modelcontextprotocol.io/specification/2026-07-28/basic/patterns/mrtr
- **[201]** Model Context Protocol (2026). Schema Reference (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/schema
- **[202]** Model Context Protocol (2026). MCP Apps (extension). https://modelcontextprotocol.io/extensions/apps/overview
- **[203]** Zavodchik, M., Fogel, S. et Meiri, G. (2026). The New MCP Specification: What Security Teams Must Prepare For. Akamai Security Research. https://www.akamai.com/blog/security-research/new-mcp-specification-security-teams-must-prepare
- **[204]** Model Context Protocol (2026). Client Best Practices. https://modelcontextprotocol.io/docs/2026-07-28/develop/clients/client-best-practices
- **[205]** Anthropic (Wu, B.) (2025, 24 novembre). Introducing advanced tool use on the Claude Developer Platform. Anthropic. https://www.anthropic.com/engineering/advanced-tool-use
- **[206]** Model Context Protocol (2025, 26 mars). *Key Changes — 2025-03-26*. https://modelcontextprotocol.io/specification/2025-03-26/changelog
- **[207]** Model Context Protocol (2026, 28 juillet). *Transports — Overview (MCP 2026-07-28)*. https://modelcontextprotocol.io/specification/2026-07-28/basic/transports
- **[208]** Model Context Protocol (2026). Security Best Practices (rév. 2026-07-28). https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices
- **[209]** Model Context Protocol (2026). Authorization — Specification 2026-07-28. https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization
- **[210]** Hardt, D., Parecki, A. et Lodderstedt, T. (2025, 28 mai). The OAuth 2.1 Authorization Framework, draft-ietf-oauth-v2-1-13 (Internet-Draft; remplacée par la –16 du 3 septembre 2026, puis par la –17 du 31 octobre 2026). IETF. https://datatracker.ietf.org/doc/html/draft-ietf-oauth-v2-1-13

- **[211]** Jones, M. B., Hunt, P. et Parecki, A. (2025, avril). RFC 9728 — OAuth 2.0 Protected Resource Metadata. IETF. https://datatracker.ietf.org/doc/html/rfc9728
- **[212]** Meyer zu Selhausen, K. et Fett, D. (2022, mars). RFC 9207 — OAuth 2.0 Authorization Server Issuer Identification. IETF. https://datatracker.ietf.org/doc/html/rfc9207
- **[213]** Fett, D., Campbell, B., Bradley, J., Lodderstedt, T., Jones, M. et Waite, D. (2023, septembre). *RFC 9449 — OAuth 2.0 Demonstrating Proof of Possession (DPoP).* RFC Editor. https://www.rfc-editor.org/rfc/rfc9449.html
- **[214]** Model Context Protocol (2026). Client Registration (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/basic/authorization/client-registration
- **[215]** Model Context Protocol (2025, 25 novembre). Key Changes — 2025-11-25. https://modelcontextprotocol.io/specification/2025-11-25/changelog
- **[216]** Parecki, A. et Smith, E. (2026, 6 juillet). OAuth Client ID Metadata Document (draft-ietf-oauth-client-id-metadata-document-02). IETF. https://www.ietf.org/archive/id/draft-ietf-oauth-client-id-metadata-document-02.html
- **[217]** Model Context Protocol (2026, 28 juillet). MCP Authorization Extensions (ext-auth): Enterprise-Managed Authorization et OAuth Client Credentials, extensions stables, révision 2026-07-28. GitHub. https://github.com/modelcontextprotocol/ext-auth
- **[218]** Model Context Protocol (2026, 28 juillet). *Enterprise-Managed Authorization (2026-07-28).* Même source que [178]. https://raw.githubusercontent.com/modelcontextprotocol/ext-auth/main/specification/stable/enterprise-managed-authorization/2026-07-28/enterprise-managed-authorization.mdx
- **[219]** OpenTelemetry (2026). Semantic conventions for Model Context Protocol (MCP). OpenTelemetry (GitHub). Même source que [386], lue sur la branche principale du dépôt dédié; [386], à une étiquette, fait foi. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/mcp.md
- **[220]** Beurer-Kellner, L. et Fischer, M. (2025). MCP Security Notification: Tool Poisoning Attacks. Invariant Labs. https://invariantlabs.ai/blog/mcp-security-notification-tool-poisoning-attacks
- **[221]** OWASP (2026). MCP Security Cheat Sheet. OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/cheatsheets/MCP_Security_Cheat_Sheet.html
- **[222]** OWASP (2025). OWASP MCP Top 10 (édition 2025, bêta). OWASP Foundation. https://owasp.org/www-project-mcp-top-10
- **[223]** Model Context Protocol (2026). Client Features — Elicitation (rév. 2026-07-28). https://modelcontextprotocol.io/specification/2026-07-28/client/elicitation
- **[224]** Hou, X., Zhao, Y., Wang, S. et Wang, H. (2025). Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions. arXiv:2503.23278. https://arxiv.org/abs/2503.23278
- **[225]** Model Context Protocol (GitHub) (2026). *MCP Conformance Test Framework.* https://github.com/modelcontextprotocol/conformance
- **[226]** Model Context Protocol (2026). @modelcontextprotocol/conformance (métadonnées du paquet : 0.1.16 courante, 0.2.0-alpha.12 du 1er octobre 2026). Registre npm. https://registry.npmjs.org/@modelcontextprotocol/conformance
- **[227]** Model Context Protocol (2026). Server Features — Resources (rév. 2026-07-28). Model Context Protocol. https://modelcontextprotocol.io/specification/2026-07-28/server/resources
- **[228]** Surapaneni, R. et Stephens, P. (2025, 31 juillet). Announcing a complete developer toolkit for scaling A2A agents on Google Cloud. Google Cloud Blog. Titre de la page; l'onglet et le chemin de

l'adresse portent un autre libellé, « Agent2Agent protocol (A2A) is getting an upgrade ». https://cloud.google.com/blog/products/ai-machine-learning/agent2agent-protocol-is-getting-an-upgrade

- **[229]** A2A Project (2025, 30 juillet). Release v0.3.0. GitHub a2aproject/A2A. https://github.com/a2aproject/A2A/releases/tag/v0.3.0
- **[230]** i-am-bee (IBM Research) (2025, 25 août). ACP Joins Forces with A2A Under the Linux Foundation (discussion no 5). GitHub. https://github.com/orgs/i-am-bee/discussions/5
- **[231]** A2A Project (s. d.). SDKs. Adresse « latest », qui suit la dernière version publiée; page consultée le 27 octobre 2026. https://a2a-protocol.org/latest/sdk
- **[232]** A2A Project (s. d., consulté le 27 octobre 2026). a2aproject (organisation GitHub). GitHub. https://github.com/a2aproject
- **[233]** AGNTCY (2026). agntcy/acp-spec — Agent Connect Protocol (dépôt archivé). GitHub. https://github.com/agntcy/acp-spec
- **[234]** Zed Industries (2026). Agent Client Protocol. Zed. https://zed.dev/acp
- **[235]** A2A Project (2026). What's New in A2A Protocol v1.0. GitHub a2aproject/A2A. https://github.com/a2aproject/A2A/blob/main/docs/whats-new-v1.md
- **[236]** Rundgren, A., Jordan, B. et Erdtman, S. (2020, juin). RFC 8785 — JSON Canonicalization Scheme (JCS). RFC Editor (soumission indépendante). https://www.rfc-editor.org/rfc/rfc8785.html
- **[237]** A2A Project (s. d.). Agent Discovery. Adresse « latest », qui suit la dernière version publiée; page consultée le 27 octobre 2026. https://a2a-protocol.org/latest/topics/agent-discovery
- **[238]** A2A Project (s. d.). Extensions in A2A. Adresse « latest », qui suit la dernière version publiée; page consultée le 27 octobre 2026. https://a2a-protocol.org/latest/topics/extensions
- **[239]** AGNTCY (2026). A2A over SLIM. AGNTCY, a Series of LF Projects, LLC. https://slim.agntcy.org/latest/slim/integrations/a2a
- **[240]** A2A Project (2026). *What's New in A2A Protocol v1.0.* Même source que [235]. https://a2a-protocol.org/latest/whats-new-v1
- **[241]** OpenTelemetry (2026). Semantic conventions for Agent2Agent Protocol (A2A) (statut Development, branche main). GitHub, open-telemetry/semantic-conventions-genai. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/a2a.md
- **[242]** Ghumare, R. (2026, 1er septembre). A2A v1.0: a builder's guide, part 2 - migration, security, and production. Agentic AI Foundation (AAIF). https://aaif.io/blog/a2a-v1-0-a-builder-s-guide-part-2-migration-security-and-production. La date de disponibilité générale du SDK JavaScript (22 juillet 2026) est celle de la publication v1.0.0 de `@a2a-js/sdk`, vérifiée le 4 novembre 2026 sur la page des versions du dépôt a2aproject/a2a-js : https://github.com/a2aproject/a2a-js/releases/tag/v1.0.0
- **[243]** A2A Project (s. d.). A2A Technology Compatibility Kit (a2a-tck). GitHub. https://github.com/a2aproject/a2a-tck
- **[244]** A2A Project (2026, 1er octobre). Meet the A2A CLI: discover, message, and manage agents from your terminal. https://a2a-protocol.org/latest/blog/2026/10/01/introducing-a2a-cli
- **[245]** A2A Project (2026). a2a-cli, versions publiées (v0.2.0 du 9 septembre 2026 à v0.3.1 du 16 octobre 2026). GitHub a2aproject/a2a-cli. https://github.com/a2aproject/a2a-cli/releases
- **[246]** Waehner, K. (s. d.). About. kai-waehner.de. Page de présentation de l'auteur (catégorie C au sens du tableau 66), sans valeur d'appui. https://kai-waehner.de/about
- **[247]** Cloud Native Computing Foundation (2024, 25 janvier). Cloud Native Computing Foundation Announces the Graduation of CloudEvents. CNCF. https://www.cncf.io/announcements/2024/01/25/cloud-native-computing-foundation-announces-the-graduation-of-cloudevents

- **[248]** CloudEvents (2022, 6 février). CloudEvents – Version 1.0.2 (spécification, balise ce@v1.0.2). CNCF. Même source que [173]. https://github.com/cloudevents/spec/blob/ce@v1.0.2/cloudevents/spec.md
- **[249]** AsyncAPI Initiative (2023). AsyncAPI 3.0.0 Release Notes, 5 décembre 2023. Linux Foundation. https://www.asyncapi.com/blog/release-notes-3.0.0
- **[250]** CloudEvents (2022, 6 février). Kafka Protocol Binding for CloudEvents, version 1.0.2 (balise ce@v1.0.2). CNCF. https://github.com/cloudevents/spec/blob/ce@v1.0.2/cloudevents/bindings/kafka-protocol-binding.md
- **[251]** CloudEvents (2022, 6 février). CloudEvents – Documented Extensions, version 1.0.2 (balise ce@v1.0.2). CNCF. https://github.com/cloudevents/spec/blob/ce@v1.0.2/cloudevents/documented-extensions.md
- **[252]** CloudEvents (2026). Auth Context. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/authcontext.md
- **[253]** CloudEvents (2026). Distributed Tracing Extension. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/distributed-tracing.md
- **[254]** OpenTelemetry (2026). Semantic conventions for messaging spans. https://opentelemetry.io/docs/specs/semconv/messaging/messaging-spans
- **[255]** CloudEvents (2026). Data Classification Extension. CNCF. https://github.com/cloudevents/spec/blob/main/cloudevents/extensions/data-classification.md
- **[256]** Apache Software Foundation (2017). KIP-98 – Exactly Once Delivery and Transactional Messaging. https://cwiki.apache.org/confluence/display/KAFKA/KIP-98+-+Exactly+Once+Delivery+and+Transactional+Messaging
- **[257]** Apache Software Foundation (2026). *Apache Kafka 4.4 – Introduction*. https://kafka.apache.org/44/getting-started/introduction
- **[258]** Apache Software Foundation (2026). KIP-932: Queues for Kafka. https://cwiki.apache.org/confluence/display/KAFKA/KIP-932%3A+Queues+for+Kafka
- **[259]** Apache Software Foundation (2025, 18 mars). Apache Kafka 4.0.0 Release Announcement. https://kafka.apache.org/blog/2025/03/18/apache-kafka-4.0.0-release-announcement
- **[260]** Apache Software Foundation (2026, 17 février). Apache Kafka 4.2.0 Release Announcement. https://kafka.apache.org/blog/2026/02/17/apache-kafka-4.2.0-release-announcement
- **[261]** Apache Software Foundation (2026, 22 octobre). Apache Kafka 4.4.0 Release Announcement. https://kafka.apache.org/blog/2026/10/22/apache-kafka-4.4.0-release-announcement
- **[262]** Confluent (2026, 25 mai). *Autonomous Agentic Event-Driven Systems Architecture*. Argument d'éditeur (catégorie C au sens du tableau 66), cité comme tel, jamais à l'appui d'une exigence. https://www.confluent.io/blog/autonomous-agentic-event-driven-systems-architecture
- **[263]** Agentic AI Foundation (2026). Project Proposal Process. GitHub aaif/technical-committee. https://github.com/aaif/technical-committee/blob/main/project_proposal_process.md
- **[264]** AGNTCY (2026). *Open Agentic Schema Framework*. https://docs.agntcy.org/oasf/open-agentic-schema-framework
- **[265]** AGNTCY (2026). Directory — Import. AGNTCY, a Series of LF Projects, LLC. https://dir.agntcy.org/latest/dir/dir-component-import
- **[266]** AGNTCY (2026). *Directory — Store*. https://dir.agntcy.org/latest/dir/dir-component-store
- **[267]** AGNTCY (2026). CLI Reference — Agent Directory Service. AGNTCY, a Series of LF Projects, LLC. https://dir.agntcy.org/latest/dir/dir-cli-reference

- **[268]** AGNTCY (2026). Introduction — SLIM. AGNTCY, a Series of LF Projects, LLC. https://slim.agntcy.org/latest/slim/slim-overview
- **[269]** Barnes, R. et al. (2023). RFC 9420 — The Messaging Layer Security (MLS) Protocol. IETF. https://www.rfc-editor.org/rfc/rfc9420.html
- **[270]** AGNTCY (2026). Identity — Introduction. AGNTCY. https://spec.identity.agntcy.org/docs/intro
- **[271]** Muscariello, L. et Polic, R. (2026). Agent Directory Service, draft-mp-agntcy-ads-02. IETF (soumission individuelle). https://datatracker.ietf.org/doc/draft-mp-agntcy-ads
- **[272]** Muscariello, L., Papalini, M., Sardara, M. et Betts, S. (2026). Secure Low-Latency Interactive Messaging (SLIM), draft-mpsb-agntcy-slim-02. IETF (soumission individuelle). https://datatracker.ietf.org/doc/draft-mpsb-agntcy-slim
- **[273]** Kim, Y. et Liu, X. (2026, 28 janvier). Towards a science of scaling agent systems: When and why agent systems work. Google Research. Article associé : [274]. https://research.google/blog/towards-a-science-of-scaling-agent-systems-when-and-why-agent-systems-work
- **[274]** Kim, Y., Gu, K., Park, C. et al. (2025). Towards a Science of Scaling Agent Systems. arXiv:2512.08296 (v3, 2026). https://arxiv.org/abs/2512.08296
- **[275]** Phillips, C. (2026, 23 janvier). Building multi-agent systems: When and how to use them. Anthropic. https://claude.com/resources/articles/building-multi-agent-systems-when-and-how-to-use-them
- **[276]** Yan, W. (2025). Don't Build Multi-Agents. Cognition. Argument d'éditeur (catégorie C au sens du tableau 66), cité comme tel, jamais à l'appui d'une exigence. https://cognition.com/blog/dont-build-multi-agents
- **[277]** Chase, H. (2025). How and when to build multi-agent systems. LangChain Blog. Argument d'éditeur (catégorie C au sens du tableau 66), cité comme tel, jamais à l'appui d'une exigence. https://www.langchain.com/blog/how-and-when-to-build-multi-agent-systems
- **[278]** Microsoft (2026). Microsoft Agent Framework Workflows Orchestrations – Magentic. Microsoft Learn. https://learn.microsoft.com/en-us/agent-framework/workflows/orchestrations/magentic
- **[279]** Fourney, A., Bansal, G., Mozannar, H. et al. (2024). Magentic-One: A Generalist Multi-Agent System for Solving Complex Tasks. arXiv:2411.04468. https://arxiv.org/abs/2411.04468
- **[280]** Papadopoulos, V., Shah, M., Zimmerman, S. et Lindsey, J. (2026). Mind Viruses: Self-Propagating Ideas in Multi-Agent LLM Systems. arXiv:2608.10218. https://arxiv.org/abs/2608.10218
- **[281]** Anthropic (s. d.). Tool search tool. Claude Platform Docs. https://platform.claude.com/docs/en/agents-and-tools/tool-use/tool-search-tool
- **[282]** LangChain (s. d.). LangGraph – Checkpointers (documentation). LangChain. https://docs.langchain.com/oss/python/langgraph/checkpointers
- **[283]** LangChain (documentation LangGraph) (s. d.). Use time-travel. https://docs.langchain.com/oss/python/langgraph/use-time-travel
- **[284]** Garcia-Molina, H. et Salem, K. (1987). Sagas. Proceedings of the 1987 ACM SIGMOD International Conference on Management of Data, p. 249–259. ACM. https://doi.org/10.1145/38713.38742
- **[285]** Garcia-Molina, H. et Salem, K. (1987, janvier). SAGAS (rapport technique TR-070-87). Princeton University, Department of Computer Science. https://www.cs.princeton.edu/research/techreps/598
- **[286]** Temporal Technologies (s. d.). Saga Pattern. Temporal Documentation. https://docs.temporal.io/design-patterns/saga-pattern
- **[287]** Chang, E. Y. et Geng, L. (2025). SagaLLM: Context Management, Validation, and Transaction Guarantees for Multi-Agent LLM Planning. Proceedings of the VLDB Endowment, 18(12), 4874–4886. doi:10.14778/3750601.3750611. https://www.vldb.org/pvldb/vol18/p4874-chang.pdf

- **[288]** Chang, E. Y. et Geng, L. (2025). SagaLLM: Context Management, Validation, and Transaction Guarantees for Multi-Agent LLM Planning (prépublication arXiv:2503.11951 v3). Proceedings of the VLDB Endowment, 18(12), 4874-4886. Même source que [287]. https://arxiv.org/abs/2503.11951
- **[289]** Yan, W. (2026, 22 avril). Multi-Agents: What's Actually Working. Cognition. Argument d'éditeur (catégorie C au sens du tableau 66), cité comme tel, jamais à l'appui d'une exigence. https://cognition.com/blog/multi-agents-working
- **[290]** Future of Life Institute (2026). Article 14: Human Oversight. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/14
- **[291]** Shavit, Y., Agarwal, S., Brundage, M. et al. (2023). Practices for Governing Agentic AI Systems. OpenAI. https://cdn.openai.com/papers/practices-for-governing-agentic-ai-systems.pdf
- **[292]** Cemri, M., Pan, M. Z., Yang, S. et al. (2025). Why Do Multi-Agent LLM Systems Fail? arXiv:2503.13657. Version citée : v3 (26 octobre 2025). https://arxiv.org/abs/2503.13657
- **[293]** Microsoft (GitHub) (2026, 2 avril). *Release python-1.0.0 · microsoft/agent-framework*. https://github.com/microsoft/agent-framework/releases/tag/python-1.0.0
- **[294]** Microsoft (2026, 12 février). *Workflow orchestrations in Agent Framework*. Microsoft Learn. https://learn.microsoft.com/en-us/agent-framework/workflows/orchestrations
- **[295]** Microsoft (2026). Observability — Microsoft Agent Framework. Microsoft Learn. https://learn.microsoft.com/en-us/agent-framework/agents/observability
- **[296]** CrewAI (s. d.). Introduction — CrewAI Documentation. https://docs.crewai.com/en/introduction
- **[297]** Google (s. d.). Template agent workflows. Agent Development Kit (ADK). https://adk.dev/agents/workflow-agents
- **[298]** Cheng, L. (2025, 19 mai). Multi-agent orchestration, maker controls, and more: Microsoft Copilot Studio announcements at Microsoft Build 2025. Microsoft Copilot Blog. https://www.microsoft.com/en-us/copilot/blog/copilot-studio/multi-agent-orchestration-maker-controls-and-more-microsoft-copilot-studio-announcements-at-microsoft-build-2025/
- **[299]** Chopra, N. (2026, 1er avril). New and improved: Multi-agent orchestration, connected experiences, and faster prompt iteration. Microsoft Copilot Blog. https://www.microsoft.com/en-us/copilot/blog/copilot-studio/new-and-improved-multi-agent-orchestration-connected-experiences-and-faster-prompt-iteration
- **[300]** Desai, Z. (2025, 29 mai). Model Context Protocol (MCP) is now generally available in Microsoft Copilot Studio. Microsoft Copilot Blog. https://www.microsoft.com/en-us/copilot/blog/copilot-studio/model-context-protocol-mcp-is-now-generally-available-in-microsoft-copilot-studio/
- **[301]** Salvi, A. (2022, 13 octobre). Operational Design Domain – Narrow frame provides safety. SAFE INTELLIGENCE, Fraunhofer IKS. https://safe-intelligence.fraunhofer.de/en/articles/odd-narrow-frame-provides-safety
- **[302]** Morris, M. R., Sohl-Dickstein, J., Fiedel, N., Warkentin, T., Dafoe, A., Faust, A., Farabet, C. et Legg, S. (2024). Position: Levels of AGI for Operationalizing Progress on the Path to AGI. Proceedings of ICML 2024 (PMLR 235, p. 36308-36321); arXiv:2311.02462 (v5, 2025). https://arxiv.org/abs/2311.02462
- **[303]** Mitchell, M., Ghosh, A., Luccioni, A. S. et Pistilli, G. (2025). Fully Autonomous AI Agents Should Not be Developed. arXiv:2502.02649 (v3). https://arxiv.org/abs/2502.02649
- **[304]** SAE International (2021, avril). J3016 – Taxonomy and Definitions for Terms Related to Driving Automation Systems for On-Road Motor Vehicles. SAE International. La révision J3016_202609 que désignent le titre d'origine et l'adresse n'a pas été vérifiée à la source; le cadre ne s'appuie que sur la taxonomie des niveaux et sur la notion de domaine de conception

opérationnel. https://saemobilus.sae.org/standards/j3016_202609-taxonomy-definitions-terms-related-driving-automation-systems-road-motor-vehicles

- **[305]** ITPro (Emma Woollacott) (2026, 27 mai). *« One-size-fits-all » agent governance sets enterprises up to fail*. Relais de presse du communiqué de Gartner du 26 mai 2026, cité à sa place [95]. https://www.itpro.com/technology/artificial-intelligence/one-size-fits-all-agent-governance-sets-enterprises-up-to-fail
- **[306]** Parasuraman, R., Sheridan, T. B. et Wickens, C. D. (2000). A model for types and levels of human interaction with automation. IEEE Transactions on Systems, Man, and Cybernetics – Part A, 30(3), 286–297. https://doi.org/10.1109/3468.844354
- **[307]** Meta AI (2025). Agents Rule of Two: A Practical Approach to AI Agent Security. Meta. https://ai.meta.com/blog/practical-ai-agent-security
- **[308]** Rundgren, A., Jordan, B. et Erdtman, S. (2020, juin). RFC 8785 — JSON Canonicalization Scheme (JCS, fiche Datatracker). Filière indépendante de la série des RFC (non endossée par l'IETF), IETF Datatracker. Même source que [236]. https://datatracker.ietf.org/doc/rfc8785
- **[309]** Kasselman, P., Lombardo, J., Rosomakho, Y., Campbell, B., Steele, N. et Parecki, A. (2026, 15 septembre). AI Identity Management System (AIMS), draft-ietf-wimse-aims-00. IETF, groupe de travail WIMSE. Révision –01 publiée le 2 novembre 2026; le contenu cité est celui de la –00. Même source que [93], qui fait foi. https://datatracker.ietf.org/doc/draft-ietf-wimse-aims
- **[310]** Fernandez Rodriguez, G., Walter, F., Nennker, A., Tonge, D. et Campbell, B. (2021). OpenID Connect Client-Initiated Backchannel Authentication Flow — Core 1.0. OpenID Foundation. https://openid.net/specs/openid-client-initiated-backchannel-authentication-core-1_0.html
- **[311]** South, T. et al. (2025). Identity Management for Agentic AI: The new frontier of authorization, authentication, and security for an AI agent world. OpenID Foundation / arXiv:2510.25819. https://arxiv.org/abs/2510.25819
- **[312]** Lodderstedt, T., Richer, J. et Campbell, B. (2023, mai). *RFC 9396 — OAuth 2.0 Rich Authorization Requests*. IETF. https://datatracker.ietf.org/doc/rfc9396
- **[313]** LangChain (2026). agent-inbox [dépôt GitHub, archivé le 20 septembre 2026]. GitHub. https://github.com/langchain-ai/agent-inbox
- **[314]** Parasuraman, R. et Manzey, D. H. (2010). Complacency and Bias in Human Use of Automation: An Attentional Integration. Human Factors, 52(3), 381–410. https://doi.org/10.1177/0018720810376055
- **[315]** Future of Life Institute (2026). EU Artificial Intelligence Act — Article 113: Entry into Force and Application (texte annoté des modifications). Future of Life Institute. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/113
- **[316]** Commission d'accès à l'information du Québec (s. d.). Utilisation et communication de renseignements personnels – Informer les personnes concernant les décisions automatisées. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/utilisation-communication-renseignements-personnels
- **[317]** Commission d'accès à l'information du Québec (s. d.). Sanctions et Cadre général d'application des sanctions administratives pécuniaires. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/sanctions-entreprises-poursuites
- **[318]** Gouvernement du Québec (2025). Décision fondée exclusivement sur un traitement automatisé. Québec.ca. Page mise à jour le 20 octobre 2025. https://www.quebec.ca/gouvernement/travailler-gouvernement/normes-gouvernance-pratiques-internes/protection-des-renseignements-personnels/technologie-et-droit-a-la-protection-des-renseignements-personnels/decision-traitement-automatise

- **[319]** Groupe de travail « Article 29 » (2018). Guidelines on Automated individual decision-making and Profiling for the purposes of Regulation 2016/679 (WP251rev.01). Commission européenne. https://ec.europa.eu/newsroom/article29/items/612053
- **[320]** Chandramouli, R. et Butcher, Z. (2023). A Zero Trust Architecture Model for Access Control in Cloud-Native Applications in Multi-Cloud Environments (NIST SP 800-207A). NIST. https://csrc.nist.gov/pubs/sp/800/207/a/final
- **[321]** Cloud Native Computing Foundation (2022, 20 septembre). SPIFFE and SPIRE Projects Graduate from Cloud Native Computing Foundation Incubator. CNCF. https://www.cncf.io/announcements/2022/09/20/spiffe-and-spire-projects-graduate-from-cloud-native-computing-foundation-incubator
- **[322]** SPIFFE (s. d.). SPIFFE Concepts. Cloud Native Computing Foundation. https://spiffe.io/docs/latest/spiffe-about/spiffe-concepts
- **[323]** Schwenkschuster, A. et Rosomakho, Y. (2026). Workload Identity Practices, draft-ietf-wimse-workload-identity-practices-07 (Internet-Draft soumis à l'IESG). IETF. Révision –08 publiée le 30 octobre 2026; dernier appel de l'IETF jusqu'au 13 novembre 2026 ([484]). https://datatracker.ietf.org/doc/draft-ietf-wimse-workload-identity-practices
- **[324]** Microsoft (2026, 14 avril). What is Microsoft Entra Agent ID? Microsoft Learn. https://learn.microsoft.com/en-us/entra/agent-id/what-is-microsoft-entra-agent-id
- **[325]** OpenID Foundation (2025, 7 octobre). *New whitepaper tackles AI agent identity challenges.* https://openid.net/new-whitepaper-tackles-ai-agent-identity-challenges
- **[326]** Microsoft (2025, 4 janvier). *Microsoft identity platform and OAuth 2.0 On-Behalf-Of flow.* Microsoft Learn. https://learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-on-behalf-of-flow
- **[327]** Hardt, D., Parecki, A. et Lodderstedt, T. (2026, 3 septembre). The OAuth 2.1 Authorization Framework, draft-ietf-oauth-v2-1-16. IETF. Même source que [176]. https://www.ietf.org/archive/id/draft-ietf-oauth-v2-1-16.html
- **[328]** Campbell, B., Bradley, J., Sakimura, N. et Lodderstedt, T. (2020, février). *RFC 8705 — OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens.* RFC Editor. https://www.rfc-editor.org/rfc/rfc8705.html
- **[329]** Meyer zu Selhausen, K. et Fett, D. (2022, mars). *RFC 9207 — OAuth 2.0 Authorization Server Issuer Identification.* IETF. Même source que [212]. https://datatracker.ietf.org/doc/rfc9207
- **[330]** Jones, M. B., Hunt, P. et Parecki, A. (2025, avril). *RFC 9728 — OAuth 2.0 Protected Resource Metadata.* IETF. Même source que [211]. https://datatracker.ietf.org/doc/rfc9728
- **[331]** Microsoft (2026). Configurable token lifetimes in the Microsoft identity platform. Microsoft Learn. https://learn.microsoft.com/en-us/entra/identity-platform/configurable-token-lifetimes
- **[332]** Tulshibagwale, A., Fletcher, G. et Kasselman, P. (2026). Transaction Tokens, draft-ietf-oauth-transaction-tokens-11 (Internet-Draft). IETF. Même source que [179]. https://datatracker.ietf.org/doc/draft-ietf-oauth-transaction-tokens
- **[333]** Schwenkschuster, A., Kasselman, P., Burgin, K., Jenkins, M., Campbell, B. et Parecki, A. (2026). OAuth Identity and Authorization Chaining Across Domains, draft-ietf-oauth-identity-chaining-17 (Internet-Draft, file de l'éditeur des RFC). IETF. https://datatracker.ietf.org/doc/draft-ietf-oauth-identity-chaining
- **[334]** Schwenkschuster, A., Kasselman, P., Rose, S., Thorgersen, S. et Cam-Winget, N. (2026). OAuth SPIFFE Client Authentication, draft-ietf-oauth-spiffe-client-auth-02 (Internet-Draft). IETF. Révision –03 publiée le 2 novembre 2026. https://datatracker.ietf.org/doc/draft-ietf-oauth-spiffe-client-auth

- **[335]** Senarath, T. S. et Dissanayaka, A. (2025, 26 août). OAuth 2.0 Extension: On-Behalf-Of User Authorization for AI Agents, draft-oauth-ai-agents-on-behalf-of-user-02 (Internet-Draft individuel, expiré). IETF. https://datatracker.ietf.org/doc/draft-oauth-ai-agents-on-behalf-of-user
- **[336]** IETF (2026, octobre). *WIMSE WG documents*. https://datatracker.ietf.org/wg/wimse/documents
- **[337]** Booth, H., Fisher, B., Galluzzo, R. et Roberts, J. (2026). Accelerating the Adoption of Software and AI Agent Identity and Authorization (document de réflexion, ébauche). NIST NCCoE. https://www.nccoe.nist.gov/sites/default/files/2026-02/accelerating-the-adoption-of-software-and-ai-agent-identity-and-authorization-concept-paper.pdf
- **[338]** NIST (2026, 29 septembre). *Comments on Software and Agentic AI Identity Concept Paper*. https://www.nist.gov/news-events/news/2026/09/comments-software-and-agentic-ai-identity-concept-paper
- **[339]** agentgateway (2026). agentgateway — dépôt de code source. GitHub. https://github.com/agentgateway/agentgateway
- **[340]** Mohamed, P. (2025, 28 mai). Introducing Governance for Agent Interactions With Support for A2A & MCP. MuleSoft Blog. https://blogs.mulesoft.com/news/mulesoft-governance-for-agent-interactions
- **[341]** MuleSoft (s. d.). Omni Gateway Overview (anciennement Flex Gateway). MuleSoft Documentation. https://docs.mulesoft.com/runtime-manager/flex-gateway-about
- **[342]** Vercel (2026, 16 septembre). Sandbox firewall. Vercel Documentation. https://vercel.com/docs/sandbox/concepts/firewall
- **[343]** Tulshibagwale, A., Cappalli, T., Scurtescu, M., Backman, A., Bradley, J. et Miel, S. (2025). OpenID Shared Signals Framework Specification 1.0. OpenID Foundation. https://openid.net/specs/openid-sharedsignals-framework-1_0-final.html
- **[344]** Cappalli, T. et Tulshibagwale, A. (2025). OpenID Continuous Access Evaluation Profile 1.0. OpenID Foundation. https://openid.net/specs/openid-caep-1_0-final.html
- **[345]** OWASP GenAI Security Project (2025, 9 décembre). *OWASP Top 10 for Agentic Applications – The Benchmark for Agentic Security in the Age of Autonomous AI*. https://genai.owasp.org/2025/12/09/owasp-top-10-for-agentic-applications-the-benchmark-for-agentic-security-in-the-age-of-autonomous-ai
- **[346]** OWASP GenAI Security Project (2026, août). OWASP Top 10 for LLM Applications 2026. OWASP Foundation. https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026
- **[347]** OWASP GenAI Security Project (2024, 17 novembre). OWASP Top 10 for LLM Applications 2025. OWASP Foundation. https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025
- **[348]** OWASP GenAI Security Project (2024, 17 novembre). OWASP Top 10 for LLM Applications 2025 (portail du projet). OWASP Foundation. Même source que [347]. https://genai.owasp.org/llm-top-10
- **[349]** OWASP Foundation (2025). OWASP Top 10 Non-Human Identities Risks – 2025. Même source que [91]. https://owasp.org/www-project-non-human-identities-top-10/2025/top-10-2025
- **[350]** OWASP Foundation (2026). OWASP Agentic Skills Top 10 (projet Incubator, version 1.0-2026). https://owasp.org/www-project-agentic-skills-top-10
- **[351]** Huang, K. (2025, 6 février). Agentic AI Threat Modeling Framework: MAESTRO. Cloud Security Alliance. https://cloudsecurityalliance.org/blog/2025/02/06/agentic-ai-threat-modeling-framework-maestro
- **[352]** MITRE (2026, 14 septembre). *mitre-atlas/atlas-data – CHANGELOG*. https://github.com/mitre-atlas/atlas-data/blob/main/CHANGELOG.md

- **[353]** Gouvernement du Canada (2026). Guide on the Use of Agentic Artificial Intelligence. https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/generative-ai/guide-use-agentic-artificial-intelligence.html
- **[354]** Willison, S. (2025, 16 juin). The lethal trifecta for AI agents: private data, untrusted content, and external communication. simonwillison.net. https://simonwillison.net/2025/Jun/16/the-lethal-trifecta
- **[355]** Hines, K., Lopez, G., Hall, M., Zarfati, F., Zunger, Y. et Kiciman, E. (2024). Defending Against Indirect Prompt Injection Attacks With Spotlighting. arXiv:2403.14720. https://arxiv.org/abs/2403.14720
- **[356]** Microsoft (2026). Prompt Shields in Azure AI Content Safety. Microsoft Learn. https://learn.microsoft.com/en-us/azure/ai-services/content-safety/concepts/jailbreak-detection
- **[357]** Beurer-Kellner, L., Buesser, B., Creţu, A.-M., Debenedetti, E., Dobos, D., Fabian, D., Fischer, M., Froelicher, D., Grosse, K., Naeff, D., Ozoani, E., Paverd, A., Tramèr, F. et Volhejn, V. (2025). Design Patterns for Securing LLM Agents against Prompt Injections. arXiv:2506.08837. https://arxiv.org/abs/2506.08837
- **[358]** Willison, S. (2023, 25 avril). The Dual LLM pattern for building AI assistants that can resist prompt injection. simonwillison.net. https://simonwillison.net/2023/Apr/25/dual-llm-pattern
- **[359]** Zhang, H., Huang, J., Mei, K., Yao, Y., Wang, Z., Zhan, C., Wang, H. et Zhang, Y. (2025). Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents. ICLR 2025. arXiv:2410.02644. https://arxiv.org/abs/2410.02644
- **[360]** Agache, A., Brooker, M., Florescu, A., Iordache, A., Liguori, A., Neugebauer, R., Piwonka, P. et Popa, D.-M. (2020). Firecracker: Lightweight Virtualization for Serverless Applications. 17th USENIX Symposium on Networked Systems Design and Implementation (NSDI '20), p. 419-434. https://www.usenix.org/conference/nsdi20/presentation/agache
- **[361]** Projet gVisor (s. d.). gVisor – Performance Guide. Google. Même source que [134]. https://gvisor.dev/docs/architecture_guide/performance
- **[362]** Projet gVisor (s. d.). gVisor – Compatibility. Google. https://gvisor.dev/docs/user_guide/compatibility
- **[363]** Agache, A., Brooker, M., Florescu, A., Iordache, A., Liguori, A., Neugebauer, R., Piwonka, P. et Popa, D.-M. (2020). Firecracker: Lightweight Virtualization for Serverless Applications (fiche et mémoire NSDI '20). 17th USENIX Symposium on Networked Systems Design and Implementation (NSDI '20), p. 419-434. Même source que [360]. https://www.usenix.org/conference/nsdi20/presentation/agache
- **[364]** WebAssembly Community Group (s. d.). WebAssembly. webassembly.org. https://webassembly.org/
- **[365]** WebAssembly Community Group (s. d.). Security. webassembly.org. https://webassembly.org/docs/security
- **[366]** Blaxel (s. d.). Sandboxes – Documentation. https://docs.blaxel.ai/Sandboxes/Overview
- **[367]** E2B (s. d.). Sandbox persistence. E2B Documentation. https://docs.e2b.dev/sandbox/persistence
- **[368]** Projet gVisor (s. d.). gVisor – GPU Support. Google. Même source que [134]. https://gvisor.dev/docs/user_guide/gpu
- **[369]** Modal (s. d.). Sandboxes. Modal Documentation. https://modal.com/docs/guide/sandboxes
- **[370]** Firecracker Project (s. d.). Firecracker Specification (SPECIFICATION.md). GitHub. https://github.com/firecracker-microvm/firecracker/blob/main/SPECIFICATION.md
- **[371]** Amazon Web Services (s. d.). Use the Instance Metadata Service to access instance metadata. Amazon EC2 User Guide. https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/configuring-instance-metadata-service.html

- **[372]** MacCárthaigh, C. (2019). Add defense in depth against open firewalls, reverse proxies, and SSRF vulnerabilities with enhancements to the EC2 Instance Metadata Service. AWS Security Blog. https://aws.amazon.com/blogs/security/defense-in-depth-open-firewalls-reverse-proxies-ssrf-vulnerabilities-ec2-instance-metadata-service
- **[373]** The Kubernetes Authors (s. d.). Runtime Class. Kubernetes Documentation. https://kubernetes.io/docs/concepts/containers/runtime-class
- **[374]** OWASP Foundation (2026). *The Top 10 Risks — Visual Overview (AST10)*. https://owasp.github.io/www-project-agentic-skills-top-10/top10
- **[375]** Future of Life Institute (2026). *Article 25: Responsibilities Along the AI Value Chain*. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/25
- **[376]** National Cyber Security Centre, CISA et al. (2023). Guidelines for secure AI system development. NCSC (Royaume-Uni). https://www.ncsc.gov.uk/collection/guidelines-secure-ai-system-development
- **[377]** OWASP GenAI Security Project (2025). Securing Agentic Applications Guide 1.0. OWASP Foundation. https://genai.owasp.org/resource/securing-agentic-applications-guide-1-0
- **[378]** Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M. et Tramèr, F. (2024). AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. arXiv:2406.13352. https://arxiv.org/abs/2406.13352
- **[379]** Ministère de la Cybersécurité et du Numérique du Québec (2025). Énoncé de principes pour une utilisation responsable de l'intelligence artificielle par les organismes publics, édition 2025. MCN. https://cdn-contenu.quebec.ca/cdn-contenu/adm/min/cybersecurite_numerique/Publications/Strategie_IA/Enonce_IA.pdf
- **[380]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative AI client inference. GitHub, open-telemetry/semantic-conventions-genai. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/client-inference.md
- **[381]** OpenTelemetry (CNCF) (2026, 12 juin). *Release v1.42.0 - open-telemetry/semantic-conventions*. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.42.0
- **[382]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative AI metrics (branche main). GitHub, open-telemetry/semantic-conventions-genai. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/gen-ai-metrics.md
- **[383]** OpenTelemetry (2026, 11 mai). Release v1.41.1 – open-telemetry/semantic-conventions. CNCF. Seul changement annoncé : l'exclusion de deux métriques `k8s.container.cpu.*` de la génération de code (#3711); aucun fichier des conventions `gen_ai.*` ne change entre v1.41.0 et v1.41.1 (comparaison des étiquettes, vérifiée le 4 novembre 2026). https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.41.1
- **[384]** OpenTelemetry (2026, 28 avril). Release v1.41.0 – open-telemetry/semantic-conventions. CNCF. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.41.0
- **[385]** OpenTelemetry (2026). OpenTelemetry Python - OpenAI Instrumentation. OpenTelemetry (opentelemetry-python-contrib). https://opentelemetry-python-contrib.readthedocs.io/en/latest/instrumentation-genai/openai.html
- **[386]** OpenTelemetry (2026). Semantic conventions for Model Context Protocol (v1.41.0). CNCF. https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/mcp.md
- **[387]** OpenTelemetry (CNCF) (2025, 25 août). *Release v1.37.0*. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.37.0

- **[388]** OpenTelemetry (CNCF) (2026). Semantic conventions for generative AI metrics (v1.41.0). https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-metrics.md
- **[389]** OpenTelemetry (2026). Semantic conventions for GenAI inference token metrics (statut Development). OpenTelemetry / CNCF. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/gen-ai-token-metrics.md
- **[390]** OpenTelemetry (2026). Naming. OpenTelemetry. https://opentelemetry.io/docs/specs/semconv/general/naming
- **[391]** OpenTelemetry (2025, 29 octobre). Release v1.38.0 – open-telemetry/semantic-conventions. CNCF. https://github.com/open-telemetry/semantic-conventions/releases/tag/v1.38.0
- **[392]** OpenTelemetry (2026). *GenAI spans – Content capture configuration (semantic-conventions-genai)*. https://github.com/open-telemetry/semantic-conventions-genai/blob/main/docs/gen-ai/gen-ai-spans.md
- **[393]** W3C (2024, 30 mai). Propagation format for distributed context: Baggage, Candidate Recommendation Snapshot. https://www.w3.org/TR/baggage
- **[394]** Future of Life Institute (2026). *Article 12: Record-Keeping*. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/12
- **[395]** ISO/IEC (2023, 18 décembre). ISO/IEC 42001:2023 — Technologies de l'information — Intelligence artificielle — Système de management. ISO. https://www.iso.org/standard/81230.html
- **[396]** OpenTelemetry (CNCF) (2026). Semantic conventions for Generative AI events (v1.41.0). https://github.com/open-telemetry/semantic-conventions/blob/v1.41.0/docs/gen-ai/gen-ai-events.md
- **[397]** Stanford Institute for Human-Centered Artificial Intelligence (2025). The 2025 AI Index Report. Stanford University. https://hai.stanford.edu/ai-index/2025-ai-index-report
- **[398]** Cottier, B., Snodin, B., Owen, D. et Adamczewski, T. (2025, 12 mars). LLM inference prices have fallen rapidly but unequally across tasks. Epoch AI. https://epoch.ai/data-insights/llm-inference-price-trends
- **[399]** Anthropic (2026). Pricing. Claude Platform Docs. https://platform.claude.com/docs/en/about-claude/pricing
- **[400]** Anthropic (s. d.). Data residency. Claude Developer Platform Documentation. https://platform.claude.com/docs/en/manage-claude/data-residency
- **[401]** Anthropic (2026). Prompt caching. Claude Platform Docs. https://platform.claude.com/docs/en/build-with-claude/prompt-caching
- **[402]** OpenAI (2026). Prompt caching. OpenAI API Docs. https://developers.openai.com/api/docs/guides/prompt-caching
- **[403]** Belcak, P., Heinrich, G., Diao, S., Fu, Y., Dong, X., Muralidharan, S., Lin, Y. C. et Molchanov, P. (2025). Small Language Models are the Future of Agentic AI (arXiv:2506.02153). NVIDIA Research; Georgia Institute of Technology. https://arxiv.org/abs/2506.02153
- **[404]** Amazon Web Services (s. d.). GENCOST05-BP01 Create stopping conditions to control long-running workflows. AWS Well-Architected Framework, Generative AI Lens. https://docs.aws.amazon.com/wellarchitected/latest/generative-ai-lens/gencost05-bp01.html
- **[405]** Amazon Web Services (s. d.). Generative AI Lens – Cost optimization (GENCOST01 à GENCOST05). AWS Well-Architected Framework. https://docs.aws.amazon.com/wellarchitected/latest/generative-ai-lens/cost-optimization.html
- **[406]** FinOps Foundation (s. d.). FinOps Framework – Scopes. FinOps Foundation. https://www.finops.org/framework/scopes

- **[407]** FinOps Foundation (2026). FinOps for AI Overview (mis à jour le 17 février 2026). FinOps Foundation. https://www.finops.org/wg/finops-for-ai-overview
- **[408]** FinOps Foundation (Linux Foundation) (2026, 4 juin). *FOCUS Specification v1.4 – Service Category*. https://focus.finops.org/docs/specification/v1-4/columns/cost-and-usage/service-category
- **[409]** FinOps Foundation (Linux Foundation) (2026). *FOCUS v1.4 – Consumed Unit*. https://focus.finops.org/docs/specification/v1-4/columns/cost-and-usage/consumed-unit
- **[410]** FinOps Foundation (s. d.). FOCUS Specification v1.4 – Introduction. FinOps Foundation. https://focus.finops.org/docs/specification/v1-4/sections/introduction
- **[411]** NIST Center for AI Standards and Innovation (2026, 17 février). Announcing the « AI Agent Standards Initiative » for Interoperable and Secure Innovation. NIST. https://www.nist.gov/news-events/news/2026/02/announcing-ai-agent-standards-initiative-interoperable-and-secure
- **[412]** Commission européenne (2024). *AI Act — Article 14: Human oversight*. https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-14
- **[413]** Commission d'accès à l'information du Québec (2024). Réaliser une évaluation des facteurs relatifs à la vie privée : guide d'accompagnement à la démarche et à sa documentation, version 3.1. CAI. https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_GU_EFVP.pdf
- **[414]** Commission d'accès à l'information du Québec (s. d.). Incidents de confidentialité et mesures de sécurité. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/incidents-confidentialite-mesures-securite-entreprises
- **[415]** Commission d'accès à l'information du Québec (2021). Intelligence artificielle et protection des renseignements personnels : retour sur la consultation sur les principes en intelligence artificielle. CAI. https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_DOC_Reflex_IA_RP.pdf
- **[416]** Gouvernement du Québec (2026, 1er avril). Communication ou réalisation d'une tâche qui concerne des renseignements personnels à l'extérieur du Québec. Québec.ca. https://www.quebec.ca/gouvernement/travailler-gouvernement/normes-gouvernance-pratiques-internes/protection-des-renseignements-personnels/communication-de-renseignements-personnels/communication-realisation-tache-exterieur-quebec
- **[417]** États-Unis (2018). 18 U.S.C. § 2713, ajouté par le CLOUD Act, Pub. L. 115-141, div. V, 23 mars 2018. Legal Information Institute. https://www.law.cornell.edu/uscode/text/18/2713
- **[418]** Gouvernement du Canada (2025). Digital Sovereignty: A Framework to improve digital readiness of the Government of Canada. https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/cloud-services/digital-sovereignty/digital-sovereignty-framework-improve-digital-readiness.html
- **[419]** Commission d'accès à l'information du Québec (s. d.). Consentement des personnes concernées. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/consentement-personnes-entreprises
- **[420]** Commission d'accès à l'information du Québec (s. d.). Conservation et destruction des renseignements personnels. CAI. https://www.cai.gouv.qc.ca/protection-renseignements-personnels/information-entreprises-privees/conservation-destruction-renseignements-personnels
- **[421]** Ministère de la Cybersécurité et du Numérique du Québec (2025). Indication d'application IA-RI-2025-003-OP : mesures applicables lors de l'utilisation de l'intelligence artificielle générative. MCN. https://cdn-contenu.quebec.ca/cdn-contenu/adm/min/cybersecurite_numerique/Publications/Strategie_IA/Indication_app_IAG.pdf
- **[422]** Ministère de la Cybersécurité et du Numérique du Québec (2026). Énoncé de politique de souveraineté numérique et d'approvisionnement en technologie de l'information. MCN.

https://cdn-contenu.quebec.ca/cdn-contenu/adm/min/cybersecurite_numerique/Publications/Enonce_politique_souveraineté_numerique.pdf

- **[423]** Gouvernement du Québec (2026, 23 avril). Outils en matière de protection des renseignements personnels. Québec.ca. https://www.quebec.ca/gouvernement/travailler-gouvernement/normes-gouvernance-pratiques-internes/protection-des-renseignements-personnels/outils
- **[424]** Commission d'accès à l'information du Québec (2025). Rapport annuel d'activités et de gestion 2024-2025. CAI. https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_RAAG-2024-2025.pdf
- **[425]** Commission d'accès à l'information du Québec (2026). Transparence et vie privée : protéger la démocratie à l'ère numérique, rapport quinquennal 2026 (communiqué du 11 juin 2026). CAI. https://www.cai.gouv.qc.ca/uploads/pdfs/CAI_Communique_RQ_2026.pdf
- **[426]** Commissariat à la protection de la vie privée du Canada (2025). Ce que vous devez savoir sur la déclaration obligatoire des atteintes aux mesures de sécurité. CPVP. https://www.priv.gc.ca/fr/sujets-lies-a-la-protection-de-la-vie-privee/protection-des-renseignements-personnels-pour-les-entreprises/atteintes-et-mesures-de-securite/atteintes-a-la-vie-privee-dans-votre-entreprise/gd_pb_201810/
- **[427]** Gouvernement du Canada (s. d.). Personal Information Protection and Electronic Documents Act (S.C. 2000, c. 5), art. 10.1 (déclaration et avis) et 10.3 (registre de toutes les atteintes). Site Web de la législation (Justice). https://laws-lois.justice.gc.ca/eng/acts/p-8.6/FullText.html. La durée de conservation du registre, 24 mois, est fixée par le Règlement sur les atteintes aux mesures de sécurité (DORS/2018-64), par. 6(1) : https://laws-lois.justice.gc.ca/fra/reglements/DORS-2018-64/TexteComplet.html
- **[428]** Parlement du Canada (2025, 6 janvier). Projet de loi C-27 (44-1), Loi de 2022 sur la mise en œuvre de la Charte du numérique. LEGISinfo. https://www.parl.ca/legisinfo/en/bill/44-1/c-27
- **[429]** Bureau du Conseil privé (2025, 14 mars). Opening of new parliamentary session, dans Opening Parliament, livret d'information pour le premier ministre du Canada. Canada.ca. https://www.canada.ca/en/privy-council/corporate/transparency/briefing-documents/prime-minister-2025/opening-parliament.html
- **[430]** Parlement du Canada (2026, 15 juin). Projet de loi C-36 (45-1), Loi visant à protéger la vie privée et les données des consommateurs, première lecture le 15 juin 2026. LEGISinfo. https://www.parl.ca/legisinfo/en/bill/45-1/c-36
- **[431]** Parlement du Canada (2026, 15 juin). Projet de loi C-36 (45-1), première lecture – Loi sur la protection de la vie privée et des données des consommateurs. Parlement du Canada. Texte du projet de loi en première lecture; [430] en donne le statut. https://www.parl.ca/DocumentViewer/en/45-1/bill/C-36/first-reading
- **[432]** Secrétariat du Conseil du Trésor du Canada (2026, 15 septembre). Algorithmic Impact Assessment. Canada.ca. https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/automated-decision-making/algorithmic-impact-assessment.html
- **[433]** Gouvernement du Canada (2026). Guide on the Scope of the Directive on Automated Decision-Making. https://www.canada.ca/en/government/system/digital-government/digital-government-innovations/responsible-use-ai/guide-scope-directive-automated-decision-making.html
- **[434]** Bureau du surintendant des institutions financières (2021). Signalement des incidents liés à la technologie et à la cybersécurité (préavis). BSIF. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-security-incident-reporting

- **[435]** Bureau du surintendant des institutions financières (2022). Ligne directrice B-13 : Gestion du risque lié aux technologies et du cyberrisque. BSIF. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management
- **[436]** Bureau du surintendant des institutions financières (2022, 13 juillet). OSFI releases final Guideline B-13 – Technology and Cyber Risk Management – Letter. BSIF. https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/osfi-releases-final-guideline-b-13-technology-cyber-risk-management-letter-2022
- **[437]** Innovation, Sciences et Développement économique Canada (2023). Code de conduite volontaire visant un développement et une gestion responsables des systèmes d'IA générative avancés. ISDE. https://ised-isde.canada.ca/site/ised/en/voluntary-code-conduct-responsible-development-and-management-advanced-generative-ai-systems
- **[438]** Commissariat à la protection de la vie privée du Canada et homologues provinciaux et territoriaux (2023). Principes pour des technologies d'IA générative responsables, dignes de confiance et respectueuses de la vie privée. CPVP. https://www.priv.gc.ca/en/privacy-topics/technology/artificial-intelligence/gd_principles_ai
- **[439]** Parlement du Canada (LEGISinfo) (2026, 15 juin). *C-8 (45-1) – An Act respecting cyber security.* https://www.parl.ca/legisinfo/en/bill/45-1/c-8
- **[440]** Parlement du Canada (LEGISinfo) (2026). *Bills – 45th Parliament, 1st Session.* https://www.parl.ca/legisinfo/en/bills?parlsession=45-1&page=2
- **[441]** Commission européenne (2024). *AI Act — Article 2: Scope.* https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-2
- **[442]** Commission européenne (2024). *AI Act — Annex III: High-risk AI systems referred to in Article 6(2).* https://ai-act-service-desk.ec.europa.eu/en/ai-act/annex-3
- **[443]** Commission européenne (2026). AI Act. Shaping Europe's digital future. https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai
- **[444]** Future of Life Institute (2026). *Article 9: Risk Management System.* Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/9
- **[445]** Future of Life Institute (2026). *Article 13: Transparency and Provision of Information to Deployers.* Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/13
- **[446]** Future of Life Institute (2026). Article 72: Post-Market Monitoring by Providers and Post-Market Monitoring Plan for High-Risk AI Systems. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/72
- **[447]** Commission européenne (AI Act Service Desk) (2024). *AI Act — Article 26: Obligations of deployers of high-risk AI systems.* https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-26
- **[448]** NIST (2026). *AI Risk Management Framework.* https://www.nist.gov/itl/ai-risk-management-framework
- **[449]** National Institute of Standards and Technology (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1. NIST. https://doi.org/10.6028/NIST.AI.600-1
- **[450]** ISO/IEC (2023, 18 décembre). ISO/IEC 42001:2023, Information technology — Artificial intelligence — Management system (fiche catalogue, édition 1). Standards Norway. Même source que [395]. https://online.standard.no/en/isoiec-42001-2023-4

- **[451]** ISO/IEC (2025). ISO/IEC 42006:2025 — Technologies de l'information — Intelligence artificielle — Exigences pour les organismes procédant à l'audit et à la certification des systèmes de management de l'IA. ISO (fiche catalogue, Standards Norway). https://online.standard.no/en/isoiec-42006-2025
- **[452]** ISO/IEC (2025). ISO/IEC 42005:2025 — Technologies de l'information — Intelligence artificielle — Évaluation de l'impact des systèmes d'IA. ISO (fiche catalogue, Standards Norway). https://online.standard.no/en/isoiec-42005-2025
- **[453]** ISO/IEC (2023). ISO/IEC 23894:2023 — Technologies de l'information — Intelligence artificielle — Recommandations relatives au management du risque. ISO (fiche catalogue, Standards Norway). https://online.standard.no/en/isoiec-23894-2023
- **[454]** Raza, S., Sapkota, R., Karkee, M. et Emmanouilidis, C. (2025). TRiSM for Agentic AI: A Review of Trust, Risk, and Security Management in LLM-based Agentic Multi-Agent Systems. arXiv:2506.04133. https://arxiv.org/abs/2506.04133
- **[455]** National Institute of Standards and Technology (2026, 20 octobre). SP 800-53 Control Overlays for Super Intelligence Systems (COSIS; anciennement Control Overlays for Securing AI Systems, COSAiS). NIST CSRC. https://csrc.nist.gov/projects/cosais
- **[456]** National Institute of Standards and Technology (2026, 7 avril). Concept Note: AI RMF Profile on Trustworthy AI in Critical Infrastructure. NIST. https://www.nist.gov/document/concept-note-artificial-intelligence-risk-management-framework-trustworthy-ai-critical
- **[457]** Commission européenne (2024). AI Act — Article 50: Transparency obligations for providers and deployers of certain AI systems. https://ai-act-service-desk.ec.europa.eu/en/ai-act/article-50
- **[458]** Badran, M. et Bonsange-Basia, V. (2025, 19 novembre). Specter Aviation Limited c. Laprade : une première sanction judiciaire au Québec liée à l'usage de l'intelligence artificielle. Gowling WLG. Décision commentée : *Specter Aviation Limited c. Laprade*, 2025 QCCS 3521 (Cour supérieure du Québec, 1er octobre 2025), référence neutre relevée à la note 1 de l'article; la décision n'a pas été rouverte. https://gowlingwlg.com/fr/insights-resources/articles/2025/specter-aviation-v-laprade-qc-first-judicial-sanction-ai
- **[459]** Future of Life Institute (2026). *Article 73: Reporting of Serious Incidents*. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/73
- **[460]** Québec (2022). Règlement sur les incidents de confidentialité, RLRQ, c. A-2.1, r. 3.1 (décret 1761-2022, G.O.Q. 2022.II.6819, 14 décembre 2022). Éditeur officiel du Québec. https://www.publicationsduquebec.gouv.qc.ca/fileadmin/gazette/pdf_encrypte/lois_reglements/2022F/78638.pdf
- **[461]** Future of Life Institute (2026). Article 27: Fundamental Rights Impact Assessment for High-Risk AI Systems. Site non officiel (agrégateur, catégorie C au sens du tableau 66), source secondaire sans valeur d'appui; le texte de référence est le règlement [61]. https://artificialintelligenceact.eu/article/27
- **[462]** OpenTelemetry (2026, 5 mai). Move GenAI semantic conventions to its own dedicated repository (demande de tirage no 3696, fusionnée le 5 mai 2026). GitHub, open-telemetry/semantic-conventions. https://github.com/open-telemetry/semantic-conventions/pull/3696
- **[463]** FinOps Foundation (2026). *FOCUS v1.4 Changelog*. https://focus.finops.org/docs/specification/v1-4/changelog
- **[464]** Alpay, S. et Cowsert, M. (2026, 10 juin). Introducing FOCUS 1.4: Invoice Reconciliation, Commitment Details, and Specification Maturity. FinOps Foundation. https://www.finops.org/insights/introducing-focus-1-4
- **[465]** FinOps Foundation (2026, octobre). FOCUS 1.5 Release Scope: Confirmed, In Review and Deferred. FinOps Foundation. https://focus.finops.org/focus-1-5-release-scope

- **[466]** South, T. et al. (2025, octobre). Identity Management for Agentic AI: The new frontier of authorization, authentication, and security for an AI agent world (livre blanc, PDF). OpenID Foundation. Même source que [311]. https://openid.net/wp-content/uploads/2025/10/Identity-Management-for-Agentic-AI.pdf
- **[467]** Computerworld (2026, 30 avril). Gartner sees untamed growth in agentic AI. Foundry. https://www.computerworld.com/article/4165686/gartner-sees-untamed-growth-in-agentic-ai.html
- **[468]** Apache Software Foundation (2026). *Apache Kafka — Introduction*. Même source que [257]. https://kafka.apache.org/intro
- **[469]** FinOps Foundation (s. d.). What is FinOps? FinOps Foundation. https://www.finops.org/introduction/what-is-finops
- **[470]** OWASP (2025). OWASP Non-Human Identities Top 10 – 2025 (portail owasp.org du projet). OWASP Foundation. Même source que [91]. https://owasp.org/www-project-non-human-identities-top-10/2025
- **[471]** SPIFFE Project (s. d.). SPIFFE Workload API (spécification). SPIFFE / CNCF. https://github.com/spiffe/spiffe/blob/main/standards/SPIFFE_Workload_API.md
- **[472]** A2A Project (2026, 28 mai). Release v1.0.1 (dépôt a2aproject/A2A). GitHub. https://github.com/a2aproject/A2A/releases/tag/v1.0.1
- **[473]** Abdin, M. et coll. (2024). Phi-3 Technical Report: A Highly Capable Language Model Locally on Your Phone (arXiv:2404.14219). Microsoft. https://arxiv.org/abs/2404.14219
- **[496]** Jones, M., Bradley, J. et Sakimura, N. (2015, mai). *RFC 7515 — JSON Web Signature (JWS)*. RFC Editor. https://www.rfc-editor.org/rfc/rfc7515.html

H Actualisation de novembre 2026

Divulgation : les relevés de cette annexe ont été conduits le 1er novembre 2026 par un agent LLM (Claude, Anthropic) à consigne de source primaire exclusive, chaque fait rapporté avec son adresse, sa date et sa preuve; un échantillon, dont la taille n'est pas consignée, en a été contre-vérifié à la source par l'agent qui a assemblé l'annexe.

H.1 Objet et régime de l'annexe

Cette annexe est informative. Ses constats et ses propositions ne modifient aucune exigence, aucun tableau ni aucune échéance de la version 1.1, sur laquelle le comité d'architecture et des risques agentiques n'a pas encore statué; seuls ses errata (tableau 72) corrigent le corps. Elle rouvre, au 1er novembre 2026, les sources datées dont dépend une exigence, une échéance ou un énoncé daté du cadre, consignées dans le corps selon l'état des sources au 27 octobre 2026 et les vérifications des 27 et 28 octobre 2026 (annexe F), et dit ce que le comité pourrait en tirer à la révision trimestrielle du catalogue (EXIG-GOV-18) ou à la révision extraordinaire qu'appelle une version incompatible, une dépréciation ou un signal inscrit (EXIG-GOV-18, EXIG-INT-23). Elle présente aussi, sans les appliquer, les reports que la Note AMF IA propose au cadre, et relève les errata et incohérences prouvés.

Régime déclaré : relevé individuel de chaque fait sur source primaire, consultée le 1er novembre 2026 (date de consultation de toutes les références propres à l'annexe) — registre de l'IETF, dépôts de code lus par étiquette et par commit, pages des projets, des éditeurs, des organismes et des régulateurs —, puis contre-vérification d'un échantillon dont la taille n'est pas consignée. Deux lignes du tableau 70 reposent sur une lecture indirecte et ne sont vérifiées que partiellement : AAIF et AGNTCY (page résumée par un outil de lecture Web) et ligne directrice de l'AMF (relais de la Note AMF IA). L'annexe ne conserve ni capture

ni empreinte des pages lues. Une page inaccessible est déclarée non vérifiée; un état inconnu n'est pas « inchangé ». Trois natures d'écart sont distinguées : un erratum (tableau 72) corrige un énoncé déjà faux à l'état des sources du 27 octobre 2026 et prime sur le corps à toute date; une omission à la date de l'état des sources (H.4) signale un fait antérieur que le corps aurait dû porter, et une nouveauté (tableau 70) un fait postérieur, sans que ni l'une ni l'autre modifie le corps tant que le comité n'a pas statué; pour les versions applicables, le catalogue fait foi (section 1.6). Les références existantes gardent leur numéro; les références propres à l'annexe suivent la dernière de l'annexe G.

H.2 Les sources datées rouvertes

Le tableau 70 reprend, une par ligne, les dépendances datées qui portent une exigence, une échéance ou un énoncé daté. La prose qui suit développe les raisonnements que le tableau résume.

Tableau 70 — Dépendances datées du cadre, rouvertes le 1er novembre 2026 sur leur source primaire

Dépendance	Sections et exigences	Texte du cadre (état des sources au 27 octobre 2026)	Au 1er novembre 2026	Conséquence pour le comité
MCP, calendrier des révisions	1.6, 6.3 (tableau 15), 6.5, 6.9, 11.7, 15.1 (tableaux 58 et 59); EXIG-INT-07, EXIG-INT-23, EXIG-MCP-02, EXIG-MCP-22, EXIG-GOV-18	Révision 2026-07-28 courante; « la feuille de route publiée le 22 août 2026 n'annonce aucune date pour la prochaine révision » [195]; retrait de Roots, Sampling, journalisation et DCR possible à partir de la première révision publiée le 28 juillet 2027 ou après [196]	2026-07-28 toujours courante [34]. SEP-3398, « Accepted: 2026-10-14 », versée au tronc le 27 octobre : publications « generally on the last Tuesday of March and September »; la révision attendue en décembre 2026 passe au 30 mars 2027, « subject to confirmation in the transition calendar » [474]	La prochaine révision de MCP a une date annoncée, le 30 mars 2027, sous réserve du calendrier de transition; ce n'est pas une publication. MCP 2026-07-28 étant au statut Adopter, c'est l'EXIG-GOV-18, et non l'EXIG-INT-23, qui s'appliquera à la publication, si la révision comporte un changement incompatible ou une dépréciation. Sur ce calendrier, la première révision admissible au retrait serait celle de fin septembre 2027 (dernier mardi : 28 septembre); l'échéance de migration du 28 juillet 2027, choix du cadre, garde sa marge. Aucune exigence à modifier
MCP, transport HTTP+SSE	6.5 (tableau 17, migration); EXIG-MCP-22	Retrait « trois mois après que la SEP-2596 atteint l'état final » [196]	SEP-2596 « Status: Final » depuis la fusion de la demande no 2856 le 3 juin 2026; registre des dépréciations inchangé, aucune fonctionnalité encore retirée [196], [475]	L'échéance n'est plus indéterminée : HTTP+SSE est admissible au retrait depuis le début de septembre 2026 (calcul de l'annexe) et peut disparaître dès la révision de

Dépendance	Sections et exigences	Texte du cadre (état des sources au 27 octobre 2026)	Au 1er novembre 2026	Conséquence pour le comité
				mars 2027. Le comité peut avancer, au catalogue, la date de migration des serveurs antérieurs qui n'offrent que ce transport. Le fait étant antérieur au 27 octobre, c'est une omission à la date de l'état des sources (H.4)
Extensions MCP	6.3 (tableau 15), 6.5 (tableau 17), 9.3 (tableau 36); EXIG-MCP-04, EXIG-INT-06, EXIG-GOV-19, EXIG-APP-02	Extensions officielles Tasks, Apps et autorisation, désactivées par défaut; Enterprise-Managed Authorization au statut Évaluer, « extension MCP stable depuis 2026-07-28 » [169], [218]	Trois stades, Experimental, Beta et Stable, avant une éventuelle promotion au protocole de base (SEP-3392, finale, versée au tronc le 29 octobre 2026 [476]). « MCP Tasks Beta, to Core »; MCP Apps, OAuth Client Credentials et Enterprise-Managed Authorization « Stable »; Skills over MCP et Server Cards « Beta » [169]	Le catalogue devrait porter le stade de chaque extension. Le stade Beta n'est ni « final ou stable » ni « brouillon ou expérimental » au sens de l'EXIG-GOV-19, et l'application de ce critère extension par extension n'est écrite nulle part : le comité dira s'il assimile Beta à un composant admis avec réserve et s'il complète l'EXIG-GOV-19 et l'EXIG-INT-09. Si Tasks rejoint le protocole de base, le quota de l'EXIG-MCP-04 devra viser la primitive tâche, qu'elle relève d'une extension ou du protocole. Skills et Server Cards, absentes du catalogue, restent inactivables (EXIG-MCP-04)
Registre officiel MCP	2.2, 6.3 (encadré), 6.5; EXIG-INT-17	En préversion; pas de serveurs privés [25], [43]	« The MCP Registry is currently in preview »; « does not support private servers » [43]; version 1.8.7 du 30 octobre 2026 [477]	Inchangé : le catalogue d'entreprise reste la seule source de découverte
Suite de conformité MCP	6.5, 6.8, 13.2; EXIG-INT-19, EXIG-APP-03, EXIG-APP-08	0.1.16 courante; 0.2.0-alpha.12 du 1er octobre 2026 [225], [226]	Mêmes versions au registre npm (latest 0.1.16; alpha 0.2.0-alpha.12); aucun commit sur la branche principale depuis le 1er octobre [226]	Inchangé : résultats consignés à titre informatif (EXIG-INT-19)
A2A, version de protocole	6.3 (tableau 15), 6.6; EXIG-A2A-01,	Version 1.0 (1.0.0 du 12 mars 2026; correctif 1.0.1 du 28 mai 2026) [29], [30]	1.0.1 reste la dernière publication; étiquette v1.1.0-rc posée le 29 octobre 2026 [30], [478]	Une version candidate n'est pas une publication : la version de ré-

Dépendance	Sections et exigences	Texte du cadre (état des sources au 27 octobre 2026)	Au 1er novembre 2026	Conséquence pour le comité
	EXIG-A2A-15, EXIG-INT-07			férence reste 1.0. Une 1.1 serait une version mineure, à traiter à la révision trimestrielle (EXIG-INT-08), sauf dépréciation (EXIG-GOV-18); son contenu n'est pas instruit ici
A2A, gouvernance	sommaire, 2.2 (tableau 5), 6.6, 6.9, 13.1, annexe F (tableau 68, no 7); EXIG-INT-20	Projet de l'AAIF au stade « Growth », annoncé le 17 août 2026, billet du projet du 27 août [5], [35]; comité directeur technique de huit entreprises (sections 6.6 et 13.1) [29]	Billet du projet daté du 27 août : « officially been accepted as a Growth Stage project » [5]; billet de l'AAIF daté du 17 août [35]; A2A figure parmi les dix projets de la fondation [130]. Le fichier de gouvernance compte « nine seats » depuis le 20 octobre [479]	La qualification « projet de l'AAIF » satisfait à l'EXIG-INT-20. Le décompte du comité directeur est un erratum (H.4)
a2a-tck	6.6, 6.8, 13.2; EXIG-A2A-14, EXIG-INT-19, EXIG-APP-03	Trousse de compatibilité; tests MUST bloquants [243]	Étiquettes 1.0.0.alpha3 et 0.3.0.beta6, posées le 20 octobre 2026; dernier commit le 22 octobre [480]	L'exigence bloquante repose sur une trousse dont la ligne 1.0 est étiquetée alpha. Le comité dira si ce statut est inscrit au catalogue avec une réserve (EXIG-INT-09, EXIG-GOV-19), à une étiquette épinglée, ou si, comme pour MCP, les résultats deviennent informatifs. L'étiquette étant antérieure au 27 octobre, c'est une omission à la date de l'état des sources (H.4)
AAIF, AGNTCY	2.2 (tableau 5), 6.3 (tableau 15), 6.9 (tableau 23); EXIG-INT-20, EXIG-INT-21, EXIG-INT-23	Dix projets au 22 octobre; proposition d'AGNTCY (no 57) sans décision [37], [38], [130]	Mêmes dix projets, AGNTCY absent [130]; proposition no 57 ouverte, étiquette « New », sans décision (page lue par un outil de lecture Web, qui la résume : vérification partielle) [37]	Signal non survenu, sous la réserve d'une lecture indirecte : statuts Évaluer et Surveiller inchangés
OAuth 2.1	6.3 (tableau 15), 6.5, 9.3 (tableaux 35 et 36), 11.7, 15.1 (tableau 59); EXIG-INT-09, EXIG-IAM-13, EXIG-MCP-09	draft-ietf-oauth-v2-1-16 (3 septembre 2026), « expirant le 7 mars 2027 »; au tableau 59, échéance externe du jalon J1 [176], [327]	draft-ietf-oauth-v2-1-17 publié le 31 octobre 2026, « Expires: 4 May 2027 », toujours document de groupe de travail; les trois octrois sont inchangés; métadonnée « Obsoletes: 6749, 6750 (if approved) » ajoutée [481]	Version à réépingler au catalogue (EXIG-INT-07, EXIG-INT-09). L'échéance du 7 mars 2027 tombe : un brouillon actif n'a pas d'échéance, son expiration se déplaçant à chaque version, et la ligne pourrait sortir des échéances externes du tableau

Dépendance	Sections et exigences	Texte du cadre (état des sources au 27 octobre 2026)	Au 1er novembre 2026	Conséquence pour le comité
				59. Le tableau 35 et l'EXIG-IAM-13, adossés à la RFC 9700, restent exacts
ID-JAG	6.3 (tableau 15), 9.3 (tableau 36); EXIG-INT-06	Brouillon –04 (21 mai 2026), statut Évaluer [177]	–05 le 30 octobre et –06 le 31 octobre 2026, document de groupe de travail [482]	Version des pilotes à réépingler; statut Évaluer inchangé
Autres brouillons OAuth et HTTP	6.5, 7.6, 9.3 (tableau 36); EXIG-MCP-12, EXIG-ORC-21	Transaction Tokens –11 en attente du rapport; chaînage –17 en file du RFC Editor; authentification SPIFFE –02; CIMD –02; Idempotency-Key –08; « On-Behalf-Of » –02 expiré [78], [179], [216], [333], [334], [335]	Tous inchangés; aucun numéro de RFC pour le chaînage; l'authentification SPIFFE –02 expire le 17 décembre 2026 [483]	Signal « publication d'une RFC » non survenu. Sans nouvelle version, l'entrée SPIFFE devient au 17 décembre un brouillon expiré, à noter comme tel (EXIG-INT-09)
WIMSE	9.2, 9.3 (tableau 36); EXIG-IAM-03 à EXIG-IAM-07, EXIG-IAM-12, EXIG-IAM-14, EXIG-MCP-21, EXIG-AUT-13, EXIG-AUT-14, EXIG-SEC-13	AIMS –00 (15 septembre 2026); Workload Identity Practices –07 (22 septembre 2026), soumis à l'IESG le 30 juin [93], [323]	AIMS inchangé. Workload Identity Practices –08 le 30 octobre; dernier appel de l'IETF ouvert le même jour, « to Informational RFC », jusqu'au 13 novembre 2026 [484]. Brouillons individuels de délégation : aucun adopté. Hors WIMSE, le brouillon individuel draft-chen-oauth-agent-revocation (OAuth) a été relancé en –01 le 30 octobre [483]	Une RFC informationnelle est proche; elle resterait une référence de conception, non une norme d'exigences. La cote Surveiller des brouillons de délégation (tableau 36) tient. Aucune exigence touchée
Conventions GenAI d'OpenTelemetry	6.3 (tableau 15), 6.9, 10.1 (tableau 41); EXIG-OBS-01, EXIG-OBS-05, EXIG-INT-23	v1.41.0 épinglée « jusqu'à l'homologation d'une version étiquetée du dépôt dédié »; branche principale : cache_write remplace cache_creation [119], [180], [181]	Dernière version centrale v1.44.0; dépôt dédié sans étiquette; registre du dépôt dédié (docs/registry/attributes/gen-ai.md, commit 244465e du 31 octobre 2026) : 85 attributs gen_ai.*, tous Development; cache_write sur la branche principale [485]	Signal non survenu : épinglage à v1.41.0 maintenu; la couche de correspondance absorbe le renommage
Standards publiés du catalogue	6.3 (tableau 15), 6.7; EXIG-INT-07, EXIG-EVT-02, EXIG-EVT-03	OpenAPI 3.2.1 (10 septembre 2026); Arazzo 1.1.0; AsyncAPI 3.1.0; CloudEvents 1.0.2 [170], [172], [173], [174]	Mêmes dernières versions [170], [486]	Inchangé
Référentiels OWASP	6.5 (tableau 18), 9.5 (tableaux 37 et 38); EXIG-SEC-01, EXIG-SEC-02	Top 10 agentique 2026; MCP Top 10 en bêta; AST10 au stade « Incubator », version 1.0-2026 [28], [222], [350]	MCP Top 10 : « Phase 3 – Beta Release and Pilot Testing - We are here right now »; AST10 : « Incubator Project », « 1.0-2026 » [222], [350]	Inchangé
MITRE ATLAS	9.5 (tableau 37), 9.9; EXIG-SEC-02, EXIG-SEC-23	Version 2026.09 du 14 septembre 2026 : 16 tactiques, 120 techniques, 88 sous-techniques, 40 mesures, 73 études de cas [352]	Version 2026.10 du 28 octobre 2026 : 16 tactiques, 129 techniques, 92 sous-techniques, 44 mesures, 77 études de cas; les trois techniques citées en 9.9 ne sont pas touchées [487]	L'EXIG-SEC-02 exige la mise à jour de la matrice « à chaque nouvelle version » d'ATLAS : la version 2026.10 la déclencherait dès l'approbation du cadre. Au rythme

Dépendance	Sections et exigences	Texte du cadre (état des sources au 27 octobre 2026)	Au 1er novembre 2026	Conséquence pour le comité
				mensuel des versions récentes, le comité pourrait préférer une revue à la révision trimestrielle, sauf technique nouvelle propre aux agents
NIST	9.3, 11.7, 12.5, 15.1 (tableau 59); EXIG-GOV-20, EXIG-CON-17	AI RMF 1.0 en révision, sans calendrier, examen formel au plus tard en 2028; initiative du CAISI du 17 février 2026; COSIS renommé le 20 octobre [99], [411], [448], [455]	« The AI RMF 1.0 is being revised as part of the White House AI Action Plan », sans nouvelle version [448]; page du CAISI « Updated August 14, 2026 » [488]; page du COSIS « Updated October 20, 2026 » [455]	Inchangé; la ligne « examen formel au plus tard en 2028 » du tableau 59 tient
Règlement européen sur l'IA	12.4 (tableau 49), 12.7, 15.1 (tableaux 58 et 59, J2a); EXIG-CON-13 à EXIG-CON-16, EXIG-CON-20	Application générale et article 50 depuis le 2 août 2026; nouvelles interdictions le 2 décembre 2026; annexe III le 2 décembre 2027; annexe I le 2 août 2028 [57], [58], [443]	Mêmes dates; page de la Commission mise à jour le 19 octobre 2026 [57], [443]. Rappel : au 2 décembre 2026, la Commission affiche une « Article 50(2) transition » pour certains fournisseurs de systèmes générateurs de contenu mis sur le marché avant le 2 août 2026 [57]. Première norme harmonisée publiée : EN 18286:2026 (système de management de la qualité, article 17), décision d'exécution (UE) 2026/2274 du 12 octobre 2026, JO L du 14 octobre 2026 [489], [490]	J2a et les échéances des EXIG-CON-13 et EXIG-CON-16 tiennent. La transition de l'article 50(2), que la section 12.7 énonce déjà, n'est pas reprise à la section 12.4 (H.4). EN 18286 est une norme harmonisée publiée à l'appui de l'article 17; la présomption de conformité qu'elle confère à l'organisation requalifiée fournisseur (EXIG-CON-15, J2a) reste à vérifier sur l'article 40 consolidé et sur la décision d'exécution (UE) 2026/2274, avec les affaires juridiques. Publiée le 14 octobre, avant l'état des sources, elle relève des omissions à cette date (H.4); le cadre ne la cite pas
E-23 du BSIF	12.3 (tableau 48), 15.1 (tableaux 58 et 59); EXIG-CON-12	Publiée le 11 septembre 2025; en vigueur le 1er mai 2027 [8]	« Date September 11, 2025 »; « Effective date May 1, 2027 »; « Date modified: 2025-09-11 » [8]	Inchangé : l'échéance du 1er mai 2027 tient
Ligne directrice IA de l'AMF	12.3	« version d'avril 2026, en vigueur le 1er mai 2027 », non reprise par le cadre	Non vérifié : la page de l'AMF renvoie HTTP 403 à l'outillage. Dernier état lu : 31 octobre 2026, « Prise d'effet : 1er mai 2027 » [491]	Voir H.3

Dépendance	Sections et exigences	Texte du cadre (état des sources au 27 octobre 2026)	Au 1er novembre 2026	Conséquence pour le comité
Projet de loi C-36	12.3 (tableau 48), 12.7; EXIG-CON-21	« Déposé le 15 juin 2026; deuxième lecture; non en vigueur » [430]	Statut « À la deuxième lecture à la Chambre des communes »; dernière étape franchie : première lecture, 15 juin 2026; aucun événement ultérieur [492]	Inchangé; l'EXIG-CON-21 anticipe toujours un projet
Projet de loi C-22	12.3 (veille)	« à l'étude au Sénat en octobre 2026 » [440]	« À l'examen en comité au Sénat »; deuxième lecture au Sénat le 22 octobre 2026 [492]	Inchangé pour le cadre
FOCUS	10.6, 13.2; EXIG-FIN-10, EXIG-APP-05	FOCUS 1.4 en vigueur; ratification de la 1.5 prévue le 3 décembre 2026 [465]	« Current published version FOCUS 1.4 »; « 1.5 ratification 3 Dec 2026 » [465]	Inchangé; à revoir après le 3 décembre

Le brouillon d'OAuth 2.1 change de numéro, pas de sens. La version –17, publiée le 31 octobre 2026 [481], porte surtout des précisions de rédaction et la mention des RFC 6749 et 6750 qu'elle rendrait obsolètes; elle définit toujours trois octrois — code d'autorisation, identifiants du client, jeton de rafraîchissement. Le profil du tableau 35 et l'EXIG-IAM-13, qui s'adossent à la RFC 9700, n'en sont pas touchés. Ce qui tombe, c'est l'échéance que le tableau 59 plaçait au jalon J1 : un brouillon actif reporte son expiration à chaque version, de sorte que la date d'expiration ne devient une échéance que si le groupe cesse de le réviser. Le comité pourra retirer cette ligne des échéances externes plutôt que d'y substituer le 4 mai 2027, comme le propose le tableau 70.

MCP fixe son calendrier. La SEP-3398, acceptée le 14 octobre et versée au tronc le 27 octobre [474], arrête deux publications par an, en principe le dernier mardi de mars et de septembre, et reporte au 30 mars 2027 la révision attendue en décembre 2026. Trois conséquences pour le cadre. L'identifiant d'une révision MCP date son dernier changement incompatible (section 6.5) : celle de mars 2027 appellera donc, à sa publication et si elle comporte un changement incompatible ou une dépréciation, la révision extraordinaire de l'EXIG-GOV-18; d'ici là, sa date est à inscrire au catalogue, sans que le signal soit survenu. Le transport HTTP+SSE, dont la SEP-2596 est finale depuis le 3 juin 2026 [475], pourra y être retiré. Roots, Sampling, la journalisation protocolaire et le DCR ne pourront l'être, si le calendrier est tenu, qu'à la publication de septembre 2027, sauf retrait accéléré pour un risque de sécurité actif (au moins 90 jours, SEP-2596) : l'échéance du 28 juillet 2027 de l'EXIG-MCP-22 précède de deux mois environ la première révision qui pourrait les retirer.

Les extensions ont un stade. Le cadre traite les extensions officielles comme un ensemble désactivé par défaut et activé au catalogue (EXIG-MCP-04). La page officielle leur attribue désormais un stade [169] : Apps et les deux extensions d'autorisation sont Stable, Tasks est Beta et destinée au protocole de base, Skills et Server Cards sont Beta. Le critère « statut final ou stable » de l'EXIG-GOV-19 pourrait y trouver une prise directe, extension par extension plutôt que pour MCP en bloc; c'est une lecture à soumettre au comité, l'EXIG-GOV-19 régissant l'admission d'un standard et son texte ne nommant pas le stade Beta.

Ce qui ne bouge pas. Aucun des trois signaux nommés à la section 6.9 n'est survenu : la prochaine révision de MCP n'a qu'une date annoncée, l'AAIF n'a pas statué sur AGNTCY [37], [130], et le dépôt des conventions GenAI d'OpenTelemetry n'a toujours publié aucune version [485]. Le chaînage d'identité n'est pas encore une RFC [483]. Les échéances réglementaires — E-23 au 1er mai 2027, annexe III du RIA au 2 décembre 2027, annexe I au 2 août 2028 — tiennent, de même que le jalon J2a du 1er novembre 2027, choix du cadre qui les précède [8], [57].

H.3 Reports de la Note AMF IA en attente

La Note AMF IA (CRE-IA-2026-01-QC, version 1.0 du 31 octobre 2026, version finale pour publication, non encore soumise au comité) propose en son annexe D neuf reports au cadre [491]. Aucun n'est appliqué à la version 1.1. Le tableau 71 les présente un à un, comme propositions en attente de décision du comité. La note pose elle-même un préalable : une relecture par la conformité et l'audit interne, attente par attente, avant l'adoption de ses exigences EXIG-AMF (§ 13.2, point 1).

Tableau 71 — Reports de la Note AMF IA au cadre (annexe D de la note), en attente de décision du comité

No	Endroit du cadre	Report proposé par la note	Ce qu'il toucherait
1	Section 12.3	Remplacer la mention selon laquelle le cadre ne reprend pas la ligne directrice par un renvoi au profil CRE-IA-2026-01-QC	Alinéa « Trois conséquences pratiques » de la section 12.3, où figure la mention de l'AMF; texte informatif, aucune exigence. Cette mention n'a pas d'appel de référence
2	EXIG-CON-11	Ajouter les lignes directrices de l'AMF à la liste des régimes	Énoncé de l'EXIG-CON-11; par ricochet, le champ de qualification réglementaire de la fiche d'agent (tableau 63), que l'annexe C de la note marque « Précisé »
3	EXIG-CON-12	Retitrer « Arrimage à la gestion du risque de modèle » : E-23 pour les institutions fédérales, EXIG-AMF-05 pour les institutions québécoises	Titre de l'EXIG-CON-12 et sa ligne à l'annexe D; l'énoncé, limité aux institutions financières fédérales, n'est pas modifié par la proposition
4	Tableau 59	Ajouter la ligne directrice IA de l'AMF au 1er mai 2027 dans les échéances externes de la phase Plateforme	Ligne « Mi-mars – fin sept. 2027 » du tableau 59. Par cohérence, et sans que la note les cite : l'encadré « Trois échéances externes » et la règle de progression qui énumère les travaux datés par une échéance externe (section 15.1)
5	Tableau 60	Greffer les travaux du § 12.1 de la note	Plan des 90 premiers jours (section 15.2) : travaux des semaines 1 à 13, « sans en retirer aucun »; la période de J1 au 1er mai 2027, que le tableau 60 ne couvre pas, relève des tableaux 58 et 59 (phase Plateforme)
6	Annexe B, tableau 63	Ajouter les champs de l'annexe C de la note	Seize lignes de l'annexe C : onze champs nouveaux, trois précisés, deux renvois; colonne de l'étape d'exigibilité à fixer pour chacun
7	Annexes D et G	Ajouter les 12 exigences de l'annexe B de la note et les références de son annexe F	Annexe D (287 lignes dans la version 1.1, 299 après ajout) et annexe G. Aussi, sans que la note les cite : le tableau 4 (préfixe EXIG-AMF), la section 1.4, selon laquelle seuls les blocs des chapitres 5 à 13 créent une obligation, et la section 1.5, selon laquelle l'annexe D récapitule les exigences « dans l'ordre du document ». La numérotation des références à partir de [474] serait à partager avec celles de la présente annexe
8	EXIG-CON-01; tableau 46	Ajouter aux critères de classe la cote de risque de chaque modèle, le niveau d'autonomie demandé et le risque de non-conformité (EXIG-AMF-07)	Colonne des critères du tableau 46 et EXIG-CON-01, qui y renvoie. Le critère « niveau d'autonomie demandé » est inapplicable en l'état : la classe dépendrait du niveau qu'elle plafonne (EXIG-CON-02), et le résultat, de l'ordre d'évaluation. Il faudrait d'abord rompre la circularité, par exemple en évaluant la classe une seule fois, avant tout plafonnement, sur l'autonomie maximale envisagée, puis en refusant tout niveau demandé au-delà du plafond
9	Section 1.6	Préciser si la règle de la plus stricte vise aussi deux régimes réglementaires (agent partagé entre des entités des deux ordres)	Premier alinéa de la section 1.6, règle de préséance, qui relèverait aussi de la section 4.3 ou d'une EXIG-CON. Le cadre applique déjà la règle la plus exigeante entre régimes de notification (EXIG-CON-25)

Deux reports dépendent d'un fait que la présente annexe n'a pas pu rouvrir : la date de prise d'effet de la ligne directrice (reports 4 et 5), lue le 31 octobre 2026 dans un navigateur par la note, mais inaccessible à l'outillage le 1er novembre (HTTP 403). Les reports 2, 3, 7, 8 et 9 toucheraient la structure normative du cadre (énoncés et titres d'exigences, préfixe et registre, critères de classe, règle de préséance); les reports 1,

4, 5 et 6 en complètent le contenu. EXIG-AMF-05 et EXIG-AMF-07, citées au tableau 71, sont des identifiants de la Note AMF IA, et non du cadre.

H.4 Errata et incohérences prouvés

Le tableau 72 ne retient que ce qu'une source primaire établit, avec le statut de chaque ligne : erratum prouvé, écart de citation prouvé ou écart entre livrables. Un énoncé exact à sa date, mais dépassé depuis, relève du tableau 70, non d'un erratum.

Tableau 72 — Errata, écarts de citation et écarts entre livrables de la version 1.1, établis le 1er novembre 2026

No	Où	Énoncé	Constat et preuve	Traitement proposé
1	Sections 6.6, « Rôle, historique et gouvernance », et 13.1	« un comité directeur technique de huit entreprises (AWS, Cisco, Google, IBM Research, Microsoft, Salesforce, SAP et ServiceNow; composition annoncée le 12 mars 2026) le pilote »	Erratum. Le fichier de gouvernance du projet compte « nine seats »; Bloomberg y a été ajouté le 20 octobre 2026, avant l'état des sources du cadre (27 octobre) [479]	Erratum prouvé. Lire « un comité directeur technique de neuf sièges : les huit entreprises de la composition annoncée le 12 mars 2026, et Bloomberg depuis le 20 octobre 2026 »; l'argument de gouvernance neutre n'en est pas touché
2	Sommaire, tableau 5, sections 2.2, 6.6, 6.9 et 13.1, tableau 68 (no 7); [5], [35]	A2A relève de l'AAIF, au stade « Growth »; billet du projet du 27 août 2026	Incohérence avec la Veille, dont l'annexe du 29 octobre tient ce passage pour « rapporté, non versé », absent du site de la fondation [493]. Au 1er novembre, le billet du projet (27 août) et celui de la fondation (17 août) se lisent [5], [35], et la fondation compte A2A parmi ses projets [35], [130]. Ce que le site affichait le 29 octobre n'est pas vérifiable ici	Écart entre livrables, non tranché ici : l'énoncé du cadre est confirmé, et l'écart est à lever dans la Veille. Écart de citation prouvé : la mention « approbation du conseil d'administration le 4 août » (tableau 5) ne figure dans aucun des deux billets qui l'appuient; retirer la date ou la rattacher à une source qui la contient
3	Sections 6.5 et 6.9 (signaux de l'EXIG-INT-23)	La prochaine révision de MCP n'a pas de date, la feuille de route du 22 août 2026 ne la donnant pas [195]	Incohérence entre livrables : l'annexe du 29 octobre de la Veille (tableau 25) date la prochaine révision de fin mars 2027 [493]. La SEP-3398, acceptée le 14 octobre, n'a été versée au tronc que le 27 octobre, jour de l'état des sources du cadre [474]. L'énoncé sur la feuille de route reste exact : ce n'est pas un erratum	Écart entre livrables, sans erratum. Inscrire au catalogue la date annoncée de la prochaine révision (30 mars 2027, sous réserve du calendrier de transition [474]), sans tenir le signal pour survenu; à la publication, la révision extraordinaire de l'EXIG-GOV-18 s'applique si elle comporte un changement incompatible ou une dépréciation (H.2)

Des omissions à la date de l'état des sources ne sont pas des errata : l'énoncé du corps reste exact, mais incomplet au 27 octobre. Le retrait de HTTP+SSE « trois mois après que la SEP-2596 atteint l'état final » (tableau 17, EXIG-MCP-22) reproduit fidèlement le registre de la spécification, mais l'échéance était déjà calculable au 27 octobre : HTTP+SSE est admissible au retrait depuis le début de septembre 2026, la SEP-2596 étant finale depuis le 3 juin 2026 (H.2). La trousse a2a-tck, que l'EXIG-INT-19 rend bloquante, était étiquetée alpha dès le 20 octobre, et la norme EN 18286 a été publiée au Journal officiel le 14 octobre (tableau 70). Les autres faits du tableau 70 antérieurs au 27 octobre (SEP-3398 acceptée le 14 octobre, déclaration du BSIF du 15 octobre, C-22 en deuxième lecture au Sénat le 22 octobre) précisent le corps sans le contredire. Trois précisions s'y ajoutent. « Deuxième lecture » (tableau 48) se lit « à l'étape de la deuxième lecture » : la dernière étape franchie par C-36 reste la première lecture du 15 juin 2026 [492], ce que dit aussi la Veille [493]. Enfin, la section 12.4 omet la transition de l'article 50(2) au 2 décembre 2026, que la section 12.7 énonce

déjà [57], [457] : un renvoi est à y ajouter. La date est celle qu'affiche la Commission; le texte du règlement (UE) 2026/1744 n'a pas été relu (H.5).

H.5 Ce que l'actualisation n'a pas rouvert

Non vérifiés le 1er novembre 2026. La page de la ligne directrice IA de l'AMF (HTTP 403); le texte du règlement (UE) 2026/1744 sur EUR-Lex (réponse sans contenu); la fiche de la Loi concernant la cybersécurité (ancien C-8) sur LEGISinfo (réponse illisible). La date d'approbation du 4 août citée au tableau 5 n'est pas étayée par les sources citées (H.4, no 2).

Non rouverts. La Loi 25 et les pages de la Commission d'accès à l'information (section 12.2); les normes ISO/IEC 42001, 42005, 42006, 23894 et 22989; le document du NCCoE; les spécifications W3C Trace Context et Baggage, SPIFFE et SPIRE, les extensions documentées de CloudEvents; les composants d'AGNTCY et les protocoles de commerce agentique, au-delà des statuts du catalogue (la Veille en suit les versions); les plateformes, cadriciels, passerelles et bacs à sable cités en exemples (tableaux 12, 27 et 40); Kafka; les prix et la documentation des modèles (EXIG-FIN-02); les chiffres d'analystes. Il en va de même de toute source du corps absente du tableau 70, par exemple l'OWASP NHI Top 10 2025, NIST AI 100-2 E2025, ISO/IEC 17021-1 et les RFC 8693 et 8785. Leur état au 1er novembre 2026 est inconnu, non « inchangé ».

Hors du cadre. Trois sources datées ne portent aucune exigence du cadre actuel. NIST IR 8547, finale depuis le 27 octobre 2026 [494], n'est pas citée, et aucune exigence ne fixe d'algorithme de signature : les exemples de l'annexe C, informatifs, signent en ES256. Aucune norme harmonisée du RIA n'y est mentionnée, alors qu'EN 18286 a été publiée avant l'état des sources du cadre; elle pourrait porter une exigence au titre de l'EXIG-CON-15 (tableau 70). Enfin, la déclaration du BSIF du 15 octobre 2026 sur les pratiques saines du Conseil de stabilité financière (« OSFI endorses the Sound Practices »), qui les présente comme complément de ses lignes directrices dont E-23, n'est pas relevée au tableau 48 [495]. L'annexe signale ces sources sans en tirer d'exigence; pour la première, la vérification longue d'objets signés — enregistrements d'audit (EXIG-OBS-12, EXIG-OBS-13), jetons d'approbation (section 8.5, annexe C.6) et cartes d'agent signées (EXIG-A2A-03, EXIG-A2A-10) — est le point où le comité pourrait vouloir inscrire l'agilité cryptographique et le rescellement.

Absences non datées. Le cadre ne traite pas non plus quatre objets de la réglementation et de l'infrastructure financières canadiennes que traite le Compendium : l'avis 11-348 des Autorités canadiennes en valeurs mobilières (chapitre 28), le cadre des services bancaires axés sur les consommateurs (chapitre 32), ISO 20022 et le Real-Time Rail de Paiements Canada (chapitre 33). L'annexe ne relève aucun fait daté à leur sujet. Le tableau 48 ne les mentionne pas : il reste incomplet pour une institution que visent ces instruments.

H.6 Correctifs de cohérence interne intégrés

Contrairement aux propositions des sections H.2 et H.3, qui restent soumises à la décision du comité, les correctifs de cohérence interne, de précision normative et de vérification bibliographique issus de la revue contradictoire du corpus ont été intégrés directement à leur place dans le corps, les figures et les annexes A à G de la présente édition. L'architecture normative de la version 1.1 est intégralement préservée : le cadre compte toujours 287 exigences normatives (237 DOIT, 34 NE DOIT PAS et 16 DEVRAIT), sans ajout ni retrait d'identifiant.

- **Alignement du corps, du registre (annexe D) et de la grille d'homologation (annexe A).** Les 287 exigences du corps, le registre récapitulatif de l'annexe D et la grille d'homologation de l'annexe A sont synchronisés point par point : les 80 exigences qui manquaient à la grille de l'annexe A y sont rattachées, le coupe-circuit y figure explicitement, et le marquage « non dérogeable » concorde strictement avec la liste fermée de l'EXIG-GOV-17 et les obligations légales.

- **Harmonisation des contrats, jetons et empreintes (annexes B et C).** Le gabarit de fiche d'agent (annexe B, tableau 63 et extrait JSON) inclut la borne de contexte en jetons (EXIG-MEM-01). L'exemple C.5 présente les deux jetons du second saut de délégation (jeton présenté par le sous-agent à la passerelle et jeton rééchangé par la passerelle pour le serveur MCP cible selon la RFC 8693). L'exemple C.6 et l'enregistrement d'audit C.8 illustrent la double approbation humaine hors bande par deux approbateurs distincts liés au même condensat `action_sha256` calculé sur la forme canonique RFC 8785 (JCS), avec recalcul exact des empreintes SHA-256.
- **Schémas vectoriels et références (figures 1 à 28, annexes F et G).** Les libellés et tracés des figures vectorielles ont été harmonisés avec le texte normatif (notamment les figures 9, 13, 14, 16, 17, 22, 23, 25, 26 et 28), le signet de la section 10.2 a été rétabli, toutes les figures et tous les tableaux sont appelés dans le texte, et les 473 entrées de l'annexe G (ainsi que les références [474] à [495] de la présente annexe) portent une date explicite ou la mention « s. d. », un intitulé distinct et des adresses vérifiées.

Références de l'actualisation

- [474] Model Context Protocol. « SEP-3398: Release Cycle Updates », statut Accepted, acceptée le 14 octobre 2026; versée au tronc par la fusion de la demande de tirage no 3398 le 27 octobre 2026. Consulté le 1er novembre 2026. https://github.com/modelcontextprotocol/modelcontextprotocol/blob/main/seps/3398-release-cycle-updates.md
- [475] Model Context Protocol. « SEP-2596: Specification Feature Lifecycle and Deprecation Policy », statut Final; passage à Final par la demande de tirage no 2856 (« Mark SEPs as final »), fusionnée le 3 juin 2026. Consulté le 1er novembre 2026. https://github.com/modelcontextprotocol/modelcontextprotocol/blob/main/seps/2596-spec-feature-lifecycle-and-deprecation.md
- [476] Model Context Protocol. « SEP-3392: Extension Lifecycle », statut Final; fusion de la demande de tirage no 3392 le 29 octobre 2026. Consulté le 1er novembre 2026. https://github.com/modelcontextprotocol/modelcontextprotocol/blob/main/seps/3392-extension-lifecycle.md
- [477] Model Context Protocol. Registre officiel, étiquette v1.8.7 du 30 octobre 2026. Consulté le 1er novembre 2026. https://github.com/modelcontextprotocol/registry/releases/tag/v1.8.7
- [478] A2A Project. Dépôt a2aproject/A2A, étiquettes : v1.0.1 (28 mai 2026), dernière publication; v1.1.0-rc (29 octobre 2026). Consulté le 1er novembre 2026. https://github.com/a2aproject/A2A/tags
- [479] A2A Project. GOVERNANCE.md, « The Committee has nine seats »; commit 98279d6 du 20 octobre 2026, « chore: Add Bloomberg as a member of the Technical Steering Committee (#2308) ». Consulté le 1er novembre 2026. https://github.com/a2aproject/A2A/blob/main/GOVERNANCE.md
- [480] A2A Project. Dépôt a2aproject/a2a-tck, étiquettes 1.0.0.alpha3 et 0.3.0.beta6 (20 octobre 2026); dernier commit du 22 octobre 2026. Consulté le 1er novembre 2026. https://github.com/a2aproject/a2a-tck/tags
- [481] Hardt, D., Parecki, A. et Lodderstedt, T. « The OAuth 2.1 Authorization Framework », draft-ietf-oauth-v2-1-17 (Internet-Draft), 31 octobre 2026, expire le 4 mai 2027. IETF. Consulté le 1er novembre 2026. https://datatracker.ietf.org/doc/draft-ietf-oauth-v2-1/
- [482] Parecki, A., McGuinness, K. et Campbell, B. « Identity Assertion JWT Authorization Grant », draft-ietf-oauth-identity-assertion-authz-grant-05 (30 octobre 2026) et –06 (31 octobre 2026). IETF. Consulté le 1er novembre 2026. https://datatracker.ietf.org/doc/draft-ietf-oauth-identity-assertion-authz-grant/
- [483] IETF. Registre des documents, états au 1er novembre 2026 : draft-ietf-oauth-transaction-tokens-11 (WG Consensus: Waiting for Write-Up), draft-ietf-oauth-identity-chaining-17 (RFC Ed Queue), draft-ietf-oauth-spiffe-client-auth-02 (expire le 17 décembre 2026), draft-ietf-oauth-client-id-metadata-document-02,

draft-ietf-httpapi-idempotency-key-header-08, draft-ietf-wimse-aims-00, draft-oauth-ai-agents-on-behalf-of-user-02 (Expired), draft-mp-agntcy-ads-02, draft-mpsb-agntcy-slim-02; draft-chen-oauth-agent-revocation-01 (30 octobre 2026, actif). Consulté le 1er novembre 2026 par l'interface https://datatracker.ietf.org/api/v1/doc/document/. Fiche de chaque document, dans l'ordre : https://datatracker.ietf.org/doc/draft-ietf-oauth-transaction-tokens/; https://datatracker.ietf.org/doc/draft-ietf-oauth-identity-chaining/; https://datatracker.ietf.org/doc/draft-ietf-oauth-spiffe-client-auth/; https://datatracker.ietf.org/doc/draft-ietf-oauth-client-id-metadata-document/; https://datatracker.ietf.org/doc/draft-ietf-httpapi-idempotency-key-header/; https://datatracker.ietf.org/doc/draft-ietf-wimse-aims/; https://datatracker.ietf.org/doc/draft-oauth-ai-agents-on-behalf-of-user/; https://datatracker.ietf.org/doc/draft-mp-agntcy-ads/; https://datatracker.ietf.org/doc/draft-mpsb-agntcy-slim/; https://datatracker.ietf.org/doc/draft-chen-oauth-agent-revocation/ (ces fiches affichent l'état courant, non celui du 1er novembre : au 4 novembre 2026, draft-mp-agntcy-ads et draft-mpsb-agntcy-slim sont passés en –03 le 2 novembre).

- [484] IETF, groupe WIMSE. « Workload Identity Practices », draft-ietf-wimse-workload-identity-practices-08, 30 octobre 2026; IESG : In Last Call, « to Informational RFC », fin le 13 novembre 2026. IETF. Consulté le 1er novembre 2026. https://datatracker.ietf.org/doc/draft-ietf-wimse-workload-identity-practices/
- [485] OpenTelemetry. Dépôts semantic-conventions (dernière étiquette v1.44.0) et semantic-conventions-genai (aucune étiquette; registre docs/registry/attributes/gen-ai.md au commit 244465e du 31 octobre 2026 : 85 attributs gen_ai.*, tous Development). Consulté le 1er novembre 2026. https://github.com/open-telemetry/semantic-conventions-genai
- [486] OAI/Arazzo-Specification (dernière étiquette 1.1.0), asyncapi/spec (v3.1.0), cloudevents/spec (v1.0.2), étiquettes des dépôts. Consulté le 1er novembre 2026. https://github.com/OAI/Arazzo-Specification/tags; https://github.com/asyncapi/spec/releases/tag/v3.1.0; https://github.com/cloudevents/spec/releases/tag/v1.0.2
- [487] MITRE. mitre-atlas/atlas-data, CHANGELOG, version 2026.10 du 28 octobre 2026. Consulté le 1er novembre 2026. https://github.com/mitre-atlas/atlas-data/blob/main/CHANGELOG.md
- [488] NIST, CAISI. « AI Agent Standards Initiative », page créée le 17 février 2026, mise à jour le 14 août 2026. Consulté le 1er novembre 2026. https://www.nist.gov/caisi/ai-agent-standards-initiative
- [489] Commission européenne. « First harmonised standard supporting the AI Act published in the Official Journal » (EN 18286:2026; décision d'exécution (UE) 2026/2274), 19 octobre 2026. Consulté le 1er novembre 2026. https://digital-strategy.ec.europa.eu/en/library/first-harmonised-standard-supporting-ai-act-published-official-journal
- [490] Commission européenne, DG GROW. « Artificial intelligence (AI) », normes harmonisées : « Commission Implementing Decision (EU) 2026/2274 of 12 October 2026 … OJ L, 2026/2274, 14.10.2026 ». Consulté le 1er novembre 2026. https://single-market-economy.ec.europa.eu/single-market/goods/european-standards/harmonised-standards/artificial-intelligence-ai_en
- [491] Bruneau, A.-G. Note AMF IA, CRE-IA-2026-01-QC, version 1.0, 31 octobre 2026 (annexe D, « Reports et errata au corpus »; annexe E, journal de vérification). Document du corpus.
- [492] Parlement du Canada, LEGISinfo. Projets de loi C-36 et C-22 (45e législature, 1re session), données JSON, état au 1er novembre 2026. Consulté le 1er novembre 2026. C-36 : https://www.parl.ca/legisinfo/en/bill/45-1/c-36/json; C-22 : https://www.parl.ca/legisinfo/en/bill/45-1/c-22/json
- [493] Bruneau, A.-G. Veille technologique, annexe « Reprise du 29 octobre 2026 » (Veille, tableau 25; Veille, réf. [343] et [350]). Document du corpus.

- [494] NIST. IR 8547, « Transition to Post-Quantum Cryptography Standards », version finale; historique « 10/27/26: IR 8547 (Final) ». Consulté le 1er novembre 2026. https://csrc.nist.gov/pubs/ir/8547/final
- [495] BSIF. « OSFI statement on the Financial Stability Board's publication of Sound Practices for Responsible Adoption of Artificial Intelligence », 15 octobre 2026. Consulté le 1er novembre 2026. https://www.osfi-bsif.gc.ca/en/news/osfi-statement-financial-stability-boards-publication-sound-practices-responsible-adoption